



Saudi Privacy and Cybersecurity Regulatory Frameworks and Controls



Saudi Privacy and Cybersecurity Regulatory Frameworks and Controls

Course Introduction

This course provides a comprehensive exploration of the Kingdom of Saudi Arabia's national cybersecurity regulatory frameworks and controls. It is designed for professionals and decision-makers aiming to gain in-depth knowledge and practical understanding of mandatory cybersecurity requirements, frameworks, and best practices applicable within Saudi Arabia. Participants will engage deeply with the Essential Cybersecurity Controls (ECC) issued by the National Cybersecurity Authority (NCA), alongside essential sector-specific regulations, standards, and guidelines, ensuring they can effectively interpret, implement, and maintain compliance across diverse organizational contexts.

Cybersecurity has become critically important as Saudi Arabia continues its digital transformation journey across sectors such as finance, healthcare, telecommunications, energy, government, and beyond. With increasing reliance on digital technologies, the cybersecurity threat landscape has expanded, bringing heightened risks of cyber-attacks, data breaches, and potential disruptions to critical national infrastructure. In response, Saudi Arabia has developed robust regulatory frameworks to strengthen national cybersecurity capabilities, safeguard sensitive data, protect vital systems, and foster secure digital transactions.

Throughout this course, learners will extensively examine:

1. **National Cybersecurity Authority (NCA) - Essential Cybersecurity Controls (ECC):** The ECC provides a set of mandatory cybersecurity controls that organizations in Saudi Arabia must implement to protect their information systems. These controls span various areas, including governance, defense, and resilience, and are essential for ensuring that organizations can protect their assets and respond effectively to cyber threats.
2. **Saudi Arabian Monetary Authority (SAMA) Cyber Security Framework (CSF):** SAMA's Cybersecurity Framework is designed to enhance the security of financial institutions by establishing stringent cybersecurity practices. The framework focuses on areas such as identity and access management, network security, incident response, and vulnerability management. Implementing robust Cybersecurity Defense and Operations helps financial institutions comply with SAMA's framework and protect their customers' data and assets.
3. **Capital Market Authority (CMA) Cybersecurity Guidelines:** The CMA provides cybersecurity guidelines specifically for organizations operating within the capital markets sector. These guidelines emphasize the importance of secure communication channels, data protection, and stringent access control mechanisms. Cybersecurity Defense and Operations ensure that these guidelines are implemented effectively to protect the integrity of capital market operations.
4. **Critical Systems Cybersecurity Controls (CSCC):** The CSCC framework focuses on protecting systems that are deemed critical to national security and economic stability. These controls are

particularly important for sectors such as energy, telecommunications, and transportation. Cybersecurity Defense and Operations are essential for implementing these controls, ensuring that critical systems are resilient and protected against cyber threats.

5. **Telework Cybersecurity Controls (TCC):** The rise in remote work has introduced new cybersecurity challenges. The TCC outlines specific measures to secure telework environments, including remote access controls, secure communication methods, and endpoint protection. Cybersecurity Defense and Operations facilitate the implementation of these controls, ensuring that remote work does not compromise organizational security.
6. **Data Cybersecurity Controls (DCC):** The DCC framework outlines measures to protect sensitive data from unauthorized access and breaches. Key areas include data encryption, access control, and continuous monitoring. Cybersecurity Defense and Operations ensure compliance with DCC requirements, safeguarding sensitive information and ensuring data integrity.
7. **Organizations' Social Media Accounts Cybersecurity Controls (OSMACC):** The OSMACC provides guidelines for securing social media accounts, which are increasingly becoming targets for cyber-attacks. This includes access controls, continuous monitoring, and incident response strategies. By aligning with these guidelines, Cybersecurity Defense and Operations help protect an organization's online presence and prevent reputational damage.
8. **Cloud Computing Cybersecurity Controls (CCC):** As organizations increasingly adopt cloud services and rely on third-party vendors, the CCC outlines measures to secure cloud environments and manage third-party risks. Cybersecurity Defense and Operations focus on implementing secure cloud configurations, monitoring third-party access, and ensuring compliance with CCC requirements.
9. **Cybersecurity Regulatory Framework (CRF) - CST (Communications, Space & Technology Commission):** The CRF is specifically tailored for service providers in the Information and Communications Technology (ICT) sector. It mandates cybersecurity requirements to enhance the cybersecurity maturity of the ICT sector and protect critical national infrastructure. The CRF emphasizes a risk-based approach, compliance with national and international standards, and the implementation of best practices for cybersecurity. By aligning with the CRF, Cybersecurity Defense and Operations help service providers in the ICT sector manage cybersecurity risks effectively, ensuring the resilience of telecommunications networks and maintaining the confidentiality, integrity, and availability of their services.
10. **Operational Technology Cybersecurity Controls (OTCC):** The OTCC is specifically designed to protect Operational Technology (OT) and Industrial Control Systems (ICS), which are critical to the operation of national infrastructure. These controls are aligned with international best practices and focus on protecting OT/ICS environments from cyber threats. Key components include network security management, incident response, physical security, and data protection within OT/ICS environments. Cybersecurity Defense and Operations are essential for implementing OTCC, ensuring the protection of critical industrial processes and maintaining the continuity and safety of national infrastructure(otcc_en).

Participants will learn not only the technical and procedural aspects of these regulations but also how to integrate them strategically within their organizations. The course emphasizes a holistic understanding, combining theoretical insights with practical case studies, real-world scenarios, and interactive discussions. By engaging comprehensively with these regulatory frameworks and cybersecurity standards, participants will be equipped to align organizational cybersecurity strategies with Saudi Arabia's regulatory landscape, ensuring effective risk mitigation, robust compliance, and enhanced cyber resilience across various technology and operational environments.

Course Structure

The course consists of six clearly structured modules, each targeting specific aspects of cybersecurity management:

1. **Cybersecurity Defense and Operations:** Building operational capacity to manage cybersecurity proactively and reactively within regulatory requirements.
2. **Cybersecurity Governance, Risk, and Compliance (GRC):** Integrating cybersecurity into organizational governance structures, risk management practices, and compliance mechanisms.
3. **Cybersecurity Resilience:** Strengthening business continuity strategies to withstand, recover, and adapt to cybersecurity incidents.
4. **Third-Party & Cloud Computing:** Managing cybersecurity risks associated with external vendors, outsourcing arrangements, and cloud service adoption.
5. **Personal Data Protection Law (PDPL):** Complying with Saudi Arabia's comprehensive framework governing the lawful and secure processing of personal data.
6. **Digital Trust:** Implementing secure digital transaction practices including digital signatures, electronic stamps, and timestamps, compliant with legal standards.

Through practical scenarios, regulatory mappings, real-world case studies, and actionable tools, this course enables participants to comprehensively understand and effectively apply Saudi cybersecurity regulatory frameworks, contributing significantly to organizational security, resilience, and compliance objectives.

Module 1: Cybersecurity Governance, Risk and Compliance

Overview

Cybersecurity Governance, Risk, and Compliance (GRC) provides organizations with a strategic framework for effectively managing cyber threats and regulatory demands. Governance establishes a foundational structure where clear roles, responsibilities, and accountability at all organizational levels ensure that cybersecurity objectives align seamlessly with overarching business goals.

Risk management within GRC entails systematically identifying, evaluating, and mitigating internal and external cyber threats, including data breaches and vulnerabilities. It emphasizes robust risk assessment methodologies such as vulnerability assessments and penetration testing, alongside establishing stringent cybersecurity controls—firewalls, encryption, access controls—to mitigate identified risks effectively.

Compliance under GRC mandates adherence to both domestic and international cybersecurity regulations, notably Saudi Arabia's NCA Essential Cybersecurity Controls (ECC), SAMA Cybersecurity Framework (CSF), CMA Cybersecurity Guidelines, Communications, Space & Technology Commission (CST) frameworks, as well as international standards such as GDPR and PCI DSS. The module further introduces structured auditing, continuous monitoring practices, and incident response mechanisms, underscoring the necessity for ongoing review, reporting, and compliance verification. Through comprehensive templates, compliance checklists, risk mitigation playbooks, and practical scenarios, participants are trained to maintain compliance, manage cybersecurity risks effectively, and enhance organizational cybersecurity maturity.

Introduction to Cybersecurity Governance, Risk and Compliance

Cybersecurity Governance, Risk, and Compliance (GRC) is a comprehensive approach that integrates strategic, operational, and compliance-related elements to safeguard an organization's information assets and digital infrastructure and comply with local/global regulations and manage cybersecurity risks in alignment with national priorities.

Governance provides the foundation for effective decision-making by setting clear roles, responsibilities, and accountability structures for cybersecurity initiatives. It ensures that leadership is actively involved in overseeing and directing the organization's cybersecurity strategy in alignment with business goals.

Risk management, on the other hand, is focused on identifying, evaluating, and mitigating both internal and external threats, including cyberattacks, data breaches, and system vulnerabilities, to reduce the likelihood of materializing risks. This involves developing risk assessment frameworks, performing vulnerability assessments, and implementing controls such as firewalls, encryption, and access management to reduce potential impacts.

Compliance is integral to ensuring that an organization meets the legal, regulatory, and contractual obligations governing data protection, privacy, and security. This includes adhering to standards and frameworks like the National Cybersecurity Authority (NCA)'s cybersecurity frameworks such as NCA Essential Cybersecurity Controls (ECC), NCA Critical Systems Cybersecurity Controls (CSCC), NCA DCC,

NCA Telework Cybersecurity Controls (TCC), NCA Data Cybersecurity Controls (DCC), NCA Organizations' Social Media Accounts Cybersecurity Controls (OSMACC), NCA Cloud Computing Cybersecurity Controls (CCC), NCA Operational Technology Cybersecurity Controls (OTCC), national sector specific cybersecurity and privacy frameworks such as Saudi Arabian Central Bank (SAMA) Cybersecurity Framework (CSF), Saudi Arabian Capital Market Authority (CMA) Cybersecurity Guidelines, Communications, Space & Technology Commission (CST) Cybersecurity Regulatory Framework (CRF), National Data Management Office (NDMO)'s Personal Data Protection Law (PDPL) and Digital Identity and Trust Services provided Digital Government Authority (DGA). Moreover, this includes adhering to international standards and frameworks applicable for some organizations such as Payment Card Industry Data Security Standard (PCI DSS), General Data Protection Regulation (GDPR), or Swift Customer Security Controls Framework (CSCF)

A well-executed GRC strategy also includes continuous monitoring and auditing of cybersecurity activities to ensure ongoing effectiveness, while establishing processes for incident response, recovery, and business continuity. By aligning cybersecurity governance with risk management and compliance, organizations can achieve a balanced approach to protecting sensitive information, reducing exposure to threats, and maintaining trust with customers, regulators, and other stakeholders.

Importance of Cybersecurity Governance, Risk and Compliance within the Broader Cybersecurity Framework

1. Cybersecurity Governance: Setting the Direction and Accountability

Defining Roles and Responsibilities: Governance provides the organizational structure and leadership necessary for managing cybersecurity efforts. It involves defining who is responsible for cybersecurity at all levels—from executives to operational teams—and ensuring clear lines of authority and accountability.

Strategic Alignment: Governance aligns cybersecurity strategies with business goals, ensuring that cyber defenses support the overall objectives of the organization. This alignment is essential in prioritizing resources and efforts effectively to mitigate the most critical threats.

Continuous Monitoring and Improvement: Governance structures ensure that cybersecurity practices are consistently reviewed and improved. This can include establishing frameworks, policies, and procedures for regular assessments of the security posture and for adapting to emerging threats.

2. Cybersecurity Risk Management: Identifying, Assessing, and Mitigating Threats

Risk Identification: Risk management involves understanding potential threats and vulnerabilities that could impact the organization's systems, data, and operations. This includes both internal and external risks—such as cyberattacks, data breaches, system failures, and human errors.

Risk Assessment and Prioritization: It is essential to assess the likelihood and potential impact of each risk. This allows organizations to prioritize which risks to mitigate based on their severity, likelihood, and the business impact.

Mitigation Strategies: Risk management helps develop and implement strategies to reduce or eliminate the impact of identified risks. This can include strengthening defenses (e.g., encryption, multi-factor authentication), creating response plans, and regularly testing security controls.

3. Cybersecurity Compliance: Adhering to Legal and Regulatory Requirements

Regulatory Requirements: Many industries are subject to specific laws and regulations governing how they manage and protect sensitive data. Compliance with these regulations is critical to avoid legal penalties, financial fines, and reputational damage.

Internal Policies and Standards: Compliance isn't just about external regulation; it also involves internal policies that set standards for how data should be handled, how systems should be secured, and how incidents should be reported and addressed. These internal policies ensure that cybersecurity efforts are standardized and effective.

Audits and Reporting: Regular audits and compliance checks help ensure that organizations are adhering to their policies and external regulations. This also facilitates transparency and builds trust with customers, investors, and regulatory bodies.

1.1 Cybersecurity Strategy:

Definition: A cybersecurity strategy is a plan that comprises a multi-layered approach with one core mission: Safeguarding digital systems, assets, and networks from internal and external threats. This strategic plan must be able to address vulnerabilities, respond to incidents, and ensure total compliance with regulatory standards [1], [2], [3].

Objective: To ensure that cybersecurity plans, goals, initiatives and projects are contributing to compliance with related laws and regulations.

Controls Matrix:

Below is a summary matrix detailing relevant Cybersecurity Strategy controls based on NCA, SAMA CSF, CST CRF, and CMA Cybersecurity guidelines:

Regulation	Main Controls	Control References
NCA ECC	3	ECC 1-1-1, ECC 1-1-2, ECC 1-1-3
SAMA CSF	1	3.2.1 (3 Sub controls)
CST CRF	1	1.1 (4 Sub controls)
CMA Cybersecurity Guidelines	1	4.1.3 (4 Sub controls)
NCA CSCC	1	CSCC 1-1-1
NCA CCC CST	-	-
NCA CCC CSP	-	-
NCA TCC	-	-
NCA DCC	-	-
NCA OSMACC	-	-
NCA OTCC	-	-

Cybersecurity Strategy Controls:

Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines:	Expected deliverables
ECC					
ECC 1-1-1		A cybersecurity strategy must be defined, documented and approved. It must be supported by the head of the organization or his/her delegate (referred to in this document as Authorizing Official). The strategy goals must be in-line with related laws and regulations.	All cybersecurity strategy models and roadmap	• Conduct a workshop with stakeholders in the organization to align the objectives of the cybersecurity strategy with the organization's strategic objectives. • Develop and document cybersecurity the strategy of the organization in order to align the organization's cybersecurity strategic objectives with related laws and regulations, including but not limited to (CCC, CSCC). A cybersecurity strategy often includes the following: ○ Vision ○ Mission ○ Strategic Objectives ○ Strategy Implementation Plan ○ Projects ○ Initiatives • In order for the cybersecurity strategy of the organization to be effective, the approval of the representative must be based on the authority matrix approved by the organization	• The cybersecurity strategy document approved by the organization (electronic copy or official hard copy). • Initiatives and projects included in the cybersecurity strategy of the organization.
ECC 1-1-2		A roadmap must be executed to implement the cybersecurity strategy.	• All cybersecurity strategy models and roadmap. • Cybersecurity performance report	• Develop a roadmap for implementing the cybersecurity strategy including the execution of the strategy's initiatives and projects to: ○ Define cybersecurity priorities.	• Strategy implementation roadmap • List of cybersecurity projects and initiatives and their status

			and measurement template.	○ Make recommendations related to cybersecurity works in the organization in a manner consistent with the nature of its work. ○ Monitor the implementation of cybersecurity strategy projects and initiatives and take corrective steps if necessary. ○ Ensure the implementation of initiatives and projects according to requirements. ○ Provide a clear and unified vision and communicate it to all internal and external stakeholders. ○ Obtain NCA's approval for any cybersecurity initiatives that are beyond the scope of the organization.	
ECC 1-1-3		The cybersecurity strategy must be reviewed periodically according to planned intervals or upon changes to related laws and regulations.		• Review and update the cybersecurity strategy periodically according to a documented and approved review plan as follows: ○ In specific intervals according to best practices (to be determined by the organization and documented with the necessary approval in the strategy document) ○ If there are changes in the relevant laws and regulations (e.g., changes in cybersecurity requirements applicable to the organization) ○ In the event of material changes in the organization • Document and approve the review procedures and changes to the cybersecurity strategy by the representative.	• An approved document that defines the review schedule for the cybersecurity strategy • An updated cybersecurity strategy after documenting changes to the cybersecurity requirements and to be approved by the representative • Project status reports • Formal approval by the representative on the updated strategy (e.g., via the organization's official e-mail, paper or electronic signature)
NCA CSCC					

Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines:	Expected deliverables
CSCC 1-1-1		In addition to the controls within sub-component 1-1 of the ECC, the cybersecurity strategy of the entity must set a priority to support the protection of critical systems of the entity.	• Template for Cybersecurity Strategy	• Work to include the protection of the entity's critical systems within the strategic objectives of cybersecurity and align it with the strategic objectives of the entity. • Conduct workshops with the stakeholders and those concerned in the entity to explain the importance of giving priority to supporting the protection of the critical systems of the entity. • Giving priority in implementing projects related to critical systems of the entity over other projects. • Giving priority to securing and protecting critical systems in cybersecurity projects and initiatives and documenting this in the implementation map of the cybersecurity strategy.	• Cybersecurity strategy document approved by the authorized person in the entity (electronic copy or official hard copy). • Presentation of the workshop that was held with the stakeholders and those concerned in the entity to give priority to supporting the protection of the critical systems of the entity. • A roadmap document for the implementation of the cybersecurity strategy, indicating the level of achievement in the implementation of projects and initiatives related to the critical systems of the entity. • Inventory review and periodic update of the list of critical systems
NCA OSMACC					

Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines:	Expected deliverables
N/A					
NCA TCC					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
N/A					
NCA OTCC					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
N/A					
NCA CCC CST					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
N/A					
NCA CCC CSP					
N/A					
SAMA CSF					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
3.2.1 Cyber Security Strategy	3.2.1.1	The cyber security strategy should be defined, approved, maintained and executed.			

	3.2.1.2	The cyber security strategy should be aligned with: a. the Member Organization's overall objectives. b. the legal and regulatory compliance requirements of the Member Organization. c. the Banking Sector's cyber security strategy.			
	3.2.1.3	The cyber security strategy should address: 1. the importance and benefits of cyber security for the Member organization. 2. the anticipated future state of cyber security for the Member Organization to become and remain resilient to (emerging) cyber security threats; 3. which and when cyber security initiatives and projects should be executed to achieve the anticipated future state.			
CST CRF					

Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
1.1 Cybersecurity Strategy	1.1.1	Define and document requirements for the [Cybersecurity Strategy] which consider the following: • Overall mission, objectives and activities of the organization in relation to cybersecurity • Relevant legislative and regulatory compliance requirements • Establishment of the cybersecurity program • Top management commitment towards cybersecurity			
	1.1.2	Ensure that the [Cybersecurity Strategy] is approved by the top management.			
	1.1.3	Ensure that the [Action Plan] for the implementation of the cybersecurity strategy considers the following: • Activities • Budget • Timeline • Resources (e.g. capabilities, personnel)			
	1.1.4	Continuously measure, review and as per requirements update the			

		[Cybersecurity Strategy] and the corresponding [Action Plan] especially in case of changes in relevant legislative and regulatory requirements, major organizational changes or lessons learned from the implementation of the previous action plans.			
CMA Cybersecurity Guidelines					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
4.1.3 Strategy and Policies	4.1.3.1	Set out, document, implement, approve and periodically update cybersecurity strategy			
	4.1.3.2	The cybersecurity strategy shall be aligned with the overall objectives of market institution and any related regulatory requirements.			
	4.1.3.3	Cybersecurity strategy shall include the following: 1. Importance of cybersecurity for			

		the market institution. 2. The expected cybersecurity state of market institution until it is able to counter cybersecurity threats. 3. Develop a time plan to implement cybersecurity initiatives, projects and strategies			
	4.1.3.4	Set out, document, implement and approve cybersecurity strategy and policies, circulate the same to related parties, and ensure compliance therewith.			

Risk Considerations in Cybersecurity Strategy

1. Misalignment Between Cybersecurity and Business Objectives

- **Risk:** If cybersecurity strategy is not aligned with business goals, organizations may either over-invest in areas with low risk or fail to protect critical business functions. A lack of alignment could lead to insufficient resources being allocated to the most pressing threats.
- **Mitigation:** Cybersecurity efforts should be integrated into the broader enterprise risk management framework. Regular discussions between the IT, cybersecurity, and business leadership teams are necessary to ensure that cybersecurity supports and enables business objectives.

2. Underestimation of Emerging Threats

- **Risk:** A static cybersecurity strategy that fails to account for emerging threats, like advanced persistent threats (APTs), or new regulatory requirements, can leave the organization vulnerable. Relying too heavily on existing defenses and not anticipating new risks can be catastrophic.
- **Mitigation:** Regular strategic reviews of the threat landscape and threat intelligence should inform adjustments to the cybersecurity strategy. A forward-thinking approach, including scenario planning and threat modeling, can help the organization anticipate new risks.

3. Over-Reliance on Technology Solutions

- **Risk:** Focusing too much on technology to solve cybersecurity challenges (e.g., firewalls, endpoint protection) without considering human, process, and organizational factors could result in a false sense of security. This can lead to gaps in incident detection, response capabilities, and resilience.
- **Mitigation:** A balanced cybersecurity strategy should include not just technology but also strong governance, regular training, and a focus on organizational culture. Cybersecurity should be seen as a combination of people, processes, and technologies working together.

4. Lack of a Robust Cybersecurity Governance Model

- **Risk:** Without a strong governance framework, cybersecurity initiatives can become fragmented or fail to achieve their full potential. Lack of clear accountability, poor decision-making structures, or absence of executive buy-in can undermine the effectiveness of the entire strategy.
- **Mitigation:** Establish a cybersecurity governance framework with clear roles, responsibilities, and oversight. A Chief Information Security Officer (CISO) or equivalent should have the authority to drive cybersecurity strategy across the organization, with involvement from the C-suite and board of directors to ensure alignment with strategic business goals.

5. Failure to Integrate Cybersecurity into Digital Transformation

- **Risk:** As organizations undergo digital transformation, there may be a tendency to focus on speed and innovation while deprioritizing cybersecurity. Failing to integrate cybersecurity into the design and deployment of new technologies (cloud, IoT, AI) can expose the organization to significant risks.
- **Mitigation:** Cybersecurity should be built into the digital transformation process from the outset, adopting a "security by design" approach. This includes ensuring that security protocols, risk assessments, and privacy considerations are part of the development lifecycle for new technologies.

6. Inadequate Risk Assessment and Prioritization

- **Risk:** A failure to accurately assess and prioritize cybersecurity risks based on their potential impact to the business can result in wasted resources or overlooked vulnerabilities. Without a clear understanding of which assets, data, or systems are most critical, cybersecurity investments may not be effectively targeted.
- **Mitigation:** Implement a risk-based approach to cybersecurity strategy. Use frameworks like NIST, or ISO 27005 to identify and assess critical assets, threats, and vulnerabilities. Regularly update risk assessments to account for new business developments and emerging threats.

7. Lack of Agility and Resilience

- **Risk:** In a rapidly changing threat landscape, a rigid cybersecurity strategy can quickly become obsolete. A lack of flexibility or ability to adapt to new risks, technologies, or business needs can leave the organization vulnerable in times of crisis.
- **Mitigation:** Build a resilient cybersecurity strategy that emphasizes agility. This includes having a flexible risk management framework, a proactive incident response plan, and the ability to quickly pivot and adapt to new threats, technologies, or regulatory requirements.

8. Overlooking Cybersecurity as a Competitive Advantage

- **Risk:** In today's market, cybersecurity is not only a defense mechanism but can also be a differentiator. Organizations that neglect cybersecurity as part of their competitive strategy may face lost opportunities or damage to their reputation, especially as customers and partners become more security conscious.
- **Mitigation:** Position cybersecurity as a key element of your brand and value proposition. Communicate a commitment to cybersecurity in marketing materials, customer-facing interfaces, and to stakeholders, building trust through transparency and responsible data management.

9. Resource Allocation and Budgeting Issues

- **Risk:** Cybersecurity often competes with other business priorities for limited resources, and this can result in inadequate funding, poorly resourced teams, or insufficient investment in necessary cybersecurity infrastructure and training.

- **Mitigation:** Ensure that cybersecurity is appropriately prioritized in the organization's budget. Leverage metrics such as risk assessments, threat modeling, and incident history to justify the financial and resource investment required to mitigate critical risks. This requires clear communication with executive leadership and stakeholders about the potential cost of cyber incidents.

10. Failure to Address Supply Chain and Vendor Risks

- **Risk:** Many organizations outsource critical operations or work with third-party vendors, and a weak link in the supply chain can introduce significant cybersecurity vulnerabilities. A breach in a third-party system can easily lead to cascading failures across an entire ecosystem.
- **Mitigation:** Develop a robust third-party risk management strategy that includes conducting cybersecurity assessments for vendors, implementing contractual cybersecurity requirements, and continuously monitoring third-party access. Integrate cybersecurity into vendor selection and due diligence processes.

11. Ineffective Incident Response and Crisis Management

- **Risk:** In the event of a cyberattack or data breach, an uncoordinated or poorly executed response can exacerbate the damage, prolong downtime, or lead to miscommunication. A lack of strategic planning for crisis management can make recovery efforts chaotic and inefficient.
- **Mitigation:** Develop a comprehensive and actionable incident response plan (IRP) with clearly defined roles, communication protocols, and escalation procedures. Regularly test and update the plan through tabletop exercises and real-world simulations.

12. Overlooking the Human Element in Cybersecurity Strategy

- **Risk:** Cybersecurity strategies that focus predominantly on technical defenses and ignore the human element can fail to address the root cause of many breaches, such as social engineering attacks or user errors. Employees and other users of the system are often the weakest link in a security chain.
- **Mitigation:** Prioritize cybersecurity awareness training across the organization, including leadership and operational staff. Create a security-conscious culture that encourages vigilance, responsible data handling, and adherence to security best practices.

13. Underestimating Regulatory and Legal Risks

- **Risk:** Failing to keep up with evolving legal and regulatory frameworks around cybersecurity and data protection can expose organizations to legal and financial penalties. Additionally, unclear jurisdictional issues or failure to comply with international laws can lead to significant risks, especially in a globalized market.
- **Mitigation:** Regularly assess the regulatory landscape and integrate compliance requirements into your cybersecurity strategy. Ensure that the organization has the necessary policies, procedures, and controls in place to meet legal obligations.

Examples of Technologies for Effective Cybersecurity Strategy

1. **Framework Selection:** Use a GRC or Framework Management Tool to select a framework (e.g., NCA ECC) as the backbone of your strategy.
2. **Risk & Threat Assessment:** Employ a Threat Modeling Tool **to** understand specific risks to your critical systems.
3. **Documentation:** Write the core strategy document (vision, mission, objectives).
4. **Roadmap & Initiatives:** Plan the implementation, budget, and timelines for your cybersecurity initiatives using a Project Management Tool.
5. **Centralization:** Link all policies, risks, controls, and compliance evidence within a GRC platform like Eramba to manage the strategy long-term.

Examples of KPIs for Cybersecurity Strategy

1. **Strategy Alignment Score:** Percentage of cybersecurity strategy elements aligned with business objectives, regulatory requirements, and industry standards (e.g., NIST, ISO 27001).
2. **Cybersecurity Maturity Level:** Score based on maturity assessments (e.g., NIST Cybersecurity Framework, CMMI) indicating the current level of cybersecurity maturity within the organization.
3. **Risk Reduction:** Percentage reduction in critical risks over a defined period after the strategy's implementation.
4. **Resource Allocation Efficiency:** Percentage of cybersecurity budget spent on strategic initiatives versus operational and maintenance activities.
5. **Executive Buy-in:** Percentage of senior executives engaged in strategy development and review (e.g., participation in strategy meetings).

Case Study : Developing a Cybersecurity Strategy Document for a Saudi Financial Institution

Scenario:

Saudi Future Bank (SFB) is a well-established financial institution based in Saudi Arabia, offering a wide range of services, including retail banking, investment products, corporate banking, and Islamic finance solutions. The bank has witnessed substantial growth in its digital banking services, with an increasing number of customers using mobile and online banking platforms. The bank's core systems and infrastructure, including its data centers, are primarily located within Saudi Arabia, in compliance with Saudi data localization regulations.

Despite its growth and adoption of digital services, SFB has faced challenges with maintaining robust cybersecurity, especially as it expands its digital footprint and adopts new technologies like cloud-based services and mobile payment systems. The bank has had to manage increasing cyber threats, including phishing attacks, social engineering, and ransomware, while ensuring compliance with Saudi Arabian Central Bank (SAMA) cybersecurity regulations.

The bank's leadership recognized the need for a Cybersecurity Strategy to address these risks, ensure the protection of sensitive financial data, achieve compliance with Saudi regulations, and improve the security of digital services.

1. Vision

"To become the most secure and trusted financial institution in Saudi Arabia, empowering customers with innovative banking solutions while ensuring the highest levels of cybersecurity protection."

2. Mission

"To safeguard customer trust and financial integrity by establishing a comprehensive cybersecurity framework that proactively identifies, mitigates, and responds to evolving cyber threats while ensuring compliance with national and international regulations."

3. Strategic Objectives

SFB's cybersecurity strategy aims to achieve the following key strategic objectives:

1. Enhance Data Security and Customer Protection

Strengthen systems and processes to protect sensitive financial and personal customer data from internal and external threats.

2. Ensure Regulatory Compliance

Fully comply with SAMA's Cybersecurity Framework, Saudi Data Protection Law (PDPL), and international data protection standards like PCI-DSS, ensuring alignment with the Kingdom's digital vision and regulations.

3. Improve Threat Detection and Incident Response

Establish advanced threat detection capabilities and a robust incident response framework to swiftly respond to cyber threats and minimize operational impact.

4. Foster a Security-Aware Culture

Empower employees with the knowledge and tools to identify, mitigate, and report potential cybersecurity risks, reducing human errors and insider threats.

5. Achieve Business Continuity and Resilience

Ensure business continuity through secure disaster recovery and continuity plans, minimizing downtime in case of cyberattacks or breaches.

4. Strategy Implementation Plan

The implementation of SFB's cybersecurity strategy will follow a structured and phased approach, covering key aspects such as technology adoption, governance, process improvement, and employee awareness. The strategy will be carried out over the course of 12 months, divided into the following phases:

Phase 1: Assessment and Planning (Month 1-2)

Key Actions:

- **Cybersecurity Risk Assessment:** Conduct a comprehensive assessment to identify risks and vulnerabilities in core systems and digital channels.
- **Compliance Gap Analysis:** Review the bank's current adherence to SAMA's cybersecurity guidelines and Saudi Data Protection Law (PDPL).
- **Stakeholder Alignment:** Engage with senior leadership to finalize cybersecurity goals, roles, and responsibilities, and align with business objectives.

Deliverables:

- Risk Assessment Report
- Compliance Gap Analysis
- Cybersecurity Strategy Document

Phase 2: Governance and Framework Design (Month 2-4)

Key Actions:

- **Governance Structure Implementation:** Establish a cybersecurity governance model with a Chief Information Security Officer (CISO) and a Cybersecurity Committee.
- **Cybersecurity Policies:** Develop comprehensive security policies and controls, including access management, data classification, and incident response protocols.
- **Regulatory Compliance Roadmap:** Develop a plan to close any gaps identified in the compliance analysis, ensuring adherence to local and international regulations.

Deliverables:

- Governance Structure
- Cybersecurity Policy Framework
- Compliance Roadmap

Phase 3: Technology and Security Controls Implementation (Month 4-6)

Key Actions:

- **Deploy Security Technologies:** Implement technologies such as SIEM, EDR, MFA, DLP, and encryption to strengthen the bank's cybersecurity posture.
- **Access Management Controls:** Enforce role-based access control (RBAC) and least-privilege principles.
- **Cloud and Third-Party Security:** Ensure secure data handling for cloud-based services and third-party integrations.

Deliverables:

- Deployed Security Tools (SIEM, EDR, MFA, DLP)
- Cloud Security Architecture
- Updated Access Management Policies

Phase 4: Incident Response and Business Continuity Planning (Month 6-8)

Key Actions:

- **Incident Response Plan (IRP):** Develop and implement an Incident Response Plan for effective threat detection and mitigation.

- **Business Continuity & Disaster Recovery (BCDR):** Design a comprehensive BCDR plan to ensure minimal operational disruption during cyberattacks or disasters.
- **Simulated Incident Drills:** Conduct tabletop exercises and penetration testing to validate the IRP and BCDR plans.

Deliverables:

- Incident Response Plan
- Business Continuity & Disaster Recovery Plans
- Test Reports

Phase 5: Employee Awareness and Training Program (Month 8-10)

Key Actions:

- **Cybersecurity Awareness Campaigns:** Roll out a company-wide training program to educate employees on recognizing threats (e.g., phishing) and adhering to security best practices.
- **Role-Based Training:** Implement advanced training for key technical staff on managing security tools and responding to incidents.
- **Security Culture Initiatives:** Launch initiatives to foster a security-first mindset across the organization.

Deliverables:

- Training Curriculum
- Employee Training Reports
- Security Culture Initiatives

Phase 6: Continuous Monitoring, Auditing, and Optimization (Month 10-12)

Key Actions:

- **Continuous Monitoring:** Implement 24/7 monitoring systems using SIEM and SOC capabilities to identify and respond to threats in real time.
- **Regular Audits:** Conduct internal and external cybersecurity audits and penetration testing to ensure systems are secure.
- **Continuous Improvement:** Use insights from audits and incident response to improve security controls and policies.

Deliverables:

- Continuous Monitoring Setup (SIEM, SOC)
- Audit Reports
- Continuous Improvement Plan

5. Projects

The following key cybersecurity projects are identified for execution within the strategy:

1. **Cybersecurity Governance Enhancement Project**
 - Establishment of a formal cybersecurity governance structure with a dedicated CISO and a cybersecurity steering committee.
 - Responsible for driving strategic cybersecurity initiatives across the bank.
2. **Advanced Threat Detection and Response Implementation**
 - Deployment of SIEM, EDR, and MFA systems for enhanced threat detection and access control.
 - Establishment of a Security Operations Center (SOC) to monitor, detect, and respond to cyber threats.
3. **Cloud and Third-Party Security Enhancement**

- Review and strengthen security protocols around third-party vendors, cloud-based services, and data storage solutions.
 - Implement robust Data Loss Prevention (DLP) and encryption measures for customer data.
 - 4. Compliance and Regulatory Adherence Project**
 - Ensure full compliance with SAMA's Cybersecurity Framework and Saudi Data Protection Laws (PDPL).
 - Regular audits and penetration testing to ensure compliance and adjust security controls accordingly.
 - 5. Employee Cybersecurity Training and Awareness Program**
 - Develop and execute an organization-wide security awareness campaign to minimize human-related cyber risks.
 - Tailored cybersecurity training for technical teams to enhance their ability to manage security tools and respond to cyber threats.
-

6. Initiatives

The following key initiatives will support the strategy:

- 1. Cybersecurity Awareness and Behavior Change Initiative**
 - Launch a year-long employee awareness program that includes phishing simulation exercises, awareness campaigns, and role-specific security training.
 - Provide incentives for employees who excel in security awareness and report potential threats.
- 2. Regulatory Compliance and Industry Certification Initiative**
 - Achieve compliance with NCA and SAMA's Cybersecurity Framework, Saudi Data Protection Law, and international standards such as PCI-DSS and SWIFT CSCF.
 - Obtain ISO/IEC 27001 certification to demonstrate the bank's commitment to information security management.
- 3. Cybersecurity Incident Simulation and Tabletop Drills Initiative**
 - Regularly conduct incident response simulations, penetration testing, and tabletop exercises with cross-functional teams to ensure the preparedness of the cybersecurity response team.
- 4. Cloud and Digital Transformation Security Initiative**
 - Implement a Cloud Security Governance Framework to ensure secure deployment and integration of cloud-based services.
 - Establish a Digital Transformation Security Strategy to address security concerns with mobile banking, online payment systems, and new customer-facing technologies.
- 5. Security Awareness & Engagement Initiative for Customers**
 - Educate customers on best practices for securing their banking information, including multi-factor authentication, and safe online banking.
 - Launch a customer-facing cybersecurity blog and a hotline for reporting suspicious activities.

Outcomes:

1. Enhanced Cybersecurity Posture

- SFB successfully implemented a comprehensive cybersecurity framework that incorporated advanced security technologies (MFA, SIEM, EDR) and improved data protection, reducing the risk of data breaches and unauthorized access.

2. Regulatory Compliance

- Full compliance with NCA and SAMA's cybersecurity requirements and Saudi Data Protection Laws (PDPL) was achieved, ensuring the bank avoided penalties and safeguarded customer data.

3. Improved Threat Detection and Response

- With the establishment of a Security Operations Center (SOC) and deployment of continuous monitoring systems, SFB was able to detect and respond to threats 40% faster than before.

4. Employee Security Awareness

- After rolling out the cybersecurity training program, employees' ability to recognize and report phishing attacks improved by 35%.

5. Enhanced Business Continuity

- The implementation of Business Continuity and Disaster Recovery Plans (BCDR) ensured that the bank could recover critical services within defined Recovery Time Objectives (RTOs) during incidents.

Conclusion:

The development and execution of the Cybersecurity Strategy for SFB led to significant improvements in the bank's cybersecurity posture. By addressing key strategic objectives such as data protection, compliance, and threat detection, the bank not only safeguarded customer data and financial assets but also built resilience against evolving cyber threats. The strategy ensured regulatory alignment, empowered employees with security knowledge, and established the bank as a trusted institution in the Kingdom of Saudi Arabia.

1.2 Cybersecurity Management:

Definition: Cybersecurity management refers to the high-level decision-making bodies and senior leaders within an organization responsible for setting the overall cybersecurity strategy, allocating resources, ensuring alignment with business objectives, and overseeing the organization's cybersecurity posture. This group typically includes members of the C-suite (e.g., Chief Information Security Officer (CISO), Chief Technology Officer (CTO), Chief Executive Officer (CEO), Chief Financial Officer (CFO), etc.) and also extend to specialized cybersecurity committees or boards that provide oversight and governance [4], [5], [6].

Objective: To ensure Authorizing Official's support in implementing and managing cybersecurity programs within the organization as per related laws and regulations.

Controls Matrix:

Below is a summary matrix detailing relevant Cybersecurity Management controls based on NCA, SAMA CSF, CST CRF, and CMA Cybersecurity guidelines:

Regulation	Main Controls	Control References
NCA ECC	3	1-2-1, 1-2-2, 1-2-3
SAMA CSF	1	3.1.1 (10 Sub controls)
CST CRF	1	1.2 (5 Sub controls)
CMA Cybersecurity Guidelines	1	4.1.1 (7 Sub controls)
NCA CSCC	-	-
NCA CCC CST	-	-
NCA CCC CSP	-	-
NCA TCC	-	-
NCA DCC	-	-
NCA OSMACC	-	-
NCA OTCC	-	-

Cybersecurity Management Controls:

Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines:	Expected deliverables
NCA ECC					
1-2-1		A dedicated cybersecurity function (e.g., division, department) must be established within the organization. This function must be independent from the Information Technology/ Information Communication and Technology (IT/ICT) functions (as per the Royal Decree number 37140 dated 14/8/1438H). It is highly recommended that this cybersecurity function reports directly to the head of the organization or his/her delegate while ensuring that this does not result in a conflict of interest.	• Cybersecurity Function Organizational Structure • Cybersecurity Roles and Responsibilities Template • Cybersecurity General Policy Template	• Establish a cybersecurity function within the organization to enable it to carry out its cybersecurity tasks as required, taking into account the following points ○ Ensure that the cybersecurity function's reporting line is different from that of the IT department or the digital transformation department, as per Royal Decree No. 37140 dated 14/8/1438H ○ Ensure that the cybersecurity function is reporting to the head of the organization or his/ her deputy/ assistant for the sectors concerned with regulation, including but not limited to, deputy/ assistant head of business sectors or regulatory sectors, or the agents and heads of business sectors in the organization ▪ Ensure the following in order to avoid conflict of interest o The cybersecurity function is responsible for all cybersecurity monitoring activities (including compliance monitoring, operation monitoring, operations, etc.) ▪ The cybersecurity function is responsible for all cybersecurity governance activities (including	• The organization's organizational structure (electronic copy or official hard copy), covering the organizational structure of the cybersecurity function. • The decision to establish the Cybersecurity functions and its mandate (electronic copy or official hard copy) • Reports on the cybersecurity policies compliance results

				defining cybersecurity requirements, managing cybersecurity risks, etc.)	
1-2-2		The position of cybersecurity function head (e.g., CISO), and related supervisory and critical positions within the function, must be filled with full-time and experienced Saudi cybersecurity professionals.		- Appoint full-time and highly qualified Saudi cybersecurity professionals to fill the following job roles and positions - Head of the cybersecurity function, who is responsible for leading the cybersecurity operations within the organization, setting the vision and direction for cybersecurity, strategies, resources and related activities, and providing insights to the organization's leadership regarding effective cybersecurity risk management methods for the organization. - Supervisory positions within the cybersecurity function (e.g., managers of departments and functions within the cybersecurity function as per the organizational structure and/or the cybersecurity function governance and operating model approved by the authorization official), and in case there is a vacancy for any supervisory position, an employee is to be assigned to run the operations of the function or department until the supervisory position is filled as per an approved timeline. - Critical roles within the cybersecurity function that include responsibilities requiring confidentiality and integrity where if not performed as required, it would have negative impacts on the cybersecurity of the organization, its operations, and its systems while also considering the national laws and regulations related to nationalizing the cybersecurity positions within the	- A detailed list of all personnel (direct or indirect employees and contractors), whose work is related to cybersecurity, that includes names, nationality, contractual type, position titles, job roles, years of experience, academic and professional qualifications. - Job descriptions of the head of the cybersecurity and the supervisory and critical positions related to cybersecurity relying on The Saudi Cybersecurity Workforce Framework (SCyWF).

				organization, including direct or indirect employees and contractors (including, but not limited to, royal orders and decrees, orders issued by the Council of Ministers, and official circulars and regulatory orders issued by the National Cybersecurity Authority). The Saudi Cybersecurity Workforce Framework (SCyWF) can be utilized as reference regarding the job positions related to cybersecurity. • Define the required academic qualifications and years of experience to serve as the head of the cybersecurity function and the supervisory and critical job roles and positions. For example, but not limited to: ○ Developing a job description of the head of the cybersecurity function position to include the minimum required number of years of experience and related fields, and the appropriate academic qualifications, and appropriate training and professional certificates in the cybersecurity and technical fields relying on The Saudi Cybersecurity Workforce Framework (SCyWF)	
1-2-3		A cybersecurity steering committee must be established by the Authorizing Official to ensure the support and implementation of the cybersecurity programs and initiatives within the organization. Committee members, roles and responsibilities, and governance framework must be defined, documented and approved. The	• Cybersecurity supervisory committee governance document template	• Establish the cybersecurity supervisory committee as a committee specialized in directing and leading cybersecurity affairs, processes, programs, and initiatives in the organization. The committee's must be directly reporting to the organization's head or his/ her deputy, taking into account non-conflict of interests • Identify the members of the supervisory committee, where the cybersecurity supervisory committee includes members who influence or are influenced by the	• Supervisory committee charter in the organization. The charter clarifies the date of establishment of the committee and its reference and its approval by the organization's representative • A documented and approved list showing

		committee must include the head of the cybersecurity function as one of its members. It is highly recommended that the committee reports directly to the head of the organization or his/her delegate while ensuring that this does not result in a conflict of interest.		cybersecurity of the organization. Such members include but are not limited to, the head of the organization or his/ her deputy, the head of the cybersecurity function, the head of the IT department, the head of the Compliance Department, the Head of the Human Resources Department. In addition, define the duties and responsibilities of the supervisory committee and its business governance framework, and formally document them in the Committee's Charter. The Committee's charter must be approved by the organization's representative (head of organization or his/ her deputy) • Include the head of cybersecurity function as a permanent member of the committee • Conduct periodic meetings (based on the intervals specified in the committee's charter document). The periodic meetings cover ensuring follow up on the implementation of cybersecurity programs and regulations in the organization, managing cybersecurity risks, and submitting meeting minutes to the organization head • Review the implementation of all cybersecurity policies and procedures • Update cybersecurity strategy initiatives and objectives • Ensure that the cybersecurity strategy is aligned with the organization's strategy on a regular basis	the names of the organization's cybersecurity supervisory committee members • Cybersecurity supervisory committee's agenda in the organization • Minutes of meetings held for the cybersecurity supervisory committee at the organization
NCA CCCC					

Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines:	Expected deliverables
N/A				•	•
NCA OSMACC					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines:	Expected deliverables
N/A					
NCA TCC					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
N/A					
NCA OTCC					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
N/A					
NCA CCC CST					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
N/A					
NCA CCC CSP					
N/A					
SAMA CSF					

Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
3.1.1.1		A cyber security committee should be established and be mandated by the board.			
3.1.1.2		The cyber security committee should be headed by an independent senior manager from a control function.			
3.1.1.3		The following positions should be represented in the cyber security committee: a. senior managers from all relevant departments (e.g., COO, CIO, compliance officer, heads of relevant business departments);b. Chief information security officer (CISO);c. Internal audit may attend as an "observer".			
3.1.1.4		A cyber security committee charter should be developed, approved and reflect: a. committee objectives; b. roles and responsibilities; c. minimum number of meeting participants; d. meeting frequency (minimum on quarterly basis).			
3.1.1.5		A cyber security function should be established.			
3.1.1.6		The cyber security function should be independent from the information technology function. To avoid any conflict of interest, the cyber security function and information technology function			

		should have separate reporting lines, budgets and staff evaluations. The board of the Member Organization should allocate sufficient budget to execute the required cyber security activities.			
3.1.1.7		The cyber security function should report directly to the CEO/managing director of the Member Organization or general manager of a control function.			
3.1.1.8		A full-time senior manager for the cyber security function, referred to as CISO, should be appointed at senior management level.			
3.1.1.9		The Member Organization should : a. ensure the CISO has a Saudi nationality; b. ensure the CISO is sufficiently qualified; c. obtain no objection from SAMA to assign the CISO.			
3.1.1.10		The board of the Member Organization should allocate sufficient budget to execute the required cyber security activities.			
CST CRF					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
1.2.1		Define and document requirements for the Cybersecurity organization which consider the following:	• Cybersecurity organization • Action Plan		

		• A cybersecurity committee and allocating members who represent different areas within the organization • The needed cybersecurity functions/ departments required to implement the Action Plan • Direct reporting to top management to avoid conflict of interest • Allocating roles and responsibilities ensuring that the conflicting duties and areas of responsibilities are clearly segregated			
1.2.2		Implement the defined Cybersecurity Organization.			
1.2.3		Implement the Action Plan through the defined Cybersecurity Organization.			
1.2.4		Oversee the implementation of the Action Plan by the cybersecurity committee by monitoring, dealing with conflicts, and enforcing necessary measures for improvement.			
1.2.5		Continuously measure, review and optimize requirements for the Cybersecurity Organization to ensure an efficient Cybersecurity Organization.			
CMA Cybersecurity Guidelines					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables

4.1.1.1		Establish a cybersecurity department separated from IT department , with taking the non-conflict of interest principle into the consideration.			
4.1.1.2		Cybersecurity Department shall be headed by a full-time, "qualified" Saudi employee and shall be referred as "Head of Cybersecurity Department".			
4.1.1.3		Allocate and approve an adequate budget to implement the cybersecurity tasks and functions by the market institution's BOD.			
4.1.1.4		Review cybersecurity roles and responsibilities periodically or in case of changes.			
4.1.1.5		Form a cybersecurity committee associated with CEO of the entity or his representative, with taking the non-conflict of interest principle into the consideration.			
4.1.1.6		Cybersecurity Committee shall comprise of Head of Cybersecurity department and Heads of relevant departments.			
4.1.1.7		Regulations of Cybersecurity Committee shall be prepared, documented and approved by an authorized person who clarify relevant objectives, roles and responsibilities.			

Risk Considerations in Cybersecurity Management

1. Lack of Clear Accountability

- **Risk Description:** If executive leadership does not clearly define roles and responsibilities, it can result in confusion over accountability for cybersecurity decisions, leading to inefficiency, gaps in security efforts, and delays in response to incidents.
- **Risk Mitigation:** Define clear roles and responsibilities for the CISO, CTO, and other leadership positions, ensuring a well-documented cybersecurity governance structure with specific reporting lines. Assign clear accountability for security decisions and incident management.

2. Insufficient Executive Buy-In

- **Risk Description:** Without full support from top executives (e.g., CEO, CFO), cybersecurity initiatives may lack necessary resources, financial backing, or strategic alignment with business goals. This can result in weak security programs and insufficient investment in cybersecurity technologies.
- **Risk Mitigation:** Ensure cybersecurity is viewed as a critical part of the organization's overall business strategy. Conduct regular briefings to educate executives on the business impact of cyber risks, the cost of breaches, and the ROI of security investments. Secure formal commitment from the CEO and board of directors.

3. Inadequate Cybersecurity Expertise at the Executive Level

- **Risk Description:** If key executives, especially within the C-suite, lack a deep understanding of cybersecurity issues, they may make decisions that overlook important risks, vulnerabilities, or emerging threats. This can undermine the organization's ability to effectively respond to cyber incidents.
- **Risk Mitigation:** Ensure that executives receive regular cybersecurity training and updates on the evolving threat landscape. Consider hiring external cybersecurity advisors or building a diverse cybersecurity governance committee to provide specialized expertise at the leadership level.

4. Misalignment with Business Objectives

- **Risk Description:** Cybersecurity initiatives may not be aligned with the organization's broader business goals and priorities, leading to inefficiencies or conflicts in resource allocation. This misalignment can weaken the overall business-technology strategy and cause friction between departments.
- **Risk Mitigation:** The cybersecurity strategy should be closely aligned with the organization's overall business goals. Cybersecurity leaders should participate in strategic planning sessions and work cross-functionally with business leaders to ensure alignment between business and security objectives.

5. Poor Risk Communication

- **Risk Description:** Ineffective communication between cybersecurity leadership and other key executives, such as the board, may lead to a lack of understanding of the organization's risk posture, or failure to take timely action to address high-priority risks.
- **Risk Mitigation:** Establish a clear communication framework for reporting cybersecurity risks, including regular risk assessments and updates to the board and other executives. Develop transparent, easy-to-understand reports that align cybersecurity risks with business impact.

6. Executive Turnover and Succession Planning Risks

- **Risk Description:** High turnover or lack of succession planning in key cybersecurity leadership roles (e.g., CISO, CTO) can lead to disruptions in cybersecurity strategy and execution, as well as knowledge gaps.
- **Risk Mitigation:** Implement a clear succession planning strategy for cybersecurity leadership roles. Cross-train key individuals within the cybersecurity team and ensure knowledge transfer occurs during transitions.

7. Lack of Cybersecurity Budget and Resource Allocation

- **Risk Description:** A failure to allocate adequate funding and resources for cybersecurity initiatives, often due to competing priorities, can leave the organization vulnerable to cyber threats.
- **Risk Mitigation:** Secure adequate budgetary allocations for cybersecurity from the C-suite and the board. Regularly demonstrate the financial and reputational impact of cyber threats to make a compelling case for cybersecurity investments.

8. Resistance to Change or Innovation

- **Risk Description:** Executives may resist adopting new technologies or approaches to cybersecurity due to a lack of awareness of emerging threats or an outdated mindset, potentially leaving the organization exposed to newer, more sophisticated attacks.
- **Risk Mitigation:** Foster a culture of continuous learning and innovation within the executive leadership team. Encourage participation in cybersecurity conferences, training, and industry events to stay current on emerging threats, tools, and best practices.

9. Conflicting Priorities Between Business Units and Cybersecurity

- **Risk Description:** Different business units may have conflicting priorities that could undermine cybersecurity initiatives. For example, a business unit may prioritize speed and innovation over security, leading to increased vulnerabilities.
- **Risk Mitigation:** Implement a framework that ensures security is considered early in decision-making processes across all departments. Ensure executive leadership fosters collaboration between cybersecurity and business unit leaders to balance security with business objectives.

Examples of Technologies for Effective Cybersecurity Management

- **Board-Level Reporting and Executive Dashboards**

Example Tools: Metabase, Redash, Superset

Purpose: These open-source business intelligence tools can be tailored to display cybersecurity metrics, risks, and performance in formats suitable for executive review.

- How it Helps Executive Leadership:

- Offers clear, visual summaries of cybersecurity posture and risk exposure.
- Bridges the technical-to-business gap for C-suite and board-level stakeholders.
- Enables real-time, data-driven decisions aligned with security and business goals.

- **Cybersecurity Budgeting and Resource Management Tools**

Example Tools: OpenProject, GanttProject, Redmine, Taiga, Wekan

Purpose: These open-source tools help manage cybersecurity budgets, resources, and project schedules.

- How it Helps Executive Leadership:

- Delivers clear visibility into project timelines, spending, and resource allocation.
- Supports informed prioritization of initiatives based on budget and risk context.
- Enables tracking and adjustment of cybersecurity investment strategies and ROI.

Examples of KPIs for Cybersecurity Management

1. **Cybersecurity Leadership Coverage:** Percentage of key cybersecurity roles (e.g., CISO, cybersecurity officers) filled with qualified executives.
2. **Cybersecurity Budget Approval Rate:** Percentage of proposed cybersecurity budgets approved by senior leadership.
3. **Leadership Engagement Rate:** Frequency of executive leadership meetings on cybersecurity (e.g., monthly or quarterly reviews).
4. **Time to Decision:** Average time taken from identifying a cybersecurity issue to decision-making by the leadership team.
5. **Cybersecurity Board Reporting:** Frequency and completeness of cybersecurity performance and risk reporting to the board or executive leadership.

Case Study: Establishing a Dedicated Cybersecurity Executive Leadership for a Saudi Organization

Scenario:

A leading Saudi financial institution, hereafter referred to as Saudi FinCorp, recognized the increasing complexity of cybersecurity threats facing the financial sector. Given the institution's critical role in the national economy and its responsibility for safeguarding customer assets and financial transactions, it was imperative to establish a strong, independent cybersecurity function that would address specific operational risks while complying with regulatory requirements set by the Saudi Arabian Central Bank (SAMA).

Saudi FinCorp is regulated by SAMA, which mandates stringent cybersecurity requirements for the financial sector. In light of the growing number of sophisticated cyber threats targeting financial institutions worldwide, Saudi FinCorp's leadership decided to create a dedicated cybersecurity function, separate from the IT department, to ensure that cybersecurity priorities received the appropriate focus, expertise, and strategic oversight.

The cybersecurity function would be directly accountable to the Board of Directors or its designated representative, and filled exclusively with experienced, full-time Saudi cybersecurity professionals to comply with both regulatory requirements and national talent development goals.

Phase 1: Establishing an Independent Cybersecurity Function

1. Defining the Independent Cybersecurity Structure

- **Objective:** Saudi FinCorp needed a dedicated cybersecurity function independent of the IT department, ensuring clear accountability for managing cybersecurity risks specific to financial services, while maintaining a distinct focus on compliance with NCA and SAMA's cybersecurity regulations.
- **Independence from IT Department:** To ensure that cybersecurity decision-making was distinct from IT operations, the cybersecurity function was separated from the institution's broader IT division. While the IT department managed network infrastructure, system development, and operational efficiency, the cybersecurity function would focus solely on protecting financial data, mitigating threats, and managing risks related to financial transactions, customer information, and critical systems.
- **Direct Reporting to the Board of Directors:** The Chief Information Security Officer (CISO) was appointed to lead the cybersecurity function and was given direct access to the Board of Directors or a Cybersecurity Subcommittee of the Board. This reporting line ensured that cybersecurity concerns were addressed at the highest level, with adequate resources and decision-making authority to implement necessary measures.
- **Ensuring No Conflict of Interest:** The division of responsibilities between the CISO and the CIO (Chief Information Officer) was critical. The CIO would continue overseeing IT infrastructure and technical support, while the CISO would focus exclusively on the security of all financial systems, ensuring alignment with NCA and SAMA's Cybersecurity Framework for Financial Institutions.

Phase 2: Appointment of Full-Time, Experienced Saudi Cybersecurity Professionals

1. Recruitment of Leadership Roles

- **Objective:** To align with NCA and SAMA's regulatory requirement of local talent development, Saudi FinCorp focused on recruiting full-time, experienced Saudi cybersecurity professionals for

key leadership roles within the cybersecurity division. This would not only ensure regulatory compliance but also support national objectives for skill development in the cybersecurity domain.

- **CISO Appointment:** The CISO was selected based on extensive experience in cybersecurity leadership, particularly in the financial sector. This individual was expected to have an in-depth understanding of the NCA and SAMA Cybersecurity Frameworks, as well as experience in risk management, data protection, and incident response within the financial industry.

Key qualifications for the CISO included:

- A proven track record in managing cybersecurity operations for large financial institutions or banks.
- Expertise in NCA and SAMA's cybersecurity regulations and industry standards such as ISO 27001, NIST, and PCI DSS.
- Ability to manage both proactive threat intelligence and reactive incident response efforts.
- Strong communication skills to report to the board and engage with senior stakeholders.
- **Supporting Cybersecurity Team:** The Cybersecurity Risk Manager, Incident Response Lead, Threat Intelligence Analyst, and other critical roles were filled with Saudi nationals who possessed specialized knowledge of financial security and regulatory compliance. These professionals were selected based on their technical expertise, as well as their ability to understand the operational needs of a regulated financial institution.
- **Training and Development Initiatives:** Saudi FinCorp also created a comprehensive cybersecurity training program for local talent, offering advanced certifications (e.g., CISSP, CISA, Certified Ethical Hacker) to help build the necessary cybersecurity skills required to protect critical financial systems.

Phase 3: Establishing a Cybersecurity Steering Committee for Strategic Oversight

1. Creation of the Cybersecurity Steering Committee

- **Objective:** To ensure the alignment of cybersecurity efforts with broader organizational goals and regulatory requirements, Saudi FinCorp established a Cybersecurity Steering Committee comprised of senior executives and external advisors. This committee would oversee the development and execution of the cybersecurity strategy and policies.
- **Committee Composition:** The Cybersecurity Steering Committee included senior leaders from the following areas:
 - **CISO (Chair):** Led the committee and provided strategic direction for cybersecurity initiatives.
 - **CEO:** Ensured the cybersecurity strategy was aligned with the institution's business objectives and regulatory requirements.
 - **CFO:** Oversaw financial investments in cybersecurity technologies and initiatives.
 - **Chief Risk Officer (CRO):** Coordinated risk management activities, ensuring that the financial risks associated with cybersecurity threats were adequately mitigated.
 - **External Cybersecurity Advisors:** Brought in external expertise on emerging threats and best practices from the global financial sector.
- **Key Responsibilities of the Committee:**
 - **Strategic Direction:** Approving the cybersecurity roadmap and major cybersecurity projects.

- Regulatory Compliance: Ensuring that cybersecurity measures complied with SAMA's Cybersecurity Framework and other financial industry regulations.
- Resource Allocation: Allocating sufficient budget and resources for cybersecurity initiatives.
- Risk Oversight: Evaluating and addressing the organization's cybersecurity risks and implementing mitigation strategies.
- Incident Management Oversight: Ensuring preparedness for cybersecurity incidents, including establishing protocols for managing financial fraud, data breaches, or cyber-attacks.

Phase 4: Integrating Cybersecurity into Organizational Strategy

1. Cybersecurity as a Business Enabler

- Cybersecurity as Core Business Function: Saudi FinCorp's leadership recognized that cybersecurity should be treated as a core organizational function, not just an IT or compliance requirement. CISO played a key role in integrating cybersecurity into every aspect of the business, from digital banking operations to mobile app security, ensuring that customers' financial data was safeguarded at all touchpoints.
- SAMA Compliance Framework Alignment: Saudi FinCorp rigorously aligned its cybersecurity efforts with the SAMA Cybersecurity Framework and NIST Cybersecurity Framework. This included:
 - Implementing cybersecurity controls that addressed data protection, fraud prevention, and secure customer transactions.
 - Developing policies around data encryption, multi-factor authentication, and incident reporting.
 - Ensuring that any outsourced services (e.g., cloud providers) adhered to the same cybersecurity standards.

2. Risk Management and Threat Intelligence

- Proactive Risk Identification: The NCDA established robust mechanisms for identifying, assessing, and mitigating cybersecurity risks, particularly those related to financial transactions, customer identity theft, and unauthorized access to financial systems.
- Cyber Threat Intelligence: The Threat Intelligence Team within the cybersecurity division monitored global and regional cybersecurity threat landscapes, sharing relevant intelligence with regulators like SAMA and other financial institutions to ensure collective defense against emerging threats.

Phase 5: Ensuring Ongoing Monitoring and Continuous Improvement

1. Implementing Advanced Cybersecurity Technologies

- SIEM (Security Information and Event Management) Solutions: Saudi FinCorp adopted cutting-edge SIEM platforms (e.g., Splunk, IBM QRadar) to monitor and respond to cybersecurity incidents in real-time. These tools helped detect anomalies in transactions, unauthorized access, and other suspicious activity.
- Endpoint Detection and Response (EDR) Tools: Advanced EDR tools were deployed to secure endpoints such as ATMs, mobile banking applications, and staff devices against malware and other threats.

- **Fraud Detection Systems:** Saudi FinCorp implemented AI-powered fraud detection systems to identify and respond to fraudulent activities such as identity theft and payment fraud in real time.

2. Continuous Testing and Simulation

- **Penetration Testing and Vulnerability Scanning:** Regular penetration testing and vulnerability assessments were carried out to identify potential weaknesses in the financial institution's systems. The results informed ongoing adjustments to cybersecurity strategies.
- **Incident Response Drills:** The organization conducted simulated cyberattacks, including phishing campaigns, denial-of-service attacks, and ransomware scenarios, to test its response protocols and improve its incident response time.

Outcome and Benefits

1. **Regulatory Compliance:**
 - By aligning the cybersecurity function with SAMA's Cybersecurity Framework, Saudi FinCorp ensured full compliance with national regulations, minimizing the risk of non-compliance penalties while enhancing its reputation as a secure financial institution.
2. **Enhanced Cybersecurity Resilience:**
 - With a dedicated cybersecurity function, a full-time leadership team, and advanced technologies, Saudi FinCorp significantly strengthened its ability to prevent, detect, and respond to emerging cybersecurity threats.
3. **Risk Management Excellence:**
 - Through the Cybersecurity Steering Committee and robust risk management practices, Saudi FinCorp proactively identified risks to its financial systems and mitigated them effectively, ensuring the continuity of operations and customer trust.
4. **Developing Local Cybersecurity Talent:**
 - By prioritizing the recruitment and development of Saudi cybersecurity professionals, Saudi FinCorp contributed to the Vision 2030 initiative to enhance local talent and reduce dependency on foreign expertise in critical technology domains.
5. **Operational Efficiency and Customer Trust:**
 - With a strong cybersecurity posture, Saudi FinCorp enhanced its operational efficiency and gained customer trust by ensuring the safety and security of financial transactions, which led to increased customer satisfaction and loyalty.

1.3 Cybersecurity Policies and Procedures:

Definitions:

Cybersecurity Policy: is a formal, high-level document that outlines an organization's approach to managing and securing its information technology (IT) systems and data. It establishes the principles, responsibilities, and expectations regarding the protection of information assets against cyber threats. Cybersecurity policies are typically broad, strategic, and aligned with the organization's business objectives [7].

Cybersecurity Procedure: is a detailed, step-by-step set of instructions or processes that describe how to carry out specific tasks or activities related to cybersecurity. Procedures are more tactical than policies and ensure consistent implementation of cybersecurity controls and practices across the organization [8].

Cybersecurity Standard: is a set of mandatory rules and technical requirements that define the specific criteria and expectations for cybersecurity controls and systems. Standards are typically established to ensure compliance with regulatory or industry requirements and to ensure consistent, measurable security practices across the organization [8].

Cybersecurity Guideline: provides best practices, recommendations, or advice for achieving security objectives. Guidelines are typically not mandatory but offer practical suggestions for how to comply with policies, procedures, and standards. They serve as helpful advice for achieving security goals while allowing for flexibility in implementation [9].

Minimum Baseline Security Standard: is the lowest acceptable level of security controls and protections that an organization must implement to ensure the safety and integrity of its information systems and data. These standards are meant to serve as the foundation for securing IT assets and must be met by all systems, applications, and networks within the organization [10].

Objective:

To ensure that cybersecurity requirements are documented, communicated and complied with by the organization as per related laws and regulations, and organizational requirements.

Controls Matrix:

Below is a summary matrix detailing relevant Cybersecurity Policies and Procedures controls based on NCA, SAMA CSF, CST CRF, and CMA Cybersecurity guidelines:

Regulation	Main Controls	Control References
NCA ECC	4	1.3.1, 1.3.2, 1.3.3, 1.3.4
SAMA CSF	1	3.1.3 (5 Sub controls)
CST CRF	-	-

CMA Cybersecurity Guidelines	1	4.1.3 (4 Sub controls)
NCA CSCC	-	-
NCA CCC CST	-	-
NCA CCC CSP	-	-
NCA TCC	1	1.1.1 (1 Sub control)
NCA DCC	-	-
NCA OSMACC	1	1.1.1 (1 Sub control)
NCA OTCC	3	1.1.1, 1.1.2, 1.1.3

Cybersecurity Policies and Procedures Controls:

Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines:	
ECC					
1.3.1		Cybersecurity policies and procedures must be defined and documented by the cybersecurity function, approved by the Authorizing Official, and disseminated to relevant parties inside and outside the organization.	All policies, procedures, and standard controls templates included within NCA's cybersecurity toolkit.	- Define and document cybersecurity requirements in cybersecurity policies, procedures, and standard controls, and approve them by the organization's representative based on the authority matrix approved by the organization. - Ensure the communication of policies and procedures to the organization's personnel and internal and external stakeholders. Such communication must be done through the approved communication channels as per the scope specified in the policy (e.g., publishing policies and procedures through the organizations internal portal, or publishing policies and procedures by e-mail.	- All cybersecurity policies, procedures, and standard controls documented and approved by the organization's representative or his/her deputy. - Communicate cybersecurity policies, procedures, and standard controls to personnel and stakeholders.
1.3.2		The cybersecurity function must ensure that the cybersecurity policies and procedures are implemented.	- A template of personnel acknowledgment and approval to follow the cybersecurity policies. - A template of personnel acknowledgment and approval to maintain	Develop an action plan to implement cybersecurity policies, procedures, and standard controls. Such plan must include all internal and external stakeholders, to whom the organizations policies, procedures, and standard controls apply. Such stakeholders must be followed up and monitored periodically to ensure the	- An action plan to implement the cybersecurity policies and procedures of the organization. - A report that outlines the review of the implementation of cybersecurity policies and procedures.

			information confidentiality.	full and effective implementation of all requirements. • The cybersecurity function must ensure the implementation of cybersecurity controls and adherence to the approved and documented cybersecurity policies, procedures, and standard controls. • Ensure the implementation of cybersecurity policies, procedures, and standard controls, including controls and requirements, manually or electronically (automated).	
1.3.3		The cybersecurity policies and procedures must be supported by technical security standards (e.g., operating systems, databases and firewall technical security standards).	• A template of all standard controls included in cybersecurity tools.	• Define, document, and approve technical standard controls to cover the organization's information and technology assets (e.g., firewall technical security standard controls, network devices, databases, server operating systems, BYOD operating systems, secure development standard, cryptography standard, etc.). • Communicate the technical standard controls to the relevant departments in the organization (e.g., IT department) and ensure that they are applied periodically to information and technology assets.	• The organization's approved technical cybersecurity standard controls documents.
1.3.4		The Cybersecurity policies and procedures must be reviewed periodically according to planned intervals or upon changes to related laws and regulations. Changes and reviews must be approved and documented.		• Review the cybersecurity policies, procedures, and standard controls in the organization periodically according to a documented and approved plan for review and based on a period specified in the policy (e.g., periodic review must be conducted annually). • Review and update the cybersecurity policies, procedures, and standard	• An approved document that defines the review schedule. • An approved document that clarifies the review of cybersecurity policies, procedures and standard controls in

				controls in the organization in the event of changes in the relevant laws and regulations (for example, when a new cybersecurity law is issued that applies to the organization. Document the review and changes to the cybersecurity policies, procedures, and standard controls and approve them by the head of the organization or his/her deputy.	the organization on a periodic basis based on the period of time set for review. - Policies, procedures, and standard controls documents indicating that they have been reviewed and updated, and that changes have been documented and approved by the representative. - Official approval and approval by the representative on updated policies, procedures, and standard controls.
NCA CCCC					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines:	Expected deliverables
N/A				•	•
NCA OSMACC					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines:	Expected deliverables
1.1.1	1.1.1.1	Referring to control 1-3-1 in the ECC, cybersecurity policies and procedures must include the following:	Template for Cybersecurity Documentation	Define and document the cybersecurity requirements for the social media accounts as part of organizations' cybersecurity policies.	Document containing cybersecurity requirements for social media accounts

		1-1-1-1 Defining and documenting the cybersecurity requirements for organizations social media accounts as part of the organization's cybersecurity policies.	Development Procedure	Ensure the document is disseminated to all personnel within the organization and relevant external parties through approved communication channels, as per the scope defined in the policy (eg., distributing policies and procedures via the organization's internal portal or sending them through email).	requirements approved by the authorizing official. Ensuring compliance with the document in addition to disseminating it to employees and relevant parties.
NCA TCC					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
1.1.1	1.1.1.1	Referring to control 1-3-1 in the ECC, cybersecurity policies and procedures must cover, at a minimum, the following: 1-1-1-1 Defining and documenting the telework cybersecurity requirements and controls as part of the organization's cybersecurity policies.	Procedure for Development of Cybersecurity Documents Template	- Develop and document cybersecurity policies for telework, which may include, but is not limited to: - Assess cybersecurity risks of telework systems, at least once a year. - Assess cybersecurity risks when planning and before allowing telework for any service or system. - Include cybersecurity risks related to telework systems, services, and systems allowed to work remotely, in the entity's cybersecurity risk register, and follow up on it at least once a year. - Secure usage and protection of devices designated for telework. - Secure handling of login ID's and passwords. - Protecting data that is saved on devices used for telework and handling it according to its classification and the entity's procedures and policies.	- A document demonstrating the cybersecurity requirements for telework approved by the entity in line with basic cybersecurity controls. (For example: electronic copy or official hard copy). - Official approval by the head of the entity or his representative on the requirements (For example: via the entity's official e-mail, or by paper or electronic signature).

				○ Secure handling of applications and solutions used for telework, such as virtual meetings, collaboration and file sharing. ○ Secure handling of home networks and ensuring their protection settings. ○ Avoid working remotely using unreliable public devices or networks or while in public places. ○ Avoid unauthorized physical access, loss, theft and vandalism of technical assets and telework systems. ○ Communicate directly with the department concerned with cybersecurity in the entity if a cybersecurity threat is suspected. ○ Training workers on the technical skills necessary to ensure the application of cybersecurity requirements and practices when dealing with telework systems. ● Ensure that the entity's requirements are supported by executive management. This is through the approval of the head of the entity or their representative.	
NCA OTCC					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
1.1.1		With reference to the ECC controls 1-3-1 and 1-3-2, the organization must document, approve, and implement	● Procedure for Development of Cybersecurity Documents Template	● Identify the OT/ICS cybersecurity requirements, and document them in the cybersecurity policies, standards, and procedures specified OT/ICS. So that they are approved by the authorized person in the organization	● OT/ICS cybersecurity policies, standards, and procedures are all documented and approved by the authorized personnel

		a customized set of cybersecurity policies and procedures for OT/ICS systems or assets.	• Cybersecurity Policy for Operational Technology Template	based on the approved authority guide within the organization. • Ensure that policies and procedures are communicated through the approved communication channels according to the scope specified in the policy to internal and external personnel (employees and contractors). • Develop and monitor periodically an action plan to implement OT/ICS cybersecurity policies and procedures that cover all internal and external personnel (employees and contractors) to ensure that all requirements are fully and effectively implemented. • The Cybersecurity department shall ensure that cybersecurity controls are implemented, and that documented and approved policies and procedures are adhered to.	within the organization or their delegate. • Confirmation that the organization is publishing policies, standards, and procedures specific to the O'T/ICS for employees and relevant parties.
1.1.2		With reference to the ECC control 1-3-3, the cybersecurity OT/ICS policies and procedures must be supported by cybersecurity requirements such as vendor recommendations, implementation guidelines, and configuration management guidelines.	• Operational Technology/Industrial Control Systems (OT/ICS) Security Standard Template • Cybersecurity Policy for Operational Technology Template	• Identify, document, and adopt technical standards to cover the assets related to OT/ICS within the organization (eg., vendor recommendations, implementation guidelines, and configuration management guidelines, etc...) • Disseminate technical standards to relevant departments within the organization (e.g., the department responsible for operational systems in the facility) and ensuring their periodic implementation on assets related to OT/ICS.	• Documents of cybersecurity standards specific to OT/ICS adopted within the organization. • Evidence confirming the implementation of cybersecurity policies and procedures specific to OT/ICS within the organization.

1.1.3		With reference to the ECC control 1-3-4, OT/ICS cybersecurity policies and procedures must be reviewed periodically and/or when there is a change in the risks landscape, organizational structure, and/or process changes.	Cybersecurity Policy for Operational Technology Template	- Review the OT/ICS cybersecurity policies, procedures and standards in the organization periodically based on defined frequency In the policy document (c.g., conduct the periodical review every year). - Review and update the OT/ICS cybersecurity policies, procedures and standards in the case of changes in related laws and regulations (e.g., when new legislative cybersecurity framework that applies to the organization is issued). - Review and update the OT/ICS cybersecurity policies, procedures and standards when changes occur that effect the security and safety of OT/ICS (c.g., changes in the level or nature of risks or in operational processes and procedures). - Document the review and changes to the OT/ICS cybersecurity policies, procedures and standards in the organization and obtaining approval from the head of the organization or his/her delegate.	- A certified document that specifies the review schedule. - Approved document of OT/ICS policies, procedures and standards, which show that they have been reviewed periodically based on the specified time frame for the review. - Policy, procedure, and standard document that outlines the review, update, documentation changes, and approval by the authorized personnel. - Official approval and endorsement by the authorized personnel of the updated policies, procedures, and standards
NCA DCC					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
N/A					
NCA CCC CST					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables

N/A					
NCA CCC CSP					
N/A					
SAMA CSF					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
3.1.3	3.1.3-1	The cyber security policy should be defined, approved and communicated.			
	3.1.3-2	The cyber security policy should be reviewed periodically according to a predefined and structured review process.			
	3.1.3-3.d	d. communicated to relevant stakeholders.			
	3.1.3-3.a-c	The cyber security policy should be: a. considered as input for other corporate policies of the Member Organization (e.g., HR policy, finance policy and IT policy);b. supported by detailed security standards (e.g., password standard, firewall standard) and procedures;c. based on best practices and (inter)national standards;			
	3.1.3-4	The cyber security policy should include: a. a definition of cyber security; b. the Member Organization's overall cyber			

		security objectives and scope;c. a statement of the board's intent, supporting the cyber security objectives; d. a definition of general and specific responsibilities for cyber security;e. the reference to supporting cyber security standards and procedures;f. cyber security requirements that ensure: 1. information is classified in a way that indicates its importance to the Member Organization; 2. information is protected in terms of cyber security requirements, in line with the risk appetite; 3. owners are appointed for all information assets; 4. cyber security risk assessments are conducted for information assets; 5. relevant stakeholders are made aware of cyber security and their expected behavior (cyber security awareness program); 6. compliance with regulatory and contractual obligations are being met; 7. cyber security breaches and suspected cyber security weaknesses are reported; 8. cyber security is reflected			
--	--	---	--	--	--

		in business continuity management.			
CST CRF					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
CMA Cybersecurity Guidelines					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
4.1.3	4.1.3.4	Set out, document, implement and approve cybersecurity strategy and policies, circulate the same to related parties, and ensure compliance therewith.			
	4.1.3.5	Review cybersecurity policies periodically in accordance with pre-defined review plan.			
	4.1.3.6	Support cybersecurity policies with detailed security technical standards (e.g., passcode and firewall standards) to be based on local and international best practices and standards.			
	4.1.3.7	Cybersecurity policies shall include the following: • Definition of cybersecurity. • The scope and objectives of the capital market institution cybersecurity.			

		• Support of senior management to cybersecurity program and objectives. • Identification of cybersecurity responsibilities and roles. Indication of the reference of applicable cybersecurity standards. • Cybersecurity controls shall include the following: ○ Classifying information in a way that demonstrates its importance to a market institution. ○ Defining ownership of all information assets. ○ Evaluating cybersecurity risks of information assets. ○ Making staff aware of cybersecurity. ○ Complying with agreements as well as regulatory and contractual obligations. ○ Reporting cybersecurity violations and suspected security vulnerabilities ○ Applying cybersecurity requirements to Business Continuity Management			
--	--	--	--	--	--

Risk Considerations in Cybersecurity Policies and Procedures

Inadequate Coverage of Emerging Cyber Threats

- **Risk Description:** Policies may fail to address new or evolving cyber threats and vulnerabilities, making the organization susceptible to future attacks.
- **Risk Mitigation:** Regularly update policies to reflect new cybersecurity risks, trends, and vulnerabilities through threat intelligence feeds, expert reviews, and collaboration with cybersecurity vendors.

Lack of Stakeholder Buy-in

- **Risk Description:** Without proper involvement from key stakeholders, policies may not be adopted or followed effectively across the organization.
- **Risk Mitigation:** Involve executives, department heads, and relevant stakeholders during the policy creation process, ensuring alignment with business goals and compliance requirements.

Ambiguity and Lack of Clarity in Procedures

- **Risk Description:** Poorly defined or ambiguous procedures can lead to inconsistent implementation and compliance, leaving security gaps.
- **Risk Mitigation:** Ensure that policies and procedures are clearly written, easy to follow, and aligned with best practices. Regularly review and update them for clarity.

Resistance to Change

- **Risk Description:** Employees may resist new policies, especially if they are seen as disruptive to daily operations or if they require significant changes to workflows.
- **Risk Mitigation:** Communicate the importance of the policies, provide training, and involve leadership in promoting the policies as part of the organization's culture.

Lack of Ongoing Monitoring and Enforcement

- **Risk Description:** Policies may be ineffective if not regularly monitored and enforced, allowing security risks to go unnoticed.
- **Risk Mitigation:** Establish a continuous monitoring process, assign responsibilities for enforcement, and implement automated tools to track compliance.

Examples of Technologies for Effective Cybersecurity Policies and Procedures

- **Governance, Risk, and Compliance (GRC) Platforms**

Example Tools: OpenGRC (based on OpenControl), Eramba, Ory KETO

Purpose: Enable policy lifecycle management, risk assessment, compliance mapping, and audit tracking aligned with security frameworks.

- **Document Management Systems**

Example Tools: Nextcloud, ONLYOFFICE, Documize

Purpose: Provide secure, collaborative environments for managing policy documents with version control and access control.

- **Policy Authoring Tools**

Example Tools: OSCAL (NIST's Open Security Controls Assessment Language), Markdown editors + Git (for versioned policies), OpenPolicyAgent (OPA)

Purpose: Support automated, codified policy checks and structured policy definitions for infrastructure compliance.

- **Collaboration & Workflow Tools**

Example Tools: Mattermost, Rocket.Chat, Draw.io (open-source fork), Penpot

Purpose: Facilitate collaborative policy development and visualization of workflows through diagrams and team communication.

Examples of KPIs for Cybersecurity Policies and Procedures

1. **Policy Adoption Rate:** Percentage of cybersecurity policies adopted by departments within the organization.
2. **Compliance Rate:** Percentage of cybersecurity controls and practices in alignment with documented policies and procedures.
3. **Policy Review Cycle Compliance:** Percentage of policies reviewed and updated within the stipulated review period (e.g., annually).
4. **Policy Violation Rate:** Number of incidents or violations of cybersecurity policies (e.g., improper access, unpatched systems).
5. **Incident Response Time:** Average time between detection of a policy violation and resolution of the issue.

Case Study : Building Cybersecurity Policies and Procedures for a Saudi Entity

Background:

A Saudi Entity , a key player in the national telecommunications infrastructure, recognized the increasing cyber threats targeting its network and customer data. Given its central role in connecting businesses, government entities, and millions of consumers, Saudi Entity faced a critical need to develop and implement robust cybersecurity policies and procedures. These policies would ensure the protection of customer data, secure telecom infrastructure, and compliance with both local regulations (such as those mandated by the Saudi National Cybersecurity Authority (NCA)) and international best practices.

Saudi Entity aimed to create a formalized cybersecurity governance structure that would define its cybersecurity policies, provide clear procedures for implementation, and integrate technical security standards to protect its infrastructure. Additionally, the cybersecurity policies and procedures would need to be regularly reviewed and updated in line with evolving cybersecurity risks, technological changes, and regulatory developments.

Phase 1: Defining Cybersecurity Policies and Procedures

1. Establishing the Cybersecurity Function

- **Objective:** The first step in building the cybersecurity framework at Saudi Entity was the establishment of a dedicated cybersecurity function separate from the IT operations department. This function was responsible for developing, implementing, and maintaining cybersecurity policies, procedures, and standards.
- **Cybersecurity Team Composition:** The team was led by the Chief Information Security Officer (CISO) and included specialists in areas such as network security, incident response, data protection, compliance, and technical standards. The team's primary goal was to ensure that cybersecurity was managed strategically, with a focus on risk management, regulatory compliance, and incident prevention.
- **Stakeholder Engagement:** The CISO worked closely with the company's leadership team, legal department, and operational units to understand their unique security needs, risks, and compliance requirements.

2. Cybersecurity Policy Development

Saudi Entity's cybersecurity policies were developed to address the specific needs and challenges of a telecommunications entity, which includes protecting sensitive customer data, securing telecommunications infrastructure, and complying with both national and international regulations.

- **Key Cybersecurity Policies:**
 - **Information Security Policy:** Establishes the framework for securing all types of data, including customer information, call records, and network traffic.
 - **Network Security Policy:** Focuses on securing the company's telecom network infrastructure, including protection against DDoS attacks, unauthorized access, and vulnerabilities in hardware and software components.
 - **Data Protection Policy:** Defines how personal and sensitive data, such as customer details and communication records, should be stored, processed, and transmitted in compliance with Saudi Data Protection Regulations.

- Access Control Policy: Details the rules for granting, managing, and terminating user access to Saudi Entity's systems, ensuring that only authorized personnel can access critical telecom resources and data.
- Incident Response Policy: Specifies the procedures for handling cybersecurity incidents, including detection, response, and reporting protocols for various types of incidents such as breaches, data leaks, and service disruptions.
- Compliance Policy: Ensures that Saudi Entity adheres to local and international cybersecurity regulations, including NCA guidelines, SAMA regulations (if applicable), GDPR (for European customers), and ISO 27001 standards.

3. Developing Cybersecurity Procedures and Technical Standards

Alongside the high-level policies, detailed procedures and technical security standards were developed to provide actionable steps for the implementation and enforcement of the policies.

- Cybersecurity Procedures:
 - Data Encryption Procedures: Defines how encryption should be implemented across telecom systems, including mobile networks and internet services, ensuring the protection of customer data in transit and at rest.
 - Patch Management Procedures: Describes the steps for ensuring that vulnerabilities in the network infrastructure, operating systems, and software applications are identified, prioritized, and patched promptly.
 - Incident Management Procedures: Outlines the steps to follow in the event of a security breach or incident, including incident classification, containment, mitigation, and reporting to stakeholders and regulatory authorities.
 - Access Control Procedures: Specifies how user access to sensitive systems will be controlled using multi-factor authentication (MFA), role-based access controls (RBAC), and regular audits.
- Technical Security Standards:
 - Network Security Standards: Sets technical requirements for securing network devices such as routers, firewalls, and intrusion detection/prevention systems (IDS/IPS). This includes specifications for network segmentation, firewall rules, and traffic filtering.
 - Operating Systems Security Standards: Defines security settings for operating systems (e.g., Windows Server, Linux) used across the organization, including patch management, secure configuration, and system hardening.
 - Database Security Standards: Outlines security measures for databases, such as encryption, access control, backup procedures, and audit logging, to protect sensitive customer data and transactional records.
 - Endpoint Security Standards: Provides guidelines for securing endpoints like employee laptops, mobile devices, and telecom infrastructure equipment against malware, ransomware, and unauthorized access.

Phase 2: Review and Approval Process

1. Policy and Procedure Review

- Objective: To ensure the policies, procedures, and technical standards were aligned with organizational goals, regulatory requirements, and international best practices, Saudi Entity established a formal review and approval process.

- **Internal Review:** All policies and procedures were initially reviewed by a cross-functional team consisting of senior leadership, legal and compliance officers, IT security teams, and risk management specialists. This step ensured that the policies would be applicable across all relevant departments while addressing the unique cybersecurity risks of a telecom entity.
- **Approval by the Authorizing Official:** After the internal review, the policies were submitted to the Authorizing Official (usually the CEO or CIO) for formal approval. This approval process was documented and included:
 - A signed approval document confirming the acceptance of the policies and procedures.
 - Detailed records of any revisions made during the review process.

Phase 3: Dissemination and Implementation

1. Communicating Policies and Procedures

- **Objective:** To ensure compliance across the organization, the cybersecurity policies and procedures were disseminated to all employees, contractors, third-party vendors, and other relevant stakeholders.
- **Internal Communication:**
 - **Training Programs:** All employees were required to complete cybersecurity awareness training to familiarize them with the new policies and procedures. This training included regular refresher courses to ensure ongoing compliance.
 - **Intranet Portal:** The finalized policies, procedures, and technical standards were made available on the company's intranet for easy access and reference by all staff members.
 - **Departmental Workshops:** Specialized workshops were held for departments such as IT, customer service, and legal to ensure that each team understood the policies and their role in enforcing them.
- **External Communication:**
 - **Third-Party Vendor Agreements:** Saudi Entity worked with key vendors and partners to ensure that they were aligned with the company's cybersecurity policies, especially regarding data protection and incident reporting. Vendors were required to sign cybersecurity agreements ensuring compliance with Saudi Entity's standards.
 - **Customer Communication:** Saudi Entity communicated with its customers regarding its cybersecurity practices, particularly around data protection and incident management, to ensure customer trust and transparency.

2. Action Plan for Implementation

- **Objective:** The implementation of the cybersecurity policies and procedures required a detailed action plan that outlined the specific steps, timeline, and resources required for successful execution.
- **Action Plan Components:**
 - **Timeline:** A clear timeline with milestones for implementing key cybersecurity procedures, such as patch management, user access control, and data encryption.
 - **Resource Allocation:** Identification of the resources (e.g., personnel, budget, tools) needed for implementation, with a focus on addressing critical vulnerabilities first.
 - **Accountability:** Designation of responsible departments and individuals for each part of the implementation process.

- Monitoring and Reporting: The cybersecurity function was tasked with monitoring the implementation of policies and procedures and reporting on progress to the executive team on a quarterly basis.
- Implementation of Technical Controls: IT and security teams worked to deploy technical security standards across all systems and devices, including routers, firewalls, servers, and mobile devices.

Phase 4: Review and Ongoing Maintenance

1. Periodic Review and Updates

- Objective: The cybersecurity policies, procedures, and technical standards were subject to periodic review to ensure that they remained effective and aligned with evolving threats and regulations.
- Review Schedule: Saudi Entity developed a review schedule outlining the timeline for periodic reviews (e.g., every six months or as necessary). These reviews would ensure that the policies remained current and effective.
- Review Process:
 - The cybersecurity team would conduct a comprehensive review of all policies and procedures, assess their effectiveness, and identify any areas for improvement or adjustment.
 - Feedback from stakeholders, including department heads, IT security staff, and external partners, would be incorporated into the review process.
 - Regulatory Changes: Any updates to Saudi NCA regulations or global standards (e.g., GDPR, ISO 27001) would trigger a review of relevant policies.

2. Documenting Changes and Approvals

- Change Management Process:
 - Any changes made to the policies, procedures, or technical standards were documented, including the rationale for the changes, specific updates, and approval from the Authorizing Official.
 - The updated documents were then communicated to all stakeholders, ensuring that everyone was aware of the changes and their implications.

Expected Deliverables:

1. Cybersecurity Policies, Procedures, and Technical Standards Document:
 - All policies, procedures, and technical standards were documented and approved by the Authorizing Official.
2. Communication of Policies and Procedures:
 - Cybersecurity policies were disseminated to all relevant internal and external stakeholders, with training and workshops to ensure compliance.
3. Action Plan for Implementation:
 - A clear action plan was created, specifying the timeline, resources, and accountability for implementing the policies and procedures.
4. Periodic Review Reports:
 - Regular review reports were generated to track the progress of policy implementation and identify areas for improvement.
5. Approved Technical Security Standards:

- The final technical security standards for network infrastructure, operating systems, databases, and endpoints were approved.
6. Review Schedule and Documentation:
- An approved review schedule was established, ensuring that cybersecurity policies and procedures would be periodically updated to address new threats and regulatory changes.
7. Approval Documentation:
- All updates to policies, procedures, and technical standards were formally approved by the Authorizing Official and communicated across the organization.

1.4 Cybersecurity Roles and Responsibilities:

Definition: Cybersecurity roles and responsibilities refer to the formalized assignment of tasks, duties, and obligations within an organization related to protecting its information systems and assets from cyber threats. These roles are outlined to ensure accountability, clarity, and effective execution of cybersecurity tasks across all levels of the organization. The responsibilities cover the entire spectrum of cybersecurity activities, from governance and policy enforcement to technical operations and incident response [11], [12], [13].

Objective:

To ensure that roles and responsibilities are defined for all parties participating in implementing the cybersecurity controls within the organization.

Controls Matrix:

Below is a summary matrix detailing relevant Cybersecurity Roles and Responsibilities controls based on NCA, SAMA CSF, CST CRF, and CMA Cybersecurity guidelines:

Regulation	Main Controls	Control References
NCA ECC	2	1.4.1, 1.4.2
SAMA CSF	1	3.1.4 (6 Sub controls)
CST CRF	1	1.2.1
CMA Cybersecurity Guidelines	1	4.1.1 (5 Sub controls)
NCA CCCC	-	-
NCA CCC CST	1	1.1.T.1
NCA CCC CSP	1	1.1.P.1
NCA TCC	-	-
NCA DCC	-	-
NCA OSMACC	-	-
NCA OTCC	1	1.2.1 (2 Sub controls)

Cybersecurity Roles and Responsibilities Controls:

Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines:	Expected deliverables
ECC					
1.4.1		Cybersecurity organizational structure and related roles and responsibilities must be defined, documented, approved, supported and assigned by the Authorizing Official while ensuring that this does not result in a conflict of interest.	• Cybersecurity Roles and Responsibilities Template.	• Define and document cybersecurity roles and responsibilities and inform and ensure all parties involved in the implementation of cybersecurity controls at the organization of their responsibilities in implementing cybersecurity programs and requirements. • Support the organizational structure, roles, and responsibilities of the organization by the executive management This must be done through the approval of the representative. • Include the following roles and responsibilities (but not limited to) : ○ Roles and responsibilities related to the cybersecurity supervisory committee. ○ Roles and responsibilities related to the head of the cybersecurity function. ○ Roles and responsibilities related to the cybersecurity function (e.g., develop and update cybersecurity policies and standard controls, conduct cybersecurity risk assessment, conduct compliance checks on	• Cybersecurity Function Organizational Structure Document. • The organization's approved cybersecurity roles and responsibilities document (electronic copy or official hard copy). • A document that clarifies the assignment of cybersecurity roles and responsibilities to the organization's personnel.

				cybersecurity policies and legislation, monitor cybersecurity events, assess vulnerabilities, manage access, develop and implement cybersecurity awareness programs, etc.) ○ Roles and responsibilities related to cybersecurity for other departments in the organization (e.g., IT, personnel, physical security, etc.) ○ Cybersecurity roles and responsibilities for all personnel. ● Assign roles and responsibilities to the organization's personnel, taking into consideration the non-conflict of interests.	
1.4.2		The cybersecurity roles and responsibilities must be reviewed periodically according to planned intervals or upon changes to related laws and regulations.		● Review the cybersecurity roles and responsibilities in the organization periodically according to a documented and approved plan for review and based on a planned interval e.g., periodic review must be conducted annually). ● Review and update the cybersecurity roles and responsibilities in the organization in the event of changes in the relevant laws and regulations (for example, when a new cybersecurity law is issued that applies to the organization. ● Document the review and changes to the cybersecurity requirements related to cybersecurity roles and responsibilities and approve them by the representative.	● An approved document that defines the review schedule for the roles and responsibilities. ● Roles and responsibilities document indicating that they are up to date and the changes to the cybersecurity requirements for roles and responsibilities have been documented and approved by the representative.
NCA CCCC					

Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines:	Expected deliverables
N/A				•	•
NCA OSMACC					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines:	Expected deliverables
N/A					
NCA TCC					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
N/A					
NCA DCC					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
N/A					
NCA OTCC					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
1.2.1	1.2.1.1	In addition to the ECC subdomain 1-4, cybersecurity requirements for Cybersecurity Roles and Responsibilities in	• Template for Cybersecurity Roles and Responsibilities	• Controls implementation guidelines: • Identify and document cybersecurity roles and responsibilities related to OT/ICS in a (RACI) matrix, ensuring that all parties involved in implementing cybersecurity controls within the organization are aware of their	• Organizational Structure Document • The document containing the cybersecurity roles and responsibilities in a (RACI) matrix related

		OT/ICS must include, at a minimum, the following: 1-2-1-1 Cybersecurity roles and responsibilities (RACI) assignment for all stakeholders of the OT/ICS assets must be defined, documented, communicated and approved by the Authorizing Official while ensuring there is no conflict of interest.		responsibilities in implementing cybersecurity programs and requirements, while considering avoiding conflicts of interest. - Ensuring that the organizational structure, roles, and responsibilities within the organization are endorsed by the executive management, through the approval and endorsement of the authorized personnel. - Working to include the following roles and responsibilities (including but not limited to): - Roles and Responsibilities related to the head of the cybersecurity function. - Roles and Responsibilities related to the cybersecurity function (e.g., developing and updating cybersecurity policies and standards, conducting cybersecurity risk assessments, ensuring compliance with cybersecurity policies and legislations, monitoring cybersecurity events, vulnerability scanning, implementing cybersecurity awareness programs, etc.). - Roles and Responsibilities related to cybersecurity for other departments within the organization (e.g., the operation department, human resources department, industrial security department, etc.). - Roles and Responsibilities related to cybersecurity for all employees, contractors, and subcontractors.	to OT/ICS that is approved by the organization (hard or soft approved copies). Proof of disseminating cybersecurity roles and responsibilities document related to the organization.
	1.2.1.2	Cybersecurity roles and responsibilities related	Template for Cybersecurity Roles and Responsibilities	Assign clear ownership and accountability for OT/ICS cybersecurity related roles and responsibilities to the	Proof showing assigning clear ownership and

		to OT/ICS assets must be assigned to the cybersecurity function in the organization.		cybersecurity function, while ensuring there is no conflict of interest.	accountability for OT/ICS cybersecurity related roles and responsibilities to the cybersecurity function, while ensuring there is no conflict of interest.
NCA CCC CST					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
1.1.T.1		In addition to the ECC control 1-4-1, the Authorizing Official shall also identify, document and approve: 1-1-T-1-1 Cybersecurity roles and RACI assignment for all stakeholders of the cloud services including Authorizing Official's roles and responsibilities.	• Template for Cybersecurity Roles and Responsibilities	• Identify cloud services in use and related cybersecurity stakeholders both internal and external (e.g. CSPs and their Cybersecurity units, corporate Cloud Cybersecurity Architecture, Engineering, Operations teams, Cloud Security Managed Services representatives, Cloud Security SaaS representatives, Authorizing Office).	• Cloud Cybersecurity Roles and Responsibilities and RACI matrix defined and approved and documented within the related Service Level • Agreements (SLAs) between CSP and CSTs.
NCA CCC CSP					
1.1.P.1		In addition to the ECC control 1-4-1, the Authorizing Official shall also identify, document and approve the following: 1-1-P-1-1 Cybersecurity Roles and RACI assignment for all stakeholders of the cloud	• Template for Cybersecurity Roles and Responsibilities • Template for Cybersecurity Organizational Structure	• Identify cloud services (e.g. based on the Cloud Service portfolio) offered and related cybersecurity stakeholders both internal and external (e.g. Cloud Cybersecurity Architecture, Engineering, Operations teams, 3rd party Cloud Security Managed Services, Authorizing Office, CSTs, etc.).	• Cloud Cybersecurity Roles and Responsibilities and RACI matrix documented and approved within the related Service Level Agreements (SLAs) between CSP and CSTs.

		services including Authorizing Official's roles and responsibilities.			
SAMA CSF					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
3.1.4	3.1.4-1	The Board of Directors has the ultimate responsibility for cyber security, including:a. ensuring that sufficient budget for cyber security is allocated;b. approving the cyber security committee charter;c. endorsing (after being approved by the cyber security committee): 1. the cyber security governance; 2. the cyber security strategy; 3. the cyber security policy.			
3.1.4	3.1.4-2.a	The cyber security committee should be responsible for:a. monitoring, reviewing and communicating the Member Organization's cyber security risk appetite periodically or upon a material change in the risk appetite;			

	3.1.4-2.b	b. reviewing the cyber security strategy to ensure that it supports the Member Organization objectives;			
	3.1.4-2.c	c. approving, communicating, supporting and monitoring: 1. the cyber security governance; 2. the cyber security strategy; 3. the cyber security policy; 4. cyber security programs (e.g., awareness program, data classification program, data privacy, data leakage prevention, key cyber security improvements); 5. cyber security risk management process; 6. the key risk indicators (KRIs) and key performance indicators (KPIs) for cyber security.			
3.1.4	3.1.4-3.a	The senior management should be responsible for: a. ensuring that standards, processes and procedures reflect security requirements (if applicable);			
	3.1.4-3.b	b. ensuring that individuals accept and			

		comply with the cyber security policy, supporting standards and procedures when they are issued and updated;			
	3.1.4-3.c	c. ensuring that cyber security responsibilities are incorporated in the job descriptions of key positions and cyber security staff.			
3.1.4	3.1.4-4.a	The CISO should be responsible for:a. developing and maintaining: 1. cyber security strategy; 2. cyber security policy; 3. cyber security architecture; 4. cyber security risk management process.			
	3.1.4-4.b	b. ensuring that detailed security standards and procedures are established, approved and implemented;			
	3.1.4-4.c	c. delivering risk-based cyber security solutions that address people, process and technology;			
	3.1.4-4.d	d. developing the cyber security staff to deliver cyber security solutions in a business context;			
	3.1.4-4.e	e. the cyber security activities across the			

		Member Organization, including: 1. monitoring of the cyber security activities (SOC monitoring); 2. monitoring of compliance with cyber security regulations, policies, standards and procedures; 3. overseeing the investigation of cyber security incidents; 4. gathering and analyzing threat intelligence from internal and external sources; 5. performing cyber security reviews;			
	3.1.4-4.f	f. conducting cyber security risk assessments on the Members Organization's information assets;			
	3.1.4-4.g	g. proactively supporting other functions on cyber security, including: 1. performing information and system classifications; 2. determining cyber security requirements for important projects; 3. performing cyber security reviews.			
	3.1.4-4.h	h. defining and conducting the cyber			

		security awareness programs;			
	3.1.4-4.i	i. measuring and reporting the KRIs and KPIs on: 1. cyber security strategy; 2. cyber security policy compliance; 3. cyber security standards and procedures; 4. cyber security programs (e.g., awareness program, data classification program, key cyber security improvements).			
3.1.4	3.1.4-5	The internal audit function should be responsible for: a. performing cyber security audits.			
3.1.4	3.1.4-6	All Member Organization's staff should be responsible for: a. complying with cyber security policy, standards and procedures.			
CST CRF					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
1.2.1		Allocating roles and responsibilities ensuring that the conflicting			

		duties and areas of responsibilities are clearly segregated			
CMA Cybersecurity Guidelines					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
4.1.1.8	4.1.1.8.1	Responsibilities of cybersecurity committee include: Monitor, review and report market institution's cybersecurity risks appetite periodically or in case of substantial change regarding risk appetite;			
	4.1.1.8.2	Periodic review of cybersecurity strategy to ensure being in support of the market institution's objectives;			
	4.1.1.8.3	Adopt and provide necessary support and oversight on: • Cybersecurity Governance; • Cybersecurity Strategy; • Cybersecurity Policies; • Cybersecurity Programs (such as awareness programs, data classification program, data			

		privacy and data breach prevention); • Cybersecurity Risk Management; and • Cybersecurity Key Risk Indicators and KPIs			
4.1.1.9	4.1.1.9.1	Responsibilities of Market Institution's BOD include, in addition to the above-mentioned, the following: Ensure that standards and procedures reflect cybersecurity requirements;			
	4.1.1.9.2	Ensure that staff accept and comply with cybersecurity policies, and support standards and procedures when issuing and updating the same; and			
	4.1.1.9.3	Ensure that cybersecurity responsibilities are included in job descriptions of relevant positions and cybersecurity positions.			
4.1.1.10	4.1.1.10.1	Responsibilities of Cybersecurity Head of Cybersecurity department include: Submit to cybersecurity committee any development and update of:			

		• Cybersecurity Strategy; • Cybersecurity Policies; • Cybersecurity Structure; and • Cybersecurity Risk Management.			
	4.1.1.10.2	Ensure that cybersecurity standards and procedures are identified, documented, approved and implemented;			
	4.1.1.10.3	Ensure development and training of cybersecurity personnel			
	4.1.1.10.4	Monitor cybersecurity activities (Monitor Security Operations Center);			
	4.1.1.10.5	Monitor compliance with cybersecurity policies, standards and procedures;			
	4.1.1.10.6	Oversee investigation of cybersecurity incidents;			
	4.1.1.10.7	Obtain and deal with proactive information (Threat Intelligence);			
	4.1.1.10.8	Review and audit cybersecurity program			
	4.1.1.10.9	Effective support for other cybersecurity-related positions, including:			

		• Classifying systems and information; • Defining cybersecurity controls for important projects; • and Reviewing cybersecurity controls.			
	4.1.1.10.10	Develop and implement cybersecurity awareness programs			
	4.1.1.10.11	Measure and report key risk indicators and KPIs on: • Cybersecurity strategy; • Compliance with cybersecurity policies; • Cybersecurity standards and procedures; and • Cybersecurity programs (Such as awareness programs and data classification program).			
4.1.1.11		Responsibility of internal audit in market institution is to conduct a review and audit of cybersecurity controls. Such audit shall be on periodical basis with			

		taking the non-conflict of interest principle into the consideration.			
4.1.1.12		All market institution's personnel are responsible for complying with cybersecurity policies, standards and procedures.			

Risk Considerations in Cybersecurity Roles and Responsibilities

1- Role Ambiguity

- **Risk Description:** Unclear roles and responsibilities may lead to confusion, duplication of efforts, or critical gaps in cybersecurity coverage.
- **Risk Mitigation:** Define roles with clear, specific responsibilities and ensure that each role is aligned with the organization's cybersecurity objectives.

2- Conflicts of Interest

- **Risk Description:** Assigning conflicting responsibilities (e.g., security and IT operations) may lead to biases and inadequate security controls.
- **Risk Mitigation:** Ensure that roles are clearly segregated and independent. Implement checks and balances to reduce the likelihood of conflicts.

3- Insufficient Training and Skillsets for Assigned Roles

- **Risk Description:** Personnel assigned to cybersecurity roles may lack the necessary expertise, leading to subpar performance and missed threats.
- **Risk Mitigation:** Invest in role-specific training and certifications, and ensure ongoing professional development to enhance competency.

4- Overlapping Responsibilities and Accountability Gaps

- **Risk Description:** Having overlapping responsibilities can lead to missed duties, while lack of clear accountability can make it difficult to identify who is responsible for key tasks.
- **Risk Mitigation:** Clearly define and document roles and responsibilities with proper segregation of duties, and assign specific accountability for each task.

5- Lack of Flexibility in Role Adaptation

- **Risk Description:** Roles that are too rigid may hinder the ability to adapt to evolving cybersecurity threats and organizational needs.
- **Risk Mitigation:** Regularly review and update roles to ensure they are flexible enough to meet new challenges and strategic goals.

Examples of Technologies for Effective Cybersecurity Roles and Responsibilities

- **Identity and Access Management (IAM) Tools**

Example Tools: Keycloak, Authentik, Authelia

Purpose: Manage users, enforce role-based access control (RBAC), and define authentication and authorization policies across applications.

- **Human Resources Management Systems (HRMS)**

Example Tools: OrangeHRM, Sentrifugo

Purpose: Manage employee data, roles, and responsibilities with integration capabilities for access control and cybersecurity responsibility tracking.

- **Role Management Tools**

Example Tools: OpenIAM (Community Edition), MidPoint (by Evolveum)

Purpose: Define roles, enforce access policies, support identity governance, and maintain role-based segregation of duties.

- **Project Management Tools**

Example Tools: Taiga, Redmine, Kanboard

Purpose: Track task ownership, role-based responsibilities, and project workflows in cybersecurity and IT operations.

Examples of KPIs for Cybersecurity Roles and Responsibilities

1. **Role Clarity Rate:** Percentage of employees with clearly defined and communicated cybersecurity roles and responsibilities.
2. **Access Control Compliance:** Percentage of employees with access to critical systems whose access rights align with their defined roles.
3. **Role-Based Training Completion Rate:** Percentage of employees with cybersecurity training relevant to their roles completed.
4. **Segregation of Duties (SoD) Compliance:** Percentage of roles that have segregated duties to avoid conflicts of interest and ensure checks and balances.
5. **Incident Responsibility Assignment Rate:** Percentage of incidents where roles and responsibilities were assigned clearly and adhered to during incident resolution.

Case Study : Developing and Implementing Cybersecurity Roles and Responsibilities for a Saudi Entity

Background:

A Saudi Entity , providing critical communication infrastructure to millions of customers and businesses, faced increasing pressure to strengthen its cybersecurity posture. Telecom networks are highly attractive targets for cyberattacks, and Saudi Entity recognized the need for a comprehensive framework that would define and implement cybersecurity roles and responsibilities across its entire organization.

The goal was to ensure that each department understood its role in supporting cybersecurity and that the Cybersecurity Function was adequately supported by all parts of the organization, from leadership to operational teams.

Phase 1: Defining Cybersecurity Roles and Responsibilities

1. Cybersecurity Organizational Structure

The first step was to define a clear cybersecurity organizational structure, ensuring that no conflicts of interest occurred and that all teams were adequately resourced to meet cybersecurity needs.

2. Roles and Responsibilities of the Cybersecurity Supervisory Committee

The Cybersecurity Supervisory Committee (CSC) in Saudi Entity was a high-level body consisting of senior executives across departments such as Risk Management, Legal, Compliance, and IT.

- Committee Chairperson: Likely the Chief Information Officer (CIO) or another senior leader.
- Committee Responsibilities:
 - Approving cybersecurity policies and strategies.
 - Allocating resources for cybersecurity initiatives.
 - Overseeing regulatory compliance related to cybersecurity.
 - Reviewing major cybersecurity incidents and proposing corrective actions.

3. Roles and Responsibilities of the Head of the Cybersecurity Function (CISO)

The CISO was responsible for leading Saudi Entity's cybersecurity function, directly reporting to the CEO or CIO to ensure a high level of attention to cybersecurity.

- CISO Responsibilities:
 - Developing and implementing security strategies.
 - Overseeing the cybersecurity team and operations.
 - Managing the organization's response to cyber incidents and data breaches.
 - Reporting on cybersecurity performance and risks to the Cybersecurity Supervisory Committee.

4. Roles and Responsibilities of Other Departments

Key departments, such as IT, Human Resources, and Physical Security, had specific cybersecurity duties:

- IT: Responsible for securing Saudi Entity's IT infrastructure, including network, servers, and devices.
- HR: Ensuring personnel follow cybersecurity training, practices, and protocols.
- Physical Security: Securing Saudi Entity's data centers and physical infrastructure.

5. Roles and Responsibilities for All Personnel

Every employee, contractor, and vendor within Saudi Entity had specific responsibilities related to cybersecurity, such as:

- Participating in cybersecurity awareness training.
- Reporting suspicious activities.
- Complying with cybersecurity policies related to data handling and access.

Phase 2: Documentation, Approval, and Review Process

The process of documenting, approving, and periodically reviewing roles and responsibilities was consistent with the approach taken in the government entity, ensuring a structured and compliant implementation.

1.5 Cybersecurity Risk Management:

Definition: Cybersecurity risk management is the process of identifying, assessing, prioritizing, and mitigating risks to the confidentiality, integrity, and availability of information and technology assets. This approach aims to reduce the organization's exposure to potential cyber threats and vulnerabilities while ensuring effective protection of sensitive data and systems. Cybersecurity risk management is an ongoing process, informed by the changing threat landscape and evolving business needs [14], [15], [16].

Objective:

To ensure managing cybersecurity risks in a methodological approach in order to protect the organization's information and technology assets as per organizational policies and procedures, and related laws and regulations.

Controls Matrix:

Below is a summary matrix detailing relevant Cybersecurity Risk Management controls based on NCA, SAMA CSF, CST CRF, and CMA Cybersecurity guidelines:

Regulation	Main Controls	Control References
NCA ECC	4	1.5.1, 1.5.2, 1.5.3, 1.5.4
SAMA CSF	1	3.2.1 (4 Major sub-controls)
CST CRF	8	3.1.1, 3.1.2, 3.1.3, 3.1.4, 3.2.1, 3.2.2, 3.2.3, 3.2.4
CMA Cybersecurity Guidelines	1	4.2.1 (9 Sub-controls)
NCA CCCC	1	1.2.1 (2 Sub-controls)
NCA CCC CST	1	1.2.T.1 (3 Sub-controls)
NCA CCC CSP	1	1.2.P.1 (3 Sub-controls)
NCA TCC	1	1.2.1 (3 Sub-controls)
NCA DCC	-	-
NCA OSMACC	1	1.2.1 (3 Sub-controls)
NCA OTCC	1	1.3.1 (7 Sub-controls)

Cybersecurity Risk Management Controls:

Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines:	Expected deliverables
NCA ECC					
1.5.1		The cybersecurity risk management methodology and procedures must be implemented by the cybersecurity function.	Cybersecurity Risk Management Register Template	- Define and document cybersecurity risk management requirements which are based on relevant regulations, best practices, and standard controls of cybersecurity risk management, taking into account the confidentiality, availability, and integrity of information and technology assets to cover the following - The methodology and procedures of cybersecurity risk management in the organization must include - Identification of assets and their value - Identification of risks to the business, assets, or personnel of the organization - Risk assessment, so that the likelihood and impact of the identified risks are defined - Risk response, where cyber risk treatment methods are identified - Risk monitoring, so that the risk register is updated after each risk assessment and response plan Support the cybersecurity risk management methodology and procedures in the organization by the Executive Management through the approval of the representative	- Cybersecurity Risk Register of the organization - Cybersecurity Risk Treatment Plan of the organization - A report that outlines the cybersecurity risk assessment and monitoring

1.5.2		Cybersecurity risk management methodology and procedures must be defined, documented and approved as per confidentiality, integrity and availability considerations of information and technology assets.	• Cybersecurity Risk Management Policy Template. • Cybersecurity Risk Management Procedures Template.	• Implement all requirements of the cybersecurity risk management methodology and procedures adopted by the organization • Establish a cybersecurity risk register to document and monitor risks • Develop plans to address cybersecurity risks of the organization	• The approved cybersecurity risk management methodology (electronic copy or official hard copy) • Approved cybersecurity risk management procedures
1.5.3	1-5-3-1	1.5.3 The cybersecurity risk assessment procedures must be implemented at least in the following cases: 1-5-3-1 Early stages of technology projects.		• Define and document the requirements of this ECC in the cybersecurity requirements document and approve them by the representative • Include cybersecurity requirements within the first phase of the information and technology projects lifecycle (Technical Project Lifecycle) within the organization • Implement cybersecurity risk assessment procedures at an early stage of technical projects to avoid events or circumstances that could compromise the confidentiality, integrity, and availability of information and technology assets, including, in particular, the identification of information and technology assets in technology projects, potential exposure to threats, and relevant vulnerabilities. • Remediate all cybersecurity risks in accordance with the approved cybersecurity risk management methodology.	• A report that outlines the identification, assessment, and remediation of cybersecurity risks throughout the technical project lifecycle in the organization
	1-5-3-2	1-5-3-2 Before making major changes to technology infrastructure.		• Define and document the requirements of this ECC in the cybersecurity requirements document and approve them by the representative	• A report that outlines the identification, assessment, and remediation of the cybersecurity risks of

				• Include cybersecurity requirements within the IT Change Management lifecycle in the organization • Implement cybersecurity risk assessment procedures before making a material change in the technology architecture to avoid events or circumstances that could compromise the confidentiality, integrity, and availability of information and technology assets, including, in particular, the identification of information and technology assets in technology projects, potential exposure to threats, and relevant vulnerabilities. These changes include, but are not limited to: a basic and sensitive update to one or several systems in the network, such as database systems, or a radical change in network mapping • Remediate all cybersecurity risks in accordance with the approved cybersecurity risk management methodology	material changes to the production environment of the organization's information and technology assets
	1-5-3-3	1-5-3-3 During the planning phase of obtaining third party services.		• Define and document the requirements of this ECC in the cybersecurity requirements document and approve them by the representative • Include cybersecurity requirements within the third-party, contracts, and procurement management procedures in the organization • Implement cybersecurity risk assessment procedures when planning to acquire services from a third party. to avoid events or circumstances that could compromise the confidentiality, integrity, and availability of information and technology assets, including, in particular, the identification of information and technology assets in	• A report that outlines the identification, assessment, and remediation of third-party cybersecurity risks that provide outsourcing services to IT or managed services

				technology projects, potential exposure to threats, and relevant vulnerabilities • Remediate all cybersecurity risks in accordance with the approved cybersecurity risk management methodology.	
	1-5-3-4	1-5-3-4 During the planning phase and before going live for new technology services		• Define and document the requirements of this ECC in the cybersecurity requirements document and approve them by the representative • Include cybersecurity requirements within the Release Management procedures in the organization • Implement cybersecurity risk assessment procedures at the planning stage and before the release of new technology products and services to avoid events or circumstances that could compromise the confidentiality, integrity, and availability of information and technology assets, including, in particular, the identification of information and technology assets in technology projects, potential exposure to threats, and relevant vulnerabilities. • Remediate all cybersecurity risks in accordance with the approved cybersecurity risk management methodology.	• A report that outlines the identification, assessment, and remediation of cybersecurity risks in the planning stage and before releasing new technical products and services in the production environment
1.5.4		1.5.4 The cybersecurity risk management methodology and procedures must be reviewed periodically according to planned intervals or upon changes to related laws and regulations. Changes and reviews must be approved and documented		• Review and update the cybersecurity risk management methodology and procedures and cybersecurity risk management requirements in the organization periodically according to a documented and approved plan for review and based on a planned interval (e.g., periodic review must be conducted annually) • Review and update the cybersecurity risk management methodology and procedures and cybersecurity risk management	• An approved document that defines the review schedule for the cybersecurity risk management methodology and procedures • Cybersecurity risk methodology and procedures indicating

				requirements in the organization in the event of changes in the relevant laws and regulations (for example, when a new cybersecurity law is issued that applies to the organization) Document the review and changes to the cybersecurity requirements related to cybersecurity risk management methodology and procedures and approve them by the representative	that they have been reviewed and updated, and that changes have been documented and approved by the representative
NCA CCCC					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines:	Expected deliverables
1-2-1	1.2.1.1	In addition to the controls in ECC subdomain 1-5, cybersecurity risk management methodology must include at least the following: 1.2.1.1 Conducting a cybersecurity risk assessment on critical systems at least once annually.	- Cybersecurity Risk Management Policy Template - Cybersecurity Risk Management Procedure Template	- Conduct a cybersecurity risk assessment on critical systems (listed within the outputs of control No. 2-1-1-1) to identify all potential threats that could affect the integrity of those systems or expose the information they process to cyber or computer risks or potential vulnerabilities. - Assess cybersecurity risks for each critical system periodically, at least once a year. - Create reports on cybersecurity risk assessments for each critical system, documenting: - Cyber risks and potential vulnerabilities - Probability of risk occurrence - Impact ratio - Risk level - Responsible for the potential risk - Description of the risk mitigation plan - Impacted assets	- Periodic cybersecurity risk assessment reports on the range of critical systems in the organization. - Cybersecurity risk treatment plans for each critical system. - Reports or evidence showing the follow-up of treatment plans and verifying their implementation

				Develop a plan to address the list of cybersecurity risks for each critical system, and give priority in implementation to the plan to address risks related to critical systems over other risks.	
	1.2.1.2	1.2.1.2 Creating a cybersecurity risk register for critical systems, and reviewing it at least once every month.	- Cybersecurity Risk Register Template - Cybersecurity Risk Management Policy Template	- Create a cybersecurity risk register for critical systems or include the risks related to critical systems clearly within the entity's general cybersecurity risk register, so that it contains the following: - Cyber risks and potential vulnerabilities - Probability of risk occurrence - Impact ratio - Risk level - Responsible for the potential risk - Description of the risk mitigation plan - Impacted assets - Work to include the cybersecurity risks of critical systems that were identified and evaluated during the risk assessment process in the cybersecurity risk register for critical systems, and assign them to stakeholders. - Follow-up the cybersecurity risk register of critical systems periodically, at least once a month, so that treatment plans are followed up, their implementation verified, any new risks added, and changes in the register documented.	- Cybersecurity risk register for critical systems. - Record of changes to the cybersecurity risk register for critical systems. - Reports or evidence showing the follow-up of treatment plans and verifying their implementation
NCA OSMACC					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines:	Expected deliverables
1.2.1	1.2.1.1	In addition to the controls within subdomain 1-5 in the ECC, requirements for	Template for Cybersecurity Risk Management Policy	Conduct a Risk Assessment to all organization's social media accounts at least once a year or less. To discover, identify,	Risk Assessment report of all the organization's social media accounts

		cybersecurity risk management should include at least the following: 1-2-1-1 Assessing cybersecurity risks for organization's social media accounts, once per year at least media accounts.	• Template for Cybersecurity Risk Management Procedure • Template for Cybersecurity Risk Register	and mitigate potential risks related to social media accounts. • Conduct review against the identified risks for all the social media accounts of the organization at least once per year or less.	as per the cybersecurity requirements of the organization, and review it periodically based on the specified date.
	1.2.1.2	. 1-2-1-2 Assessing cybersecurity risks during planning and before permitting use of organization's social	• Template for Cybersecurity Risk Management Policy • Template for Cybersecurity Risk Management Procedure Template for Cybersecurity Risk Register	• Conduct Cybersecurity Risk Assessment during planning and before permitting use of organization's social media accounts.	• Risk Assessment report of all the organization's social media accounts as per the cybersecurity requirements, prior of initial use of the accounts.
	1.2.1.3	1-2-1-3 Including cybersecurity risks related to organization's social media accounts in the organization's cybersecurity risk register, and monitoring it at least once a year.	• Template for Cybersecurity Risk Management Policy • Template for Cybersecurity Risk Management Procedure • Template for Cybersecurity Risk Register	• Define and document the cybersecurity risks for the organization's social media accounts. • Verify that the cybersecurity risk associated with the social media are included in the organization's cybersecurity risk register. • Review and monitor the social media risks at least every year or less.	• Inclusion of social media accounts' risks in the cybersecurity risk register. • Review report of cybersecurity risks associated with the requirements for the organization's social media accounts.
NCA TCC					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
1.2.1	1.2.1.1	In addition to the controls within subdomain 1-5 in the ECC, requirements for cybersecurity	• Cybersecurity risk management policy.	• Conduct a cybersecurity risk assessment on telework systems in order to identify all potential threats that could affect the	• Periodic cybersecurity risk assessment reports

		risk management should include at least the following: 1-2-1-1 Assessment of the cybersecurity risks for telework systems, once per year at least	• Cybersecurity risk management procedure. • Cybersecurity risk register.	integrity of those systems or expose the information they process to any cyber risks or potential vulnerabilities, taking into account the nature of those systems. • Assess the cybersecurity risks of each system periodically, at least once a year. • Create reports on the cybersecurity risk assessment processes for each system, provided that the following is documented: ○ Cyber risks and potential vulnerabilities. ○ The probability of the risk occurring. ○ Impact ratio. ○ Risk level. ○ Responsible for the potential risk. ○ Description of the risk treatment plan. ○ Affected assets. • Work on developing a plan to address the list of cybersecurity risks for each system.	on the entity's telework systems. • Treatment plans for cybersecurity risks for all telework systems. • Follow up on treatment plans and verify their implementation.
	1.2.1.2	Assessment of cybersecurity risks during planning and before permitting telework for any service or system.	• Cybersecurity risk management policy. • Cybersecurity risk management procedure. • Cybersecurity risk register.	• Work on defining the requirements for this control, document them in the cybersecurity requirements document, and have them approved by the authority holder. • Include cybersecurity requirements within the entity's IT change management cycle. • Implement cybersecurity risk assessment procedures when planning and before allowing telework for any service or system. • Work on addressing all cybersecurity risks identified according to the cybersecurity risk management methodology. • Work on developing a treatment plan for the list of cybersecurity risks for each system, while following up the treatment plan periodically.	• A document that identifies and documents the requirements of this control (such as a policy and/or procedure approved by the authority holder). • A report detailing the identification, assessment, and remediation of cybersecurity risks related to planning and prior allowing telework for any service or system. • Cybersecurity risk register for teleworking

					includes (during planning, upon implementation and before use).
	1.2.1.3	Including the cybersecurity risks related to telework systems and its related services and systems in the entity's cybersecurity risk register, and monitoring it at least once a year.	• Cybersecurity risk management policy. • Cybersecurity risk management procedure. • Cybersecurity risk register.	• Work on creating a cybersecurity risk register for telework systems, services and systems that are allowed to work remotely, or include the risks related to them clearly within the entity's general cybersecurity risk register, so that it contains the following: ○ Cyber risks and potential vulnerabilities. ○ The probability of the risk occurring. ○ Impact ratio. ○ Risk level. ○ Responsible for the potential risk. ○ Description of the risk treatment plan. ○ Affected assets. • Include the cybersecurity risks of telework systems, services and systems allowed for telework that were identified and evaluated during the evaluation process, and assign them to stakeholders. • Follow up the cybersecurity risk register for telework systems, services and systems allowed to work remotely periodically, at least once a year, so that treatment plans are followed up, their implementation is verified, any new risks are added, and changes are documented in the register.	• Cybersecurity risk register for telework and services and systems permitted to work remotely. • Changes log of the cybersecurity risk register for telework systems, services, and authorized telework. • Follow up on treatment plans and verify their implementation. • Periodically review cybersecurity risks related to telework systems.
NCA OTCC					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
1.3.1	1.3.1.1	In addition to the ECC subdomain 1-5, cybersecurity	• Template for Cybersecurity	• Develop and implement a dedicated OT/ICS cybersecurity risk management methodology and extend the organization's	• Approved OT/ICS cybersecurity risk

		requirements for cybersecurity risk management in OT/ICS must include, at a minimum, the following: 1-3-1-1 OT/ICS cybersecurity risk management methodology must be included as part of the organization's risk management and safety risk management methodologies.	- Operational Technology Policy - Template for Cybersecurity Risk Management Procedure - Template for Cybersecurity Risk Register	- risk management and safety risk management methodologies with that. - Review and verify that the prepared OT/ICS cybersecurity risk management methodology is a part of and in line with the general organization's risk management and safety risk management methodologies. - Develop a periodic review plan and prepare summary reports.	- management methodology. - A proof that OT/ICS cybersecurity risk management methodology is part of the general organization's risk management and safety risk management methodologies.
	1.3.1.2	OT/ICS cybersecurity risk management methodology must be included as part of the organization's risk management and safety risk management methodologies.	- Template for Cybersecurity Operational Technology Policy - Template for Cybersecurity Risk Management Procedure - Template for Cybersecurity Risk Register	- Conduct cybersecurity risk assessment for OT/ICS assets periodically (based on a defined frequency). - Conduct cybersecurity risk assessment before signing contracts and agreements with third-party organizations related to OT/ICS. - Conduct cybersecurity risk assessment when there are changes in related regulatory requirements.	- Cybersecurity risk assessment for OT/ICS assets reports. - OT/ICS risk register. - A proof that OT/ICS risk assessment is conducted periodically and includes risk assessment associated with the signing of contracts and agreements with OT/ICS related third-party organizations and/or upon changes in related regulatory requirements.
	1.3.1.3	Risk register for OT/ICS cybersecurity risks must be included as part of the organization's risk register.	- Template for Cybersecurity Operational Technology Policy - Template for Cybersecurity Risk Register	- Develop a risk register for the (OT/ICS) assets. - Include the (OT/ICS) risk register in the organization's risk register.	- OT/ICS risk register. - A proof that OT/ICS risk register is part of the organization's risk register.

			Management Procedure • Template for Cybersecurity Risk Register		
	1.3.1.4	Appropriate level assignment to facilities which include (OT/ICS) must be conducted based on approved methodology.	• Template for Cybersecurity Operational Technology Policy • Template for Cybersecurity Risk Management Procedure • Template for Cybersecurity Risk Register	• Document and approve the methodology used for the appropriate level assignment to facilities which include (OT/ICS). • Ensure that the appropriate level assignment process is conducted in line with the approved methodology.	• Approved document containing OT/ICS facilities level assignment methodology. • A proof that a proper level assignment process is conducted in line with the approved methodology.
	1.3.1.5	Include a qualitative analysis of cybersecurity risks within the Process Hazard Analysis (PHA) which is applied with any change in operations and/or procedures in Plants.	• Template for Cybersecurity Operational Technology Policy • Template for Cybersecurity Risk Management Procedure • Template for Cybersecurity Risk Register	• Update the Process Hazard Analysis procedures and include cybersecurity risks within the study. • Ensure that the qualitative analysis of the OT/ICS cybersecurity risks are included in the Process Hazard Analysis (PHA) study report.	• A proof that the Process Hazard Analysis procedures are updated to include cybersecurity risks within the study. • Latest report of the Process Hazard Analysis study.
	1.3.1.6	In the event that cybersecurity requirements cannot be implemented within the OT/ICS environment, the specific justifications for not applying those requirements must be documented	• Template for Cybersecurity Operational Technology Policy • Template for Cybersecurity Risk Management Procedure	• In case cybersecurity requirements cannot be implemented within the OT/ICS environment, the following shall be implemented: ○ Document the specific justifications for not applying those requirements; this include an official letter from the vendors in case they don't recommend applying such requirement due to technical or	• The document containing the specific justifications for not applying the selected requirements; this include an official letter from the vendors in case they don't recommend applying such requirement due

		and approved by the respective cybersecurity function and the Authorizing Official.	• Template for Cybersecurity Risk Register	operational reasons showcasing the details and technical justifications. ○ Conduct cybersecurity risk assessment to identify the risks from not applying such control, and include the alternative controls following the risk acceptance process. ○ Obtain approval from cybersecurity function and the authorizing official.	to technical or operational reasons showcasing the details and technical justifications. • The cybersecurity risk assessment report containing the alternative controls, while following the risk acceptance process. • The approval from cybersecurity function and the authorizing official.
	1.3.1.7	In the event of risk acceptance, alternative cybersecurity controls must be clearly defined, documented, approved by the Authorizing Official, and implemented effectively for a defined period of time while reassessing the risk continuously.	• Template for Cybersecurity Operational Technology Policy • Template for Cybersecurity Risk Management Procedure • Template for Cybersecurity Risk Register	• In the event of risk acceptance: ○ Clarifying and documenting residual risks, and obtaining approval from the authorizing official ○ Define and document alternative cybersecurity controls, then obtain approval by the respective cybersecurity function and the Authorizing Official. ○ Alternative cybersecurity controls must be implemented effectively for a defined period of time. ○ Continuously reassess the risk and the effectiveness of the alternative cybersecurity controls.	• Cybersecurity risk assessment report showcasing the documentation of alternative cybersecurity • Approval of the respective cybersecurity function and the authorizing official. • A proof that alternative cybersecurity controls are implemented for a defined period of time. • A proof that the risk and the effectiveness of the alternative cybersecurity controls are continuously reassessed.
NCA CCC CST					

Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
1.2.T.1	1.2.T.1.1	Cybersecurity risk management methodology mentioned in the ECC Subdomain 1-5 shall also include for the CST, as a minimum: Defining acceptable risk levels for the cloud services.	• Template for Cybersecurity Risk Management Policy	In addition to the ECC control 1-5 implementation guidelines: • Identify cloud services in use and analyse their business impact in a defined process (e.g.: Business Impact Analysis) to understand and assess (at least) service disruptions, data leaks and exposures, unauthenticated access risks and blast radius of damage one cloud issue may cause. • Define risk levels for cloud services (e.g.: critical, high, medium, low) based on the organization's cybersecurity risk management methodology, and implementing necessary measures according to the risk level.	• Catalogue of cloud services with assigned acceptable risk level.
	1.2.T.1.2	Considering data and information classification accredited by CST in cybersecurity risk management methodology.	• Template for Cybersecurity Risk Management Policy • Templates for Cybersecurity Risk Management Processes	• Identify data processed/stored in the organization and classify it into agreed upon categories (e.g. public, restricted, secret, top secret) based on value to the organization, and include them in the cybersecurity risk management methodology.	• Cybersecurity Risk Management Methodology with unique approach to data classes.
	1.2.T.1.3	Developing cybersecurity risk register for cloud services, and monitoring it periodically according to the risks.	• Template for Cybersecurity Risk Management Policy • Template for Cybersecurity Risk Register	• Identify risks related to cloud services and CSPs - use Threat Intelligence feeds and Incident Response registries to analyse risk applicable to cloud services (e.g. data leakage due to misconfigured public cloud storage service or due to weak authentication) and periodically monitoring them according to nature and classification of the risk, ensuring they are addressed with appropriate priority.	• Cybersecurity Cloud Services Risk Register. • Cybersecurity Cloud Services Risk Register review plan.
NCA CCC CSP					

1.2.P.1	1.2.P.1.1	Cybersecurity risk management methodology mentioned in the ECC Subdomain 1-5 shall also include for the CST, as a minimum: Defining acceptable risk levels for the cloud services and clarifying them to the CST if the risk was related to him/her.	• Template for Risk Management Policies	In addition to the ECC control 1-5 implementation guidelines: • Identify offered cloud services and analyse their business impact in a defined process (e.g. Business Impact Analysis) to understand and assess risks (for example, service disruption, data leak, unauthorized access, etc.) and the damage one cloud issue may cause. • Define risk levels for cloud services (eg.: critical, high, medium, low), and the acceptable risk levels. • Communicate acceptable risk levels with CSTs (eg.: sharing a Risk Assessment/Threat Analysis of cloud services provided to the CST).	• Defined acceptable risk levels of cloud services documented and communicated with the concerned and relevant stakeholders, including the CSTs.
	1.2.P.1.2	Considering data and information classification in cybersecurity risk management methodology.	• Template for Cybersecurity Risk Management Policies • Template for Cybersecurity Risk Management Procedure • Template for Risk Register	• Identify types of data and information processed/stored in the cloud services and classify it into agreed upon categories with the CST (e.g. public, restricted, secret, top secret) based on value and criticality to the CST, and include them in the cybersecurity risk management methodology when dealing with the cybersecurity risks related to cloud services.	• Cybersecurity Risk Management Methodology includes clear procedure to deal with data based on its classification levels.
	1.2.P.1.3	Developing cybersecurity risk register for cloud services and monitoring it periodically according to the risks.	• Template for Cybersecurity Risk Management Policies • Template for Cybersecurity Risk Management Procedure • Template for Risk Register	• Identify cybersecurity risks related to cloud services and CSTs and assess them based on the approved methodology. • Maintain the Cloud Services Risk Register that includes all sufficient information to analyse risk, take informed decision about how to respond to risks and track associated actions. • Review the Risk Register periodically, based on an approved plan, considering the identified risks and their criticality.	• Cybersecurity Cloud Services Risk Register. • Cybersecurity Cloud Services Risk Register review plan. • Cybersecurity Cloud Services Risk Register review reports.
SAMA CSF					

Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
3.2.1 Cyber Security Risk Management	3.2.1-1	The cyber security risk management process should be defined, approved and implemented.			
	3.2.1-2	The cyber security risk management process should focus on safeguarding the confidentiality, integrity and availability of information assets.			
	3.2.1-3	The cyber security risk management process should be aligned with the existing enterprise risk management process			
	3.2.1-4.a	The cyber security risk management process should be documented and address: a. risk identification;			
	3.2.1-4.b	b. risk analysis;			
	3.2.1-4.c	c. risk response;			
	3.2.1-4.d	d. risk monitoring & review			
	3.2.1-5	The cyber security risk management process should address the Member Organization's information assets, including (but not limited to):			

		a. business processes; b. business applications; c. infrastructure components			
	3.2.1-6.a	The cyber security risk management process should be initiated: a. at an early stage of the project;			
	3.2.1-6.b	b. prior to critical change;			
	3.2.1-6.c	c. when outsourcing is being considered;			
	3.2.1-6.d	d. when launching new products and technologies.			
	3.2.1-7	Existing information assets should be periodically subject to cyber security risk assessment based on their classification or risk profile.			
	3.2.1-8	The cyber security risk management activities should involve: a. business owners; b. IT specialists; c. cyber security specialists;d. key user representatives.			
	3.2.1-9	The result of the risk assessment should be reported to the relevant business owner (i.e., risk owner) within the Member Organization;			

	3.2.1-10	The relevant business owner (i.e., risk owner) within the Member Organization should accept and endorse the risk assessment results.			
	3.2.1-11	The Member Organization's cyber security risk appetite and risk tolerance should be clearly defined and formally approved.			
3.2.1.1 Cyber Security Risk Identification	3.2.1.1-1	Cyber security risk identification should be performed.			
	3.2.1.1-2	Identified cyber security risks should be documented (in a central register).			
	3.2.1.1-3	Cyber security risk identification should address relevant information assets, threats, vulnerabilities and the key existing cyber security controls.			
3.2.1.2 Cyber Security Risk Analysis	3.2.1.2-1	A cyber security risk analysis should be performed.			
	3.2.1.2-2	The cyber security risk analysis should address the level of potential business impact and likelihood of cyber security threat events materializing.			

3.2.1.3 Cyber Security Risk Response	3.2.1.3-1	The relevant determined cyber security risks should be treated according to the Member Organization's risk appetite and cyber security requirements.			
	3.2.1.3-2	Cyber security risk response should ensure that the list of risk treatment options are documented (i.e., accepting, avoiding, transferring or mitigating risks by applying cyber security controls).			
	3.2.1.3-3.a	Accepting cyber security risks should include: a. the consideration of predefined limits for levels of cyber security risk;			
	3.2.1.3-3.b	b. the approval and sign-off by the business owner, ensuring that: 1. the accepted cyber security risk is within the risk appetite and is reported to the cyber security committee; 2. the accepted cyber security risk does not contradict SAMA regulations.			
	3.2.1.3-4	Avoiding cyber security risks should involve a decision by a business owner to cancel or			

		postpone a particular activity or project that introduces an unacceptable cyber security risk.			
	3.2.1.3-5	Transferring or sharing the cyber security risks should: a. involve sharing the cyber security risks with relevant (internal or external) providers; b. be accepted by the receiving (internal or external) provider(s); c. eventually lead to the actual transferring or sharing of the cyber security risk.			
	3.2.1.3-6	Applying cyber security controls to mitigate cyber security risks should include: a. identifying appropriate cyber security controls; b. evaluating the strengths and weaknesses of the cyber security controls; 1. assessing the cost of implementing the cyber security controls; 2. assessing the feasibility of implementing the cyber security controls; 3. reviewing relevant compliance requirements for the cyber security controls; c. selecting cyber			

		security controls;d. identifying, documenting and obtaining sign-off for any residual risk by the business owner.			
	3.2.1.3-7	Cyber security risk treatment actions should be documented in a risk treatment plan.			
3.2.1.4 Cyber Risk Monitoring and Review	3.2.1.4-1.a	The cyber security treatment should be monitored, including: a. tracking progress in accordance to treatment plan.			
	3.2.1.4-1.b	b. the selected and agreed cyber security controls are being implemented.			
	3.2.1.4-2	The design and effectiveness of the revised or newly implemented cyber security controls should be reviewed.			
CST CRF					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
3.1 Cybersecurity Risk Assessment	3.1.1	Define and document [Requirements for Cybersecurity Risk Assessment] which consider the following: • Purpose and scope of the risk assessment in the organization			

		• The frequency and circumstance when risk assessment should be conducted in the organization • Ensuring that the [Requirements for Cybersecurity Risk Assessment] cover the risks to the information assets of the organization, individuals, and other organizations			
	3.1.2	Define and implement a {Risk Assessment} process consisting of: • Risk identification: Identify and document internal and external risks based on the information assets of the organization [Asset Discovery]and maintain the identified risks in a [Risk Register] • Risk analysis: Analyze and document the identified risks in terms of probability and impact • Risk evaluation: Identify, prioritize, and document which risk should be treated or accepted based on the organization's risk appetite. Risk evaluation outcomes must be officially approved by the top management			

		• Report the top cybersecurity risks within the [Risk Register] along with the remediation plans to the CST			
	3.1.3	Integrate the {Risk Assessment} process into the organization's risk management framework and apply it at least for the following events: • In the early stages of major technical projects or major changes to the organization or technical architecture • Before launching new products and services			
	3.1.4	Continuously measure, review and optimize the [Requirements for Cybersecurity Risk Assessment] as well as the effectiveness of the process			
3.2 Cybersecurity Risk Treatment & Monitoring	3.2.1	Define and document [Requirements for Cybersecurity Risk Treatment and Monitoring] which consider the following: • The risk treatment plan • The risk monitoring plan			
	3.2.2	Define and implement a {Risk Treatment} process describing how assessed risks are treated			

		resulting in a [Risk Treatment Plan].			
	3.2.3	Define and implement a {Risk Monitoring} process that monitors and reviews the identified risks, the implementation of the risk treatment plan, the residual risk, and the status of the accepted risks.			
	3.2.4	Continuously measure, review and optimize the [Requirements for Cybersecurity Risk Treatment and Monitoring] as well as the effectiveness of the processes.			
CMA Cybersecurity Guidelines 4.2.1.1, 4.2.1.2, 4.2.1.3, 4.2.1.4, 4.2.1.5, 4.2.1.6, 4.2.1.7, 4.2.1.8, 4.2.1.9					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
4.2.1 Cybersecurity Risk Management	4.2.1.1	Set up , document, approve, implement and periodically review cybersecurity risk management methodology.			
	4.2.1.2	Cybersecurity risk management methodology aims to protect confidentiality, integrity and availability of information assets.			
	4.2.1.3	Cybersecurity risk management			

		methodology shall be consistent with risk management methodology adopted by market institution.			
	4.2.1.4	Document Cybersecurity risk management methodology, and identify, analyze, respond to, monitor and review risks			
	4.2.1.5	Cybersecurity risk management methodology includes information and technology assets of capital market institution including, but not limited to: Work procedures. Business applications. Infrastructure components. Employees			
	4.2.1.6	Apply cybersecurity risk assessment procedures in the following stages: • Early stage of the project. • Before making any material change in technology infrastructure. • Before obtaining third party's services. • Before launching new products and technologies.			

	4.2.1.7	Set out and document cybersecurity risks in unified record including all information and technology assets of market institution.			
	4.2.1.8	Document options list of risk processing (i.e. accept, avoid, transfer or limit risks by way of implementing Cybersecurity controls)			
	4.2.1.9	Give highest priority to and closely monitor highest cybersecurity risks as well as to prepare periodic reports on procedures taken to mitigate their effects.			

Risk Considerations in Cybersecurity Risk Management

Incomplete Risk Identification

- **Risk Description:** Failure to identify all relevant cybersecurity risks, including third-party risks and emerging threats, can lead to unaddressed vulnerabilities.
- **Risk Mitigation:** Conduct comprehensive risk assessments involving all stakeholders and use threat intelligence to stay updated on emerging risks.

Ineffective Risk Mitigation Strategies

- **Risk Description:** Implementing insufficient or ineffective risk controls can leave the organization exposed to attacks.
- **Risk Mitigation:** Prioritize risks based on potential impact and likelihood, and implement defense-in-depth strategies that are regularly tested and updated.

Over-reliance on Automated Risk Management Tools

- **Risk Description:** Excessive reliance on automated tools may overlook nuanced risks or produce false positives, leading to delayed responses or inadequate defenses.
- **Risk Mitigation:** Combine automated tools with human oversight and ensure manual checks are incorporated into the risk management process.

Failure to Align with Business Objectives

- **Risk Description:** A disconnect between risk management processes and the organization's business objectives may lead to misaligned priorities.
- **Risk Mitigation:** Align risk management strategies with business goals, ensuring that critical business operations are not compromised by cybersecurity measures.

Inconsistent Risk Assessments

- **Risk Description:** Irregular or inconsistent risk assessments can lead to outdated or incomplete data, leaving the organization unprepared.
- **Risk Mitigation:** Implement a regular risk assessment schedule, and ensure that findings are documented, communicated, and acted upon in a timely manner.

Examples of Technologies for Effective Cybersecurity Risk Management

- **Risk Management Platforms**

- Example Tools: Eramba, OpenGRC (OpenControl-based), SimpleRisk
- Purpose: Enable structured cybersecurity risk identification, assessment, mitigation planning, and compliance tracking.

- **Security Information and Event Management (SIEM) Systems**

- Example Tools: Wazuh, ELK Stack, OSSIM
- Purpose: Aggregate and analyze logs to detect threats, support risk assessment, and enable incident response.

- **Risk Assessment Tools**

- Example Tools: CIS-CAT (Community Edition), OpenSCAP, ThreatMapper (open-source by Deepfence)
- Purpose: Assess system configurations and map threats to risk exposure using recognized cybersecurity frameworks.

- **Vulnerability Management Tools**

- Example Tools: OpenVAS, Trivy, Nikto
- Purpose: Scan and assess vulnerabilities, contributing to risk analysis and mitigation planning.

Examples of KPIs for Cybersecurity Risk Management

1. **Number Risk Assessment:** Number of risk assessments conducted within the defined period (e.g., quarterly, annually).
2. **Risk Mitigation Success Rate:** Percentage of identified risks that have been mitigated or reduced to an acceptable level.
3. **Residual Risk Level:** Percentage of risks that remain after mitigation, indicating the effectiveness of risk management practices.
4. **Compliance with Risk Management Policies:** Percentage of risk management activities conducted in alignment with documented risk management policies and procedures.
5. **Risk Incident Frequency:** Number of security incidents attributed to previously identified risks that were not mitigated.

Case Study: Developing and Implementing Cybersecurity Risk Management for a Saudi Financial Institution

Background:

A Saudi Financial Institution recognized the need to protect sensitive financial data, customer assets, and ensure business continuity in an increasingly complex digital environment. The bank's reliance on digital systems for financial transactions, customer data processing, and regulatory compliance required a robust cybersecurity risk management framework.

Given the financial sector's strict regulatory requirements (e.g., Saudi Arabian Monetary Authority (SAMA) regulations), the bank needed to ensure that cybersecurity risks were effectively managed and mitigated, particularly in critical areas such as payment systems, data privacy, and third-party vendor relationships.

Phase 1: Defining Cybersecurity Risk Management Methodology and Procedures

1. Risk Management Methodology Development

The Cybersecurity Risk Management Methodology was designed to focus on the CIA triad, considering the confidentiality of financial data, the integrity of transactions, and the availability of critical services. The methodology was developed using industry best practices, including frameworks such as ISO 27005 and NIST SP 800-53.

Key elements of the methodology included:

- **Risk Identification:** Assessing cybersecurity risks related to financial systems, customer information, and regulatory compliance.
- **Risk Assessment:** Conducting qualitative and quantitative assessments of identified risks based on their potential impact on financial services.
- **Risk Treatment and Mitigation:** Implementing measures such as encryption, access control, transaction monitoring, and incident response to mitigate identified risks.

2. Cybersecurity Risk Assessment Procedures

The institution implemented a comprehensive risk assessment process at key points in the lifecycle of financial projects, including:

- **Early Stages of Technology Projects:** Risk assessments conducted before launching new financial products or services to ensure that potential cybersecurity risks are addressed early.
- **Before Major Changes to Technology Infrastructure:** Risk assessments for major IT infrastructure changes, such as database migrations or system updates, to ensure these changes do not introduce vulnerabilities.
- **Third-Party Vendor Engagements:** Risk assessments conducted to evaluate the cybersecurity posture of third-party vendors handling sensitive financial data or critical systems.
- **Pre-Launch and Go-Live for New Services:** Risk assessments conducted before launching new online banking services, payment systems, or digital wallets to ensure the platform's security.

Phase 2: Approval, Documentation, and Review

1. Documentation and Approval

The Cybersecurity Risk Management Framework was documented and approved by the Board of Directors and SAMA regulators. This document outlined:

- The formal risk management process.

- Responsibilities for risk assessment and mitigation across departments.
- Procedures for periodic reviews and updates of the risk management methodology.

2. Periodic Review and Update

The risk management methodology was scheduled for annual reviews to ensure it stayed aligned with emerging threats and changing regulatory requirements. Reviews were conducted more frequently if there were significant changes in regulatory guidelines, financial services, or technologies.

Phase 3: Implementation and Integration

1. Embedding Risk Management in Financial Projects

The risk management methodology was embedded into the institution's financial project lifecycle:

- Integrating cybersecurity risk assessments as a requirement for all major financial projects.
- Ensuring that third-party service providers conducted cybersecurity assessments before entering into agreements.

2. Ongoing Risk Mitigation

The financial institution implemented continuous monitoring tools to track evolving threats and vulnerabilities. Real-time risk assessment dashboards were set up to provide visibility into potential cybersecurity issues.

1.6 Cybersecurity in Information Technology Projects:

Definition: Cybersecurity in information technology projects refers to the integration of cybersecurity best practices, policies, and standards into the planning, design, execution, and deployment phases of technology-related initiatives. This includes the identification of cybersecurity risks early in the project lifecycle, ensuring secure software development practices, and ensuring secure configurations before deployment. The goal is to reduce vulnerabilities and ensure that the IT systems being developed are resilient to cyber threats [17], [18].

Objective:

To ensure that cybersecurity requirements are included in project management methodology and procedures in order to protect the confidentiality, integrity and availability of information and technology assets as per organization policies and procedures, and related laws and regulations.

Controls Matrix:

Below is a summary matrix detailing relevant Cybersecurity controls in Information Technology Projects based on NCA, SAMA CSF, CST CRF, and CMA Cybersecurity guidelines:

Regulation	Main Controls	Control References
NCA ECC	4	1.6.1, 1.6.2 (2 Sub controls), 1.6.3 (5 Sub controls), 1.6.4
SAMA CSF	2	3.1.5.1, 3.1.5.2
CST CRF	4	1.7.1, 1.7.2, 1.7.3, 1.7.4
CMA Cybersecurity Guidelines	4	4.3.3.3, 4.3.3.4, 4.3.3.5, 4.3.3.6
NCA CSCC	2	1.3.1 (2 Sub controls), 1.3.2 (4 Sub controls)
NCA CCC CST	-	-
NCA CCC CSP	-	-
NCA TCC	-	-
NCA DCC	-	-
NCA OSMACC	-	-
NCA OTCC	2	1.4.1 (3 Sub controls), 1.4.2

Cybersecurity in Information Technology Projects Controls :

Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines:	Expected deliverables
ECC					
1.6.1		Cybersecurity requirements must be included in project and asset information/ technology) change management methodology and procedures to identify and manage cybersecurity risks as part of project management lifecycle. The cybersecurity requirements must be a key part of the overall requirements of technology projects.	- Secure Software Development Cycle Policy Template. - Secure Software Development Cycle Procedure Template.	- Include cybersecurity requirements in the project management methodology and procedures and in the change management of the information and technology assets in the organization to ensure that cybersecurity risks are identified and addressed. Such requirements include: - Assess and detect vulnerabilities before the deployment of services or systems online, or upon any change to systems within Information and Technology Project Management. - Fix identified vulnerabilities before launching projects and changes. - Review Secure Configuration and Hardening and Patching and address observations identified before launching projects and changes. - Define the requirements for connection with cyber surveillance systems. - Support cybersecurity requirements of the project management methodology and procedures by the Executive Management through the approval of	- Project Management Methodology Document in the organization. - Change management methodology or procedures in the organizations information and technology assets document.

				the head of the organization or his/ her deputy.	
1.6.2	1.6.2.1	The cybersecurity requirements in project and assets information/technology) change management must include at least the following. 1-6-2-1 Vulnerability assessment and remediation.		- Define and document the requirements of this control in the cybersecurity requirements document and approve them by the representative. - Define systems, services, and technology components subject to Vulnerabilities Assessment within the scope of technical projects and change requests. - Develop and adopt procedures for the implementation of Vulnerabilities Assessment and remediation in accordance with related laws and regulations. - Conduct Vulnerabilities Assessment before launching technical projects in the production environment and assess it in a timely manner and address it effectively. - Conduct Vulnerabilities Assessment before the implementation of changes to the production environment and assess it in a timely manner and address it effectively.	- A document (such as approved policy or procedure) indicating the identification and documentation of the requirements related to this control. - A report that outlines the assessment and remediation of cybersecurity vulnerabilities throughout the technical project lifecycle and changes to information and technology assets.
	1.6.2.2	Conducting a configurations review, secure configuration and hardening and patching before changes or going live for technology projects.	- Cybersecurity Requirements Checklist Template for Project Management and Changes to Information and Technology Assets. - Cybersecurity Requirements Checklist Template	- Define and document the requirements of this ECC in the cybersecurity requirements document and approve them by the representative. - Define systems, services, and technology components subject to Secure Configuration and Hardening review within the scope of technical projects and change requests. - Provide technical Security Standard controls for systems, services, and technology components subject to	- A document (such as approved policy or procedure) indicating the identification and documentation of the requirements related to this control. - Technical Security Standard controls for systems, services, and technology components subject to

			for Application Development.	Secure Configuration and Hardening review. • Develop and adopt procedures for the implementation of Secure Configuration and Hardening review in accordance with the relevant laws and regulations. • Review secure Configuration and Hardening and Patching before launching technology projects in the production environment. • Review secure Configuration and Hardening and Patching before implementing changes to the production environment.	Secure Configuration and Hardening review. • A report that outlines the assessment and review of Secure Configuration and Hardening throughout the technical project lifecycle and changes to information and technology assets in the organization before launching projects and implementing changes.
1.6.3	1.6.3.1	The cybersecurity requirements related to software and application development projects must include at least the following: 1-6-3-1 Using secure coding standards.	• Secure Coding Standard Template.	• Define and document the requirements of this ECC in the cybersecurity requirements document and approve them by the representative. • Define and document technical cybersecurity requirements for Secure Coding Standard controls (covering all phases of the secure coding process) based on relevant laws and regulations, best practices and standard controls related to the development and protection of software and applications against internal and external threats in the organization to minimize cyber risks and focus on key security objectives namely, confidentiality, integrity, and availability. • Communicate Secure Coding Standard controls to the relevant departments in the organization (eg., IT department) and their implementation periodically.	• A document (such as approved policy or procedure) indicating the identification and documentation of the requirements related to this control. • Secure Coding Standard controls approved by the organization. • Documents that confirm the implementation of secure Coding Standard controls to information and technology assets.

	1.6.3.2	Using trusted and licensed sources for software development tools and libraries.		- Define and document the requirements of this ECC in the cybersecurity requirements document and approve them by the representative. - Use only modern, reliable and licensed sources for software development tools and libraries.	- A document (such as approved policy or procedure) indicating the identification and documentation of the requirements related to this control. - An updated list of licensed and documented software used for application development tools and libraries.
	1.6.3.3	Conducting compliance test for software against the defined organizational cybersecurity requirements.	Cybersecurity Requirements Checklist Template for Application Development.	- Define and document the requirements of this ECC in the cybersecurity requirements document and approve them by the representative. - Conduct testing to verify that applications meet the cybersecurity requirements of the organizations, such as penetration testing, to ensure that cybersecurity controls are applied to the development of secure coding standard controls and detect weaknesses, vulnerabilities, and issues in software. - Access Management requirements for users and review the cybersecurity architecture.	- A document (such as approved policy or procedure) indicating the identification and documentation of the requirements related to this control. - List of application development projects and list of security tests performed to verify the comprehensiveness of the tests and the extent to which the applications meet the organization's cybersecurity requirements and implementation reports.
	1.6.3.4	Secure integration between software components.		Define and document the requirements of this ECC in the cybersecurity requirements document and approve them by the representative.	A document (such as approved policy or procedure) indicating the identification and

				• Ensure security of integration between applications by, but not limited to, • security testing of various integration technologies, including: ○ Perform System Integration Testing (SIT). ○ Perform API testing.	documentation of the requirements related to this control. • A report that outlines the testing and assessment of secure Integration between applications based on the organization's cybersecurity requirements and implementation reports.
	1.6.3.5	Conducting a configurations review, secure configuration and hardening and patching before going live for software products.		• Define and document the requirements of this ECC in the cybersecurity requirements document and approve them by the representative. • Review secure Configuration and Hardening and Patching before launching applications and ensure their implementation in the following cases: ○ Secure Configuration and Hardening of information and technology assets and applications must be reviewed periodically and their implementation according to the approved technical security standard controls must be ensured. ○ Secure configuration and hardening must be reviewed before launching projects and changes in information and technology assets. ○ Secure Configuration and Hardening must be reviewed before launching applications. • Approve the Image for the Secure configuration and hardening of information and technology assets in	• A document (such as approved policy or procedure) indicating the identification and documentation of the requirements related to this control. • Reports or evidence that Secure Configuration and Hardening and patching are reviewed before launching applications. • Reports or evidence that Secure Configuration and Hardening and patching are periodically reviewed.

				accordance with the technical security standard controls and kept it in a safe place. • Provide technology required to centrally manage Secure Configuration and Hardening and ensure the automated implementation or update of Secure Configuration and Hardening for all information and technology assets at pre-determined regular intervals.	
1.6.4		The cybersecurity requirements in project management must be reviewed periodically.		• Review the cybersecurity project management requirements periodically according to a documented and approved plan for review and based on a planned interval (e.g., periodic review must be conducted annually). • Document the review and changes to the cybersecurity requirements for project management in the organization and approve them by the head of the organization or his/her deputy.	• An approved document that defines the review schedule for the cybersecurity requirements for project management. • Evidence that the periodic review of cybersecurity requirements in project management and changes to the information and technology assets of the organization is performed.
NCA CCCC					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines:	Expected deliverables
1.3.1	1.3.1.1	In addition to the sub-controls within Control 1-6-2 in the ECC, it must cover the cybersecurity	• Cybersecurity Requirements Checklist for IT Projects and Change	• Determine stress testing methods for the technical components of critical systems, using one of the following methods:	• Evaluation and stress test reports for technical components of critical systems.

		requirements for project management and changes to the information and technical assets of critical systems in the entity, with a minimum of the following: 1-3-1-1 Carrying out stress testing of the technical components of critical systems (Stress Testing) to ensure the capacity of the various components.	Management Template	○ Distributed Stress Testing: It is about distributing stress on several devices that may be in different geographical areas and testing them at the same time to examine their endurance capacity. ○ Exploratory Stress Testing: It is a test that focuses on detecting and analyzing errors in technical components after testing and analyzing them in different scenarios, which cannot be easily covered in the scope of other tests. ○ Application Stress Testing: It is a test that focuses on detecting application-related errors, related to performance, network issues, and data blocking. ○ Systemic Stress Testing: It tests many systems running on the server, to detect errors (e.g.: One program blocking another program). ○ Transactional Stress Testing: It is a stress test that is conducted during the transitioning between applications, to ensure that the system is tuned and optimized. ● Document the results of stress tests for technical components of critical systems. ● Dealing with data based on its classification, so that special data and systems are specified for stress testing, and system data in the production environment is not used in the stress testing process. ● Define a plan for improvement based on test results and update implementation status.	● Document showing sample data used for stress testing of technical components of critical systems and not from production environments data. ● Improvement plan and implementation status for stress testing of technical components of critical systems.
--	--	--	----------------------------	---	---

	1.3.1.2	Ensure the application of business continuity requirements.	• Cybersecurity Roles and Responsibilities Template • Cybersecurity Requirements Checklist for IT Projects and Change Management Template • Cybersecurity Business Continuity Policy Template	• Work on conducting a risk assessment for risks that may affect business continuity. • Work on vulnerability remediation to prevent incidents that may impact business continuity. • Work on identifying the legislative and regulatory requirements that may impact business continuity. • Work on developing incident response plans that may impact business continuity. • Develop disaster recovery plans for business continuity. • Work to define the roles and responsibilities of third parties related to business continuity in the entity. • Reports of change requests on infrastructure assets to implement business continuity requirements. • Work to use the performance measurement indicator (KPI) to ensure the continuous development and correct and effective use of cybersecurity requirements for business continuity.	• Reports on the results of the risk assessment process affecting business continuity. • Reports on the results of the vulnerability assessment and remediation process affecting business continuity. • Reports or evidence demonstrating the comprehensiveness and coverage of legislative and regulatory requirements related to business continuity. • Cybersecurity Incident Response Plans impacting business continuity. • Disaster recovery plans. • A document of the roles and responsibilities of the parties related to business continuity within the organization. • Reports on change requests within the organization. • Reports on the Key Performance
--	----------------	---	---	--	--

					Indicators (KPI) related to business continuity.
1.3.2	1.3.2.1	In addition to sub controls in the ECC controls 3-6-1 1-3-2-1 Security Source Code Review prior to release	• Cybersecurity Requirements Checklist for Software Development Template • Secure Systems Development Life Cycle Policy Template	• Work on defining the scope of the source code to be reviewed before launching the project. • Work on reviewing the source code either by using technical tools, or reviewing manually, and that the methods of reviewing the source code be effective such as: reviewing gaps in the source code, ensuring that there is no confidential information in the source code, ensuring that there are no security problems in the design Source Code Ensure that unsafe algorithms are not used, and review the source code using OWASP. • Work on documenting the review results and defining a plan to address the source code comments. • Work to fully implement and follow up the treatment plan before launching the project.	• Source code security review procedures, which include: determining the scope of the source code, and the methods taken to conduct the source code security review. • Reports of the results of the security source code review. • Source code improvement plan reports. • Reports showing the implementation and follow-up of the source code improvement plan.
	1.3.2.2	Securing access, storage, and documentation of source code and its versions.	• Cybersecurity Requirements Checklist for Software Development Template • Secure Systems Development Life Cycle Policy Template	• Work to determine the scope of the source code. • Work to restrict access to the source code to developers and source code reviewers, by specifying access permissions according to the needs, duration, and scope of the work. • Work to define procedures for obtaining access permissions from responsible persons. • Work on reviewing the access permissions to the source code, and revoking the permissions if the work need or duration expires.	• Procedures for securing access, storage, and documentation of the source code, which include: determining the scope of the source code, and backup copies of the source code. • Procedures for requesting access to the source code from responsible persons.

				• Work to ensure that the source code is stored and documented in safe and reliable ways.	• A sample of requests for access permissions to the source code. • Reports from reviewing source code access permissions. • A list of restrictions applied to the level of access and storage security of the source code. • A list of previous versions of the source code and the restrictions applied to secure it.
	1.3.2.3	Authenticated API.	• Cybersecurity Requirements Checklist for Software Development Template • Secure Systems Development Life Cycle Policy Template	• Work on securing the application interface when there is integration with other applications. • Restricting access to the API, such as giving access permissions according to the scope of work. • Verify API access permissions. • Using secure protocols (such as TLS) in the API • Performing regular penetration tests on the API.	• Screenshot of locking the application interface when there is integration with other applications. • Reports of restricted API access. • Reports of API access verification. • Screenshot of Using secure protocols in the API. • Reports from Penetration tests on the API.
	1.3.2.4	Safe and reliable transfer of applications from the Testing Environment to the Production Environment, with any data, identities, or	• Cybersecurity Requirements Checklist for Software Development Template	• Work to delete any data, identities, or passwords related to the testing environment before transferring to the production environment. • Work to encrypt all critical systems data during transmission.	• Reports showing the deletion of any data, identities, or passwords related to the testing environment before

		passwords associated with the test environments deleted prior to transfer.	Secure Systems Development Life Cycle Policy Template	- Work to use safe, updated and approved transfer tools. - Work on providing an action plan to clarify the scope and time of the transfer. - Work on reviewing the implementation of the action plan for safe transportation and ensuring its effectiveness. - Work to develop and approve transportation procedures.	the transfer to the production environment. - Reports showing that all critical systems data is encrypted during transmission. - Reports of the tools used for the transfer process. - Action plan for the transportation process. - Review reports on the application of the action plan for the transfer process. - Approved procedures for the transportation process.
NCA OSMACC					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines:	Expected deliverables
N/A					
NCA TCC					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
N/A					
NCA DCC					

Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
N/A					
NCA OTCC					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
1.4.1	1.4.1.1	In addition to the ECC controls 1-6-2 and 1-6-3, cybersecurity requirements in OT/ICS project management must include, at a minimum, the following: 1-4-1-1 Cybersecurity requirements must be part of O'T/ICS project's lifecycle.	• Template for Cybersecurity requirements checklist on IT and change management projects • Template for Cybersecurity Operational Technology Policy	• Approve the updated OT/ICS project's lifecycle. • Verify and ensure that all OT/ICS projects are in line with the defined and approved OT/ICS project's lifecycle requirements.	• Document outlining the project management methodology for OT/ICS, detailing cybersecurity requirements throughout the lifecycle of projects related to OT/ICS • Evidence confirming that the project management methodology of OT/ICS, which outlines cybersecurity requirements throughout the lifecycle of projects related to OT/ICS, is up-to date and approved by the authorizing official or his/her delegate. • Evidence confirming that all projects related to OT/ICS are compliant with and

					adhere to the cybersecurity requirements approved in the lifecycle of projects related to OT/ICS
	1.4.1.2	Cybersecurity requirements must be included as part of any functional and acceptance testing and evaluation process (such as Factory Acceptance Testing "FAT", Site Acceptance Testing "SAT", Commissioning Testing, Change Testing, Integration Testing and Source Code Review).	• Template for Cybersecurity Operational Technology Policy • Template for OT/ICS Security Standard • Checklist for Cybersecurity Requirements in Software Development	• Develop, document and include cybersecurity requirements within Factory Acceptance Testing "FAT", Site Acceptance Testing "SAT", Commissioning Testing, Change Testing, Integration Testing, and Source Code Review. • Verify and ensure that all Factory Acceptance Testings "FAT", Site Acceptance Testings "SAT" • Commissioning Testings, Change Testings, Integration Testing, and Source Code Review are conducted in line with the defined OT/ICS cybersecurity requirements.	• A proof that Factory Acceptance Testing "FAT", Site Acceptance Testing "SAT", Commissioning Testing, Change Testing, Integration Testing, and Source Code Testing are in line with OT/ICS cybersecurity requirements. • Sample of the latest forms used related to Factory Acceptance Testing "FAT", Site Acceptance Testing "SAT", Commissioning Testing, Change Testing, Integration Testing, and Source Code Testing • showcasing the inclusion of cybersecurity requirements.
	1.4.1.3	Secure-by-design principles must be included as part of security architectural designs for	• Template for Cybersecurity Operational Technology Policy	• Define and include secure-by-design principles in security architectural designs for OT/ICS environments. • Implement secure-by-design principles for OT/ICS environments.	• Documented requirements for security architectural designs for OT/ICS environments

		O'T/ICS environments.	• Template for OT/ICS Security Standard • Checklist for Cybersecurity Requirements in Software Development	• Verify and ensure that all OT/ICS environments are designed using the secure-by-design principles.	showcasing the secure-by-design principles. • A proof that all security architectures for OT/ICS environments are designed based on secure-by-design principles.
	1.4.1.4	System development environments including testing environment and integration platforms must be protected.	• Template for Cybersecurity Operational Technology Policy • Template for OT/ICS Security Standard • Checklist for Cybersecurity Requirements in Software Development	• Identify if there is a system development environments including testing environment and integration platforms. • Define and document a procedure containing requirements related to the protection of the identified environments. • Approve the procedure by the systems owner. • Verify and ensure that the identified environments are protected in line with defined procedure.	• List of identified system development environments. • The approved procedure by systems owner. • A proof that all identified environments are protected in line with defined procedure.
1.4.2		Cybersecurity requirements within the organization's OT/ICS project management must be reviewed, and their implementation effectiveness is measured and evaluated periodically.	• Template for Cybersecurity Operational Technology Policy • Template for OT/ICS Security Standard • Template for Key Performance Indicator Report	• Regularly review cybersecurity requirements within OT/ICS project management according to a documented and approved review plan based on a specific time frame (eg., conducting annual periodic reviews). • Develop key performance indicators (KPIs) for each control within the related policy or procedure to ensure the implementation effectiveness is measured and evaluated periodically (based on defined frequency).	• Evidence confirming the periodic review of cybersecurity requirements within the organization's OT/ICS project management. • A proof that shows the key performance indicators (KPIs) for each control within the related policy or procedure to ensure the implementation

					effectiveness is measured and evaluated periodically (based on defined frequency).
NCA CCC CST					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
N/A					
NCA CCC CSP					
N/A					
SAMA CSF					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
3.1.5.1	3.1.5-1	Cyber security should be integrated into the Member Organization's project management methodology to ensure that cyber security risks are identified and addressed as part of a project.			
3.1.5.2	3.1.5-2	The Member Organization's project management methodology should ensure that: a. cyber security objectives are included in project objectives;			

		b. the cyber security function is part of all phases of the project; c. a risk assessment is performed at the start of the project to determine the cyber security risks and to ensure that cyber security requirements are addressed either by the existing cyber security controls (based on cyber security standards) or to be developed; d. cyber security risks are registered in the project-risk register and tracked; e. responsibilities for cyber security are defined and allocated; f. a cyber security review is performed by an independent internal or external party.			
CST CRF					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
1.7.1		Define and document [Requirements for Cybersecurity in Project Management] which consider the following: • Defining integration of cybersecurity in project management (e.g. cybersecurity personnel			

		as part of the project team) • Defining project objectives to ensure that the cybersecurity is included in all phases of the project			
1.7.2		Perform a risk assessment at the beginning and during the course of each project in accordance with the [Cybersecurity Risk Assessment] to identify the cybersecurity risks if any and define the mitigation plans.			
1.7.3		Track the identified cybersecurity risks and monitor the implementation of the mitigation plans during the course of the project. [Cybersecurity Risk Treatment and Monitoring].			
1.7.4		Continuously measure, review and optimize the [Requirements for Cybersecurity in Project Management].			
CMA Cybersecurity Guidelines					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
4.3.3.3		Set out, document, approve, implement, monitor and periodically			

		evaluate project management methodology.			
4.3.3.4		Project management methodology shall include cybersecurity requirements to ensure identification and addressing of cybersecurity-related risks as a part of the project			
4.3.3.5		Project management methodology shall include the following: Include cybersecurity objectives within the project objectives. Consider cybersecurity management as a part of project stages. Assess risks at the beginning of project in order to set out and process cybersecurity risks. Document Cybersecurity risks in project risk record and follow up these risks. Identify and assign cybersecurity responsibilities. Review cybersecurity by an independent internal or external party			
4.3.3.6		Project and change management methodology includes evaluating and processing vulnerabilities and			

		reviewing configuration, shielding and patching			
--	--	--	--	--	--

Risk Considerations in Cybersecurity in Information Technology Projects

Inadequate Integration of Cybersecurity in Project Lifecycle

- **Risk Description:** Cybersecurity may not be incorporated early enough in the project lifecycle, resulting in security vulnerabilities and inefficiencies.
- **Risk Mitigation:** Integrate cybersecurity from the project initiation phase, ensuring that secure design and risk management are considered from the outset.

Insufficient Vendor and Third-Party Security Oversight

- **Risk Description:** Lack of oversight of third-party vendors may introduce security risks into IT projects.
- **Risk Mitigation:** Ensure third-party vendors comply with cybersecurity requirements through due diligence, audits, and continuous monitoring.

Failure to Maintain Secure Development Practices

- **Risk Description:** Security flaws in software development (e.g., poor coding practices, lack of patching) can lead to vulnerabilities.
- **Risk Mitigation:** Adopt secure coding practices, conduct regular code reviews, and implement a continuous vulnerability assessment framework throughout the development cycle.

Lack of Testing and Validation of Security Controls

- **Risk Description:** Failure to thoroughly test security measures before deployment can lead to unforeseen risks.
- **Risk Mitigation:** Implement rigorous testing (e.g., penetration testing, vulnerability scanning) before deploying new IT systems or changes.

Insufficient Change Management and Patch Management

- **Risk Description:** New technology implementations may lead to outdated or incompatible patches, leaving systems vulnerable.
- **Risk Mitigation:** Adopt strong change and patch management processes that ensure timely updates and compatibility checks during project development and implementation.

Examples of Technologies for Effective Cybersecurity in Information Technology Projects

- **Project Management Tools**

Tools: Taiga, Redmine, Kanboard

Purpose: Plan, assign, and track cybersecurity-related tasks and milestones, ensuring timely delivery and team accountability across security-focused IT projects.

- **Secure Software Development Tools**

Tools: SonarQube (Community Edition), Semgrep, Brakeman

Purpose: Perform static application security testing (SAST) to identify vulnerabilities, insecure code patterns, and logic errors during development.

- **Version Control Systems**

Tools: Git, GitLab (Community Edition), Gitea

Purpose: Manage source code versions, enable collaborative development, and integrate security checks (e.g., SAST) into secure software pipelines.

- **Continuous Integration/Continuous Deployment (CI/CD) Tools**

Tools: Jenkins, GitLab CI/CD (open-source), Drone CI

Purpose: Automate code build, testing, and deployment workflows while embedding security validation checks (e.g., linting, SAST, compliance) into the pipeline.

- **Security Testing Tools**

Tools: OWASP ZAP, Burp Suite Community Edition, w3af, Nikto

Purpose: Simulate real-world attacks and scan web applications for vulnerabilities such as XSS, SQLi, and misconfigurations during the development and testing phases.

Examples of KPIs for Cybersecurity in Information Technology Projects

1. **Security Requirements Completion Rate:** Percentage of IT projects where cybersecurity requirements are fully integrated into project planning and execution.
2. **Vulnerability Assessment Results:** Number of vulnerabilities identified and remediated before project deployment.
3. **Security Testing Success Rate:** Percentage of IT projects that pass security testing (e.g., penetration tests, vulnerability scans) before going live.
4. **On-Time Project Delivery with Security Measures:** Percentage of IT projects delivered on time with all planned security measures in place.
5. **Security Defects Post-Deployment:** Number of cybersecurity-related issues identified in the first 30/60/90 days after an IT project's launch.

Case Study : Developing and Implementing Cybersecurity in Information Technology Projects for a Saudi Entity

Background:

A Saudi Entity , a critical player in the country's telecommunications infrastructure, sought to improve its cybersecurity posture as it embarked on multiple large-scale IT projects. As part of its digital transformation initiatives, Saudi Entity realized the importance of integrating cybersecurity requirements throughout the project management lifecycle to mitigate risks to its infrastructure, services, and customer data.

Saudi Entity's leadership wanted to ensure that its IT projects adhered to the highest cybersecurity standards to prevent data breaches, service disruptions, and ensure the protection of customer information. To achieve this, the entity decided to embed robust cybersecurity requirements into its Project and Asset Change Management procedures.

Phase 1: Defining Cybersecurity Requirements for Technology Projects

1. Integrating Cybersecurity into the Change Management Process

Saudi Entity's cybersecurity requirements for IT projects were included in the Project and Asset Change Management Procedures. This ensured that cybersecurity was a foundational part of project planning, risk assessments, and implementation. The requirements covered the following areas:

- **Vulnerability Assessment and Remediation:** Each technology project went through vulnerability assessments to identify and mitigate any security weaknesses before moving forward. Regular scans and penetration testing were conducted to ensure the integrity of systems.
- **Configuration Review and Secure Configuration:** Saudi Entity implemented a requirement for all projects to undergo a configuration review before deployment to ensure that the systems were securely configured and hardened against potential attacks. This included patching and securing any misconfigured systems.
- **Patching:** A strict patch management process was followed, ensuring that all software and systems were patched against known vulnerabilities before changes were deployed or services went live.

2. Cybersecurity Requirements for Software Development

For Saudi Entity's software development projects, cybersecurity requirements included:

- **Secure Coding Standards:** The entity mandated the use of OWASP guidelines and other secure coding practices to ensure that applications were free from common vulnerabilities such as buffer overflows, SQL injection, and cross-site scripting.
- **Using Trusted and Licensed Software Tools:** Only trusted, licensed, and secure development libraries and tools were used to ensure that no malware or unlicensed code was introduced.
- **Compliance Testing for Software:** Saudi Entity conducted extensive compliance testing for software projects to ensure that all applications adhered to both internal and external cybersecurity standards, such as GDPR and SAMA.
- **Integration of Software Components:** Secure integration practices were implemented to ensure that all software components communicated securely with one another, without exposing vulnerabilities in the system.
- **Configuration and Hardening of Software:** Saudi Entity implemented configuration review and hardening processes for software applications to ensure secure deployment.

Phase 2: Documentation, Approval, and Review

1. Documentation of Cybersecurity Requirements

Saudi Entity documented all cybersecurity requirements for technology projects, including risk assessments, vulnerability scanning, and secure software development practices. These were included in the Cybersecurity Standards for Technology Projects document.

2. Approval of Cybersecurity Standards

The documented standards were reviewed and approved by Saudi Entity's Cybersecurity Steering Committee and the CISO. This approval process involved a cross-functional review to ensure alignment with Saudi Entity's overall security strategy and regulatory obligations.

3. Periodic Review of Cybersecurity Requirements

Cybersecurity standards were reviewed periodically, with updates made in response to emerging threats, regulatory changes, or lessons learned from past projects. The review was conducted at least once per year, or more frequently if significant changes occurred in the cybersecurity landscape.

1.7 Cybersecurity Regulatory Compliance:

Definition: Cybersecurity regulatory compliance refers to the adherence to laws, regulations, and standards that govern how organizations must protect sensitive data and systems from cyber threats. Compliance ensures that the organization meets legal, industry-specific, and governmental requirements related to data protection, cybersecurity controls, and incident response. Non-compliance can lead to legal penalties, financial loss, and reputational damage [19], [20].

Objective:

To ensure that the organization's cybersecurity program is in compliance with related laws and regulations.

Controls Matrix:

Below is a summary matrix detailing relevant Cybersecurity Regulatory Compliance controls based on NCA, SAMA CSF, CST CRF, and CMA Cybersecurity guidelines:

Regulation	Main Controls	Control References
NCA ECC	2	1.7.1, 1.7.2
SAMA CSF	2	3.2.2, 3.2.3 (3 Sub controls)
CST CRF	4	1.3.1, 1.3.2, 1.3.3, 1.3.4
CMA Cybersecurity Guidelines	-	-
NCA CCCC	-	-
NCA CCC CST	1	1.3.T.1 (1 Sub control)
NCA CCC CSP	1	1.3.P.1 (1 Sub control)
NCA TCC	-	-
NCA DCC	-	-
NCA OSMACC	-	-
NCA OTCC	-	-

Cybersecurity Regulatory Compliance Controls:

Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines:	Expected deliverables
ECC					
1.7.1		The organization must comply with related national cybersecurity laws and regulations.	Compliance with Cybersecurity Standard controls, Laws and Regulations Policy Template.	- Work with stakeholders in the organization (i.e., legal function and governance and compliance function) to identify, document, and periodically update a list of national cybersecurity laws and regulations and related requirements that are relevant to the organization's operations and issued by the National Cybersecurity Authority (NCA) (which might include, but not limited to, royal orders and decrees, orders issued by the Council of Ministers, and official circulars and regulatory orders issued by the National Cybersecurity Authority (NCA)). - Ensure compliance with all national cybersecurity laws and regulations requirements referred to in the previous point. - Provide necessary technologies; to verify compliance with national cybersecurity laws and regulations. - Prepare periodic reports for organization's compliance with all national cybersecurity laws and regulations to be submitted to the National Cybersecurity Authority (NCA) whenever requested.	- A document (such as a policy, procedure, or/and letter approved by the authorization official) indicating the identification and documentation of the requirements related to this control. - An updated list that clarifies the national cybersecurity laws and regulations that are relevant to the organization's operations and issued by the National Cybersecurity Authority (NCA). - A report that clarifies the extent of organization's compliance with national cybersecurity laws and regulations applicable to the organization.

1.7.2		The organization must comply with any nationally-approved international agreements and commitments related to cybersecurity.		• Work with the organization's stakeholders to identify, document, approve and periodically update the list of international cybersecurity agreements or obligations, and periodically document and update them, subject to prior approval by the National Cybersecurity Authority. • Ensure compliance with all cybersecurity national laws and regulations requirements approved by the National Cybersecurity Authority within the organization. • Provide necessary technologies to verify compliance with the laws and regulations related to cybersecurity.	• A document (such as approved policy or procedure) indicating the identification and documentation of the requirements related to this control. • An updated list of locally approved international agreements and obligations applicable to cybersecurity function. • A report that outlines the extent of compliance with cybersecurity international agreements and obligations applicable to the organization.
NCA CCCC					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines:	Expected deliverables
N/A				•	•
NCA OSMACC					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines:	Expected deliverables
N/A					
NCA TCC					

Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
N/A					
NCA OTCC					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
N/A					
NCA CCC CST					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
1.3.T.1		In addition to the ECC control 1-7-1, the CST legislative and regulatory compliance should include as a minimum with the following requirements: 1-3-T-1-1 Continuous or real-time compliance monitoring of the CSP with relevant cybersecurity legislation and contract clauses.	• Template for Compliance with Laws and Regulations Policy • Template for Reviewing and Auditing Policy • Template for Audit Plan Record	• Identify national legislation and regulations related to cybersecurity of cloud services and Cloud Service Providers • Review the contract with CSP regarding cybersecurity obligations. • Define the way how to monitor/verify it regularly (eg: CSP's obligation to report to CSTs vulnerabilities can be verified with if these reports are delivered or justified) • Request CSP's compliance reports (e.g: by making it a contractual requirement) • Monitor CSP's compliance in a continuous manner (like daily or weekly verification) or in real-time (e.g. automated checks)	• CSP's compliance reports verified periodically. • Reports or evidence demonstrating the monitoring of compliance within contracts.
NCA CCC CSP					
1.3.P.1		In addition to the ECC control 1-7-1, the CSP legislative and regulatory compliance should	• Template for Compliance with Laws and Regulations Policy	• Identify Periodically (e.g. annually or when a change occurs) all laws, regulations, instructions, decisions, regulatory frameworks and controls, and	• List of all laws, regulations, instructions, decisions, regulatory frameworks and controls, and

		include as a minimum with the following requirements: 1.3.P.1.1 Continuous compliance with all laws, regulations, instructions, decisions, regulatory frameworks and controls, and mandates regarding cybersecurity in KSA.	• Template for Reviewing and Auditing Policy • Template for Audit Plan Log	mandates regarding cybersecurity that are being applied within the KSA. • Monitor CSP's compliance with these requirements in a continuous manner (eg. utilizing tools for daily or weekly verification).	mandates regarding cybersecurity that are being applied within the KSA that are applicable to the CSP. • Reports clarifying the status of compliance with these requirements. • Reports clarifying periodic plans for monitoring compliance.
SAMA CSF					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
3.2.2	3.2.2-1	A process should be established for ensuring compliance with relevant regulatory requirements affecting cyber security across the Member Organization. The process of ensuring compliance should: a. be performed periodically or when new regulatory requirements become effective; b. involve representatives from key areas of the Member Organization; c. result in the update of cyber security policy, standards and procedures to			

		accommodate any necessary changes (if applicable).			
3.2.3	3.2.3-1.a	The Member Organization should comply with: a. Payment Card Industry Data Security Standard (PCI-DSS);			
	3.2.3-1.b	b. EMV (Europay, MasterCard and Visa) technical standard;			
	3.2.3-1.c	c. SWIFT Customer Security Controls Framework – March 2017.			
CST CRF					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
1.3.1		Define and document [Requirements for Cybersecurity Compliance] which consider the following: • Relevant national legislative and regulatory requirements related to cybersecurity • Locally accredited international/cross-border requirements (e.g. included in internationally agreements or commitments)			

		• Organization's internal requirements			
1.3.2		Define and implement the {Compliance Process} to ensure compliance requirements are identified periodically, documented and communicated (e.g. when new regulatory requirements become effective, necessity to update the organization's cybersecurity requirements).			
1.3.3		Ensure the compliance requirements are incorporated within the organization.			
1.3.4		Continuously measure, review and optimize the [Requirements for Cybersecurity Compliance] as well as the effectiveness of the process to ensure compliance.			
CMA Cybersecurity Guidelines					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
N/A					

Risk Considerations in Cybersecurity Regulatory Compliance

Non-compliance with Changing Regulations

- **Risk Description:** Failure to stay current with changing cybersecurity regulations and industry standards can lead to non-compliance and legal penalties.
- **Risk Mitigation:** Establish a regulatory monitoring system to track changes in laws and industry standards and ensure regular updates to compliance procedures.

Overlooking Third-Party Compliance

- **Risk Description:** Third-party vendors or partners may not meet compliance standards, putting the organization at risk.
- **Risk Mitigation:** Implement vendor risk assessments and include compliance requirements in contracts with third parties.

Inadequate Documentation of Compliance Efforts

- **Risk Description:** Poor documentation can lead to difficulties in demonstrating compliance during audits or regulatory reviews.
- **Risk Mitigation:** Maintain detailed records of compliance activities, including audits, assessments, and corrective actions taken.

Compliance Fatigue and Resource Constraints

- **Risk Description:** Organizations may struggle with compliance requirements due to resource limitations or fatigue, leading to insufficient controls or neglect of updates.
- **Risk Mitigation:** Ensure sufficient resources are allocated to compliance activities, and promote a culture of compliance across the organization.

Insufficient Employee Awareness of Compliance Requirements

- **Risk Description:** Employees may be unaware of their roles in maintaining compliance, leading to inadvertent violations.
- **Risk Mitigation:** Include compliance requirements in training programs, and ensure employees understand the consequences of non-compliance.

Examples of Technologies for Effective Cybersecurity Regulatory Compliance

- **GRC Platforms**
Tools: Eramba (Community Edition), OpenGRC (OpenControl), SimpleRisk (Community Edition)
Purpose: Manage governance, risk, and compliance activities across frameworks (e.g., GDPR, HIPAA, ISO 27001) through centralized policy management, risk assessment, and audit tracking
- **Compliance Management Tools**
Tools: OSCAL (NIST Open Security Controls Assessment Language), OpenSCAP
Purpose: Track, assess, and document compliance with cybersecurity regulations and frameworks, providing structured assessments and continuous monitoring capabilities
- **Compliance Automation Tools**
Tools: Wazuh (with compliance modules), osquery, Chef InSpec
Purpose: Automate the enforcement and auditing of cybersecurity policies and regulatory requirements across systems and endpoints
- **Privacy Management Software**
Tools: PDP4E (Privacy Data Protection for Engineers), PrivaMap
Purpose: Support privacy-by-design implementation, automate data protection impact assessments (DPIAs), and monitor compliance with privacy regulations like GDPR

Examples of KPIs for Cybersecurity Regulatory Compliance

1. **Compliance Audit Success Rate:** Percentage of successful compliance audits (e.g., GDPR, PCI-DSS, HIPAA).
2. **Regulatory Violation Rate:** Number of regulatory violations or fines due to non-compliance with cybersecurity regulations.
3. **Compliance Automation Rate:** Percentage of compliance activities automated using tools like GRC platforms (e.g., RSA Archer, MetricStream).
4. **Regulatory Change Response Time:** Average time taken to respond to and implement changes after new cybersecurity regulations are introduced.
5. **Compliance Documentation Accuracy:** Percentage of cybersecurity policies, controls, and procedures aligned with regulatory requirements.

Case Study : Developing and Implementing Cybersecurity Roles and Responsibilities for a Saudi Financial Institution

Background:

A Saudi Financial Institution , a prominent player in the country's banking and finance sector, recognized the need to ensure that it fully complied with national cybersecurity laws, as well as internationally-recognized security frameworks. Given the sensitive nature of financial data and the institution's role in facilitating global transactions, it was imperative to develop a comprehensive cybersecurity framework that addressed the specific regulatory requirements set by both local and international bodies, including SAMA, PCI-DSS, and SWIFT.

Phase 1: Identifying Regulatory Compliance Requirements

1. National Cybersecurity Laws and Regulations

The financial institution analyzed the relevant national regulations, including:

- Saudi Arabian Monetary Authority (SAMA) cybersecurity regulations and standards.
- Data Protection Laws: Addressing the handling of personal and financial data within the context of the banking and finance industry.
- Specific compliance standards for financial institutions in the Kingdom, including laws related to customer data protection, digital payment systems, and financial transactions.

2. International Cybersecurity Frameworks

The institution also reviewed globally-recognized cybersecurity standards and regulatory frameworks, including:

- Payment Card Industry Data Security Standard (PCI-DSS): Ensuring secure processing, storage, and transmission of cardholder data.
- EMV (Europay, MasterCard, and Visa) Technical Standards: Aligning with global standards for payment systems security.
- SWIFT Customer Security Controls Framework (CSCF): Adhering to SWIFT's security controls for the protection of financial messaging systems.
- Other relevant international agreements or frameworks, such as the NIST Cybersecurity Framework and ISO/IEC 27001.

Phase 2: Establishing Cybersecurity Roles and Responsibilities

1. Compliance Ownership and Oversight

The institution established clear roles and responsibilities for ensuring compliance with cybersecurity regulations. These roles included:

- CISO: Responsible for overall cybersecurity compliance and governance.
- Compliance Officer: Responsible for ensuring adherence to financial regulations, including SAMA's cybersecurity guidelines and PCI-DSS.
- IT Security Team: Tasked with implementing the technical aspects of cybersecurity, such as vulnerability assessments, patching, and incident response.

2. Compliance Process Implementation

The institution implemented a compliance process with the following key steps:

- Periodic Compliance Reviews: Conducting periodic assessments to ensure adherence to national regulations (e.g., SAMA) and international standards (e.g., PCI-DSS, SWIFT).
- Collaboration with Key Areas: The compliance process involved representatives from various departments, including IT, legal, risk management, and internal audit.

- **Cybersecurity Policy Updates:** Any changes in regulations were incorporated into the institution's cybersecurity policies, standards, and procedures.

3. Regulatory Compliance Training

- **Employee Training:** A comprehensive training program was developed to educate employees about compliance with cybersecurity regulations, particularly PCI-DSS and SWIFT CSCF requirements.
- **Role-Specific Training:** Specialized training was delivered to key departments (e.g., payment processing teams, software developers) to ensure that they followed the relevant standards.

Phase 3: Compliance Monitoring and Reporting

1. Regular Compliance Audits

- **Internal Audits:** Regular internal audits were performed to assess the institution's compliance with cybersecurity requirements.
- **Third-Party Audits:** The institution also underwent third-party audits for specific compliance areas like PCI-DSS and SWIFT.

2. Reporting to Management

- **Compliance Dashboards:** Real-time dashboards were created to track compliance status, issues, and risks.
- **Executive Reporting:** Regular compliance reports were submitted to senior management and the board, detailing the institution's status in meeting national and international cybersecurity regulations.

1.8 Cybersecurity Periodical Assessment and Audit:

Definition: Cybersecurity periodical assessment and audit refers to the regular, systematic evaluation of an organization's cybersecurity posture and its adherence to policies, standards, and regulatory requirements. This process involves internal and external audits, vulnerability assessments, and control testing to identify gaps, weaknesses, and areas for improvement in the organization's cybersecurity defenses [21], [22] .

Objective:

To ensure that cybersecurity controls are implemented and in compliance with organizational policies and procedures, as well as related national and international laws, regulations and agreements.

Controls Matrix:

Below is a summary matrix detailing relevant Cybersecurity Periodical Assessment and Audit controls based on NCA, SAMA CSF, CST CRF, and CMA Cybersecurity guidelines:

Regulation	Main Controls	Control References
NCA ECC	3	1.8.1, 1.8.2, 1.8.3
SAMA CSF	1	3.2.5 (2 Sub controls)
CST CRF	1	1.4 (7 Sub controls)
CMA Cybersecurity Guidelines	1	4.2.2 (4 Sub controls)
NCA CSCC	2	1.4.1, 1.4.2
NCA CCC CST	-	-
NCA CCC CSP	-	-
NCA TCC	-	-
NCA DCC	2	1.1.1, 1.1.2
NCA OSMACC	-	-
NCA OTCC	2	1.6.1, 1.6.2

Cybersecurity Periodical Assessment and Audit Controls:

Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines:	Expected deliverables
ECC					
1.8.1		Cybersecurity reviews must be conducted periodically by the cybersecurity function in the organization to assess the compliance with the cybersecurity controls in the organization.	• Cybersecurity Review and Audit Template. • Cybersecurity Review and Audit Log Template.	• Review the implementation of cybersecurity requirements at the organization by the cybersecurity function periodically according to a documented and approved plan for review and based on a period specified in the policy (e.g., quarterly review), to ensure that the cybersecurity controls of the organization are effectively implemented and operate in accordance with the regulatory policies and procedures of the organization, the national laws and regulations, and the international requirements approved by the organization.	• A document (such as approved policy or procedure) indicating the identification and documentation of the requirements related to this control. • Approved plan to review the implementation of cybersecurity controls. • Documents that confirm the implementation of Cybersecurity Standard controls information, technology, and physical assets. • Periodic review reports of cybersecurity controls implementation in the organization.
1.8.2		Cybersecurity audits and reviews must be conducted by independent parties	• Cybersecurity Review and Audit Template.	• Review and audit cybersecurity controls implementation at the organization by parties independent of the cybersecurity function, such as the internal audit	• A document (such as approved policy or procedure) indicating the identification and

		outside the cybersecurity function (e.g., Internal Audit function) to assess the compliance with the cybersecurity controls in the organization. Audits and reviews must be conducted independently, while ensuring that this does not result in a conflict of interest, as per the Generally Accepted Auditing Standards (GAAS), and related laws and regulations.	• Cybersecurity Review and Audit Log Template.	department, or by third parties that cooperated with independently from the relevant cybersecurity function to achieve the principle of non-conflict of interests when reviewing the implementation of all cybersecurity requirements in the organization. • Perform the review periodically according to a documented and approved plan for review and based on a period specified in the policy (e.g., review must be conducted annually), in order to ensure that the organization's cybersecurity controls are effectively implemented and operate in accordance with the regulatory policies and procedures of the organization, the national laws and regulations approved by NCA, and the international requirements approved by the organization.	documentation of the requirements related to this control. • Approved plan to review and audit the implementation of cybersecurity controls. • Audit reports by the internal audit department or an independent external auditor on all cybersecurity requirements of the organization
1.8.3		Results from the cybersecurity audits and reviews must be documented and presented to the cybersecurity steering committee and Authorizing Official. Results must include the audit/review scope, observations, recommendations and remediation plans.	• Cybersecurity Review Report Template.	• Review and document results of cybersecurity review and audit. The review report must include: ○ Scope of review and audit. ○ Discovered observations. ○ Recommendations and corrective actions. ○ Observations remediation plan. • Share and discuss the results of cybersecurity review and audit with the cybersecurity supervisory committee and the representative.	• A document (such as approved policy or procedure) indicating the identification and documentation of the requirements related to this control. • Audit reports (by the internal audit department or compliance department or an independent external auditor on all cybersecurity requirements of the organization .

					Evidence that the results of the cybersecurity review and audit presented the cybersecurity supervisory committee and the representative.
NCA CSCC					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines:	Expected deliverables
1.4.1		Referring to officer 1-8-1 in the basic controls of cybersecurity, the department concerned with cybersecurity must; Review the implementation of cyber security controls for critical systems, once a year; at least.	- Cybersecurity Review and Audit Policy Template - Compliance with Cybersecurity Legislation and Regulations Policy Template - Audit Plan Risk Register Template	- Ensure that the plan to review the implementation of cybersecurity requirements includes all critical systems in the entity. - Work on documenting the results of the cyber security review and audit and discussing them with the concerned departments. - Presenting the results to the Cyber Security Supervisory Committee and the authorized person, and the results should include the scope of the review and audit, the observations discovered, recommendations and corrective actions, the evaluation of cyber risks and the plan to identify the observations. - Review the implementation of cyber security controls for critical systems on an annual basis.	- Plan to review the implementation of cybersecurity requirements or controls. - Periodic review reports on the implementation of cybersecurity controls for critical systems in the entity, including a plan for addressing observations. - Meeting notes transcript of the Cybersecurity Supervisory Committee.
1.4.2		Referring to officer 2-8-1 in the basic controls of cybersecurity, the application of cybersecurity	- Cybersecurity Review and Audit Policy Template - Compliance with Cybersecurity	Ensure that the cyber security audit plan by independent parties includes all critical systems in the entity.	Audit reports of cybersecurity controls for critical systems; By parties independent of the department

		controls for critical systems must be reviewed; By parties independent of the department concerned with cybersecurity from within the entity, once; At least every three years.	Legislation and Regulations Policy Template Audit Plan Risk Register Template	Auditing of cybersecurity controls for critical systems is carried out at least every three years.	concerned with cybersecurity from within the entity, once; At least every three years. - Plan to review the implementation of cybersecurity controls requirements. - Meeting notes transcript of the Cybersecurity Supervisory Committee - Work on documenting reports and discussing the plan to address observations with the relevant departments.
NCA OSMACC					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines:	Expected deliverables
N/A					
NCA TCC					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
N/A					
NCA OTCC					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables

1.6.1		With reference to ECC control 1-8-1, the organization's cybersecurity function must review the implementation of (OTCC-1:2022) controls at least annually.	• Template for Cybersecurity Operational Technology Policy • Template for OT/ICS Security Standard • Template for Cybersecurity Auditing Procedure • Template for Cybersecurity Audit Plan Record	• Review the implementation of (OTCC-1:2022) controls at least annually. • Ensure that the results are documented and shared with relevant functions within the organization.	• The reports for the review of the implementation of (OTCC-1:2022) controls. • A proof that the results have been shared with relevant functions within the organization.
1.6.2		With reference to ECC control 1-8-2, the implementation of (OTCC-1:2022) controls must be reviewed by independent parties within the organization, outside the cybersecurity function at least once every three years.	• Template for Cybersecurity Operational Technology Policy • Template for OT/ICS Security Standard • Template for Cybersecurity Auditing Procedure • Cybersecurity Audit Report Template	• Review the implementation of (OTCC-1:2022) controls at least once every three years by independent parties of the Cybersecurity Organization such as internal audit, or by third parties. • Ensure that the results are documented and shared with relevant functions within the organization and to follow up on the observed notes until they are addressed.	• The reports for the review of the implementation of (OTCC-1:2022) controls conducted by independent parties of the Cybersecurity Organization such as internal audit, or by third parties. • A proof that the results have been shared with relevant functions within the organization and to follow up on the observed notes until they are addressed.
NCA DCC					
1.1	1.1.1	With reference to ECC control 1-8-1, the cybersecurity function in the organization must review the implementation of the Data Cybersecurity	• Template for Cybersecurity Auditing Procedure • Template for Cybersecurity Reviewing and Auditing Policy	• Identify the requirements of this control and document them in a cybersecurity requirements document, followed by approval from the authorizing officials. • Review the implementation of all Data Cybersecurity requirements in the	• Document detailing the identification and documentation of the requirements of this control (e.g. a policy and/or procedure

		Controls periodically as specified for each data classification level.	• Template for Cybersecurity Auditing Plan Log	organization as per the data classification level. • Review must be conducted at least annually across all data classification levels. • Review must be conducted at least annually for the implementation of Data Cybersecurity Controls across all data classification levels. • An approved audit plan based on the specified period of time should be documented and approved to ensure that cybersecurity controls are effectively implemented and operate in accordance with the organizational policies and procedures, as well as related national and international laws, regulations and agreements.	approved by the authorizing officials). • Annual review report for all data classification levels at least once a year.
	1.1.2	With reference to ECC control 1-8-2, cybersecurity review and audit must be conducted periodically by independent parties outside the organization's cybersecurity function as specified for each data classification level.	• Template for Cybersecurity Reviewing and Auditing Policy	• Identify the requirements of this control and document them in a cybersecurity requirements document, followed by approval from the authorizing officials. • Identify the independent parties outside the organization's cybersecurity function, such as internal audit management or third party auditors, to review and audit the implementation of Data Cybersecurity Controls in the organization. • Review must be conducted at least every 2 years or less for Public or Confidential data classification level and at least annually or less for Secret or Top Secret data classification level. • Implement Data Cybersecurity Controls by independent parties separate from the cybersecurity management within the	• Document detailing the identification and documentation of the requirements of this control (e.g. a policy and/or procedure approved by the authorizing officials). • Independent auditor's report that were carried out on all data cybersecurity requirements in the organization.

				organization, according to the specified timeframe for each level. An approved audit plan based on the specified period of time should be documented to ensure that the cybersecurity controls are effectively implemented and operate in line with the organizational policies and procedures of the authority, the relevant national legal and regulatory requirements, and international requirements.	
NCA CCC CST					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
N/A					
NCA CCC CSP					
N/A					
SAMA CSF					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
3.2.5	3.2.5-1	Cyber security audits should be performed independently and according to generally accepted auditing standards and SAMA cyber security framework.			
	3.2.5-2	Cyber security audits should be performed according to the Member Organization's audit manual and audit plan.			

CST CRF,					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
1.4	1.4.1	Define and document [Requirements for Cybersecurity Audit] which consider the following: • Conducting independent and periodical audits (e.g. conduct audits at least once a year for critical systems) • Protection and retention of [Audit Records] • Reporting to top management			
	1.4.2	Define and implement {Internal Audit} process to verify the compliance with the identified [Requirements for Cybersecurity Compliance].			
	1.4.3	Conduct independent audits at planned intervals (or when significant changes occur) to review the implementation of the [Requirements for Cybersecurity Compliance] in the organization.			

	1.4.4	Document the findings and recommendations and present them to the top management.			
	1.4.5	Protect the [Audit Records] from unauthorized access, modification, and destruction.			
	1.4.6	Ensure that the audit records are retained as proof for e.g. compliance to legislative and regulatory requirements.			
	1.4.7	Continuously measure, review and optimize the [Requirements for Cybersecurity Audit] as well as the effectiveness of the process and review activities.			
CMA Cybersecurity Guidelines					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
4.2.2	4.2.2.1	Perform review and audit for cybersecurity controls periodically.			
	4.2.2.2	Document results and remarks of review and recommended procedures, and then communicate the same to the authorized person.			
	4.2.2.3	Perform Cybersecurity audit by parties independent from			

		Cybersecurity Department according to the generally accepted auditing standards and in accordance with Market Institutions Cybersecurity Manual.			
	4.2.2.4	Review application of cybersecurity controls in accordance with the internal audit manual and plan adopted by the market institution.			

Risk Considerations in Cybersecurity Periodical Assessment and Audit

Lack of Independent Auditing

- **Risk Description:** Audits conducted by internal personnel without independence may lead to biased results and overlook security gaps.
- **Risk Mitigation:** Ensure that audits are conducted by independent, qualified third parties or external auditors.

Failure to Act on Audit Findings

- **Risk Description:** Even if vulnerabilities or issues are identified, failure to take timely corrective actions can leave the organization exposed.
- **Risk Mitigation:** Establish a clear process for addressing audit findings, including assigning responsibilities and tracking resolution timelines.

Inconsistent Auditing Practices

- **Risk Description:** Irregular or poorly defined auditing practices can lead to incomplete assessments of cybersecurity controls.
- **Risk Mitigation:** Develop a standardized auditing framework, with regular and comprehensive audits to ensure consistent and thorough evaluations.

Insufficient Audit Scope

- **Risk Description:** Audits may focus only on specific areas and miss critical aspects of cybersecurity risk, such as third-party risk or new technologies.
- **Risk Mitigation:** Ensure that audits cover all relevant areas of cybersecurity, including emerging threats and risks from third-party services.

Audit Delays and Resource Constraints

- **Risk Description:** Delays in performing cybersecurity audits or insufficient resources to conduct them may lead to missed vulnerabilities.
- **Risk Mitigation:** Set clear schedules for periodic audits and allocate the necessary resources to ensure timely execution.

Examples of Technologies for Effective Cybersecurity Periodical Assessment and Audit

- **Audit Management Tools**

Tools: Eramba (Community Edition), OpenAudit, AuditNet (framework templates)

Purpose: Automate audit workflows, track findings, and manage remediation plans aligned with cybersecurity standards and risk-based auditing

- **Security Testing and Scanning Tools**

Tools: OpenVAS, Nikto, Wapiti

Purpose: Perform automated vulnerability scanning and basic compliance auditing to detect weaknesses and verify cybersecurity posture

- **Penetration Testing Tools**

Tools: Metasploit Framework, Kali Linux

Purpose: Simulate real-world attacks and assess system defenses as part of internal or external cybersecurity audits

- **Risk and Compliance Auditing Tools**

Tools: SimpleRisk (Community Edition), OpenGRC, Wazuh (with audit and compliance modules)

Purpose: Plan and execute risk-based audits, track audit results, and ensure alignment with regulatory and industry security frameworks

Examples of KPIs for Cybersecurity Periodical Assessment and Audit

1. **Audit Completion Rate:** Percentage of scheduled audits completed within the defined timeframes.
2. **Audit Findings Severity:** Percentage of audit findings classified as high severity (critical issues vs. minor recommendations).
3. **Audit Remediation Rate:** Percentage of audit findings addressed and remediated within a specified timeframe.
4. **External vs. Internal Audit Findings:** Comparison of findings from internal vs. external audits to evaluate the effectiveness of internal controls.
5. **Audit Process Efficiency:** Average time taken to complete an audit cycle from initiation to reporting.

Case Study: Developing and Implementing Cybersecurity Periodical Assessment and Audit for a Saudi Investment Market Member

Background:

A Saudi Investment Market Member, a key player in the Kingdom's financial market, recognized the need to ensure a robust cybersecurity posture to safeguard its investment activities and protect sensitive financial data. With increasing regulatory pressure from the Saudi Arabian Capital Market Authority (CMA) and other international financial institutions, The organization decided to establish a formal cybersecurity assessment and audit framework to periodically assess its cybersecurity controls and ensure compliance with the Market Institutions Cybersecurity Manual and international standards.

Phase 1: Designing the Cybersecurity Audit and Assessment Framework

1. Understanding Regulatory and Compliance Requirements

The organization identified the following key regulatory and compliance requirements that informed its cybersecurity audit process:

- Saudi Capital Market Authority (CMA) Cybersecurity Regulations.
- Market Institutions Cybersecurity Manual issued by the Saudi Stock Exchange (Tadawul).
- Financial industry standards such as PCI-DSS, SWIFT Customer Security Controls Framework (CSCF), and other relevant international standards.

2. Defining the Cybersecurity Review Scope

The organization defined the audit scope, focusing on:

- Cybersecurity controls related to access management, data protection, and network security.
- Incident detection and response mechanisms.
- Compliance with the Market Institutions Cybersecurity Manual and any other applicable cybersecurity standards.
- Security of online trading systems and financial transaction data.

3. Selecting Independent Audit Functions

The organization appointed an internal audit team that operated independently of the cybersecurity function, in line with Generally Accepted Auditing Standards (GAAS). The audit team was tasked with:

- Conducting regular cybersecurity audits as per the predefined audit plan.
- Collaborating with third-party auditors when necessary for specialized reviews (e.g., security of trading platforms).

Phase 2: Conducting Cybersecurity Audits and Reviews

1. Audit Execution

- Cybersecurity Audits: Independent auditors conducted comprehensive assessments, reviewing:
 - Security architecture of trading platforms.
 - Compliance with data protection and privacy regulations.
 - Authentication and access control mechanisms for systems with high-value transactions.
- Third-Party Service Providers: Audits included the review of external service providers and their compliance with the organization's cybersecurity policies.

2. Documentation and Reporting

- Audit Results: Audit findings were documented and included:
 - Scope of the audit and areas assessed.
 - Observations on any gaps, weaknesses, or areas of non-compliance.
 - Recommendations for strengthening controls.

- Remediation plans to address identified issues.
- The final audit reports were presented to the Cybersecurity Steering Committee and the Authorizing Official (e.g., CISO or CEO).

Phase 3: Remediation and Monitoring

1. Remediation Process

The cybersecurity function worked with relevant teams to implement remediation plans:

- Policy Updates: Updating cybersecurity policies to address audit findings.
- Security Enhancements: Enhancing technical controls based on audit recommendations, such as implementing advanced threat detection tools.
- Training: Providing additional training for employees based on identified areas of improvement.

2. Continuous Monitoring

- The organization established a continuous monitoring system to track the status of remediation efforts and ensure that the organization remained compliant with cybersecurity regulations.
- Follow-Up Audits were conducted to assess the effectiveness of the remediation efforts.

1.9 Cybersecurity in Human Resources:

Definition: Cybersecurity in human resources refers to the integration of cybersecurity practices within HR policies and processes to ensure that employees are appropriately screened, trained, and monitored regarding cybersecurity responsibilities. It includes ensuring that access rights to critical systems are managed, and that all personnel are aware of their roles in protecting the organization's information assets [23], [24], [25].

Objective:

To ensure that cybersecurity risks and requirements related to personnel (employees and contractors) are managed efficiently prior to employment, during employment and after termination/separation as per organizational policies and procedures, and related laws and regulations.

Controls Matrix:

Below is a summary matrix detailing relevant Cybersecurity in Human Resources controls based on NCA, SAMA CSF, CST CRF, and CMA Cybersecurity guidelines:

Regulation	Main Controls	Control References
NCA ECC	6	1.9.1, 1.9.2, 1.9.3, 1.9.4, 1.9.5, 1.9.6
SAMA CSF	1	3.3.1 (7 Sub-controls)
CST CRF	5	1.8.1, 1.8.2, 1.8.3, 1.8.4, 1.8.5
CMA Cybersecurity Guidelines	1	4.1.5 (3 Sub-controls)
NCA CCCC	1	1.5.1 (2 Sub-controls)
NCA CCC CST	1	1.4.T.1 (1 Sub-control)
NCA CCC CSP	2	1.4.P.1, 1.4.P.2 (4 Total sub-controls)
NCA TCC	-	-
NCA DCC	1	1.2.1 (2 Sub-controls)
NCA OSMACC	1	1.3.1 (2 Sub-controls)

Cybersecurity Human Resources Controls:

Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines:	Expected deliverables
NCA ECC					
1.9.1		Personnel cybersecurity requirements (prior to employment, during employment and after termination/separation) must be defined, documented and approved.	Human Resources Cybersecurity Policy Template	- Define and document personnel cybersecurity requirements in the cybersecurity requirements document and approved by the representative Requirements include, but are not limited to - Include cybersecurity responsibilities and non-disclosure clauses in the contracts of employees in the organization (to cover the periods during and after the end/termination of the job relationship with the organization) - Conduct screening or vetting for the personnel of cybersecurity functions, technical functions with privileged access, and critical systems functions - Ensure the comprehensiveness of the cybersecurity requirements related to employees during the employee's lifecycle in the organization, including the following requirements	Cybersecurity policy for human resources approved by the representative

				• Cybersecurity requirements prior to recruitment • Cybersecurity requirements during work • Cybersecurity requirements upon completion or termination of work • Support the organization's policy by the Executive Management This must be done through the approval of the organization head or his/ her deputy	
1.9.2		The personnel cybersecurity requirements must be implemented.	•	• Implement all personnel-related cybersecurity requirements that have been identified, documented and approved in the Human Resources Cybersecurity Policy • Develop an action plan to implement cybersecurity requirements related to the personnel of the organization • Include personnel cybersecurity requirements in the organization's HR procedures to ensure compliance with cybersecurity requirements for all internal and external stakeholders	• Documents that confirm the implementation of cybersecurity requirements related to personnel as documented in the HR Cybersecurity Policy • Cybersecurity Function Personnel contract Forms (signed copy) • Screening or vetting requests for the personnel of cybersecurity functions and technical functions with privileged access
1.9.3		The personnel cybersecurity requirements prior to employment must include at least the following: 1-9-3-1 Inclusion of personnel cybersecurity responsibilities and non-disclosure clauses (covering the cybersecurity	• Acknowledgment and confidentiality templates	• Define and document the requirements of this ECC in the cybersecurity requirements document and approve them by the representative • Work with relevant departments to include cybersecurity responsibilities and non-	• A document (such as approved policy or procedure) indicating the identification and documentation of the requirements related to this control

		requirements during employment and after termination/ separation) in employment contracts. 1-9-3-2 Screening or vetting candidates of cybersecurity and critical/privileged positions.		disclosure clauses in the contracts of employees in the organization (to cover the periods during and after the end/termination of the job relationship with the organization) • Include such requirements in the organization's HR procedures to ensure compliance with cybersecurity requirements for all internal and external stakeholders • Define and document the requirements of this ECC in the cybersecurity requirements document and approve them by the representative • Work with relevant departments to ensure Screening or Vetting of all employees in cybersecurity functions • Work with relevant departments to ensure the Screening or Vetting of all employees working in technical functions with privileged access, including database management personnel, firewall management personnel, and systems management personnel • Include such requirements in the organization's HR procedures to ensure compliance with cybersecurity requirements for all internal and external stakeholders	• Evidence that the Screening or Vetting of employees working in cybersecurity functions and technical functions with privileged access was performed, including but not limited to ○ An official document from the relevant authorities indicating the performance of Screening or Vetting
--	--	--	--	---	--

1.9.4		The personnel cybersecurity requirements during employment must include at least the following: 1-9-4-1 Cybersecurity awareness (during on-boarding and during employment). 1-9-4-2 Implementation of and compliance with the cybersecurity requirements as per the organizational cybersecurity policies and procedures.	•	• Define and document the requirements of this ECC in the cybersecurity requirements document and approve them by the representative • Work with relevant departments to provide cybersecurity awareness at the beginning and during work through the organization's approved communication channels • Include such requirements in the organization's HR procedures to ensure compliance with cybersecurity requirements for all internal and external stakeholders • Support the organization's policy by the Executive Management This must be done through the approval of the representative • Define and document the requirements of this ECC in the cybersecurity requirements document and approve them by the representative • Inform all employees of the organization and obtain their approval on the cybersecurity policies and procedures, in order to educate the organization's employees of the importance of their role in implementing the cybersecurity requirements • Include personnel cybersecurity requirements in the organization's HR procedures to	• A document (such as approved policy or procedure) indicating the identification and documentation of the requirements related to this control • Documents that confirm the provision of awareness content to employees in cybersecurity before work at the organization and providing them with access through e-mails, workshops, or any other means, including but not limited to ○ Review cybersecurity awareness messages shared with employees through emails ○ Review of content presented in the workshop ○ Review the cybersecurity awareness plan • A document (such as approved policy or procedure) indicating the identification and documentation of the requirements related to this control. • An acknowledgment form for approving cybersecurity policies by one of the organization's employees (signed copy)
---------------------	--	--	---	---	--

				ensure compliance with cybersecurity requirements for all internal and external stakeholders	
1.9.5		Personnel access to information and technology assets must be reviewed and removed immediately upon termination/separation.	•	- Define and document the requirements of this ECC in the cybersecurity requirements document and approve them by the representative - Review access of employees and revoke it immediately after the end/termination of their professional service at the organization, which may include the following - Define professional end-of-service or termination procedures covering cybersecurity requirements - o Ensure the return of all organization's assets and revoke employees' access rights immediately upon the end of their relationship with the organization	A discharge form with a signed and approved sample for the implementation of the procedures
1.9.6		Personnel cybersecurity requirements must be reviewed periodically.	•	Review and update the cybersecurity policy and requirements for personnel in the organization periodically according to a documented and approved plan for review and based on a planned interval (e.g., review must be conducted annually) or in the event of changes in related laws and regulations Document the review and changes to the	- An approved document that sets the policy's review schedule - Policy indicating that it is up to date and the changes to the cybersecurity requirements for personnel have been documented and approved by the head of the organization or his/her deputy

				cybersecurity requirements for personnel in the organization and approve them by the head of the organization or his/her deputy	Formal approval by the head of the organization or his/her deputy on the updated policy (e.g., via the organization's official e-mail, paper or electronic signature)
NCA CCCC					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines:	Expected deliverables
1.5.1	1.5.1.1	In addition to the sub-controls within Control 3-9-1 in the basic controls of cybersecurity, it must cover the requirements of cybersecurity, before the start of the professional relationship of employees with the entity, at a minimum level; the following: 1-5-1-1 Screening or Vetting for personnel working on critical systems.	Human Resources Cybersecurity Policy Template	- Determine the job positions related to the critical systems for which the security scan is to be conducted, which includes, e.g.: - Database Administrator for critical systems. - Network Administrator for critical systems. - Domain Administrator for critical systems. - System Administrators from the technical and business side for critical systems. - All contract employees. - Developing, documenting, and approving a procedure for conducting security scans on workers on critical systems on a regular basis. - Conducting security scanning for candidates to work on critical systems as part of the recruitment process, which includes, e.g.:	- Security scanning for personnel working on critical systems, which include eg: - A list of all personnel working on critical systems from the operational and technical side, indicating their nationalities, roles and responsibilities. - Database Administrator security scanning for critical systems. - Security scanning of Network Administrators for critical systems. - Security scanning of Domain Administrator for critical systems. - Security survey for System Administrators from the technical side (Custodian) and from the business owner side of critical systems.

				○ Review the recommendations of previous employers, submitted by the candidate, and ensure their accuracy (for those with experience). ○ Verify the validity of the applicant's CV. ○ Ensure the academic and professional qualifications claimed. ○ Independent verification of identity (personal ID, passport, etc.). ○ Review criminal records from the concerned authorities. • Verify that a security scan has been performed on existing workers on critical systems. Which may include: ○ Ensure that the candidate is competent enough to perform his role in protecting information. ○ Ensure that the candidate is trusted to assume the job duties.	
	1.5.1.2	1-5-1-2 To occupy support functions, and technical development, for critical systems; Competent citizens.	• Human Resources Cybersecurity Policy Template	• identify critical jobs for those working on critical systems, which include, but are not limited to: ○ Administrative careers. ○ Support careers. ○ Technical development. • Ensure that competency requirements for each job description for those working	• The job description of the current employees working on critical systems at the entity, • which includes, e.g.: ○ Job title ○ The purpose of the job ○ Duties and responsibilities ○ Required qualifications ○ Preferred qualifications

				- on critical systems are identified and documented. - Ensure the selection and nomination of highly qualified citizens to fill administrative positions, support positions, and technical development positions related to critical systems.	- working conditions - Resumes of employees working on critical systems, including administrative positions and technical support and development positions.
NCA OSMACC					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines:	Expected deliverables
1.3.1	1.3.1.1	In addition to the subcontrols within control 1-9-4 in the ECC, the cybersecurity requirements for personnel responsible for managing the organization's social media accounts should include at least the following: 1-3-1-1 Cybersecurity awareness about social media accounts.	- Plan for Cybersecurity Awareness Program - Template for Acceptable Use Policy - Template for Cybersecurity Human Resources	- Develop and document a social media cybersecurity awareness program, which must include topics such as use of social media, do's and don'ts of social media, managing access to the social media accounts, privacy issues on social media, types of cybercrimes social media accounts are prone to, organization's brand value on social media etc. - All personnel responsible for managing the social media accounts must be undergoing the cybersecurity awareness program for social media accounts. - Conduct the social media cybersecurity awareness program for employees and individuals responsible for managing social media accounts	- Documented and approved customized awareness program for organization's social media. - Records of periodically conducted awareness sessions/training.

				on a periodic basis and maintain record of training.	
	1.3.1.2	1-3-1-2 Implementation of and compliance with the cybersecurity requirements as per the organizational cybersecurity policies and procedures for the organization's social media accounts.	• Template for Cybersecurity Human Resources Policy • Template for Cybersecurity Policies Compliance • Template for Confidentiality Agreement	• Implement the cybersecurity requirements for the social media accounts as part of organizations cybersecurity policies. • Verify the compliance to cybersecurity requirements for the social media accounts in a periodic basis, as defined in the organization's policies and procedures. • Ensure that all personnel have read and signed the Acceptable Use Policy.	• Compliance report of cybersecurity requirements for the organization's social media accounts. • Sample of implementation of cybersecurity requirements for the social media accounts. • Sample of Acceptable Use Policy forms signed by the organization's personnel.
NCA TCC					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
N/A					
NCA OTCC					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
1.7.1		In addition to subcontrols in the ECC control 1-9-3, cybersecurity requirements related to human resources for OT/ICS environment must include, at a minimum, screening or vetting of all personnel including employees, contractors and subcontractors) who have	• Template for Cybersecurity Operational Technology Policy • Template for OT/ICS Security Standard • Template for Cybersecurity	• Identify list of individuals who has access or can utilize the OT/ICS assets (including employees, contractors and subcontractors). • Ensure that screenings or vetting is conducted for the identified list.	• The identified list of individuals of who has access or can utilize the OT/ICS assets (including employees, contractors and subcontractors). • A proof that the screenings or vetting is conducted for the identified list.

		access or can utilize OT/ICS assets prior to granting them access.	Human Resources Policy		
1.7.2		With reference to the ECC control 1-9-6, the cybersecurity requirements for cybersecurity in human resources in OT/ICS must be reviewed, and their implementation effectiveness is measured and evaluated periodically.	• Template for Cybersecurity Operational Technology Policy • Template for OT/ICS Security Standard • Template for Cybersecurity Human Resources Policy • Template for Key Performance Indicator Report	• Regularly review the cybersecurity requirements for O'T/ICS relate to human resources according to a documented and approved review plan based on a specific timeframe (e.g., conducting annual reviews). • Develop key performance indicators (KPIs) for each control within the related policy or procedure to ensure the implementation effectiveness is measured and evaluated periodically (e.g., conducting annual reviews).	• Evidence confirming the periodic review of cybersecurity requirements for Ol/eS related to human • A proof that shows the key performance indicators (KPIs) for each control within the related policy or procedure to ensure the implementation effectiveness is measured and evaluated periodically (based on defined frequency).
NCA DCC					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
1.2.1	1.2.1.1	In addition to the subcontrols in the ECC control 1-9-3, personnel's cybersecurity requirements prior to employment, during employment and after termination/separation must include at least the following: 1-2-1-1 Screening and vetting candidates in jobs related to data handling.	• Template for Cybersecurity Human Resources Policy	• Identify the requirements of this control and document them in a cybersecurity requirements document, followed by approval from the authorizing officials. • Identify the suitable candidates for secret and top secret data handling jobs based on the skillset and CV screening. • Review their skillset using various methodologies including interviews, skill based test, both oral as well as	• Document detailing the identification and documentation of the requirements of this control (e.g. a policy and/or procedure approved by the authorizing officials). • A recruitment and onboarding process which includes screening and vetting as per the skillset of the candidate.

				written. Also, develop a background verification process for the selected candidates either by an internal or third party vendor team. • Develop, document and approve an action plan for granting new access to the candidates according to the roles and permissions required. • Develop a periodic review process to delete unused and unjustified roles and permissions.	• Selection of background verification vendor or internal team. • Periodically verified and approved list of users with their permissions (eg. Privacy/Data Protection Officer). • Review of HR Cybersecurity policy in line with data cybersecurity policies.
	1.2.1.2	1-2-1-2 A signed agreement by personnel pledging to not use social media, communication applications or personal cloud storage to create, store or share the organization's data, with the exception of secure communication applications approved by relevant authorities.	• Template for Cybersecurity Human Resources Policy • Template for Cybersecurity Policies Compliance • Template for Confidentiality Agreement	• Identify the requirements of this control and document them in a cybersecurity requirements document, followed by approval from the authorizing officials. • Identify the personnel who should be working on the confidential, secret or top secret data, based on the classification. • Review the employment agreement of the personnel and develop and document a clause with the help of legal department, pledging to not use generative artificial intelligence systems, social media, or communication applications to create, store or share the organization's data, with the exception of generative artificial intelligence systems, and secure	• Document detailing the identification and documentation of the requirements of this control (e.g. a policy and/or procedure approved by the authorizing officials). • Signed agreement by the personnel on the use of generative artificial intelligence systems, social media, and communication applications.

				communication applications approved by relevant authorities.	
NCA CCC CST					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
1.4.T.1		In addition to sub controls in the ECC control 1-9-3, the following requirements should be covered prior the professional relationship of staff with the CST shall cover, at a minimum: 1.4.T.1.1 Screening or vetting candidates of personnel with access to Cloud Service sensitive functions (Key Management, Service Administration, Access Control).	• Template for Cybersecurity Human Resources Policy	• Review job titles and descriptions for duties in areas of Key Management (including encryption), technical Cloud Service Management, Identity and Access Management) and make sure candidates for these jobs are under screening/vetting (e.g.: Cloud Access Provisioning Engineer, Cloud Service Administrator, Key Vault Security Engineer)	• Catalogue of privileged user roles (including Key Management, Service Administration, Access control) • Screening/Vetting process defined for candidates that use these user roles.
NCA CCC CSP					
1.4.P.1	1.4.P.1.1	In addition to sub controls in the ECC controls 1-9-3 and 1-9-4, the following requirements should be covered prior and during the professional relationship of personnel with the CSP as a minimum: 1-4-P-1-1 Positions of cybersecurity functions in CSP's data centers within the KSA must be filled with qualified and suitable Saudi nationals.	• Template for Cybersecurity for Human Resources	• Identify cybersecurity roles, positions and functions related to the data centers based in the KSA (e.g.: Cloud Security Engineer, Cybersecurity Monitoring Team, etc.). • Employ for these positions Saudi nationals with professional cybersecurity experience and certification relevant to the position and seniority. Consider cybersecurity industry recognized professional certifications (e.g.: CISSP, CISA, CCSK, CCSP).	• List of cybersecurity positions related to the data centers within the KSA and the requirements for each position. • List of employees filling these positions and their qualifications. • Cybersecurity training program and the provided training certificates based on it.

				include data center cybersecurity staff in the cybersecurity training program to improve their skills and qualifications.	
	1.4.P.1.2	Screening or vetting candidates of personnel working inside KSA who have access to Cloud Technology Stack, periodically.	Template for Cybersecurity for Human Resources	Review KSA-based job titles and descriptions for duties relevant to access to Cloud Technology Stack and make sure candidates for these jobs are under screening/vetting (e.g.: Cloud Engineer, Cloud Service Administrator, Key Vault Security Engineer, etc.) before employment and periodically.	- Screening/Vetting process defined and implemented for candidates with access to Cloud Technology Stack including a plan for a periodic screening/vetting. - Reports of screening/vetting for these candidates. Information privacy and sensitivity must be in consideration when dealing with these reports.
	1.4.P.1.3	Cybersecurity policies as a prerequisite to access to Cloud Technology Stack, signed and appropriately approved.	- Template for Cybersecurity for Human Resources - Template for Cybersecurity Compliance	Make joiners/workers familiar with organization's cybersecurity policies before they are granted the access to Cloud Technology Stack by signing a formal form,	Cybersecurity policies acknowledgement and compliance form is signed by all personnel working on Cloud Technology Stack before having access.
1.4.P.2		In addition to sub controls in the ECC control 1-9-5, the following requirements should be in place, as a minimum, for the termination/completion of a human resource's professional relationship with the CSP: 1-4-P-2-1 Assurance that assets owned by the organization (especially those with security exposure) are accounted for and returned upon termination.	Template for Cybersecurity for Human Resources	- Include steps to validate the return of all organization's assets held by workers as part of the procedures for clearing a party upon termination of service. - Document validation process through an official form (e.g. a clearance form) and require employees to sign it.	Signed clearance forms include employees' acknowledgment to return all organization's assets, with validation by the concerned department.
SAMA CSF					

Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
3.3.1 Human Resources	3.3.1-1	The human resources process should define, approve and implement cyber security requirements.			
	3.3.1-2	The effectiveness of the human resources process should be monitored, measured and periodically evaluated.			
	3.3.1-3.a	The human resource process should include: a. cyber security responsibilities and non-disclosure clauses within staff agreements (during and after the employment);			
	3.3.1-3.b	b. staff should receive cyber security awareness at the start and during their employment;			
	3.3.1-3.c	c. when disciplinary actions will be applicable;			
	3.3.1-3.d	d. screening and background check;			
	3.3.1-3.e	e. post-employment cyber security activities, such as: 1. revoking access rights; 2. returning information assets assigned (e.g., access badge, tokens, mobile devices, all electronic and physical information).			
CST CRF					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables

1.8.1		Define and document [Requirements for Cybersecurity in Human Resources] which consider the following: • Defining cybersecurity requirements related to personnel in the organization including contractors before they are employed, during their work, and upon completion/termination of their work • Conduct background verification checks on all candidates for employment • Hiring highly professional personnel on the jobs related to critical systems • Ensuring that the terms and agreements related to the employment also cover the code of conduct (e.g. non-disclosure agreements, cybersecurity responsibilities) and has been included during and after termination of employment with the organization • Ensuring that the code of conduct is signed by all the personnel • Enforcing the [Acceptable Use of Information Assets]			
1.8.2		Ensure that necessary actions (e.g. modify access authorizations in accordance with the new operational role) are performed when individuals are reassigned or transferred to			

		other positions within the organization.			
1.8.3		Ensure that all suspected breaches of relevant cybersecurity requirements by personnel are subject to a proper investigation and appropriate disciplinary action is taken			
1.8.4		Ensure necessary actions (e.g. revoking personnel access rights and privileges, retrieving assigned information assets, retaining access to information assets formerly controlled by terminated individual) have been carried out upon completion of professional services or termination of personnel.			
1.8.5		Continuously measure, review and optimize the [Requirements for Cybersecurity in Human Resources].			
CMA Cybersecurity Guidelines					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
4.1.5.1		Set out, document, implement and approve Cybersecurity controls related to HR operation			
4.1.5.2		Monitor effectiveness of cybersecurity controls related to HR operation and evaluate these controls periodically.			
4.1.5.3		HR cybersecurity controls shall include the following:			

		• Cybersecurity Responsibilities and Non-Disclosure Clauses in Employee Contracts (during employment and after termination). • Conduct a cybersecurity awareness at the beginning and during the term of employment. • Applicability of disciplinary measures. • Security screening of staff by entities authorized to conduct such screening. • Requirements for cybersecurity controls after ending/terminating the employment relationship such as: ○ Remove access privileges ○ Return of personal information assets (for example: Access card, mobile devices, and all online and physical information)			
--	--	--	--	--	--

Risk Considerations in Cybersecurity Human Resources

Inadequate Personnel Screening

- **Risk Description:** Failure to thoroughly vet candidates for cybersecurity positions or sensitive roles can lead to security risks.
- **Risk Mitigation:** Implement comprehensive background checks and cybersecurity-focused screening for candidates, especially those in critical roles.

Failure to Address Insider Threats

- **Risk Description:** Personnel with access to sensitive systems may intentionally or unintentionally cause harm, leading to data breaches or system compromise.
- **Risk Mitigation:** Develop strong access controls, regularly review user access, and promote a culture of security awareness.

Lack of Post-Termination Security Procedures

- **Risk Description:** Failure to remove access rights or recover company assets upon employee termination can leave systems vulnerable.
- **Risk Mitigation:** Implement a formal offboarding process that includes the immediate removal of access and recovery of organizational assets.

Insufficient Ongoing Security Training for HR Staff

- **Risk Description:** HR staff may not be adequately trained on the latest cybersecurity threats or privacy regulations, putting sensitive personnel data at risk.
- **Risk Mitigation:** Provide regular cybersecurity training for HR staff, emphasizing the protection of personnel data and security awareness.

Non-compliance with Labor Laws and Regulations

- **Risk Description:** Cybersecurity policies related to personnel may inadvertently violate labor laws or employee rights, leading to legal consequences.
- **Risk Mitigation:** Ensure that cybersecurity policies comply with local labor laws and privacy regulations, and review policies with legal counsel.

Examples of Technologies for Effective Cybersecurity Human Resources

- **Human Resource Management Systems (HRMS)**
Tools: OrangeHRM, Sentrifugo
Purpose: Manage employee records, track roles and access permissions, and document cybersecurity responsibilities and training within HR workflows
- **Identity & Access Management (IAM) Tools**
Tools: Keycloak, Authelia, Authentik
Purpose: Govern user identity, enforce role-based access control (RBAC), and align access privileges with HR-defined roles and policies
- **Background Check Tools**
Tools: OSINT-based frameworks (e.g., SpiderFoot, Maltego Community Edition), manual open-source investigation practices
Purpose: Perform open-source intelligence gathering and background verification for cybersecurity-sensitive roles in environments where third-party services are not viable or preferred

Examples of KPIs for Cybersecurity Human Resources

1. **Employee Background Check Completion Rate:** Percentage of new hires subjected to cybersecurity-related background checks.
2. **Access Revocation Rate:** Percentage of former employees' access rights to critical systems revoked within 24 hours of termination.
3. **Security Awareness Training Rate:** Percentage of employees who complete cybersecurity training during onboarding and annually thereafter.
4. **Incident Reporting Rate:** Number of cybersecurity incidents involving human error or negligence (e.g., improper access, phishing) involving HR personnel.
5. **Employee Role Compliance Rate:** Percentage of employees with roles aligned to organizational cybersecurity policies and HR security controls.

Case Study: Developing and Implementing Cybersecurity in Human Resources for a Saudi Financial Institution

Background:

A Saudi Financial Institution, operating in the banking and investment sector, recognized that the security of its human resources processes was critical to maintaining its cybersecurity posture. Given the sensitive nature of financial transactions and the regulatory environment in the Kingdom, the institution decided to implement a robust set of cybersecurity requirements related to personnel before, during, and after employment. This initiative was driven by the need to protect against cyber threats that could arise from both external attackers and insider threats.

Phase 1: Developing Personnel Cybersecurity Requirements

1. Personnel Cybersecurity Requirements Prior to Employment

Before employees were hired, SFI defined and documented clear cybersecurity requirements:

- **Cybersecurity Clauses in Employment Contracts:** All employment contracts were updated to include:
 - Cybersecurity responsibilities, including adherence to the institution's data protection policies and protocols.
 - Non-disclosure agreements that protected sensitive customer and financial data during and after employment.
- **Screening and Background Checks:** The institution adopted a strict screening process for candidates in sensitive roles, especially those with access to financial systems and customer data. This process included:
 - Background checks for potential cybersecurity risks.
 - Vetting of candidates' previous employment history and online presence to ensure they did not pose a cybersecurity threat.

2. Personnel Cybersecurity Requirements During Employment

During employment, the institution implemented several cybersecurity requirements:

- **Cybersecurity Awareness and Training:** Every new employee underwent a thorough cybersecurity onboarding process that included training on topics such as:
 - Phishing and social engineering awareness.
 - Proper password management and use of secure authentication methods.
 - Specific training on the security of financial systems and customer data.
- **Compliance with Cybersecurity Policies:** Employees were required to adhere to all cybersecurity protocols, such as:
 - Secure use of devices (e.g., laptops, tablets, mobile phones).
 - Encryption and data protection measures for storing and sharing financial data.
- **Regular Access Reviews:** The HR department conducted periodic reviews of employee access rights to ensure that they only had access to the information necessary for their role. Access revocation was immediate when an employee's role changed or they left the institution.

3. Personnel Cybersecurity Requirements After Termination/Separation

Upon termination or separation, the SFI implemented a strict offboarding process:

- **Immediate Revocation of Access Rights:** As soon as an employee left the institution, their access to critical systems, networks, and customer information was immediately revoked.

- **Return on Assets:** All company-owned devices, physical access tokens, and security badges were collected. Employees were required to return any data storage devices (e.g., USB drives, mobile devices) before departure.
- **Post-Employment Security Activities:** Employees were reminded of their ongoing non-disclosure obligations and instructed not to retain any proprietary or confidential data after leaving the institution. A final audit ensured all organizational assets were returned.

Phase 2: Implementation and Ongoing Evaluation

1. Integrating HR and Cybersecurity

The institution integrated these personnel cybersecurity requirements into its HR processes, with collaboration between the HR, IT, and Legal departments. This ensured a seamless onboarding and offboarding process for all employees.

2. Monitoring and Measuring Effectiveness

The HR department worked closely with the cybersecurity team to monitor and evaluate the effectiveness of the HR cybersecurity requirements:

- **Periodic Audits:** Regular audits were conducted to ensure compliance with personnel cybersecurity requirements.
- **Feedback Mechanism:** A feedback mechanism was introduced for employees to report potential gaps or issues with cybersecurity training, awareness, or procedures.

3. Continuous Improvement

The institution regularly updated its personnel cybersecurity procedures based on lessons learned from incidents and evolving threats. The HR process was refined to ensure that cybersecurity remained a top priority.

1.10 Cybersecurity Awareness and Training Program:

Definition: A cybersecurity awareness and training program is a structured initiative designed to educate and train employees and other stakeholders on cybersecurity threats, best practices, policies, and procedures. The goal of the program is to build a strong security culture within the organization, reduce human errors that lead to security breaches, and ensure all individuals understand their role in maintaining cybersecurity [26], [27], [28], [29].

Objective:

To ensure that personnel are aware of their cybersecurity responsibilities and have the essential cybersecurity awareness. It is also to ensure that personnel are provided with the required cybersecurity training, skills and credentials needed to accomplish their cybersecurity responsibilities and to protect the organization's information and technology assets.

Controls Matrix:

Below is a summary matrix detailing relevant Cybersecurity Awareness and Training controls based on NCA, SAMA CSF, CST CRF, and CMA Cybersecurity guidelines:

Regulation	Main Controls	Control References
NCA ECC	5	1.10.1, 1.10.2, 1.10.3, 1.10.4, 1.10.5
SAMA CSF	2	3.1.6, 3.1.7 (9 Sub-controls)
CST CRF	1	4.1.4 (6 Sub-controls)
CMA Cybersecurity Guidelines	1	1.5 (6 Sub-controls)
NCA CCCC	-	-
NCA CCC CST	-	-
NCA CCC CSP	-	-
NCA TCC	2	1.3.1, 1.3.2 (8 Sub-controls under 1.3.1)
NCA DCC	1	1.3.1 (7 Sub-controls)
NCA OSMACC	2	1.4.1, 1.4.2 (8 Sub-controls)
NCA OTCC	2	1.8.1, 1.8.2 (2 Sub-controls under 1.8.2)

Cybersecurity Awareness and Training Controls:

Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines:	Expected deliverables
ECC					
1.10.1		A cybersecurity awareness program must be developed and approved. The program must be conducted periodically through multiple channels to strengthen the awareness about cybersecurity, cyber threats and risks, and to build a positive cybersecurity awareness culture.	• Awareness program template. • Awareness content template for all employees. • Awareness content form for supervisory and executive positions. • Information and Technology Assets Operators Awareness Content Form.	• Develop and approve cybersecurity awareness program and plan in the organization through multiple channels periodically, including but not limited to: ○ Awareness emails. ○ Cybersecurity awareness workshops. ○ Distribution of awareness publications. ○ Awareness presentation through billboards. ○ Launch of a cybersecurity training and awareness platform. • The program may include a plan to coordinate with the Human Resources department, the Media and Internal Communications department, and the cybersecurity function to raise awareness of cybersecurity, its threats and risks, and build a positive cybersecurity culture. • The organization's program must be supported by the Executive Management. This must be done through the approval of the representative.	• The awareness program document approved by the organization.
1.10.2		The cybersecurity awareness program must be implemented.		• Implement the approved cybersecurity awareness and training program in coordination with the cybersecurity	• Action plan to implement the cybersecurity

				awareness and training department, which may include the following: ○ Implement the approved cybersecurity awareness program in the organization, including but not limited to sending awareness emails or conducting cybersecurity awareness workshops. ○ Evaluate cybersecurity awareness of all personnel and define and address cybersecurity weaknesses.	awareness program adopted by the organization. • Awareness programs to be shared with employees. • List of beneficiaries of awareness programs.
1.10.3	1.10.3.1	The cybersecurity awareness program must cover the latest cyber threats and how to protect against them, and must include at least the following subjects: 1-10-3-1 Secure handling of email services, especially phishing emails.		• Define and document the requirements of this ECC in the cybersecurity requirements document and approve them by the representative. • Provide cybersecurity awareness programs that cover the safe handling of e- mail services, especially with emails and social engineering.	• A document (such as approved policy or procedure) indicating the identification and documentation of the requirements related to this control. • Action plan to implement the cybersecurity awareness program adopted by the organization. • Evidence of providing awareness content for the safe handling of e- mail services, especially with phishing emails.
	1.10.3.2	Secure handling of mobile devices and storage media.		• Define and document the requirements of this ECC in the cybersecurity requirements document and approve them by the representative. • Provide cybersecurity awareness programs to cover the safe handling of mobile devices and storage media.	• A document (such as approved policy or procedure) indicating the identification and documentation of the requirements related to this control. • Action plan to implement the

					cybersecurity awareness program adopted by the organization. • Evidence that awareness content is provided for the safe handling of mobile devices and storage media.
	1.10.3.3	Secure Internet browsing.		• Define and document the requirements of this ECC in the cybersecurity requirements document and approve them by the representative. • Provide cybersecurity awareness programs that cover the safe handling of internet browsing services, especially dealing with suspicious websites such as phantom phishing sites and suspicious websites and links.	• A document (such as approved policy or procedure) indicating the identification and documentation of the requirements related to this control. • Action plan to implement the cybersecurity awareness program adopted by the organization. • Evidence that awareness content is provided for the secure handling of internet browsing services.
	1.10.3.4	Secure use of social media.		• Define and document the requirements of this ECC in the cybersecurity requirements document and approve them by the representative. • Provide cybersecurity awareness programs that cover the safe handling of social media.	• A document (such as approved policy or procedure) indicating the identification and documentation of the requirements related to this control. • Action plan to implement the

					cybersecurity awareness program adopted by the organization. • Evidence that awareness content is provided for safe handling of social media.
1.10.4	1.10.4.1	Essential and customized (i.e., tailored to job functions as it relates to cybersecurity) training and access to professional skillsets must be made available to personnel working directly on tasks related to cybersecurity including: 1-10-4-1 Cybersecurity function's personnel.		• Define and document the requirements of this ECC in the cybersecurity requirements document and approve them by the representative. • Develop and implement an approved cybersecurity training plan for employees of the cybersecurity function in coordination with the training department in the organization, which may include the following: ○ Implement the cybersecurity training plan for the organization in coordination with the Training and Employee Development Department. ○ Assist in the establishment of cybersecurity career paths to allow career progression, deliberate development, and growth within and between cybersecurity career fields. ○ Support in advocating for adequate funding for cybersecurity training resources, to include both internal and industry-provided courses, instructors, and related materials.	• A document (such as approved policy or procedure) indicating the identification and documentation of the requirements related to this control. • Approved training plans and programs for the cybersecurity department employees at the organization. • Cybersecurity training certificates.
	1.10.4.2	Personnel working on software/application development. and 1-10-4-2		• Define and document the requirements of this ECC in the cybersecurity requirements document and approve them by the representative.	• A document (such as approved policy or procedure) indicating the identification and documentation of the

		information and technology assets operations.		• Develop and implement an approved training plan in the field of secure program and application development, and the safe management of the organizations information and technology assets for relevant employees in coordination with the training department in the organization. This may include the following: ○ Training plan to develop programs, applications and employees operating the organizations information and technology assets must be implemented in coordination with Training and Employee Development Department. ○ Assistance in defining career paths for software and application developers and the employees operating the organizations information and technology assets must be provided to allow for professional growth and upgrades in professional areas related to software development. • Provide support in requesting the adequate funding of training resources related to the development of programs, applications and employees operating the organization's information and technology assets, including internal and sector-related courses, trainers and related materials.	requirements related to this control. • Approved training programs for employees involved in the development of programs, applications, and employees operating the organization's information and technology assets. • Training certificates in software and application development.
	1.10.4.3	1-10-4-3 Executive and supervisory positions.		• Define and document the requirements of this ECC in the cybersecurity requirements document and approve them by the representative.	• A document (such as approved policy or procedure) indicating the identification and documentation of the

				• Develop and implement an approved cybersecurity training plan for employees of the cybersecurity Supervisory and executive functions in coordination with the training department in the organization, which may include the following: ○ Awareness of the importance of cybersecurity, developing the cybersecurity culture and the key risks and threats, such as phishing emails for supervisory and executive positions (Whale phishing) must be conducted. ○ Training plan for supervisory and executive positions in the organization must be implemented in coordination with the Training and Employee Development Department. ○ Assistance in the establishment of cybersecurity career paths to allow career progression, deliberate development, and growth within and between cybersecurity career fields must be provided. ○ Support in advocating for adequate funding for cybersecurity training resources, including both internal and industry-provided courses, instructors, and related materials must be provided.	requirements related to this control. • Security training programs dedicated to supervisory and executive positions in the organization. • Training certificates in supervisory and executive positions.
1.10.5		The implementation of the cybersecurity awareness program must be reviewed periodically.		• Review the cybersecurity requirements of cybersecurity awareness and training programs by conducting a periodic assessment according to a documented and approved plan for review and based on a planned interval (e.g., quarterly)) to implement awareness and training plans by the Cybersecurity function and in cooperation with relevant departments	• Results of cybersecurity awareness program implementation review in the organization. • A document that defines the cybersecurity awareness and training implementation review

				(such as the Awareness and Training Department). Conduct application review through traditional channels (e.g., email) or automated channels using a compliance management system The organization may develop a review plan explaining the cybersecurity requirements implementation review schedule for cybersecurity awareness and training programs.	cycle (Compliance Assessment Schedule). Compliance assessment report that shows the assessment of the implementation of cybersecurity requirements for cybersecurity awareness and training programs.
NCA CCCC					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines:	Expected deliverables
N/A				•	•
NCA OSMACC					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines:	Expected deliverables
1.4.1	1.4.1.1	In addition to the subcontrols within control 1-10-3 in the ECC, the cybersecurity awareness program must cover the awareness about the potential cyber risks and threats related to the organization's social media accounts and the secure use to minimize	Plan for Cybersecurity Awareness Program	- Develop and document a social media cybersecurity awareness program, which must include topics such as secure use of devices used for organization's social media accounts, review security configuration and hardening for social media devices, data protection of social media devices, prohibition of use of classified data or personal data of the employee on social media device. - All the personnel in the organization must be undergoing the cybersecurity	- Documented and approved customized awareness program for social media which includes secure use and protection of social media devices. - Sample of the awareness materials/contents provided to the organization's personnel.

		these risks and threats, including the following: 1-4-1-1 Secure use and protection of devices dedicated to the organization's social media accounts and ensuring that they do not contain classified data or used for personal purposes.		awareness program for social media accounts. Conduct the social media cybersecurity awareness program on a periodic basis and maintain record of training.	
	1.4.1.2	Secure handling of identities, passwords and security questions.	Plan for Cybersecurity Awareness Program	- Develop and document a social media cybersecurity awareness program, which must include topics such as identity management of social media accounts, strong password policies, secure handling of identity credentials, setting up security questionnaire, multi-factor authentication on social media accounts. - All the personnel in the organization must be undergoing the cybersecurity awareness program for social media. - Conduct the social media cybersecurity awareness program on a periodic basis and maintain record of training.	- Documented and approved customized awareness program for social media which includes secure handling of identity and access of social media accounts. - Sample of the awareness materials/contents provided to the organization's personnel.
	1.4.1.3	Organization's social media accounts restoration plan and dealing with cybersecurity incidents.	Plan for Cybersecurity Awareness Program	- Develop and document a social media cybersecurity awareness program, which must include topics such as incident and threat management for social media accounts, identification of incident, reporting of suspicious activity on social media account, restoration plan for social media account recovery. - All the personnel in the organization must be undergoing the cybersecurity awareness program for social media.	- Documented and approved customized awareness program for social media which includes social media account incident management and restoration plan. - Sample of the awareness materials/contents provided to the

				• Conduct the social media cybersecurity awareness program on a periodic basis and maintain record of training. • Establishing and documenting a plan for social media account recovery: ○ Contact information for the Cybersecurity Incident Response Team (IRT). ○ Timely notification to the Incident Response Team. ○ Documenting the incident after account recovery.	organization's personnel. • Documented plan to recover the organization's social media accounts.
	1.4.1.4	Secure handling of applications and solutions used for the organization's social media accounts.	• Plan for Cybersecurity Awareness Program	• Develop and document a social media cybersecurity awareness program, which must include topics such as social media applications and solutions, security configuration hardening of applications and solutions, monitoring and logging of social media applications. • All the personnel in the organization must be undergoing the cybersecurity awareness program for social media. • Conduct the social media cybersecurity awareness program on a periodic basis and maintain record of training.	• Documented and approved customized awareness program for social media which includes secure handling of social media applications and solutions. • Sample of the awareness materials/contents provided to the organization's personnel.
	1.4.1.5	Not to use the organization's social media accounts for personal purposes such as browsing.	• Plan for Cybersecurity Awareness Program	• Develop and document a social media cybersecurity awareness program, which must include topics such as usage of organization's social media accounts, social media etiquettes for the account operations for the organization, prohibition of use of social media account for personal usage. • All the personnel in the organization must be undergoing the cybersecurity awareness program for social media.	• Documented and approved customized awareness program for social media which includes prohibition of usage of organization's social media account for personal usage. • Sample of the awareness materials/contents

				Conduct the social media cybersecurity awareness program on a periodic basis and maintain record of training.	provided to the organization's personnel.
	1.4.1.6	Avoiding accessing the organization's social media accounts using untrusted public devices or networks.	Plan for Cybersecurity Awareness Program	- Develop and document a social media cybersecurity awareness program, which must include topics such as access to the social media accounts, avoiding public devices/networks or those which are not defined by organization's policies, risks associated with accessing social media accounts on untrusted public devices or networks. - All the personnel in the organization must be undergoing the cybersecurity awareness program for social media. - Conduct the social media cybersecurity awareness program on a periodic basis and maintain record of training.	- Documented and approved customized awareness program for social media which includes prohibition of accessing organization's social media accounts using untrusted public devices or networks. - Sample of the awareness materials/contents provided to the organization's personnel.
	1.4.1.7	Communicating directly with the cybersecurity department if a cybersecurity threat is suspected	Plan for Cybersecurity Awareness Program	- Develop and document a social media cybersecurity awareness program, which must include topics such as incident response to social media cybersecurity threat, how to contact directly to cybersecurity department in case of a threat. - All the personnel in the organization must be undergoing the cybersecurity awareness program for social media. - Conduct the social media cybersecurity awareness program on a periodic basis and maintain record of training.	- Documented and approved customized awareness program for social media which includes communicating directly with cybersecurity department for suspected cybersecurity threat to social media accounts. - Sample of the awareness materials/contents provided to the organization's personnel.

1.4.2		In addition to the sub controls within control 1-10-4 in the ECC, personnel responsible for managing the organization's social media accounts must be trained on the required technical skills, plans and procedures necessary to ensure the implementation of the cybersecurity requirements and practices when using the organization's social media accounts.	Plan for Cybersecurity Awareness Program	- Develop and document a training curriculum for the personnel to be trained for proper handling and management of social media accounts which must include required skills to manage the accounts, organization's social media standard controls as a part of procedures to follow for the cybersecurity requirements, implementation, operation and monitoring of social media accounts' activities for threat management. - Personnel responsible for managing the social media accounts in the organization must be undergoing the cybersecurity training for required skills and procedures. - Conduct the social media training program on a periodic basis and maintain record of training.	- Documented and approved customized training program for authorized personnel who are responsible for managing the organization's social media accounts. - Sample records of training conducted for or attended by personnel responsible for managing the social media accounts.
NCA TCC					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
1.3.1	1.3.1.1	In addition to the sub-controls within control 1-10-3 in the ECC, the cybersecurity awareness program must cover the awareness about the potential cyber risks and threats related to telework, including the following: 1-3-1-1 Secure use of telework devices and how to protect them.	Cybersecurity awareness program.	- Work on defining the requirements for this control, document them in the cybersecurity requirements document, and have them approved by the authority holder. - Provide cybersecurity awareness programs that cover the secure usage of telework devices and how to protect them.	- A document that identifies and documents the requirements of this policy (such as a policy and/or procedure approved by the authority holder). - Document of providing awareness content of the secure use of telework devices and how to protect them.

					• Proof of providing awareness content on the safe use of telework devices and how to protect them.
	1.3.1.2	Secure handling of identities and passwords.	• Cybersecurity awareness program.	• Work on defining the requirements for this control, document them in the cybersecurity requirements document, and have them approved by the authority holder. • Provide cybersecurity awareness programs that cover secure handling of identities and password.	• A document that identifies and documents the requirements of this policy (such as a policy and/or procedure approved by the authority holder). • Action plan to implement the cybersecurity awareness program that covers the secure handling of identities and password. • Proof of providing awareness content of the secure handling of identities and password.
	1.3.1.3	Protection of the stored data on the telework devices, and to be handled based on its classification.	• Cybersecurity awareness program.	• Work to define the requirements for this control, document them in the cybersecurity requirements document, and have them approved by the authority holder. • Provide awareness programs in cybersecurity that cover the protection of data that is saved on devices used for telework and dealing with them according to their classification and the entity's procedures and policies.	• A document that identifies and documents the requirements of this control (such as a policy and/or procedure approved by the authority holder). • An action plan to implement a cybersecurity awareness program

					that covers the protection of data that is saved on devices used for telework and dealing with it according to its classification and the entity's procedures and policies. • Proof of providing awareness content to protect the data that is saved on devices used for telework and dealing with it according to its classification and the entity's procedures and policies
	1.3.1.4	Secure handling of applications and solutions used for telework such as: virtual conferencing and collaboration, and file sharing solutions.	• Cybersecurity awareness program.	• Work on defining the requirements for this control, document them in the cybersecurity requirements document, and have them approved by the authority holder. • Provide cybersecurity awareness programs that cover the secure handling of applications and solutions used for telework such as: virtual conferencing and collaboration, and file sharing solutions.	• A document that identifies and documents the requirements of this control (such as a policy and/or procedure approved by the authority holder). • Action plan to implement the cybersecurity awareness program that cover the secure handling of applications and solutions used for telework such as: virtual conferencing and collaboration, and file sharing solutions.

					• Proof of providing awareness content to avoid working remotely using unreliable public devices or networks or while in public places.
	1.3.1.5	Secure handling of home networks, making sure it is configured in a secure way.	• Cybersecurity awareness program.	• Work on defining the requirements for this control, document them in the cybersecurity requirements document, and have them approved by the authority holder. • Provide cybersecurity awareness programs that cover the secure handling of home networks, making sure it is configured in a secure way.	• A document that identifies and documents the requirements of this control (such as a policy and/or procedure approved by the authority holder). • Action plan to implement the cybersecurity awareness program that cover secure handling of home networks, making sure it is configured in a secure way. • Proof of providing awareness content to avoid working remotely using unreliable public devices or networks or while in public places.
	1.3.1.6	Avoidance of teleworking using unreliable public devices or networks or while in public places.	• Cybersecurity awareness program.	• Work on defining the requirements for this control, document them in the cybersecurity requirements document, and have them approved by the authority holder. • Provide cybersecurity awareness programs that cover the secure handling	• A document that identifies and documents the requirements of this control (such as a policy and/or procedure approved by the authority holder).

				of home networks, making sure it is configured in a secure way.	• Action plan to implement the cybersecurity awareness program that cover the avoidance of teleworking using unreliable public devices or networks or while in public places. • Proof of providing awareness content to avoid working remotely using unreliable public devices or networks or while in public places.
	1.3.1.7	Unauthorized physical access, loss, theft, and sabotage of technical assets and telework systems.	• Cybersecurity awareness program.	• Work on defining the requirements for this control, document them in the cybersecurity requirements document, and have them approved by the authority holder. • Provide cybersecurity awareness programs that cover the unauthorized physical access, loss, theft, and sabotage of technical assets and telework systems.	• A document that identifies and documents the requirements of this control (such as a policy and/or procedure approved by the authority holder). • Action plan to implement the cybersecurity awareness program that cover the unauthorized physical access, loss, theft, and damage of technical assets and telework systems. • Proof of providing awareness content on unauthorized physical

					access, loss, theft and damage of technical assets and teleworking systems.
	1.3.1.8	To Communicate directly with the cybersecurity department If a cybersecurity threat is suspected.	• Cybersecurity awareness program.	• Work on defining the requirements for this control, document them in the cybersecurity requirements document, and have them approved by the authority holder. • Provide cybersecurity awareness programs that cover how to communicate directly with the cybersecurity department If a cyber threat is suspected.	• A document that identifies and documents the requirements of this control (such as a policy and/or procedure approved by the authority holder). • Action plan to implement the cybersecurity awareness program on how to communicate directly with the cybersecurity department if a cyber threat is suspected. • Proof of providing awareness content and communicating directly with the department concerned with cybersecurity in if a cyber threat is suspected.
1.3.2		In addition to the sub-controls within control 1-10-4 in the ECC, employees must be trained with the required technical skills to ensure the implementation of the cybersecurity requirements when	• Cybersecurity awareness program.	• Work on defining the requirements for this control, document them in the cybersecurity requirements document, and have them approved by the authority holder. • Develop and implement training program for employees working in cybersecurity team or other team members wherever	• A document that identifies and documents the requirements of this control (such as a policy and/or procedure approved by the authority holder).

		handling telework systems.		required, to ensure implementation of cybersecurity requirements with required technical skills for teleworking systems. • Periodic awareness programs to be conducted to ensure safe handling of the cyber • security incidents and implementation/services requirements.	• Documented training program and its periodic implementation for handling cyber security services and support for teleworking requirements. • Training certificates for workers on the technical skills necessary to ensure the application of cybersecurity requirements and practices when dealing with telework systems.
NCA OTCC					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
1.8.1		In addition to subcontrols in the ECC control 1-10-3, the cybersecurity awareness program must include a secure and safe interaction with the OT/ICS assets or systems.	• Template for Cybersecurity Operational Technology Policy • Template for OT/ICS Security Standard • Template for Cybersecurity Awareness Program	• Include awareness topics about a secure and safe interaction with the OT/ICS assets or systems as part of the cybersecurity awareness program. • Ensure that the awareness topics related to the secure and safe interaction with the OT/ICS assets or systems are implemented.	• The approved cybersecurity awareness program showcasing the topics related to the secure and safe interaction with the OT/ICS assets or systems. • A proof that the awareness topics related to the secure and safe interaction with the OT/ICS assets or systems are implemented.

1.8.2	1.8.2.1	In addition to subcontrols in the ECC control 1-10-4, cybersecurity requirements in OT/ICS cybersecurity awareness and training program must include, at a minimum, the following: 1-8-2-1 Customized training, qualifications, knowledge, and professional skillsets must be provided to all personnel with access to the OT/ICS assets. The organization is encouraged to utilize the reference material provided in the Saudi Cybersecurity Workforce Framework (SCyWF).	• Template for Cybersecurity Operational Technology Policy • Template for OT/ICS Security Standard • Template for Cybersecurity Awareness Program	• Identify a list with all personnel names with access to the OT/ICS. • Prepare and document customized training, qualifications, knowledge, and professional skillsets for all identified personnel. • Conduct customized training, qualifications, knowledge, and professional skillsets for all identified personnel.	• Documented and approved customized training, qualifications, knowledge, and professional skillsets for OT/ICS personnel. • A proof that all personnel with access to the OT/ICS assets completed prepared trainings, qualifications, and professional skillsets.
	1.8.2.2	Participation in OT/ICS authorized and/or specialized organizations and groups must be encouraged to stay up-to-date on common cybersecurity practices.	• Template for Cybersecurity Operational Technology Policy • Template for OT/ICS Security Standard	• Employees, who manage the OT/ICS systems shall participate in OT/ICS authorized and/or specialized organizations and groups, including but not limited to (CySec conference, Dragos Industrial Security Conference).	• A proof that employees, who manage the OT/ICS systems participated in OT/ICS authorized and/or specialized organizations and groups, including but not limited to (CySec conference, Dragos Industrial Security Conference).
NCA DCC					

Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
1.3.1	1.3.1.1	In addition to the subcontrols in ECC control 1-10-3, the cybersecurity awareness program must cover topics related to data protection, including the following: 1-3-1-1 Risks of data leakage and unauthorized access to data during its lifecycle.	Cybersecurity Awareness Program Plan	- identify the requirements of this control and document them in a cybersecurity requirements document, followed by approval from the authorizing officials. - All the personnel in the organization should be undergoing the cybersecurity awareness program for data protection and data classification, with designated awareness sessions for new personnel before granting access to organization's data. - Develop and document a data protection cybersecurity awareness program, which should include topics such as introduction to data leakage, what counts as a data leakage such as using unapproved generative artificial intelligence systems, risks associated with data leakage, and action plan to be followed if a leakage happens or unauthorized access to data during its lifecycle. - Conduct the data protection cybersecurity awareness program on a periodic basis and maintain record of training.	- Document detailing the identification and documentation of the requirements of this control (eg. a policy and/or procedure approved by the authorizing officials). - Documented and approved customized awareness program for data protection which includes risks of data leakage and unauthorized access to data during its lifecycle. - Sample of the related awareness program components (awareness emails, awareness sessions, awareness test campaigns, etc.)
	1.3.1.2	Secure handling of classified data while traveling and outside the workplace.	Cybersecurity Awareness Program Plan	- Identify the requirements of this control and document them in a cybersecurity requirements document, followed by approval from the authorizing officials. - All the personnel in the organization should be undergoing the cybersecurity awareness program for data protection.	Document detailing the identification and documentation of the requirements of this control (eg. a policy and/or procedure approved by the authorizing officials).

				• Develop and document a data protection cybersecurity awareness program, which should include topics such as data introduction to data classification, data classification policy, secure handling of classified data while outside the workplace and travel. • Conduct the data protection cybersecurity awareness program on a periodic basis and maintain record of training.	• Documented and approved customized awareness program for data protection which includes secure handling of classified data while traveling and outside the workplace. • Sample of the awareness program components (educational email messages, awareness sessions, phishing awareness campaigns, etc.).
	1.3.1.3	Secure handling of data during meetings (virtual and in-person).	• Cybersecurity Awareness Program Plan	• Identify the requirements of this control and document them in a cybersecurity requirements document, followed by approval from the authorizing officials. • All the personnel in the organization should be undergoing the cybersecurity awareness program for data protection. • Develop and document a data protection cybersecurity awareness program, which should include topics such as protocols for virtual and in person meeting, meeting etiquettes, exchange of data with wider audience, proper disposal of information post recording the data during meetings. • Conduct the data protection cybersecurity awareness program on a periodic basis and maintain record of training.	• Document detailing the identification and documentation of the requirements of this control (eg. a policy and/or procedure approved by the authorizing officials). • Documented and approved customized awareness program for data protection which includes secure handling of data during meetings. • Sample of the awareness program components (educational email messages, awareness

					sessions, phishing awareness campaigns, etc.).
	1.3.1.4	Secure handling when using printers, scanners and copiers.	Cybersecurity Awareness Program Plan	- Identify the requirements of this control and document them in a cybersecurity requirements document, followed by approval from the authorizing officials. - All the personnel in the organization should be undergoing the cybersecurity awareness program for data protection. - Develop and document a data protection cybersecurity awareness program, which should include topics such as restricted printer use from unauthorized access, remote configurations for printers and scanners, attentive to the printed data and proper disposal if data is no longer required. - Conduct the data protection cybersecurity awareness program on a periodic basis and maintain record of training.	- Document detailing the identification and documentation of the requirements of this control (eg. a policy and/or procedure approved by the authorizing officials). - Documented and approved customized awareness program for data protection which includes secure use of printers, scanners and copy machines. - Sample of the awareness program components (educational email messages, awareness sessions, phishing awareness campaigns, etc.).
	1.3.1.5	Procedures for secure data disposal.		- Identify the requirements of this control and document them in a cybersecurity requirements document, followed by approval from the authorizing officials. - All the personnel in the organization should be undergoing the cybersecurity awareness program for data protection. - Develop and document a data protection cybersecurity awareness program, which should include topics such as	- Document detailing the identification and documentation of the requirements of this control (eg. a policy and/or procedure approved by the authorizing officials). - Documented and approved customized

				introduction to secure data disposal, data disposal policy, data disposal process, shredding and information about data disposal vendor, if any. • Conduct the data protection cybersecurity awareness program on a periodic basis and maintain record of training.	awareness program for data protection which includes secure data disposal. • Sample of the awareness program components (educational email messages, awareness sessions, phishing awareness campaigns, etc.).
	1.3.1.6	Risks of sharing documents and information through non-secure channels.		• Identify the requirements of this control and document them in a cybersecurity requirements document, followed by approval from the authorizing officials. • All the personnel in the organization should be undergoing the cybersecurity awareness program for data protection. • Develop and document a data protection cybersecurity awareness program, which should include topics such as proper channels to share documents in the organization, risk associated with data leakage such as using generative artificial intelligence systems, and penalties associated with sharing documents through non-secure channels. • Conduct the data protection cybersecurity awareness program on a periodic basis and maintain record of training.	• Document detailing the identification and documentation of the requirements of this control (eg. a policy and/or procedure approved by the authorizing officials). • Documented and approved customized awareness program for data protection which includes risk of sharing documents through non-secure channels. • Sample of the awareness program components (educational email messages, awareness sessions, phishing awareness campaigns, etc.).

	1.3.1.7	Cybersecurity risks related to the use of external storage media.	Cybersecurity Awareness Program Plan	- Identify the requirements of this control and document them in a cybersecurity requirements document, followed by approval from the authorizing officials. - All the personnel in the organization should be undergoing the cybersecurity awareness program for data protection. - Develop and document a data protection cybersecurity awareness program, which should include topics such as storage media policy, usage of external storage media units in the organization, risk associated with data leakage from storage device, approval process for using external storage media, if required. - Conduct the data protection cybersecurity awareness program on a periodic basis and - maintain record of training.	- Document detailing the identification and documentation of the requirements of this control (e.g. a policy and/or procedure approved by the authorizing officials). - Documented and approved customized awareness program for data protection which includes risk related to the use of external storage media. - Sample of the awareness program components (educational email messages, awareness sessions, phishing awareness campaigns, etc.).
NCA CCC CST					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
N/A					
NCA CCC CSP					
N/A					
SAMA CSF					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables

3.1.6 Cyber Security Awareness	3.1.6.1	The cyber security awareness programs should be defined, approved and conducted to promote cyber security awareness and to create a positive cyber security culture.			
	3.1.6.2	A cyber security awareness program should be defined and conducted for: a. staff of the Member Organization; b. third parties of the Member Organization;c. customers of the Member Organization.			
	3.1.6.3	The cyber security awareness program should target cyber security behaviors by tailoring the program to address the different target groups through multiple channels.			
	3.1.6.4	The activities of the cyber security awareness program should be conducted periodically and throughout the year.			
	3.1.6.5	The cyber security awareness program should at a minimum include: a. an explanation of cyber security measures provided. the roles and responsibilities			

		regarding cyber security; c. information on relevant emerging cyber security events and cyber threats (e.g., spear-phishing, whaling).			
	3.1.6.6	The cyber security awareness program should be evaluated to: a. measure the effectiveness of the awareness activities; b. formulate recommendations to improve the cyber security awareness program.			
	3.1.6.7	Customer awareness should address for both retail and commercial customers and, at a minimum, include a listing of suggested cyber security mechanisms which customers may consider implementing to mitigate their own risk(s).			
3.1.7 Cyber Security Training	3.1.7.1	Specialist or security-related skills training should be provided to staff in the Member Organization's relevant functional area categories in line with their job descriptions, including: a. key roles within the organization; b. staff of the cyber			

		security function; c. staff involved in developing and (technically) maintaining information assets; d. staff involved in risk assessments.			
	3.1.7.2	Education should be provided in order to equip staff with the skills and required knowledge to securely operate the Member Organization's information assets.			
CST CRF					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
4.1.4 Training and Awareness	4.1.4.1	Develop, approve, document, and implement a Cybersecurity Awareness Program to promote Cybersecurity awareness. The Cybersecurity			
	4.1.4.2	Awareness Program aims to provide protection against the highest cybersecurity threats and risks and to address different groups using multiple channels.			
	4.1.4.3	Cybersecurity Awareness Program shall be launched periodically			
	4.1.4.4	Cybersecurity and Awareness Program includes protection			

		against cyber threats, including: Cybersecurity roles and responsibilities. Information about cybersecurity incidents and threats, for example: Phishing. Secure handling of mobile devices and storage media. Secure browsing of internet. Safe use of social media			
	4.1.4.5	Evaluate Cybersecurity Awareness Program to measure its effectiveness and make recommendations for necessary improvement.			
	4.1.4.6	Provide specialized training to cybersecurity personnel in relevant functions.			
CMA Cybersecurity Guidelines					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
1.5.1		Define and document [Requirements for Cybersecurity Awareness & Training] which consider the following: • Goals and scope • Number and frequency of trainings/year • Allocated resources			
1.5.2		Define and implement a [Cybersecurity Awareness & Training Program] (e.g.			

		defining goals, scope, targeted audience, validation criteria) that includes various cybersecurity topics considering the following: • Cybersecurity roles and responsibilities of the targeted audience • Trending Cybersecurity events and threats (e.g. social engineering attacks such as phone scams and impersonation calls) • Advice to personnel not to attempt unauthorized activities (e.g. introduce or use unauthorized equipment or software on a system, relocate equipment without proper authorization). • Secure handling of portable devices and storage media, email services (especially spam and phishing emails), internet surfing services and social media • Clear desk and clear screen policy (e.g. lock sensitive information stored on papers in a safe place, lock screens of computers and/or terminals when not in use or unattended)			
--	--	--	--	--	--

1.5.3		Enhance and implement the [Requirements for Cybersecurity Awareness & Training] to include periodic validation tests to evaluate the 13 effectiveness of the conducted [Cybersecurity Awareness and Training Program] and record the results of evaluation (e.g. check whether the personnel will click on a suspicious link in an email).			
1.5.4		Enhance and implement the [Requirements for Cybersecurity Awareness & Training] to define the circumstances under which the [Cybersecurity Awareness & Training Program] have to be provided (e.g. initial cybersecurity trainings to new users, training upon changes to information systems or job roles).			
1.5.5		Tailor the [Cybersecurity Awareness & Training Program] to provide specialized or security-related skills and trainings to targeted group of people considering the following personnel:			

		• Cybersecurity department • IT personnel • Personnel working in the software development • Personnel involved in cybersecurity risk management • Personnel with privileged access to critical information assets • Executive personnel			
1.5.6		Continuously measure, review and optimize the [Requirements for Cybersecurity Awareness & Training].			

Risk Considerations in Cybersecurity Awareness and Training

Low Employee Engagement

- **Risk Description:** Employees may not take the training seriously, leading to low retention and effectiveness of the program.
- **Risk Mitigation:** Make the training interactive, engaging, and relevant to employees' daily tasks. Use varied formats such as gamification and real-world case studies.

Lack of Customization

- **Risk Description:** A one-size-fits-all approach to training may not address the specific needs or roles of different employees.
- **Risk Mitigation:** Tailor the training program based on roles and responsibilities, providing specialized training for different departments.

Insufficient Training for Critical Roles

- **Risk Description:** Employees in key positions may not receive the appropriate level of training, leaving the organization vulnerable to insider threats or security gaps.
- **Risk Mitigation:** Prioritize training for cybersecurity personnel, senior leadership, and staff in sensitive positions.

Infrequent Training Updates

- **Risk Description:** Cybersecurity training that is not updated regularly may become outdated, failing to address current threats and vulnerabilities.
- **Risk Mitigation:** Update the training content regularly to reflect new threats, technologies, and organizational changes.

Failure to Measure Effectiveness

- **Risk Description:** Without assessing the effectiveness of the training program, it is difficult to know if it is achieving its intended goals.
- **Risk Mitigation:** Implement assessment tools such as quizzes, surveys, and simulated phishing campaigns to measure employee knowledge and behavior changes after training.

Examples of Technologies for Effective Cybersecurity Awareness and Training

- **Learning Management Systems (LMS)**

Tools: Moodle, Open edX

Purpose: Deliver, track, and manage cybersecurity awareness training programs and course materials across the organization

- **Phishing Simulation Tools**

Tools: GoPhish, King Phisher

Purpose: Simulate phishing attacks to evaluate user awareness, reinforce training, and measure organizational resilience to social engineering

- **Training and Development Platforms**

Tools: OWASP Juice Shop (hands-on training), TryHackMe (free tier), Hack The Box (community labs)

Purpose: Provide role-based, interactive cybersecurity training for technical and non-technical staff

- **Assessment and Measurement Tools**

Tools: LimeSurvey, Google Forms, Framadate

Purpose: Conduct quizzes, surveys, and evaluations to assess cybersecurity knowledge retention and awareness program effectiveness

Examples of KPIs for Cybersecurity Awareness and Training

1. **Training Completion Rate:** Percentage of employees completing cybersecurity training within the required period (e.g., annually).
2. **Training Effectiveness (Phishing Simulation):** Success rate of employees in identifying and reporting simulated phishing emails.
3. **Incident Response Time (Post-Training):** Average time taken for employees to identify and respond to security incidents after completing the training program.
4. **Training Engagement Rate:** Percentage of employees actively engaged in cybersecurity awareness activities (e.g., click-through rate on training emails, participation in workshops).
5. **Post-Training Security Incident Reduction:** Percentage reduction in security incidents attributed to employee actions (e.g., phishing attacks, data leaks) following training.

Case Study: Developing and Implementing Cybersecurity Awareness and Training Program for a Saudi Entity

Background:

A Saudi Entity sought to enhance its cybersecurity posture by building a robust Cybersecurity Awareness and Training Program. The entity recognized that a well-informed workforce was crucial to safeguarding sensitive data, protecting against cyber threats, and building a culture of cybersecurity across the organization.

The entity's leadership decided to implement a comprehensive cybersecurity awareness program that would address current and emerging cyber threats, ensure that employees adhered to cybersecurity best practices, and promote a security-conscious culture at all levels of the organization.

Phase 1: Developing the Cybersecurity Awareness Program

1. Program Objectives and Scope

The goal of the program was to provide continuous education on cybersecurity to all employees across the entity. The program was designed to:

- Raise awareness about cybersecurity threats and risks.
- Educate personnel on how to protect themselves and organizational assets from cyberattacks.
- Ensure the development of a positive cybersecurity culture across the entire workforce.

The program was tailored to target specific groups within the entity, ensuring that the content was relevant to their roles and responsibilities.

2. Target Audiences

The program was designed for different personnel categories, including:

- All employees (general workforce).
- Cybersecurity personnel (involved in defending systems and managing threats).
- IT staff, including those involved in software development, maintenance, and information systems operations.
- Executive and supervisory positions who require a high-level understanding of cybersecurity threats and governance.
- Third-party contractors and suppliers who interact with the entity's systems and information.

3. Key Training Modules

The cybersecurity awareness program covered several critical areas, including but not limited to:

- Secure Handling of Email:
 - Training on how to recognize phishing emails and social engineering attacks.
 - Best practices for handling email attachments and links to avoid malware.
- Secure Use of Mobile Devices and Storage Media:
 - Guidance on how to secure mobile devices (e.g., smartphones, tablets) and prevent loss of sensitive information.
 - Proper handling of USB drives and other external storage devices to avoid malware infection.
- Safe Internet Browsing:
 - Best practices for browsing securely, avoiding malicious websites, and keeping browsers updated.
 - Awareness on secure networks (e.g., avoiding unsecured Wi-Fi).
- Secure Use of Social Media:

- Guidelines on privacy settings, avoiding oversharing, and recognizing social media-based attacks.
- Social engineering threats that target users through social media platforms.
- Customized Cybersecurity Training for Critical Roles:
 - Cybersecurity function personnel received specialized training on threat management, vulnerability assessment, and incident response.
 - Software/application development staff received secure coding practices and methods for protecting against code injection attacks and vulnerabilities.
 - Executive and supervisory staff were given high-level training to understand the implications of cyber threats and the role of leadership in fostering a security-aware culture.

4. Delivery Channels

The program leveraged multiple channels to ensure broad engagement and accessibility:

- In-person training: Periodic seminars, workshops, and live sessions with cybersecurity experts.
- E-learning modules: Interactive training courses available on the entity's internal portal.
- Webinars and virtual sessions: Online sessions for remote workers and leadership, focusing on emerging threats and incident management.
- Posters, newsletters, and digital signage: Awareness materials placed around the organization to continuously reinforce key cybersecurity messages.

Phase 2: Implementing the Cybersecurity Awareness Program

1. Awareness Campaigns

- The program was launched with a strong initial awareness campaign, including emails, posters, and briefings from leadership.
- Ongoing monthly campaigns focused on different cybersecurity topics, such as password hygiene, safe internet use, and recognizing phishing attempts.
- Simulated phishing campaigns were periodically conducted to assess employee awareness and improve phishing detection skills.

2. Continuous Evaluation and Feedback

- Surveys and quizzes were distributed to gauge the effectiveness of the program, allowing employees to demonstrate their knowledge of key topics.
- Real-time feedback mechanisms allowed employees to report challenges or gaps in training.
- Cybersecurity professionals continuously evaluated the content based on emerging threats and updated security guidelines.

3. Integration with Other Security Functions

The cybersecurity awareness program was aligned with other internal security initiatives, such as incident response training, business continuity exercises, and secure software development practices.

- Leadership provided visible support for the program to demonstrate its importance and to encourage participation across all levels of the organization.

4. Program Review and Adjustment

- The program was reviewed annually to ensure it remained relevant and comprehensive.
- Adjustments were made based on audit results, incident reports, and emerging threats.

Reference:

- [1] "Cyber Security Strategy: Definition and Implementation." Accessed: Apr. 22, 2025. [Online]. Available: <https://www.sentinelone.com/cybersecurity-101/cybersecurity/cyber-security-strategy/>
- [2] L. Carin, G. Cybenko, and J. Hughes, "Cybersecurity strategies: The queries methodology," *Computer*, vol. 41, no. 8, pp. 20–26, 2008.
- [3] S. AlDaajeh, H. Saleous, S. Alrabaee, E. Barka, F. Breitingner, and K.-K. R. Choo, "The role of national cybersecurity strategies on the improvement of cybersecurity education," *Computers & Security*, vol. 119, p. 102754, 2022.
- [4] "Cybersecurity Governance | CISA." Accessed: Apr. 22, 2025. [Online]. Available: <https://www.cisa.gov/topics/cybersecurity-best-practices/cybersecurity-governance>
- [5] N. Kshetri, *Cybersecurity management: An organizational and strategic approach*. University of Toronto Press, 2021. Accessed: Apr. 22, 2025. [Online]. Available: https://books.google.com/books?hl=en&lr=&id=dPNWEAAAQBAJ&oi=fnd&pg=PP1&dq=Cybersecurity+Management&ots=fH2QEEMsAI&sig=nkw_JleBba2FEYiX_yB8q4NCHmU
- [6] B. Krumay, E. W. N. Bernroider, and R. Walser, "Evaluation of Cybersecurity Management Controls and Metrics of Critical Infrastructures: A Literature Review Considering the NIST Cybersecurity Framework," in *Secure IT Systems*, vol. 11252, N. Gruschka, Ed., in Lecture Notes in Computer Science, vol. 11252, Cham: Springer International Publishing, 2018, pp. 369–384. doi: 10.1007/978-3-030-03638-6_23.
- [7] "CISSP prep: Security policies, standards, procedures and guidelines | Infosec." Accessed: Apr. 22, 2025. [Online]. Available: <https://www.infosecinstitute.com/resources/cissp/cissp-prep-security-policies-standards-procedures-guidelines/>
- [8] "CISSP prep: Security policies, standards, procedures and guidelines | Infosec." Accessed: Apr. 22, 2025. [Online]. Available: <https://www.infosecinstitute.com/resources/cissp/cissp-prep-security-policies-standards-procedures-guidelines/>
- [9] "Cybersecurity Toolkits." Accessed: Apr. 22, 2025. [Online]. Available: <https://nca.gov.sa/en/regulatory-documents/guidelines-list/665/>
- [10] "Minimum Security Baseline - Detox Technologies." Accessed: Apr. 22, 2025. [Online]. Available: <https://detoxtechnologies.com/minimum-security-baseline/>
- [11] M. E. Hathaway, "Leadership and responsibility for cybersecurity," *Georgetown Journal of International Affairs*, pp. 71–80, 2012.
- [12] A. Singh, "SAMA's Role in Strengthening Cyber Resilience in Saudi Arabia," IT BUTLER. Accessed: Apr. 22, 2025. [Online]. Available: <https://itbutler.sa/blog/samas-role-in-strengthening-cyber-resilience-in-saudi-arabia/>
- [13] S. AlDaajeh, H. Saleous, S. Alrabaee, E. Barka, F. Breitingner, and K.-K. R. Choo, "The role of national cybersecurity strategies on the improvement of cybersecurity education," *Computers & Security*, vol. 119, p. 102754, 2022.
- [14] "Risk Management," NIST, Jun. 2016, Accessed: Apr. 22, 2025. [Online]. Available: <https://www.nist.gov/risk-management>
- [15] I. Lee, "Cybersecurity: Risk management framework and investment cost analysis," *Business Horizons*, vol. 64, no. 5, pp. 659–671, 2021.

- [16] P. Katsumata, J. Hemenway, and W. Gavins, "Cybersecurity risk management," in *2010-MILCOM 2010 Military Communications Conference*, IEEE, 2010, pp. 890–895. Accessed: Apr. 22, 2025. [Online]. Available: <https://ieeexplore.ieee.org/abstract/document/5680181/>
- [17] "Cybersecurity in Project Management With Practical Examples," Bakkah Learning. Accessed: Apr. 22, 2025. [Online]. Available: <https://bakkah.com/knowledge-center/cybersecurity-in-pm>
- [18] M. Stadnyk and A. Palamar, "Project management features in the cybersecurity area," *Вісник Тернопільського національного технічного університету*, vol. 106, no. 2, pp. 54–62, 2022.
- [19] A. Folorunso, I. Wada, B. Samuel, and V. Mohammed, "Security compliance and its implication for cybersecurity," *World Journal of Advanced Research and Reviews*, vol. 24, no. 01, pp. 2105–2121, 2024.
- [20] "What is Cybersecurity Compliance? Why Is It Important?" Accessed: Apr. 22, 2025. [Online]. Available: <https://www.sisainfosec.com/blogs/what-is-cybersecurity-compliance-why-is-it-important/>
- [21] S. Bozkus Kahyaoglu and K. Caliyurt, "Cyber security assurance process from the internal audit perspective," *Managerial auditing journal*, vol. 33, no. 4, pp. 360–376, 2018.
- [22] R. Sabillon, J. Serra-Ruiz, V. Cavaller, and J. Cano, "A comprehensive cybersecurity audit model to improve cybersecurity assurance: The cybersecurity audit model (CSAM)," in *2017 International Conference on Information Systems and Computer Science (INCISCOS)*, IEEE, 2017, pp. 253–259. Accessed: Apr. 22, 2025. [Online]. Available: <https://ieeexplore.ieee.org/abstract/document/8328116/>
- [23] J. J. Llorens, "The Role of Human Resource Management in Cybersecurity," in *Public Personnel Management*, Routledge, 2023, pp. 175–184. Accessed: Apr. 22, 2025. [Online]. Available: <https://www.taylorfrancis.com/chapters/edit/10.4324/9781003403401-13/role-human-resource-management-cybersecurity-jared-llorens>
- [24] I. Haider and D. Estrin, "Integrating Cybersecurity Principles into Human Resources Management: Legal and Ethical Perspectives".
- [25] T. Jameel and A. Ramazan, "Cybersecurity Knowledge Among Human Resources (HR) Employees: Effects on HR Laws and Practices", Accessed: Apr. 22, 2025. [Online]. Available: https://www.researchgate.net/profile/Ashfaq-Ramazan/publication/382589790_Cybersecurity_Knowledge_Among_Human_Resources_HR_Employees_Effects_on_HR_Laws_and_Practices/links/66a3d3d075fcd863e5df4e09/Cybersecurity-Knowledge-Among-Human-Resources-HR-Employees-Effects-on-HR-Laws-and-Practices.pdf
- [26] A. Alruwaili, "A REVIEW OF THE IMPACT OF TRAINING ON CYBERSECURITY AWARENESS.," *International Journal of Advanced Research in Computer Science*, vol. 10, no. 5, 2019, Accessed: Apr. 22, 2025. [Online]. Available: <https://search.ebscohost.com/login.aspx?direct=true&profile=ehost&scope=site&authtype=crawler&jrnl=09765697&AN=139360143&h=Y%2Bf9eKZqBjMeudTyxWTfdclGrjpN%2B7%2BeddmiYwAmC17KLMfJpvxqXD%2F74%2F4OEBb5S5m3fusLqup3MNHtzt5Wsw%3D%3D&crl=c>
- [27] R. Sabillon, J. Serra-Ruiz, and V. Cavaller, "An effective cybersecurity training model to support an organizational awareness program: The Cybersecurity Awareness TRaining Model (CATRAM). A Case Study in Canada," in *Research anthology on artificial intelligence applications in security*, IGI Global, 2021, pp. 174–188. Accessed: Apr. 22, 2025. [Online]. Available: <https://www.igi-global.com/chapter/an-effective-cybersecurity-training-model-to-support-an-organizational-awareness-program/270597>

- [28] M. Zwillling, G. Klien, D. Lesjak, Ł. Wiechetek, F. Cetin, and H. N. Basim, "Cyber Security Awareness, Knowledge and Behavior: A Comparative Study," *Journal of Computer Information Systems*, vol. 62, no. 1, pp. 82–97, Jan. 2022, doi: 10.1080/08874417.2020.1712269.
- [29] "Cybersecurity Awareness and Training," Cloudavize. Accessed: Apr. 22, 2025. [Online]. Available: <https://www.cloudavize.com/cybersecurity-awareness/>

Module 2: Cybersecurity Defense and Operations

Overview

Cybersecurity Defense and Operations (CDO) represents the core mechanism through which organizations actively protect their digital landscape from both internal and external cyber threats. This extensive module delineates the process of translating Saudi Arabian regulatory mandates—such as those from the National Cybersecurity Authority (NCA), Saudi Central Bank (SAMA), and Capital Market Authority (CMA)—into daily security operations. It encompasses essential operational dimensions, including establishing visibility and control and executing active defense mechanisms.

Key components include asset management, systematically tracking hardware, software, and critical digital resources, alongside identity and access management (IAM), which restricts system access exclusively to authorized personnel through well-defined policies and procedures. This foundational layer also emphasizes regular vulnerability management, proactively identifying, assessing, and remediating vulnerabilities to mitigate risks before they materialize into breaches.

Additionally, the module covers active defense strategies, such as comprehensive incident management, involving preparation, detection, containment, eradication, and recovery from cybersecurity incidents. Penetration testing simulates real-world attacks to uncover hidden vulnerabilities in an organization's digital infrastructure. Forensics and continuous monitoring are integral for promptly detecting anomalies, preserving evidence, and refining response capabilities.

The module places significant emphasis on the practical implementation of regulatory standards, enhanced by real-world case studies from various sectors such as finance, energy, and government. By integrating practical templates, actionable checklists, and relevant metrics, this module equips learners with the operational blueprint necessary for establishing a robust, resilient, and compliant cybersecurity function.

Introduction to Cybersecurity Defense and Operations

Cybersecurity Defense and Operations encompass a range of strategies, practices, and technological solutions designed to protect an organization's information systems, networks, and data from cyber threats. This domain is concerned with both proactive measures—such as network security, system hardening, and regular vulnerability assessments—and reactive measures—such as incident response, recovery, and continuous monitoring. The ultimate goal is to ensure the confidentiality, integrity, and availability of critical assets and information, thereby safeguarding the organization from unauthorized access, data breaches, malware, and other cyber threats.

In the context of an increasingly digital world, where cyber threats are not only frequent but also highly sophisticated, Cybersecurity Defense and Operations have become a strategic imperative for organizations across all sectors. Effective cybersecurity measures are crucial for protecting an organization's assets, ensuring compliance with regulatory requirements, maintaining operational continuity, and preserving trust among customers, partners, and stakeholders.

Importance of Cybersecurity Defense and Operations within the Broader Cybersecurity Framework

1. **Protecting Critical Assets:** At the heart of Cybersecurity Defense and Operations is the protection of an organization's most valuable assets, including sensitive customer data, intellectual property, and critical infrastructure. By implementing robust cybersecurity measures, organizations can prevent unauthorized access, data leaks, and other forms of cyber threats that could compromise their operations.
2. **Maintaining Trust and Reputation:** A strong cybersecurity posture is essential for maintaining the trust of customers, partners, and stakeholders. Cybersecurity incidents can lead to significant reputational damage, loss of customer trust, and legal liabilities. By implementing effective defense and operations strategies, organizations can mitigate these risks and protect their reputation.
3. **Ensuring Compliance with Regulatory Requirements:** Compliance with cybersecurity regulations and standards is a fundamental requirement for organizations operating in various sectors. Cybersecurity Defense and Operations play a crucial role in ensuring compliance with these regulatory requirements, which include guidelines and standards set by the National Cybersecurity Authority (NCA), Saudi Arabian Monetary Authority (SAMA), Capital Market Authority (CMA), and the Communications, Space & Technology Commission (CST).
4. **Ensuring Business Continuity:** Cyber incidents can disrupt business operations, leading to financial losses and operational downtime. By implementing comprehensive cybersecurity defense and operations strategies, organizations can ensure they are prepared to respond to and recover from such incidents, thereby maintaining business continuity and operational resilience.
5. **Adapting to Evolving Threats:** The cybersecurity landscape is dynamic, with new threats emerging regularly. Cybersecurity Defense and Operations provide a structured approach to continuously monitor, detect, and adapt to these evolving threats, enabling organizations to stay ahead of cyber adversaries.
6. **Fostering a Security-Aware Culture:** Cybersecurity Defense and Operations extend beyond technical measures to include fostering a culture of security awareness across the organization. This involves training employees, establishing clear security policies, and promoting best practices to ensure that all personnel understand their role in protecting the organization's digital assets.

2.1 Asset Management:

Definition: Asset Management in cybersecurity involves the systematic identification, classification, tracking, and protection of information assets across the organization. These assets encompass hardware, software, data, and other critical resources. The goal is to ensure comprehensive visibility of all assets to support effective risk management and strengthen cybersecurity posture [1], [2], [3].

Objective: To ensure that the organization has an accurate and detailed inventory of information and technology assets in order to support the organization's cybersecurity and operational requirements to maintain the confidentiality, integrity and availability of information and technology assets.

Controls Matrix:

Below is a summary matrix detailing relevant Asset Management controls based on NCA, SAMA CSF, CST CRF, and CMA Cybersecurity Guidelines:

Regulation	Main Controls	Control References
NCA ECC	6	2-1-1, 2-1-2, 2-1-3, 2-1-4, 2-1-5, 2-1-6
SAMA CSF	3	3.3.3-1, 3.3.3-2, 3.3.3-3
CTS CRF	13	2.1.1, 2.1.2, 2.1.3, 2.1.4, 2.1.5, 2.2.1, 2.2.2, 2.2.3, 2.5.1, 2.5.2, 2.5.3, 2.5.4, 2.5.5
CMA CSG	3	4.3.5-1, 4.3.5-2, 4.3.5-3
NCA CSCC	1	2-1-1 (2 sub-controls)
NCA CCC CST	1	2-1-T-1 (1 sub-control)
NCA CCC CSP	1	2-1-P-1 (2 sub-controls)
NCA TCC	1	2-1-1 (1 sub-control)
NCA DCC	-	-
NCA OSMACC	1	2-1-1 (1 sub-control)
NCA OTCC	2	2-1-1 (5 sub-controls), 2-1-2

Asset Management Controls:

Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
ECC					
ECC 2-2-1		Cybersecurity requirements for identity and access management must be defined, documented and approved.	Identity and Access Management Policy Template.	• Develop and document cybersecurity policy for identity and access management in the organization, which may include, but is not limited to - o Grant access, including - Access to user accounts - Privileged Access to accounts - Remote access to the organization's networks and systems - Define and approve the authority of each type of users - o Revoke and Change Access. - o Review Identity and Access - o Manage passwords • Support the organization's policy by the Executive Management This must be done through the approval of the representative.	• Cybersecurity policy that covers Identity and Access Management (e.g., electronic copy or official hard copy) • Formal approval by the head of the organization or his/her deputy on the policy (e.g., via the organization's official e-mail, paper or electronic signature).
ECC 2-1-2		The cybersecurity requirements for managing information and technology assets must be implemented.		• All cybersecurity requirements to manage information and technology assets of the organization, which may include the following: - Approved cybersecurity requirements for the management of information and technology assets in the organization must be implemented, including but not limited to, classifying all information and technology assets of the organization, documenting and approving them in an approved and official	• Documents that confirm the implementation of cybersecurity requirements related to information and technology asset management as documented in the policy. • An action plan to implement the cybersecurity requirements of information

				document (e.g., a documented record for the management of the organization's information and technology assets), as well as encoding all information and technology assets of the organization based on the approved classification of the organization's information and technology assets. - Specific procedures for dealing with assets based on their classification and in accordance with the relevant laws and regulations must be established.	and technology assets management. • A documented and up-to-date record of all information and technology assets (e.g., Excel spreadsheet or displayed through automated means using solutions such as CMDB) must be provided. • Specific procedures for dealing with assets based on their classification and in accordance with the relevant laws and regulations.
ECC 2-1-3		Acceptable use policy of information and technology assets must be defined, documented and approved.	Asset Acceptable Use Policy Template.	• Develop acceptable use policy for information and technology assets of the organization, which may include the following - o Set of specific regulations for access to and use of assets. - o A set of clear examples of unacceptable use. - o Consequences if defined rules of acceptable use of assets are breached - o The method used to monitor adherence to the defined rules of acceptable use of the organization's information and technology assets • Acceptable use policy of the organization's information and technology assets must be communicated to all employees and stakeholders in the organization through, including but not limited to the official email or through the organization's website	• Approved policy that covers the requirements for acceptable use of the organization's information and technology assets (e.g., electronic copy or official hard copy) • Acceptable use policy of the organization's information and technology assets must be communicated to all employees and stakeholders in the organization through, including but not limited to the official email or through the organization's website. Evidence that all employees and stakeholders are aware

				• Support the organization's policy by the Executive Management This must be done through the approval of the organization head or his/ her deputy	and informed must be provided • Formal approval by the head of the organization or his/her deputy on the policy (e.g., via the organization's official e-mail, paper or electronic signature)
ECC 2-1-4		Acceptable use policy of information and technology assets must be implemented.		Cybersecurity policy for the acceptable use policy of the information and technology assets of the organization must be implemented, including the following: - o Requirements for the acceptable use of information and technology assets by the organization must be implemented, including but not limited to: requesting each employee view and approve the Acceptable Use Policy of information and technology assets - o These requirements must be communicated through the organization's approved communication channels to educate the organization's internal and external stakeholders to implement these requirements - o Appropriate mechanisms and techniques must be developed to monitor violations of the Acceptable Use Policy requirements and warn of disciplinary actions in the event of violations	• An action plan to implement the acceptable use requirements of information and technology assets of the organization • Evidence of communicating these requirements through the communication channels approved by the organization • A completed and approved form that clarifies the approval of the Acceptable Use Policy by all organization's employees (e.g., scanned physical copy, digital platform, or official hard copy)
ECC 2-1-5		Information and technology assets must be classified, labeled and handled as per related		• Define and document the requirements of this ECC in the cybersecurity requirements of information and technology assets management at the organization and must be approved by the representative	• A cybersecurity policy that covers the information and technology asset management requirements of the organization (e.g., electronic copy or official hard copy)

		law and regulatory requirements.		• Work with the concerned departments to identify all information and technology assets, including (but not limited to) - o Infrastructure (e.g., servers) - o Applications and services - o Networks (e.g., router) - o Workstations - o Peripherals (e.g., printers) - o Operating systems (if any) • Document all information and technology assets in a single register with characteristics such as (asset name, description, owner and criticality) • Work with asset owners to identify, document and approve asset classification in the register in accordance with the relevant laws and regulations • Work with the concerned departments to ensure the coding of assets based on their classification, including but not limited to labelling the assets or automatically coding them through modern systems • Work with the concerned departments to ensure that assets are handled according to the defined and approved classification level and based on the approved procedures for dealing with each asset	• Formal approval by the head of the organization or his/her deputy on the policy (e.g., via the organization's official e-mail, paper or electronic signature) • A document that outlines the method and system of asset classification, coding and requirements • An action plan to implement the requirements of classification and coding of information and technology assets (Labelling) in accordance with the relevant laws and regulations. • An up-to-date register that includes all information and technology assets, indicating the level of classification for each asset (e.g., Excel or through automated means using technical solutions such as CMDB) • Evidence that outlines that the organization's assets are classified according to the defined and approved classification level • Evidence that outlines that the organization's assets have been labelled according to the classification level defined and based on but not limited to the
--	--	---	--	--	--

					coding labels that demonstrate the coding of all assets within the organization • Evidence of the implementation of controls on the organization's assets in accordance with their classification level, including but not limited to the procedures followed when dealing with each asset based on its classification
ECC 2-1-6		The cybersecurity requirements for managing information and technology assets must be reviewed periodically.		• Review and update cybersecurity requirements for information and technology assets management in the organization periodically according to a documented and approved plan for review and based on a planned interval or in the event of changes in relevant laws and regulations. • Document and approve review and changes to the organization's cybersecurity requirements of the information and technology assets management by the head of the organization or his/ her deputy	• Results of information and technology assets management cybersecurity requirements implementation review in the organization • A document that defines the cybersecurity requirements implementation review cycle to manage the information and technology assets of the organization (Compliance Assessment Schedule) • Log of updates and changes to the information and technology asset management cybersecurity requirements • Compliance assessment report that outlines the results of the cybersecurity requirements implementation assessment for information and technology asset management

					• An approved document that sets the policy's review schedule • Policy indicating that it has been reviewed and updated, and that changes have been documented and approved by the head of the organization or his/her deputy • Formal approval by the head of the organization or his/her deputy on the updated policy (e.g., via the organization's official e-mail, paper or electronic signature)
NCA CCCC					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines:	Expected deliverables
NCA CCCC 2-1-1 In addition to the controls under subcomponent 2-1 of the basic controls for cybersecurity, the	2-1-1-1	Maintain an annual updated list of all assets of critical systems.	-Asset management policy template -Asset classification standards template -Asset management standard template	-Work on developing the asset inventory of critical systems in electronic format. Several methods can be applied to store and use an inventory and inventory of assets, including but not limited to: - Configuration management database (CMDB) - Asset management software - Specialized asset management tool - Spreadsheets - Database -Ensure that the inventory of informational and technical assets for critical systems includes, for example, the following:	- An inventory of all assets for critical systems and their technical components. - Annual audit reports of asset inventories for critical systems.

cybersecurity requirements for the management of information and technology assets should include, at a minimum, the following:				• The type of assets and the description of the assets. • Asset classification level and reclassification date. • Compliance requirements (such as recording whether the assets fall within the scope of privacy, data retention, or other legal obligations). • Asset site. • The owner of the assets (e.g. Asset Protection Custodian). -Ensure that the inventory list is centralized between the department concerned with cybersecurity, information technology, and other concerned departments, and that it is updated and verified at least once a year.	
	2-1-1-2	Identifying asset owners and involving them in the asset management life cycle of critical systems.	Asset management policy template	-Work to identify all asset owners of critical systems and develop a list of all their roles and responsibilities in terms of asset management. -Work on an awareness program for all asset owners on how to carry out their responsibilities. -Work on implementing a mechanism to involve all owners in the asset life cycle, for example: -Ensure that the assets are included in the inventory list and updated continuously at least annually. -Classification of assets. -Description of assets. - Safe destruction of assets. - Changes that occur to assets.	- A document that includes all the owners of the assets of the critical systems and all their duties and responsibilities. - A documented procedure for involving owners in the asset life cycle.
NCA OSMACC					

Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines:	Expected deliverables
NCA OSMACC 2-1-1 In addition to the controls within subdomain 2-1 in the ECC, cybersecurity requirements for managing information and technology assets must include at least the following:	2-1-1-1	Identifying and inventorying organization's social media accounts, and information and technology assets related to them, and updating them at least once, every year.	Template for Asset Management Policy Template for Asset Management Standard including Classification Guidelines	Identify and document the list of social media accounts, along with the associated information and technology assets related to them, across all the platforms that are used by the organization. Maintain and periodically review the inventory of social media assets at least once a year or less.	Documented and approved inventory of all the social media accounts with related assets. Periodic review report of inventory of social media assets of the organization.
NCA TCC					

Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
2-1-1 In addition to the controls within subdomain 2-1 in the ECC, cybersecurity requirements for asset management related to telework systems should include at least the following:	2-1-1-1	Identifying and maintaining an annually-updated inventory of information and technology assets of the telework systems.	-Asset management policy -Asset classification standards template	-Work on defining the requirements for this control, document them in the cybersecurity requirements document, and have them approved by the authority holder. -Develop an inventory of information and technical assets for telework systems in an electronic format, specifying the inventory date, several methods can be applied to store and use an inventory and inventory of assets, including but not limited to: -Configuration Management Database (CMDB) -Asset management programs -A specialized tool for asset management -Spreadsheets -Database -Identify all the information and technical assets (hardware & software) used in teleworking system and document them. - Ensure that the inventory is centralized between the department concerned with cybersecurity and information technology and other	-A document that identifies and documents the requirements of this control (such as a policy and/or procedure approved by the authority holder). -Detailed telework asset inventory. -Periodic plan for asset inventory update with the latest information and approval.

				concerned departments, and that it is updated and ensured its accuracy at least once a year.	
NCA OTCC					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
2-1-1: In addition to the controls in ECC subdomain 2-1, cybersecurity requirements for asset management in OT/ICS environment must include, at a minimum, the following:	2-1-1-1	OT/ICS assets inventory must be developed in electronic format for all OT/ICS assets, and reviewed periodically.	• Template for Cybersecurity Operational Technology Policy • Template for OT/ICS Security Standard • Template for Asset Management Policy • Template for Asset Management Standard	• Develop, document and approve the OT/ICS assets inventory in electronic format (e.g. Excel sheet is accepted as a minimum). • Develop a periodic review plan (based on a defined frequency). • Review and update OT/ICS asset inventory periodically (based on a defined frequency). The asset inventory must show the name of the reviewer and the date of the review.	• An OT/ICS assets inventory in electronic format showing all OT/ICS assets are inventoried. • A proof that the OT/ICS asset inventory are reviewed periodically (based on a defined frequency).
	2-1-1-2	Automated solution to collect asset inventory	• Template for Cybersecurity Operational Technology Policy • Template for OT/ICS Security Standard	• Deploy an automated solution to collect OT/ICS asset inventory information (e.g. dedicated OT/ICS asset scanners). • Verify and ensure that implemented solution does not impact the process and operational continuity.	• A periodically generated OT/ICS assets inventory report (based on

		information must be utilized.	• Template for Asset Management Policy • Template for Asset Management Standard		a defined frequency). • A proof of the provision of OT/ICS asset's automation solutions. • A proof that the OT/ICS assets inventory solution is implemented and does not impact the process.
	2-1-1-3	OT/ICS asset inventory must be stored securely.	• Template for Cybersecurity Operational Technology Policy • Template for OT/ICS Security Standard • Template for Asset	• Ensure compliance with identity and access management procedures for automation systems and technologies. • Ensure that both the access to automated solution and the OT/ICS Asset inventory in electronic format are protected by password and only authorized personnel can access the data.	• A proof showing the compliance with identity and access management procedures for automation systems and technologies. • A proof showing the OT/ICS asset inventory is

			Management Policy • Template for Asset Management Standard		protected by password.
	2-1-1-4	Asset owners for all OT/ICS assets must be identified and involved throughout the relevant asset inventory management lifecycle.	-Template for Cybersecurity Operational Technology Policy -Template for OT/ICS Security Standard -Template for Asset Management Policy -Template for Asset Management Standard	• Identify and document all asset owners for all OT/ICS assets. Prepare a formalized register of OT/ICS assets and their owners. • Verify and ensure that the asset owners and custodian are involved throughout the relevant asset inventory management lifecycle.	-A proof that shows the identified asset owners for all OT/ICS assets in asset register/asset inventory. -A proof that highlights the involvement of asset owners throughout the OT/ICS asset inventory management lifecycle.
	2-1-1-5	Criticality rating for all assets must be assigned, documented, and approved by asset owners.	•Template for Cybersecurity Operational Technology Policy •Template for OT/ICS Security Standard •Template for Asset Management Policy •Template for Asset Management Standard	•Define principles and rules for the mechanism of classifying assets criticality ratings. •Define and document the criticality rating for all OT/ICS assets based on the defined rules and principles. •Verify and ensure that criticality rating is approved by the relevant asset owner.	•A proof that shows the approved criticality rating for all assets by asset owners. • A documented proof that shows the assigned criticality rating for all assets in asset register/asset inventory.

			Including Classification Guidelines		
2-1-2		With reference to the ECC control 2-1-6, the cybersecurity requirements for managing OT/ICS assets must be reviewed, and their implementation effectiveness is measured and evaluated periodically.	• Template for Cybersecurity Operational Technology Policy • Template for OT/ICS Security Standard • Template for Asset Management Policy • Template for Key Performance Indicator Report	• Review the cybersecurity requirements for managing OT/ICS assets periodically based on a documented and approved review plan and on a defined frequency (e.g., conduct a review annually). • Develop key performance indicators (KPIs) for each control within the related policy or procedure to ensure the implementation effectiveness is measured and evaluated periodically based on a defined frequency (e.g., conduct an annual review).	• Proof of conducting periodical reviews for cybersecurity requirements related to OT/ICS asset management. • A proof that shows the key performance indicators (KPIs) for each control within the related policy or procedure to ensure the implementation effectiveness is measured and evaluated periodically (based on a defined frequency).
NCA CCC					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
2-1-T-1 In addition to controls in the ECC control 2-1, the CST shall cover the following additional controls for cybersecurity requirements for cybersecurity event logs and	2-1-T-1-1	Inventory of all cloud services and information and technology assets related to the cloud services.	• Template for Asset Management Policy	• Identify cloud services in use (e.g.: via contract review, solution architecture review, active network connections monitoring) • Identify data stored or processed in cloud (e.g. review cloud services for data flows and data storages) • Identify cloud technology assets or group of assets (e.g. review cloud services for technical components in use). Consider fluent nature of IaaS components and auto scalability functions.	• Inventory of cloud services and related data and assets.

monitoring management, as a minimum:				• Maintain Inventories of cloud services, data and technical assets (e.g. build a database of cloud services and data stored and/or processed and technical assets involved in these operations);	
2-1-P-1 In addition to controls in the ECC control 2-1, the CSP shall cover the following additional controls for cybersecurity requirements for cybersecurity event logs and monitoring management, as a minimum:	2-1-P-1-1	Inventory of all information and technology assets using suitable techniques such as Configuration Management Database (CMDB) or similar capability containing an inventory of all technical assets.	• Template for Asset Management Policies • Template for Asset Management that contains Classification guide	• Identify types of information and technology assets in use (e.g. using Asset Discovery techniques, scans, etc.). • Identify types of information and technology assets used in the dedicated assets for cloud computing systems (such as virtual servers, cloud storage, application firewall, etc.). • Maintain CMDB-class technology to capture all information and technical assets. • Update Asset Inventory automatically to capture fluent changes in cloud asset landscape.	• Asset inventory techniques are identified and utilized. • Document outlining the inventory of technical assets specific to cloud systems. • Organization's information and technology assets information is maintained within an asset inventory (e.g. CMDB).
	2-1-P-1-2	Identifying assets owners and involving them in the asset management lifecycle.	• Template for Asset Management Policies	• Identify duties and obligations (e.g.: regulatory, contractual) associated with assets (e.g.: approve changes related to assets, manage accesses to assets). • Define and document Roles and Responsibilities for assets in the asset management lifecycle (e.g.:	• Document outlining asset inventory and owners assigned to the assets. • Evidence demonstrating that roles and responsibilities of asset owners are aligned

				create, deploy, manage, dispose) and communicate them with asset owners. Assign owners to information and technology assets to ensure that all information or technology asset has an owner.	with their respective assets.
SAMA CSF					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
CSF 3.3.3-1		The asset management process should be defined, approved, and implemented.	- Asset Management Policy Template - Asset Management System (e.g., Configuration Management Database - CMDB)	This ensures that the organization has a structured and consistent approach to managing its information and technology assets. Below guideline might be considered: - Define an asset management policy and ensure it is approved by relevant stakeholders. - Implement a comprehensive asset management system that tracks the lifecycle, classification, and ownership of assets. - Ensure that the process is communicated to all relevant teams and individuals responsible for asset management.	- Approved asset management policy and process documentation. - Asset management system implementation reports. - Records of asset management training and awareness sessions.
CSF 3.3.3-2		The effectiveness of the asset management process should be monitored, measured, and	- Monitoring and Reporting Tools (e.g., Dashboard in CMDB for asset tracking) - Audit Tools for Periodic Reviews	This ensures that the asset management strategy is functioning as intended and can be adapted if necessary. Below guidelines might be considered: Implement a performance monitoring system for asset	- KPI reports on the effectiveness of the asset management process. - Periodic review reports, including identified

		periodically evaluated.		management, using key performance indicators (KPIs) to measure success. • Schedule periodic reviews (e.g., annually) of the asset management process to identify gaps or areas for improvement. • Establish a feedback mechanism to continuously improve the asset management process based on the evaluation results.	gaps and recommendations for improvements. • Records of any corrective actions or updates made to the asset management process.
CSF 3.3.3-3		The asset management process should include the following components: • A unified register of all assets. • Ownership and custodianship of information assets. • Reference to relevant processes, depending on asset management. • Asset classification, labeling, and handling.	• Asset Management System (e.g., CMDB) for unified asset register. • Ownership Assignment Tools for asset tracking and management. • Asset Classification Guidelines and Templates. • Asset Discovery Tools (e.g., network scanners, automated discovery tools).	• Maintain a unified asset register that includes all assets (hardware, software, data, etc.). • Assign ownership and custodianship for each asset, ensuring that responsible individuals are identified. • Reference relevant processes (e.g., change management, risk management) in relation to asset management. • Classify, label, and handle assets based on their criticality and value to the organization. • Implement automated discovery tools to ensure continuous identification of new assets.	• Unified asset register with ownership and classification details. • Asset ownership and custodianship records. • Regular reports on newly discovered assets and their integration into the asset register. • Audit reports showing the effective classification and handling of assets.

		• Discovery of new information assets.			
CST CRF					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
2.1 Asset Discovery	2.1.1	• Define and document the requirements for asset discovery, which should include: - o Defining an inventory of information assets (e.g., software, hardware, critical information, databases, equipment). - o Defining the frequency for	•Template for Asset Management Policies •Asset Inventory Management System (e.g., Configuration Management Database - CMDB) •Asset Discovery Requirements Template	•Create a documented policy outlining asset discovery requirements, specifying the information assets within the organization. •Define specific timelines (e.g., quarterly updates or system change triggers) for reviewing and updating the asset inventory. •Assign and document ownership for each asset, ensuring that the responsible individual or department is clearly identified.	•Approved and documented asset discovery policy. •Asset inventory records showing all information assets and their assigned owners. •Updated asset inventory based on a predefined review and update schedule.

		updating the asset inventory. o Ownership of the information assets.			
	2.1.2	• Define and implement an asset discovery process to identify all information assets (e.g., using an asset discovery tool) and update the asset inventory. • Assign an asset owner to each identified information asset.	• Asset Discovery Tools (e.g., network scanning tools, automated discovery tools) • Asset Ownership Assignment Templates • Centralized Asset Management System	• Implement automated or manual asset discovery processes that periodically scan for new assets or changes in asset configurations. • Update the asset inventory promptly upon discovering new assets or modifying existing ones. • Ensure each asset is assigned a documented owner, with responsibility clearly defined in the asset management system.	• Asset discovery reports generated by the automated discovery tools. • Updated asset inventory with newly identified assets and assigned owners. • Audit reports verifying that the discovery process is implemented and that assets are being updated.
	2.1.3	• Review and update the asset inventory based on the frequency defined in the requirements or whenever modifications occur (e.g., addition or removal of assets).	• Asset Inventory Management System (e.g., CMDB) • Asset Review Schedule	• Develop a regular review process where the asset inventory is assessed against predefined timelines (e.g., quarterly or annually). • Implement a change management process to ensure any asset additions, removals, or modifications are reflected in the asset inventory in real time. • Conduct periodic audits to ensure the asset inventory remains accurate and comprehensive.	• Updated asset inventory, including any additions, removals, or modifications. • Audit reports validating that asset updates comply with the review schedule. • Change management logs recording asset modifications.
	2.1.4	• Use dedicated and	• Automated Asset Discovery Tools	• Deploy automated discovery tools that continuously monitor and	• Reports generated from automated discovery tools, showing the current

		automated tools to discover all information assets and integrate them into a centralized system.	(e.g., network scanning, endpoint discovery) Centralized Asset Management System (e.g., CMDB)	track the organization's assets across the network. Ensure the automated tools are integrated with a central management system to provide real-time asset inventory upd\]Periodically validate the accuracy of the automated discovery process to ensure completeness and correctness.	status of the asset inventory. - Centralized asset management reports detailing newly identified or modified assets. - Validation reports confirming the accuracy of automated asset discovery.
	2.1.5	•Continuously measure, review, and optimize the asset discovery process to ensure it aligns with defined requirements and remains effective.	- Asset Discovery Performance Metrics (KPIs) - Asset Discovery Optimization Plan	- Develop KPIs for the asset discovery process, measuring performance areas such as discovery accuracy, update speed, and asset coverage. - Conduct regular reviews of the asset discovery process to identify gaps or inefficiencies, and adjust the process accordingly. - Implement continuous improvements to enhance the accuracy, efficiency, and effectiveness of the asset discovery process.	- Reports detailing the performance of the asset discovery process based on defined KPIs. - Continuous improvement logs outlining changes or optimizations made to the discovery process. - Evidence of enhanced accuracy and efficiency in the discovery and management of assets.
2.2 Asset Classification	2.2.1	Define and document the Requirements for	Template for Asset Management Policies	Develop a comprehensive asset classification policy that outlines classification categories (e.g., public,	Documented and approved requirements for asset classification, covering

		Asset Classification, which consider the following: Classification and labelling of information assets as well as the respective protective measures for identification, handling, transfer, storage, return, deletion, and disposal.	• Template for Information Classification Policy • Asset Classification Standards	confidential, restricted) for all information assets. • Define handling procedures for each classification level to ensure proper protection, storage, and disposal. • Document the classification and labelling requirements and ensure they are communicated to relevant stakeholders responsible for asset management.	classification, labelling, and protective measures. • Evidence of stakeholder communication and awareness of asset classification guidelines. • Documented classification policy and procedures for the handling of classified assets.
	2.2.2	• Define and implement an Asset Classification process to classify and label information assets within your Asset Inventory according to specific criteria (e.g., criticality, business value, legal requirements, confidentiality,	• Asset Classification Tools (automated labelling software) • Information Protection Policy • Centralized Asset Management System (CMDB)	• Implement an automated or manual process to classify and label assets based on predefined criteria, including business value and legal requirements. • Integrate the classification process with the asset inventory to ensure that all information assets are appropriately labelled and categorized. • Ensure compliance with the information protection guidelines, especially for sensitive or critical assets.	• A classified and labelled asset inventory, with assets categorized based on criticality, confidentiality, and business value. • Evidence of compliance with asset classification criteria and information protection requirements. • Reports showing the integration of asset

		integrity, and availability) and the Requirements for Information Protection.			classification with the asset management system.
	2.2.3	Continuously measure, review, and optimize the Requirements for Asset Classification as well as the effectiveness of the process.	• Key Performance Indicators (KPIs) for Asset Classification • Asset Classification Audit Tools	• Develop KPIs to monitor the effectiveness of the asset classification process (e.g., percentage of assets correctly classified, labelling accuracy). • Periodically review the asset classification process to identify any gaps or inefficiencies. • Continuously improve the classification process to align with evolving business, legal, and security requirements.	• Reports showing the performance of the asset classification process based on predefined KPIs. • Evidence of continuous improvement in the classification process, including updates or optimizations. • Audit reports validating the effectiveness and accuracy of the asset classification system.
2.5 Asset Maintenance	2.5.1	•Define and document the Requirements for Asset Maintenance, which consider the following: -Asset maintenance -Tracking and monitoring -Recovery plan	•Template for Asset Maintenance Policy •Asset Monitoring and Tracking Tools •Recovery Plan Template	•Develop a comprehensive asset maintenance policy that outlines how assets will be maintained, including routine check-ups and repair schedules. •Establish clear tracking and monitoring procedures for information assets, including logs to record any maintenance activities. •Create a recovery plan for asset restoration in case of a security incident, covering all critical and non-critical assets.	•Documented asset maintenance policy that includes procedures for tracking and monitoring. •Approved recovery plan for asset restoration following security incidents. •Logs and records that demonstrate ongoing asset maintenance.

	2.5.2	• Define and implement an Asset Maintenance process to maintain and repair the organization's information assets (including offsite assets) and keeping a log of these activities.	• Asset Maintenance Tools (automated or manual tracking of asset health) • Centralized Asset Management System (CMDB)	• Implement a comprehensive asset maintenance program that regularly inspects, maintains, and repairs all organizational information assets. • Include offsite assets in the maintenance schedule and ensure that logs are kept for every repair or maintenance activity. • Integrate the maintenance process into the overall asset management lifecycle to ensure continuous monitoring and maintenance of asset health.	• A log of all maintenance activities, including details about offsite assets. • Evidence of compliance with the asset maintenance process (e.g., completed maintenance schedules and repair logs). • Documentation showing the integration of the maintenance process within the asset lifecycle.
	2.5.3	• As per the organization-defined recovery plan, execute the asset recovery during or after a security incident.	• Incident Recovery Plan Template • Asset Recovery and Restoration Tools	• Develop and implement an asset recovery plan that outlines the steps to be taken to recover information assets during or after a security incident. • Ensure that recovery procedures are regularly tested and validated to minimize downtime in case of an incident. • Include all critical assets in the recovery plan and assign roles for asset restoration to relevant personnel.	• Documented asset recovery plan, with clear procedures to follow during a security incident. • Records showing that recovery procedures have been tested and validated. • Logs detailing asset recovery activities during past security incidents.
	2.5.4	• Monitor information assets appropriately,	• Asset Classification and Monitoring Tools	• Monitor the condition and usage of assets according to their	• Logs and reports showing the monitoring

		based on the Asset Classification.	Asset Management System (with built-in monitoring features)	classification (e.g., more frequent monitoring for high-criticality assets). - Use automated monitoring systems that alert relevant stakeholders if any anomalies or irregularities are detected in classified assets. - Ensure that monitoring data is stored securely and reviewed periodically to detect potential security incidents.	of assets based on their classification. - Alerts and records of incidents related to classified assets. - Documentation demonstrating compliance with asset classification monitoring requirements.
	2.5.5	Continuously measure, review, and optimize the Requirements for Asset Maintenance as well as the effectiveness of the process.	- Key Performance Indicators (KPIs) for Asset Maintenance - Asset Maintenance Review Templates	- Implement a process to continuously review and improve asset maintenance based on predefined KPIs (e.g., asset downtime, repair frequency, and cost-effectiveness). - Periodically review the asset maintenance process to identify any inefficiencies and gaps. - Continuously update the asset maintenance policy to align with changing business requirements, technology upgrades, and security needs.	- Reports showing KPIs for the asset maintenance process. - Evidence of continuous improvement in asset maintenance activities. - Documentation of periodic reviews and optimizations of asset maintenance policies and processes.
CMA Cybersecurity Guidelines					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables

4.3.5 Information and Technology Assets Management	4.3.5 - 1	Set out, document, approve, implement, monitor, and periodically evaluate information and technology assets management to ensure the organization maintains an accurate, unified, and updated asset record.	• Asset Management Policy Template • Asset Inventory Monitoring Tools • Asset Lifecycle Management System	• Establish a comprehensive information and technology asset management policy that outlines procedures for documenting, approving, and implementing asset management activities. • Monitor all assets throughout their lifecycle, ensuring accurate documentation of all updates, changes, or modifications. • Periodically evaluate the effectiveness of the asset management process and make any necessary adjustments to keep records unified and up to date.	• A documented and approved asset management policy that outlines the organization's procedures. • Periodic reports demonstrating the monitoring and evaluation of information and technology assets. • Evidence of regular updates to asset records to ensure accuracy and completeness.
	4.3.5 – 2	• Information and technology asset management should include, but is not limited to: - o Unified record of all information and technology assets throughout their full lifecycle. - o Ownership of information and technology assets.	• Asset Inventory Management System (to maintain unified records) • Asset Classification and Labeling System • Backup Solutions for Asset Records	• Implement a unified system to track all assets from acquisition to decommissioning, ensuring that the system includes asset ownership and detailed lifecycle information. • Assign ownership of each information and technology asset, ensuring accountability for asset management. • Classify, label, and properly handle all assets according to their business value, criticality, and security requirements. • Ensure backups of all asset records are regularly maintained and	• Unified asset register showing the lifecycle, ownership, and classification of each information and technology asset. • Backup records of all asset information, stored in a secure location. • A documented policy outlining the classification, handling, and backup of asset records.

		- o Classification, labeling, and handling of information and technology assets. - o Maintaining backups of asset records and keeping them in a safe place.		stored securely, either on-premises or in the cloud, with regular backup tests.	
	4.3.5 – 3	• Set out, document, approve, implement, circulate, and periodically evaluate an acceptable use policy for information and technology assets.	• Acceptable Use Policy Template • Policy Management System	• Define and document an acceptable use policy for all information and technology assets, outlining the permitted and prohibited uses of the assets. • Ensure the policy is approved by relevant stakeholders and circulated to all employees and asset users. • Periodically review and update the acceptable use policy to reflect changes in asset usage, technological advancements, and regulatory requirements.	• A documented and approved acceptable use policy for information and technology assets. • Proof of the policy's circulation to all relevant employees and asset users. • Periodic reviews of the acceptable use policy, with evidence of any updates made to maintain compliance and relevancy.

Risk Considerations in Asset Management

1. **Unauthorized Access:** Without proper classification and inventory, sensitive assets may be exposed to unauthorized access, leading to data breaches.
 2. **Untracked Assets:** Failure to maintain an up-to-date asset inventory can result in untracked assets, which can be a major vulnerability for cyberattacks.
 3. **Regulatory Non-compliance:** Inadequate asset management practices may lead to violations of regulatory requirements (NCA ECC, SAMA CSF, etc.), resulting in penalties and fines.
 4. **Data Loss:** Improper handling or disposal of classified assets could lead to accidental data loss or intentional data theft.
-

Examples of Technologies for Effective Asset Management

- **Configuration Management Database (CMDB):** Provides a centralized repository for tracking the configuration and status of all assets within the organization. CMDB can be integrated with other systems like IT service management (ITSM) to automate asset tracking.
 - **Asset Discovery Tools:** Automated tools that continuously scan the organization's network to detect all connected assets, including new devices or systems that may have been added without proper documentation.
 - **Asset Classification Software:** Automated solutions that label and classify assets based on predefined criteria such as criticality, sensitivity, and business value.
 - **Audit Tools:** Tools that assist in periodically reviewing and auditing asset management processes, ensuring that all requirements are met and all assets are appropriately managed.
 - **Asset Tracking Systems:** These systems help maintain a detailed inventory of assets and monitor their status, usage, and ownership throughout their lifecycle.
-

Examples of KPIs for Asset Management

1. **Asset Inventory Accuracy:** Percentage of assets accurately inventoried and classified.
2. **Asset Classification Compliance:** Percentage of assets that are correctly classified and labeled according to regulatory standards.
3. **Asset Discovery Coverage:** Percentage of assets discovered through automated tools compared to manual processes.
4. **Frequency of Asset Updates:** Frequency with which the asset inventory is reviewed and updated to reflect changes.
5. **Audit Compliance Rate:** Percentage of successful audits related to asset management practices.

Samples of Auditor's Checklist for Asset Management

1. Is there a defined and approved Asset Management Policy?
2. Is a centralized and updated inventory of all information and technology assets maintained?
3. Are critical and sensitive assets identified, classified, and labeled according to regulatory standards?
4. Are processes in place for the secure disposal of decommissioned assets?
5. Are asset management records periodically reviewed for accuracy and completeness?
6. Are automated tools like CMDB or asset discovery solutions used for tracking assets?
7. Are roles and responsibilities for asset management clearly defined and documented?
8. Are audits conducted to ensure compliance with asset management policies and regulations?

Samples of Audit Scenarios for Asset Management

Scenario 1: Asset Inventory Validation

- **Objective:** Verify the completeness and accuracy of the organization's asset inventory.
- **Steps:**
 1. Request the most recent asset inventory records.
 2. Cross-check a sample of physical and digital assets against the inventory.
 3. Ensure assets are classified and labeled appropriately.
- **Questions:**
 - Are all assets accounted for in the inventory?
 - Are there discrepancies in asset classifications or records?

Scenario 2: Asset Lifecycle Management

- **Objective:** Assess the organization's processes for managing the lifecycle of assets.
- **Steps:**
 1. Review policies for asset acquisition, maintenance, and disposal.
 2. Verify if sensitive data is securely wiped before asset disposal.
 3. Examine records of asset maintenance activities.
- **Questions:**
 - Are lifecycle processes followed consistently for all assets?
 - Is sensitive information adequately protected during the lifecycle?

Scenario 3: Regulatory Compliance

Objective: Ensure compliance with asset management-related regulations.

- **Steps:**
 1. Identify relevant regulatory requirements (e.g., NCA ECC, SAMA CSF).
 2. Check if asset management policies address these requirements.
 3. Verify evidence of compliance, such as certifications or audit reports.
- **Questions:**

- Are the organization's asset management processes aligned with regulations?
- Are compliance gaps identified and addressed promptly?

Case Study 1: Implementing Asset Management for a Financial Institution

Scenario:

A mid-sized financial institution identified a gap in its asset management practices. The institution lacked a unified, up-to-date asset inventory and had no established procedures for tracking assets throughout their lifecycle. This presented challenges in maintaining compliance with SAMA CSF and NCA ECC standards.

Actions Taken:

1. **Define Requirements:** The institution worked with its IT and cybersecurity departments to develop comprehensive requirements for asset management, addressing classification, lifecycle management, and ownership.
2. **Implement Asset Management System:** A Configuration Management Database (CMDB) was deployed to automate the asset discovery process. All assets were inventoried and classified based on their criticality and business value.
3. **Create Acceptable Use Policy:** A policy was developed, approved by executive management, and distributed to all employees. Employees were required to acknowledge their understanding of acceptable asset use.
4. **Perform Regular Audits:** The financial institution implemented a schedule for reviewing asset management practices, conducting quarterly reviews to ensure compliance with regulatory requirements.
5. **Continuous Improvement:** Based on audit results, the asset management policies and tools were optimized to better track the criticality of assets and ensure timely updates to the asset inventory.

Outcome:

The institution successfully addressed its asset management gap by implementing a structured, automated approach. Quarterly audits provided evidence of compliance with SAMA CSF and NCA ECC, reducing the risk of data breaches and improving asset visibility. This approach also enabled the institution to meet regulatory requirements with ease, ensuring operational resilience and customer trust.

Case Study 2: Asset Management Implementation in an Energy Sector Organization

Scenario:

A large energy company faced challenges in managing its operational technology (OT) assets, including critical infrastructure components like SCADA systems. The lack of a unified asset inventory resulted in several untracked assets that posed significant cyber risks. Moreover, the company struggled to comply with NCA OTCC controls, which mandate rigorous asset management practices for critical OT systems.

Actions Taken:

1. **Asset Inventory Creation:** The organization implemented an automated asset discovery tool to identify and classify all OT assets, ensuring every device and system was inventoried.
2. **Asset Classification & Labeling:** The company established an asset classification process that assigned criticality ratings to all OT assets. This ensured the most sensitive and critical assets were prioritized for enhanced security measures.
3. **Regular Audits:** Quarterly audits were introduced to ensure the OT asset inventory was accurate and up to date. An internal audit team was tasked with validating compliance with NCA OTCC requirements.
4. **Ownership Assignment:** Asset owners were identified and made responsible for the lifecycle management of specific assets, ensuring accountability at every stage.

Outcome:

The energy company successfully implemented a structured asset management program that met all NCA OTCC requirements. The company reduced risks by identifying and securing critical OT assets, thereby minimizing the likelihood of cyberattacks. Quarterly audits provided further assurance that the asset inventory remained accurate and compliant with regulatory standards.

2.2 Identity and Access Management:

Definition: Identity and Access Management (IAM) in cybersecurity involves the systematic identification, authentication, authorization, and management of user and system access to organizational resources. This includes processes for verifying identities, assigning roles, granting permissions, and ensuring secure access to critical assets such as hardware, software, data, and services. The goal is to ensure only authorized entities can access appropriate resources, supporting effective risk management, compliance, and strengthening the organization's overall cybersecurity posture[4], [5], [6].

Objective: To ensure the secure and restricted logical access to information and technology assets in order to prevent unauthorized access and allow only authorized access for users which are necessary to accomplish assigned tasks.

Controls Matrix:

Below is a summary matrix detailing relevant identity and access management controls based on NCA, SAMA CSF, CST CRF, and CMA Cybersecurity Guidelines:

Regulation	Main Controls	Control References
NCA ECC	4	2-2-1, 2-2-2, 2-2-3 (5 sub-controls), 2-2-4
SAMA CSF	4	3.3.5 (20 sub-controls)
CTS CRF	9	4.7.1, 4.7.2, 4.7.3, 4.7.4, 4.7.5, 4.7.6, 4.7.7, 4.7.8, 4.7.9
CMA CSG	2	4.3.4-1, 4.3.4-2, 4.3.4-3 (18 sub-controls)
NCA CCCC	2	2-2-1 (8 sub-controls), 2-2-2
NCA CCC CST	1	2-2-T-1 (5 sub-controls)
NCA CCC CSP	1	2-2-P-1 (12 sub-controls)
NCA CCC DCC	1	DCC-2.2.1 (4 sub-controls)
NCA TCC	2	2-2-1 (3 sub-controls), 2-2-2
NCA OSMACC	2	2-2-1 (9 sub-controls), 2-2-2
NCA OTCC	2	2-2-1 (11 sub-controls), 2-2-2

Identity and Access Management Controls:

Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines:	Expected deliverables
ECC					
ECC 2-1-1		Cybersecurity requirements for managing information and technology assets must be defined, documented and approved.	Asset Management Policy Template.	- Develop and document cybersecurity requirements for information and technology assets management in the organization, including the following: - The cybersecurity requirements for types and description of information and technology asset management must be identified - Information and technology asset classification levels requirements in terms of data included and processed, and the criticality of the technology asset from a cybersecurity perspective must be defined - Requirements for the defined stages of the information and technology assets life cycle (including but not limited to: preservation, processing, storage, destruction, etc.) must be defined - Roles and responsibilities requirements for the ownership and management of information and technology assets must be defined - Support the organization's developed requirements by the Executive Management. This must be done through the approval of the representative.	- Information asset management cybersecurity requirements (in form of policy or standard) approved by the organization (e.g., electronic copy or official hard copy) - Formal approval by the head of the organization or his/her deputy on the requirements (e.g., via the organization's official e-mail, paper or electronic signature)
ECC 2-2-2		The cyber security requirements for		All cybersecurity requirements must be implemented for the organization's approved identity and access management	Action plan for cybersecurity

		identity and access management must be implemented.		procedures. It is also recommended that the identity and access management cover the following, but not limited To: - o User Authentication based on user login management. - o Password management based on the organization's password policy - o User authorization management based on a need-to-know and Needto-use basis. - o User authorization management based on least privilege and Segregation of Duties - o Remote access management to the organization's networks. - o Access Cancellation and Update Management.	requirements for Identity and Access Management • Evidence that the identity and access management controls must be implemented on all technical and information assets in the organization, including but not limited to, the configuration of all technical information systems in line with the cybersecurity controls and requirements of identity and access management.
ECC 2-2-3 The cybersecurity requirements for identity and access management must include at least the following:	2-2-3-1	Single-factor authentication based on username and password.	Identity and Access Management Tools, Password Management Systems	- Define and document requirements for single-factor authentication. - Ensure unique username and password creation processes. - Enforce password policies such as complexity, expiration, and lockout mechanisms.	- Cybersecurity policy for username and password authentication. - Evidence of password management policies. - Formal approval by authorized personnel.
	2-2-3-2	Multi-factor authentication for remote access, defining suitable authentication factors, number of	Multi-Factor Authentication Solutions, VPN Access Control Systems, Privileged Access management system.	- Define and document the multi-factor authentication (MFA) requirements. - Conduct impact assessments for authentication failure risks. - Implement MFA with suitable techniques such as OTP, biometrics, or hardware tokens.	- Documented MFA policy and procedures. - Evidence of MFA configurations and deployment for remote access. - Audit logs showcasing MFA activity.

		factors, and suitable techniques based on the result of impact assessment of authentication failure and bypass for remote access and privileged accounts.		- Monitor and periodically test MFA implementation.	
	2-2-3-3	User authorization based on identity and access control principles: Need-to-Know and Need-to-Use, Least Privilege and Segregation of Duties.		• Define and document the requirements of this ECC in the cybersecurity requirements of identity and access management at the organization and must be approved by the representative • Define basic authorizations for all organization's employees, such as the authority to use email, internal portal, and human resources system • Define and document the requirements of this ECC in the cybersecurity requirements of identity and access management at the organization and must be approved by the representative. • Manage user authorization to all information and technology assets in the organization via an automated centralized access control system such as Active Directory • Develop and adopt specific procedures for granting powers to employees in the organization, as there are requirements to request authority, including: - o Applicant information (identity) - o Details of the authority in question (explanation of authority and assets involved)	• Cybersecurity policy that covers Identity and Access Management (e.g., electronic copy or official hard copy) • Evidence that outlines the implementation of User authorization management requirements, including but not limited to a screenshot showing the configuration of systems to ensure the implementation of user authorization management based on a Need to Know and Need to Use basis and least privilege and Segregation of Duties.

				- o Description of Business Requirements for authorization - o Time required for authorization - o Approvals required (e.g., Line Manager approval)	
	2-2-3-4	Privileged access management.		• Define and document the requirements of this ECC in the cybersecurity requirements of identity and access management at the organization and must be approved by the representative • Define privileged access at the level of infrastructure, networks, and applications in the organization. • Identify Personnel with Privileged Access. • Develop Privileged Access Management procedures by the organization, taking into account the following - o Privileged accounts must not be used for normal daily tasks, and a normal user account must be used for this purpose - o Privileged accounts must not be used for internet access. - o Privileged accounts must not be used for email access - o Privileged accounts must not be restricted for remote access - o Default accounts must be disabled/ deleted. - o Workstation protection system must be installed and updated on the workstation that will be used to access privileged accounts. - o Secure versions of operating systems used in the organization must be built and prepared in a secure manner. - o Protection programs must be installed and unused services must be	• Privileged Access Management Policy in the organization (e.g., electronic copy or official hard copy) • Formal approval by the head of the organization or his/her deputy on the policy (e.g., via the organization's official e-mail, paper or electronic signature) • Evidence that outlines the implementation of privileged access management requirements, including but not limited to a screenshot showing the configuration of systems to ensure that administrators are granted privileged access.

				disabled These copies must be used to configure desktops and servers. • Define modern and advanced technologies and mechanisms for the Privileged Access Management • Grant privileged access based on functional duties after obtaining the necessary approvals, taking into consideration the principle of segregation of duties • Continuously monitor cybersecurity event logs for privileged accounts	
	2-2-3-5	Periodic review of users' identities and access rights.		• Define and document the requirements of this ECC in the cybersecurity requirements of identity and access management at the organization and must be approved by the representative • Define privileged access at the level of infrastructure, networks, and applications in the organization. • Identify Personnel with Privileged Access. • Develop a plan for periodic review of identity and access as follows - o Across all applications in the organization - o Network level - o Infrastructure and servers level - o Workstations level • Review authorities in collaboration with IT department and application managers to revoke access in the following cases (e.g., limited to) - o Access has not been used for a long period of time (e.g., over 3 months) - o Access causes conflict of interest - o The employee's need for access has not been confirmed by his manager - o Expiry of the access period	• Privileged Access Management Policy in the organization (e.g., electronic copy or official hard copy) • Formal approval by the head of the organization or his/her deputy on the policy (e.g., via the organization's official e-mail, paper or electronic signature) • Evidence that outlines the implementation of periodic review requirements of identity and access, e.g., an official and approved document that clarifies the periodic review of the identity and access.

2-2-4		The Implementation of the cybersecurity requirements for identity and access management must be reviewed periodically.		• Review the cybersecurity requirements of identity and access management by conducting a periodic assessment (according to a documented and approved plan for review, and based on a planned interval "e.g., quarterly") to implement identity and access management requirements by the Cybersecurity function and in cooperation with relevant departments (such as IT Department) • Review and update cybersecurity requirements for identity and access management in the organization periodically according to a documented and approved plan for review and based on a planned interval or in the event of changes in relevant laws and regulations • Document the review and changes to the cybersecurity requirements for identity and access management in the organization and approve them by the head of the organization or his/her deputy.	• Results of identity and access management requirements implementation review in the organization • A document that defines the cybersecurity requirements implementation review cycle for identity and access management at the organization (Compliance Assessment Schedule). • Compliance assessment report that outlines the assessment of the implementation of cybersecurity requirements for identity and access management in the organization • An approved document that sets the policy's review schedule • Policy indicating that it has been reviewed and updated, and that changes have been documented and approved by the head of the organization or his/her
-------	--	--	--	--	--

					deputy • Formal approval by the head of the organization or his/her deputy on the updated policy (e.g., via the organization's official e-mail, paper or electronic signature).
NCA CSCC					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines:	Expected deliverables
CSCC-2.2.1	CSCC-2.2.1.1	In addition to the sub-controls under item 2-2-3 in the basic controls for cybersecurity, they must cover the cybersecurity requirements related to managing access identities and the permissions for critical systems in the entity, at a minimum:	Identity and Access Management Policy Template	The design and settings of the network must not allow remote access from outside the Kingdom to critical systems that are not connected to the Internet, as well as technical support from outside the Kingdom for critical systems, whether connected to the Internet or not. This does not mean that users of critical systems connected to the Internet are not allowed to access them. Such as: (adjusting VPN	A list of technical controls settings to prevent remote access to critical systems from outside the Kingdom.

		Prohibiting remote access from outside the Kingdom of Saudi Arabia.		settings to prevent entry from outside Saudi Arabia).	
	CSCC-2.2.1.2	Restricting remote entry from inside the Kingdom; Provided that it is verified by the security operations center of the entity, at every entry process; and continuously monitor remote access-related activities.	Identity and Access Management Policy Template	Work on developing procedures to restrict remote entry from inside the Kingdom, for example: Entry from inside the Kingdom is automatically denied to all users, and when needed, the reason for the need is presented, and then the necessary approvals are taken from the concerned department and the cybersecurity department according to the procedures approved by the entity. Granting access for a limited period only as needed. Grant access to the system specified in the request only. Granting access from inside the Kingdom through specialized systems approved by the	Procedures document for restricting remote entry from within the Kingdom to critical systems. A document to set the configuration of remote access systems, for example, the (VPN) system. A guide explaining the monitoring of remote access events through the entity's security operations center.

				entity, for example: the (VPN) or (MDM) systems. Work to save all activities and records of remote login operations and ensure that they are sent to the operations and monitoring center to ensure that they are constantly monitored by specialized teams by linking login logs with monitoring systems, for example: the (SEIM) system.	
	CSCC-2.2.1.3	Multifactor authentication (MFA) for all users.	Identity and Access Management Policy Template	Work on developing procedures for logins that contain multi-factor authentication. Work to activate multi-element verification next to the username and password, which may be, for example: One Time Password in a text message sent to the registered user's mobile number. One Time Password is displayed in a random number generator (HardToken) program or device for multi-factor identity	A guide explaining the implementation of multi-element identity verification requirements for all users on critical systems, including but not limited to: A screenshot showing adjusting the settings of

				verification. Identity verification using biometric features (e.g. fingerprint).	critical systems to ensure confirmation of the multielement - identity verification request.
	CSCC-2.2.1.4	Multi-Factor Authentication (MFA) for critical users; And the systems used to manage and monitor the critical systems mentioned in Control 4-1-3-2.	Identity and Access Management Policy Template Standards template for user devices with important and critical privileges	Determine the important and critical privileges of critical systems (System Administrative), which includes at the level of infrastructure and networks such as: (Network Administrative) and applications such as: (Application Administrative) and databases such as: (Database Administrative) in the entity. Identify Personnel with Privileged Access. Work on developing procedures for managing Privileged Access authorities approved in the entity, taking into consideration the following:	An inventory of the accounts of employees who have important and critical privileges. A guide explaining the implementation of multi-factor authentication requirements for logins, including but not limited to: A screenshot showing critical system settings to ensure certainty of the

				Multi-factor authentication for all users of critical systems with important and critical privileges. Privileged accounts must not be used for day-to-day operations. Privileged accounts must not be used for internet access Privileged accounts must not be used for email access. Preventing the use of Privileged accounts for remote logins, and granting the authority to use after obtaining approval with a practical justification. Default accounts must be disabled. Workstation protection system must be installed and updated on the workstation that will be used to access privileged accounts Secure versions of operating systems used in the organization must be built and prepared in a secure manner. Protection programs must be installed and unused services must be	multi-factor identity verification request for users with important, critical permissions. Requests to grant important and critical privileges and approvals. Audit reports on important and critical account activities.
--	--	--	--	--	---

				disabled. These copies must be used to configure desktops and servers Work to identify modern and advanced technologies and mechanisms for managing important and critical privileges. Ensure that important and critical privileges are granted based on job tasks after obtaining the necessary approvals, taking into account the principle of separation of duties. Work on recording logins on accounts with important and critical privileges for follow-up and monitoring.	
	CSCC-2.2.1.5	Prepare password standard controls taking into consideration best practices and implementation.	Identity and Access Management Policy Template Standards template for managing login identities and permissions, which	Ensure all employees have a unique identifier, which may be a job number, employee name, or other naming mechanisms to ensure that usernames are unique. Prepare password standard controls taking into consideration best practices,	Configure configuration include secure password standards for critical systems. Using safe methods and algorithms to

			includes password management.	including e.g.: The expiration period of the password is at least 30 days for important and critical and critical privileges, and at least 90 days for the remaining privileges. The password validity period (Expiration Period) is at least 30 days for important and critical and critical, and the rest of the permissions are at least 90 days password complexity password lockout password activation password history The number of attempts allowed is 3 The passwords used during the last 12 times should not be repeated Passwords should not be used based on the personal data of the user with permissions and privileges, such as date of birth. The password must be complex and contain at least 4 characters from the following: Upper case letters Lower case	store and process passwords, e.g. using hashing functions.
--	--	--	---	---	--

				letters Numbers (١٢٣٤) Special characters(@*%#)	
	CSCC-2.2.1.6	Using safe methods and algorithms to store and process passwords, e.g. using hashing functions.	Identity and Access Management Policy Template	Working on providing security systems and solutions for saving and processing passwords and ensuring that encryption requirements are met based on national encryption standards, for example: Working on the use of accepted shorthand functions based on national encryption standards, for example: SHA-256. Ensure that the hashing functions are Resistant Inversion, Collision Resistant, and Pre-Resistant image.	Document the procedures for storing and handling passwords for critical systems.
	CSCC-2.2.1.7	Secure management of Service Accounts between applications and systems; And disable interactive human login through it.	Identity and Access Management Policy Template	Work on developing clear procedures for dealing with service accounts and ensuring that they are managed securely between applications and systems, and disabling interactive human login through them, for example: disable all service accounts	Document the procedures for secure management of service accounts. A list of service accounts and their owners,

				and activate only the necessary ones. identify the service accounts needed by the business and to be used by the entity with the concerned departments. Assigning an owner to each service account to ensure that it is managed securely.	showing their status (activated or disabled). Restrictions applicable to access to these accounts. Requests to obtain access to service accounts.
	CSCC-2.2.1.8	With the exception of Database Administrators, access or direct interaction of any user with databases is prohibited. This is done through applications only, and based on the powers conferred on them; Taking into account the implementation of	Database Security Policy Template Database Security Standard Template Identity and Access Management Policy Template	Work on developing procedures for dealing with databases, for example: Do not grant direct access or interaction privileges except to database administrators. Work to identify the users and supervisors who are required to access or interact with the databases and grant them permissions due to the need to work with the concerned department. Work to develop procedures to ensure that the authorized person has access to databases through	Procedure document for safe handling of databases for critical systems. List of databases containing classified data and the classification of data stored on them. Mechanism for approving access requests to databases.

		security solutions that limit or prevent database administrators from accessing Classified Data.		protected and updated devices that contain all the required security solutions. Work to grant privileges based on need only and give privileges to implement specific work requirements only. Work to determine access or interaction permissions to be through applications only, with the exception of database administrators. Working to provide security technologies and solutions to prevent access to classified data, such as blocking data completely or partially (Data Masking).	Requests to obtain access to databases through database administrators. Restrictions applied to access classified data.
CSCC-2.2.2		Going back to Control 2-2-3-5 in Basic Controls for Cyber Security, access identities on critical systems should be reviewed, at least	Identity and Access Management Policy Template	Work to review the entry identities and privileges of the critical systems in the entity by conducting a periodic evaluation (according to a documented and approved plan for the review, and based on a specified period of time at least every three months).	The results of reviewing the entry identities and privileges of the critical systems in the entity. A document specifying the

		once, every three months.		Work to review all entry identities and permissions in all respects, for example: The principle of minimum permissions and privileges The principle of separation of duties and the principle of the need for knowledge and use in cooperation with the relevant departments (such as the department concerned with information technology). Granted validity period. The status of the person authorized with the granted permissions, for example: if they are still in the administration or have been transferred to another team, or has resigned from the organization. Document all reviews and changes made to the entry identities and privileges of critical systems in the entity, for example: Periodic reviews of the privileges and permissions	cycle of reviewing the access identities and privileges of the critical systems in the entity (evaluation table).
--	--	----------------------------------	--	--	--

				granted. Changes made from the last revision. Changes or modifications required to be changed to the privileges and permissions granted.	
NCA OSMACC					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines:	Expected deliverables
2-2-1 In addition to the subcontrols within control 2-2-3 in the ECC, cybersecurity requirements for identity and access management related to organization's social media accounts	2.2.1.1	Using social media accounts designated for organizations, not individuals.	Template for Identity and Access Management Policy	Identify organization's social media accounts across all social media platforms, excluding accounts belonging to individuals with official titles (e.g., Excellencies and Honors). Ensuring the secure usage and management of these accounts.	Sample of social media accounts used in the organization to verify that it is designated only for organizations and not individuals. And it should be noted that individuals referred to within the organization may either be responsible for managing the organizations social media accounts or may be regular users for these accounts, such as employees, clients, and affiliates of the organization. In both cases, they are required to adhere to the organization's policy, regarding the use of social media accounts.

must include at least the following:					
	2.2.1.2	Registering using official information (official specific social media email and official mobile number), and do not use personal information.	Template for Identity and Access Management Policy	Verify that the social media accounts of the organization are registered only using official email and official mobile number that are designated only for social media accounts. Further, confirm that personal information of any personnel is not used to create organization's social media account.	Sample of the official information used for registration of social media account.
	2.2.1.3	Verifying organization's social media accounts whenever possible and maintaining a consistent identity across all organization's social media accounts used; to facilitate knowledge of official accounts, and to discover fraud or unofficial accounts.	Template for Identity and Access Management Policy	Verify that the social media accounts of the organization are verified/authorized by the social media platform. Further, verify that the social media accounts have consistent identity across all organization's social media accounts used.	Sample of organization's social media accounts that have been verified/authorized by the social media platform.
	2-2-1-4	Using a secure and specific password for each organization's social media account, changing the password regularly,	Template for Identity and Access Management Policy Template for Identity and Access Management Standards, encompassing password management	Verify that each social media account is registered using a secure password that is different than the passwords used for the other social media accounts. Further, verify and implement the periodic change of social media accounts passwords regularly and without using previously used passwords.	Documented social media accounts controls specifying cybersecurity requirements for password management of social media accounts. Periodic

		and not to repeat use of passwords.			reports that details changes in the passwords of social media accounts.
	2.2.1.5	Using multi-factor authentication for organization's social media accounts logins.	Template for Identity and Access Management Policy	Verify that the organizations' social media accounts are using multi-factor authentication for logging in to the accounts. This must be done using the credentials and devices of the organization for added security.	Sample of using multi-factor authentication while logging in to the social media accounts.
	2.2.1.6	Activating and updating security questions and documenting them in a safe place.	Template for Identity and Access Management Policy	Verify that the organizations' social media accounts are using security questions for security purposes. Further, review and verify that the security questions are updated periodically and documented securely with restricted access to only the authorized personnel.	Documented social media accounts controls requiring the setup and update of security questions for the organizations' social media accounts. Documented security questions in a secured and restricted file with access only to authorized personnel.
	2.2.1.7	Managing organization's social media accounts access rights based on business need, considering the sensitivity of the accounts, the level of access rights and the type of devices and systems used.	Template for Identity and Access Management Policy	Verify that the access rights to organizations' social media accounts are based on the business needs of the organization, the sensitivity of accounts, and the type of devices and systems used.	Documented social media accounts controls restricting the access rights of social media accounts based on the business needs within the organization considering the sensitivity of the accounts, the level of access rights, and the type of devices and systems used. Documented procedure of granting access to social media accounts

					(provisioning workflow). Sample of approved and implemented access right requests.
	2.2.1.8	Restricting access rights of service providers of social media management, social media monitoring or brand protection.	Template for Identity and Access Management Policy	Identify, document, and verify the access rights of social media account management service providers, monitoring social media platforms, or safeguarding the organization's identity from fraud.	Documented social media controls restricting the access rights of social media accounts to the service providers. Sample of access rights granted to service providers.
	2-2-1-9	Restricting access to organization's social media accounts to specific devices.	Template for Identity and Access Management Policy	The entity's procedures for restricting access to social media accounts to specific devices must be documented.	Documented social media accounts controls restricting access to organization's social media accounts to specific devices.
2-2-2		With reference to ECC sub-control 2-2-3-5, user identities and access rights used for organization's social media accounts must be reviewed at least once every year.	Template for Identity and Access Management Policy	Inventory and document the user identities and access rights used for organization's social media accounts. Maintain and periodically review all the user identities and access rights at least every year or less.	Review report of user identities and access rights of organization's social media accounts.
NCA TCC					
2-2-1 In addition to the sub-controls within control 2-2-3 in the ECC,	2-2-1-1	Managing telework access rights based on need, considering the sensitivity of the systems, the level of access rights and the type of devices used	Identity and access management policy	Work on defining the requirements for this control, document them in the cybersecurity requirements document, and have them approved by the authority holder. Develop telework access management procedures by the organization,	A document that identifies and documents the requirements of this control (such as a policy and/or procedure

cybersecurity requirements for identity and access management related to telework systems shall include at least the following:		by employees for telework.		taking into account the following: System sensitivity. Level of access. Type of devices used by employees to work remotely. Validity period. Implement the required technological controls to provide and manage identities and access rights of telework assets.	approved by the authority holder). A list of all permissions and accesses used for telework. Requests for granting permissions and access to users to enable telework, along with the necessary approvals. Audit reports on the activities of authorized accounts.
	2-2-1-2	Restricting remote access for the same user from multiple computers at the same time (Concurrent Logins).	Identity and access management policy	Work on defining the requirements for this control, document them in the cybersecurity requirements document, and have them approved by the authority holder. Implement secure session management by setting a maximum number of session allowed by one user. When there is a need for an exception to this	A document that identifies and documents the requirements of this control (such as a policy and/or procedure approved by the authority holder). A screenshot of the remote access

				requirement, procedures are determined to obtain the necessary approval from the relevant department and the department concerned with cybersecurity.	restriction for the same user from multiple computers at the same time, including the maximum number of sessions the user is allowed. Procedures adopted for exceptions to this requirement. A formal approval for any exception.
	2-2-1-3	Using secure standards to manage identities and passwords used in the telework systems.	Identity and access management policy Identity and access management standards	Work on defining the requirements for this control, document them in the cybersecurity requirements document, and have them approved by the authority holder. Develop password standard taking into consideration best practices, including but not limited to:	A document that identifies and documents the requirements of this control (such as a policy and/or procedure approved by the authority holder). Proof of

				The minimum number of password symbols for important and sensitive privileges is 10 and for the rest of the privileges is 8. Password expiration period is at least 30 days for important and high privileged permissions, and at least 90 days for the remaining permissions. Password complexity. Password and account Lockout. Password activation. Password history log. Number of attempts allowed is 3. Passwords used during the last 12 times must not be repeated. Passwords should not be used based on the personal data of the user with privileges, such as date of birth. The password must be complex and include at least 4 of the following characters: Upper case letters Lower case letters Numbers (1234) Special symbols (#%)	using secure standards to manage identities and passwords used in the telework systems for example but not limited, a screenshot of password configuration policy and screenshot of MFA implementation.
--	--	--	--	---	--

				Activate two-factor authentication for telework systems in addition to the user name and password, which may be, for example: One Time Password in a text message sent to the mobile number registered to the end user. One Time Password is displayed in a hard token program or device for multi factor authentication. Use biometrics to verify identities (example: fingerprint). Use Virtual Private Network (VPN) to encrypt traffic between user and systems.	
2-2-2		With reference to the ECC sub-control 2-2-3-5, user's identities and access rights used for teleworking must be reviewed at least once every year.	Identity and access management policy	Work on defining the requirements for this control, document them in the cybersecurity requirements document, and have them approved by the authority holder. Review the login identities and access permissions used for telework by conducting a periodic	The results of reviewing the login identities and access permissions used for telework. A document specifying the cycle of

				evaluation (according to a documented and approved review plan, and based on a specific time period of at least once a year). Review all login identities and access permissions used for telework in all aspects, including but not limited to: The principle of minimum permissions and privileges The principle of separation of duties and the principle of need-to-know. The granted validity period. The status of the person who has been granted permissions, for example: if he is still working in the entity or has been transferred to another sector, or has left work. Document all reviews and changes made to login identities and access permissions used for telework, including but not limited to: Periodic reviews of the privileges and access permissions granted. Changes	reviewing the login identities and access permissions used for telework (evaluation table).
--	--	--	--	--	--

				that have been made from the last review. Changes or modifications required to be made to the privileges and access permissions granted.	
NCA OTCC					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
2-2-1 In addition to subcontrols in ECC control 2-2-3, cybersecurity requirements for identity and access management in OT/ICS environment must include, at a minimum,	2.2.1.1	Identity and access management lifecycle for OT/ICS is separated and independent from Information Technology (IT) including centrally managed identity and access management solutions.	Template for Cybersecurity Operational Technology Policy Template for OT/ICS Security Standard Template for Identity and Access Management Policy Template for Identity and Access Management Standard	Develop an identity and access management process, which include its lifecycle (creating new user, renewing existing user, and removing existing user) for OT/ICS. Verify and ensure that developed OT/ICS identity and access management lifecycle is separated and independent from the Information Technology (IT).	Documented identity and access management lifecycle process for OT/ICS. A site visit to check the (Active Directory Domain) for OT/ICS separation and independence from Information Technology (IT) (Active Directory Domain).

the following:					
	2.2.1.2	Service accounts must be managed securely for OT/ICS services, applications, systems, and devices that are separated and disconnected from interactive users account logins.	Template for Cybersecurity Operational Technology Policy Template for OT/ICS Security Standard Template for Identity and Access Management Policy Template for Identity and Access Management Standard	Define a service account management procedure in coordination with the vendor for OT/ICS services, applications, systems, and devices that are separated and disconnected from interactive users account logins, where they are managed securely. Ensure that all listed accounts are managed in line with defined procedure.	A service accounts for OT/ICS systems list. A service account management procedure. Site visit to check all service accounts that they are managed in line with defined cybersecurity requirements and procedure.
OTCC-2.2.1	OTCC-2.2.1.3	Default credentials for all OT/ICS assets must be changed, disabled, or removed.	Template for Cybersecurity Operational Technology Policy Template for OT/ICS Security Standard Template for Identity and Access Management	Ensure the default credentials for all OT/ICS assets have been changed, disabled, or removed in coordination with the vendor.	A proof from the vendor showing that all OT/ICS default credentials have been changed, disabled, or removed. Site visit to check the OT/ICS accounts

			Policy Template for Identity and Access Management Standard		and ensure the default credentials disabled, change, or removed
OTCC-2.2.1	OTCC-2.2.1.4	Sessions must be managed securely, including session authenticity, session lockout, and session timeout termination.	Template for Cybersecurity Operational Technology Policy Template for OT/ICS Security Standard Template for Identity and Access Management Policy Template for Identity and Access Management Standard	Define sessions management procedures in coordination with vendor to manage the sessions securely. This includes session authenticity, session lockout, and session timeout termination for windows servers and windows desktop. Ensure the implementation of the defined procedures for sessions management. This includes session authenticity, session lockout, and session timeout termination for windows servers and windows desktop.	A documented sessions management procedures. Site visit to check the sessions policy including session authenticity, session lockout, and session timeout termination for windows servers and windows desktop.
OTCC-2.2.1	OTCC-2.2.1.5	Automatic disabling/removing of service accounts, programs, or	Template for Cybersecurity Operational Technology Policy Template for	Ensure that accounts related to engineers and operators don't have the ability to uninstall programs. Define a specific user account for each	Site visit to check the privileges of both engineers and operators. Site visit to

		accounts related to (OT/ICS) assets must be prevented, except for monitoring systems.	OT/ICS Security Standard Template for Identity and Access Management Policy Template for Identity and Access Management Standard	individual (System Admin or Engineers). For example: (The individual must have a specific user name and password when he/she wants to use the engineering workstation). This includes setting the correct privileges for each user.	ensure the administrator accounts are created for individuals.
OTCC-2.2.1	OTCC-2.2.1.6	Dual approval and explicit privilege escalation mechanisms for sensitive actions within the OT/ICS environment must be employed.	Template for Cybersecurity Operational Technology Policy Template for OT/ICS Security Standard Template for Identity and Access Management Policy Template for Identity and Access Management Standard	Define and formally document sensitive procedures within the OT/ICS environment. Implement dual approval and explicit privilege escalation mechanisms for documented actions.	A documented sensitive procedure within the OT/ICS environment. A proof that dual approval and explicit privilege escalation mechanisms for sensitive actions within the OT/ICS environment are used/employed.
OTCC-2.2.1	OTCC-2.2.1.7	Remote access to the OT/ICS networks must be	Template for Cybersecurity Operational	Define, document and approve cybersecurity requirements and rules regarding the remote	A documented cybersecurity requirements

		restricted and exceptionally enabled when necessary and justified. A cybersecurity risk assessment must be conducted prior to granting a remote access and its associated risks are monitored and managed. The granted access must be through trusted multi-factor authenticated and encrypted channel for a defined period of time and with limited access privilege. The remote access session must be monitored and recorded while its	Technology Policy Template for OT/ICS Security Standard Template for Identity and Access Management Policy Template for Identity and Access Management Standard	access to the OT/ICS networks. Prepare the risk assessment and risk monitoring procedure for remote access to the OT/ICS networks. Implement the solution with trusted multi-factor authenticated and encrypted channel for OT/ICS remote access (e.g. secure remote access tool). Monitor and record remote access sessions while its time duration and granted user's privilege must be in accordance with the cybersecurity risk assessment.	and rules regarding the remote access to the OT/ICS networks. Risk assessment procedure Risk assessment reports. A proof that the OT/ICS remote access solution with trusted multi-factor authenticated and encrypted channel is implemented. Monitoring and recording reports regarding the remote sessions.
--	--	---	--	--	--

		time duration and granted user's privilege must be in accordance with the cybersecurity risk assessment.			
OTCC-2.2.1	OTCC-2.2.1.8	Secure and complex password standards must be implemented.	Template for Cybersecurity Operational Technology Policy Template for OT/ICS Security Standard Template for Identity and Access Management Policy Template for Identity and Access Management Standards, encompassing password management	Define, document and approve secure and complex password standards. Implement approved password standards on OT/ICS.	Document on password management standard Site visit to ensure that the passwords standards are implemented within local or group policy.
OTCC-2.2.1	OTCC-2.2.1.9	Secure mechanisms to store OT/ICS	Template for Cybersecurity Operational Technology Policy	Define and document OT/ICS assets' passwords storing procedure. Implement the secure mechanisms to store	Documented OT/ICS assets' passwords storing

		assets' passwords must be used.	Template for OT/ICS Security Standard Template for Identity and Access Management Policy Template for Identity and Access Management Standard	OT/ICS assets passwords (e.g. secure password manager). Verify and ensure that all OT/ICS assets' passwords are stored in line with documented procedures and by secure mechanisms. Ensure emergency account are stored in line with documented procedures and by secure mechanisms.	procedures. Site visit to check the OT/ICS assets' passwords and emergency account are stored in line with approved procedures by secure mechanisms.
OTCC-2.2.1	OTCC-2.2.1.1 0	With reference to the ECC subcontrol 2-2-3-5, users' identities and access rights must be reviewed in response to cybersecurity incidents, personnel roles changes, or whenever there is a change in OT/ICS system architecture.	Template for Cybersecurity Operational Technology Policy Template for OT/ICS Security Standard Template for Identity and Access Management Policy Template for Identity and Access Management Standard	Develop an approved procedure document and an action plan for periodic review of users' identities and access rights in case of cybersecurity incidents, personnel roles changes, or whenever there is a change in OT/ICS system architecture. Verify and ensure the implementation of the periodic review plan for user identities and access rights, especially when responding to cybersecurity incidents, personnel role changes, or any	Procedures and action plan for periodic review of users identities and access rights. Proof that showcase the implementation of the periodic review plan for user identities and access rights, especially when responding to

				changes in the architecture structure of OT/ICS.	cybersecurity incidents, personnel role changes, or any changes in the architecture structure of OT/ICS.
OTCC-2.2.1	OTCC-2.2.1.1	Access shall be immediately revoked when no longer needed.	Template for Cybersecurity Operational Technology Policy Template for OT/ICS Security Standard Template for Identity and Access Management Policy Template for Identity and Access Management Standard	Develop an action plan for revoking access immediately when it is no longer needed, including but not limited to: Unused accesses. Conflict of interest. Unconfirmed need. Access expiry. Verify and ensure the implementation of the action plan for revoking access immediately when it is no longer needed.	Documented action plan for revoking access immediately when it is no longer needed. Proof that showcase the implementation of the action plan for revoking access immediately when it is no longer needed.
2-2-2		With reference to the ECC control 2-2-4, the implementation of	Template for Cybersecurity Operational Technology Policy	Review the identity and access management requirements periodically based on a documented and approved	The results of reviewing the identity and access

		cybersecurity requirements for identity and access management in OT/ICS environment must be reviewed periodically.	Template for OT/ICS Security Standard Template for Identity and Access Management Policy	review plan and on a defined frequency (e.g., conduct a review annually). Review and update the requirements periodically or as a result of regulatory changes. Document and approve the reviews and changes.	management requirements. A document specifying the cycle of reviewing the identity and access management requirements (evaluation table).
NCA CCC					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
CSP 2-2-P-1 In addition to sub controls in the ECC control 2-2-3, the CSP shall cover the following additional sub controls for cybersecurity requirements for identity					

and access management requirements, as a minimum:					
	CSP-2.2-P-1-1	Identity and access management of generic accounts credentials for accountability cannot be assigned for a specific individual.	•Template for Identity and Access Management Standards, encompassing password management •Template for Identity and Access Management Policy •Template for Standards on Devices with Sensitive Privileges	Identify both privileged and non-privileged generic accounts (e.g.: service accounts, technical accounts, non-personal accounts).Implementing technical restrictions on user accounts based on assigned permissions (e.g.: regularly update credential information, establishing a policy for acceptable account usage, specifying authorized access, usage scenarios, and permissible procedures)	Document outlining the list of users of generic accounts (service accounts, technical accounts, etc.).Technical restrictions applied to the use and management of generic accounts.
	CSP-2.2-P-1-2	Secure session management, including session authenticity, session lockout, and session timeout termination.	Template for Identity and Access Management Standards, encompassing password management •Template for Identity and Access Management Policy Template for Standards on Devices with Sensitive Privileges	Tunnel sessions through authenticated proxies with capability to lockout sessions and terminate due to inactivity (e.g.: use of cloud native bastion services, when applicable)Configure session management system for session lockouts and session timeouts (e.g.: the session lockout after 15 minutes and timeout after 10 minutes of inactivity)	Evidence demonstrating configurations applied to sessions, including authenticity, lockout, and timeout.
	CSP-2.2-P-1-3	Multi-factor authentication for privileged users, and candidates of personnel with access to Cloud Technology Stack.	Template for Identity and Access Management Standards, encompassing password management Template for Identity and Access Management Policy Template for Standards on Devices with Sensitive Privileges	Define privileged roles and identities that have access to Cloud Technology Stack (e.g. Engineers, Operators, Administrators)Build a mandatory multi-factor authentication (e.g. using software tokens, SMS messages) policy and assign it to privileged users or groups of users.	List of privileged accounts with access to Cloud Technology Systems (CTS).
	CSP-2.2-P-1-4	Multi-factor authentication technologies for	Template for Identity and Access Management Standards, encompassing password	Define and implement an Identity and Access Management (IAM) process that includes the purpose, and governance of how a CSP must address unauthorized	Authentication and monitoring of Accesses.The number of allowed access

		access to privileged accounts that have access to cloud technology systems (CTS). to detect and prevent unauthorized access (e.g. unsuccessful login attempt threshold).	managementTemplate for Identity and Access Management PolicyTemplate for Standards on Devices with Sensitive Privileges	access threat for their respective defined scope.The process description contains as minimum: oAccepted user authentication methods with configuration (e.g. password complexity policy, MFA usage). oConditional access requiring certain criteria to be met before granting access. oUser authentication monitoring for anomalies and suspicious behaviour (e.g. many unsuccessful logins in a row, impossible travel). oEnable self-service password to reset and password management oConfigure e-mail/mobile notifications for cloud account authentications to make sure the account owner is notified about account authentications	attempts is limited and the account is temporarily closed if the limit is exceeded.Sample of system configuration and monitoring report.Access attempt alerts.
	CSP-2.2-P-1-5	Utilizing secure methods and algorithms for saving and processing passwords, such as: Secure Hashing functions.	Template for Identity and Access Management Standards, encompassing password management Template for Identity and Access Management PolicyTemplate for Standards on Devices with Sensitive Privileges	Store passwords (both locally and centrally)in an irreversible form () e.g. using secure hashing functions).Use approved cryptography hash functions.Review these functions periodically to prevent compromised or insufficient functions.Use cryptographic salt to create unique password hashes even if users choose the same passwords. •Utilizing the mentioned algorithms and functions in national encryption standards(advanced level)	Evidence that demonstrates a sample of stored passwords.Document outlining the applied standard to the storage of passwords.
	CSP-2.2-P-1-6	Secure management of third-party personnel's accounts.	Template for Identity and Access Management Standards, encompassing password management Template for Identity and Access Management PolicyTemplate for Standards on Devices with Sensitive Privileges	Define and implement Identity and Access Management (IAM) restrictions for accounts of third parties such as service providers, contractors, etc.Define and implement procedures for managing third party accounts, including creating, monitoring and revocation, and obtaining the necessary approvals for each phase.Enable event logs for third-party accounts and monitor their related	Restrictions implemented to third party accounts based on approved standards.Procedures adopted for managing third party accounts during their life cycle.A sample of third party account requests

				activities. Use clear label for third party accounts. Use Federated Identities and Authentication services and identities (e.g.: ADFS, SAML2, oAuth2) for third parties' accounts. • Periodic review of accounts and privileges according to a defined review plan.	showing obtaining the necessary approvals. Sample of third-party account activity monitoring logs. Defined labels or third party accounts. Implemented Federated Identities and Authentication. Third party's accounts and privileges review plan and reports.
	CSP-2.2-P-1-7	Access control enforced to management systems, and administrative consoles.	Template for Identity and Access Management Standards, encompassing password management Template for Identity and Access Management Policy Template for Standards on Devices with Sensitive Privileges	Identify and inventory management systems and administrative consoles, and review them periodically. Obtain the necessary approvals before assigning any access to the administrative and management systems. Review access privileges to management systems and administrative consoles periodically. Use Privilege Access Management (PAM) technology to control access to administrative and management systems and encrypt communication through the network. Enable Multi-Factor Authentication (MFA) for access to management systems and administrative consoles. Activate and monitor event logs on activities related to accessing management systems and administrative consoles, and record access sessions.	List of management systems and administrative consoles. A sample of requests for access to management systems and administrative consoles. A plan to review the access privileges to management systems and administrative consoles and review reports. Evidence of using Privilege Access Management (PAM) technology to access management systems and administrative consoles. Evidence of encryption of access communications through the network for management systems

					and administrative consoles and a list of activated encryption algorithms. •Evidence of Multi-Factor Authentication (MFA) implementation.A sample of event monitoring and related alerts from Security Information and Event Management (SIEM).A sample of recording of sessions.
	CSP-2.2-P-1-8	Masking of displayed authentication inputs, especially passwords, to prevent shoulder surfing.	Template for Identity and Access Management Standards, encompassing password management Template for Identity and Access Management Policy Template for Standards on Devices with Sensitive Privileges	Activate data masking features for sensitive data (e.g. passwords, mobile numbers, and email addresses) when displayed during password recovery/change requests.	Evidence that demonstrates the implementation of obfuscation and masking of sensitive and personal information.
	CSP-2.2-P-1-9	Getting CST's approval before accessing any CST-related asset by the CSP or CSP's third parties.	Template for Identity and Access Management Standards, encompassing password management Template for Identity and Access Management Policy Template for Standards on Devices with Sensitive Privileges	Make CST's approval a prerequisite before allowing any access to its associated assets or data by the CSP, provided that obtaining consent must be through approved channels between the CST and the CSP.	The approved access request procedures to access the CST's assets or data approved by the CSP.A sample of approval requests.
	CSP-2.2-P-1-10	Capability to immediately interrupt a remote access session and	Template for Identity and Access Management Standards, encompassing password management. Template for Identity and	Tunnel remote sessions through an authenticated proxy. Configure proxy to terminate immediately the session under defined conditions (e.g.: policy violation).Configure a proxy to stop	Establish controlled remote access sessions. Sample of system/proxy configurations.

		prevent any future access for a user.	Access Management PolicyTemplate for Standards on Devices with Sensitive Privileges	accepting connections from specific sources or users.	
	CSP-2.2-P-1-11	Provision to CSTs of Multi-factor authentication services for privileged cloud users.	Template for Identity and Access Management Standards, encompassing password management. Template for Identity and Access Management PolicyTemplate for Standards on Devices with Sensitive Privileges. Template for Standards on Network Detection and Response (NDR)	Identify privileged cloud service user roles and groups, and enable the functionality of MFA for these users.	Evidence demonstrating that cloud services are authenticated using MFA.
	CSP-2.2-P-1-12	Assurance of restricted and controlled access to storage systems and means (such as Storage Area Network (SAN)).	Template for Identity and Access Management Standards, encompassing password managementTemplate for Identity and Access Management PolicyTemplate for Standards on Devices with Sensitive PrivilegesTemplate for Standards on Network Detection and Response (NDR)	Define and implement a process to restrict and control access to storage systems and means (such as Storage Area Network (SAN)).The process description contains as a minimum: ○Restrict physical and virtual access to storage systems and means. ○Use encryption to protect data at rest and in transit. ○Implement access control lists (ACLs) to restrict access to specific storage resources. ○Regularly review and audit access rights to storage systems and means.	Evidence of implementing the process to restrict and control access to storage systems and means.Sample of access control lists (ACLs) to restrict access to specific storage resources.
CST-2.2-T-1 In addition to sub controls in the ECC control 2-2-3, the CST shall	CST-2.2-T-1-1	Identity and access management for all cloud credentials along their full lifecycle.	Template for Identity and Access Management Standards, encompassing password	Analyse and adapt the Identity and Access model relevant to cloud services (e.g.: RBAC, roles, service principals, policies, resources, resource groups, accounts, accounts groups)Manage accesses	Cloud Identity Lifecycle process defined

cover the following additional sub controls for cybersecurity requirements for identity and access management requirements, as a minimum:			managementTemplate for Identity and Access Management Policy	granularlyMake use of Federated AuthenticationEnable strong/multifactor authentication	
	CST-2.2-T-1-2	Confidentiality of cloud user identification, cloud credential and cloud access rights information, including the requirement on users to keep them private (for employed, third party and CST personnel).	Template for Identity and Access Management Standards, encompassing password managementTemplate for Identity and Access Management Policy	Restrict Access to Identity Management and Access Management systems to the dedicated staff (e.g.: IAM Operations personnel)Make authentication technical methods encrypted (e.g.: TLS in place)	Login screens only via encrypted channels (e.g. TLS)
	CST-2.2-T-1-3	Secure session management, including session authenticity, session lockout, and session timeout termination.	Template for Identity and Access Management Standards, encompassing password managementTemplate for Identity and Access	Tunnel sessions through authenticated proxies with capability to lockout sessions and terminate due to inactivity (e.g.: use of cloud native bastion services, when applicable)Configure session management system for session lockouts and session timeouts (e.g.:	Session management system with session lockouts and session timeouts configured.

			Management PolicyTemplate for Configuration and Hardening PolicyTemplate for Secure Configuration and Hardening Standard	the session logout after 5 minutes and timeout after 10 minutes of inactivity)	
	CST-2.2-T-1-4	Multi-factor authentication for privileged cloud users.	Template for Identity and Access Management Standards, encompassing password management Template for Identity and Access Management Policy	Define privileged cloud entitlements (e.g.: modifications in functions: Key Management, Identity and Access Management, Service Management/Administration)Define privileged roles and identities that use these privileged entitlements (e.g. Role of IAM Engineer for Artificial Intelligence Cloud Solutions)Build a mandatory multi-factor authentication (e.g. using software/mobile authenticator) policy and assign it to privileged users or groups of users.	Multi-factor authentication policy assigned to privileged users or groups of users.List of privileged cloud users.
	CST-2.2-T-1-5	Formal process to detect and prevent unauthorized access to cloud (such as a threshold of unsuccessful login attempts).	Template for Identity and Access Management Standards, encompassing password managementTemplate for Identity and Access Management Policy	Enable self-service password to reset and password managementConfigure e-mail/mobile notifications for cloud account authentications to make sure the account owner is notified about account authenticationsPrevent using the same account from various locations	Impossible travel scenarios detected and prevented

				(e.g. impossible travel).Setting up alerts and notifications for unsuccessful login attempts and monitoring them as part of event monitoring activities.Restricting user access after exceeding the maximum number of unsuccessful login attempts.	
DCC-2.2.1 In addition to the subcontrols in ECC control 2-3-3, cybersecurity requirements for Information System and Processing Facilities Protection must include at least the following:	DCC-2.2.1.1	Applying security patches and updates from the time of announcement on systems used to handle data as specified for each data classification level.	Template for Patch and Update Management PolicyTemplate for Patch and Update Management Standard	Identify the requirements of this control and document them in a cybersecurity requirements document, followed by approval from the authorizing officials. Identify the systems and services handling data across all classification. Review the patching guidance with respect to the systems and services utilized and document the patching procedures to be followed in line with the guidance. Periodic security patching and updates should be conducted at least every month or earlier for systems and services handling Public or Confidential data and immediately for systems and services handling Secret or Top Secret data.	Document detailing the identification and documentation of the requirements of this control (e.g. a policy and/or procedure approved by the authorizing officials). Documented security patching procedures for systems and services handling data. Patching review report for periodic security patching.
	DCC-2.2.1.2	Reviewing the secure configuration and hardening of systems	Template for Patch and Update Management	Identify the requirements of this control and document them in a cybersecurity requirements	Document detailing the identification and documentation

		used to handle data as specified for each data classification level.	PolicyTemplate for Configuration and Hardening PolicyTemplate for Configuration and Hardening Standard	document, followed by approval from the authorizing officials. Identify the systems handling data across all classification. Review the security configuration guidance with respect to the systems utilized and document the hardening procedures to be followed in line with the guidance. Periodic security configuration and hardening should be conducted at least annually or earlier for systems handling Public or Confidential data and at least every 6 months or earlier for systems and services handling Secret or Top Secret data.	of the requirements of this control (e.g. a policy and/or procedure approved by the authorizing officials). Approved standard for reviewing security configuration and hardening for data processing systems (e.g., approved hard copy or electronic version). Reports indicating that security configuration and hardening for systems used for data handling are reviewed according to the timeframe for each level.
	DCC-2.2.1.3	Reviewing and hardening the default configuration (e.g., default passwords and backgrounds) of the technology assets	Template for Patch and Update Management Policy	Identify the requirements of this control and document them in a cybersecurity requirements document, followed by approval from the authorizing officials. Identify the technology assets and systems handling data across all	Document detailing the identification and documentation of the requirements of this control (e.g. a policy and/or procedure

		used to handle the data.		classification. Review the default configurations which includes, but not limited to, default passwords, guests accounts, service accounts, backgrounds, default administrators, legacy protocols, open ports in the system. Verify and ensure that the security configurations should not be set as default for the technology assets.	approved by the authorizing officials). Default configuration review report for technology assets.
	DCC-2.2.1.4	Disabling the Print Screen or Screen Capture features on the devices that create or process documents.		Identify the requirements of this control and document them in a cybersecurity requirements document, followed by approval from the authorizing officials. Identify the devices that process Secret and Top Secret data of the organization. Review and verify the Print Screen or Screen Capture features on the devices and ensure that they are disabled in the system.	Document detailing the identification and documentation of the requirements of this control (e.g. a policy and/or procedure approved by the authorizing officials). Review report that verifies that devices' print screen feature is disabled on devices that handles Secret and Top secret documents. Sample of the system security configurations.
SAMA CSF					

Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
SAMA IAM 1	N/A	The identity and access management policy, including the responsibilities and accountabilities, should be defined, approved, and implemented.	Identity and Access Management Policy Template	Define and approve an IAM policy that outlines responsibilities and accountabilities. Ensure the policy is reviewed and signed off by relevant stakeholders. Implement the policy within all systems and processes.	A formally approved IAM policy document. Evidence of policy implementation.
SAMA IAM 2	N/A	The compliance with the identity and access policy should be monitored.	Access Compliance Monitoring Tools	Implement tools and processes to monitor adherence to the IAM policy. Conduct regular compliance reviews and audits to identify any deviations or gaps.	Compliance monitoring reports. Audit findings and remediation plans.
SAMA IAM 3	N/A	The effectiveness of the cybersecurity controls within the identity and access management policy should be measured and periodically evaluated.	IAM Control Assessment Tools	Conduct periodic evaluations of IAM controls. Use KPIs and metrics to assess the effectiveness of controls. Update policies and controls based on evaluation findings.	Periodic control effectiveness reports. Updated IAM controls and policies.
SAMA IAM 4	4-a	Business requirements for access control (i.e., need-to-have and need-to-know).	Access Control Management Tools	Define access control requirements based on business needs. Ensure access is granted based on the principles of least privilege and need-to-know.	Documented access control requirements. Evidence of compliance with access control principles.

	4-b	User access management for joiners, movers, and leavers.	User Access Management Tools (e.g., IAM software)	Develop processes for managing user access throughout their lifecycle (joiner, mover, leaver). Ensure changes in job status or position trigger timely access updates.	Documented processes for managing user access. Audit trails of access requests, approvals, and changes.
	4-b-1	All identified user types should be covered (i.e., internal staff, third parties).	User Provisioning Tools	Develop processes to manage access for internal staff and third parties. Ensure all user types are included in IAM policies.	Documented processes covering all user types. Evidence of access provisioning for internal staff and third parties.
	4-b-2	Changes of job status or job positions for internal staff should be instigated by the HR department.	HR System Integration	Integrate IAM processes with HR systems to automate access updates based on job status changes.	Evidence of HR-initiated access updates. Logs of job status changes and corresponding access modifications.
	4-b-3	Changes for external staff or third parties should be instigated by the appointed accountable party.	IAM System	Designate accountable parties for managing access changes for external staff. Ensure accountability is documented.	Records of accountable parties for external staff. Audit logs of access updates.
	4-b-4	User access requests should be formally approved in accordance with business and	Access Request Management Tools	Implement tools to capture and manage formal access requests. Ensure approvals are logged and accessible for audits.	Approved access request forms. Audit trails of submitted and approved requests.

		compliance requirements.			
	4-b-5	Changes in access rights should be processed in a timely manner.	Access Management System	Establish SLAs for processing access changes. Monitor and track access change requests to ensure timely completion.	SLA reports for access change processing. Logs of processed access changes.
	4-b-6	Periodically review user access rights and profiles.	User Access Review Tools	Schedule regular reviews of user access rights. Use automated tools to identify unnecessary or excessive permissions.	Access review reports. Logs of access updates following reviews.
	4-b-7	Establish an audit trail of submitted, approved, and processed user access requests and revocation requests.	Audit Log Management Tools	Maintain detailed logs of access requests and revocations. Ensure logs are regularly reviewed for anomalies.	Comprehensive audit trails of access management activities.
	4-c	User access management should be supported by automation.	Automated IAM Tools	Implement automation to manage user access processes efficiently. Integrate automation with other systems for seamless workflows.	Evidence of automation implementation. Logs demonstrating automated access management.
	4-d	Centralization of the identity and access management function.	Centralized IAM Tools	Consolidate IAM processes and tools into a single management platform. Ensure centralized oversight of access controls.	Centralized IAM system documentation. Reports demonstrating centralized management.

	4-e	Multi-factor authentication for sensitive and critical systems and profiles.	Multi-Factor Authentication Tools	Implement MFA for access to sensitive systems. Conduct risk assessments to determine MFA requirements for critical systems.	MFA implementation logs. Risk assessment reports.
	4-f	Privileged and remote access management, which should address: 1. the allocation and restricted use of privileged and remote access.	Privileged Access Management (PAM) Tools	Define and implement policies for allocating and restricting privileged and remote access. Ensure strict adherence to role-based access principles.	Privileged access policies. Evidence of restricted access implementation.
	4-f-1-a	Multi-factor authentication should be used for all remote access.	Multi-Factor Authentication Tools	Enforce MFA for all remote access connections. Conduct periodic reviews to ensure compliance.	Logs demonstrating MFA enforcement. Compliance review reports.
	4-f-1-b	Multi-factor authentication should be used for privilege access on critical systems based on a risk assessment.	Risk Assessment Tools	Conduct risk assessments to identify critical systems requiring MFA for privileged access. Implement MFA accordingly.	Risk assessment reports. Logs showing MFA implementation on critical systems.
	4-f-2	The periodic review of users with privileged and remote accounts.	Privileged Account Management Tools	Schedule and conduct periodic reviews of privileged and remote accounts to identify and address any unauthorized access.	Review reports of privileged and remote accounts. Updated account management logs.
	4-f-3	Individual accountability.	Identity and Access Monitoring Tools	Implement measures to ensure all privileged actions are tied to individual accounts. Prohibit shared credentials.	Logs showing individual accountability. Evidence of

					restricted shared account usage.
	4-f-4-a	The use of non-personal privileged accounts, including: Limitation and monitoring of non-personal privileged accounts.	Privileged Access Monitoring Tools	Monitor and restrict the use of non-personal privileged accounts. Define rules for usage and enforce strict controls.	Logs of non-personal account usage. Reports demonstrating adherence to defined rules.
	4-f-4-b	Confidentiality of passwords for non-personal privileged accounts.	Password Management Tools	Implement secure storage and access mechanisms for non-personal account passwords. Monitor password usage for confidentiality breaches.	Password storage logs. Evidence of confidentiality enforcement.
	4-f-4-c	Changing passwords frequently and at the end of each session.	Password Rotation Tools	Automate password rotation for non-personal privileged accounts. Enforce password changes at the end of each session.	Logs of automated password changes. Reports showing password change compliance.
CST CRF					
Control reference number	Control clauses		Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
4.7.1	Define and document [Requirements for Identity and Access Management] which		IAM Policy Templates	Develop IAM requirements covering all specified areas. Ensure formal	Approved IAM requirements document.

	consider the following: User accounts, privilege accounts, granting, and revoking access rights; Authentication and authorization requirements (e.g., in case of remote access, two-factor authentication); Password management requirements.		approval and dissemination across the organization.	Evidence of dissemination and implementation.
4.7.2	Define and implement a process to [Allocate/Revoke User Rights] considering: Assign access rights to users based on what they are authorized to use (e.g., Role-Based Access Control); Reallocate user access rights upon change of job functions (e.g., changing departments); Manage user authentication and authorization based on the access control principle (e.g., need-to-know, need-to-use, least privilege); Maintain an up-to-date [Access Control List]; Revoke access rights to information systems upon change of contractual agreements (e.g., termination of employment).	Access Control Systems	Establish clear processes for allocating and revoking access rights. Automate changes where possible and maintain an updated access control list.	Logs of user access changes. Evidence of adherence to access control principles.
4.7.3	Control and restrict the allocation and use of privilege access rights.	Privileged Access Management (PAM) Tools	Define and enforce restrictions on privileged access. Conduct periodic reviews to validate proper use of privileged accounts.	Privileged access logs. Review and audit findings.

4.7.4	Provide multi-factor authentication for access to sensitive and critical information systems as well as for remote access.	Multi-Factor Authentication (MFA) Tools	Deploy MFA for all sensitive systems and remote access points. Regularly update configurations based on security assessments.	MFA deployment logs. Audit reports verifying MFA enforcement.
4.7.5	Enforce the password management requirements (e.g., use of strong passwords for authentication, regular password changes, account suspension after failed login attempts). Ensure user authentication information is secured against disclosure (e.g., using encryption mechanisms during the transfer of authentication information).	Password Management Tools	Implement and monitor compliance with password policies. Use encryption mechanisms to protect authentication data.	Password management policy. Logs showing enforcement and compliance.
4.7.6	Regularly review user identity and access rights (review frequency based on account types, criticality, etc.) and ensure conformance to access control principles (e.g., asset owner should regularly review user access rights).	Identity and Access Review Tools	Schedule and conduct regular reviews of access rights. Address any deviations from access control principles.	Access review logs. Evidence of corrective actions taken.
4.7.7	Enhance and implement the [Requirements for Identity and Access Management] to use tools to automate and centralize the identity and access management.	Centralized IAM Systems	Deploy centralized IAM tools to streamline access management. Automate routine tasks for efficiency.	Centralized IAM system documentation. Evidence of automation deployment.

4.7.8	Use dedicated systems for tasks that require administrative access (e.g., configuration of critical systems).	Dedicated Administrative Computers	Deploy and maintain systems specifically for administrative tasks. Enforce strict access policies for these systems.	Logs of administrative tasks. Documentation of system configurations.	
4.7.9	Continuously measure, review and optimize the [Requirements for Identity and Access Management] as well as the effectiveness of the process.	Policy Management Tools	Conduct periodic evaluations of IAM processes. Use findings to optimize tools and policies.	IAM evaluation reports. Updated IAM policies and procedures.	
CMA Cybersecurity Guidelines					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
4.3.4.1		Set out, document, approve, implement and monitor access identity and privileges management policy.	IAM Policy Templates	Develop and formalize an IAM policy covering identity and privilege management. Ensure the policy is approved and regularly reviewed for effectiveness.	Approved IAM policy document. Evidence of policy implementation and monitoring.
4.3.4.2		Measure and periodically evaluate the effectiveness of cybersecurity controls within the access identity and privileges management policy.	Control Monitoring Tools	Establish periodic evaluation mechanisms to assess the performance of IAM controls. Use key metrics to refine and improve policies.	IAM evaluation reports. Evidence of periodic assessments and updates.
4.3.4.3 Access identity and privileges management	3.1	Access control according to work requirements (principles of Need-	Access Control Systems	Implement access control mechanisms adhering to business requirements and the principles of	Access control logs. Audit findings and corrective actions.

policy shall include the following:		to-Know, Need-to-Have, and Least Privilege).		least privilege. Regularly audit and adjust access rights.	
	3.2.1	Users Access Management: Covering all users (employees and third parties).	Access Management Platforms	Define clear processes for onboarding, offboarding, and user access changes. Automate user access processes wherever feasible. Ensure access management policies encompass all internal and external users. Verify compliance through regular reviews.	User access records. Automation logs. Comprehensive user access list. Review findings.
	3.2.2	Involving User ID verification.	User Identity Verification Tools	Deploy robust identity verification methods to ensure only authorized users access systems.	Verified user access logs. Evidence of identity verification processes.
	3.2.3	HR Department shall be responsible for conducting any change to employment status or position of employees.	HR Access Management Tools	Integrate HR processes with IAM to ensure timely updates to user access rights based on employment status changes.	Updated access logs reflecting employment status changes. Integration documentation.
	3.2.4	Cybersecurity Department's approval shall be obtained in case of conducting any change to external employees or third parties.	Approval Management Systems	Establish formal approval workflows for access changes involving external users.	Approval records. Change logs.

	3.2.5	Obtain official and certified approval for user access according to work requirements (i.e., principles of Need-to-Know and Need-to-Have to avoid unauthorized access and unintended data leakage).	Access Request Approval Tools	Implement standardized access request and approval processes. Ensure all requests are documented and compliant.	Approved access requests. Documentation of approval processes.
	3.2.6	Process any emergency changes to access privileges in a timely manner.	Emergency Access Management Tools	Develop procedures for handling emergency access changes. Monitor and document all such changes.	Emergency access change logs. Monitoring reports.
	3.2.7	Review user access privileges and profiles periodically.	Access Review Tools	Conduct regular reviews of user access privileges to identify and rectify discrepancies.	Access review reports. Rectification logs.
	3.2.8	Review the submitted, approved and processed user access applications and process related cancellation applications.	Access Management Tools	Maintain audit trails of all user access requests, approvals, and cancellations.	Access application logs. Cancellation records.
4.3.4	3.3	User Access Management shall be automated.	Automated Access Management Systems	Deploy automation tools to streamline user access provisioning, monitoring, and deprovisioning.	Automation logs. Evidence of streamlined processes.

	3.4	Provide uniform systems for access identity and privileges management.	Unified IAM Platforms	Use centralized platforms to ensure consistent application of access policies.	Centralized IAM system documentation. Policy application evidence.
	3.5	Multi-Factor Authentication for access to sensitive systems and accounts.	Multi-Factor Authentication Tools	Enforce MFA for sensitive systems and accounts. Periodically review and update configurations.	MFA deployment logs. Review and update records.
	3.6.1	Management controls of high and sensitive privileges and access management include: Restricted and customized use of remote access and accounts with high and sensitive privileges; especially:	Privileged Access Management (PAM) Tools	Define and enforce strict controls for privileged and remote access. Regularly review and monitor privileged accounts.	PAM policies. Privileged account review logs.
	3.6.1.1	Use Multi-Factor Authentication mechanism for all remote access operations.	MFA Tools	Enforce MFA for all remote access activities. Monitor compliance and effectiveness.	MFA activity logs. Compliance reports.
	3.6.1.2	Use Multi-Factor Authentication mechanism for accounts with high and sensitive privileges on sensitive	MFA Tools	Deploy MFA based on risk assessments for sensitive accounts. Regularly validate configurations.	Risk-based MFA implementation logs. Validation records.

		systems according to risk assessment.			
	3.6.2	Conduct periodic review for users with important and sensitive accounts and remote access accounts.	Review and Audit Tools	Schedule regular audits of sensitive and remote access accounts. Address discrepancies promptly.	Review findings. Audit reports.
	3.6.3	Accountability in case of violations.	Incident Management Tools	Define accountability mechanisms and consequences for access violations.	Incident response reports. Documentation of accountability measures.
	3.6.4	Use of important and sensitive systems accounts includes: 1-Restriction and monitoring; 2-Maintaining password confidentiality; 3- Changing passwords periodically.	Password Management Tools	Enforce password policies for sensitive systems. Monitor and log password changes. Use of Active Directory password policy. PAM implementation.	Password policy logs. Monitoring reports. PAM Implementation and configuration.

Risk Considerations in Identity and Access Management

1. **Unauthorized Access:**
Inadequate authentication and authorization mechanisms can lead to unauthorized access to critical systems and sensitive data. This can result in data breaches, financial losses, operational disruptions, and reputational damage.
2. **Weak Credentials:**
Poor password management practices, such as weak or reused passwords and shared accounts, increase the likelihood of account compromise. Attackers can exploit these vulnerabilities to gain unauthorized access.
3. **Privilege Misuse:**
Excessive or inappropriate access privileges granted to users or roles can lead to the misuse of sensitive systems and data, either accidentally or intentionally. This risk can escalate if privileged accounts are not adequately monitored or controlled.
4. **Regulatory Non-Compliance:**
Failure to implement and enforce identity and access management controls aligned with regulatory requirements (e.g., NCA, SAMA, CMA, CST) can result in legal penalties, hefty fines, and reputational damage.
5. **Insider Threats:**
Both malicious insiders and negligent employees pose a risk to organizational security. They can abuse their access privileges to steal confidential information, damage systems, or disrupt business operations.
6. **Lack of Access Reviews:**
Failure to periodically review and update user access rights can lead to orphaned accounts, unauthorized access, and accumulation of excessive privileges over time.
7. **Privileged Account Exploitation:**
Privileged accounts are prime targets for attackers due to their elevated access levels. Mismanagement or compromise of these accounts can enable attackers to bypass critical security controls.
8. **Ineffective Multi-Factor Authentication (MFA) Implementation:**
Inadequate or inconsistent enforcement of MFA can weaken security, especially for sensitive systems and remote access.
9. **Shadow IT and Unmanaged Identities:**
The use of unauthorized applications and untracked identities outside the organization's IAM framework increases the risk of unauthorized access and compliance violations.
10. **Poor Monitoring and Audit Practices:**
Lack of robust monitoring and audit capabilities makes it difficult to detect and respond to unauthorized access attempts, insider threats, and policy violations.
11. **Human Error:**
Mistakes in configuring or managing access controls, such as granting unnecessary privileges or failing to revoke access for former employees, can expose systems to significant risks.

Examples of Technologies for Effective Identity and Access Management

1. **Identity Management Systems (IDMS):**
Centralized systems for managing user identities, roles, and access privileges. These systems provide essential features such as user provisioning, password management, and enforcement of access control policies.
2. **Privileged Access Management (PAM):**
Solutions designed to secure and monitor privileged accounts and their usage. PAM ensures the application of least privilege principles, enforces multi-factor authentication for critical systems, and logs activities for audit purposes.
3. **Multi-Factor Authentication (MFA):**
Enhances security by requiring multiple forms of authentication (e.g., something the user knows, has, or is) before granting access. MFA is critical for protecting both regular and privileged accounts.
4. **Role-Based Access Control (RBAC):**
Simplifies access management by assigning permissions to roles rather than individual users. RBAC ensures that users only access resources necessary for their roles, improving security and compliance.
5. **Access Control Lists (ACLs):**
Provide granular control over resources by defining which users or groups have permissions to access or perform specific actions on resources.
6. **Single Sign-On (SSO):**
Improves user experience and reduces password fatigue by allowing users to authenticate once and access multiple applications or systems seamlessly.
7. **Identity Governance and Administration (IGA):**
Automates processes for managing and reviewing user access rights, ensuring compliance with organizational policies and regulatory requirements. IGA provides robust reporting capabilities for audits.
8. **Virtual Private Network (VPN) Solutions:**
Secures remote access to organizational resources by encrypting connections and ensuring only authorized users gain access. VPNs are often combined with MFA for enhanced protection.
9. **Security Information and Event Management (SIEM):**
Collects, correlates, and analyzes security logs to detect unauthorized access attempts and respond to potential security incidents.
10. **Biometric Authentication Systems:**
Incorporate advanced authentication methods such as fingerprint scanning, facial recognition, or retina scans to enhance identity verification processes.
11. **Cloud Access Security Brokers (CASBs):**
Act as a security enforcement point between users and cloud applications to monitor access and enforce policies across cloud environments.
12. **Password Management Tools:**
Enable users to securely store, generate, and manage passwords. These tools also facilitate periodic password updates and compliance with password complexity requirements.

Examples of KPIs for Identity and Access Management

1. **User Provisioning Time:**
Average time taken to create user accounts and grant access to required resources. Lower provisioning time indicates streamlined access management processes.
2. **Password Reset:**
Number of password resets performed within a specific timeframe. High frequency may indicate issues with password complexity policies or user password management practices.
3. **Multi-Factor Authentication (MFA) Adoption Rate:**
Percentage of users actively utilizing multi-factor authentication for account security. Higher adoption rates reflect enhanced security practices.
4. **Access Certification Completion Rate:**
Percentage of access reviews completed within the defined review period. A high rate indicates effective governance and adherence to compliance requirements.
5. **Privileged Access Audit Coverage:**
Percentage of privileged accounts reviewed and audited regularly. Comprehensive coverage demonstrates strong oversight of privileged access.
6. **Number of IAM-Related Security Incidents:**
Number of reported security incidents linked to identity and access management failures (e.g., unauthorized access, compromised credentials).
7. **Mean Time to Detect (MTTD):**
Average time taken to identify IAM-related security incidents. A lower MTTD signifies better monitoring and detection capabilities.
8. **Mean Time to Respond (MTTR):**
Average time taken to resolve IAM-related security incidents after detection. A lower MTTR reflects effective incident response processes.
9. **Access Request Fulfillment Rate:**
Percentage of access requests fulfilled within the defined service level agreement (SLA). Higher fulfillment rates indicate efficient IAM operations.
10. **Inactive or Orphaned Accounts:**
Number of inactive or orphaned accounts (accounts without an active owner). A lower count indicates proper account lifecycle management.
11. **IAM Policy Compliance Rate:**
Percentage of user accounts and systems complying with IAM policies and controls. A higher rate reflects effective enforcement of IAM policies.
12. **Privileged Account Reviews:**
Number of reviews conducted for privileged accounts within a specific timeframe. Frequent reviews ensure tighter control over elevated access.
13. **Authentication Failure Rate:**
Percentage of failed authentication attempts across systems. High failure rates could indicate potential unauthorized access attempts or user challenges with authentication mechanisms.

Samples of Auditor's Checklist for Identity and Access Management

1. Is there a defined, approved, and updated IAM policy?
2. Are user access rights periodically reviewed and updated to align with job roles?
3. Are Multi-Factor Authentication (MFA) mechanisms implemented for sensitive and critical systems?
4. Are privileged accounts managed using a Privileged Access Management (PAM) solution?
5. Is access to systems and resources granted based on the principles of least privilege and need-to-know?
6. Are user onboarding, offboarding, and role changes systematically managed?
7. Are audit trails maintained for access requests, approvals, and privileged account activities?
8. Is centralized identity management implemented for consistent application of IAM policies?
9. Are IAM-related security incidents detected and responded to promptly?

Samples of Audit Scenarios for Identity and Access Management

Scenario 1: Privileged Account Review

- **Objective:** Assess the management of privileged accounts.
- **Steps:**
 1. Review logs of privileged account activities in the PAM solution.
 2. Verify the application of MFA for privileged accounts.
 3. Check records of periodic reviews of privileged account usage.
- **Questions:**
 - Are privileged accounts used only for their intended purpose?
 - Are privileged account activities logged and reviewed regularly?

Scenario 2: Access Control Implementation

- **Objective:** Evaluate the effectiveness of access control mechanisms.
- **Steps:**
 1. Review a sample of access control configurations and policies.
 2. Check compliance with least privilege and need-to-know principles.
 3. Validate the enforcement of MFA for sensitive systems.
- **Questions:**
 - Are access control mechanisms aligned with the organization's policies?
 - Are there any unauthorized access attempts or violations?

Scenario 3: User Lifecycle Management

- **Objective:** Verify the processes for user onboarding, offboarding, and role changes.
- **Steps:**
 1. Examine access records for terminated users to ensure access was revoked promptly.
 2. Review policies for handling role changes and access updates.
 3. Check if periodic access reviews are conducted and documented.
- **Questions:**
 - Are access rights updated promptly for employment status changes?
 - Are orphaned accounts detected and deactivated?

Scenario 4: Incident Management for IAM

- **Objective:** Assess the organization's ability to detect and respond to IAM-related security incidents.
- **Steps:**
 1. Request logs of recent IAM-related incidents.
 2. Analyze response times (MTTD and MTTR) for incidents.
 3. Verify the implementation of corrective actions to prevent recurrence.
- **Questions:**
 - Were IAM-related incidents resolved promptly and effectively?
 - Are lessons learned from incidents documented and acted upon?

Case Study 1: Strengthening Identity and Access Management in a Government Organization

Scenario:

A government authority faced challenges in managing identity and access due to legacy systems, decentralized identity management, and a lack of visibility into user privileges. The organization was also under scrutiny to comply with stringent regulatory requirements such as NCA ECC and ensure the security of its systems.

Actions Taken:

1. **Modernize IAM Infrastructure:** The organization transitioned to a centralized IAM system, replacing fragmented legacy systems and enabling unified management of identities across all departments.
2. **Implement Privileged Access Management (PAM):** A PAM solution was deployed to secure access to sensitive systems and ensure accountability for privileged actions.
3. **MFA Across the Board:** Multi-Factor Authentication was mandated for all users accessing critical applications and systems.
4. **Enforce Least Privilege Principle:** Access rights were audited, and unnecessary privileges were revoked to align with the least privilege principle.
5. **Automated Access Provisioning:** Automated tools were implemented to streamline user provisioning, deprovisioning, and periodic access reviews.
6. **Conduct Awareness Training:** A comprehensive training program was rolled out to educate staff on secure identity and access practices and the importance of compliance.

Outcome:

The government organization successfully streamlined its IAM processes, improving operational efficiency and security. The centralized IAM system provided greater visibility into user privileges, while PAM and MFA ensured secure access to sensitive resources. Regular audits demonstrated compliance with NCA ECC, and the overall risk of unauthorized access and data breaches was significantly reduced. This strengthened trust and confidence among citizens and stakeholders in the organization's cybersecurity practices.

Case Study 2: Identity and Access Management Implementation in a Cloud Environment

Scenario: A company migrating to a cloud environment needs to ensure secure access to cloud resources while maintaining control over user identities and permissions and ensure compliance with NCA CCC.

Actions Taken:

1. **Choose Cloud IAM Solution:** Select a cloud-based IAM solution that integrates with the chosen cloud provider (e.g., AWS IAM, Azure Active Directory).
2. **Establish Identity Federation:** Enable single sign-on for users to access both on-premises and cloud applications.
3. **Implement Fine-Grained Access Control:** Utilize cloud-native IAM features to define granular access permissions to specific cloud resources.
4. **Monitor and Audit Access:** Leverage cloud monitoring and auditing tools to track user activity and detect any suspicious behavior.
5. **Enforce Security Policies:** Implement security policies to govern user access, password management, and data protection in the cloud environment.
6. **Annual Compliance Assessment:** Perform compliance assessments in an annual basis to ensure compliance with the NCA CCC.

Outcome:

The company successfully secured access to its cloud resources, improved user experience with SSO, and maintained compliance with security and regulatory requirements.

Case Study 3: Identity and Access Management in an Energy Sector Organization

Scenario:

An energy company lacked visibility into its privileged accounts and struggled to manage remote access securely. This posed risks to critical infrastructure and compliance with NCA OTCC standards.

Actions Taken:

1. **Privileged Access Management:** A PAM solution was deployed to monitor and secure privileged accounts.
2. **MFA for Remote Access:** Multi-Factor Authentication was enforced for all remote access operations, including the OT environment.
3. **Centralized Identity Management:** All identity and access processes were centralized for better oversight.
4. **Conduct Access Reviews:** Periodic reviews were scheduled to ensure access rights aligned with the principle of least privilege.

Outcome:

The company improved its IAM processes, reducing risks associated with privileged and remote accounts. Compliance with NCA OTCC standards was achieved, and security incidents related to unauthorized access significantly decreased.

Case Study 4: Implementing Identity and Access Management in a Financial Institution

Scenario:

A financial institution identified a lack of comprehensive access controls and inconsistent identity management practices. This created security vulnerabilities and made compliance with SAMA CSF standards challenging.

Actions Taken:

1. **Develop IAM Policy:** The institution formalized an Identity and Access Management policy, covering access control principles and accountability.
2. **Deploy MFA:** Multi-Factor Authentication was implemented across all critical systems.
3. **Automate Access Management:** Automated IAM tool were deployed to manage access provisioning, deprovisioning, and periodic reviews.
4. **Perform Regular Audits:** Quarterly audits were introduced to assess access compliance and identify gaps.
5. **Educate Employees:** Comprehensive training programs were launched to educate employees on secure access practices and policies.

Outcome:

The institution enhanced its security posture by implementing structured IAM practices. Quarterly audits provided evidence of compliance with SAMA CSF, while MFA reduced unauthorized access attempts. Automating access management saved time and ensured accuracy.

2.3 Information System and Information Processing Facilities Protection:

Definition: Information System and Processing Facilities Protection refers to the comprehensive set of practices, controls, and measures designed to safeguard information systems and processing facilities, including hardware, software, and infrastructure. This protection ensures the confidentiality, integrity, and availability of organizational systems against cyber risks such as unauthorized access, malware, and physical damage [7], [8].

Objective: To ensure the protection of information systems and information processing facilities (including workstations and infrastructures) against cyber risks by implementing robust controls and security measures.

Controls Matrix:

Below is a summary matrix detailing relevant identity and access management controls based on NCA, SAMA CSF, CST CRF, and CMA Cybersecurity Guidelines:

Regulation	Main Controls	Control References
NCA ECC	4	2-3-1, 2-3-2, 2-3-3 (4 sub-controls), 2-3-4
SAMA CSF	-	—
CST CRF	-	—
CMA CSG	-	—
NCA CSCC	1	2-3-1 (8 sub-controls)
NCA CCC CST	1	2-3-T-1 (1 sub-control)
NCA CCC CSP	1	2-3-P-1 (10 sub-controls)
NCA TCC	1	2-3-1 (5 sub-controls)
NCA DCC	1	2-2-1 (4 sub-controls)
NCA OSMACC	1	2-3-1 (4 sub-controls)
NCA OTCC	2	2-3-1 (13 sub-controls), 2-3-2

Information System and Information Processing Facilities Protection Controls:

National Cybersecurity Authority - Essential Cybersecurity Controls ECC					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines:	Expected deliverables
ECC-2.3.1		Cybersecurity requirements for protecting information systems and information processing facilities must be defined, documented and approved.	Database Security Policy Template	Develop and document cybersecurity policy for Information System and Processing Facilities Protection in the organization, including the following: Modern and advanced protection techniques and mechanisms, providing them and ensuring their reliability. Malware Protection Solution Configuration. Scope of devices to be protected, including all workstations, critical systems in the organization, etc. Secure copies of the operating systems used in the organization must be built and prepared in a secure manner, protection programs must be installed, and unused services must be disabled. Such copied must be used in the configuration of desktops and servers.	Cybersecurity policy that covers the requirements of Information System and Processing Facilities Protection at the organization (e.g., electronic copy or official hard copy). Formal approval by the head of the organization or his/her deputy on the policy (e.g., via the organization's official e-mail, paper or electronic signature). Secure Configuration and Hardening Policy Template Server Security Policy Template Malware Protection Policy Template Storage Media Policy Template Patch Management Policy Template

				Workstations and systems in the organization must be periodically scanned against malware. Use of external storage media and its security must be restricted. Patch management for systems, applications and devices. Central sources of time synchronization in the organization must be defined to be from a reliable source. Support the organization's policy by the Executive Management. This must be done through the approval of the organization head or his/her deputy.	
ECC-2.3.2		The cybersecurity requirements for protecting information systems and information processing facilities must be implemented.	Secure Configuration and Hardening Policy Template Server Security Policy Template Malware Protection Policy Template Storage Media Policy Template Patch Management Policy Template	Implement all cybersecurity requirements for Information System and Processing Facilities Protection in the organization. This may include the following: Modern and advanced protection techniques and mechanisms availability and reliability must be ensured. Scope of devices to be protected and reviewed periodically must be ensured. Use of external storage media	Documents that confirm the implementation of cybersecurity requirements related to information systems and processing facilities as documented in the policy. An up-to-date list of the organization's virus protection systems and the extent of their download. Restrict the use of external storage media and procedures for approving

				and its security must be restricted. Patches throughout the organization's devices, systems, and applications must be implemented. Central Clock Synchronization and from a reliable source must be implemented.	their use. Evidence that the scope of patches covers all devices, systems and applications. Evidence that the organization uses a central server and a reliable source for timing synchronization.
ECC-2.3.3	ECC-2.3.3.1	Advanced, up-to-date and secure management of malware and virus protection on servers and workstations.		Define and document the requirements of this ECC in the cybersecurity requirements document and approve them by the representative. Provide anti-virus, suspicious programs, and malware protection techniques and mechanisms, including the following: Continuously ensure that the technologies used are current and advanced and contain protection against advanced persistent threat. Determine the domain of the assets on which the protection system will be installed and identify and update their status. Install the protection system throughout the workstations, systems and servers of the organization. Review the protection system	Documents indicating the identification and documentation of the requirements of this ECC in the policies or procedures of the organization approved by the representative. List of antivirus systems and evidence of protection against APT (including but not limited to a screenshot or direct example from the APT Monitoring page of the protection system). Reports or evidence of installing the protection technologies across all workstations, systems and servers of the organization. Reports or evidence of following-up the scope of installing and periodic updating of these technologies.

				periodically to ensure that the scope of the protection system is comprehensive for all workstations, systems, and servers of the organization through the protection system's control unit. Develop and implement a remediation action plan (when needed) to install the protection system on all devices while taking action against devices and systems where it is frequently observed that the modern and advanced protection system is not installed. Follow up on the protection system periodically to ensure updates are installed and released on all workstations, systems and servers of the organization.	
ECC-2.3.3	ECC-2.3.3.2	Restricted use and secure handling of external storage media.		Define and document the requirements of this ECC in the cybersecurity requirements document and approve them by the representative. Restrict the use of external storage media by : Groups in the privileged access management system must be created according to authority so that	A document (such as approved policy or procedure) indicating the identification and documentation of the requirements related to this control. Report or evidence indicating the restriction of using external storage media (including but not

				the use of external storage media is automatically not activated on all workstations, the organization's systems, and servers. Documented procedures must be defined to provide approval for the use of external storage media (including but not limited to: requesting approvals via e-mail, paper, or through an internal system). Such procedures include: Reason for requesting approval for use. Use start and end date. Mechanism for handling data stored in storage media so that it is checked prior to use and data is erased after completion.	limited to a screenshot or direct example from access management system showing the vigor restriction of the use of external storage media on workstations and servers). Approval procedures for the use of storage media for part of the approved devices.
ECC-2.3.3	ECC-2.3.3.3	Patch management for information systems, software and devices.		Define and document the requirements of this ECC in the cybersecurity requirements document and approve them by the representative. Define procedures for patch management for systems, devices and applications, which include: The scope of systems where patches are implemented must be defined	A document (such as approved policy or procedure) indicating the identification and documentation of the requirements related to this control. Evidence indicating the inclusion of change management in patches (including but not limited to including patches in change

				to include: Workstations Operating Systems Network Devices Databases Applications Time period required to implement patches must be defined according to the quality of operating system, the system criticality, applicable patches, and importance of patches. Patches procedures must be included in change management methodology or change management must be included into patch management policy. Change management approval must be included as part of patch approval form for all systems, devices and applications, including but not limited to requesting approvals via e-mail, paper, or through an internal system. Patches must be implemented to the defined scope after obtaining the necessary approval. Implementation of patches must be continuously reviewed to ensure that all necessary patches are implemented to all devices, systems, and	management methodology or enforcing change management by including it in the requirements of Patch Management). Approval procedures indicate that change management approval is required for patches. Reports or evidence that the scope of patches covers all devices, systems and applications. Reports or evidence that the patches are performed according to the period specified in the procedures (including but not limited to a screenshot or direct example that displays the date and scope for several samples of patches approved by e-mail, internal system or paper that are performed in advance to include all the organization's devices, systems and applications periodically).
--	--	--	--	---	--

				applications. Required patches must be periodically monitored to ensure patches by, but not limited to, the protection system, patch management system, and vulnerability alerts sent by email.	
ECC-2.3.3	ECC-2.3.3.4	Centralized clock synchronization with an accurate and trusted source (e.g., Saudi Standard controls, Metrology and Quality Organization (SASO)).		Define and document the requirements of this ECC in the cybersecurity requirements document and approve them by the representative. Perform time synchronization through the organization's central server NTP. Configure central server time to synchronize with, but not limited to, one of the following reliable sources: Saudi Standard controls, Metrology and Quality Organization (time.saso.gov.sa). King Abdulaziz Technology City for Science and (KACST) (time.isu.net.sa).	A document (such as approved policy or procedure) indicating the identification and documentation of the requirements related to this control. Evidence that the organization uses a central server to synchronize timing (including but not limited to a screenshot or direct example of the presence of this server in the network with all server details) Evidence of using a reliable and accurate source (including but not limited to: a screenshot or direct example of the configuration of this server that proves the use of the SASO source or others).
ECC-2.3.4		The cybersecurity requirements for		Review the cybersecurity requirements for Information	An approved document that defines the review schedule

		protecting information systems and information processing facilities must be reviewed periodically.		System and Processing Facilities Protection in the organization periodically according to a documented and approved plan for review and based on a planned interval (e.g., periodic review must be conducted annually). Document the review and changes to the cybersecurity requirements for Information System and Processing Facilities Protection in the organization and approve them by the head of the organization or his/her deputy.	for the requirements document. Evidence that the periodic review of security requirements is performed to protect information systems and processing facilities in the organization. Formal approval by the head of the organization or his/her deputy on the updated requirements (e.g., via the organization's official e-mail, paper or electronic signature).
National Cybersecurity Authority – Critical Systems Cybersecurity Controls CSCC					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
CSCC-2.3.1 In addition to the sub-controls under Control 2-3-3 in the Basic Controls of Cybersecurity, they must cover the cybersecurity requirements to	CSCC-2.3.1.1	Allowing only a specific whitelisting of applications and programs to run on critical systems.	Server Security Policy Template Server Security Standard Template Malware Protection Policy Template Malware Protection Standard Template Virtualization Security Standard Template	Work to determine and approve a list of operating files for applications and programs that are allowed to run on servers for critical systems, by conducting a risk assessment that results in a list of allowed files. Work on specifying this list as files allowed through the server's security system or	A list of allowed and approved operating files that have been matched in the system or server for critical systems.

protect critical systems, and their information processing devices, at a minimum, the following:			Advanced Persistent Threats (APT) Standard Template	directly through the server settings. Work to link this list to the rules specified in the security information and events management system that monitors server logs, so that any use of operating files outside of this list is followed up.	
	CSCC-2.3.1.2	Protecting servers for critical systems with end-point protection technologies approved by the organization.	Server Security Policy Template Server Security Standard Template Malware Protection Policy Template Malware Protection Standard Template Virtualization Security Standard Template Advanced Persistent Threats (APT) Standard Template	Work to identify protection technologies for critical devices and ensure that it contains appropriate technologies to protect against advanced and continuous attacks. Work to download these technologies on all servers of critical systems in the entity. Work on continuously monitoring the protection systems of critical systems and ensuring that alerts for new version updates are activated. Work on linking the protection system for critical systems with the security information and events management system.	List of protection systems for critical systems. Special protection systems installed on critical systems.
	CSCC-2.3.1.3	Applying security fixes and updates patches, at least	Server Security Policy Template	Determine the procedures for applying security fixes and updates patch at the entity and	Procedures for applying security patches and patch updates to critical

		once a month, to critical external systems connected to the Internet; and at least every three months, for internal critical systems; With following the change mechanisms approved by the entity.	Server Security Standard Template Virtualization Security Standard Template Patch Management Policy Template Patch Management Standard Template	have them approved by the authority, including: At least once a month, apply patches and updates to critical external systems, including but not limited to: external web applications. Apply patches and updates to internal critical systems at least every three months, including but not limited to: Data systems of critical applications. Ensure that the entity's change management approval is part of the approvals required to implement security fixes and update patches for critical systems. Monitor the application of update patches and security fixes on critical systems on an ongoing basis through the use of tools and techniques for managing update patches and vulnerability management.	systems.Patch update and patch application reports as per the planned period for critical systems.
	CSCC-2.3.1.4	Allocating workstations for technical staff with privileged accounts; Provided	Server Security Policy Template Server Security Standard Template	identify computers other than the user's computer for those working in technical jobs who have important and critical privileges to manage their critical systems.	Isolated computers designated for accessing critical systems. A list of accounts with access to these devices and the restrictions applied to

		that it is isolated in a private management network and that it is not linked to any other network or service (e.g.: e-mail service, the Internet).	Configuration and Hardening Policy Template Secure Configuration and Hardening Standard Template Virtualization Security Standard Template	isolate these devices in their own network and not be connected to any of the other party's networks. isolate these devices from the Internet and other services and applications used by users, including, but not limited to: e-mail service, special applications for managing employee information, and applications that are accessed via the Internet. create accounts for these devices and monitor them continuously among the entity's important and critical accounts.	ensure that they cannot be used on other devices.
	CSCC-2.3.1.5	Encrypt any Non-console administrative access to any of the technical components of critical systems, using secure encryption algorithms and protocols.	Server Security Policy Template Server Security Standard Template Virtualization Security Standard Template Cryptography Policy Template Cryptography Standard Template	Work to define encryption standards for supervisory access over the network to critical systems and ensure their alignment with national standards for encryption, so that: Secure communication technologies and protocols are identified, including but not limited to: SSH and TLS. The minimum length of the key is specified.	An encryption standard for supervisory access over a network.

				Allocate supervisory access over the network to critical systems and use multi-factor authentication for access.	
	CSCC-2.3.1.6	Reviewing the configuration of critical systems and their immunizations (Secure Configuration and Hardening) every six months at least.	Server Security Policy Template Server Security Standard Template Configuration and Hardening Policy Template Secure Configuration and Hardening Standard Template Virtualization Security Standard Template	Working on defining safe technical standards for setting up, configuring, hardening systems and ensuring that they are obtained from reliable sources, for example: Companies developing these systems. Reference sources for preparation and immunization. Work to include safe technical standards for configuration and hardening critical systems, for example: - Manage privilege and access sessions. -encryption. - Records management. - Safe system configuration. * Periodic review of the configuration and hardening of critical systems, according to the specified plan, so that it takes place at least every six months. document the results of reviewing the configuration	Secure standards for implementing settings up, configuring and hardening critical systems. Periodic configuring and hardening application reports according to the planned duration for critical systems.

				and hardening of critical systems.	
	CSCC-2.3.1.7	Review and modify the factory configuration (Default Configuration) and ensure that there are no Hard-Coded, backdoor and default passwords as applicable.	Server Security Policy Template Server Security Standard Template Configuration and Hardening Policy Template Secure Configuration and Hardening Standard Template Virtualization Security Standard Template	review the Default Configuration of all critical systems of the entity so that they are modified possible and the results of the review are documented. ensure that there are no static, background, and default passwords on critical systems, so that: The source code of the entity's applications is reviewed and any fixed passwords are removed. Review access rights to critical systems and disable any accounts that are not being used or whose creation has expired. O Disable or modify the default accounts for critical systems, including, but not limited to: disabling the default account for databases. Work on documenting the results of reviewing and processing passwords for critical systems based on the above.	A report on reviewing the factory settings of all critical systems. Password review reports for critical systems.

	CSCC-2.3.1.8	Protect systems' critical records and files from unauthorized access, tampering, alteration, or deletion.	Server Security Policy Template Server Security Standard Template Virtualization Security Standard Template Endpoint Detection and Response Standard Template Cybersecurity Event Logs and Monitoring Management Policy Template Cybersecurity Event Logs and Monitoring Management Standard Template	Work to protect system's critical records and files from unauthorized access, through encryption or setting a password. Work to allocate access rights to critical system records and files to include a specific group of workers. Work to protect critical records and files from unauthorized tampering, alteration or deletion by restricting the permissions to write, modify and delete all records and files, including but not limited to: event logs, database files, and application system files. Work to take backup copies of all critical records and files of critical systems on an ongoing basis.	Access to critical records and files of critical systems. Backup reports of critical logs and files of critical systems.
National Cybersecurity Authority – Organization Social Media Accounts Cybersecurity Controls OSMACC					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
OSMACC-2.3.1 In addition to the subcontrols	OSMACC-2.3.1.1	Applying updates and security patches for social media applications	Template for Patch and Update Management Standard Template for Patch and Update	Identify the applications handling the social media accounts. Review the patching guidance with respect to the social	Documented procedures for security patches and updates for social media applications.

in ECC Control 2-3-3, cybersecurity requirements for protecting organization's social media accounts and technology assets related to them must include at least the following:		at least once a month.	Management Packages Policy	media applications utilized and document the patching procedures to be followed in line with the guidance. Periodic security patching and updates must be conducted at least every month or less for applications handling social media accounts.	Periodic report for security patches and updates implemented on social media accounts applications.
	OSMACC-2.3.1.2	Reviewing configurations and hardening of organization's social media accounts and technology assets related to them at least once a year.	Template for Configuration and Hardening Policy Template for Secure Configuration and Hardening Standard Template for Social Media Security Standard	Identify the applications that are used by the organization that handles social media accounts. Review the guidelines and procedures for protection and hardening related to social media account application and adhere to them when implementing protection and hardening on the applications. Periodic security configuration and hardening must be conducted at least annually or earlier for applications handling social media accounts.	Documented security hardening procedures for applications handling social media accounts. Secure configurations and hardening review report that have been conducted periodically.
	OSMACC-2.3.1.3	Reviewing and hardening default configurations, such as default passwords, pre-		Identify the technology assets and systems handling social media accounts. Document and approve security configuration and	Documented policies and procedures for hardening default settings.

		login, and logout, for organization's social media accounts and technology assets related to them.		hardening policy for all technology assets. Review the default configurations which includes, but not limited to, default passwords, pre-login, account lockout, guests accounts, service accounts, backgrounds, default administrators, legacy protocols, open ports in the system. Verify and ensure that the security configurations must not be set as default for the technology assets.	Sample of default configurations for social media accounts. Default configuration review report for social media accounts.
	OSMACC-2.3.1.4	Restricting activation of features and services in social media accounts on need basis and carrying out risk assessment if there is a need to activate it.		Identify the applications handling the social media accounts. Document and approve security configuration and hardening policy for all technology assets. Review the features and services within the social media account and perform a risk assessment before activating these features. Further, verify that only those services are activated which are required based on the risk assessment conducted.	Documented risk assessment of social media accounts and their features before activation.
National Cybersecurity Authority - Telework Cybersecurity Controls TCC					

Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
TCC-2.3.1 In addition to the sub controls in the ECC control 2-3-3, cybersecurity requirements for protecting telework systems and information processing facilities must include at least the following:	TCC-2.3.1.1	Applying updates and security patches for telework systems at least once every month.	Patch Management Policy. Configuration and Hardening Standard. Patch Management Standard.	Work on defining the requirements for this control, document them in the cybersecurity requirements document, and have them approved by the authority holder. Define procedures for patch management on systems, devices and applications, which include: The scope of systems where patches are implemented must be defined to include: Workstations. Operating Systems. Network Devices. Databases. Applications. Time period required to implement patches must be at least once every month. Patches procedures must be included in change management methodology or change management must be	A document that identifies and documents the requirements of this control (such as a policy and/or procedure approved by the authority holder). Approved procedures indicate that change management approval is required for patches. Reports that the scope of patches covers all devices and applications of telework systems. Reports that the patches are performed according to the period specified in the procedures (including but not limited to: a screenshot or direct example that displays the date and scope for several samples of patches approved by e-mail, internal system or paper that are performed in advance to include devices,

				included into patch management policy. Change management approval must be included as part of patch approval form for all systems, devices and applications, including but not limited to: requesting approvals via e-mail, paper, or through an internal system. Patches must be implemented to the defined scope after obtaining the necessary approval. Continuously review the application of update packages and patches to ensure that all necessary updates have been applied to all devices, systems and applications for remote work.	systems and applications periodically).
	TCC-2.3.1.2	Reviewing telework systems' configurations and hardening at least once every year.	Patch Management Policy. Configuration and Hardening Standard	Work on defining the requirements for this control, document them in the cybersecurity requirements document, and have them approved by the authority holder. Define technical standard to Review telework systems' configurations and hardening from trusted sources for	A document that identifies and documents the requirements of this control (such as a policy and/or procedure approved by the authority holder). Telework configuration and hardening standard approved by the organization (e.g., electronic copy or official hard copy).

				example but not limited, the vendor of telework system. Define a procedure for reviewing configuration and hardening of telework system. Review the configuration and hardening of telework system based on approved standard at least once a year, this include but not limited: access management, encryption and secure system setting.	Reports that telework systems configuration and hardening are reviewed at least every year.
	TCC-2.3.1.3	Reviewing and changing default configurations, and ensuring the removal of hard-coded, backdoor and/or default passwords.	Patch Management Policy. Configuration and Hardening Standard	Work on defining the requirements for this control, document them in the cybersecurity requirements document, and have them approved by the authority holder. Ensure that there are no hard-coded, backdoor or default passwords on telework systems based on approved standard and document the results.	A document that identifies and documents the requirements of this control (such as a policy and/or procedure approved by the authority holder). Reports of reviewing and changing default configurations, and ensuring the removal of hard-coded, backdoor and/or default passwords.
	TCC-2.3.1.4	Securing Session Management which includes the session authenticity,		Work on defining the requirements for this control, document them in the cybersecurity requirements document, and have them approved by the authority	A document that identifies and documents the requirements of this control (such as a policy and/or procedure approved by the authority holder).

		lockout, and timeout.		holder. Implement secure session management process that includes: Authentication. Authorization. Access. Control. Lockout. Timeout. Define session duration by ensuring no impact on availability of the services and information while teleworking. Document and approve the session lockout and session timeout duration in telework systems from stakeholders.	Documented and approved telework policy on having defined session management process, and duration for session lock out and session time out. Screenshot of session management that include: Session authentication. Session lockout. Session timeout
	TCC-2.3.1.5	Restricting the activation of the features and services of the telework systems based on needs, provided that potential cyber risks are analyzed in case there is a		Work on defining the requirements for this control, document them in the cybersecurity requirements document, and have them approved by the authority holder. Documenting and specifying restrictions in telework systems, after clarifying and accepting the risks, to ensure safe activation over the Internet to activate technical features and services	A document that identifies and documents the requirements of this control (such as a policy and/or procedure approved by the authority holder). An approved procedures document to restrict the activation of features and services in telework systems as needed.

		need to activate them.		based on the user's need, while specifying the duration of activation. Develop and document workflow for appropriate approval of a user request for specific feature/services required for a particular business operations and specify the duration of activation. Perform analysis of potential cyber risk before approving and activating specific user request for certain technical features or services in telework systems.	Reports analyzing potential cyber risks before activation.
National Cybersecurity Authority – Operational Technology Cybersecurity Controls OTCC					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
OTCC-2.3.1 In addition to subcontrols in the ECC control 2-3-3, cybersecurity requirements for system and processing facility protection in OT/ICS	OTCC-2.3.1.1	Advanced, up-to-date protection mechanisms and techniques must be utilized and securely managed to block and protect from malware, Advanced	Template for Cybersecurity Operational Technology PolicyTemplate for OT/ICS Security Standard Template for Malware Protection Standards Template for Server Security Standard	Implement advanced protection mechanisms (solution) to block and protect from malware, Advanced Persistent Threats (APT), malicious files, and activities. Implement the newest version of solutions, updates or signatures and periodically review the mechanisms. Ensure that the solution is	Site visit to check the following: The implemented advanced protection mechanisms (solution).The coverage of solution (Must cover all OT/ICS assets).The solution, signatures, and its database version. The schedule scanning The logs of scanning for all endpoints.

environment must include, at a minimum, the following:		Persistent Threats (APT), malicious files, and activities.	Template for Advanced Persistent Threat (APT) Protection Standard	managed to block and protect from malware. This includes the periodic updates (based on a defined frequency), and enabling the schedule scan, in addition to saving the logs for at least 3 months.	
	OTCC-2.3.1.2	Periodic security configurations' review and hardening must be conducted in alignment with the vendor implementation guidance or recommendations with respect to cybersecurity and organization's formal change management mechanisms.	Template for Cybersecurity Operational Technology PolicyTemplate for OT/ICS Security Standard Template for Secure Configuration and Hardening Standard	Develop a checklist to review and assess the security configurations' and hardening of OT/ICS systems. The checklist must be aligned with vendor implementation guidance or recommendations (Vendor Security Baselines).	A documented periodic security configurations' review and hardening procedure. A proof that security configurations review and hardening are periodically conducted in alignment with vendor implementation guidance or recommendations.
	OTCC-2.3.1.3	Periodic security patches and upgrades must be implemented in	Template for Cybersecurity Operational Technology PolicyTemplate for	Obtain a confirmation of the latest approved patches from the vendor in order to align with the applied security patches. Define, document,	A document of the periodic security patches and updates implementation procedure.

		alignment with vendor implementation guidance or recommendations with respect to cybersecurity and organization's formal change management mechanisms.	OT/ICS Security Standard Template for Patch and Update Management Policy Template for Patch and Update Management Standard	and approve the periodic security patches and upgrades implementation procedure in line with the gathered guidance or recommendations with respect to cybersecurity and the organization's formal change management mechanisms. Implement and verify the approved periodic security patches and updates by the vendor. Ensure that periodic security patches and updates comply with the change management procedure followed in the organization.	Site visit to check the patches and updates implementation. The confirmation of the latest approved patches and updates from the vendor. The change request related to the implementation of updates and security patches.
	OTCC-2.3.1.4	Principles of least privilege and least functionality must be applied.	Template for Cybersecurity Operational Technology Policy Template for OT/ICS Security Standard	Define roles and responsibilities within the organization and document least privileges and least functionalities for all defined roles. Implement principles of least privilege and least functionality (e.g. by Privileged Access Management tool). Verify and ensure that all OT/ICS are embraced by the least privilege and least functionality principles.	A documented least privileges and least functionalities for all roles defined within the organization. Site visit to check the implemented least privileges and least functionalities:

	OTCC-2.3.1.5	Safety Instrumented Systems (SIS) controllers must be configured in appropriate modes at all times, which prevent any unauthorized changes, and changes to improper modes are limited to exceptional cases with a specific period of time.	Template for Cybersecurity Operational Technology Policy Template for OT/ICS Security Standard	Ensure that Safety Instrumented Systems (SIS) controllers are configured in appropriate modes at all times. Define a procedure in case there is a need to change the Safety Instrumented Systems (SIS) controllers to improper modes. Ensure that changes to improper modes occurs only in exceptional circumstances with a specific period of time.	Site visit to check the Safety Instrumented Systems (SIS) controllers that they are in appropriate modes. A documented list of non-exceptional cases in case of the need to change the control units of Safety Instrumented Systems (SIS) to improper modes.
	OTCC-2.3.1.6	Application whitelisting techniques or other similar techniques must be deployed to limit the applications that are allowed to run in OT/ICS environment.	Template for Cybersecurity Operational Technology Policy Template for OT/ICS Security Standard	Ensure that the application whitelisting techniques or other similar techniques are utilized to limit the applications that are allowed to run in OT/ICS environment.	Site visit to check the application whitelisting techniques or other similar techniques that are implemented.

	OTCC-2.3.1.7	OT/ICS assets must be managed through dedicated, segmented and hardened Engineering Workstation (EWS) and Human-Machine Interface (HMI) for management purposes and maintenance.	Template for Cybersecurity Operational Technology PolicyTemplate for OT/ICS Security Standard	Verify and ensure that all Engineering Workstation (EWS) and Human-Machine Interface (HMI) for management and maintenance purposes are dedicated and segmented. Verify and ensure that all Engineering Workstation (EWS) and Human-Machine Interface (HMI) for management and maintenance purposes are hardened in line with approved requirements and principles.	Site visit to check all OT/ICS assets are managed through dedicated, segmented and hardened Engineering Workstations (EWS) and Human-Machine Interfaces (HMI).
	OTCC-2.3.1.8	External storage media is scanned and analyzed against malware and APT.The scan must be executed in an isolated and secure environment.	Template for Cybersecurity Operational Technology PolicyTemplate for OT/ICS Security StandardTemplate for Storage Media Security Policy	Develop an isolated and secure environment for external storage media scanning. Identify, document, and implement the scanning procedure. Verify and ensure that all external storage media are scanned and analyzed against malware and APT.	A documented external storage media scanning procedure.Proof that shows all external storage media are scanned and analyzed against malware and APT
	OTCC-2.3.1.9	Usage of external storage media in the production environment must	Template for Cybersecurity Operational Technology PolicyTemplate for	Restrict usage of external storage media in the production environment to avoid unauthorized access and unexpected influence on the	A procedure document for data transfer in the production environment.Site visit to check the usage of external

		be restricted unless secure mechanisms for data transfer are developed and properly implemented.	OT/ICS Security Standard	process. Develop and implement secure mechanisms and procedure for data transfer in the production environment (e.g. dedicated file servers, USBs, and hard disks used exclusively for the facility).	storage media in the production environment is restricted.
	OTCC-2.3.1.10	Systems' logs and critical files must be protected from unauthorized access, tampering, illegitimate modification and/or deletion.	Template for Cybersecurity Operational Technology PolicyTemplate for OT/ICS Security Standard	Ensure that all system and security logs are enabled. Ensure systems' logs and critical files are protected from unauthorized access and tampering by enabling session lockout and session timeout on the workstation as well as creating individual users with set of privileges.	Site visit to check the following: System and security logs. Session management. List of accounts.
	OTCC-2.3.1.11	Unauthorized applications, scripts, tasks, and changes must be detected and analyzed.	Template for Cybersecurity Operational Technology PolicyTemplate for OT/ICS Security Standard	Ensure that the logs of unauthorized applications, scripts, tasks, and changes are detected and forwarded to the SIEM solution or log collector, then sent to the Security Operation Center (SOC) to be analyzed.	A proof that the logs of unauthorized applications, scripts, tasks, and changes are detected. OT/ICS use-cases list by the Security Operation Center (SOC).
	OTCC-2.3.1.12	New communications sessions and commands	Template for Cybersecurity Operational Technology PolicyTemplate for	Implement techniques and tools to detect executed commands and new communication sessions (e.g. network traffic monitoring	A proof that the logs of new communication sessions and commands execution are detected. OT/ICS use-

		execution must be detected and analyzed.	OT/ICS Security Standard	tools or intrusion detection system). Ensure that the logs of new communication sessions and commands execution are detected and forwarded to the SIEM solution, then sent to the Security Operation Center (SOC) to be analyzed.	cases list by Security Operation Center (SOC).
	OTCC-2.3.1.13	Direct communications between the OT/ICS environment and external hosts must be detected and analyzed.	Template for Cybersecurity Operational Technology PolicyTemplate for OT/ICS Security Standard	Implement network traffic analysis tool between OT/ICS and external hosts (e.g. network traffic monitoring tools).Ensure that the logs of direct communications between the OT/ICS environment and external hosts are detected and forwarded to the SIEM solution, then sent to the Security Operation Center (SOC) to be analyzed.	A proof that the logs of new communications sessions and commands execution are detected.OT/ICS use-cases list by Security Operation Center (SOC).
OTCC-2.3.2		With reference to the ECC control 2-3-4, the cybersecurity requirements for system and processing facilities protection in	Template for Cybersecurity Operational Technology PolicyTemplate for OT/ICS Security StandardTemplate for Key Performance Indicator Report	Review the cybersecurity requirements for system and processing facilities protection in OT/ICS environment periodically based on a documented and approved review plan and on a defined frequency (e.g., conduct a review annually). Develop key	A proof that shows the periodic review of cybersecurity requirements to protect systems and processing facilities related to OT/ICS.A proof that shows the key performance indicators (KPIs) for each control within the related

		OT/ICS environment must be reviewed, and their implementation effectiveness is measured and evaluated periodically.		performance indicators (KPIs) for each control within the related policy or procedure to ensure the implementation effectiveness is measured and evaluated periodically based on a defined frequency (e.g., conduct an annual review).	policy or procedure to ensure the implementation effectiveness is measured and evaluated periodically based on a defined frequency.
National Cybersecurity Authority - Cloud Cybersecurity Controls CCC					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines:	Expected deliverables
CCC-CSP-2.3-P-1 In addition to sub-controls in the ECC control 2-3-3, the CSP shall cover the following additional sub-controls for cybersecurity requirements for information system and processing facilities protection	CCC-CSP-2.3-P-1-1	Ensuring that all configurations are applied in accordance with CSP's cybersecurity standards.	Template for Server Security Policy Template for Server Security Standards •Template for Virtual System Security Standards Template for Proxy Server System Standards •Template for Configuration and Hardening Policy	Document and approve cybersecurity standards for information systems. Configure information systems based on the approved standards before deployment and before implementing changes. Verify periodically information systems configurations based on the approved standards. Monitor changes to configurations. Restrict modification rights of configurations to privileged roles.	Approved cybersecurity standards for information systems. Checklist for applying standards to configurations before deployment and before changes are applied. Review plan for information systems configurations and review reports. Sample event logs for monitoring changes to configurations. Restrictions applied to modifying configurations and the list

requirements, as a minimum				Manage modifications of configurations in a formal Change Management process.	of workers with permission to change configurations. A sample of configurations change requests.
	CCC-CSP-2.3-P-1-2	Assurance of separation and isolation of data, environments and information systems across CSTs, to prevent data commingling.	Template for Server Security Policy Template for Server Security Standards Template for Virtual System Security Standards Template for Proxy Server System Standards Template for Configuration and Hardening Policy Template for Data Cybersecurity Policy Template for Data Cyber Security Standards	Implement reliable mechanisms for separation and isolation of CSTs' data using virtualization hardware at the level of environments, servers, networks, and information processing systems (e.g.: Software Defined Network). Periodically test isolation mechanisms (e.g. penetration tests).	Data and systems verified separation across CSTs.' data. Test reports to validate the prevention of data commingling.
	CCC-CSP-2.3-P-1-3	Adopting of cybersecurity principles for technical system configurations adhering to the minimum	•Template for Server Security Policy •Template for Server Security Standards Template for Virtual System Security Standards	Activate the "Minimum Functionality Principle" at the level of solution and systems architecture based on business needs and service providers' recommendations. •Define and implement minimum baseline	Minimum functionality requirements defined at the level of configuration and functionality for technologies, systems, software and services, etc.

		functionality principle.	•Template for Proxy Server System Standards - Template for Configuration and Hardening Policy	requirements for the configuration and functionality of technologies, systems, software, and services.Review configurations periodically to verify that excessive functions are not enabled.	Configuration audit reports for compliance with specified requirements.
	CCC-CSP-2.3-P-1-4	The ability of the Cloud Technology Stacks to securely handle input validation, exceptions, and failures.	Template for Server Security Policy Template for Server Security Standards •Template for Virtual System Security Standards •Template for Proxy Server System Standards Template for Configuration and Hardening Policy	Implement unified input validation technical framework across the Cloud Technology Stacks (e.g.: special characters, length, character sets, etc.).Configure Cloud Technology Stacks to validate inputs.Configure logging and monitoring to catch exceptions and failures.	A sample of the configuration for input validation.A sample of enabling automatic monitoring and logging to catch exceptions and failures.Evidence confirming the logging and monitoring of alerts/audit reports.
	CCC-CSP-2.3-P-1-5	Full isolation of security functions and applications from other functions and applications in the Cloud Technology Stack.	Template for Server Security Policy Template for Server Security Standards Template for Virtual System Security Standards •Template for Authenticated Server Systems Standards	Deploy security solutions/tools and applications in dedicated physical or logical environments.	Document demonstrating that security functions and applications are isolated from other functions and applications in the Cloud Technology Stack.Architecture design documentation.

	CCC-CSP-2.3-P-1-6	Notify the CSTs of the cybersecurity requirements provided by the CSP and applicable for use by the CSTs.	Template for Server Security Policy Template for Server Security Standards Template for Virtual System Security Standards Template for Proxy Server System Standards	Define cybersecurity requirements for CSTs (e.g.: secure connection, secure integration protocol) Send notifications to CSTs about security requirements provided by the service provider and the methods of activating them on the services used by subscribers.	A document of cybersecurity requirements provided by the service provider and methods of activating them on the services used by the subscribers. Evidence that demonstrates the communication of requirements that can be activated according to the request of the subscribers, which have been shared with them.
	CCC-CSP-2.3-P-1-7	Detection and prevention of unauthorized changes to software, and systems.	Template for Server Security Policy Template for Server Security Standards Template for Virtual System Security Standards Template for Proxy Server System Standards	Identify and document Cybersecurity requirements for Change Management, Access Control, and Logging and Monitoring to detect and prevent unauthorized changes (e.g. define roles and responsibilities to design, approve, and implement a change; allow only privileged users to implement a change; elevate privileges for making changes; enable audit logs for change implementation; monitor user activities when implementing changes) • Implement both	Cybersecurity requirements for change management. Provided evidence that confirms applied restrictions that prevent, detect, and remediate unauthorized changes. Evidence illustrating system configuration for change prevention tools. Documents demonstrating change monitoring report/alerts.

				administrative and technical controls to enforce these requirements (e.g. Change Management, Privileged Access Management systems, Logging and Monitoring systems)	
	CCC-CSP-2.3-P-1-8	Complete isolation and protection of multiple guest environments.	Template for Server Security Policy Template for Server Security Standards •Template for Virtual System Security Standards Template for Proxy Server System Standards	Build and maintain the Threat Model for the virtualization technology. Identify and respond to virtualization technology issues (e.g.: memory leak, escape to host). Configure virtualization technology for guest isolation Test virtualization technology for issues related to isolation and protection of guest environment.	Guest environments isolated. Architectural design document for hosting environments illustrating isolation. Sample of virtual environment threat model. Sample of test report.
	CCC-CSP-2.3-P-1-9	The community cloud services provided to CSTs (government organizations and CNI organizations) shall be isolated from any other cloud computing provided to organizations	Template for Server Security Policy Template for Server Security Standards Template for Virtual System Security Standards Template for Proxy Server System Standards	Define necessary procedures to ensure the physical and logical isolation and segregation of cloud services provided to government organizations and CNI organizations from any other cloud computing provided to organizations outside the scope of work. Implement the isolation mechanisms between community cloud and	Architectural design documentation. Sample of the Isolation mechanisms implemented between cloud services provided to government entities and sensitive infrastructure entities from any other cloud computing services provided to other external entities.

		outside the scope of work.		public/private and other community clouds (e.g.: physical and logical barriers applied)	
	CCC-CSP-2.3-P-1-10	Modern technologies, such as Endpoint Detection and Response (EDR) technologies, to ensure that the information servers and devices of CSP's information processing systems and devices of are ready for rapid response to incidents.	Template for Endpoint Detection and Response (EDR)Template for Advanced Persistent Threat (APT) Protection StandardTemplate for Advanced Persistent Threat (APT) System Protection StandardsTemplate for Malware Protection PolicyTemplate for Malware Protection StandardsTemplate for Server Security PolicyTemplate for Server Security StandardTemplate for Virtual System Security StandardsTemplate for Proxy Server Systems Standards	Provide EDR techniques and mechanisms to detect, prevent, and protect against programs, suspicious activities, and malware.Ensure that the technologies provided are up-to-date and contain advanced and persistent attacks (APT) protection.Review the protection system periodically to ensure that the scope of the protection system is comprehensive for all users' devices, party systems, and servers through the control unit of the protection system.Develop and implement a corrective action plan (when needed) to install the protection system on all devices.Follow up the protection system periodically to ensure the updates are released on all users' devices, the party's systems and servers.	EDR systems implemented across all devices and servers.EDR systems configurations review plan and reports.EDR systems updates plan and reports.

CCC-CST-2.3-T-1	CCC-CST-2.3-T-1-1	Verifying that the CSP isolates the community cloud services provided to CSTs (government organizations and CNI organizations) from any other cloud computing provided to organizations outside the scope1 of work.	Template for Reviewing and Auditing PolicyTemplate for Audit Plan LogTemplate for Server Security Standard	Review CSP's independent audits and assurance for proves of effective isolation of community clouds from public and other community clouds (e.g.: review physical isolation controls, logical isolation controls, multi-tenancy).	CSP's community cloud isolation verified by agreed upon means between the CST and CSP.
National Cybersecurity Authority - Data Cybersecurity Controls DCC					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines:	Expected deliverables
DCC-2.2.1 In addition to the subcontrols in ECC control 2-3-3, cybersecurity requirements for Information System and Processing	DCC-2.2.1.1	Applying security patches and updates from the time of announcement on systems used to handle data as specified for each	Template for Patch and Update Management PolicyTemplate for Patch and Update Management Standard	Identify the requirements of this control and document them in a cybersecurity requirements document, followed by approval from the authorizing officials. Identify the systems and services handling data across all classification. Review the patching guidance with	Document detailing the identification and documentation of the requirements of this control (e.g. a policy and/or procedure approved by the authorizing officials). Documented security patching procedures for

Facilities Protection must include at least the following:		data classification level.		respect to the systems and services utilized and document the patching procedures to be followed in line with the guidance. Periodic security patching and updates should be conducted at least every month or earlier for systems and services handling Public or Confidential data and immediately for systems and services handling Secret or Top Secret data.	systems and services handling data. Patching review report for periodic security patching.
	DCC-2.2.1.2	Reviewing the secure configuration and hardening of systems used to handle data as specified for each data classification level.	Template for Patch and Update Management PolicyTemplate for Configuration and Hardening PolicyTemplate for Configuration and Hardening Standard	Identify the requirements of this control and document them in a cybersecurity requirements document, followed by approval from the authorizing officials. Identify the systems handling data across all classification. Review the security configuration guidance with respect to the systems utilized and document the hardening procedures to be followed in line with the guidance. Periodic security configuration and hardening should be conducted at least annually or earlier for systems handling	Document detailing the identification and documentation of the requirements of this control (e.g. a policy and/or procedure approved by the authorizing officials). Approved standard for reviewing security configuration and hardening for data processing systems (e.g., approved hard copy or electronic version). Reports indicating that security configuration and hardening for systems used for data handling are

				Public or Confidential data and at least every 6 months or earlier for systems and services handling Secret or Top Secret data.	reviewed according to the timeframe for each level.
	DCC-2.2.1.3	Reviewing and hardening the default configuration (e.g., default passwords and backgrounds) of the technology assets used to handle the data.	Template for Patch and Update Management Policy	Identify the requirements of this control and document them in a cybersecurity requirements document, followed by approval from the authorizing officials. Identify the technology assets and systems handling data across all classification. Review the default configurations which includes, but not limited to, default passwords, guests accounts, service accounts, backgrounds, default administrators, legacy protocols, open ports in the system. Verify and ensure that the security configurations should not be set as default for the technology assets.	Document detailing the identification and documentation of the requirements of this control (e.g. a policy and/or procedure approved by the authorizing officials).Default configuration review report for technology assets.
	DCC-2.2.1.4	Disabling the Print Screen or Screen Capture features on the devices that		Identify the requirements of this control and document them in a cybersecurity requirements document,	Document detailing the identification and documentation of the requirements of this control

		create or process documents.		followed by approval from the authorizing officials. Identify the devices that process Secret and Top Secret data of the organization. Review and verify the Print Screen or Screen Capture features on the devices and ensure that they are disabled in the system.	(e.g. a policy and/or procedure approved by the authorizing officials). Review report that verifies that devices' print screen feature is disabled on devices that handles Secret and Top secret documents. Sample of the system security configurations.
--	--	------------------------------	--	--	---

Risk Considerations in Information System and Processing Facilities Protection:

1. **Unauthorized Access:** Lack of proper access controls can result in unauthorized access to critical systems and sensitive data, leading to breaches and operational disruptions.
2. **Malware and Advanced Persistent Threats (APTs):** Systems are vulnerable to malware and APTs if not adequately secured, resulting in potential data breaches or service interruptions.
3. **Inadequate Configuration Management:** Failure to secure system configurations, including default settings and credentials, can expose systems to attacks.
4. **Patch Management Deficiencies:** Delayed or incomplete patching of vulnerabilities can be exploited by attackers to gain unauthorized access or disrupt services.
5. **Non-Compliance:** Failure to implement cybersecurity measures aligned with NCA, SAMA, and other regulations can result in legal penalties, financial losses, and reputational harm.
6. **Insufficient Monitoring:** Lack of real-time monitoring and log analysis can hinder the ability to detect and respond to security incidents effectively.

Examples of Technologies for Effective Information System and Processing Facilities Protection:

1. **Endpoint Detection and Response (EDR):** Detects and mitigates threats on endpoints such as workstations and servers.
2. **Intrusion Detection and Prevention Systems (IDPS):** Monitors network traffic for suspicious activities and prevents unauthorized access.
3. **Malware Protection Solutions:** Provides advanced, up-to-date protection against malware, viruses, and APTs.
4. **Patch Management Tools:** Automates patch deployment across systems to address vulnerabilities promptly.
5. **Firewalls:** Protects internal systems by filtering incoming and outgoing traffic based on predefined rules.
6. **Secure Configuration and Hardening Tools:** Ensures systems are configured according to security standards to reduce attack surfaces.
7. **Backup and Recovery Systems:** Ensures availability and integrity of critical data through periodic backups and reliable recovery mechanisms.
8. **Time Synchronization Systems:** Ensures consistent timekeeping across systems using reliable sources like NTP.
9. **SIEM Solutions:** Collects and correlates security event logs to detect and respond to threats effectively.

Examples of KPIs for Information System and Processing Facilities Protection:

1. **Patch Compliance Rate:** Percentage of systems updated with the latest security patches.
 2. **Backup Success Rate:** Percentage of successful backups completed within the defined schedule.
 3. **Mean Time to Detect (MTTD):** Average time taken to identify a cybersecurity incident.
 4. **Mean Time to Respond (MTTR):** Average time taken to resolve a cybersecurity incident.
 5. **System Uptime Rate:** Percentage of uptime for critical systems and facilities.
 6. **Configuration Review Frequency:** Number of configuration reviews conducted for critical systems within a defined period.
 7. **Incident Response Effectiveness:** Percentage of incidents resolved within the agreed SLA.
 8. **Log Review Rate:** Percentage of logs reviewed and analyzed for anomalies.
 9. **Malware Protection Coverage:** Percentage of systems covered by advanced malware protection solutions.
-

Samples of Auditor's Checklist for Information System and Processing Facilities Protection:

1. Are systems and processing facilities protected with advanced malware protection solutions?
 2. Are system configurations reviewed and hardened periodically?
 3. Are backups performed for all critical systems, and are recovery mechanisms tested?
 4. Are patches applied promptly to all systems, including critical ones?
 5. Is a time synchronization system implemented and configured to use a reliable source (e.g., SASO)?
 6. Are logs from critical systems monitored and analyzed periodically for security incidents?
 7. Are external storage media usage policies defined and enforced?
 8. Are there documented procedures for securing session management and timeout mechanisms?
-

Samples of Audit Scenarios for Information System and Processing Facilities Protection:

Scenario 1: Patch Management Audit

- **Objective:** Assess the effectiveness of the patch management process.
- **Steps:**
 1. Review patching records to verify the timely application of patches.
 2. Verify that critical systems are updated as per policy timelines.
 3. Assess integration of patch management with change management procedures.
- **Questions:**
 - Are patches applied within the defined timelines?
 - Are all critical systems included in the patching process?

Scenario 2: Malware Protection Assessment

- **Objective:** Ensure robust malware protection mechanisms are in place.
- **Steps:**
 1. Review configurations of malware protection solutions.
 2. Verify that APT protection is implemented on critical systems.
 3. Assess the periodic review and updates of protection mechanisms.
- **Questions:**
 - Is malware protection implemented across all systems?
 - Are updates to malware protection solutions applied consistently?

Scenario 3: Backup and Recovery Validation

- **Objective:** Evaluate the adequacy of backup and recovery processes.
- **Steps:**
 1. Verify backup frequency and success rates.
 2. Test recovery mechanisms for critical systems.
 3. Review policies for handling backup failures.
- **Questions:**
 - Are backups completed as scheduled?
 - Can critical systems be restored promptly during disruptions?

Scenario 4: Configuration and Hardening Review

- **Objective:** Ensure system configurations align with approved standards.
 - **Steps:**
 1. Review system configurations for compliance with security standards.
 2. Assess the frequency of configuration reviews.
 3. Verify that default credentials and unnecessary services are disabled.
 - **Questions:**
 - Are configuration reviews conducted as per the defined schedule?
 - Are system configurations hardened to reduce vulnerabilities?
-

Case Study 1: Enhancing Information Systems Protection in a Government Organization

Scenario: A government organization faced challenges with outdated system configurations and inadequate malware protection.

Actions Taken:

1. Implemented advanced malware protection across all systems.
2. Conducted regular system configuration reviews and applied hardening measures.
3. Deployed a centralized time synchronization system for all servers.

Outcome: The organization improved its cybersecurity posture and compliance with NCA ECC standards, reducing the risk of cyber threats.

2.4 Email Protection:

Definition: Email Protection involves the implementation of strategies, technologies, and best practices to secure an organization's email systems and communications from cyber threats such as phishing, spam, malware, and advanced persistent threats (APTs). It ensures that email services are safeguarded against unauthorized access, data breaches, and disruptions, thereby maintaining the confidentiality, integrity, and availability of email communications[9], [10].

Objective: To ensure the protection of the organization's email services from cyber risks by deploying advanced security mechanisms, filtering malicious content, enforcing authentication protocols, and periodically reviewing and improving email security measures.

Controls Matrix:

Below is a summary matrix detailing relevant identity and access management controls based on NCA, SAMA CSF, CST CRF, and CMA Cybersecurity Guidelines:

Regulation	Main Controls	Control References
NCA ECC	4	2-4-1, 2-4-2, 2-4-3 (5 sub-controls), 2-4-4
CST CRF	4	4.15.1, 4.15.2, 4.15.3, 4.15.4

Email Protection Controls:

National Cybersecurity Authority - Essential Cybersecurity Controls ECC					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
ECC-2.4.1		Cybersecurity requirements for protecting email service must be defined, documented and approved.	Email Protection Policy Template	Develop and document cybersecurity requirements for protecting email service in the organization, including the following: - Advanced and up-to-date protection techniques and mechanisms, providing them and ensuring their reliability. - Scope of devices to be protected, including all workstations, critical systems in the organization, etc. - Secure copies of the operating systems used in the organization must be built and prepared in a secure manner, protection programs must be installed, and unused services must be disabled. - Such copied must be used in the configuration of desktops and servers. - Workstations and systems in the organization must be periodically scanned against malware.	Cybersecurity policy that covers the requirements of protecting email service at the organization (e.g., electronic copy or official hard copy). Formal approval by the head of the organization or his/her deputy on the policy (e.g., via the organization's official e-mail, paper or electronic signature).

				Use of external storage media and its security must be restricted. Patch management for systems, applications and devices. Central sources of time synchronization in the organization must be defined to be from a reliable source. Support the organization's policy by the Executive Management. This must be done through the approval of the organization head or his/her deputy.	
ECC-2.4.2		The cybersecurity requirements for email service must be implemented.	Secure Configuration and Hardening Policy Template Server Security Policy Template Malware Protection Policy Template Storage Media Policy Template Patch Management Policy Template	Implement all cybersecurity requirements for protecting email service in the organization. This may include the following: Modern and advanced protection techniques and mechanisms availability and reliability must be ensured. The scope of devices to be protected and reviewed periodically must be ensured. Use of external storage media and its security must be restricted. Patches throughout the organization's devices, systems, and applications must be implemented. Central Clock Synchronization and from a reliable source must be implemented.	Documents that confirm the implementation of cybersecurity requirements related to protecting email service as documented in the policy. An up-to-date list of the organization's virus protection systems and the extent of their download. Restrict the use of external storage media and procedures for approving their use. Evidence that the scope of patches covers all

					devices, systems and applications. Evidence that the organization uses a central server and a reliable source for timing synchronization.
ECC-2.4.3 The cybersecurity requirements for protecting the email service must include at the least the following:	ECC-2.4.3.1	Analyzing and filtering email messages (specifically phishing emails and spam) using advanced and up-to-date email protection techniques.		Define and document the requirements of this ECC in the cybersecurity requirements document and approve them by the representative. Define and provide advanced technologies to analyze and filter the organization's emails. Activate analysis and filtering features in the email protection system through the dashboard. Periodically review the list of suspicious emails such as phishing messages, spam messages, etc. through the system by the specialized team to follow up email protection. Add new intrusion indicators related to email in the protection system on an ongoing basis.	A document (such as approved policy or procedure) indicating the identification and documentation of the requirements related to this control. Screenshot or direct example showing subscription and use of modern and advanced technologies to analyze and filter emails in the organization. Screenshot or direct example of the configuration of email to prove the feature of analyzing and filtering emails, including phishing emails and spam emails.
ECC-2.4.3	ECC-2.4.3.2	Multi-factor authentication for remote and webmail		Define and document these requirements in the cybersecurity requirements document, and	

		access to email service, defining authentication factors, number of factors and suitable technique based on the result of impact assessment of authentication failure and bypass.		approve them by the representative. Develop procedures for remote access and organization's webmail access to email service with multi-factor authentication. Use appropriate multi-factor authentication techniques linked to remote access and organization's webmail access technologies. Employ two authentication elements: Something you know (password). Something you have (one-time password via SMS or app). Something you are (biometrics).	
ECC-2.4.3	ECC-2.4.3.3	Email archiving and backup.		Define and document the requirements of this ECC in the cybersecurity requirements of email security at the organization and must be approved by the representative. Define technologies compatible with the organization's technical systems and infrastructure to backup and archive the organization's email. Define retention period for backup and archiving of the organization's email. Perform backup at the level of the organization's email servers. Activate archiving of all email boxes of the organization.	A document (such as approved policy or procedure) indicating the identification and documentation of the requirements related to this control. Screenshot or direct example showing subscription and use of modern and advanced technologies for backup and archiving of email, as well as the approved capacity and duration.

					Backup reports for the organization's email servers. Screenshot or direct example that shows the activation of the email boxes archiving feature.
ECC-2.4.3	ECC-2.4.3.4	Secure management and protection against Advanced Persistent Threats (APT), which normally utilize zero-day viruses and malware.		Define and document the requirements of this ECC in the cybersecurity requirements of email security at the organization and must be approved by the representative. Define and provide advanced technologies within the organization to provide email protection against advanced persistent threats and zero-day malware. Activate features of advanced persistent threats and zero- day malware in the email protection system. Review the list of suspicious emails that have been filtered by the system because they contain advanced persistent threats and zero-day malware. Take necessary measures to protect the device of the recipient of the suspicious email message if it is not blocked by the protection system,	A document (such as approved policy or procedure) indicating the identification and documentation of the requirements related to this control. Screenshot or direct example showing subscription and use of modern and advanced technologies for email ATP protection in the organization. Screenshot or direct example showing email configuration in the organization and the activation of ATP protection.

				and factors and indicators of penetration must be blocked.	
ECC-2.4.3	ECC-2.4.3.5	Validation of the organization's email service domains through Haseen platform by using Sender Policy Framework (SPF), Domain Keys Identified Mail (DKIM), and Domain Message Authentication Reporting and Conformance (DMARC).		Define and document the requirements of this ECC in the cybersecurity requirements of email security at the organization and must be approved by the representative. Create an SPF Record containing servers authorized to send emails to protect the organization from the risk of spoofing. Create DKIM Record, which uses the digital signature in all emails issued by the organization's domain to ensure the integrity of e-mails. Create "Domain-based Message Authentication, Reporting & Conformance (DMARC), which leverages existing email authentication techniques with SPF and DKIM to protect email domains from spoofing attacks. Ensure linking the scope of email with the mail documentation service of Haseen platform.	A document (such as approved policy or procedure) indicating the identification and documentation of the requirements related to this control. Screenshot showing the preparation of the SPF Record, which shows the servers authorized to send email from the organization scope.
ECC-2.4.4		The cybersecurity requirements for email service must be reviewed periodically. [cite: 41]		Review the implementation of cybersecurity requirements for email protection by conducting a periodic assessment (according to a documented and approved plan for	Results of email protection cybersecurity requirements implementation review in the organization

				review, and based on a planned interval "e.g., quarterly") to implement the organization's email protection procedures by the Cybersecurity function and in cooperation with relevant departments (such as IT Department). Conduct application review through traditional channels (e.g., email) or automated channels using a compliance management system. The organization may develop a review plan explaining the cybersecurity requirements implementation review schedule for email protection. Review and update Cybersecurity requirements for email protection in the organization must be reviewed and updated periodically according to a documented and approved plan for review and based on a planned interval or in the event of changes in relevant laws and regulations. Document the review and changes to the cybersecurity requirements for email protection in the organization and approve them by the head of the organization or his/her deputy.	A document that defines the cybersecurity requirements application review cycle for the organization's email protection (Compliance Assessment Schedule). Compliance assessment report that outlines the assessment of the implementation of cybersecurity requirements for the organizations email protection An approved document that sets the policy's review schedule Policy indicating that it has been reviewed and updated, and that changes have been documented and approved by the head of the organization or his/her deputy. Formal approval by the head of the organization or his/her deputy on the updated policy (e.g., via the organization's official
--	--	--	--	--	---

					e-mail, paper or electronic signature).
CST CRF					
Control reference number	Control clauses	Control implementation guidelines			Expected deliverables
4.15.1 (CL1)	Define and document [Requirements for Emails and Web Browser Protection] which consider the following: • Utilization of standardized security mechanisms for email and web browser protection	Develop and document cybersecurity requirements for email and web browser protection in the organization using Email and Web Browser Protection Policy Template. This should include standardized security mechanisms like: - Email filtering for spam and phishing - Multi-factor authentication for email - Secure email backup and archiving - Protection against advanced persistent threats (APTs) - Restrictions on accessing untrusted websites			Documented cybersecurity requirements for email and web browser protection.
4.15.2 (CL1)	Implement the [Requirements for Emails and Web Browser Protection] (e.g., email filtering for spam and phishing protection, multi-factor authentication, backup and archive for emails, protection against Advanced Persistent Threats, untrusted websites).	Implement the defined cybersecurity requirements for email and web browser protection. This may include: - Deploying email filtering solutions to block spam and phishing emails. - Enforcing multi-factor authentication for email access. - Implementing regular email backups and archiving. - Deploying security measures to protect against APTs. - Implementing restrictions on accessing untrusted websites.			Evidence of implementation of the email and web browser protection requirements.
4.15.3 (CL1)	Restrict the access to unauthorized web-based email services (e.g., firewall rules, network based URL filters).	Restrict access to unauthorized web-based email services by implementing: - Firewall rules to block access to specific email services. - Network-based URL filters to block access to known malicious email websites.			Evidence of access restrictions to unauthorized web-based email services.

4.15.4 (CL3)	Continuously measure, review and optimize the [Requirements for Emails and Web Browser Protection].	Continuously measure, review, and optimize the implemented security measures for email and web browser protection. This may include: - Monitoring the effectiveness of email filtering and APT protection. - Reviewing and updating security policies and procedures. - Conducting periodic security assessments and penetration testing.	Documentation of the continuous monitoring, review, and optimization activities.
--------------	---	---	--

Risk Considerations in Email Protection

1. **Phishing Attacks:** Email is one of the most common attack vectors for phishing attempts, which can result in credential theft or the spread of malware.
 2. **Spam and Malicious Emails:** High volumes of spam or malicious emails can clog organizational email systems and expose users to threats such as ransomware or spyware.
 3. **Advanced Persistent Threats (APT):** Sophisticated attackers may use email to deliver zero-day malware or establish footholds within an organization's systems.
 4. **Unauthorized Access:** Weak passwords or the lack of multi-factor authentication (MFA) can lead to unauthorized access to sensitive emails.
 5. **Email Spoofing and Domain Spoofing:** Attackers can impersonate legitimate domains to trick recipients into disclosing sensitive information or performing unauthorized actions.
 6. **Data Loss and Leakage:** Emails containing sensitive or classified information can be intercepted, forwarded, or leaked to unauthorized parties.
 7. **Non-Compliance with Regulations:** Failure to adhere to standards such as NCA, SAMA CSF, or CST guidelines can lead to penalties and reputational damage.
 8. **Lack of Archiving and Backup:** Failure to maintain a secure backup of email records can result in loss of critical data during incidents.
 9. **Human Error:** Mistakenly opening malicious attachments or links can compromise the organization's cybersecurity posture.
-

Examples of Technologies for Effective Email Protection

1. **Email Filtering Solutions:** Tools to filter spam, phishing emails, and malicious content.
 2. **Advanced Threat Protection (ATP):** Solutions to defend against APTs and zero-day threats targeting email systems.
 3. **Multi-Factor Authentication (MFA):** Secure access to email accounts using two or more authentication factors.
 4. **Sender Policy Framework (SPF), DKIM, and DMARC:** Standards for email domain validation to prevent spoofing.
 5. **Email Archiving and Backup Solutions:** Platforms or tools for securing email archiving and backup.
 6. **Encryption Tools:** For securing email content in transit and at rest.
 7. **Security Information and Event Management (SIEM):** To monitor and analyze email-related security incidents.
 8. **Anti-Phishing Tools:** Software that flags suspicious emails and provides real-time training to users.
 9. **Firewall and URL Filtering:** To block access to unauthorized or malicious email services.
 10. **Endpoint Detection and Response (EDR):** To detect and mitigate threats stemming from email attachments or links.
-

Examples of KPIs for Email Protection

1. **Percentage of Spam Emails Blocked:** Measures the efficiency of email filtering solutions.
 2. **Phishing Email Detection Rate:** Percentage of phishing emails successfully identified and quarantined.
 3. **MFA Adoption Rate for Email:** Percentage of users utilizing MFA for email access.
 4. **Email Backup Completion Rate:** Percentage of email backups successfully completed within defined timeframes.
 5. **Email Archiving Coverage:** Proportion of user mailboxes covered under archiving policies.
 6. **Number of Email-Related Security Incidents:** Tracks incidents such as phishing attempts or unauthorized access.
 7. **Mean Time to Detect (MTTD) Email Threats:** Average time taken to identify email-based threats.
 8. **Mean Time to Respond (MTTR) to Email Incidents:** Average time taken to mitigate or resolve email-related incidents.
 9. **Domain Spoofing Prevention Rate:** Percentage of spoofing attempts prevented through SPF, DKIM, and DMARC.
 10. **Compliance Audit Success Rate:** Percentage of audits passed for email security controls.
-

Samples of Auditor's Checklist for Email Protection

1. Are there documented and approved cybersecurity requirements for email protection?
2. Is email filtering enabled for detecting spam, phishing, and malicious emails?
3. Are multi-factor authentication (MFA) mechanisms implemented for email access?
4. Are email archiving and backup solutions in place and functioning correctly?
5. Are SPF, DKIM, and DMARC records configured and validated for email domains?
6. Are advanced persistent threat (APT) protections enabled in email systems?
7. Are periodic reviews conducted for email protection requirements?
8. Is there evidence of user awareness training for identifying phishing attempts?
9. Are email-related security incidents logged, monitored, and resolved promptly?
10. Are access permissions for email systems granted based on least privilege?

Samples of Audit Scenarios for Email Protection

Scenario 1: Phishing Email Detection

- **Objective:** Assess the effectiveness of phishing email detection mechanisms.
- **Steps:**
 1. Review email filtering logs for blocked phishing emails.
 2. Test with simulated phishing emails to measure detection capabilities.
 3. Verify the reporting process for suspicious emails.
- **Questions:**
 - Are phishing attempts effectively detected and blocked?
 - Are employees trained to report phishing emails?

Scenario 2: Email Archiving and Backup

- **Objective:** Verify the implementation of email archiving and backup policies.
- **Steps:**
 1. Review email backup schedules and reports.
 2. Test restoration of archived emails.
 3. Validate compliance with data retention policies.
- **Questions:**
 - Are backups performed as per policy?
 - Are email archives protected against unauthorized access?

Scenario 3: Spoofing Prevention

- **Objective:** Validate domain protection against spoofing attempts.
- **Steps:**
 1. Review SPF, DKIM, and DMARC configurations.
 2. Test email spoofing prevention mechanisms.
 3. Analyze email domain validation logs.
- **Questions:**
 - Are domain spoofing protections enabled and functioning?
 - Are there instances of spoofing attempts bypassing controls?

Case Study 1: Enhancing Email Security in a Government Organization

Scenario: A government agency faced frequent phishing attacks targeting its employees.

Actions Taken:

1. Implemented advanced email filtering tools to detect phishing attempts.
2. Configured SPF, DKIM, and DMARC records via Haseen portal to validate email domains.
3. Mandated MFA for all email accounts.
4. Conducted awareness campaigns on phishing prevention.

Outcome:

- Phishing email detection improved by 85%.
 - Domain spoofing attempts were entirely blocked.
 - Employee awareness reduced the rate of successful phishing attacks.
-

Case Study 2: Email Protection for a Financial Institution

Scenario: A bank identified gaps in email backup and archiving, leading to compliance challenges.

Actions Taken:

1. Deployed secure email archiving and backup solutions.
2. Conducted periodic reviews of email security policies.
3. Integrated ATP protection into the email system to mitigate malware risks.

Outcome:

- Full compliance with SAMA CSF and NCA ECC.
- Backup success rates reached 99%.
- APT-related incidents reduced by 70%.

Case Study 3: Strengthening Email Security in a Healthcare Organization

Scenario: A healthcare organization faced multiple email-based ransomware attacks, jeopardizing sensitive patient data and disrupting operations.

Actions Taken:

1. Implemented advanced email filtering and ATP solutions to block malicious emails and ransomware.
2. Enabled MFA for all employees accessing email services, including webmail and remote access.
3. Established a robust email backup and recovery process to restore email services during incidents.
4. Conducted organization-wide awareness training for staff to identify phishing emails and avoid clicking on suspicious links or attachments.
5. Validated the organization's email domains using SPF, DKIM, and DMARC to prevent spoofing and unauthorized use of its domain.

Outcome:

- Ransomware attacks via email were reduced by 95%.
- Recovery time for email services during incidents decreased from 72 hours to less than 12 hours.
- Employees reported an 80% increase in correctly identifying and reporting phishing attempts.
- The organization's email domain became fully compliant with security standards, ensuring secure communication with external partners.

2.5 Network Security Management:

Definition: Network Security Management encompasses the strategies, technologies, policies, and practices implemented to safeguard an organization's network infrastructure and its associated resources from cyber threats. This domain focuses on the confidentiality, integrity, and availability of network services, preventing unauthorized access, disruption, and exploitation of network assets. Network security management ensures secure communication, segmentation, and resilience against both external and internal threats [11], [12], [13].

Objective: To ensure the protection and resilience of the organization's network infrastructure against cyber risks by implementing robust security measures, maintaining effective monitoring, and enforcing access controls, thereby enabling secure and efficient network operations.

Controls Matrix:

Below is a summary matrix detailing relevant network security management controls based on NCA Controls, SAMA CSF, CST CRF, and CMA Cybersecurity Guidelines:

Regulation	Main Controls	Control References
NCA ECC	4	2-5-1, 2-5-2, 2-5-3 (9 sub-controls), 2-5-4
SAMA CSF	-	-
CTS CRF	15	4.5.1 through 4.5.15
CMA CSG	-	-
NCA CSCC	1	2-4-1 (9 sub-controls)
NCA CCC CST	1	2-4-T-1 (1 sub-control)
NCA CCC CSP	1	2-4-P-1 (6 sub-controls)
NCA TCC	1	2-4-1 (4 sub-controls)
NCA DCC	-	-
NCA OSMACC	-	-
NCA OTCC	2	2-4-1 (16 sub-controls), 2-4-2

Network Security Management Controls:

National Cybersecurity Authority - Essential Cybersecurity Controls ECC					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
ECC-2.5.1		Cybersecurity requirements for network security management must be defined, documented and approved.	Network Security Policy Template	Develop and document cybersecurity policy for network security in the organization, including the following: Network Access Requirements Third Parties Access Requirements to the Network Network Protection Requirements Physical and environmental security requirements to ensure that network devices are stored in a secure and appropriate environment. Security technology standard controls for all network devices used within the organization must be defined, documented and approved. Support the organization's policy by the Executive Management. This must be done through the approval of the organization head or his/her deputy.	Network security management policy approved by the organization (e.g., electronic copy or official hard copy). Cybersecurity policy that covers the requirements of technical security standard controls and network security management in the organization (e.g., electronic copy or official hard copy). Formal approval by the head of the organization or his/her deputy on the policy and technical standard (e.g., via the organization's official e-mail, paper or electronic signature).

ECC-2.5.2		The cybersecurity requirements for network security management must be implemented.	Implement all cybersecurity requirements for network security in the organization, including the following: Ensure physical or logical segregation and division of the organization's network parts. Use Firewall to protect the organization's networks. Implement the principle of multi-stage security defense (Defense-in-Depth) to provide advanced and more effective protection for the organization's network devices. Isolate the production environment network from the development and testing networks of the organization. Ensure security of navigation and internet connection in the organization, including setting up network devices and restricting access to suspicious websites. Protect the internet browsing channel from advanced persistent threats. Ensure the security and protection of wireless networks at the organization. Ensure the security of the organization's network ports, protocols, and services restrictions and management. Use advanced protection systems to detect and prevent intrusions in the organization's networks. Ensure the security of the organization's DNS. Establish procedures to ensure the continuous implementation of cybersecurity requirements adopted for the organization's network security management in accordance with the relevant laws and regulations.	An action plan to implement the cybersecurity requirements of information and technology assets management. Sample showing the implementation of the organization's network management controls, including but not limited to: Sample that shows the organization's use of modern technologies for security management, as well as restrictions and management of ports, protocols and services. Sample that shows network configuration to prevent critical systems from being connected to the organizations wireless network. Sample showing implementation of logical isolation between production environment network, test environment network, and other networks. Sample of defined and approved procedures for handling critical network devices and systems of the organization.
ECC-2.5.3	ECC-2.5.3.1	Logical or physical segregation and	Define and document the requirements of this ECC in the cybersecurity requirements of network security	Cybersecurity policy that covers the requirements of

The cybersecurity requirements for network security management must include at least the following:		segmentation of network segments using firewalls and defense-in-depth principles.	management at the organization and must be approved by the representative. Define network zones based on trust level e.g., trust in the internet zone is "low", trust level in an internet-isolated zone hosting databases is "high". Define necessary procedures to ensure the physical or logical isolation and segregation of network parts in the organization (for example but not limited to procedures for using the internal virtual network to isolate network parts). Activate appropriate and advanced technologies for the safe physical or logical isolation and segregation of network parts, including but not limited to: Firewall Isolation. Isolation for systems accessed from outside the organization in a neutral zone (DMZ). Insulation of network parts via VLAN. Implement the principle of multi-stage security defense (Defense-in-Depth), which includes the implementation of technical controls and administrative controls for protection.	network security management in the organization (e.g., electronic copy or official hard copy). Formal approval by the head of the organization or his/her deputy on the policy (e.g., via the organization's official e-mail, paper or electronic signature).
ECC-2.5.3	ECC-2.5.3.2	Network segregation between production, test and development environments.	Define and document the requirements of this ECC in the cybersecurity requirements of network security management at the organization and must be approved by the representative. Network domains must be logically separated to clarify production environment network addresses and development and testing environment networks (e.g., using VLANs). Network must be configured to ensure that production environment networks are isolated from development and testing environment networks through the use of firewall systems. Network segregation and network diagram must be documented to illustrate the isolation of production	Cybersecurity policy that covers all the requirements of network security management in the organization (e.g., electronic copy or official hard copy). Formal approval by the head of the organization or his/her deputy on such requirements (e.g., via the organization's official e-mail, paper or electronic signature). List of server

			environment networks from development and testing networks.	addresses in production environment and development and testing environment. An up-to-date network diagram document that shows logical segregation and clarifies the isolation between the production environment network from the development and testing networks.
ECC-2.5.3	ECC-2.5.3.3	Secure browsing and Internet connectivity including restrictions on the use of file storage/sharing and remote access websites, and protection against suspicious websites.	Define and document the requirements of this ECC in the cybersecurity requirements of network security management at the organization and must be approved by the representative. Define necessary procedures to ensure navigation and internet connection security at the organization, including but not limited to: Procedures for restriction of suspicious websites, file sharing and storage sites, and remote access sites. Configuration of firewall systems to connect by using Proxy to analyze and filter data transmitted to and from the organization.	Cybersecurity policy that covers all the requirements of network security management in the organization (e.g., electronic copy or official hard copy). Formal approval by the head of the organization or his/her deputy on such requirements (e.g., via the organization's official e-mail, paper or electronic signature). Sample showing the implementation of requirements related to browsing and internet connection security, including but not limited to: Sample showing the implementation of browsing and internet connection security

					requirements (e.g., screenshot showing evidence of use of modern and advanced technologies for browsing and internet connection security)Sample showing the implementation of the requirements of appropriate and advanced technologies for browsing and internet connection security (e.g., a screenshot showing evidence that the network settings and firewall systems are conducted and configured to ensure security of browsing and internet connection, evidence of restriction of suspicious websites, file sharing and storage sites, remote access sites)
ECC-2.5.3	ECC-2.5.3.4	Wireless network protection using strong authentication and encryption techniques. A comprehensive risk assessment and management exercise must be conducted to assess	Wireless Network Security Standard Template.	Define and document the requirements of this ECC in the cybersecurity requirements of network security management at the organization and must be approved by the representative.Implement security requirements of wireless networks in the organization, which may	Wireless Security Standard approved by the organization (e.g., electronic copy or official hard copy).Sample showing the implementation of wireless network security and protection requirements, including but not limited to:Sample showing the implementation of wireless network security and

		and manage the cyber risks prior to connecting any wireless networks to the organization's internal network.		include the following:Appropriate and advanced technologies for wireless network security and protection.Verification of username and connect the wireless network to the user's name before granting the user access to the wireless network.Separation of the internal network (LAN) from the wireless network by isolating the two networks from each other, as well as isolating the wireless visitor network from the wireless network of the organization.Encrypt wireless communication by configuring wireless network devices to support the highest cryptography standard controls and in line with the relevant laws and regulations.Conduct of a thorough study of the risks arising from connecting wireless networks to the organization's internal network in case there is a need to link them, and deal with them in a way that	protection requirements (e.g., a screenshot showing evidence of subscription and use of modern and advanced technologies to implement wireless network security and protection, including but not limited to wireless network connection cryptography, as well as configuration of network devices and firewall systems in line with the verification of the users name before granting the access to connect to the organization's wireless network).Sample of conducting a thorough study of the risks arising from connecting wireless networks to the organization's internal network in case there is a need to link them, and deal with them in a way that ensures the protection of the organization's technical assets. There must be evidence of risk analysis and study, including but not limited to, providing a thorough report that includes identifying and classifying risks, notes, and remediation
--	--	--	--	--	--

				ensures the protection of the organization's technical assets. There must be evidence of risk analysis and study, including but not limited to, providing a thorough report that includes identifying and classifying risks, notes, and remediation plan (e.g., through an advanced automation program or an Excel sheet).	plan (e.g., through an advanced automation program or an Excel sheet).Sample of separating the internal network (LAN) from the wireless network by isolating the two networks from each other, as well as isolating the wireless visitor network from the wireless network of the organization.
ECC-2.5.3	ECC-2.5.3.5	Management and restrictions on network services, protocols and ports.	Define and document the requirements of this ECC in the cybersecurity requirements of network security management at the organization and must be approved by the representative.Implement the requirements of restrictions and management of network ports, protocols and services at the organization, which may include the following:Appropriate and advanced technologies for restrictions and management of network ports, protocols and services.Procedures for managing ports, protocols, network services and access authorities.Restrict unused ports and protocols in the organization, including but not limited to:Restriction by firewall systems.Physical closure of unused ports.Regularly review and update of protection systems configuration, including but not limited to:Periodic review at least on an annual basis.Development of all technical controls and standard controls that are reviewed and verified with relation to the configuration of protection systems		Cybersecurity policy that covers all the requirements of network security management in the organization (e.g., electronic copy or official hard copy).Formal approval by the head of the organization or his/her deputy on such requirements (e.g., via the organization's official e-mail, paper or electronic signature).Sample showing the implementation of requirements related to network ports, protocols, and services restrictions and management, including but not limited to:Sample showing the implementation

			within an advanced automation program or through Excel Sheet program, and monitor and update them, if necessary, after obtaining the prior approval of the representative. Establishment of approval procedures to update the Firewall Rules to ensure that no update or change is made without the approval of the representative.	of network ports, protocols, and services restrictions and management requirements (e.g., screenshot showing evidence of subscription and use of modern and advanced technologies to apply restrictions and manage network ports, protocols, and services through firewall system). Sample showing the periodic review of the protection systems configuration and updates on an ongoing basis, including but not limited to periodic review at least on an annual basis, as well as the development of all technical controls and standard controls that are reviewed and verified with relation to the protection systems configuration within the advanced automation program or through Excel Sheet. This is in addition to supporting the review by obtaining prior approval for review and update of the configuration, if necessary. Sample showing
--	--	--	--	---

				approval procedures form to update the Firewall Rules to ensure that no update or change is made without obtaining the approval of the representative. In addition, a sample showing what has been updated on the Firewall Rules.
ECC-2.5.3	ECC-2.5.3.6	Intrusion Prevention Systems (IPS).	Define and document the requirements of this ECC in the cybersecurity requirements of network security management at the organization and must be approved by the representative. Implement the requirements of advanced protection systems to detect and prevent intrusions in the organization, which may include the following: Intrusion Prevention System. Appropriate and advanced technologies for Intrusion Prevention System. Protect the organization by using (IPS/IDS) to cover all infrastructure of the organization, including: Internal Network. DMZ. Wireless network. Periodically review (IPS/IDS) configurations, and all technical controls and standard controls that are reviewed and verified with relation to the configuration of (IPS/IDS) within an advanced automation program or through Excel Sheet, must be developed, followed up and updated, if necessary, with the prior approval of the representative.	Cybersecurity policy that covers all the requirements of network security management in the organization (e.g., electronic copy or official hard copy). Formal approval by the head of the organization or his/her deputy on such requirements (e.g., via the organization's official e-mail, paper or electronic signature). Sample showing the implementation of requirements related to (IPS/IDS), including but not limited to: Sample showing the implementation of (IPS/IDS) (e.g., a screenshot showing evidence of subscription and use of modern and advanced technologies to implement

				(IPS/IDS), as well as access to technical infrastructure, demonstrating the use of (IPS/IDS) and the comprehensiveness of all the organization's information and technology assets within (IPS/IDS) Periodic review report on IPS/IDS configuration and development of all technical controls and standard controls must be reviewed and verified in relation to the configuration of (IPS/IDS) within an advanced automation program or through Excel Sheet, as well as supporting the review by obtaining prior approval for review and update of the configuration if required.
ECC-2.5.3	ECC-2.5.3.7	Security of Domain Name Service (DNS) through Haseen platform.	Define and document the requirements of this ECC in the cybersecurity requirements of network security management at the organization and must be approved by the representative. Use DNS Security or DNS Firewall to protect the organization's systems against DNS Poisoning attacks and use documented DNS. Refrain from using public domain name services such as Google DNS or service provider domain names.	Cybersecurity policy that covers all the requirements of network security management in the organization (e.g., electronic copy or official hard copy). Formal approval by the head of the organization or his/her deputy on such requirements (e.g., via the

				organization's official e-mail, paper or electronic signature). Screenshot showing domain name configuration at the organization (DNS) indicating the use of a documented DNS address. Screenshot of DNS Security that indicates IP range protection at the organization.
ECC-2.5.3	ECC-2.5.3.8	Secure management and protection of Internet browsing channel against Advanced Persistent Threats (APT), which normally utilize zero-day viruses and malware.	Define and document the requirements of this ECC in the cybersecurity requirements of network security management at the organization and must be approved by the representative. Implement the requirements of internet browsing channel APT Protection in the organization, which may include the following: Internet browsing channel APT Protection. Appropriate and advanced technologies Internet browsing channel APT Protection and ensure the effectiveness of these technologies. Implement internet browsing channel APT Protection by using advanced systems and technologies to protect against the risk of Zero-Day Malware, including, but not limited to, subscribing to and securely managing an APT Protection provider.	Cybersecurity policy that covers all the requirements of network security management in the organization (e.g., electronic copy or official hard copy). Formal approval by the head of the organization or his/her deputy on such requirements (e.g., via the organization's official e-mail, paper or electronic signature). Sample showing the implementation of the requirements related to Internet browsing channel APT Protection, including but not limited to: Sample showing the implementation of the requirements of Internet browsing channel

				APT Protection (e.g., a screenshot showing evidence subscription and use of modern and advanced technologies to implement Internet browsing channel APT Protection and evidence of the APT Protection against zero-day malware.
ECC-2.5.3	ECC-2.5.3.9	Protecting against Distributed Denial of Service (DDoS) attacks to limit risks arising from these attacks.	Define and document the requirements of this ECC in the cybersecurity requirements document and approve them by the representative. Provide DDoS protection techniques and mechanisms, including the following: Ensure that the technologies used are current and advanced. Determine the domain of the assets on which the protection system will be installed and identify and update their status. Install the protection system throughout the workstations, systems and servers of the organization. Review the protection system periodically to ensure that the scope of the protection system is comprehensive for all workstations, systems, and servers of the organization through the protection system's control unit. Develop and implement a remediation action plan (when needed) to install the protection system on all devices while taking action against devices and systems where it is frequently observed that the modern and advanced protection system is not installed. Follow up on the protection system periodically to ensure updates are installed and released on all workstations, systems and servers of the organization.	Documents indicating the identification and documentation of the requirements of this ECC in the policies or procedures of the organization approved by the representative. List of DDoS systems and evidence of protection against DDoS (including but not limited to a screenshot or direct example from the DDoS Monitoring page of the protection system). Reports or evidence of installing the protection technologies across all workstations, systems and servers of the organization. Reports or evidence of following-up the scope of installing and periodic updating of these technologies.

ECC-2.5.4	The cybersecurity requirements for network security management must be reviewed periodically.	Review the cybersecurity requirements of network security in the organization by conducting a periodic assessment (according to a documented and approved plan for review, and based on a planned interval "e.g., quarterly") to implement network security management requirements by the Cybersecurity function and in cooperation with relevant departments (such as IT Department).Conduct application review through traditional channels (e.g., email) or automated channels using a compliance management system.The organization may develop a review plan explaining the implementation of cybersecurity requirements to network security management in the organization.Review and update cybersecurity requirements for network security management in the organization periodically according to a documented and approved plan for review and based on a planned interval or in the event of changes in relevant laws and regulations.Document the review and changes to the cybersecurity requirements for network security in the organization and approve them by the head of the organization or his/her deputy.	Results of network security cybersecurity requirements implementation review in the organization.An approved document that defines the cybersecurity requirements implementation review cycle to manage the organization's network security (Compliance Assessment Schedule).Compliance assessment report that outlines the assessment of the implementation of cybersecurity requirements for the organization's network security.An approved document that sets the policy's review schedule.Policy indicating that it has been reviewed and updated, and that changes have been documented and approved by the head of the organization or his/her deputy.Formal approval by the head of the organization or his/her deputy on the updated policy (e.g., via the organization's official e-mail, paper or electronic signature).
National Cybersecurity Authority – Critical Systems Cybersecurity Controls CCCC			

Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
CSCC-2.4.1 In addition to the sub-controls within Control 3-5-2 in the Basic Controls of Cybersecurity, the cybersecurity requirements for managing the security of networks of critical systems of the entity must cover, at a minimum, the following:	CSCC-2.4.1.1	Logically and/or physically segregating and isolating critical systems' networks.	Network Security Policy Template Network Security Standard Template • Wireless Network Security Standard Template Network Detection and Response Standard Template	the application of isolation and physical or logical division of the network of critical systems, for example: Isolation using a firewall. Isolation of critical systems that are accessed from outside the entity in a neutral zone (DMZ). Isolation of network segments of critical systems by means of a virtual internal network (VLAN). Work to prevent critical systems from being connected to the Internet if these provide an internal service to the entity and there is no need to access the systems service from outside the entity. Work on adjusting firewall menu settings so that all types of communications between network parts of critical systems are automatically blocked (Explicitly), and firewall menus are made available based on user request and business	Planning and drawing the infrastructure of critical systems networks. Lists firewall for critical systems and other security configuration for networks review firewall configuration and lists; Every six months, at least.

				requirements and reviewed periodically.	
CSCC-2.4.1	CSCC-2.4.1.2	Review the firewall settings and lists every six months, at least.	Network Security Policy Template Network Security Standard Template • Wireless Network Security Standard Template Network Detection and Response Standard Template	Work on reviewing firewall settings and lists at least every six months for the firewall of critical systems networks, for example but not limited to: Review unused/activated lists within the last 90 days to be deleted and disabled. Update settings according to recent resource versions. Arrange lists according to effectiveness and performance. Review and analyze VPN lists. Documenting the audit results to include, but not be limited to: Changes after review. Review date. Accreditation.	Report of reviewing firewall configuration for critical systems in the entity (evaluation table).
CSCC-2.4.1	CSCC-2.4.1.3	Prevent direct connection of any device to the local network for critical systems; Only after examining, and ensuring the availability of the verified protection elements, for the	Network Security Policy Template Network Security Standard Template Wireless Network Security Standard Template • Network Detection and Response Standard Template	Work on providing systems to manage access control devices for networks, for example: Network Access Control (NAC). Work on developing procedures, to check devices and directly connect any device to the local network for critical systems after examining it using tools to scan and detect malicious software approved by the entity (End-	Document procedures for secure connection of critical systems to the local network. • Proof showing the restrictions in place to ensure direct connection is prevented.

		acceptable levels of critical systems.		point protection solutions) and ensure the availability of protection elements that achieve the acceptable level of critical systems, for example: Ensure that protection technologies and mechanisms are capable of detecting all types of malicious software (such as Viruses, Trojan Horses, Worms, Spyware, Adware, and Rootkits) (Root Kits) and other malwares.	
CSCC-2.4.1	CSCC-2.4.1.4	Prevent critical systems from connecting to the wireless network.	Network Security Policy Template Network Security Standard Template• Wireless Network Security Standard Template• Network Detection and Response Standard Template	Work on developing procedures to prevent critical systems from connecting to the wireless network, for example: Isolate the network of critical systems from the rest of the networks in the organization. Adjust configuration for critical systems or configuration for security technologies to prevent access to the wireless network.	Document prevention procedures for critical systems from connecting to the wireless network. A guide showing setting critical systems configuration to prevent connection to the wireless network.
CSCC-2.4.1	CSCC-2.4.1.5	Network Advanced persistent threat.	• Network Security Policy Template Network Security Standard Template	Work to provide protection systems from advanced persistent threats at the network level (Network APT) and update them continuously, for example:	A list of all available APT protection systems for critical systems.

			Wireless Network Security Standard Template Network Detection and Response Standard Template	Provide advanced protection systems to detect and prevent intrusions such as ((Intrusion Prevention/Detection Systems (IDS/IPS, HIDS/HIPS)) on all parts of the network and update them continuously.	
CSCC-2.4.1	CSCC-2.4.1.6	Preventing critical systems from connecting to the Internet if they provide an internal service to the entity; There is no very necessary need to access the service from outside the entity.	Network Security Policy Template Network Security Standard Template• Wireless Network Security Standard Template Network Detection and Response Standard Template	Work on developing procedures to prevent the connection of critical systems, for example: Work with the concerned departments to identify critical systems that do not require access to a service from outside the entity. Working on adjusting network configuration to isolate internal critical systems from Internet connection, for example, but not limited to: adjusting firewall configuration to prevent communication or network design that completely isolates critical systems from Internet connection.	Procedures document for isolating critical systems on the Internet document. Configuration applied at the level of network devices and servers that indicate that access to the Internet is prohibited.
CSCC-2.4.1	CSCC-2.4.1.7	Provision of critical systems services, through networks independent of the Internet, in the event	Network Security Policy Template• Network Security Standard Template• Wireless Network Security	Working to develop procedures for providing critical systems services that are provided to limited parties via networks independent of the Internet, for example but	Document the procedures for providing critical systems services. A guide explaining the settings applied at the level of network devices and servers, which describes

		that the services of those systems are directed to limited parties; Not for individuals.	Standard TemplateNetwork Detection and Response Standard Template	not limited to:Work with the concerned departments to identify critical systems that provide services outside the entity.Work to provide security solutions to provide services to limited parties securely, including but not limited to: Site-to-Site VPN.	communication through independent networks.
CSCC-2.4.1	CSCC-2.4.1.8	Distributed Denial of Service Attack "DDoS"	- Network Security Policy - Standard TemplateNetwork Security Standard TemplateWireless Network Security Standard TemplateNetwork Detection and Response Standard TemplateProtection against Distributed Denial of Service (DDoS) attacks Standard template	Working to provide protection systems against network disruption attacks (Distributed Denial of Service Attack "DDoS") on critical systems and updating them continuously.Adjust firewall settings to protect against Distributed Denial of Service Attacks (DDoS).Working to apply the principle of multiple availability (High Availability) to the entity's critical systems that provide an external service, including, but not limited to: firewall systems, Web proxy systems.Work on concluding an agreement with the service provider or Internet service provider to implement mechanisms and ensure protection against network disruption attacks	Systems and technologies to protect against network disruption attacks for critical systems.List of Distributed Denial of Service Attack "DDoS" configuration and controls.

				(Distributed Denial of Service Attack "DDoS").	
CSCC-2.4.1	CSCC-2.4.1.9	Allow whitelisting only for firewall lists for critical systems.	•Network Security Policy Template - Network Security Standard Template - Wireless Network Security Standard Template - Network Detection and Response Standard Template	Develop whitelisting only for firewall lists for critical systems and reviewing them frequently. Work on adjusting the firewall list settings so that all types of communications between network parts are automatically blocked (Explicitly), and firewall lists are made available based on user request and business requirements and reviewed periodically.	A list showing the specific permissions for firewall lists for critical systems.
National Cybersecurity Authority - Telework Cybersecurity Controls TCC					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
TCC-2.4.1 In addition to the sub-controls in the ECC control 2-5-3, cybersecurity requirements of telework systems' network security	TCC-2.4.1.1	Restrictions on network services, protocols and ports used to access remotely, specifically to internal systems and to only be opened based on need.	Network security policy Network security standard	Work on defining the requirements for this control, document them in the cybersecurity requirements document, and have them approved by the authority holder. Implement the requirements of restrictions on network services, protocols and ports used to access remotely by using appropriate and	A document that identifies and documents the requirements of this control (such as a policy and/or procedure approved by the authority holder).Sample showing the implementation of requirements related to network services, protocols, and ports restrictions, including but not limited to:Template showing the

management must include at least the following:				advanced technologies including but not limited to restriction by firewall systems. Establishment of approval procedures to update the Firewall Rules to ensure that no update or change is made without the approval of the representative.	implementation of network services, protocols, and ports restrictions requirements (e.g., screenshot showing evidence of subscription and use of modern and advanced technologies to apply restrictions network services, protocols, and ports through firewall system)
TCC-2.4.1	TCC-2.4.1.2	Reviewing firewall rules and configurations, at least once every year.	Network security policy Network security standard	Work on defining the requirements for this control, document them in the cybersecurity requirements document, and have them approved by the authority holder. Work on reviewing firewall settings, lists and rules related to telework systems; At least once a year, for example but not limited to: Review unused/activated lists within the last 90 days to be deleted and disabled. Update settings according to recent resource versions. Arrange lists according to effectiveness and performance. Review and analyze VPN lists	A document that identifies and documents the requirements of this control (such as a policy and/or procedure approved by the authority holder).Review report of firewall settings for sensitive systems in the entity (evaluation table).Documented process to periodic review of firewall rules & configurations.

				Documenting the audit results to include, but not be limited to: Changes after review. Review date. Accreditation	
TCC-2.4.1	TCC-2.4.1.3	Protecting against Distributed Denial of Service Attack (DDoS) attacks to limit risks arising from these attacks.	Network security policy Network security standard Protection against Distributed Denial of Service (DDoS) attacks Standard template	Work on defining the requirements for this control, document them in the cybersecurity requirements document, and have them approved by the authority holder. Provide protection systems from Distributed Denial of Service Attacks (DDoS) on telework systems to reduce the risks resulting from network disruption attacks and update them on an ongoing basis. Adjust firewall settings to protect against Distributed Denial of Service Attacks (DDoS). Apply the principle of multiple availability (High Availability) to the entity's telework systems, including, but not limited to: firewall systems, web proxy systems. Work on concluding an agreement with the service provider or Internet service provider to implement mechanisms and	A document that identifies and documents the requirements of this control (such as a policy and/or procedure approved by the authority holder). Systems and techniques for protecting against network disruption attacks on telework systems. A list of settings and controls for protection against network disruption attacks (Distributed Denial of Service Attack "DDoS").

				ensure protection against network disruption attacks (Distributed Denial of Service Attack "DDoS").	
TCC-2.4.1	TCC-2.4.1.4	Protecting against Advanced Persistent Threats (APT) at the network layer.	Network security policyNetwork security standardAdvanced Persistent Threats (APT) Standard Template	Work on defining the requirements for this control, document them in the cybersecurity requirements document, and have them approved by the authority holder.Working to provide protection systems against advanced persistent threats at the network level for telework systems (Network APT) and updating them continuously, for example but not limited to:Provide advanced protection systems to detect and prevent intrusions, such as: Intrusion Prevention/Detection Systems (IDS/IPS, HIDS/HIPS) on all parts of the network and updating them continuously.Update continuous monitoring procedures at the network level to protect against threats.	A document that identifies and documents the requirements of this control (such as a policy and/or procedure approved by the authority holder).A list of all systems available to protect against advanced persistent threats to teleworking systems.Documented procedures for continuous monitoring, as well as applying and using advanced persistent threat protection tools.
National Cybersecurity Authority – Operational Technology Cybersecurity Controls OTCC					

Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
OTCC-2.4.1 In addition to subcontrols in ECC control 2-5-3, cybersecurity requirements for network security management in OT/ICS environment must cover, at a minimum, the following:	OTCC-2.4.1.1	OT/ICS environment must be segmented logically or physically from other environments or networks.	Template for Cybersecurity Operational Technology PolicyTemplate for OT/ICS Security Standard Data Diode Standard Template for Network Security PolicyTemplate for Network Security Standard	Implement logical or physical OT/ICS segmentation from other networks (e.g., VLANs, next-generation firewalls, Data diode).Verify and ensure that assets in the OT/ICS environment are not reachable from other environments or networks.	Network diagrams confirming the segmentation. Site visit to check the logical or physical segmentation of OT/ICS networks from other networks.
	OTCC-2.4.1.2	Different zones within the OT/ICS environment must be segmented logically or physically in accordance with the zone's appropriate level that isolates data flows and directs traffic to "Choke Points".	Template for Cybersecurity Operational Technology PolicyTemplate for OT/ICS Security StandardTemplate for Network Security PolicyTemplate for Network Security Standard	Ensure that the diagrams show the high level architecture including the zones within the OTICS/ environment, and the connection between the IT corporate network and the OT/ICS network.Implement logical or physical OT/ICS segmentation between OT/ICS zones using e.g. VLANs and next-generation firewalls.	Network diagrams illustrating the segmentationSite visit to check that all O'T/ICS zones are segmented logically or physically from other environments or and that the traffic directs to "Choke Points".
	OTCC-2.4.1.3	Safety Instrumented Systems (SIS) must be segmented logically	Template for Cybersecurity Operational	Ensure Safety Instrumented Systems (SIS) are stand-alone and segmented logically or	Network diagrams illustrating the segmentation.Site visit to check that all Safety

		or physically from other OT/ICS networks.	Technology PolicyTemplate for OT/ICS Security StandardTemplate for Network Security PolicyTemplate for Network Security Standard	physically from other OT/ICS networks.Verify and ensure that the network diagram clearly shows the Safety Instrumented Systems (SIS) segmentation.	Instrumented Systems (SIS) are segmented logically or physically.
	OTCC-2.4.1.4	Wireless technologies (such as WiFi-, Bluetooth, cellular, satellite, etc.) must be restricted, and to only be used when the technology meets specific business requirements and is properly secured.	Template for Cybersecurity Operational Technology PolicyTemplate for OT/ICS Security StandardTemplate for Network Security PolicyTemplate for Network Security Standard	Restrict wireless technologies usage (e.g., Wi-Fi, Bluetooth, Cellular, Satellite, etc.).Define and document the business justifications and requirements for wireless technologies usage.Definedocument, and implement wireless technologies usage requirements and principles.Verify and ensure that all deployed wireless technologies are in line with documented requirements and principles.	The business justifications and requirements for wireless technologies usage.A document that demonstrates wireless technologies usage requirements and principles.Site visit to ensure that wireless technologies usage are restricted and in line with documented requirementsand principles.
	OTCC-2.4.1.5	Wireless technologies must be segmented logically or physically from other OT/ICS networks.	Template for Cybersecurity Operational Technology PolicyTemplate for OT/ICS Security StandardTemplate for Network Security	Identify the list of the wireless technologies used.Implement logical or physical segmentation between wireless technologies and other OT/ICS networks (e.g. VLANs, next-generation firewalls).Verify and ensure	List of the wireless technologies used.Network diagrams illustrating the segmentation.Site visit to check that all wireless technologies are segmented logically or physically from other OT/ICSnetworks.

			PolicyTemplate for Network Security Standard	that wireless technologies do not interact with other environments or networks related to OT/ICS.	
	OTCC-2.4.1.6	Network communications, services, and connection points between different zones must be limited to the minimum to meet operational, maintenance, and safety requirements.	Template for Cybersecurity Operational Technology PolicyTemplate for OT/ICS Security StandardTemplate for Network Security PolicyTemplate for Network Security Standard	Managing firewall rules to restrict network communications, services, and connection points between different zones and limiting them to the minimum necessary, to meet operational, maintenance, and safety requirements.	Site visit to check that network communications, services, and connection points between different zones are limited to the minimum while meeting operational, maintenance, and safety requirements.
	OTCC-2.4.1.7	Direct exposure of common remote authentication and access management services on external-facing hosts must be prevented.	Template for Cybersecurity Operational Technology PolicyTemplate for OT/ICS Security StandardData Diode StandardTemplate for Network Security PolicyTemplate for Network Security Standard	Avoid direct access to authentication services by e.g. disabling services on external-facing hosts.Verify and ensure that direct exposure of common remote authentication and access management services on all external-facing hosts is prevented.	Network diagrams illustrating the segregation and segmentation clearly of OT/ICS environment from other environments.
	OTCC-2.4.1.8	Only authorized business-critical services are	Template for Cybersecurity Operational	Conduct risk assessment to ensure that the risks are monitored and	Risk assessment.Site visit to check that the obsolete systems are only used for

		accessible from the internal OT/ICS networks, and accessibility to services with known vulnerabilities must be limited to the greatest extent possible.	Technology PolicyTemplate for OT/ICS Security StandardTemplate for Network Security PolicyTemplate for Network Security Standard	controlled.Ensure that the obsolete systems are only used for authorized business-critical services with applying compensating controls such as (delete unwanted services, restrict the access to these systems, manage the account to certain list of users).	authorized business-critical services with applying compensating controls.
	OTCC-2.4.1.9	Direct communications between corporate zone and OT/ICS zones must be prevented, and direct all the required connections through dedicated, secured, and hardened jump host/solution in the DMZ zone.	Template for Cybersecurity Operational Technology PolicyTemplate for OT/ICS Security StandardData Diode StandardTemplate for Network Security PolicyTemplate for Network Security Standard	Prevent direct communications between corporate zone and OT/ICS zones.In case there is a need to send data to the corporate zone, direct all the required connections through dedicated, secured, and hardened jump host/solution in the DMZ zone.	Network diagrams confirming that the DMZ zone is utilized.Site visit to check that all the required connections between corporate zone and OT/ICS zones are going through dedicated, secured, and hardened jump host/solution in the DMZ zone.
	OTCC-2.4.1.10	Remote access point in the DMZ zone must not be connected to the OT/ICS networks unless needed, while ensuring that the	Template for Cybersecurity Operational Technology PolicyTemplate for OT/ICS Security StandardTemplate for Network Security	Ensure that the remote access point in the DMZ zone is not being connected to the OT/ICS networks unless needed.Define a procedure in case there is a need to connect to the OT/ICS networks from the DMZ zone	Site visit to check that remote access point in the DMZ is not connected to the OT/ICS networks without need.Approved remote sessions procedure.A proof that in case remote sessions are needed, they are multi-

		session is multi-factor authenticated, recorded, and established for a defined period of time only.	PolicyTemplate for Network Security Standard	through remote access point, the procedure must include at least these requirements: O The session is multi-factor authenticated. The session is recorded. O The established session has a defined period of time.	factor authenticated, recorded, and established for a defined period of time only.
	OTCC-2.4.1.11	Proxies must be employed between the corporate and OT/ICS zones for all machine-to-machine traffic.	Template for Cybersecurity Operational Technology PolicyTemplate for OT/ICS Security StandardData Diode StandardTemplate for Network Security PolicyTemplate for Network Security StandardTemplate for Proxy Protection Standard	Implement proxy solution between the corporate and OT/ICS zones for all machine-to-machine traffic.Verify and ensure that all machine-to-machine traffic between the corporate and OT/ICS zones is going through the proxy.	Site visit to ensure that all machine-to-machine traffic between the corporate and OT/ICS zones is going through the proxy.
	OTCC-2.4.1.12	Dedicated gateways must be used to segment OT/ICS networks from corporate zone.	Template for Cybersecurity Operational Technology PolicyTemplate for OT/ICS Security StandardData Diode StandardTemplate for Network Security PolicyTemplate for	Implement dedicated gateway to segment OT/ICS networks from corporate zone.	Site visit and network diagram showing that dedicated gateway to segment OT/ICS networks from corporate zone are implemented.

			Network Security Standard		
	OTCC-2.4.1.13	Dedicated DMZ zone must be used to reside any system that needs services provided by corporate zone.	Template for Cybersecurity Operational Technology PolicyTemplate for OT/ICS Security StandardData Diode StandardTemplate for Network Security PolicyTemplate for Network Security Standard	Define and implement a dedicated DMZ zone based on the requirements related to cybersecurity.Include all systems that provide services between the OT/ICS zone and corporate zone within a dedicated DMZ. zone.	List of all systems that provide services between the OT/ICS zone and corporate zone.Site visit to check that the dedicated DMZ zone is utilized, and that is when any of the systems that provide services between the OT/ICS zone and corporate zone is in use.
	OTCC-2.4.1.14	Strict limitation on enabling/usage of industrial protocols and ports to the minimum to meet operational, maintenance, and safety requirements.	Template for Cybersecurity Operational Technology PolicyTemplate for OT/ICS Security StandardData Diode StandardTemplate for Network Security PolicyTemplate for Network Security Standard	Verify and ensure that there is strict limitation on enabling/usage of industrial protocols and ports to meet operational, maintenance, and safety requirements.	Site visit to ensure that there is strict limitation on enabling/usage of industrial protocols and ports to meet operational, maintenance, and safety requirements.
	OTCC-2.4.1.15	Periodic patches and upgrades for production assets must be certified by respective vendor	Template for Cybersecurity Operational Technology PolicyTemplate for OT/ICS Security	Ensure all periodic update packages and security patches for assets in the production environment are approved by the vendorConduct a test in a testing environment before	A certification of periodic patches and upgrades from the vendor.Implemented dedicated and separated test environment.A proof that all periodic patches and upgrades

		and tested in a separate environment prior to implementation.	StandardTemplate for Network Security PolicyTemplate for Network Security StandardTemplate for Patch and Update Management Standard	applying periodic updates and patches for assets in the production environment.	for production assets are tested in a testing environment.
	OTCC-2.4.1.16	Details related to network architecture and topology, zones, network data flows, connectivity, and interdependencies must be documented, updated, and maintained.	Template for Cybersecurity Operational Technology PolicyTemplate for OT/ICS Security StandardTemplate for Network Security PolicyTemplate for Network Security Standard	Document all details related to network architecture and topology, zones, network data flows, connectivity, and interdependencies.Ensure that network diagrams and documentation is periodically updated.	The latest and updated network diagram.
OTCC-2.4.2	With reference to the ECC control 2-5-4, the cybersecurity requirements for network security management in OT/ICS environment must be reviewed, and their implementation effectiveness is measured and evaluated periodically.	Template for Cybersecurity Operational Technology PolicyTemplate for OT/ICS Security Standard Template for Network Security PolicyTemplate for Key Performance Indicator Report	Review the cybersecurity requirements for network security management periodically based on a documented and approved review plan and on a defined frequency (e.g., conduct a review annually). Develop key performance indicators (KPIs) for each control within the related policy or procedure to ensure	A proof that shows the periodic review of cybersecurity requirements to manage OT/ICS network security. A proof that shows the key performance indicators (KPIs) for each control within the related policy or procedure to ensure the implementation effectiveness is measured and	

				the implementation effectiveness is measured and evaluated periodically based on a defined frequency (e.g., conduct an annual review).	evaluated periodically (based on defined frequency).
National Cybersecurity Authority - Cloud Cybersecurity Controls CCC					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
CCC-CSP-2.4-P-1 In addition to the subcontrols in the ECC control 2-5-3, the CSP shall cover the following additional sub controls for cybersecurity requirements for networks security management requirements, as a minimum:	CCC-CSP-2.4-P-1-1	Monitoring of traffic across the external and internal networks to detect anomalies.	Template for Network Security Standards Template for Network Security Policy	Define scope for Network Anomaly Detection. Identify all internal and external networks and network routes. Establish methods and thresholds for effective Anomaly Detection considering low False Positives rates. Implement a monitoring solution considering traffic volume. Correlate network events with other security events. Periodically review correlations rules. Consider AI-based anomaly detection methods.	Inventory of network flows. Anomaly detection rules defined on detection tools.
	CCC-CSP-2.4-P-1-2	Network isolation and protection of Cloud Technology Stack network from	Template for Network Security Standards Template for Network Security Policy	Identify potential risks related to Cloud Technology Stack network and apply relevant protection. Isolate physically or logically (e.g.: Software Defined Networks) networks	Threat Model for Cloud Technology Stack network. Network-level controls implementation. Architecture design documentation.

		other internal and external networks.		for Cloud Technology Stack and internal and external networks.	
	CCC-CSP-2.4-P-1-3	Protection from denial-of-service attacks (including Distributed Denial of Service (DDoS)).	Template for Network Security Standards Template for Network Security Policy Template for Distributed Denial of Service (DDoS) Protection Standard	Identify networks exposed to denial-of-service and distributed denial of service attacks. Establish network monitoring to detect volumetric attacks. Conduct deep packet analysis to detect bot-generated traffic for blackholing. Utilize technologies and techniques to stop and prevent DDoS attacks.	A document or report demonstrating that Denial of Service threats are analysed, detected and mitigated.
	CCC-CSP-2.4-P-1-4	Protection of data transmitted through the network; from and to the Cloud Technology Stack network using cryptography primitives; for management and administrative access.	Template for Network Security Standards Template for Network Security Policy	Encrypt Cloud Technology Stack management and administrative network connection (both interactive and non-interactive - API) with strong encryption mechanisms using random number generators, entropy sources, and basic memory or math operations that are required by the cryptographic algorithms.	Evidence ¹ illustrating that Cloud Technology management networks are strongly encrypted.
	CCC-CSP-2.4-P-1-5	Access control between different network segments.	Template for Network Security Standards Template	Enforce only authenticated traffic between different network segments. Assign the network connection to a	Network connections assigned to authenticated users/identities. Access control list.

			for Network Security Policy	user/identity who is responsible for data transfers between network segments.Manage authorizations to establish connections across network segments.	
	CCC-CSP-2.4-P-1-6	Isolation between cloud service delivery network, cloud management network and CSP enterprise network.	Template for Network Security StandardsTemplate for Network Security Policy	Segregate physically or logically corporate networks from networks related to cloud services and cloud management and build isolation mechanisms (e.g.: Software Defined Networks) for these networks.	Isolation mechanisms for networks.Architecture design documentation.
CCC-CST-2.4-T-1	CCC-CST-2.4-T-1-1	Protecting the connection channel with CSP.	Template for Network Security PolicyTemplate for Network Security Standard	Define security requirements for connectivity with CSPs in terms of confidentiality, integrity and availability of data transferred through these connections (e.g. encryption in transit, connection redundancy, fail-over connectivity, volumetric DDoS protection, channel/VPN authentication)Design and implement the network connection accordingly (e.g.: use two separate ISPs to two regions where CSP operates, use VPNs)Define Disaster	Disaster Recovery Plan for CST to CSPs connections.A network diagram document illustrating the implementation of cybersecurity practices to protect network communication between CSTs and CSPs.

				Recovery Plan for cloud connectivity.	
CST CRF					
Control reference number	Control clauses	Control implementation guidelines		Expected deliverables	
4.5.1 CL1	Define and document [Requirements for Network Security] which consider the following: Managing and controlling the security of the networks operated by the organization and the information assets connected to it Segregation of networks Security requirements to protect the network services and the information transferred through it	Use “Network Security Policy Template” to develop and document cybersecurity requirements for network security management in the organization. This should include: - Defining clear security responsibilities for managing and controlling network security. - Establishing network segregation strategies to isolate sensitive systems and data. - Implementing security measures to protect network services and data transmission.		Documented/Approved cybersecurity requirements/Policy for network security management.	
4.5.2 CL1	Document the [Network Plan] which clearly reflects the actual state of the network (e.g. all devices, connections into the networks, network critical servers).	Maintain an up-to-date network plan that accurately reflects the current network infrastructure, including all devices, connections, and critical servers.		A documented and up-to-date network plan.	
4.5.3 CL1	Ensure that the incoming and outgoing traffic is controlled (e.g. preventing malicious traffic, monitoring the traffic loads of switching facilities, controlling unwanted communication such as email,	Implement measures to control network traffic, including: - Preventing malicious traffic through firewalls and intrusion detection/prevention systems. - Monitoring traffic loads to ensure network availability and performance. - Controlling unwanted communications such as spam emails and unauthorized SMS messages.		Evidence of network traffic control measures.	

	SMS) based on the [Requirements for Network Security].		
4.5.4 CL1	Ensure that only trusted and authorized protocols and IP address ranges are allowed to cross the boundary (e.g. using firewalls). Disable unused protocols, (e.g. disabling IPv6 if not used) on the equipment to reduce the attack surface on the network.	Configure firewalls to allow only trusted protocols and IP addresses, and disable unused protocols to minimize the attack surface.	Firewall configuration and evidence of disabled unused protocols.
4.5.5 CL1	Protect the information transferred (e.g. from the interception, copying, modification) through that organization's network and ensure the confidentiality and integrity of the information are maintained (e.g. encryption).	Protect data transmitted over the network using encryption and other security measures to ensure confidentiality and integrity.	Evidence of data protection measures for network traffic.
4.5.6 CL1	Segregate the network into zones (e.g. domains, subnets) depending on the criticality of the information assets or services present in those zones (e.g. isolating production network from development and testing networks, separating network containing user workstations from authentication servers).	Implement network segmentation to isolate different zones based on their criticality and sensitivity.	Evidence of network segmentation.

4.5.7 CL1	Restrict the access to the organization's network (both wired and wireless networks) based on the access control list [Identity and Access Management].	Restrict network access based on defined access control lists and user roles.	Evidence of network access restrictions.
4.5.8 CL1	Secure the end user data, voice and signaling information transferred through the organization's telecommunications network (e.g. VoIP/SIP traffic, SS7).	Secure end-user data and voice communications transmitted over the organization's telecommunications network using appropriate security measures.	Evidence of secure telecommunications network configuration.
4.5.9 CL1	Segregate the hosted customer network from the organization's telecommunication operational network.	Isolate the hosted customer network from the organization's internal telecommunications network to prevent unauthorized access or interference.	Evidence of network segregation between customer and operational networks.
4.5.10 CL2	Cooperate with other organizations that own or operate interconnected networks with the organization's network to detect and protect the connected users and the networks from malicious acts (e.g. to block email spams, DDoS, abnormal traffic patterns, implement Caller ID authentication to block illegal caller ID spoofing).	Collaborate with other organizations to enhance network security and protect against threats such as spam, DDoS attacks, and caller ID spoofing.	Documentation of cooperation agreements or procedures.
4.5.11 CL2	Ensure that the interfaces (e.g. Internet Exchange Points) to other networks are	Secure network interfaces and connections to other networks using appropriate security measures,	Evidence of secure network interface configuration.

	appropriately secured (e.g. securing BGP infrastructure, implementing high availability through redundancy, using strong cryptography).	including BGP security, redundancy, and strong encryption.	
4.5.12 CL2	Enhance and implement the [Requirements for Network Security] to handle internal and external attacks (e.g. DoS/DDoS) against the organization's network.	Implement security measures to protect the network from internal and external attacks, such as denial-of-service (DoS) and distributed denial-of-service (DDoS) attacks.	Evidence of implemented security measures against network attacks.
4.5.13 CL2	Ensure that mechanisms are in place at the ICT facilities to detect and avoid network congestion which results in disruptions of services (e.g. implementation of additional facilities to balance the traffic load).	Implement mechanisms to prevent and mitigate network congestion, ensuring service availability and preventing disruptions.	Evidence of network congestion prevention and mitigation mechanisms.
4.5.14 CL2	Use specific tools to analyze and filter all traffic (e.g. port filtering, host-based filtering) to detect any unauthorized traffic in the network.	Utilize tools to analyze and filter network traffic to detect and prevent unauthorized access and malicious activities.	Evidence of network traffic analysis and filtering tools.
4.5.15 CL3	Continuously measure, review and optimize the [Requirements for Network Security].	Regularly monitor, review, and improve network security measures to ensure their effectiveness and adapt to evolving threats.	Documentation of continuous monitoring, review, and optimization activities.

Risk Considerations in Network Security

1. **Unauthorized Access:** Risks of unverified devices or users gaining access to critical network segments.
2. **Insufficient Network Segmentation:** Lack of proper segmentation can allow attackers to move laterally and compromise critical systems.
3. **Advanced Persistent Threats (APTs):** Persistent attackers exploiting network vulnerabilities to maintain access.
4. **DDoS Attacks:** Distributed denial-of-service attacks overwhelming network resources.
5. **Misconfigured Firewalls:** Allowing unintended traffic or blocking legitimate operations due to poor rule management.
6. **Unpatched Network Devices:** Vulnerable network hardware or software can be exploited by attackers.
7. **Insider Threats:** Malicious or negligent internal actors compromising network security.
8. **Wireless Network Vulnerabilities:** Risks from poorly secured Wi-Fi or unauthorized access points.
9. **Data Interception:** Sensitive data transmitted across the network being intercepted or altered.
10. **Regulatory Non-Compliance:** Failure to adhere to frameworks like NCA ECC, SAMA CSF, or CST CRF may result in penalties or reputational damage.

Examples of Technologies for Effective Network Security

1. **Firewalls:** Use next-generation firewalls to filter and control network traffic. Open-source options include *pfSense* and *OPNsense*.
 2. **Intrusion Detection/Prevention Systems (IDS/IPS):** Use tools like *Snort* or *Suricata* to detect and prevent intrusions.
 3. **Network Access Control (NAC):** Open-source NAC tools can enforce authentication and segmentation, such as *PacketFence*.
 4. **DDoS Mitigation Solutions:** Use open-source solutions like *FastNetMon* or *ddos-deflate* to help detect and mitigate volumetric attacks.
 5. **SIEM Solutions:** Free or open-source platforms like *Wazuh*, *OSSIM* (AlienVault), or *TheHive* can be used for security information and event management.
 6. **Network Monitoring Tools:** Tools such as *Nagios*, *Zabbix*, or *Icinga* support real-time monitoring of network health.
 7. **Virtual Private Networks (VPNs):** Use secure VPN protocols such as *OpenVPN* or *WireGuard* for remote access.
 8. **Encryption Tools:** Use open-source encryption tools like *GnuPG* for data encryption and *VeraCrypt* for disk encryption.
 9. **DNS Security Solutions:** Use *Pi-hole* or *dnscrypt-proxy* to secure DNS traffic and block malicious domains.
 10. **Proxy Servers:** Deploy proxy tools such as *Squid* or *Privoxy* to manage and filter outbound web traffic.
-

Examples of KPIs for Network Security

1. **Firewall Rule Review:** Percentage of firewalls reviewed and updated on schedule.
 2. **Incident Detection Time:** Average time taken to detect network-based threats.
 3. **Patch Management Efficiency:** Percentage of network devices patched within defined timeframes.
 4. **Mean Time to Resolve (MTTR):** Average time taken to resolve network security incidents.
 5. **DDoS Mitigation Success Rate:** Percentage of mitigated DDoS attacks.
 6. **Unauthorized Access Attempts:** Number of blocked unauthorized network access attempts.
 7. **Wireless Network Security Compliance:** Percentage of wireless networks configured with WPA3 or higher.
 8. **Network Availability Uptime:** Percentage of time the network is operational and available.
 9. **Intrusion Prevention Coverage:** Proportion of critical network segments covered by IDS/IPS.
 10. **Regulatory Compliance Rate:** Percentage of compliance with network-related regulations or frameworks.
-

Samples of Auditor's Checklist for Network Security

1. Are network security policies documented, approved, and reviewed regularly?
 2. Is there evidence of proper network segmentation between production, development, and testing environments?
 3. Are firewalls configured with whitelist-only rules and reviewed periodically?
 4. Are intrusion detection/prevention systems (IDS/IPS) deployed and functioning effectively?
 5. Is there a mechanism for managing and restricting network services, protocols, and ports?
 6. Are DDoS mitigation measures implemented and tested regularly?
 7. Are wireless networks segmented and secured with encryption and authentication mechanisms?
 8. Are network traffic monitoring and anomaly detection tools deployed?
 9. Are periodic vulnerability scans and patch management processes in place for network devices?
 10. Is there a documented incident response plan for network security incidents?
-

Samples of Audit Scenarios for Network Security

Scenario 1: Firewall Rule Review

- **Objective:** Assess the effectiveness of firewall configurations.
- **Steps:**
 1. Review firewall rule configurations and access logs.
 2. Test unused rules for potential risks.
 3. Verify periodic review and approval of changes.
- **Questions:**
 - Are firewall rules aligned with the organization's security policy?
 - Are there unused or overly permissive rules that need removal or restriction?

Scenario 2: Network Segmentation

- **Objective:** Validate proper network segmentation practices.
- **Steps:**
 1. Review VLAN configurations and segmentation policies.
 2. Test access control between critical and non-critical network segments.
 3. Verify network diagrams for accurate segmentation.
- **Questions:**
 - Are critical systems isolated from non-critical networks?
 - Are access control policies enforced between different zones?

Scenario 3: Wireless Network Security

- **Objective:** Assess the security of wireless networks.
- **Steps:**
 1. Review encryption protocols (e.g., WPA3) and authentication mechanisms.
 2. Verify the isolation of guest and corporate networks.
 3. Test wireless network configurations for vulnerabilities.
- **Questions:**
 - Are wireless networks encrypted with secure protocols?
 - Are guest and internal networks properly segmented?

Case Study 1: Preventing Unauthorized Network Access in a Manufacturing Company

Scenario: A manufacturing company experienced several unauthorized access attempts due to insufficient network access controls and improper segmentation of critical systems.

Actions Taken:

1. **Implemented Network Access Control (NAC):**
 - Deployed Cisco ISE to authenticate devices and users accessing the network.
 - Applied least privilege principles to ensure limited access to critical network segments.
2. **Revised Firewall Policies:**
 - Conducted a comprehensive review of firewall rules to remove unused and overly permissive configurations.
 - Implemented a whitelist-only approach for critical segments.
3. **Enhanced Network Segmentation:**
 - Segregated critical production systems from the rest of the network using VLANs and next-generation firewalls.
 - Created a DMZ for devices requiring external connectivity.
4. **Introduced Security Awareness Training:**
 - Conducted periodic training sessions for staff to recognize unauthorized access attempts and follow incident reporting procedures.

Outcome:

- Unauthorized access attempts reduced by **95%**.
 - Compliance with NCA ECC and NCA OTCC achieved.
 - Improved visibility and control over network traffic, significantly enhancing security posture.
-

Case Study 2: Mitigating DDoS Attacks for a Public Sector Organization

Scenario: A government entity experienced frequent DDoS attacks, disrupting its public-facing services and creating reputational risks.

Actions Taken:

1. **Deployed a Cloud-Based DDoS Mitigation Solution:**
 - Partnered with Cloudflare to absorb and mitigate volumetric DDoS attacks.
 - Configured the network to automatically reroute malicious traffic to a scrubbing center.
2. **Upgraded Network Monitoring Tools:**
 - Deployed SolarWinds for real-time monitoring and detection of anomalous traffic patterns.
 - Integrated alerts into their SIEM platform (Splunk) for faster incident response.
3. **Improved ISP Coordination:**
 - Established an agreement with the Internet Service Provider (ISP) to block traffic from known malicious IP ranges.
4. **Implemented High-Availability (HA) Systems:**
 - Designed the infrastructure with redundant firewalls and proxy servers to maintain availability during attacks.

Outcome:

- Service uptime during DDoS attacks improved to **99.9%**.
 - Detection and mitigation time for DDoS incidents reduced by **60%**.
 - Enhanced stakeholder confidence in the organization's resilience to cyber threats.
-

Case Study 3: Securing Wireless Networks in an Educational Institution

Scenario: An educational institution's wireless network was exploited due to weak encryption and a lack of segmentation between guest and corporate networks.

Actions Taken:

1. **Upgraded Wireless Security Protocols:**
 - Migrated from WPA2 to WPA3 for stronger encryption and enhanced authentication mechanisms.
2. **Segmented Wireless Networks:**
 - Created separate VLANs for guest, faculty, and administrative networks to ensure logical isolation.
 - Restricted access between the corporate and guest networks using firewalls.
3. **Introduced Multi-Factor Authentication (MFA):**
 - Enforced MFA for faculty and administrative access to the wireless network.
4. **Implemented Wireless Intrusion Detection/Prevention Systems (WIDS/WIPS):**
 - Deployed Aruba WIDS/WIPS to monitor and block rogue access points and unauthorized wireless connections.
5. **Conducted Regular Security Assessments:**
 - Performed quarterly vulnerability scans and penetration tests to identify and address wireless security gaps.

Outcome:

- Wireless network breaches eliminated.
- Compliance with NCA ECC achieved.
- User satisfaction improved due to enhanced security and reduced downtime.

2.6 Mobile Devices Security:

Definition: Mobile Devices Security involves the implementation of policies, practices, and technologies to safeguard mobile devices, such as laptops, smartphones, tablets, and other portable devices, from cyber threats. It includes protecting sensitive organizational information, securing devices against unauthorized access, and ensuring data integrity while maintaining compliance with organizational and regulatory security standards. Additionally, it supports secure usage within Bring Your Own Device (BYOD) environments [14], [15], [16].

Objective: To ensure the protection of mobile devices (including laptops, smartphones, tablets) from cyber risks and secure the handling of the organization's information (including sensitive information) while utilizing Bring Your Own Device (BYOD) policy.

Controls Matrix:

Below is a summary matrix detailing relevant identity and access management controls based on NCA, SAMA CSF, CST CRF, and CMA Cybersecurity Guidelines:

Regulation	Main Controls	Control References
NCA ECC	4	2-6-1, 2-6-2, 2-6-3 (4 sub-controls), 2-6-4
SAMA CSF	4	3.3.10.1, 3.3.10.2, 3.3.10.3, 3.3.10.4 (5 sub-controls: a, b, c, d, e)
CTS CRF	5	2.3.1, 2.3.2, 2.3.3, 2.3.4, 2.3.5
CMA CSG	4	4.3.16-1, 4.3.16-2, 4.3.16-3, 4.3.16-4 (5 sub-controls: 1, 2, 3, 4, 5)
NCA CSCC	1	2-5-1 (2 sub-controls)
NCA CCC CST	1	2-5-T-1 (1 sub-control)
NCA CCC CSP	1	2-5-P-1 (4 sub-controls)
NCA TCC	1	2-5-1 (2 sub-controls)
NCA DCC	1	2-3-1 (2 sub-controls)
NCA OSMACC	1	2-4-1 (2 sub-controls)
NCA OTCC	2	2-5-1 (5 sub-controls), 2-5-2

Mobile Devices Security Controls:

National Cybersecurity Authority - Essential Cybersecurity Controls ECC					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
ECC-2.6.1		Cybersecurity requirements for mobile devices security and BYOD must be defined, and approved.	Workstations, Mobile Devices and BYOD Security Policy Template.	Develop and document Cybersecurity policy for mobile devices and BYOD in the organization, including the following: Mobile Devices Cybersecurity Requirements, BOYD Cybersecurity Requirements. Support the organization's policy by the Executive Management. This must be done through the approval of the organization head or his/her deputy.	Cybersecurity policy and standard for mobile devices and personal devices (BYOD) at the organization (e.g., electronic copy or official hard copy). Formal approval by the head of the organization or his/her deputy on the policy and technical standard (e.g., via the organization's official e-mail, paper or electronic signature).
ECC-2.6.2		The cybersecurity requirements for mobile devices security and BYOD must be implemented.	All cybersecurity requirements related to the security of mobile devices and BYOD for the organization must be implemented, which may include the following: Ensure the isolation, segregation, and cryptography of data and information of the organization stored on mobile devices and BYOD from the rest of the		An action plan to implement the cybersecurity requirements for mobile devices and personal devices (BYOD) security

			information and data on the device.Ensure the use must be specified and restricted to the requirements of the organization.Provide us of workstations and mobile devices with privileged access following the principle of least privilege.Ensure that the storage media of critical and sensitive workstations and mobile devices are encrypted and have privileged access.Ensure that data and information of the organization stored on mobile devices and BYOD must be deleted when devices are lost or after the end/termination of the functional relationship with the organization.Ensure the activation of Remote Wipe on all mobile devices that process the organization's classified information.Implement the organization's Group Policy and apply it to all workstations and mobile devices to ensure compliance with regulatory and security controls.Provide security awareness to users Centrally manage workstations and mobile devices through, but not limited to, the Active Directory server or through a centralized management system.Implement secure configuration and hardening controls to workstations and mobile devices in accordance with cybersecurity standard controls.Establish procedures to ensure the implementation of cybersecurity requirements adopted for the organization's mobile devices and personal devices (BYOD) management in accordance with the relevant laws and regulations.	management.Sample showing the implementation of mobile devices and BYOD security controls at the organization, including but not limited to:Sample showing that the organization's use of advanced technologies for mobile devices and personal devices (BYOD) security (e.g., the existence of advanced technologies necessary to separate and encrypt the organization's data and information stored on mobile devices and BYOD).Sample showing the central management of workstations and mobile devices, including but not limited to a screenshot from the Active Directory server in addition to
--	--	--	--	---

				configuration. Defined and approved procedures for handling mobile devices and personal devices (BYOD) at the organization.
ECC-2.6.3 The cybersecurity requirements for mobile devices security and BYOD must include at least the following:	ECC-2.6.3.1	Separation and encryption of organization's data and information stored on mobile devices and BYODs.	Define and document the requirements of this ECC in the cybersecurity requirements of mobile devices and BYOD at the organization and must be approved by the representative. Implement the requirements of separating and encrypting the organization's data and information stored on mobile devices and BYOD devices, which may include the following: Separation and cryptography of data and information. Appropriate and advanced technologies for separating and encrypting data and information. Use necessary technologies (such as Mobile Device Management) to encrypt the organization's data and information stored on mobile devices and BYOD.	Cybersecurity policy that covers all the security requirements of mobile devices and personal devices (BYOD) at the organization (e.g., electronic copy or official hard copy). Formal approval by the head of the organization or his/her deputy on such requirements (e.g., via the organization's official e-mail, paper or electronic signature). Sample showing the implementation of mobile devices and BYOD security requirements, including but not

				limited to:Sample showing the implementation of the requirements of appropriate and advanced technologies for the security of mobile devices and BYOD (e.g. screenshot showing the use of advanced systems to provide and ensure data cryptography on mobile devices and BYOD at the organization).Defined and approved procedures for encrypting data and information stored on mobile devices and BYOD.
ECC-2.6.3	ECC-2.6.3.2	Controlled and restricted use based on job requirements.	Define and document the requirements of this ECC in the cybersecurity requirements of mobile devices and BYOD at the organization and must be approved by the representative.Implement the specified and restricted use requirements based on the requirements of the organization's business interest.These requirements may include the following:The use must be specified and restricted to the requirements of the	Cybersecurity policy that covers all the security requirements of mobile devices and personal devices (BYOD) at the organization (e.g., electronic copy or official hard

			organization. Appropriate and advanced technologies for specific and restricted use based on the requirements of the organization's business interest. Develop necessary procedures to restrict the use of mobile devices and link them to their network based on the requirements of the business interest. Assess mobile devices configuration and security controls, including but not limited to the implementation of (Patches, AV) prior to linking them to the organization's domain or network.	copy). Formal approval by the head of the organization or his/her deputy on such requirements (e.g., via the organization's official e-mail, paper or electronic signature). Sample showing the implementation of requirements related to the specific and restricted use based on the organization's business interest, including but not limited to Sample showing the implementation of the specific and restricted use requirements based on the organization's business interest (e.g., a screenshot showing evidence that the necessary procedures are in place to restrict the use of mobile devices and link them
--	--	--	--	--

				to their network based on the business interest). Defined and approved procedures for restricting the use of mobile devices (e.g., a form of procedures, as well as a sample report showing evidence of ensuring that the mobile device settings and security controls are assessed, including the implementation of patches and antivirus updates prior to being linked to the network).
ECC-2.6.3	ECC-2.6.3.3	Secure wiping of organization's data and information stored on mobile devices and BYOD in cases of device loss, theft or after termination/separation from the organization.	Define and document the requirements of this ECC in the cybersecurity requirements of mobile devices and BYOD at the organization and must be approved by the representative. Ensure that data and information of the organization stored on mobile devices and BYOD must be deleted when devices are lost or after the end/termination of the functional relationship with the organization. Use necessary technologies (such as Mobile Device Management) to ensure the deletion of sensitive data and information when the devices are lost,	Cybersecurity policy that covers all the security requirements of mobile devices and personal devices (BYOD) at the organization (e.g., electronic copy or official hard copy). Formal approval by the head of the organization or his/her deputy on such

			and after the end/termination of the functional relationship with the organization.	requirements (e.g., via the organization's official e-mail, paper or electronic signature). Sample showing the implementation of requirements related to the deletion of data and information stored on mobile devices and BYOD to include, but not limited to Sample showing the implementation of deletion requirements for data and information stored on mobile devices and BYOD devices (e.g., a screenshot showing evidence of deleting data and information stored on mobile devices and personal devices when, for example, the subscription with a data deletion service and integrated secure management of
--	--	--	---	---

				mobile devices and BYOD devices provider is no longer valid. Sample of the followed procedures template showing evidence of ensuring the deletion of data and information stored on mobile devices and personal devices BOYD when they are lost or after the end/termination of the functional relationship with the organization.
ECC-2.6.3	ECC-2.6.3.4	Security awareness for mobile devices users.	Define and document the requirements of this ECC in the cybersecurity requirements of mobile devices and BYOD at the organization and must be approved by the representative. Implement security awareness requirements for users, which may include the following: Provide security awareness to users. Appropriate and advanced technologies to provide security awareness to users. Implement the requirements of this control by providing security awareness to users on mobile devices and BYOD on a regular basis.	Cybersecurity policy that covers all the security requirements of mobile devices and personal devices (BYOD) at the organization (e.g., electronic copy or official hard copy). Formal approval by the head of the organization or his/her deputy on such requirements (e.g., via the organization's

				official e-mail, paper or electronic signature). Sample showing the implementation of security awareness requirements for users, including but not limited to Sample showing the implementation of security awareness requirements for users (e.g., presentation showing security awareness to the organization's employees regarding the optimal and safe use of mobile devices and BYOD devices or a screen shot from mobile devices' screensaver showing an awareness message to users)
ECC-2.6.4	The cybersecurity requirements for mobile devices security and BYOD must be reviewed periodically.	Review the implementation of cybersecurity requirements for mobile devices and BYOD security by conducting a periodic assessment (according to a documented and approved plan for review, and based on a planned interval "e.g.,	Results of mobile devices and BYOD cybersecurity requirements implementation	

		quarterly") to implement the organization's mobile devices and BYOD security procedures by the Cybersecurity function and in cooperation with relevant departments (such as IT Department).Conduct application review through traditional channels (e.g., email) or automated channels using a compliance management system.The organization may develop a review plan outlining the cybersecurity requirements implementation review schedule for mobile devices and BYOD security.Review and update cybersecurity requirements for mobile devices and BYOD security in the organization periodically according to a documented and approved plan for review and based on a planned interval or in the event of changes in relevant laws and regulations.Document the review and changes to the cybersecurity requirements for mobile devices and BYOD security in the organization and approve them by the head of the organization or his/her deputy.	review in the organizationA document that defines the cybersecurity requirements implementation review cycle for mobile devices and BYOD security (Compliance Assessment Schedule).Compliance assessment report that outlines the assessment of the implementation of cybersecurity requirements for the organizations mobile devices and BYOD securityAn approved document that sets the policy's review schedulePolicy indicating that it has been reviewed and updated, and that changes have been documented and approved by the head of the organization or his/her deputy.Formal
--	--	---	---

					approval by the head of the organization or his/her deputy on the updated policy (e.g., via the organization's official e-mail, paper or electronic signature).
National Cybersecurity Authority – Critical Systems Cybersecurity Controls CSCC					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
CSCC-2.5.1 In addition to the sub-controls within Control 2-6-3 in the Basic Controls of Cybersecurity, it must cover the cybersecurity requirements related to the security of mobile devices and (BYOD) devices of the entity, at a minimum; the following:	CSCC-2.5.1.1	Restrict access from mobile devices to critical systems, except for a temporary period only; This is after conducting a risk assessment and obtaining the necessary approvals from the department concerned with cyber security in the entity.	Mobile Devices and BYOD Security Policy Template Mobile Devices Security Standard Template User device security standard template	Work all to prevent access from mobile devices to critical systems, taking into account that access is intended for other purposes access as an end user. Work on developing procedures to allow access for a temporary period only when needed, for example: Work on developing procedures for assessing the risks of access from mobile devices to critical systems based on business needs and	Critical systems risk assessment procedures document. Document procedures for granting permissions mechanisms to critical systems. Samples of approval requests. Full Disk Encryption for mobile devices with access to critical systems.

				obtaining the necessary approvals from the concerned department and the cybersecurity department according to the approved procedures. Access is allowed for a temporary period only, and access is immediately disabled once the period expires. Allow access to a specific system only upon request, not all systems. Record and monitor access attempts from mobile devices and activities related to accesses.	
CSCC-2.5.1	CSCC-2.5.1.2	Full Disk Encryption for mobile devices with access to critical systems.	Mobile Devices Security Standard Template User device security standard template Workstations, Mobile Devices and BYOD Security Policy Template	End-to-end encryption of all portable drives for critical systems using accepted methods based on, but not limited to, National Encryption Standards: AES-256-FIPS. Work to provide technical systems and security	A guide demonstrating the implementation of cryptographic requirements for critical systems. Evidence for disk encryption on mobile devices used to access critical systems.

				solutions that implement the required encryption requirements.	
National Cybersecurity Authority – Organization Social Media Accounts Cybersecurity Controls OSMACC					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
OSMACC-2.4.1 In addition to the subcontrols within control 2-6-3 in the ECC, cybersecurity requirements for mobile device security related to organization's social media accounts must include at least the following:	OSMACC-2.4.1.1	Centrally manage mobile devices for organization's social media accounts using a Mobile Device Management system (MDM).	Template for User Devices, Mobile Devices, and Personal Devices Security Policy Template for Mobile Devices Security Standard	Identify the list of mobile devices in the organization that are used for handling organization's social media accounts. Define and implement a mobile device management (MDM) system, as per the requirements of the organization, to manage the mobile devices who have access to social media accounts.	Documented list of all the mobile devices in the organization used for handling organization's social media accounts. Sample of Mobile Device Management (MDM) system's configurations.
	OSMACC-2.4.1.2	Applying updates and security patches on mobile devices, at least once every month.	Template for User Devices, Mobile Devices, and Personal Devices Security Policy	Identify the list of mobile devices in the organization that are used for handling organization's social media accounts.	Documented security patching procedures for social media applications.

				Review guidelines and procedures for updates and patches related to mobile devices handling social media accounts, and adhere to them when applying security and hardening measures on mobile devices. Periodic security patching and updates must be conducted at least every month or earlier for mobile devices handling social media accounts.	Patching review report for periodic security patching.
National Cybersecurity Authority - Telework Cybersecurity Controls TCC					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
TCC-2.5.1 In addition to the sub-controls within control 2-6-3 in the ECC, cybersecurity requirements for mobile device security	TCC-2.5.1.1	Central management of mobile devices and BYODs using a Mobile Device Management system (MDM).	Workstations, Mobile Devices and BYOD Security Policy Template Mobile Devices Security Standard Template	Work on defining the requirements for this control, document them in the cybersecurity requirements document, and have them approved by the authority holder. Ensure that	A document that identifies and documents the requirements of this control (such as a policy and/or procedure approved by the authority holder). Documented procedures for

related to telework systems shall include at least the following:				mobile devices and BYOD devices are managed centrally using the Mobile Device Management system to maintain confidentiality, integrity, and availability of organization's information.	implementing the mobile device management system on all BYOD devices using MDM provided by the entity. Sample of MDM implementation.
	TCC-2.5.1.2	Applying updates and security patches on mobile devices, at least once every month.	Workstations, Mobile Devices and BYOD Security Policy Template Mobile Devices Security Standard Template	Work on defining the requirements for this control, document them in the cybersecurity requirements document, and have them approved by the authority holder. Ensure that the approval of the change management in the entity is part of the approvals required to implement security updates and patches for mobile device security for telework in the entity. Define a documented, periodic	A document that identifies and documents the requirements of this control (such as a policy and/or procedure approved by the authority holder). Documented process to apply technical updates & security patches on mobile devices. Reports showing the patches performed according to the period specified in the procedures.

				plan to implement mobile security updates and patches and mobile device management (MDM) solutions for telework at least once a month.Follow up on the implementation of mobile security patch and update packages for telework continuously through the use of patch and update management tools and technologies.	
National Cybersecurity Authority – Operational Technology Cybersecurity Controls OTCC					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
OTCC-2.5.1 In addition to subcontrols in the ECC control 2-6-3, cybersecurity requirements for mobile device security in OT/ICS must cover, at a	OTCC-2.5.1.1	Usage of mobile devices for OT/ICS must be restricted unless specifically required. A cybersecurity risk assessment must be conducted where risks must be defined and managed. A management approval	Template for Cybersecurity Operational Technology PolicyTemplate for OT/ICS Security StandardTemplate for Mobile Devices Security Standard	Restrict usage of mobile devices for OT/ICS to avoid unauthorized access and unexpected influence on the process.Define and document exceptional cases where usage of mobile devices is required.Conduct a	Report of Cybersecurity risk assessment when using mobile devices.Document for Cybersecurity requirements when using mobile devices.Site visit to check that usage of mobile devices for

minimum, the following:		must be granted by respective cybersecurity function for a defined period of time only in alignment with organization's formal access management mechanisms.		cybersecurity risk assessment to identify and manage risks in line with the organization's mechanisms. Define, document, and implement cybersecurity requirements specified for mobile devices usage. Ensure that all mobile devices used are implementing and in line with the approved documented requirements.	OTICS is restricted and limited only to defined cases.
	OTCC-2.5.1.2	Mobile devices must only be used for their intended purposes and in compliance with cybersecurity requirements of its respective zones prior to being connected to OT/ICS environment, and are hardened and updated with the latest security patches and	Template for Cybersecurity Operational Technology Policy Template for OT/ICS Security Standard Template for Mobile Devices Security Standard Template for Security Configuration and Hardening Standard Template for Advanced Persistent	Define and document a hardening and update procedure when using mobile devices dedicated for work purposes. Verify and ensure that all mobile devices are used only for their intended purposes (e.g. by the mobile devices management tools). Verify and ensure that all mobile	A documented hardening and update procedure and that is for when using mobile devices dedicated for work purposes. Site visit to check that all mobile devices are used only for their intended purposes. Reports illustrating installed security patches for mobile devices Reports

		scanned against malware and APT.	Threat (APT) Protection Standard	devices are hardened and updated with the latest security patches and scanned against malware and APT.	for mobile devices scanning.
	OTCC-2.5.1.3	Limited and approved list of mobile devices must be defined while ensuring that only these mobile devices can be connected to OT/ICS environment.	Template for Cybersecurity Operational Technology PolicyTemplate for OT/ICS Security StandardTemplate for Mobile Devices Security Standard	Define and formally document a limited and approved list of mobile devices which can be connected to OT/ICS.Verify and ensure that only listed mobile devices can be connected to OT/ICS environment.	A documented and approved list of mobile devices which can be connected to OT/ICS.Site visit to check that only listed mobile devices can be connected to the OT/ICS environment.
	OTCC-2.5.1.4	Centralized management of mobile devices must be deployed.	Template for Cybersecurity Operational Technology PolicyTemplate for OT/ICS Security StandardTemplate for Mobile Devices Security Standard	Deploy a centralized mobile devices management solution.Verify and ensure that all identified mobile devices are managed by a centralized solution.	A proof that ensures the deployment of a centralized mobile devices management solution.A proof that all identified mobile devices are managed by a centralized solution.
	OTCC-2.5.1.5	Encryptions mechanisms must be used for mobile devices authorized to access the OT/ICS assets.	Template for Cybersecurity Operational Technology PolicyTemplate for OT/ICS Security StandardTemplate for	Define, document, and approve encryption mechanisms on mobile devices authorized to access the OT/ICS assets. The approved mechanisms should be	A proof that all mobile devices authorized to access the OT/ICS assets have implemented approved encryption mechanisms.

			Encryption StandardTemplate for Mobile Devices Security Standard	compliant with the organization's regulations.Verify and ensure that all mobile devices authorized to access the OT/ICS assets have implemented approved encryption mechanisms.	
OTCC-2.5.2	With reference to the ECC control 2-6-4, the cybersecurity requirements for mobile devices security in OT/ICS environment must be reviewed, and their implementation effectiveness is measured and evaluated periodically.	Template for Cybersecurity Operational Technology PolicyTemplate for OT/ICS Security StandardTemplate for Mobile Devices Security StandardTemplate for Key Performance Indicator Report s	Review the cybersecurity requirements for mobile devices security in the OT/ICS environment periodically based on a documented and approved review plan and on a defined frequency (e.g., conduct a review annually).Develop key performance indicators (KPIs) for each control within the related policy or procedure to ensure the implementation effectiveness is measured and	A proof that shows the periodic review of cybersecurity requirements to secure the mobile devices in the OT/ICS environment.A proof that shows the key performance indicators (KPIs) for each control within the related policy or procedure to ensure the implementation effectiveness is measured and evaluated periodically (based on defined frequency).	

				evaluated periodically based on a defined frequency (e.g., conduct an annual review).	
National Cybersecurity Authority - Cloud Cybersecurity Controls CCC					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
CCC-CSP-2.5-P-1 In addition to subcontrols in the ECC control 2-6-3, the CSP shall cover the following additional sub controls for cybersecurity requirements for mobile device security, as a minimum:	CCC-CSP-2.5-P-1-1	Inventory of all end user and mobile devices.	Template for User Devices, Mobile Devices, and Personal Devices Security Policy Template for User Devices Security Standard Template for Mobile Devices Security Standard	Maintain the inventory of all end-user devices (e.g.: laptops, tablets) and mobile devices (e.g. smartphones, smartwatches) and their owners and users. Consider both CSP-owned and BYOD. Periodically (e.g. annually) review the inventory	Maintained inventory of end-user and mobile devices. Periodic reviews reports.
	CCC-CSP-2.5-P-1-2	Centralized mobile device security management.	Template for User Devices, Mobile Devices, and Personal Devices Security Policy Template for User Devices Security Standard Template for Mobile Devices Security Standard	Define requirements for centralized platform to manage security of mobile devices (e.g.: apply security policy, enforce PIN to unlock device, wipe device) Select and deploy centralized security management	All mobile devices centrally managed in terms of security. Sample of system configuration.

				platform/productOn-board all mobile devices in business use to that platform	
	CCC-CSP-2.5-P-1-3	Screen locking for end user devices.	Template for Configuration and Hardening PolicyTemplate for User Devices, Mobile Devices, and Personal Devices Security PolicyTemplate for User Devices Security StandardTemplate for Mobile Devices Security StandardPlan for Cybersecurity Awareness Program	Define screen lock policy and relevant parameters (e.g. timeout, unlock methods).Enforce that policy by configuring end user devices accordingly (e.g. using Active Directory GPO, end-point agents or MDM)Make users aware to lock screen manually when they are not close to them.	Screen lock policy enforced to user devices.Documents illustrating user awareness methods for manually locking the screen when they are not in proximity to their devices.
	CCC-CSP-2.5-P-1-4	Data sanitation and secure disposal for end-user devices, especially for those with exposure to the Cloud Technology Stack.	Template for User Devices, Mobile Devices, and Personal Devices Security PolicyTemplate for User Devices Security StandardTemplate for Mobile Devices Security Standard	Identify end-user devices and technologies exposed to the Cloud Technology Stack (e.g.: MS Windows, Linux, Apple iOS)Select effective data sanitation and disposal methods relevant to these technologies.Dispose securely these devices	Approved and implemented data sanitation and device disposal tools and methods for Cloud Technology Stack elated end-user devices.

				(and data) when necessary.	
CCC-CST-2.5-T-1 In addition to sub controls in the ECC control 2-6-3, the CST shall cover the following additional sub controls for cybersecurity requirements for mobile device security, as a minimum:	CCC-CST-2.5-T-1-1	Data sanitation and secure disposal for end-user devices with access to the cloud services.	Template for User Devices, Mobile Devices, and Personal Devices Security Policy Template for User Devices Security Standard Template for Mobile Devices Security Standard	Identify end-user devices with access to the cloud services (e.g.: mobile, desktop, laptop) Select effective data sanitation and disposal methods relevant to these technologies (e.g. device to wipe out using Mobile Device Management systems) Build processes and capabilities to securely sanitize these devices (e.g.: use MDM with desired device sanitation features).	Approved and implemented data sanitation and device disposal tools and methods.
National Cybersecurity Authority - Data Cybersecurity Controls DCC					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
DCC-2.3.1 In addition to the subcontrols in ECC control 2-6-3, cybersecurity	DCC-2.3.1.1	Centrally managing the organization's owned mobile devices using Mobile Device Management (MDM)	Template for User Devices, Mobile Devices, and Personal Devices Security Policy Template for	Identify the requirements of this control and document them in a cybersecurity requirements	Document detailing the identification and documentation of the requirements of this control (e.g. a policy and/or procedure

requirements for mobile devices must cover at least the following:		system and activating the remote wipe feature.	Mobile Devices Security Standard	document, followed by approval from the authorizing officials. Identify the list of mobile devices in the organization that store, use and process organization's data. Define and implement a Mobile Device Management (MDM) system, as per the requirements of the organization, to manage the mobile devices who have access to data. Review that the MDM system should have remote swipe functionality enabled in all the devices.	approved by the authorizing officials). Documented list of all the mobile devices in the organization handling the data. Implementation plan for Mobile Device Management (MDM) system. Screenshot of Mobile Device Management (MDM) system in use. Sample of related Mobile Device Management (MDM) configurations
	DCC-2.3.1.2	Centrally managing BYOD devices using Mobile Device Management (MDM) system and activating the remote wipe feature.	Template for User Devices, Mobile Devices, and Personal Devices Security Policy	Identify the requirements of this control and document them in a cybersecurity requirements document, followed by approval from the authorizing	Document detailing the identification and documentation of the requirements of this control (e.g. a policy and/or procedure approved by the authorizing officials). Documented

				officials. Identify the list of personnel's mobile devices outside the organization that store, use and process organization's data. Define and implement a Mobile Device Management (MDM) system, as per the requirements of the organization, to manage the mobile devices who have access to organization's public and confidential data. Review that the MDM system must have remote wipe/delete functionality enabled in all the BYOD devices. Verify that BYOD devices should not have access to any secret or top secret data of the organization. Ensure that BYOD devices are	list of all the personnel's mobile devices outside the organization handling the organization's data. Implementation plan for Mobile Device Management (MDM) system for BYOD devices.
--	--	--	--	---	--

				not used for any secret or top secret data.	
SAMA Cyber Security Framework CSF					
Control reference number	Sub-Control	Control clauses	Control implementation guidelines	Expected deliverables	
3.3.10.1		The BYOD cyber security standard should be defined, approved and implemented.	Define the standard with clear guidelines on acceptable use, device security requirements, data protection measures, and user responsibilities. Obtain necessary approvals and communicate the standard to all employees.	Defined and approved BYOD security standard	
3.3.10.2		The compliance with the identity and access policy should be monitored.	Establish a monitoring process to ensure compliance with the BYOD security standard. This can include regular audits, device inspections, and user awareness training.	Evidence of BYOD compliance monitoring	
3.3.10.3		The effectiveness of the BYOD cyber security controls should be measured and periodically evaluated.	Regularly assess the effectiveness of the BYOD security controls through security assessments, vulnerability scans, and incident response reviews. Adjust the controls as needed to maintain adequate security.	Reports and documentation of BYOD security control evaluations	
3.3.10.4 The BYOD standard should include:	3.3.10.4.a	Responsibilities of the user (including awareness training).	Clearly define user responsibilities for device security, data protection, and acceptable use. Conduct regular awareness training to educate users on BYOD policies and security best practices.	Documented user responsibilities and evidence of awareness training	
	3.3.11.4.b	Information regarding the restrictions and consequences for staff	Inform staff about restrictions on device modification (e.g., jailbreaking) and the consequences of non-compliance. Explain	Documented restrictions and consequences for staff	

		when the Member Organization implements cyber security controls on their personal devices; for example when using modified devices (jailbreaking), terminating the employment or in case of loss or theft of the personal device.	procedures for handling device loss or theft and employee termination.	
	3.3.11.4.c	The isolation of business information from personal information (e.g., containerization).	Implement data isolation techniques like containerization to separate business data from personal data on BYOD devices.	Evidence of data isolation implementation
	3.3.11.4.d	The regulation of corporate mobile applications or approved "public" mobile applications.	Define and enforce policies for the use of corporate and approved public mobile applications on BYOD devices. This can include whitelisting or blacklisting specific applications.	Documented policies for mobile application usage
	3.3.11.4.e	The use of mobile device management (MDM); applying access controls to the device and business container	Utilize MDM solutions to manage BYOD devices, enforce access controls, and implement encryption mechanisms to secure data transmission and storage.	Evidence of MDM implementation and configuration

		and encryption mechanisms on the personal device (to ensure secure transmission and storage).		
CST CRF				
Control reference number	Control clauses	Control implementation guidelines	Expected deliverables	
2.3.1 CL1	Define and document [Cybersecurity Requirements for BYOD] within the organization which consider the following: • Isolation of personal information from the business information • Restrictions on the use of devices depending on the organization's business interest • Restrictions on the access of critical systems • Secure deletion of the organization's information	Develop and document a comprehensive BYOD policy that outlines the organization's requirements for using personal devices for work. This policy should include: - Clear guidelines on separating personal and business data on the device. - Restrictions on device usage based on the organization's needs. - Limitations on accessing critical systems from personal devices. - Procedures for securely deleting company data from the device.	Documented BYOD policy that covers all the specified requirements.	
2.3.2 CL1	Enforce the defined [Cybersecurity Requirements for BYOD] within the organization.	Implement and enforce the BYOD policy through appropriate technical and administrative controls. This may include: - Using Mobile Device Management (MDM) solutions to manage and secure devices. - Implementing access controls to restrict access to sensitive data and systems. - Providing user training and awareness on BYOD security practices.	Evidence of BYOD policy implementation and enforcement.	
2.3.3 CL1	Securely delete the organization's information after the completion of the	Establish procedures for securely deleting organization data from personal devices when	Documented procedures for secure	

	associated job function and when the information is no longer necessary.	employees leave the organization or when the data is no longer needed. This may involve using remote wipe capabilities or providing instructions for users to manually delete data.	data deletion from BYOD devices.	
2.3.4 CL2	Ensure that the organization's information stored on the devices are encrypted.	Implement encryption mechanisms to protect organization data stored on personal devices. This can include full-disk encryption, file-level encryption, or containerization.	Evidence of encryption implementation on BYOD devices.	
2.3.5 CL3	Continuously measure, review and optimize the [Cybersecurity Requirements for BYOD] within the organization.	Regularly review and update the BYOD policy and security controls to ensure they remain effective and relevant. This may involve conducting periodic security assessments, monitoring BYOD usage, and gathering feedback from users.	Documentation of continuous monitoring, review, and optimization activities.	
CMA Cybersecurity Guidelines				
Control reference number	Sub-Control	Control clauses	Control implementation guidelines	Expected deliverables
4.3.16-1		Set, document, approve and apply a BYOD cybersecurity policy.	Develop and document a comprehensive BYOD security policy by using the BYOD Security Policy Template that outlines the organization's requirements for using personal devices for work. This policy should include: - Clear guidelines on acceptable use of personal devices for work purposes. - Device security requirements, such as password protection and software updates. - Data protection measures, including data encryption and access controls. - User responsibilities for device security and data protection. - Incident reporting and response procedures.	Documented BYOD security policy that covers all the specified requirements.

4.3.16-2		Monitor compliance with the BYOD cybersecurity policy.	Establish a process to monitor compliance with the BYOD security policy. This can include: - Regular audits of devices to ensure they meet security requirements. - Monitoring of network traffic for suspicious activity from personal devices. - User training and awareness programs to promote compliance.	Evidence of BYOD policy compliance monitoring.
4.3.16-3		Measure effectiveness of BYOD cybersecurity controls, and evaluate them periodically.	Regularly assess the effectiveness of the BYOD cybersecurity controls through security assessments, vulnerability scans, and incident response reviews. Adjust the controls as needed to maintain adequate security.	Reports and documentation of BYOD security control evaluations.
4.3.16-4 BYOD cybersecurity policy shall include the following:	4.3.16-4-1	User responsibilities including training and raising awareness.	Clearly define user responsibilities for device security, data protection, and acceptable use. Conduct regular awareness training to educate users on BYOD policies and security best practices.	Documented user responsibilities and evidence of awareness training.
	4.3.16-4-2	Indication of restrictions imposed, and consequences to which employees shall be subject when applying cybersecurity controls to their personal devices; for example in cases such as using devices with modified (cracked) software (rooting or cracking tools "Jailbreaking"),	Inform staff about restrictions on device modification (e.g., jailbreaking) and the consequences of non-compliance. Explain procedures for handling device loss or theft and employee termination.	Documented restrictions and consequences for staff.

		termination of employment, or loss of personal device.		
	4.3.16-4-3	Separate market data and information from personal information (Containerization):	Implement data isolation techniques like containerization to separate business data from personal data on BYOD devices.	Evidence of data isolation implementation.
	4.3.16-4-4	Rule of use of genuine mobile applications related to market institution or general use.	Define and enforce policies for the use of genuine mobile applications on BYOD devices. This can include whitelisting or blacklisting specific applications.	Documented policies for mobile application usage.
	4.3.16-4-5	Use of Mobile Device Management (MDM) to apply remote access controls, encryption mechanisms and deletion of data and information stored on the personal device remotely.	Utilize MDM solutions to manage BYOD devices, enforce access controls, and implement encryption mechanisms to secure data transmission and storage.	Evidence of MDM implementation and configuration.

Risk Considerations in Mobile Devices Security

- **Unauthorized Access:** Risks of lost, stolen, or compromised devices leading to unauthorized access to sensitive data.
 - **BYOD Risks:** Personal devices may not comply with organizational policies, increasing vulnerabilities.
 - **Data Leakage:** Improper configurations or malware can result in sensitive organizational data leakage.
 - **Malware and APTs:** Mobile devices are often targeted by malicious software or advanced persistent threats.
 - **Weak Authentication:** Use of weak passwords or lack of multi-factor authentication increases vulnerability.
 - **Unpatched Vulnerabilities:** Delays in applying updates leave devices susceptible to exploitation.
 - **Insider Threats:** Malicious or careless employees can exploit mobile devices to harm the organization.
 - **Wireless Network Risks:** Mobile devices on unsecure or public Wi-Fi networks can be intercepted.
 - **Remote Wipe Failures:** Inability to remotely delete data on lost or stolen devices can lead to breaches.
 - **Non-Compliance:** Failure to meet standards like SAMA CSF, NCA ECC, or CST CRF may lead to penalties.
-

Examples of Technologies for Effective Mobile Devices Security

- **Mobile Device Management (MDM):** Centrally manage devices, enforce policies, and enable remote wipe.
 - **Endpoint Protection Solutions:** Protect devices from malware and unauthorized access.
 - **Data Encryption Tools:** Encrypt sensitive data stored or transmitted by mobile devices.
 - **Secure Containers:** Isolate organizational data from personal data on BYOD devices.
 - **Anti-Malware Tools:** Detect and prevent malware threats on mobile endpoints.
 - **Multi-Factor Authentication (MFA):** Enforce MFA for accessing devices and sensitive applications.
 - **Remote Wipe Solutions:** Enable secure data deletion from lost or stolen devices.
 - **VPNs:** Ensure secure communication over untrusted networks.
 - **Access Control Mechanisms:** Restrict and monitor access to mobile devices and applications.
 - **Patch Management Tools:** Keep devices updated with the latest security patches.
-

Examples of KPIs for Mobile Devices Security

- **Device Compliance Rate:** Percentage of devices meeting organizational security requirements.
 - **Patch Management Efficiency:** Percentage of devices updated with the latest patches within the defined period.
 - **Remote Wipe Success Rate:** Percentage of lost or stolen devices successfully wiped remotely.
 - **Data Encryption Coverage:** Percentage of devices with active encryption for sensitive data.
 - **User Security Awareness Training Coverage:** Proportion of employees trained on mobile device security practices.
 - **Incident Response Time:** Average time taken to address mobile device-related security incidents.
 - **BYOD Enrollment Rate:** Percentage of BYOD devices enrolled in the MDM system.
 - **Unauthorized Access Attempts:** Number of blocked attempts to access organizational systems via mobile devices.
-

Samples of Auditor's Checklist for Mobile Devices Security

1. Are mobile device security policies documented, approved, and regularly updated?
 2. Is an MDM system deployed to manage mobile devices centrally?
 3. Are encryption mechanisms implemented for sensitive data on mobile devices?
 4. Are mobile devices patched and updated regularly?
 5. Is remote wipe functionality activated for all mobile devices?
 6. Are access controls, such as MFA, implemented for mobile devices?
 7. Are BYOD devices segregated from corporate data using secure containers?
 8. Are mobile devices monitored for threats, including malware and unauthorized access?
 9. Is user awareness training conducted regularly for mobile device security?
 10. Are incident response plans in place for mobile device-related breaches?
-

Samples of Audit Scenarios for Mobile Devices Security

Scenario 1: MDM Deployment and Effectiveness

Objective: Assess the deployment and effectiveness of the Mobile Device Management system.

Steps:

1. Review MDM system configurations and policy enforcement.
2. Verify device compliance reports for organizational policies.
3. Test remote wipe functionality for enrolled devices.

Questions:

- Is the MDM system effectively managing devices?
- Are organizational policies enforced on all enrolled devices?

Scenario 2: BYOD Policy Compliance

Objective: Ensure BYOD devices comply with organizational security standards.

Steps:

1. Review the list of enrolled BYOD devices and their compliance status.
2. Check configurations for data isolation and encryption on BYOD devices.
3. Validate user adherence to BYOD policy requirements.

Questions:

- Are all BYOD devices compliant with the BYOD policy?
- Is business data isolated from personal data on BYOD devices?

Case Study 1: Strengthening Mobile Device Security in a Telecommunication Company

Scenario:

A leading telecommunication company faced challenges in managing and securing mobile devices used by employees and contractors. These devices accessed sensitive customer data and internal systems. Key vulnerabilities identified included unpatched devices, lack of centralized control, and unauthorized access attempts, particularly from BYOD devices.

Actions Taken:

1. Deployment of an MDM System:

- Implemented an enterprise-grade Mobile Device Management (MDM) solution to enforce security policies across all corporate and BYOD devices.
- Configured the MDM system to enable encryption, enforce password policies, and restrict unauthorized applications.
- Enabled features like geofencing and remote wipe to protect devices from unauthorized use in untrusted locations.

2. Enhanced Patch Management Process:

- Established automated patch management for all mobile devices, ensuring updates were applied promptly.
- Conducted periodic audits to ensure all devices met the latest security standards.

3. Improved Access Controls:

- Introduced multi-factor authentication (MFA) for accessing internal systems via mobile devices.
- Restricted BYOD devices to specific applications and data using secure containers.

4. Security Awareness and Training:

- Launched a comprehensive security awareness campaign targeting employees and contractors.
- Focused on the importance of mobile device security, secure handling of sensitive data, and recognizing phishing threats.

5. Monitoring and Threat Detection:

- Integrated mobile device logs into the company's Security Information and Event Management (SIEM) system for real-time monitoring.
- Enabled alerts for unauthorized access attempts, malware threats, and policy violations.

Outcome:

- Unauthorized access attempts reduced by 96%.
- Full compliance achieved with telecommunications regulations, including CST CRF and NCA ECC and NCA CCC.
- Increased employee awareness of mobile device security, with 95% of employees passing security quizzes post-training.
- Improved visibility and control over all mobile devices, enhancing the company's overall security posture.

Case Study 2: Enhancing Mobile Device Security in a Semi-Government Agency

Scenario:

A semi-government agency managing critical infrastructure faced risks from unmanaged mobile devices used by employees and external vendors. These devices posed threats due to inadequate encryption, lack of patching, and no centralized control. Additionally, the agency had to meet stringent compliance requirements, including NCA OTCC and CMA Cybersecurity Guidelines.

Actions Taken:

1. **Comprehensive Policy Development:**
 - Developed and approved a detailed Mobile Device Security Policy, including BYOD guidelines, encryption requirements, and patch management protocols.
 - Incorporated the policy into onboarding and vendor agreements to ensure compliance.
2. **Centralized Mobile Device Management:**
 - Deployed an MDM solution to manage corporate and BYOD devices.
 - Enabled remote wipe and data isolation for sensitive agency data.
 - Established role-based access controls to restrict device access based on user roles and responsibilities.
3. **Advanced Encryption and Threat Prevention:**
 - Implemented end-to-end encryption for all data stored and transmitted by mobile devices.
 - Deployed endpoint protection solutions to detect and prevent malware and advanced persistent threats (APTs).
4. **Telework Security Enhancements:**
 - Secured mobile devices used in telework environments by applying hardening configurations and ensuring patching.
 - Monitored telework device compliance with regular security assessments.
5. **Regular Assessments and Incident Management:**
 - Conducted quarterly security audits to ensure compliance with regulatory requirements.
 - Established an incident response plan for mobile device-related security breaches.
6. **Employee and Vendor Training:**
 - Organized targeted training sessions for employees and vendors on secure mobile device usage and phishing recognition.
 - Distributed guidelines for handling sensitive agency data on mobile devices.

Outcome:

- Reduced the risk of data breaches by 85% through enhanced encryption and centralized management.
- Achieved compliance with regulatory frameworks, including NCA OTCC, NCA ECC, and CMA Cybersecurity Guidelines.
- Improved patch management efficiency, with 98% of devices patched within 30 days of release.
- Increased security awareness, with 90% of employees and vendors scoring above 85% in post-training assessments.

2.7 Data and Information Protection:

Definition: Data and Information Protection involves implementing policies, processes, and technologies to safeguard an organization's data and information from unauthorized access, alteration, loss, or destruction. This includes protecting the confidentiality, integrity, and availability of data throughout its lifecycle, whether at rest, in transit, or during processing. Additionally, it ensures compliance with organizational standards, legal requirements, and regulatory frameworks [17], [18].

Objective: To ensure the confidentiality, integrity, and availability of the organization's data and information in alignment with organizational policies, procedures, and relevant laws and regulations.

Controls Matrix:

Below is a summary matrix detailing relevant network security management controls based on NCA Controls, SAMA CSF, CST CRF, and CMA Cybersecurity Guidelines:

Regulation	Main Controls	Control References
NCA ECC	3	2-7-1, 2-7-2, 2-7-3
SAMA CSF	-	-
CTS CRF	6	4.11.1, 4.11.2, 4.11.3, 4.11.4, 4.11.5, 4.11.6
CMA CSG	9	4.1.2-1, 4.1.2-2, 4.1.2-3, 4.1.2-4, 4.3.17-5, 4.1.2-6, 4.1.2-7, 4.1.2-8, 4.1.2-9
NCA CCCC	1	2-6-1 (5 sub-controls)
NCA CCC CST	1	2-6-T-1 (2 sub-controls)
NCA CCC CSP	1	2-6-P-1 (5 sub-controls)
NCA TCC	1	2-6-1 (2 sub-controls)
NCA DCC	1	2-4-1 (4 sub-controls)
NCA OSMACC	1	2-5-1 (1 sub-control)
NCA OTCC	2	2-6-1 (4 sub-controls), 2-6-2

Data and Information Protection Controls:

National Cybersecurity Authority - Essential Cybersecurity Controls ECC				
Control reference number	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
ECC-2.7.1	Cybersecurity requirements for protecting and handling data and information must be defined, documented and approved as per the related laws and regulations.	Data Security Policy Template	Cybersecurity requirements for data and information protection must be included and documented in line with policies issued by the National Data Management Office, including but not limited to: Data and Information Protection Requirements. Data and Information Ownership Requirements. Data and information Classification and Labelling Requirements. Data and Information Privacy Requirements. The policy must be supported by the Executive Management. This must be done through the approval of the organization head or his/her deputy.	Cybersecurity policy that covers the requirements of Data and Information Protection in the organization (e.g., electronic copy or official hard copy). Formal approval by the head of the organization or his/her deputy on the policy (e.g., via the organization's official e-mail, paper or electronic signature).
ECC-2.7.2	The cybersecurity requirements for protecting and handling data and information must be implemented, based on the classification levels.	Implement all cybersecurity requirements for data and information protection procedures in the organization. This may include the following:		Documents that confirm the implementation of cybersecurity requirements related to information and

		Data and information must be classified and labelled. Data and information must be backed up and archived. Data and information must be encrypted. Data and information must be securely deleted. Data and information must be securely transferred. Data and information must be securely stored. Data and information must be securely processed. Data and information must be securely disposed. Data and information must be securely used. Data and information must be securely managed. Data and information must be securely protected. Data and information must be securely handled. Data and information must be securely accessed. Data and information must be securely shared. Data and information must be securely transferred across borders. Data and information must be securely transferred across systems. Data and information must be securely transferred across applications. Data and information must be securely transferred across networks. Data and information must be securely transferred across devices. Data and information must be securely transferred across borders. Data and information must be securely transferred across systems.	data protection as documented in the policy. An action plan to implement the cybersecurity requirements for data and information protection. Evidence of implementation across all technical and information assets (e.g., configuration of technical systems).
--	--	---	---

		Data and information must be securely transferred across applications. Data and information must be securely transferred across networks. Data and information must be securely transferred across devices. Establish procedures to ensure the implementation of cybersecurity requirements adopted for the organization's data and information protection in accordance with the relevant laws and regulations.	
ECC-2.7.3	The cybersecurity requirements for data and information protection must be reviewed periodically.	Review the implementation of cybersecurity requirements for data and information protection by conducting a periodic assessment (according to a documented and approved plan for review, and based on a planned interval "e.g., quarterly") to implement the organization's data and information protection procedures by the Cybersecurity function and in cooperation with relevant departments (such as IT Department). Conduct application review through traditional channels (e.g., email) or automated channels using a compliance management system. The organization may develop a review plan outlining the cybersecurity requirements implementation review schedule for data and information protection. Review and update cybersecurity requirements for data and information protection in the organization periodically according to a documented and	Results of data and information protection cybersecurity requirements implementation review in the organization. A document that defines the cybersecurity requirements implementation review cycle for the organization's data and information security (Compliance Assessment Schedule). Compliance assessment report that outlines the assessment of the implementation of cybersecurity requirements for data and information protection in the organization.

		approved plan for review and based on a planned interval or in the event of changes in relevant laws and regulations. Document the review and changes to the cybersecurity requirements for data and information protection in the organization and approve them by the head of the organization or his/her deputy.	An approved document that sets the policy's review schedule Policy indicating that it is up to date and the changes to the cybersecurity requirements for data and information protection have been documented and approved by the head of the organization or his/her deputy. Formal approval by the head of the organization or his/her deputy on the updated policy (e.g., via the organization's official e-mail, paper or electronic signature).		
National Cybersecurity Authority – Critical Systems Cybersecurity Controls CSCC					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
CSCC-2.6.1 In addition to the sub-controls within Control 2-7-3 in the Basic Controls of Cybersecurity, it	CSCC-2.6.1.1	Not to use critical system data in a production environment other than the production environment, except after using	•Data Cybersecurity Policy Template Data Cybersecurity Standard Template	Work on identifying and classifying critical systems data based on the relevant legislative and regulatory requirements. Work to identify and use techniques/mechanisms to protect critical systems data	Reports on identifying and classifying critical systems data in the entity. A list of technologies/mechanisms used to protect the data of critical systems in the entity.

must cover the cybersecurity requirements for data and information protection; At a minimum, the following:		strict controls to protect that data, such as: data masking techniques or data scrambling techniques.		when used in a non-production environment, such as: data leakage prevention techniques.	
	CSCC-2.6.1.2	Categorize all critical systems data.	Data Cybersecurity Policy Template Data Cybersecurity Standard Template	Ensure that all critical systems data are classified based on the relevant legislative and regulatory requirements. Work on defining mechanisms and methods for dealing with data based on its classification.	A document showing the classification of all critical systems data with the rules taken based on the classification of the data.
	CSCC-2.6.1.3	Protect classified data of critical systems through Data Leakage Prevention techniques.	•Data Cybersecurity Policy Template Data Cybersecurity Standard Template Data Loss Prevention Standard Template	Work to identify and use techniques/mechanisms to prevent data leakage. Work on preparing a data loss prevention (DLP) solution based on the entity's data classification mechanism and based on size and type, and activate the alerts feature when an attempt is made to share critical data outside the entity. Working to develop procedures to deal with cases of data leakage of critical systems.	Reports of techniques/mechanisms used to prevent critical systems data leakage. A screenshot showing the application of data leakage (DLP) technology and activating a feature to receive alerts when an attempt is made to share critical systems data outside the entity. Procedures for dealing with cases of critical systems data leakage.
	CSCC-2.6.1.4	Determine the required retention	Data Cybersecurity Policy Template	Work on holding a workshop with stakeholders of critical	Reports retention periods for business data in critical

		period for business data related to critical systems; According to the relevant legislation, and only required data is kept in production environments for critical systems.	Data Cybersecurity Standard Template	systems, in addition to other relevant stakeholders from business units to determine retention periods for business data in critical systems based on data quality, data need and relevant legislation. Work with relevant departments to delete business data whose required retention period has expired according to the retention periods for business data in critical systems and using tools to ensure data deletion, such as: destroying and destroying devices containing critical data, overwriting critical data (Data Overwrite Method).	systems, based on the quality and need of the data. Reports of deletion of business data whose required retention period has expired in critical systems. Reports of tools used to delete critical systems data.
	CSCC-2.6.1.5	Prevent the transfer of any production environment data of critical systems to any other environment.	Data Cybersecurity Policy Template Data Cybersecurity Standard Template	Work to prevent the unauthorized transfer of critical systems data from the production environment to other environments (such as development and testing) through methods such as: restricting access and defining access to the production environment to the team responsible for its operation only, and ensuring that	Documented procedures to prevent the transfer of any production environment data of critical systems to any other environment.

				developers or testers do not access the environment production.	
National Cybersecurity Authority – Organization Social Media Accounts Cybersecurity Controls OSMACC					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
OSMACC-2.5.1 In addition to the subcontrols in ECC control 2-7-3, cybersecurity requirements for protecting and handling data and information for organization's social media accounts must include at least the following:	OSMACC-2.5.1.1	Technology assets for management of organization's social media accounts must not contain classified data, per relevant regulations.	Template for Cybersecurity Data Policy Template for Cybersecurity Data Standard	Review and verify that only relevant classification of data is present in the technology assets used for handling organization's social media accounts and no confidential data of the organization is present in these assets, in accordance with the organizational policies and procedures, as well as related national laws, regulations and agreements.	Review report of data classification contained in the assets used for handling organization's social media accounts.
National Cybersecurity Authority - Telework Cybersecurity Controls TCC					

Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
TCC-2.6.1 In addition to the sub controls in the ECC control 2-7-5, cybersecurity requirements for protecting and handling data and information must include at least the following:	TCC-2.6.1-1	Identifying classified data, according to the relevant regulations, that can be used, accessed or dealt with through telework systems.	Data Loss Prevention Standard Template	Work on defining the requirements for this control, document them in the cybersecurity requirements document, and have them approved by the authority holder. Identify data in storage and data in transit in private telework systems in accordance with the entity's data policies and Data Cybersecurity Controls (DCC) issued by the National Cybersecurity Authority. Determine the classification of data at each stage according to data cybersecurity controls (DCC).Ensure that all data that may be used, accessed or handled through teleworking systems is classified based on relevant regulatory and legislative requirements. Determine mechanisms and methods for dealing with data based on its classification.	A document that identifies and documents the requirements of this control (such as a policy and/or procedure approved by the authority holder). Documented and approved process for the data types their classification in telework systems. A guide to applying technical systems in cybersecurity to classify data within telework system.

	TCC-2.6.1-2	Protecting classified data, which was identified in control 2-6-1-1, using controls such as: not allowing the use of a specific type of classified data, or by the use of technology (e.g. Data leakage Prevention), such controls and technologies can be determined by analyzing the cyber risks of the organization.	Data Loss Prevention Standard Template	Work on defining the requirements for this control, document them in the cybersecurity requirements document, and have them approved by the authority holder. Identify and classify telework systems data based on relevant regulatory and legislative requirements. Conduct a cybersecurity risk analysis on the classified data (which was included in the outputs of control No. 2-6-1-1) in order to identify all potential threats that could affect the integrity of that data or expose it to any cyber risks or potential vulnerabilities. Taking into account the nature of this data. Based on the results of cyber risk analysis reports, work is done to identify controls or techniques that contribute to preventing the use of a type of classified data or preventing data leakage in the entity. Review, approve and implement controls necessary	A document that identifies and documents the requirements of this control (such as a policy and/or procedure approved by the authority holder). An approved document with a guide to implementing controls for data protection (preventing data leakage).A guide to implementing cybersecurity controls and techniques to prevent access, use, and transfer of restricted information to an internal or external user.
--	-------------	---	--	--	--

				to prevent data loss, using data leakage prevention tools and others, which are determined based on identified use cases and risk factors. • Data blocking use cases can be controlled at different levels, but are not limited to: email, sending documents with an external party, transferring data via physical devices such as: (USB, hard disk, etc.), and sharing data via hard drives. Network, transmission via Bluetooth connection, unwanted access to internal database server for telework users, use of remote sharing applications.	
National Cybersecurity Authority – Operational Technology Cybersecurity Controls OTCC					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
OTCC-2.6.1 In addition to subcontrols in the ECC control 2-7-3, cybersecurity requirements for data and information	OTCC-2.6.1.1	Electronic and physical data (at rest and in transit) must be protected at a level consistent with its classification.	Template for Cybersecurity Operational Technology Policy Template for OT/ICS Security Standard	Identify and classify electronic and physical data in OT/ICS environment. Ensure that the physical data (at rest and in transit) are protected by restricting the access to any classified or critical physical data, such as network diagrams, P&ID	Site visit to check that electronic and physical data (at rest and in transit) are protected in line with the data classification.

protection in OT/ICS must include, at a minimum, the following:			Template for Data Cybersecurity Policy Template for Data Cybersecurity Standard	diagrams, and engineering documents. Ensure that the electronic data (at rest and in transit) are protected by implementing security controls including but not limited to: (enable session timeout and lockout in engineering workstation, configure the removable media settings).	
	OTCC-2.6.1.2	Data Leakage Prevention (DLP) mechanisms must be used to protect the classified data and information.	Template for Cybersecurity Operational Technology Policy Template for OT/ICS Security Standard Template for Data Loss Prevention Standard Template for Data Cybersecurity Policy Template for Data Cybersecurity Standard	Implement Data Leakage Prevention (DLP) mechanisms in the OT/ICS environment (e.g. data transfer monitoring or data access management tools). Verify and ensure that data and information are protected by Data Leakage Prevention (DLP) mechanisms.	Site visit to check that classified data and information are protected by Data Leakage Prevention (DLP) mechanisms.
	OTCC-2.6.1.3	Secure wiping mechanisms for configuration details and stored data	Template for Cybersecurity Operational Technology	Define and formally document secure wiping procedure for OT/ICS assets.	A documented secure wiping procedures.

		from OT/ICS assets prior to decommissioning must be implemented.	PolicyTemplate for OT/ICS Security Standard Template for Data Cybersecurity PolicyTemplate for Data Cybersecurity Standard	Verify and ensure that all OT/ICS assets before decommissioning are securely wiped.	A proof that all OT/ICS assets are securely wiped before decommissioning.
	OTCC-2.6.1.4	Transfer or usage of OT systems' data in any environment other than production environment must be limited, except after applying strict controls for protecting that data.	Template for Cybersecurity Operational Technology PolicyTemplate for OT/ICS Security Standard Template for Data Cybersecurity PolicyTemplate for Data Cybersecurity Standard	Limit and verify transfer or usage of OT systems data in any environment other than the production environment. Ensure that the transfer or usage of OT systems data in any environment other than production environment is limited, except after applying strict controls including but not limited to; (scanning the USBs and Hard Disks against Malware and APT, configure the removable media settings to allow a certain list of known USBs, and using secure file server).	Site visit to check that the transfer or usage of OT systems data in any environment other than production is limited, apart from environments that apply strict controls for protecting that data.
OTCC-2.6.2	With reference to the ECC control 2-7-4, the cybersecurity requirements for data and information protection in OT/ICS environment must be reviewed, and their		Template for Cybersecurity Operational Technology PolicyTemplate for	Review the cybersecurity requirements for data and information protection periodically based on a documented and approved review plan and on a defined	A proof that shows the periodic review of cybersecurity requirements for data and information protection in the OT/ICS environment.

	implementation effectiveness is measured and evaluated periodically.	OT/ICS Security Standard Template for Data Cybersecurity Policy Template for Key Performance Indicator Report	frequency (e.g., conduct a review annually). Develop key performance indicators (KPIs) for each control within the related policy or procedure to ensure the implementation effectiveness is measured and evaluated periodically based on a defined frequency (e.g., conduct reviews annually).	A proof that shows the key performance indicators (KPIs) for each control within the related policy or procedure to ensure the implementation effectiveness is measured and evaluated periodically based on a defined frequency (e.g., conduct reviews annually).	
National Cybersecurity Authority - Cloud Cybersecurity Controls CCC					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
CCC-CSP-2.6-P-1 In addition to sub controls in the ECC control 2-7-3, the CSP shall cover the following additional sub controls for cybersecurity requirements for data and information protection	CCC-CSP-2.6-P-1-1	Prohibiting the use of Cloud Technology Stack's data in any environment other than production environment, except after applying strict controls for protecting that data, such as: data masking or data scrambling techniques.	Template for Data Security Policy Template for Data Security Standard	Segregate physically or logically production and non-production environment. Generate and use synthetic data in non-production environments Build barriers to transfer data from/to production environment Introduce an authorized channel/gateway to exchange data between environments that verifies data relevant to Cloud Technology Stack is masked/tokenized/scrambled in a way that ensures that	Segregated production data with test data. Architecture design documentation.

requirements, as a minimum:				original data cannot be reverse engineered.	
	CCC-CSP-2.6-P-1-2	Provision to CSTs of securely data storage processes, procedures, and technologies to comply with related legal and regulatory requirements.	Template for Data Security Policy Template for Data Security Standard	Identify legal and regulatory requirements related to cloud data storage (e.g.: encryption of personal information)Enable functionalities and technologies (and related processes) to let CSTs comply with these obligations (e.g. encryption mechanisms inbuilt in cloud services Communicate to CST these functionalities	List of applicable legal and regulatory requirements. Data storage processes and technologies compliant to legal requirements.
	CCC-CSP-2.6-P-1-3	Disposal of CST's data should be performed in a secure manner on termination or expiry of the contract with the CSP.	Template for Data Security Policy Template for Data Security Standard	Monitor contracts with CSTs regarding their expiration or termination. Dispose CST's data as soon as possible when there is no valid contract. • Dispose CST's data using approved methods to ensure this process is irreversible considering used data storage technical methods and data recovery technical capabilities.	Contract statuses monitoring Records of disposed CSTs data with specification of the disposal methods used.
	CCC-CSP-2.6-P-1-4	Commitment to maintain the confidentiality of the CST's data and	Template for Data Security Policy Template for	Identify and analyse legal and regulatory requirements for storing and processing CST's data (e.g.: data encryption).	Ensure storing and processing CST's data is subject to legal and regulatory regulations.

		information, according to related legal and regulatory requirements.	Data Security Standard		
	CCC-CSP-2.6-P-1-5	Providing CSTs with secure means to export and transfer data and virtual infrastructure	Template for Data Security Policy Template for Data Security Standard	Build cloud services with embedded functionalities to export and transfer data and virtual infrastructure out over a secured, encrypted connection or channel.	Secure data/assets export functionalities over an encrypted and secure channel or connection.
CCC-CST-2.6-T-1 In addition to sub controls in the ECC control 2-7-3, the CST shall cover the following additional sub controls for cybersecurity requirements for protecting CST's data and information in cloud computing, as a minimum:	CCC-CST-2.6-T-1-1	Exit Strategy to ensure means for secure disposal of data on termination or expiry of the contract with the CSP.	Template for Data Cybersecurity Policy Template for Data Cybersecurity Standard	Analyse cloud technical capabilities to securely dispose data stored in cloud storage (e.g.: data encryption using CST managed key including that key disposal) Define Cloud Exit strategy including cryptographic key disposal to make CST's data encrypted in CSP's infrastructure after leaving.	Cloud Exit Strategy documented. Evidence confirming the existence of a service provided by the CSP that allow the CST to securely dispose of data or, at the very least, within the contract between the CST and the CSP, grants the CST the ability to dispose of the data.
	CCC-CST-2.6-T-1-2	Using secure means to export and transfer data and virtual infrastructure.	Analyse portability of solutions deployed to CSPs (e.g.: dependency on CSP's native services, features, technologies) Ensure the formatting of data and export technical capabilities of data in cloud services (eg.: usage of standardized data formats, protocols) Ensure the virtual assets and data can be transferred out securely (e.g.: through encrypted channels) on demand.		Defined requirements and applied security measures relevant to export and transfer of data and virtual infrastructure.

National Cybersecurity Authority - Data Cybersecurity Controls DCC					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
DCC-2.4.1 In addition to the subcontrols in ECC control 2-7-3, cybersecurity requirements for data and information protection must cover at least the following:	DCC-2.4.1.1	Using Watermark feature to label the whole document when creating, storing, printing on the screen and on each copy so that the symbol can be traced to the user or device level.	Template for Cybersecurity Data Protection Policy Template for Cybersecurity Data Protection Standard	Identify the requirements of this control and document them in a cybersecurity requirements document, followed by approval from the authorizing officials. Review and select the software or system, used to create, store, print and display data in the organization, that has the capability to label data using watermark as per the data classification and unique traceable number throughout the document's lifecycle. Implement the above said features for all the secret and top secret data documents while creating, storing, printing or displaying the document.. Identify and define the data classification policy to include the watermark labelling and unique traceable features for the organization's documents.	Document detailing the identification and documentation of the requirements of this control (e.g. a policy and/or procedure approved by the authorizing officials). Implementation plan for Watermark and unique traceable number feature in document software or system. Documented and approved data cybersecurity policy which includes the documentation features for secret and top-secret data. Sample of a document labelled with watermark.

	DCC-2.4.1.2	Using Data Leakage Prevention technologies and Rights Management technologies.	Template for Cybersecurity Data Protection Policy Template for Cybersecurity Data Protection Standard	Identify the requirements of this control and document them in a cybersecurity requirements document, followed by approval from the authorizing officials. Define and document Data Leakage Prevention (DLP) and Rights Management standards. Identify and implement the Data Leakage Prevention (DLP) and Rights Management systems as per the requirements for confidential, secret and top secret data. Review the Data Leakage Prevention techniques that should include, but not limited to, rule for incident identification, message filtering mechanism, data leak prevention for endpoints, network, cloud and/or storage, content filtering capabilities, incident response and remediation. Review the Rights Management techniques that should include, but not limited to, automated provisioning,	Document detailing the identification and documentation of the requirements of this control (e.g, a policy and/or procedure approved by the authorizing officials). Documented Data Leakage Prevention standard. Implementation plan for Data Leakage Prevention (DLP) system. Implementation plan for Rights Management system. Screenshot of Data Leakage Prevention (DLP) and Rights Management systems in use. Sample of Data Leakage Prevention (DLP) and Rights Management systems' configurations.
--	-------------	--	---	--	--

				privileged activity monitoring, login auditing, password management utilities, LDAP entry management, two factor authentication.	
	DCC-2.4.1.3	Prohibiting the use of data in any environment other than the production environment, except after conducting a risk assessment and applying controls to protect that data, such as: data masking or data scrambling techniques.	Template for Cybersecurity Data Protection Policy	Identify the requirements of this control and document them in a cybersecurity requirements document, followed by approval from the authorizing officials. Identify and maintain record of all the environments other than production environment. Review and verify that migration of restricted, secret and top secret data in the production environment is not allowed in the non-production environments. However, in case of business requirements, appropriate checks and controls should be applied, which includes, but not limited to, data masking/data scrambling, data purging, data anonymization, appropriate business and technical approvals of requirements, information security assessment.	Document detailing the identification and documentation of the requirements of this control (e.g., a policy and/or procedure approved by the authorizing officials). Documented procedures and controls about migration of production data into other environments.

				Develop and document cybersecurity controls that include data migration risk assessment, protection of data during migration through protection techniques (e.g. data masking, data scrambling, etc.) Develop and document procedures about migration of production data in non-production environments.	
	DCC-2.4.1.4	Using brand protection service to protect the organization's identity from impersonation.	Template for Data Loss Prevention Standard	Identify the requirements of this control and document them in a cybersecurity requirements document, followed by approval from the authorizing officials. Identify and maintain record of all the identities in the organization brand online that might be prone to impersonation. Review the available vendors that provide brand protection services and analyse the suitability of the service based on the requirements of the organization. Review and implement the brand protection service for the organization's identities.	Document detailing the identification and documentation of the requirements of this control (e.g. a policy and/or procedure approved by the authorizing officials). Documented list of identities in the organization that are prone to impersonation. Implementation plan of vendor brand protection service. Sample of brand protection reports and alerts.

CST CRF			
Control reference number	Control clauses	Control implementation guidelines	Expected deliverables
4.11.1 CL1	Define and document [Requirements for Information Protection] which consider the following: Classification level and criteria (e.g. restricted, confidential, public) (Asset Classification) Privacy, ownership, protection, transmission, and retention of information Ensuring the privacy of personally identifiable information or other sensitive information in the organization [Cybersecurity Compliance]	Develop and document cybersecurity requirements for information protection, considering: - Defining classification levels and criteria for information assets. - Establishing procedures for handling information based on its classification. - Addressing privacy, ownership, protection, transmission, and retention of information. - Ensuring compliance with regulations related to personally identifiable information (PII) and other sensitive data.	Documented cybersecurity requirements for information protection.
4.11.2 CL1	Define and implement an {Information Classification} process considering: Categorize information based on the classification criteria specified in the requirements Handle critical information according to the defined criteria (e.g. business value, legal, technical, national requirements) and cross-border	Develop and implement an information classification process that includes: - Categorizing information assets based on defined classification criteria. - Handling critical information according to specific criteria, including business value, legal, technical, and national requirements, as well as cross-border considerations.	Documented information classification process and evidence of implementation.
4.11.3 CL1	Implement security mechanisms to protect information (in transit, at rest, in use) taking into account the	Implement security mechanisms to protect information in all states (in transit, at rest, in use). This may include: - Encryption of data in transit and	Evidence of implemented security mechanisms for information protection.

	[Requirements for Cryptography] and data loss prevention techniques.	at rest. - Access controls to restrict unauthorized access. - Data loss prevention (DLP) techniques to prevent data leakage. - Secure storage and disposal of information.	
4.11.4 CL1	Prevent the transmission of information from production environment to another environment and the usage of critical systems data in test and development environments.	Establish and implement strict controls to prevent the transfer of production data to other environments (e.g., development, testing). This can include access restrictions, data masking techniques, or separate isolated environments.	Evidence of controls preventing data transmission from production to other environments.
4.11.5 CL2	Determine a retention period for information in accordance with organizational requirements and relevant legislations. Restrict the retention of critical information to the necessary requirements. [Cybersecurity Compliance]	Define and implement data retention policies based on organizational needs and legal requirements. Ensure that critical information is retained only for the necessary duration.	Documented data retention policies and evidence of compliance.
4.11.6 CL3	Continuously measure, review and optimize the [Requirements for Information Protection] as well as the effectiveness of the process.	Regularly monitor, review, and improve information protection measures to ensure their continued effectiveness and alignment with organizational needs and regulatory requirements.	Documentation of continuous monitoring, review, and optimization activities.
CMA Cybersecurity Guidelines			
Control reference number	Control clauses	Control implementation guidelines	Expected deliverables
4.1.2-1	Develop and design Data Governance Program.	Develop and design a comprehensive Data Governance Program that outlines the organization's policies and procedures for managing and protecting data. This program should include: Clear roles and responsibilities for data management.	Documented Data Governance Program

		Data classification and labeling standards. Data access control policies. Data retention and disposal procedures. Data breach response plan.	
4.1.2-2	Identify data fields: Data Owners -Business Procedures- Data managers -Data Lists-Data Custodians -Report lists-Data users- Systems and applications- Data Dictionaries- Policies and standards	Identify and document all data fields within the organization's information systems. This includes: Identifying the types of data stored in each field. Determining the sensitivity and criticality of each data field. Implementing data masking or encryption for sensitive data fields.	Documented list of all data fields.
4.1.2-3	Identify sensitive data elements within data fields.	Identify and document sensitive data elements within each data field. This includes: Defining criteria for identifying sensitive data. Implementing access controls and encryption for sensitive data elements.	Documented list of sensitive data elements.
4.1.2-4	Determine classification and mechanism of data encoding according to level of importance.	Define data classification levels and the corresponding encoding mechanisms based on the level of data importance. This includes: Developing a data classification guide. Implementing encryption and access controls based on data classification levels.	Documented data classification levels and encoding mechanisms.
4.3.17-5	Identify privacy of data and information.	Identify and document the privacy requirements for data and information. This includes: Complying with relevant data privacy regulations. Implementing data anonymization or pseudonymization techniques.	Documented privacy requirements for data and information.
4.1.2-6	Create centralized platform for managing and controlling changes and providing access to sensitive data assets.	Implement a centralized platform for managing and controlling changes to sensitive data assets. This includes:	Centralized platform for managing and controlling changes to sensitive data assets.

		Implementing access controls and encryption for sensitive data. Monitoring and logging access to sensitive data.	
4.1.2-7	Specify mechanism to measure level of data protection.	Define and implement mechanisms to measure the level of data protection. This includes: Conducting regular security assessments and audits. Monitoring and reporting on security incidents.	Documented mechanisms for measuring data protection levels.
4.1.2-8	Identify and implement workflow plans of governance structure and key data elements and fields.	Identify and document the workflow plans for the data governance structure and key data elements and fields. This includes: Defining roles and responsibilities for data governance. Implementing data quality control procedures.	Documented workflow plans for data governance.
4.1.2-9	Observe, monitor, and report workflow procedures.	Monitor and report on the workflow procedures for data governance. This includes: Tracking data access and modification requests. Reporting on data quality issues and security incidents.	Documented monitoring and reporting procedures for data governance.

Risk Considerations in Data and Information Protection

1. **Unauthorized Access:**
 - Risks from inadequate access controls or identity management systems, leading to unauthorized access to sensitive data.
2. **Data Leakage:**
 - Improper data classification or lack of Data Leakage Prevention (DLP) mechanisms can expose sensitive data.
3. **Unencrypted Data:**
 - Storing or transmitting data without encryption increases exposure to cyber threats.
4. **Weak Data Backup Protocols:**
 - Insufficient or insecure backup methods risk data loss during breaches or incidents.
5. **Regulatory Non-Compliance:**
 - Failing to meet standards such as NCA ECC, CST CRF, or SAMA CSF can result in legal and financial penalties.

Examples of Technologies for Effective Data and Information Protection

1. **Data Classification Solutions:**
 - Automates classification based on sensitivity levels (e.g., Varonis, Boldon James).
2. **Encryption Tools:**
 - Secure data in transit and at rest using AES-256 or TLS.
3. **Data Loss Prevention (DLP) Systems:**
 - Monitor and prevent unauthorized data transfers (e.g., Symantec DLP, McAfee DLP).
4. **Access Control Mechanisms:**
 - Enforce role-based access controls (RBAC) using tools like SailPoint or BeyondTrust PAM.
5. **Backup Solutions:**
 - Tools like Veeam Backup & Replication to ensure regular and secure backups.

Examples of KPIs for Data and Information Protection

1. **Encryption Coverage:**
 - Percentage of sensitive data encrypted at rest and in transit.
2. **DLP Incident Rate:**
 - Number of DLP alerts generated and resolved within a given period.
3. **Backup Success Rate:**
 - Percentage of successful backups completed without errors.
4. **Compliance Rate:**
 - Proportion of systems and processes compliant with relevant standards like NCA ECC.
5. **Access Control Violations:**
 - Instances of unauthorized access attempts blocked or flagged.

Samples of Auditor's Checklist for Data and Information Protection

1. Are data classification policies and procedures in place and followed?
 2. Is sensitive data encrypted at rest and in transit?
 3. Are DLP systems deployed and actively monitoring data flow?
 4. Are access control mechanisms like RBAC implemented and reviewed periodically?
 5. Are regular backups performed, and is backup integrity tested periodically?
 6. Are compliance requirements with NCA ECC, CST CRF, and SAMA CSF documented and adhered to?
 7. Is there an incident response plan for data breaches?
 8. Are periodic reviews conducted to ensure adherence to data protection policies?
-

Samples of Audit Scenarios for Data and Information Protection

Scenario 1: Encryption Compliance

- **Objective:** Assess encryption practices for sensitive data.
- **Steps:**
 1. Review encryption policies and implementation guidelines.
 2. Verify encryption configurations on data storage and during transmission.
 3. Test decryption processes for compliance with organizational standards.
- **Questions:**
 - Is sensitive data encrypted using approved methods?
 - Are encryption keys securely managed?

Scenario 2: Data Leakage Simulation

- **Objective:** Test the effectiveness of DLP mechanisms.
 - **Steps:**
 1. Simulate an attempt to exfiltrate sensitive data.
 2. Monitor alerts and actions triggered by DLP systems.
 3. Review incident response actions and logging.
 - **Questions:**
 - Does the DLP system detect and block unauthorized data transfers?
 - Are incidents logged and escalated appropriately?
-

Case Study 1: Data Protection in a Financial Institution

Background

A leading financial institution faced increasing challenges in securing sensitive customer data across its operations. The risks identified included:

- Unauthorized access attempts from external threat actors.
- Lack of a comprehensive Data Loss Prevention (DLP) system.
- Gaps in encryption practices, leaving some sensitive customer data vulnerable.
- Limited employee awareness of data protection protocols.

The institution needed to comply with stringent regulations, including **SAMA CSF**, and **NCA ECC-DCC**, while maintaining customer trust and protecting its reputation.

Challenges Identified

1. **Unauthorized Access:**
 - Weak access controls allowed multiple incidents of attempted data breaches.
2. **Data Leakage:**
 - Absence of a DLP system increased the risk of accidental or malicious data sharing.
3. **Compliance Gaps:**
 - Non-alignment with regional data protection regulations like NCA DCC.
4. **Employee Awareness:**
 - Employees lacked adequate training on secure data handling and phishing recognition.

Actions Taken

1. **Deployment of a Comprehensive DLP System:**
 - Implemented Symantec DLP to monitor data in motion, at rest, and in use.
 - Configured policies to restrict sensitive data transfer via email, external drives, and cloud applications.
 - Enabled real-time alerts for potential data leakage incidents.
2. **Strengthened Access Controls:**
 - Introduced **Role-Based Access Control (RBAC)** to restrict data access based on job roles.
 - Integrated **Multi-Factor Authentication (MFA)** to protect access to sensitive systems.
3. **Enhanced Encryption Practices:**
 - Applied AES-256 encryption for sensitive customer data both at rest and in transit.
 - Used Transport Layer Security (TLS) for secure communication channels.
4. **Regular Audits and Monitoring:**
 - Conducted biannual data protection audits to identify compliance gaps.
 - Integrated DLP logs into the Security Information and Event Management (SIEM) system for real-time threat detection.
5. **Employee Training and Awareness Campaign:**

- Launched organization-wide training on data protection best practices.
- Conducted phishing simulations to improve employee vigilance against social engineering attacks.

Outcomes

- **Reduction in Unauthorized Access:**
 - Incidents dropped by **85%**, attributed to RBAC and MFA implementation.
 - **Enhanced Compliance:**
 - Achieved full compliance with SAMA CSF, and NCA ECC.
 - **Improved Employee Awareness:**
 - **94% of employees** passed data security quizzes, up from 60% before training.
 - **Reduced Data Leakage:**
 - DLP system identified and blocked **95%** of potential data exfiltration attempts.
 - **Improved Incident Response:**
 - Average response time to data protection incidents reduced by **50%**.
-

Expanded Case Study 2: Data Protection in a Semi-Government Agency

Background

A semi-government agency managing critical national infrastructure faced significant risks due to inadequate data protection measures. The agency relied on outdated systems, lacked centralized control over sensitive data, and struggled to meet compliance requirements under **NCA ECC and NCA DCC**.

Challenges Identified

1. **Data Misclassification:**
 - Sensitive data was not adequately classified, leading to inconsistent protection measures.
2. **Unencrypted Data:**
 - Critical data in transit and at rest remained unencrypted, exposing it to interception.
3. **Vendor Risks:**
 - External vendors were granted access to sensitive systems without sufficient controls.
4. **Telework Vulnerabilities:**
 - Mobile and telework devices lacked security hardening, posing risks during remote operations.

Actions Taken

1. **Policy Development:**
 - Designed and implemented a **Data Protection Policy** with clear guidelines on classification, encryption, and access management.
 - Incorporated these policies into vendor agreements to ensure third-party compliance.
2. **Centralized Data Management:**
 - Deployed a **Data Classification and Management System** to classify and label sensitive data.
 - Used Data Loss Prevention (DLP) tools to monitor and control data access.
3. **Encryption and Access Control:**
 - Applied end-to-end encryption for all sensitive data, including backups and communications.
 - Restricted vendor access to specific systems using **RBAC** and monitored their activities.
4. **Telework Security Enhancements:**
 - Implemented an **MDM Solution** to secure devices used for remote work.
 - Applied hardening configurations to all telework devices and ensured compliance through regular assessments.
5. **Regular Audits and Incident Management:**
 - Conducted quarterly audits to identify vulnerabilities and ensure compliance.
 - Developed an incident response plan to handle data breaches, with simulation exercises to test its effectiveness.

6. Training for Employees and Vendors:

- Organized targeted training on secure data handling, phishing recognition, and device security.
- Distributed best practices for managing sensitive agency data during telework.

Outcomes

- **Reduced Risk of Data Breaches:**
 - Risk reduced by **85%** through centralized data management and enhanced encryption.
- **Improved Compliance:**
 - Achieved full alignment with NCA ECC, and NCA DCC.
- **Strengthened Vendor Oversight:**
 - Vendor compliance improved by **90%** due to clear agreements and restricted access.
- **Enhanced Patch Management:**
 - **98% of devices** were patched within 30 days of updates being released.
- **Increased Security Awareness:**
 - **90% of employees and vendors** scored above 85% in post-training assessments.
- **Faster Incident Response:**
 - Incident response time reduced by **40%**, ensuring minimal disruption during breaches.

2.8 Cryptography:

Definition: Cryptography involves the use of mathematical techniques to secure information by transforming it into a format that is unreadable without the correct decryption process. It ensures the confidentiality, integrity, and authenticity of data in transit and at rest, protecting sensitive information from unauthorized access, alteration, or disclosure. Cryptography also encompasses key management practices and the use of approved cryptographic solutions to comply with technical and regulatory requirements [19], [20], [21].

Objective: To ensure the proper and efficient use of cryptographic techniques to safeguard information assets in alignment with organizational policies, procedures, and applicable laws and regulations. This includes defining, implementing, and periodically reviewing cryptographic requirements to ensure the protection of sensitive data throughout its lifecycle.

Controls Matrix:

Below is a summary matrix detailing relevant cryptography controls based on NCA Controls, SAMA CSF, CST CRF, and CMA Cybersecurity Guidelines:

Regulation	Main Controls	Control References
NCA ECC	4	2-8-1, 2-8-2, 2-8-3 (3 sub-controls), 2-8-4
SAMA CSF	4	3.3.9-1, 3.3.9-2, 3.3.9-3, 3.3.9-4 (3 sub-controls: a, b, c)
CTS CRF	5	4.1.1, 4.1.2, 4.1.3, 4.1.4, 4.1.5
CMA CSG	4	4.3.11-1, 4.3.11-2, 4.3.11-3, 4.3.11-4 (4 sub-controls: 1, 2, 3, 4)
NCA CCCC	1	2-7-1 (3 sub-controls)
NCA CCC CST	1	2-7-T-1 (2 sub-controls)
NCA CCC CSP	1	2-7-P-1 (2 sub-controls)
NCA TCC	1	2-7-1 (1 sub-control)
NCA DCC	1	2-5-1 (2 sub-controls)
NCA OSMACC	-	No specific cryptography controls found
NCA OTCC	2	2-7-1, 2-7-2

Cryptography Controls:

National Cybersecurity Authority - Essential Cybersecurity Controls ECC					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
2.8-1		Cybersecurity requirements for cryptography must be defined, documented and approved. This includes developing a cybersecurity policy for cryptography in the organization.	Cryptography Policy Template.	• Develop and document cybersecurity policy for cryptography in the organization, including the following: - O Standard controls of approved cryptography solutions and applicable restrictions (technically and regulatorily). - O Secure management of cryptographic keys during their lifecycle. - O Information must be encrypted in transit and storage based on classification as well as the relevant laws and regulations. • Support the organization's policy by the Executive Management. This must be done through the approval of the organization head or his/her deputy.	• Cybersecurity policy that covers all the requirements of cryptography in the organization (e.g., electronic copy or official hard copy). • Formal approval by the head of the organization or his/her deputy on the policy (e.g., via the organization's official e-mail, paper or electronic signature).
2.8-2		The cybersecurity requirements for cryptography	• Implement all cybersecurity requirements to the organization's approved cryptography procedures. • It	An action plan to implement cybersecurity	

		must be implemented.	is also recommended that the cryptography procedures cover the following, but not limited to: - O Standard controls of approved cryptography solutions and applicable restrictions (technically and regulatorily). - O Secure management of cryptographic keys during their lifecycle. - O Information must be encrypted in transit and storage based on classification as well as the relevant laws and regulations. • Approved cryptographic hash functions should be defined based on national cryptographic standard controls.	requirements for cryptography. • Evidence showing the uses modern cryptography technologies in the organization (e.g., the presence of advanced encryption technologies in the organization, security procedures and standard controls that support the implementation of cryptography in the organization).
2.8-3 The cybersecurity requirements for cryptography must include at least the following:	2.8-3-1	Approved cryptographic solutions ¹ standard controls and its technical and regulatory limitations.	Cryptography Standard Template. • Define and document the requirements of this ECC in the cybersecurity requirements document and must be approved by the representative. • Define standard controls of approved cryptographic solutions and use NCAs' cryptographic standard controls, including, but not limited to: -Acceptable symmetric and asymmetric cryptographic fundamentals. -PKI Procedures. -Key Cycle Management Procedure. • Define standard controls and technical limitations of approved cryptographic solutions and ensure their compliance with national cryptography standard controls, including but not limited to:	• Cryptography standard controls document approved by the organization (e.g., electronic copy or official hard copy). • Formal approval by the head of the organization or his/her deputy on such standard controls (e.g., via the organization's official e-mail, paper or electronic signature).

			-Acceptable symmetric and asymmetric cryptographic designs. -Acceptable common application protocols related to cryptography. -PKI technologies and tools. -Key cycle management techniques and tools.	• Evidence showing the implementation of the requirements of the approved technical cryptographic solutions standard controls and the restrictions applied to them (e.g., a screenshot showing evidence of ensuring that modern and advanced technologies are used to implement the standard controls of approved technical cryptography solutions and the restrictions applied to all systems in the organization).
	2.8-3-2	Secure management of cryptographic keys during their lifecycles.	• Define and document the requirements of this ECC in the cybersecurity requirements document and must be approved by the representative. • Define and approve procedures for the secure management of cryptographic keys during their lifecycle. • Define and implement appropriate and advanced techniques for the secure management of cryptographic keys during their lifecycle, including, but not limited to: - Cryptographic key storage mechanism. - Cryptographic key transfer mechanism.	• Cybersecurity policy that covers all the requirements of cryptography in the organization (e.g., electronic copy or official hard copy). • Cybersecurity procedure that covers all the requirements of cryptographic keys management in the

			Key creation and destruction mechanism. • Review the effectiveness of technologies used for the secure management of cryptographic keys.	organization (e.g., electronic copy or official hard copy). • Document that defines the technology effectiveness review cycle used for the secure management of cryptographic keys during their lifecycle. • Formal approval by the head of the organization or his/her deputy on such documents (e.g., via the organization's official e-mail, paper or electronic signature). • Evidence that the secure management requirements for cryptographic keys are implemented throughout their lifecycle (e.g., a screenshot showing evidence to ensure that cryptographic key settings are configured to the best standard controls for the secure management of
--	--	--	---	---

				cryptographic keys during their lifecycle).
	2.8-3-3	Encryption of data in-transit and at-rest as per classification and related laws and regulations.	• Define and document the requirements of this ECC in the cybersecurity requirements document and must be approved by the representative. • Define appropriate and advanced technologies to encrypt data in transit based on their classification, including but not limited to: TLS (Transport Layer Security) must be used. • Define appropriate and advanced technologies to encrypt data in transit based on their classification. • Review the effectiveness of technologies used to encrypt data in transit based on classification. • Define appropriate and advanced technologies to encrypt data in storage based on their classification, including but not limited to: TDE (Transparent Data Encryption) must be used. • Define appropriate and advanced technologies to encrypt data in storage based on their classification. • Review the effectiveness of technologies used to encrypt data in transit based on classification.	• Cryptography of data in transit document approved by the organization (e.g., electronic copy or official hard copy). • Formal approval by the head of the organization or his/her deputy on such procedures (e.g., via the organization's official e-mail, paper or electronic signature). • Evidence that data in transit cryptography requirements must be implemented based on their classification (but not limited to a screenshot showing the implementation of data in transit encryption based on its classification). • Cryptography of data in transit document approved by the organization (e.g.,

				electronic copy or official hard copy). • Formal approval by the head of the organization or his/her deputy on such procedures (e.g., via the organization's official e-mail, paper or electronic signature). • Evidence that data in transit cryptography requirements must be implemented based on their classification (but not limited to a screenshot showing the implementation of data in transit encryption based on its classification).
2.8-4		The cybersecurity requirements for cryptography must be reviewed periodically.	• Review the cybersecurity requirements of cryptography by conducting a periodic assessment (according to a documented and approved plan for review, and based planned on a interval "e.g., quarterly") to implement identity and access management requirements by the Cybersecurity function and in cooperation with relevant departments (such as IT Department). • Review and update cybersecurity requirements for cryptography in the organization periodically according to a documented and approved plan for review and based	• Results of cryptography requirements implementation review in the organization. • A document that defines the cybersecurity requirements implementation review cycle for cryptography in the organization

			on a planned interval or in the event of changes in relevant laws and regulations. • Document the review and changes to the cybersecurity requirements for cryptography in the organization and approve them by the head of the organization or his/her deputy.	(Compliance Assessment Schedule). • Compliance assessment report that outlines the assessment of the implementation of cybersecurity requirements for cryptography in the organization. • An approved document that sets the policy's review schedule. • Policy indicating that it is up to date and the changes to the cybersecurity requirements for cryptography have been documented and approved by the head of the organization or his/her deputy. • Formal approval by the head of the organization or his/her deputy on the updated policy (e.g., via the organization's official e-mail, paper or electronic signature).
National Cybersecurity Authority – Critical Systems Cybersecurity Controls CSCC				

Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
2.7-1 In addition to the sub-controls under Control 2-8-3 of the Basic Cybersecurity Controls, the cryptographic cybersecurity requirements should cover, at a minimum, the following:	2.7-1-1	encrypt all critical systems data; During the transfer (Data-In-Transit).	• Work to identify appropriate and advanced technologies; To encrypt critical systems data in transit, for example: - O Using the Transport Layer Security protocol, which is one of the most common encryption protocols (TLS - Transport Layer Security). - O Applying appropriate and advanced technologies to encrypt critical systems data during transmission at the advanced level in accordance with the standard of the National Cybersecurity Authority. - O Review the effectiveness of techniques used to encrypt critical systems data in transit.	• Data encryption procedures during transmission at the entity. • Encryption standards approved by the entity. • Protocols and technologies used to encrypt critical systems data in transit. • Reports reviewing the effectiveness of the encryption techniques used.	
	2.7-1-2	encrypt all critical systems data; While storing (Data-At-Rest) at the level of files, the database, or at the level of specific columns, within the database.	• Work to identify appropriate and advanced technologies; To encrypt critical systems data during storage, for example: - O Use transparent data encryption that is used on limited systems with restricted resources (TDE Transparent Data Encryption), including but not limited to: block encryption algorithms. - O Apply appropriate and advanced technologies to encrypt critical systems data during storage. - O Review the techniques used to encrypt critical systems data during storage.	• Procedures for encrypting critical systems data during storage, whether at the level of files, the database, or at the level of specific columns within the database, in the entity. • Protocols and technologies used to encrypt critical systems data during storage.	

	2.7-1-3	Using updated and secure methods, algorithms, keys, and encryption devices in accordance with what is issued by the NCA in this regard.	Cryptography Standard Template.	• Working on defining secure encryption algorithms, keys, and devices by adhering to the correct and updated application standards by reviewing them annually and ensuring that they are in line with the encryption standards issued by the Cybersecurity Authority. • Using the advanced level of encryption methods and algorithms based on national encryption standards. • Review the techniques used for the secure management of algorithms, keys, and cryptographic devices.	• Cybersecurity procedures that cover the safe management of encryption algorithms, keys, and devices at the entity (example: an electronic copy or an official hard copy). • A document defining the cycle of reviewing the effectiveness of the techniques used; For the secure management of algorithms, keys and encryption devices during their life cycle operations at the entity. • Protocols and technologies used to encrypt critical systems data.
National Cybersecurity Authority - Telework Cybersecurity Controls TCC					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
TCC-2.7.1 In addition to the sub-controls within control 2-8-3 in the	TCC-2.7.1-1	The use of updated and secure methods and algorithms for encryption over	Encryption policy Encryption standard	Work on defining the requirements for this control, document them in the cybersecurity requirements document, and have them	A document that identifies and documents the requirements of this control (such as a policy and/or procedure

ECC, cybersecurity requirements for cryptography related to telework systems shall include at least the following:		the entire network connection used for telework, according to the Advanced level within the National Cryptography Standards (NCS 1:2020).	Encryption key management standards	approved by the authority holder. Identify secure algorithms, keys, and encryption devices by adhering to correct application standards and updating them by reviewing them annually and ensuring that they are in line with the encryption standards issued by the Cybersecurity Authority. Use of advanced level encryption methods and algorithms based on the National Encryption Standards (NCS 1:2020) across the entire network used for telework. Review the effectiveness of techniques used for secure management of algorithms, keys and cryptographic devices. Strong algorithms and encryption tools to be used wherever possible, such as but not limited to: telework device password encryption, data files encryption while transferring outside organization, encryption of secret information stored in telework systems.	approved by the authority holder). Cybersecurity procedures that cover the secure management of the entity's algorithms, keys, and encryption devices (for example: an electronic copy or an official hard copy). A document defining the cycle of reviewing the effectiveness of the techniques used; for the secure management of algorithms, keys and encryption devices during their life cycle operations at the organization. A list of protocols and technologies used to encrypt the entire network connection used for telework.
National Cybersecurity Authority – Operational Technology Cybersecurity Controls OTCC					

Control reference number	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
OTCC-2.7.1	In addition to subcontrols in the ECC control 2-8-3, the organization must ensure that cryptographic technologies used in OT/ICS environment are aligned with the NCA National Cryptographic Standard (NCS1:2020).	Template for Cybersecurity Operational Technology Policy Template for OT/ICS Security Standard Template for Cryptography Policy Template for Cryptography Standard Template for Key Management Standard	Identify and document all cryptographic technologies used in OT/ICS environment. Verify and ensure that cryptographic technologies used in OT/ICS environment are aligned with the NCA National Cryptographic Standard (NCS-1:2020).	A documented cryptographic technologies used in OT/ICS environment list. Site visit to check that all cryptographic technologies used in OT/ICS environment are aligned with the NCA National Cryptographic Standard (NCS-1:2020).
OTCC-2.7.2	With reference to the ECC control 2-8-4, the cybersecurity requirements for cryptography in OT/ICS environment must be reviewed, and their implementation effectiveness is measured and evaluated periodically.	Template for Cybersecurity Operational Technology Policy Template for OT/ICS Security Standard Template for Cryptography Policy	Review the cybersecurity requirements for cryptography in the OT/ICS environment periodically based on a documented and approved review plan and on a defined frequency (e.g., conduct a review annually). Develop key performance indicators (KPIs) for each control within the related policy or procedure to ensure the implementation	A proof that shows he periodic review of cybersecurity requirements for cryptography in the OT/ICS environment. A proof that shows the key performance indicators (KPIs) for each control within the related policy or procedure to ensure the

		Template for Key Performance Indicator Report	effectiveness is measured and evaluated periodically based on a defined frequency (e.g., conduct a review annually).	implementation effectiveness is measured and evaluated periodically (based on defined frequency)	
National Cybersecurity Authority - Cloud Cybersecurity Controls CCC					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
2-7-P-1 In addition to sub controls in the ECC control 2-8-3, the CSP shall cover the following additional sub controls for cryptography, as a minimum:	2-7-P-1-1	Technical mechanisms and cryptographic primitives for strong encryption, in according to the advanced level in the National Cryptographic Standards (NCS-1:2020).	Template for Encryption Standard Template for Encryption Key Management Standard Template for Encryption Policy	Build encrypted cloud storage services compliant with the National Cryptographic Standards (NCS-1:2020)	NCS-1:2020 compliant data encryption mechanisms
	2-7-P-1-2	Certification authority and issuance capability in a secure	Template for Encryption Standard	Build certification authority and issuance capability considering best practices in this area (e.g.: dedicated and isolated	Installation and activation of a trusted source/authority for accreditation.

		manner, or usage of certificates from a trusted certification authority.	Template for Encryption Key Management Standard Template for Encryption Policy	environment, strict access control, hardware security modules in place) Review certificates in use if issued by trusted certification authority.	Trusted and certified certificates
2-7-T-1 In addition to sub controls in the ECC control 2-8-3, the CST shall cover the following additional sub controls for cryptography, as a minimum:	2-7-T-1-1	Technical mechanisms and cryptographic primitives for strong encryption, in according to the advanced level in the National Cryptographic Standards (NCS-1:2020).	Template for Encryption Standard Template for Encryption Key Management Standard Template for Encryption Policy	Develop a Cryptographic Standard aligned with National Cryptographic Standards (NCS-1:2020).	Cryptographic standard document.
	2-7-T-1-2	Encryption of data and information transferred to or transferred out of the cloud according to the relevant law and regulatory requirements.	Template for Encryption Standard Template for Encryption Policy Template for Encryption Key Management Standard	Identify law and regulations related to cloud data flows (e.g.: National Cryptographic Standards) and verify compliance with these regulations.	Encryption of data and information transferred to or transferred out of the cloud according to the relevant law and regulatory requirements. Hybrid cloud connectivity encryption.
National Cybersecurity Authority - Data Cybersecurity Controls DCC					

Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
DCC-2.5.1 In addition to the subcontrols in ECC control 2-8-3, cybersecurity requirements for cryptography must cover at least the following:	DCC-2.5.1.1	Using secure and up-to-date cryptographic methods and algorithms when creating, storing, transmitting data, and for overall network communication medium; as per the requirements of the "advanced level" in the National Cryptographic Standards (NCS-1:2020).	Template for Encryption Standard Template for Encryption Policy Template for Encryption Key Management Standard	Identify the requirements of this control and document them in a cybersecurity requirements document, followed by approval from the authorizing officials. Identify and document all the cryptographic algorithms for both data at rest and data in transit state of the secret and top-secret data of the organization. Review and verify the cryptographic algorithms used in the organization for the abovementioned data are aligned with the requirements of the "advanced level" in NCA National Cryptographic Standards (NCS-1:2020).	Document detailing the identification and documentation of the requirements of this control (e.g. a policy and/or procedure approved by the authorizing officials). Documented cryptographic technologies used for secret and top-secret data of the organization. Sample of encryption system's configurations.
	DCC-2.5.1.2	Using secure and up-to-date cryptographic methods and algorithms when creating, storing,	Template for Encryption Standard Template for Encryption Policy Template for Encryption Key	Identify the requirements of this control and document them in a cybersecurity requirements document, followed by approval from the authorizing officials. Identify and document all the cryptographic algorithms for	Document detailing the identification and documentation of the requirements of this control (e.g. a policy and/or procedure

		transmitting data, and for overall network communication medium; as per the requirements of the "moderate level" in the National Cryptographic Standards (NCS-1:2020).	Management Standard	both data at rest and data in transit state of the confidential data of the organization. Review and verify the cryptographic algorithms used in the organization for the abovementioned data are aligned with the requirements of the "moderate level" in NCA National Cryptographic Standards (NCS-1:2020).	approved by the authorizing officials). Documented cryptographic technologies used for confidential data of the organization.
SAMA Cyber Security Framework CSF					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
3.3.9-1	A cryptographic security standard should be defined, approved and implemented.		Cryptography Security Standard Template	Develop a comprehensive cryptographic security standard that outlines the organization's approved cryptographic solutions, their usage, and key management procedures.	Cryptographic security standard document
3.3.9-2	The compliance with the cryptographic security standard should be monitored.		Establish a monitoring process to ensure compliance with the cryptographic security standard. This can include regular audits, key management reviews, and vulnerability assessments.		Evidence of cryptographic security standard compliance monitoring
3.3.9-3	The effectiveness of the cryptographic security controls should be measured and periodically evaluated.		Regularly assess the effectiveness of the cryptographic security controls through security assessments, penetration testing, and incident		Reports and documentation of

		response reviews. Adjust the controls as needed to maintain adequate security.	cryptographic security control evaluations
3.3.9.-4 The cryptographic security standard should include:	a. An overview of the approved cryptographic solutions and relevant restrictions (e.g., technically, legally).	Provide a clear overview of the approved cryptographic solutions, including algorithms, key lengths, and protocols. Specify any technical or legal restrictions on their usage.	Documented overview of approved cryptographic solutions and restrictions
	b. The circumstances when the approved cryptographic solutions should be applied.	Define the specific circumstances and scenarios where the approved cryptographic solutions should be applied, such as data encryption, system protection, or digital signatures.	Documented circumstances for applying cryptographic solutions
	c. The management of encryption keys, including lifecycle management, archiving and recovery.	Establish comprehensive procedures for managing encryption keys throughout their lifecycle, including generation, distribution, rotation, storage, archiving, and recovery.	Documented encryption key management procedures
CST CRF			
Control reference number	Control clauses	Control implementation guidelines	Expected deliverables
4.1.1 CL1	Define and document [Requirements for Cryptography] which consider the following: Defining basic cryptographic protocols and techniques (e.g. AES 256, RSA 2048, and PKI) together with relevant restrictions (e.g. self- signed certificates, MD5) Conditions under which approved cryptographic protocols should be applied (data in transit, at rest, in use) taking into account the [Requirements for Information Protection]	Develop and document cybersecurity requirements for cryptography, considering: - Defining basic cryptographic protocols and techniques, along with any relevant restrictions. - Specifying the conditions under which approved cryptographic protocols should be applied, considering data states (in transit, at rest, in use) and information protection requirements.	Documented cybersecurity requirements for cryptography.

4.1.2 CL1	Create a list of [Cryptographic Solutions] (e.g. products, algorithms and protocols) in accordance to relevant restrictions (e.g. legal, technical, national) and make sure it is approved by the responsible roles.	Create a list of approved cryptographic solutions (products, algorithms, protocols) that adhere to relevant restrictions (legal, technical, national) and obtain necessary approvals from responsible roles.	Documented list of approved cryptographic solutions.
4.1.3 CL1	Use the [Cryptographic Solutions] based on the identified circumstances, in order to protect information throughout its complete life cycle (in transit, at rest, in use) according to its classification [Requirements for Information Protection]	Utilize the approved cryptographic solutions to protect information throughout its lifecycle (in transit, at rest, in use), based on the identified circumstances and the classification of the information.	Evidence of using approved cryptographic solutions for information protection.
4.1.4 CL2	Define and implement a (Life Cycle Management of Cryptographic Keys) process for handling the generation, protection, archiving, recovery, and destruction of cryptographic keys.	Develop and implement a comprehensive process for managing cryptographic keys throughout their lifecycle, including generation, protection, archiving, recovery, and destruction.	Documented key management process and evidence of implementation.
4.1.5 CL3	Continuously measure, review and optimize the [Requirements for Cryptography].	Regularly monitor, review, and improve cryptography measures to ensure their continued effectiveness and alignment with organizational needs and regulatory requirements.	Documentation of continuous monitoring, review, and optimization activities.
CMA Cybersecurity Guidelines			
Control reference number	Control clauses	Control implementation guidelines	Expected deliverables
4.3.11-1	Define, document, approve and implement encryption standards.	Develop a comprehensive encryption standard that outlines the organization's approved encryption solutions, their usage, and key management procedures.	Encryption standard document

4.3.11-2	Monitor compliance with encryption standards.	Establish a monitoring process to ensure compliance with the encryption standard. This can include regular audits, key management reviews, and vulnerability assessments.	Evidence of encryption standard compliance monitoring
4.3.11-3	Periodically measure and evaluate effectiveness of encryption cybersecurity controls.	Regularly assess the effectiveness of the encryption security controls through security assessments, penetration testing, and incident response reviews. Adjust the controls as needed to maintain adequate security.	Reports and documentation of encryption security control evaluations
4.3.11-4 Encryption standard shall include the following:	1- General review of approved encryption solutions and restrictions thereof (Technically and organizationally).	Provide a clear overview of the approved encryption solutions, including algorithms, key lengths, and protocols. Specify any technical or organizational restrictions on their usage.	Documented overview of approved encryption solutions and restrictions
	2- Cases to which the approved encryption solutions shall apply.	Define the specific circumstances and scenarios where the approved encryption solutions should be applied, such as data encryption, system protection, or digital signatures.	Documented cases for applying encryption solutions
	3- Managing encryption keys, including managing their life cycle, as well as archiving and recovering them.	Establish comprehensive procedures for managing encryption keys throughout their lifecycle, including generation, distribution, rotation, storage, archiving, and recovery.	Documented encryption key management procedures
	4- Encrypting data during transfer and storage based on their classification and according to the relevant best practices, standards and legislative and regulatory requirements.	Implement data encryption mechanisms for data in transit and at rest, based on data classification and in accordance with relevant best practices, standards, and legal requirements.	Evidence of data encryption implementation for data in transit and at rest

Risk Considerations in Cryptography

1. **Key Management Risks:**
 - Ineffective lifecycle management (generation, storage, rotation, and destruction) can lead to key compromise.
2. **Weak Cryptographic Algorithms:**
 - Using outdated algorithms (e.g., MD5, SHA-1) increases susceptibility to attacks.
3. **Misconfigured Cryptographic Systems:**
 - Incorrectly implemented encryption protocols (e.g., TLS) leave systems vulnerable.
4. **Regulatory Non-Compliance:**
 - Failing to meet cryptographic standards, such as NCA NCS or SAMA CSF, results in penalties.
5. **Quantum Computing Threat:**
 - Advances in quantum computing may break current encryption standards.
6. **Poor Incident Response:**
 - Inadequate processes to respond to cryptographic failures or breaches increase risks.
7. **Vendor or Third-Party Risks:**
 - Cryptographic solutions provided by third parties may introduce vulnerabilities.
8. **Data Exposure Risks:**
 - Lack of encryption for sensitive data during transmission or storage can lead to breaches.

Examples of Technologies for Effective Cryptography Management

1. **Public Key Infrastructure (PKI):**
Tools: *EJBCA* (open-source PKI Certificate Authority), *OpenXPKI*.
2. **Hardware Security Modules (HSMs):**
Note: No fully open-source HSMs exist, but for emulation/testing, *SoftHSM* (by OpenDNSSEC) can be used.
3. **Key Management Solutions:**
Tools: *HashiCorp Vault* (open-source version), *Barbican* (OpenStack Key Manager).
4. **Encryption Libraries:**
Tools: *OpenSSL*, *Google Tink*, *BouncyCastle*.
5. **Cryptographic Algorithms:**
Examples: *AES-256*, *RSA-2048*, *Elliptic Curve Cryptography (ECC)*.
(These are standards, not tools, and widely supported in open libraries.)
6. **Secure Protocols:**
Examples: *TLS 1.3*, *IPSec*, *SSH*.
(Implemented in tools like *OpenSSH*, *LibreSSL*, *StrongSwan*, etc.)

7. Quantum-Safe Solutions:

Tools: *OpenQuantumSafe* (includes liboqs, test tools for PQC algorithms), *CRYSTALS-Kyber*, *Dilithium*.

8. Compliance Monitoring:

Tools: *Wazuh* (open-source SIEM with compliance modules), *OpenSCAP* (for policy and compliance scanning).

Examples of KPIs for Cryptography

1. Key Rotation Rate:

- Percentage of cryptographic keys rotated within the defined timeframe.

2. Encryption Implementation:

- Percentage of systems implementing AES-256 or approved cryptographic standards.

3. Compliance Rate:

- Percentage of systems compliant with NCA NCS, and SAMA CSF.

4. Incident Response Time:

- Average time to mitigate cryptographic vulnerabilities.

5. Audit Findings:

- Number of cryptography-related findings identified and resolved.

6. Certificate Expiration Monitoring:

- Percentage of certificates renewed before expiry.

Samples of Auditor's Checklist for Cryptography

1. Are cryptographic policies and procedures documented and approved?
2. Are keys securely stored, rotated, and destroyed according to lifecycle management practices?
3. Are cryptographic algorithms compliant with NCA NCS-1:2020 and SAMA CSF standards?
4. Is sensitive data encrypted at rest and in transit?
5. Are secure protocols (e.g., TLS 1.3) implemented for data transmission?
6. Are third-party cryptographic tools audited for security and compliance?
7. Are periodic reviews conducted for the effectiveness of cryptographic controls?
8. Are employees trained on cryptographic security practices?

Samples of Audit Scenarios for Cryptography

Scenario 1: Encryption Compliance

- **Objective:** Evaluate compliance with encryption standards for data protection.
- **Steps:**
 1. Review encryption configurations for databases and network communication.
 2. Validate compliance with NCS-1:2020 standards.
 3. Test encryption key storage and rotation mechanisms.
- **Questions:**
 - Are approved encryption methods in use (e.g., AES-256)?
 - Are encryption keys securely managed?

Scenario 2: Key Management Assessment

- **Objective:** Assess the organization's key management practices.
- **Steps:**
 1. Review the documented key lifecycle management policy.
 2. Verify the use of HSMs for secure key storage.
 3. Test the process for key rotation and destruction.
- **Questions:**
 - Are keys stored in secure, access-controlled environments?
 - Are key management policies compliant with regulatory standards?

Case Study 1: Enhancing Cryptographic Security in a Bank

Background

A prominent financial institution, serving millions of customers, faced increasing cyber threats due to outdated cryptographic implementations. The organization relied on older cryptographic standards like SHA-1 and unpatched systems, which exposed it to risks such as key compromise, data breaches, and non-compliance with regulatory requirements (e.g., SAMA CSF and NCA NCS-1:2020).

Challenges

1. **Outdated Cryptographic Algorithms:**
 - Legacy systems were using SHA-1 and DES, which were no longer secure.
 - Encryption methods did not meet national standards like NCA NCS-1:2020.
2. **Inefficient Key Management:**
 - Keys were stored in plaintext on servers, increasing the risk of theft.
 - No proper rotation policy was in place, leading to prolonged use of compromised keys.
3. **Regulatory Non-Compliance:**
 - The bank failed to meet SAMA and NCA requirements for encryption of sensitive customer data at rest and in transit.
4. **Inconsistent Encryption Practices:**
 - Sensitive data was encrypted in some systems but left exposed in others, creating gaps in security.

Actions Taken

1. **Algorithm Upgrade:**
 - Migrated to modern cryptographic standards like AES-256 for data encryption and TLS 1.3 for secure communication.
 - Retired all instances of legacy algorithms, including SHA-1 and DES.
2. **Key Management System Implementation:**
 - Deployed HashiCorp Vault to centralize and secure cryptographic key management.
 - Introduced lifecycle management for keys, including automated rotation, secure storage in HSMs, and timely destruction.
3. **Policy and Process Standardization:**
 - Developed and approved a comprehensive Cryptographic Security Policy in compliance with SAMA CSF and NCA guidelines.
 - Conducted a full inventory of cryptographic usage across all systems and standardized encryption practices.
4. **Employee Training and Awareness:**
 - Conducted workshops for IT staff to educate them on secure cryptographic implementation and regulatory compliance.
5. **Monitoring and Compliance:**
 - Integrated cryptographic logs into the bank's SIEM solution to monitor encryption status in real-time.

- Performed regular audits and penetration testing to ensure compliance with regulatory requirements from SAMA and NCA.

Outcomes

1. **Improved Security:**
 - Reduced cryptographic incidents by 70% after retiring legacy algorithms.
 - Key compromise incidents dropped to zero due to the introduction of HSMs and secure key management.
 2. **Regulatory Compliance:**
 - Achieved full compliance with SAMA CSF, NCA NCS-1:2020, and other relevant standards.
 3. **Operational Efficiency:**
 - Automated key lifecycle management reduced manual intervention, saving significant time for IT teams.
 4. **Customer Trust:**
 - Enhanced reputation and customer confidence due to improved data protection measures.
-

Case Study 2: Cryptography in a Government Agency

Background

A government agency managing critical national infrastructure faced challenges in securing sensitive information due to outdated systems, inconsistent encryption practices, and a lack of centralized cryptographic policies. The agency's infrastructure included legacy operational technology (OT) systems and relied heavily on third-party vendors, increasing the risk of breaches.

Challenges

1. **Lack of Secure Key Management:**
 - Cryptographic keys were shared via unsecured channels like email.
 - No centralized repository or HSM was in place for key storage.
2. **Unencrypted Data:**
 - Sensitive data in transit and at rest remained unencrypted, exposing it to interception and tampering.
3. **Vendor Risks:**
 - Third-party vendors had access to critical systems without sufficient cryptographic safeguards.
4. **Regulatory Non-Compliance:**
 - The agency failed to align with NCA NCS-1:2020 standards for cryptography in OT/ICS environments.
5. **Telework Vulnerabilities:**
 - Telework devices lacked encryption for sensitive data, leading to potential data leaks.

Actions Taken

1. **Deployment of HSMs:**
 - Deployed Thales Luna HSM for secure key storage and centralized management.
 - Established robust key lifecycle management, including generation, distribution, rotation, and destruction.
2. **Encryption Standardization:**
 - Applied AES-256 encryption for data at rest and TLS 1.3 for data in transit.
 - Standardized encryption practices across all OT and IT systems, ensuring compliance with NCA NCS-1:2020.
3. **Vendor and Third-Party Management:**
 - Restricted vendor access to critical systems using RBAC.
 - Implemented secure communication protocols and encrypted file transfers for vendors.
4. **Telework Security Enhancements:**
 - Introduced Mobile Device Management (MDM) solutions to secure telework devices.
 - Enforced encryption of sensitive files and emails during remote operations.
5. **Policy Development:**
 - Developed and approved a Cryptographic Security Policy covering OT/ICS systems.

- Integrated encryption standards into vendor contracts to ensure third-party compliance.
- 6. **Auditing and Monitoring:**
 - Conducted quarterly cryptographic audits to identify and mitigate gaps.
 - Monitored cryptographic usage through a centralized SIEM solution.
- 7. **Employee and Vendor Training:**
 - Conducted training sessions on cryptographic best practices for employees and vendors.
 - Distributed guidelines for secure encryption implementation during telework.

Outcomes

1. **Enhanced Security:**
 - Reduced cryptographic vulnerabilities by 85% due to standardized encryption practices.
 - Implemented secure key management practices, eliminating risks of key compromise.
2. **Regulatory Compliance:**
 - Achieved full alignment with NCA NCS-1:2020 standards for cryptography in OT/ICS environments.
3. **Improved Vendor Oversight:**
 - Vendor compliance improved by 90% through restricted access and secure communication protocols.
4. **Telework Security:**
 - Reduced telework vulnerabilities by 80% through encryption and MDM solutions.
5. **Operational Improvements:**
 - Automated key management processes reduced operational overhead and improved efficiency.
 - Encryption applied to 100% of sensitive data in transit and at rest.
6. **Faster Incident Response:**
 - Incident response time for cryptographic failures reduced by 40%, ensuring minimal disruption during breaches.
7. **Increased Awareness:**
 - 90% of employees and vendors scored above 85% in post-training cryptography assessments, ensuring robust understanding and compliance with secure practices.

2.9 Backup and Recovery Management:

Definition: Backup and Recovery Management involves creating, maintaining, and executing strategies to ensure the availability, integrity, and security of organizational data and systems. This includes safeguarding data through regular backups and ensuring efficient recovery processes to minimize disruptions caused by cyber threats, system failures, or disasters [22], [23], [24].

Objective: To ensure the protection of the organization's data, information systems, and software configurations from cyber risks in alignment with organizational policies, procedures, and applicable laws and regulations. This includes providing reliable mechanisms for data restoration in case of loss or corruption.

Controls Matrix:

Below is a summary matrix detailing relevant network security management controls based on NCA Controls, SAMA CSF, CST CRF, and CMA Cybersecurity Guidelines:

Regulation	Main Controls	Control References
NCA ECC	4	ECC-2.9.1, ECC-2.9.2, ECC-2.9.3 (3 sub-controls), ECC-2.9.4
SAMA CSF	-	-
CTS CRF	8	4.12.1, 4.12.2, 4.12.3, 4.12.4, 4.12.5, 4.12.6, 4.12.7, 4.12.8
CMA CSG	-	-
NCA CSCC	2	CSCC-2.8.1 (3 sub-controls), CSCC-2.8.2
NCA CCC CST	-	-
NCA CCC CSP	1	2-8-P-1 (2 sub-controls)
NCA TCC	2	2-8-1 (1 sub-control), 2-8-2
NCA DCC	-	-
NCA OSMACC	-	-
NCA OTCC	2	OTCC-2.8.1 (4 sub-controls), OTCC-2.8.2

Backup and Recovery Management Controls:

National Cybersecurity Authority - Essential Cybersecurity Controls ECC					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
ECC-2.9.1	Cybersecurity requirements for backup and recovery management must be defined, documented and approved.		Backup and Recovery Management Policy Template	Develop and document cybersecurity policy for backup management in the organization, including the following: - Scope and coverage of critical information and technology systems backups - Fast recovery of data and systems after exposure to cybersecurity incidents - Periodic inspection of backup recovery effectiveness - Time limit for backups - Appropriate and advanced technologies for backups must be defined - Support the organization's policy by the Executive Management. This must be done through the approval of the organization head or his/her deputy.	Cybersecurity policy that covers the requirements of Backup and Recovery Management in the organization (e.g., electronic copy or official hard copy). Formal approval by the head of the organization or his/her deputy on the policy (e.g., via the organization's official e-mail, paper or electronic signature).

ECC-2.9.2	The cybersecurity requirements for backup and recovery management must be implemented.		All cybersecurity requirements must be implemented for the organization's approved Backup and Recovery Management procedures. It is also recommended that the Backup and Recovery Management procedures cover the following, but not limited to: Appropriate and advanced technologies for backups must be used. Scope and coverage of critical information and technology systems backups. Fast recovery of data and systems after exposure to cybersecurity incidents must be implemented. Periodic inspection of backup recovery effectiveness must be implemented. Period required for backup must be defined, including but not limited to backup of changing data in the last 24 hours.	An action plan to implement cybersecurity requirements for backup and recovery management Evidence such as, but not limited to, a screenshot of a backup tool showing the latest backups taken, schedule and scope of backups.
ECC-2.9.3 The cyber security requirements for backup and recovery management must include at least the following:	ECC-2.9.3.1	Scope and coverage of backups to cover critical technology and information assets.	Define and document the requirements of this ECC in the cybersecurity requirements of backups management at the organization and must be approved by the representative. Define the scope of backups for all critical information and technology assets in the organization, including but not limited to: - Databases - Applications - Servers - Network Devices Define specialized technologies for backup.	Documents indicating the identification and documentation of the requirements of this ECC in the policies or procedures of the organization approved by the representative. A report of periodic backups as per the defined duration for all asset domains.

			Determine the period required to backup all information and technology assets according to sensitivity and classification. Implement backup to all critical information and technology assets in the organization. Review the organization backups periodically, to include the aforementioned scope and any information and technology assets that have been identified by the organization.	
	ECC-2.9.3.2	Ability to perform quick recovery of data and systems after cybersecurity incidents.	Define and document the requirements of this ECC in the cybersecurity requirements of backups management at the organization and must be approved by the representative. Identify appropriate procedures to recover data and systems after exposure to cybersecurity incidents, by but not limited to Define the scope of backup recovery, which may contain all devices, systems, and servers, and classify them according to their importance and criticality. Determine the recovery period according to classification and importance of specified scope. Use specialized technologies for data and system recovery. Calculate the period required to recover all backups for all assets domain to ensure rapid recovery of backups in the event of a cyber security incident.	Documents indicating the identification and documentation of the requirements of this ECC in the policies or procedures of the organization approved by the representative. Report on specific procedures for recovery of backups.
	ECC-2.9.3.3	Periodic tests of backup's recovery effectiveness.	Define and document the requirements of this ECC in the cybersecurity requirements of backups management at the organization and must be approved by the representative.	Documents indicating the identification and documentation of the requirements of this ECC in the policies or

			Plan for periodic inspection of backup recovery effectiveness must be developed. Ensure the effectiveness of recovery procedures by conducting a periodic backup recovery test to ensure the ability to recover data and systems according to the period specified in the procedures and according to the period calculated to complete the recovery of backup copies.	procedures of the organization approved by the representative. Backup effectiveness test reports showing the difference between the expected duration and the test duration to recover all backups.
ECC-2.9.4	The cybersecurity requirements for backup and recovery management must be reviewed periodically.	Review the cybersecurity requirements of Backup and Recovery Management by conducting a periodic assessment (according to a documented and approved plan for review, and based on a planned interval "e.g., quarterly") to implement identity and access management requirements by the Cybersecurity function and in cooperation with relevant departments (such as IT Department).Conduct application review through traditional channels (e.g., email) or automated channels using a compliance management system. The organization may develop a review plan explaining the implementation review schedule for Backup and Recovery Management. Review and update cybersecurity requirements for backups management in the organization periodically according to a documented and approved plan for review and based on a planned interval or in the event of changes in relevant laws and regulations. Document the review and changes to the cybersecurity requirements for Backup and Recovery Management in the organization and approve them by the head of the organization or his/her deputy.	Results of backup management requirements implementation review in the organization. A document that defines the cybersecurity requirements application review cycle for backup management at the organization (Compliance Assessment Schedule). Compliance assessment report that outlines the assessment of the implementation of cybersecurity requirements for	

					Backup and Recovery Management in the organization. An approved document that sets the policy's review schedule Policy indicating that it is up to date and the changes to the cybersecurity requirements for Backup and Recovery Management have been documented and approved by the head of the organization or his/her deputy. Formal approval by the head of the organization or his/her deputy on the updated policy (e.g., via the organization's official e-mail, paper or electronic signature).
National Cybersecurity Authority – Critical Systems Cybersecurity Controls CSCC					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
CSCC-2.8.1	CSCC-2.8.1.1	The scope of online and offline	Backup Standard Template	Work on identifying databases for critical systems.	Online and Offline Backup reports, which

In addition to the sub-controls under Control 3-9-2 in the Basic Cyber Security Controls, it should cover the cyber security requirements for managing backups, at a minimum; the following:		backups to include all critical systems.	Backup Policy Template	Work on identifying applications for critical systems. Work on identifying servers for critical systems. Work on identifying network devices for critical systems. Defining technologies for backing up critical systems. Apply backups to all critical systems.	includes all critical systems that contain: the scope of the backup, the techniques used for the backup process in the entity. Reports from applying backups for all critical systems.
	CSCC-2.8.1.2	Make backups at planned intervals; Based on the entity's risk assessment, the Commission recommends that backup copies of critical systems be made on a daily basis.	Backup Standard Template Backup Policy Template	Work on the entity's risk assessment in accordance with the entity's regulatory policies and procedures, and in accordance with the relevant legislative and regulatory requirements. Work to determine the sensitivity of the system and the need for data and its recentness, depending on the result of risk assessment. Work on defining an action plan for the periods of making backup copies of critical systems. Work on implementing the action plan for backing up critical systems at agreed time periods.	Reports from the entity's risk assessment. An action plan for backing up critical systems according to the time plan based on the entity's risk assessment. Screenshot of a backup tool showing the latest backups taken of critical systems at agreed time intervals.

	CSCC-2.8.1.3	Secure access, storage, and transmission of backup content and media for critical systems, and protect them from unauthorized destruction, modification, or viewing.	Storage Media Security Policy Template Physical Security Policy Template Backup Standard Template Backup Policy Template	Working to secure unauthorized access, modification, and viewing of the content of backup copies of critical systems and their media, through, but not limited to limiting access according to need and scope of work, and reviewing access permissions at regular intervals. Working to secure the storage of backup content and media for critical systems through, but not limited to: storing off-site and physical backup media off-site in a safe and reliable location, and storing online backups separately from production environments. Testing and development. Work to determine procedures for the safe transfer of the content of backup copies of critical systems and their media, through, but not limited to: encrypting backup data during transfer, and using	Reports of access to storage media for critical systems. Reports of review of access rights at regular intervals. Backup procedures. Reports of encrypted backups in transit. Reports of tools used to transfer security to backups
--	--------------	--	--	---	--

				safe, updated and approved transfer tools.	
CSCC-2.8.2	Referring to Control 2-9-3-3 in Basic Cyber Security Controls, a periodic check is required; At least every three months, to determine the effectiveness of restoring backups of critical systems.	Backup Standard Template Backup Policy Template		Work on developing a plan to conduct a periodic examination at least every three months; To measure the effectiveness of restoring backups of critical systems. Work to ensure the effectiveness of recovery procedures, by conducting a test to restore backup copies of critical systems periodically; At least every three months.	An action plan to test the effectiveness of backups for critical systems. Backup Restoration Testing reports for critical systems at least every three months.
National Cybersecurity Authority - Telework Cybersecurity Controls TCC					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
2-8-1 In addition to the subcontrols in the ECC control 2-9-3, cybersecurity requirements for backup and recovery management must include at	2-8-1-1	Performing backup within planned intervals, according to the organization's risk assessment.	Backups policy template Backups standard template	Work on defining the requirements for this control, document them in the cybersecurity requirements document, and have them approved by the authority holder. In line with the organization risk assessment policy, define the plan for periodic planned	A document that identifies and documents the requirements of this control (such as a policy and/or procedure approved by the authority holder). A documented and approved plan for making backup copies of telework systems.

least the following:				backup of data and settings of telework systems. Review the backup performance within planned internals Ensure to have business continuity via backup plans of telework systems.	A guide to implementing the technical controls required to perform planned backups of teleworking systems and ensure business continuity.
2-8-2	With reference to the ECC subcontrol 2-9-3-3, a periodical test must be conducted at least once every six months in order to determine the efficiency of recovering telework systems backups.	Backups policy template Backups standard template	Work on defining the requirements for this control, document them in the cybersecurity requirements document, and have them approved by the authority holder. Based on defined backup periodicity and business continuity plan, define and approve the periodic testing of telework backup systems at least once every six months. Ensure the effectiveness of the recovery procedures by conducting a test to restore backups periodically to ensure the ability to restore data and telework systems according to the period specified in the procedures and according to the period that has been identified for	A document that identifies and documents the requirements of this control (such as a policy and/or procedure approved by the authority holder). Document a business plan and procedures for implementing cybersecurity requirements for backup management. Test reports that examine the effectiveness of backups for telework systems, so that it clarifies the difference between the expected duration and the test	

				the completion of restoring backups.	duration for restoring all backups.
National Cybersecurity Authority – Operational Technology Cybersecurity Controls OTCC					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
OTCC-2.8.1 In addition to subcontrols in the ECC control 2-9-5, cybersecurity requirements for backup and recovery management in OT/ICS must include, at a minimum, the following:	OTCC-2.8.1.1	Backups for all OT/ICS assets must be covered and stored in centralized and offline locations.	Template for Cybersecurity Operational Technology Policy Template for OT/ICS Security Standard Template for Backup Policy Template for Backup Standard	Verify and ensure that backups for all OT/ICS assets are covered and stored in a centralized and offline locations.	A documented OT/ICS backup plan including its requirements and principles. A backup scope list of OT/ICS. Site visit to check that backups for all OT/ICS assets are covered and stored in a centralized and offline locations.
	OTCC-2.8.1.2	OT/ICS assets' critical configuration files and engineering files must be included in the backup's scope.	Template for Cybersecurity Operational Technology Policy Template for OT/ICS Security Standard Template for Backup Policy Template for Backup Standard	Verify and ensure that all OT/ICS assets' critical configuration files and engineering files are included in the backup's scope.	A documented list of OT/ICS assets' critical configuration files and engineering files. Site visit to check that all OT/ICS assets critical configuration files and engineering files are included in the backup's scope.
	OTCC-2.8.1.3	Backups must be performed periodically as per	Template for Cybersecurity Operational Technology Policy	Verify and ensure that all backups are performed periodically (based on a defined frequency).	A proof that shows all backups are performed periodically as per the defined frequency.

		the defined OT/ICS assets classification and their associated risks.	Template for OT/ICS Security Standard Template for Backup Management Policy Template for Cybersecurity Backup Management Standard		
	OTCC-2.8.1.4	Access, storage, and transfer of backups and their mediums must be secured to ensure their protection against damage, change, or unauthorized access.	Template for Cybersecurity Operational Technology Policy Template for OT/ICS Security Standard Template for Backup Policy Template for Backup Standard	Define and implement security mechanisms on backup mediums to ensure that the access, storage, and transfer of backups are protected. Verify and ensure that documented requirements and principles embrace protection against damage, change, or unauthorized access.	Site visit to check implemented security mechanisms on backup mediums to ensure that the access, storage, and transfer of backups are protected. Site visit to check that documented requirements and principles embrace protection against damage, change, or unauthorized access.
OTCC-2.8.2	With reference to the ECC control 2-9-4, the cybersecurity requirements for backup and recovery management in OT/ICS environment must be reviewed, and their implementation effectiveness is measured and evaluated periodically.		Template for Cybersecurity Operational Technology Policy Template for OT/ICS Security Standard	Review the cybersecurity requirements for backup management for OT/ICS periodically based on a documented and approved review plan and on a defined frequency (e.g., conduct a review annually).	A proof that shows the periodic review of cybersecurity requirements for backup and recovery management in the OT/ICS environment.

		Template for Backup Management Policy Template for Key Performance Indicator Report	Develop key performance indicators (KPIs) for each control within the related policy or procedure to ensure the implementation effectiveness is measured and evaluated periodically (based on defined frequency).	A proof that shows the key performance indicators (KPIs) for each control within the related policy or procedure to ensure the implementation effectiveness is measured and evaluated periodically (based on a defined frequency).	
National Cybersecurity Authority - Cloud Cybersecurity Controls CCC					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
2-8-P-1 In addition to sub controls in the ECC control 2-9-3, the CSP shall cover the following additional sub controls for cybersecurity requirements for backup and recovery	2-8-P-1-1	Securing access, storage and transfer of CST's data backups and its mediums, and protecting it against damage, amendment or unauthorized access.	Template for Backup Policy Template for Backup Standards Template for Storage Media Security Standards	Identify risks related to access, storage and transfer of CST's data backups and its media, including those related to damage, amendment or unauthorized access (e.g.: accidental damage, theft, lost media) Define security measures for secure access, storage and transfer of CST's data backups (e.g. access control, encryption) Implement defined measures.	List of identified risks. Defined and applied security measures. Regular review reports.

management, as a minimum:				Periodically review implemented security measures to ensure its applicability.	
	2-8-P-1-2	Securing access, storage and transfer of Cloud Technology Stack backups and its mediums, and protecting it against damage, amendment or unauthorized access.	Template for Backup Policy Template for Backup Standards Template for Storage Media Security Standards	Identify risks related to access, storage and transfer of CTS data backups and its media, including those related to damage, amendment or unauthorized access (e.g.: accidental damage, theft, lost media) Define security measures for secure access, storage and transfer of CTS data backups (e.g. access control, encryption) Implement defined measures. Periodically review implemented security measures to ensure its applicability.	List of identified risks. Defined and applied security measures. Regular review reports.
CST CRF					
Control reference number	Control clauses		Control implementation guidelines		Expected deliverables
4.12.1 CL1	Define and document [Requirements for Backup and Recovery Management] which consider the following:		Develop and document cybersecurity requirements for backup and recovery management, considering: - Defining the scope of online and offline backups, including retention periods.		Documented cybersecurity requirements for backup and recovery management.

	-Scope of online and offline backups including the retention period -Rapid recovery of information after cybersecurity incidents -Periodically backup of information assets -Protection of backups - Availability of backups	- Ensuring rapid recovery of information after cybersecurity incidents. - Establishing periodic backup schedules for information assets. - Implementing security measures to protect backups. - Ensuring the availability of backups when needed.	
4.12.2 CL1	Define and implement a [Backup] process considering the following: -- - Business requirements [e.g. Recovery Point Objective] -Scope of online and offline backups and their coverage of information assets (e.g. backup of complete system, through processes such as imaging)	Define and implement a backup process that considers: - Business requirements, such as Recovery Point Objective (RPO). - The scope of online and offline backups and their coverage of information assets, including full system backups.	Documented backup process and evidence of implementation.
4.12.3 CL1	Define and implement a [Recovery] process to ensure that information assets are recovered within an acceptable timeframe based on their criticality [Asset Classification]	Define and implement a recovery process that ensures information assets are recovered within an acceptable timeframe based on their criticality.	Documented recovery process and evidence of implementation.
4.12.4 CL1	Ensure the confidentiality, integrity, and availability of backups in adverse situations (e.g. using encryption, protection of backups via physical security [Protection of Physical Information Assets])	Implement security measures to ensure the confidentiality, integrity, and availability of backups in adverse situations. This can include: - Encryption of backup data. - Physical security controls to protect backup media. - Offsite storage of backups.	Evidence of implemented security measures for backups.
4.12.5 CL2	Establish an alternate storage/backup site that provides	Establish an alternate storage or backup site that provides security measures equivalent to the primary	Documentation of alternate storage/backup site

	security measures equivalent to the primary site.	site to ensure business continuity in case of disasters or incidents.	and its security measures.
4.12.6 CL2	Continuously test and review the [Backup] and the [Recovery] processes to check their effectiveness.	Regularly test and review the backup and recovery processes to ensure their effectiveness and identify any areas for improvement.	Documentation of backup and recovery testing and review activities.
4.12.7 CL2	Enhance and implement the [Requirements for Backup and Recovery Management] to use tools to automate the [Backup] and the [Recovery] processes	Utilize tools to automate the backup and recovery processes, improving efficiency and reducing the risk of human error.	Evidence of automated backup and recovery tools.
4.12.8 CL3	Continuously measure, review and optimize the [Requirements for Backup and Recovery Management] as well as the effectiveness of the processes	Regularly monitor, review, and improve backup and recovery management processes to ensure their continued effectiveness and alignment with organizational needs and regulatory requirements.	Documentation of continuous monitoring, review, and optimization activities.

Risk Considerations in Backup and Recovery Management

1. **Data Loss or Corruption:**
 - Failure to perform regular backups may result in permanent loss of critical data.
2. **Insufficient Backup Coverage:**
 - Missing critical systems or data in backup scope can lead to incomplete recovery.
3. **Unsecured Backups:**
 - Lack of encryption or physical security for backup media can expose data to unauthorized access or tampering.
4. **Inconsistent Recovery Processes:**
 - Poorly defined or tested recovery procedures may delay restoration during an incident.
5. **Regulatory Non-Compliance:**
 - Not adhering to standards such as NCA ECC or SAMA CSF can lead to legal penalties.
6. **Backup Media Failure:**
 - Physical or electronic backup storage can fail due to aging or environmental conditions.
7. **Cyber Threats:**
 - Ransomware targeting backup systems or unauthorized deletion of backup data.
8. **Vendor Dependence:**
 - Overreliance on third-party backup providers can lead to gaps in security or availability.

Examples of Technologies for Effective Backup and Recovery Management

1. **Backup Solutions**

Tools: *Bacula, UrBackup, Restic, Duplicati* (all free/open-source).
2. **Cloud Backup Services**

Note: Most are commercial, but you can build your own using open-source tools like *Rclone* (for syncing to cloud storage) or *Restic* with backends like S3-compatible services (e.g., MinIO).
3. **Disaster Recovery Tools**

Tools: *DRLM (Disaster Recovery Linux Manager), ReaR (Relax-and-Recover), Amanda* (Advanced Maryland Automatic Network Disk Archiver).
4. **Encryption for Backup**

Tools: *AES-256, GnuPG, OpenSSL, TLS 1.3* (via secure transport implementations).
5. **Storage Solutions**

Tools: *Ceph, OpenZFS, GlusterFS* (distributed and scalable open-source storage).
6. **Compliance Monitoring Tools**

Tools: *Wazuh* (includes compliance modules), *OpenSCAP* (security compliance checker).
7. **Data Integrity Tools**

Tools: *AIDE (Advanced Intrusion Detection Environment), Open Source Tripwire, SHA-256 hash tools* (e.g., sha256sum).

8. Hardware Security Modules (HSMs)

Tools: *SoftHSM* (for development and testing, from OpenDNSSEC).

9. Automation Tools

Tools: *Ansible, Puppet, Rundeck*.

Examples of KPIs for Backup and Recovery Management

1. **Backup Success Rate:**
 - Percentage of successful backups completed without errors.
2. **Recovery Time Objective (RTO):**
 - Average time taken to restore systems during an incident.
3. **Backup Frequency:**
 - Percentage of critical systems backed up daily.
4. **Data Coverage Rate:**
 - Percentage of critical data assets included in the backup scope.
5. **Backup Integrity Testing:**
 - Frequency of successful integrity checks performed on backups.
6. **Compliance Rate:**
 - Percentage of backup processes compliant with regulatory standards.
7. **Incident Recovery Rate:**
 - Percentage of incidents where recovery objectives were met.

Samples of Auditor's Checklist for Backup and Recovery Management

1. Are backup policies and procedures documented, approved, and reviewed periodically?
2. Are critical systems and data assets included in the scope of backups?
3. Are backups encrypted during storage and transmission?
4. Is access to backup systems and media restricted and monitored?
5. Are backup and recovery processes aligned with regulatory standards (e.g., NCA ECC, SAMA CSF)?
6. Are regular tests conducted to ensure the integrity and effectiveness of backups?
7. Are backup intervals defined and adhered to for critical systems?
8. Is there an alternate storage location for backups to ensure redundancy?
9. Are recovery objectives (RPO/RTO) defined and met during tests?

Samples of Audit Scenarios for Backup and Recovery Management

Scenario 1: Backup Integrity Testing

- **Objective:** Assess the integrity of backups for critical systems.
- **Steps:**
 1. Review policies and procedures for backup integrity checks.
 2. Verify logs for successful completion of integrity checks.
 3. Test the restoration of data from backups to ensure accuracy.
- **Questions:**
 - Are backup integrity checks conducted regularly?
 - Is restored data consistent with the original?

Scenario 2: Disaster Recovery Simulation

- **Objective:** Evaluate the organization's ability to recover from a ransomware attack.
 - **Steps:**
 1. Simulate a ransomware attack that encrypts critical systems.
 2. Attempt recovery using the latest backups.
 3. Measure recovery time against defined RTO.
 - **Questions:**
 - Are backups secure and inaccessible to ransomware?
 - Was the RTO met during the recovery process?
-

Case Study 1: Backup and Recovery in a Telecommunication Company

Background

A leading telecommunication service provider faced operational disruptions due to inadequate backup and recovery processes. The company managed vast amounts of customer data, hosting critical applications for clients in various industries. Any data loss or downtime could lead to significant reputational and financial damages.

Challenges

1. **Scalability Issues:** Existing backup systems could not handle the rapidly growing data volumes.
2. **Data Security Risks:** Customer data backups lacked proper encryption, making them vulnerable to breaches.
3. **Compliance Requirements:** Failure to meet regulatory standards such as NCA CCC and PDPL for backup security.
4. **Unreliable Recovery:** Recovery tests revealed frequent failures and excessive recovery times, impacting SLAs with clients.
5. **Geographical Redundancy:** Lack of offsite backups in geographically distinct locations to ensure disaster resilience.

Actions Taken

1. **Enhanced Backup Infrastructure:**
 - Deployed scalable solutions such as Rubrik and AWS Backup for efficient cloud-based backups.
 - Implemented incremental backups to reduce storage requirements and time.
2. **Encryption Implementation:**
 - Applied AES-256 encryption for all backups in transit and at rest.
 - Integrated HSMs for secure key management.
3. **Compliance Alignment:**
 - Revised backup policies to meet NCA CCC and PDPL requirements.
 - Conducted regular compliance audits to ensure adherence.
4. **Disaster Recovery Upgrades:**
 - Established multiple geographically distinct data centers for offsite backups.
 - Created an automated disaster recovery plan using VMware Site Recovery Manager.
5. **Testing and Monitoring:**
 - Conducted quarterly recovery drills to test system robustness and meet RTO/RPO requirements.
 - Integrated SIEM tools to monitor backup operations for anomalies.

Outcomes

- Achieved full compliance with regulatory standards.
- Reduced recovery times by 60%, ensuring SLA obligations were met.
- Increased customer trust through enhanced data protection measures.
- Established 100% geographical redundancy for critical backups.

- Enhanced operational efficiency, saving 30% in backup costs.

Case Study 2: Backup and Recovery in a Healthcare Company

Background

A healthcare provider managing sensitive patient data faced significant challenges in securing and recovering electronic medical records (EMRs) and operational systems. The organization was particularly vulnerable to ransomware attacks and operational outages due to inadequate backup strategies.

Challenges

1. **Ransomware Threats:** A ransomware attack encrypted EMR databases, crippling hospital operations.
2. **Regulatory Non-Compliance:** Non-adherence to HIPAA and NCA ECC regulations for data protection.
3. **Unsecured Backup Media:** Physical backup drives were not securely stored, leading to theft and potential data breaches.
4. **Downtime Impact:** Delays in restoring medical records impacted patient care and hospital reputation.
5. **Lack of Backup for IoT Devices:** IoT-enabled medical devices were excluded from backup schedules.

Actions Taken

1. **Comprehensive Backup Policy:**
 - Developed and implemented a robust policy covering EMRs, IoT devices, and critical infrastructure.
 - Ensured daily backups for EMRs and weekly backups for non-critical systems.
2. **Cybersecurity Enhancements:**
 - Deployed ransomware protection tools like Immutable Backups and air-gapped storage.
 - Encrypted all backups using AES-256 and ensured backups were stored in secure offsite locations.
3. **Regulatory Compliance:**
 - Aligned backup and recovery processes with HIPAA, NCA ECC, and other relevant regulations.
 - Conducted regular audits to verify compliance.
4. **Disaster Recovery Testing:**
 - Performed monthly disaster recovery drills simulating ransomware attacks and system outages.
 - Measured RTO and RPO to ensure adherence to recovery objectives.
5. **IoT Integration:**
 - Included IoT medical devices in backup schedules, ensuring minimal disruption during failures.

Outcomes

- Successfully restored EMRs and critical systems within the defined RTO during recovery drills.
- Ransomware mitigation efforts led to a 90% reduction in backup-related vulnerabilities.
- Achieved full compliance with HIPAA and NCA ECC standards.
- Minimized downtime impact on patient care, enhancing trust and reputation.
- IoT device backups ensured continuity of medical services during device malfunctions.

Reference:

- [1] C. C. Editor, "asset - Glossary | CSRC." Accessed: Mar. 25, 2025. [Online]. Available: <https://csrc.nist.gov/glossary/term/asset>
- [2] M. Stone, C. Irrechukwu, H. Perper, D. Wynne, and L. Kauffman, "IT Asset Management," National Institute of Standards and Technology, NIST Special Publication (SP) 1800-5, Sep. 2018. doi: 10.6028/NIST.SP.1800-5.
- [3] "IT Asset Management for the Financial Services Sector | NCCoE." Accessed: Mar. 25, 2025. [Online]. Available: <https://www.nccoe.nist.gov/financial-services/it-asset-management>
- [4] "Identity & Access Management," NIST, Jun. 2016, Accessed: Mar. 25, 2025. [Online]. Available: <https://www.nist.gov/identity-access-management>
- [5] C. C. Editor, "Identity and access management - Glossary | CSRC." Accessed: Mar. 25, 2025. [Online]. Available: https://csrc.nist.gov/glossary/term/identity_and_access_management
- [6] "Identity management: What you need to know," ISO. Accessed: Mar. 25, 2025. [Online]. Available: <https://www.iso.org/information-security/identity-management>
- [7] J. T. Force, "Security and Privacy Controls for Information Systems and Organizations," National Institute of Standards and Technology, NIST Special Publication (SP) 800-53 Rev. 5, Dec. 2020. doi: 10.6028/NIST.SP.800-53r5.
- [8] Joint Task Force Interagency Working Group, "Security and Privacy Controls for Information Systems and Organizations," National Institute of Standards and Technology, Sep. 2020. doi: 10.6028/NIST.SP.800-53r5.
- [9] A. Almomani, B. B. Gupta, S. Atawneh, A. Meulenberg, and E. Almomani, "A Survey of Phishing Email Filtering Techniques," *IEEE Communications Surveys & Tutorials*, vol. 15, no. 4, pp. 2070–2090, 2013, doi: 10.1109/SURV.2013.030713.00020.
- [10] S. Rose, J. S. Nightingale, S. Garfinkel, and R. Chandramouli, "Trustworthy email," National Institute of Standards and Technology, Gaithersburg, MD, NIST SP 800-177r1, Feb. 2019. doi: 10.6028/NIST.SP.800-177r1.
- [11] S. Sengupta, A. Chowdhary, A. Sabur, A. Alshamrani, D. Huang, and S. Kambhampati, "A Survey of Moving Target Defenses for Network Security," Mar. 21, 2020, *arXiv*: arXiv:1905.00964. doi: 10.48550/arXiv.1905.00964.
- [12] A. Alshamrani, S. Myneni, A. Chowdhary, and D. Huang, "A Survey on Advanced Persistent Threats: Techniques, Solutions, Challenges, and Research Opportunities," *IEEE Communications Surveys & Tutorials*, vol. 21, no. 2, pp. 1851–1877, 2019, doi: 10.1109/COMST.2019.2891891.
- [13] "What Is Network Security?," Cisco. Accessed: Mar. 25, 2025. [Online]. Available: <https://www.cisco.com/c/en/us/products/security/what-is-network-security.html>
- [14] G. Howell, J. M. Franklin, V. Sritapan, M. Souppaya, and K. Scarfone, "Guidelines for managing the security of 34 mobile devices in the enterprise," National Institute of Standards and Technology (U.S.), Gaithersburg, MD, NIST SP 800-124r2, May 2023. doi: 10.6028/NIST.SP.800-124r2.
- [15] M. Zinkus, T. M. Jois, and M. Green, "Data Security on Mobile Devices: Current State of the Art, Open Problems, and Proposed Solutions," May 26, 2021, *arXiv*: arXiv:2105.12613. doi: 10.48550/arXiv.2105.12613.
- [16] "Mobile Device Security: Bring Your Own Device | NCCoE." Accessed: Mar. 25, 2025. [Online]. Available: <https://www.nccoe.nist.gov/mobile-device-security/bring-your-own-device>

- [17] "Data Security | NCCoE." Accessed: Mar. 25, 2025. [Online]. Available: <https://www.nccoe.nist.gov/data-security>
- [18] I. Gupta and A. K. Singh, "A Holistic View on Data Protection for Sharing, Communicating, and Computing Environments: Taxonomy and Future Directions," Feb. 24, 2022, *arXiv*: arXiv:2202.11965. doi: 10.48550/arXiv.2202.11965.
- [19] "Cryptography," *NIST*, Jun. 2016, Accessed: Mar. 25, 2025. [Online]. Available: <https://www.nist.gov/cryptography>
- [20] D. Ott, C. Peikert, and other workshop participants, "Identifying Research Challenges in Post Quantum Cryptography Migration and Cryptographic Agility," Sep. 16, 2019, *arXiv*: arXiv:1909.07353. doi: 10.48550/arXiv.1909.07353.
- [21] L. T. A. N. Brandão, "Privacy-Enhancing Cryptography to Complement Differential Privacy," *NIST*, Nov. 2021, Accessed: Mar. 25, 2025. [Online]. Available: <https://www.nist.gov/blogs/cybersecurity-insights/privacy-enhancing-cryptography-complement-differential-privacy>
- [22] M. Bartock, J. Cichonski, M. Souppaya, M. Smith, G. Witte, and K. Scarfone, "Guide for cybersecurity event recovery," National Institute of Standards and Technology, Gaithersburg, MD, NIST SP 800-184, Dec. 2016. doi: 10.6028/NIST.SP.800-184.
- [23] "msp-protecting-data-extended.pdf." Accessed: Mar. 25, 2025. [Online]. Available: <https://www.nccoe.nist.gov/sites/default/files/legacy-files/msp-protecting-data-extended.pdf>
- [24] "What Is Disaster Recovery? - Cisco." Accessed: Mar. 25, 2025. [Online]. Available: <https://www.cisco.com/site/us/en/learn/topics/security/what-is-disaster-recovery.html>

2.10 Vulnerability Management:

Definition: Vulnerabilities Management is the process of identifying, evaluating, and addressing security weaknesses within an organization’s systems, applications, and networks. It aims to proactively reduce the attack surface by remediating known vulnerabilities, aligning with organizational risk appetite and compliance requirements [1], [2].

Objective: To ensure timely detection and effective remediation of technical vulnerabilities to prevent or minimize the probability of exploiting these vulnerabilities to launch cyber-attacks against the organization.

Controls Matrix:

Below is a summary matrix detailing relevant vulnerability management controls based on NCA Controls, SAMA CSF, CST CRF, and CMA Cybersecurity Guidelines:

Regulation	Main Controls	Control References
NCA ECC	4	2-10-1, 2-10-2, 2-10-3 (5 Sub controls), 2-10-4
SAMA CSF	3	3.3.17.1, 3.3.17.2, 3.3.17.3 (6 Sub controls)
CTS CRF	6	4.3.1, 4.3.2, 4.3.3, 4.3.4, 4.3.5, 4.3.6
CMA CSG	3	4.3.12-1, 4.3.12-2, 4.3.12-3 (7 Sub controls)
NCA CCCC	2	2-9-1 (3 Sub controls), 2-9-2
NCA CCC CST	1	2-9-T-1 (2 Sub controls)
NCA CCC CSP	1	2-9-P-1 (2 Sub controls)
NCA TCC	1	2-9-1 (2 Sub controls)
NCA OTCC	2	2-9-1 (3 Sub controls), 2-9-2

Vulnerability Management Controls:

National Cybersecurity Authority - Essential Cybersecurity Controls ECC					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
2-10-1		Cybersecurity requirements for technical vulnerabilities management must be defined, documented and approved.	Vulnerabilities Management Policy Template.	• Develop and document cybersecurity policy for vulnerabilities management in the organization, including the following: Vulnerabilities assessment and testing requirements for all technology assets. • Requirements for periodic vulnerability assessment. • Requirements for the classification of vulnerabilities according to their severity. • Requirements to address vulnerabilities using effective tools and methods. • Support the organization's policy by the Executive Management. This must be done through the approval of the organization head or his/her deputy.	• Cybersecurity policy that covers the requirements of vulnerabilities management (e.g., electronic copy or official hard copy). • Formal approval by the head of the organization or his/her deputy on the policy (e.g., via the organization's official e-mail, paper or electronic signature).
2-10-2		The cybersecurity requirements for technical vulnerabilities management must be implemented.	Vulnerability Management Process Template. Vulnerability Management Log Template.	Implement all cybersecurity requirements to the organization's approved vulnerabilities management. It is also recommended that the vulnerabilities management procedures cover the following, but not limited to: Periodic	Vulnerability Management Procedure. Patch Management Procedures. Vulnerabilities detection and testing reports (pre- and post-treatment) indicating classification of vulnerabilities.

				vulnerability assessment and detection procedures. The mechanism for classifying vulnerabilities according to their severity. • Procedures for addressing vulnerabilities based on their classification and associated cyber risks. Mechanism and procedure for escalation of technical vulnerabilities. Methods of linking vulnerabilities management procedures to the security patch management procedures.	
2-10-3 The cybersecurity requirements for technical vulnerabilities management must include at least the following:	2-10-3-1	Periodic vulnerabilities assessments.	• Define and document the requirements of this ECC in the cybersecurity requirements document and approve them by the representative. • Identify technologies and tools to assess and detect vulnerabilities of information and technology assets. Install and link vulnerabilities assessment and detection technologies and tools with the organizations information and technology assets. • Develop periodic plan and procedures to inspect and detect vulnerabilities in the information and technology assets in the organization, including: Applications Devices and servers Databases Organization's Networks.	• Cybersecurity policy that covers the periodical assessment and detecting vulnerabilities (based on the plan and planned interval specified in the policy) of the following assets: Applications Devices and servers Databases Organization's Networks (e.g., electronic copy or official hard copy). • Formal approval by the head of the organization or his/her deputy on such requirements (e.g., via the organization's official e-mail, paper or electronic signature).	

				• Vulnerabilities management procedures and a periodic plan to assess and detect vulnerabilities. Periodic reports to assess and detect vulnerabilities.
	2-10-3-2	Vulnerabilities classification based on criticality level.	• Define and document the requirements of this ECC in the cybersecurity requirements document and approve them by the representative. • Prepare and review vulnerabilities assessment reports on the information and technology assets in the organization, including the classification of vulnerabilities based on the following: Description of vulnerabilities and their exploitative potential and the expected impact of the organization Network segmentation Classification of vulnerabilities by concerned assets Classification of vulnerabilities based on Common Vulnerability Scoring System (CVSS).	Cybersecurity policy that covers the vulnerabilities classification mechanism and methodology based on their criticality and cyber risks and based on the organization's network segmentation (e.g., electronic copy or official hard copy). • Formal approval by the head of the organization or his/her deputy on such document (e.g., via the organization's official e-mail, paper or electronic signature). • Vulnerabilities management procedures that illustrate the classification mechanism Vulnerabilities detection and assessment reports indicating the classification of vulnerabilities.
	2-10-3-3	Vulnerabilities remediation based on classification and associated risk levels.	• Define and document the requirements of this ECC in the cybersecurity requirements document and approve them by the representative. • Share the organization's information and technology asset vulnerabilities assessment and detection reports with the relevant departments, including but not	Cybersecurity policy that covers plans to address the identified vulnerabilities in the organization (e.g., electronic copy or official hard copy). • Formal

			limited to. • Application management department - Workstations' department - Infrastructure department - Database management department - Network department Ensure that the reports shared contain: - Vulnerabilities description - Name of the relevant assets in which vulnerabilities were assessed and detected - Vulnerabilities classification Cooperate with the concerned departments to determine a time period and a plan to address the vulnerabilities, taking into account the vulnerabilities classification and classification of the relevant assets. • Develop a mechanism to ensure that vulnerabilities are addressed based on the plan.	approval by the head of the organization or his/her deputy on such document (e.g., via the organization's official e-mail, paper or electronic signature). • Vulnerability Management Procedure - Patch Management Procedures - Vulnerability assessment (before and after remedy).
	2-10-3-4	Ensure the management of software updates and security patches includes verifying their safety and effectiveness in a non-production environment before deployment in the production environment.	• Define and document the requirements of this ECC in the cybersecurity requirements document and approve them by the representative. • Link vulnerabilities management procedures to the security patch management procedures and change procedures. • Analyze vulnerabilities assessment and detection reports to identify the organizations information and technology assets wo which security patches must be installed. • Cooperate with the concerned departments to determine a time period and plan to install patches, taking into account the need for updating and classification of the relevant assets. • Implement a robust testing process in the non-production environment to validate the integrity and functionality of patches before deployment. This should include simulating real-world scenarios to ensure the patch does not introduce new vulnerabilities or disrupt system operations.	• Cybersecurity policy and procedures that cover the security patch management requirements to address vulnerabilities. (e.g., electronic copy or official hard copy) • Formal approval by the head of the organization or his/her deputy on such document (e.g., via the organization's official e-mail, paper or electronic signature). • Vulnerability Management Procedure • Patch Management Procedures • Vulnerability assessment (before and after remedy).

	2-10-3-5	Subscription with authorized and trusted cybersecurity resources for up-to-date information and notifications on technical vulnerabilities.	• Define and document the requirements of this ECC in the cybersecurity requirements document and approve them by the representative. • Identify and register with reliable sources regarding alerts for new and updated vulnerabilities. This includes: National entities (e.g., NCA, NCSC) Suppliers and Information and Technology Asset Manufacturers (OEMS) Specialized cybersecurity groups in general and in the organization's sector. • Cybersecurity companies through their tools and technologies.	Cybersecurity policy that covers this control (e.g., electronic copy or official hard copy). Formal approval by the head of the organization or his/her deputy on such document (e.g., via the organization's official e-mail, paper or electronic signature). List of communication channels subscribed in to receive alerts on new vulnerabilities.
2-10-4		The cybersecurity requirements for technical vulnerabilities management must be reviewed periodically.	Review the cybersecurity requirements of Vulnerabilities Management by conducting a periodic assessment (according to a documented and approved plan for review, and based on a planned interval "e.g., quarterly") to implement identity and access management requirements by the Cybersecurity function and in cooperation with relevant departments (such as IT Department). • Conduct application reviews through traditional channels (e.g., email) or automated channels using a compliance management system. The organization may develop a review plan explaining the implementation review schedule for Vulnerabilities Management. • Review and update cybersecurity requirements for vulnerability management in the organization periodically according to a documented and approved plan for review and based on a planned interval or in the event of changes in relevant laws and regulations.	Results of vulnerabilities management cybersecurity requirements implementation review in the organization. A document that defines the cybersecurity requirements implementation review cycle for vulnerabilities management in the organization (Compliance Assessment Schedule). Compliance assessment report that outlines the assessment of the implementation of cybersecurity requirements for the organization's Vulnerabilities Management. An approved document that sets the policy's review

			Document the review and changes to the cybersecurity requirements for Vulnerabilities Management in the organization and approve them by the head of the organization or his/her deputy.	schedule. Policy indicating that it has been reviewed and updated, and that changes have been documented and approved by the head of the organization or his/her deputy. Formal approval by the head of the organization or his/her deputy on the updated policy (e.g., via the organization’s official e-mail, paper or electronic signature).	
National Cybersecurity Authority – Critical Systems Cybersecurity Controls CSCC					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
2-9-1 In addition to the sub-controls under Control 2-10-3 in the Cybersecurity Core Controls, the cybersecurity requirements for vulnerability management for critical	2-9-1-1	Use reliable means and tools to find vulnerabilities.	Cybersecurity Risk Management Procedure Template. Vulnerability Register Template. Vulnerabilities Management Policy Template. Vulnerabilities Management Standard Template.	- Work on identifying the tools used to discover vulnerabilities and review them to ensure their effectiveness. - Work on using more than one way to discover vulnerabilities in critical systems, including: 1- Using more than one tool approved by trusted parties to detect vulnerabilities, including open-source tools. 2- Use of globally recognized vulnerability tools that have independent reports on tool effectiveness testing.	List of methods and tools used to discover vulnerabilities.

systems should cover, at a minimum, the following:				3- Review vulnerabilities alerts from suppliers related to critical systems. 4- Review vulnerability alerts from the National Cybersecurity Authority and the National Cybersecurity Guidance Center. 5- Manual scanning to discover vulnerabilities in critical systems. 6- Updating the tools used to discover vulnerabilities.	
	2-9-1-2	Vulnerability assessment and remediation (by installing updates and fixes packages) on technical components of critical systems, at least once a month, for critical external systems connected to the Internet; And at least every three months, for critical internal systems.	Cybersecurity Risk Management Procedure Template. Vulnerability Register Template. Vulnerabilities Management Policy Template. Vulnerabilities Management Standard Template.	• Work to identify external critical systems (i.e. connected to the Internet) and internal critical systems and their technical components according to the entity's inventory of critical systems. • Evaluating vulnerabilities on all components of critical systems, determining their type, classifying their level of severity, and assigning an owner to them to be addressed by installing update and fix packages. • Ensure that the vulnerability treatment plan includes addressing the vulnerabilities discovered on external critical systems and their technical components within one month from the time they are discovered.	Assessment reports and plans to identify the vulnerabilities discovered in critical systems and reports on the implementation of these plans.

	2-9-1-3	Immediate remediation of newly discovered critical vulnerabilities; Following the change management mechanisms approved by the entity.	Cybersecurity Risk Management Procedure Template. Vulnerability Register Template. Vulnerabilities Management Policy Template. Vulnerabilities Management Standard Template.	• Ensure that the vulnerability treatment plan includes addressing critical vulnerabilities discovered on critical systems and their technical components as soon as they are discovered or as soon as they are announced by approved system developers, and identify gaps by following up on treatment plans while following the approved procedures for emergency changes by submitting requests and obtaining the necessary approvals.	A plan for the critical vulnerabilities discovered in critical systems.
2-9-2	Referring to Control 2-10-3-1 in Basic Cyber Security Controls, vulnerabilities on technical components, of critical systems, should be scanned and discovered once a month; at least.		Cybersecurity Risk Management Procedure Template. Vulnerability Register Template. Vulnerabilities Management Policy Template. Vulnerabilities Management Standards Template.	• Ensure that schedule scans and discovering vulnerabilities of critical systems components (including but not limited to applications, encryption devices, databases, network devices) are scheduled at least once a month.	Schedule scan reports and find vulnerabilities for critical systems.
National Cybersecurity Authority - Telework Cybersecurity Controls TCC					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
2-9-1	2-9-1-1	Assessing vulnerabilities on technical components of	Vulnerability Management	Work on defining the requirements for this control,	A document that identifies and documents the

In addition to the subcontrols in the ECC control 2-10-3, cybersecurity requirements for technical vulnerabilities management of telework systems must include at least the following:		telework systems, and to be classified based on criticality at least once every three months.	Policy Template. Vulnerability Management Standard Template. Vulnerability Assessment Procedure. Vulnerability Register.	document them in the cybersecurity requirements document, and have them approved by the authority holder. Based on defined backup periodicity and business continuity plan, define and approve the periodic testing of telework backup systems at least once every six months. Ensure the effectiveness of the recovery procedures by conducting a test to restore backups periodically to ensure the ability to restore data and telework systems according to the period specified in the procedures and according to the period that has been identified for the completion of restoring backups.	requirements of this control (such as a policy and/or procedure approved by the authority holder). Document a business plan and procedures for implementing cybersecurity requirements for backup management. Test reports that examine the effectiveness of backups for telework systems, so that it clarifies the difference between the expected duration and the test duration for restoring all backups.
	2-9-1-2	Remediating vulnerabilities for telework systems, at least once every three months.	Vulnerability Management Policy Template. Vulnerability Management Standard Template. Vulnerability Assessment Procedure. Vulnerability Register.	Work on defining the requirements for this control, document them in the cybersecurity requirements document, and have them approved by the authority holder. Sharing reports of the vulnerabilities inspected and discovered in the information and technical assets of teleworking system of the organization with the concerned departments, which include, but are not limited to: Department	Work on defining the requirements for this control, document them in the cybersecurity requirements document, and have them approved by the authority holder. Vulnerability management procedures. Procedures for managing security fixes and updates patches for telework systems. Reports of vulnerabilities for telework systems (before and after treatment).

				concerned with managing applications Department of Management of user devices Infrastructure Department concerned with database management Network management Ensure that the shared vulnerability reports of teleworking system contain: A description of the vulnerabilities. Relevant asset's name which vulnerabilities were scanned and discovered in. Classification of vulnerabilities. Work with the concerned departments to define a timeline and a plan to address the vulnerabilities, taking into account the classification of the vulnerabilities and the classification of the assets concerned. Develop a mechanism to ensure that gaps are addressed according to the plan.	
National Cybersecurity Authority – Operational Technology Cybersecurity Controls OTCC					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
2-9-1 In addition to subcontrols in the ECC control 2-10-3,	2-9-1-1	Scope and activities of vulnerability assessments must be defined for OT/ICS environment as part of	Template for Cybersecurity Vulnerability	Define, document, and approve vulnerability assessment scope and activities for OT/ICS environment ensuring limited or no impact on the production	A documented OT/ICS vulnerability assessment scope and activities. A proof that OT/ICS vulnerability assessment is part of the

cybersecurity requirements for vulnerability management in OT/ICS must cover, at a minimum, the following:		organization's formal vulnerability management while ensuring limited or no impact on the production environment.	Template for Cybersecurity Operational Technology Policy Template for OT/ICS Security Standard	environment. Include OTICS /vulnerability assessment as part of the organization's formal vulnerability management process. Verify and ensure that all OT/ICS assets are covered by the approved vulnerability assessment process.	organization's formal vulnerability management.
	2-9-1-2	With reference to the ECC subcontrol 2-10-3-3, remediation of newly discovered critical vulnerabilities presenting significant risks to the OT/ICS environment must be performed in a timely manner.	Template for Vulnerability Management Policy Template for Vulnerability Management Standard Template for Cybersecurity Vulnerability Management Processes and Procedures, including a template for managing discovered vulnerabilities Template for Vulnerability Register	Develop a procedure for the remediation of newly discovered critical vulnerabilities presenting significant risks in a timely manner. Ensure that the vulnerabilities management procedures are implemented.	Approved vulnerability remediation plan. A vulnerability remediation report. A proof that all newly discovered critical vulnerabilities that pose significant risks to the OT/ICS environment are remediated in a timely manner.

	2-9-1-3	With reference to the ECC subcontrol 2-10-3-1, vulnerability assessment for OT/ICS systems must be conducted periodically.	• Template for Cybersecurity Operational Technology Policy • Template for OT/ICS Security Standard • Template for Vulnerability Management Policy • Template for Vulnerability Management Standard • Template for Cybersecurity Vulnerability Management Processes and Procedures, including a template for managing discovered vulnerabilities • Template for Vulnerability Register	• Verify and ensure that vulnerability assessment is conducted periodically in accordance to the facility level stated in (OTCC-1:2022).	Periodically prepared vulnerability assessment reports. A Proof that vulnerability assessment for OT/ICS systems is conducted periodically in accordance to the facility level stated in (OTCC-1:2022).
2-9-2		With reference to the ECC control 2-10-4, the cybersecurity requirements for vulnerability management in OT/ICS environment must be reviewed, and their implementation	Template for Cybersecurity Operational Technology Policy	Review the cybersecurity requirements for vulnerability management specific to OT/ICS periodically based on a documented and approved review plan and on a defined	A proof that shows the periodic review of cybersecurity requirements for vulnerability management in the OT/ICS environment.

	effectiveness is measured and evaluated periodically.	Template for OT/ICS Security Standard Template for Vulnerability Management Policy Template for Key Performance Indicator Report	frequency (e.g., conduct a review annually). Develop key performance indicators (KPIs) for each control within the related policy or procedure to ensure the implementation effectiveness is measured and evaluated periodically based on a defined frequency (e.g., conduct a review annually).	A proof that shows the key performance indicators (KPIs) for each control within the related policy or procedure to ensure the implementation effectiveness is measured and evaluated periodically (based on a defined frequency).
--	---	---	--	--

National Cybersecurity Authority - Cloud Cybersecurity Controls CCC

Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
2-9-P-1 In addition to sub controls in the ECC control 2-10-3, the CSP shall cover the following additional sub controls for cybersecurity requirements for vulnerability management requirements, as a minimum:	2-9-P-1-1	Assessing and remediating vulnerabilities on external components of Cloud Technology Stack at least once every month, and at least once every three months for internal components of Cloud Technology Stack.	Template for Security Vulnerability Assessment Procedure, including a registry template for managing discovered vulnerabilities Template for Vulnerability Log Template for Vulnerability Management Policy Template for Vulnerability	Define and implement a Threat and Vulnerability Management policy that includes the intent, purpose, and governance of how a CSP must address threats and vulnerabilities for their respective scope under the Security Shared Responsibility Model. At a minimum, the policy should specify: The frequency of assessments for external components of Cloud Technology Stack monthly assessments. The frequency of assessments for internal components of Cloud Technology Stack - quarterly	Threat and Vulnerability Management Policy. Sample of assessments. Sample of remediation's plans and actions.

			Management Standard.	assessments. Remediation of threats and vulnerabilities for external components and internal components must be completed based on the severity of the identified threats and vulnerabilities. Identify vulnerability detection methods that are in use. What components to be covered under the scope considering applicable laws, regulations, and contractual requirements. The vulnerability severity levels relevant to the organization. When and how and to whom vulnerabilities should be reported and reviewed, especially significant vulnerabilities. O How remediating actions are tracked for timely and effective closure.	
	2-9-P-1-2	Notification to CSTs of identified vulnerabilities that may affecting them, and safeguards in place.	Template for Security Vulnerability Assessment Procedure, including a registry template for managing discovered vulnerabilities Template for Vulnerability Log	Report immediately to CSTs detected vulnerabilities (that impact them) with sufficient information to analyse related risks and correlate Threat Response on CST side.	Reports sent to CSTs about detected vulnerabilities that impact them.

			Template for Vulnerability Management Policy Template for Vulnerability Management Standard.		
2-9-T-1 In addition to sub controls in the ECC control 2-10-3, the CST shall cover the following additional sub controls for cybersecurity requirements for vulnerability management requirements, as a minimum:	2-9-T-1-1	Assessing and remediating vulnerabilities cloud services and at least once every three months.	Template for Security Vulnerability Assessment Procedure, including a registry template for managing discovered vulnerabilities. Template for Vulnerability Log. Template for Vulnerability Management Policy. Template for Vulnerability Management Standard.	Define and implement the Threat and Vulnerability Management control policy that includes the intent, purpose, and governance of how a CST must address threats and vulnerabilities for their respective scope under the Security Shared Responsibility Model. At a minimum, the policy should specify: The frequency of assessments (e.g., quarterly assessments). Acceptable periods of remediation of threats and vulnerabilities - three months. The vulnerability detection methods are in use (e.g., end-point threat detection agent). What components to be covered under the scope considering applicable laws, regulations, and contractual requirements. The vulnerability severity levels relevant to the organization. When and how and to whom vulnerabilities	Document outlining the establishment and assurance of the implementation of a Vulnerability Management Policy encompassing cloud computing. Report assessing and addressing vulnerabilities related to cloud services at least once every three months.

				should be reported and reviewed, especially significant vulnerabilities. How remediating actions are tracked for timely and effective closure.	
	2-9-T-1-2	Management of CSP-notified vulnerabilities safeguards in place.	Template for Security Vulnerability Assessment Procedure. Template for Vulnerability Management Policy. Template for Vulnerability Management Standard. Template for Vulnerability Log.	Define and implement a Threat and Vulnerability Management policy that includes the intent, purpose, and governance of how a CST must address threats and vulnerabilities for their respective scope under the Security Shared Responsibility Model. At a minimum, the policy should specify: How a CST is notified about vulnerabilities detected by CSP. Assessment methods for these vulnerabilities. How remediating actions are tracked for timely and effective closure.	Document outlining the establishment and assurance of the implementation of a Vulnerability Management Policy encompassing cloud computing. Report on managing vulnerabilities notified to the CST by the CSP, including the remediation process.
SAMA Cyber Security Framework CSF					
Control reference number	Control clauses		Control implementation guidelines		Expected deliverables
3.3.17-1	The vulnerability management process should be defined, approved, and implemented.		Define a formal process for managing vulnerabilities, document it, obtain approval from relevant authority, and put the process into action.		Documented vulnerability management process. Evidence of approval.
3.3.17-2	The effectiveness of the vulnerability management process should be measured and periodically evaluated.		Establish metrics to track the performance of the vulnerability management process (e.g., the number of vulnerabilities identified, time to remediate). Regularly assess the effectiveness of the process using these metrics.		Reports on vulnerability management process performance. Documentation of periodic evaluations.

3.3.17-3 The vulnerability management process should include:	3.3.17-3-a all information assets;	Ensure the vulnerability management process incorporates the following elements: Include all information assets (hardware, software, data, network components) in the scope of the vulnerability management process.	Inventory of all information assets included in the vulnerability management process.
	3.3.17-3-b frequency of performing the vulnerability scan (risk-based);	Determine the frequency of vulnerability scans based on the risk level of the assets. Higher-risk assets should be scanned more frequently.	Schedule for vulnerability scans based on risk assessment.
	3.3.17-3-c classification of vulnerabilities;	Classify vulnerabilities based on their severity (e.g., critical, high, medium, low).	Documented vulnerability classification scheme. Vulnerability assessment reports with classifications.
	3.3.17-3-d defined timelines to mitigate (per classification);	Establish specific timelines for remediating vulnerabilities based on their classification. Critical vulnerabilities should be addressed more urgently.	Remediation plan with defined timelines for each vulnerability class.
	3.3.17-3-e prioritization for classified information assets;	Prioritize vulnerability management efforts for information assets that handle sensitive or classified data.	Documented prioritization criteria for information assets.
	3.3.17-3-f patch management and method of deployment.	Implement a system for managing and deploying security patches. Define and follow a controlled patch deployment process.	Patch management plan. Records of patch deployments.
CST CRF			
Control reference number	Control clauses	Control implementation guidelines	Expected deliverables
4.3.1 CL1	Define and document [Requirements for Vulnerability Management] which consider the following: -Scope, tools and technology, reporting -The frequency of scans -Timeframes for remediating the vulnerabilities (based on the criticality)	This control emphasizes the importance of establishing and documenting clear requirements for your vulnerability management program. These requirements should cover the scope of systems and assets included, the tools and technologies used for vulnerability scanning and assessment, reporting mechanisms, the frequency of vulnerability scans, and the expected timeframes for remediating	Documented vulnerability management requirements.

		vulnerabilities based on their severity. You should define and document comprehensive requirements for vulnerability management, taking into account the scope of assets, tools and technologies, reporting procedures, scan frequency, and remediation timelines based on vulnerability criticality.	
4.3.2 CL1	Define and implement a Vulnerability Management process consisting of: -Scanning: Conduct vulnerability scans on information assets (Asset Inventory) using relevant tools according to the frequency defined in the requirements (e.g., monthly for critical systems) -Analyzing: Analyze the impact that the vulnerability has on the critical information assets and assign a criticality to it and define and assign timeframes (depending on the criticality) within which the vulnerabilities have to be remediated. -Reporting: Report vulnerabilities [Vulnerabilities Report] along with criticality of the assets to the respective departments and define the recommended action. [Patch Management]	This control focuses on putting a structured vulnerability management process in place. This process should include regular vulnerability scans on your information assets using appropriate tools, analysis of the identified vulnerabilities to determine their potential impact and assign a criticality level, and reporting of the vulnerabilities to the relevant teams along with recommended remediation actions. You need to define and implement a formal vulnerability management process and utilize vulnerability scanning tools. This process should include regular vulnerability scanning of information assets, analysis of identified vulnerabilities to determine their severity and potential impact, and reporting of vulnerabilities along with remediation recommendations.	Documented vulnerability management process. Vulnerability scan reports. Vulnerability remediation plans. Vulnerability assessment system's dashboard.
4.3.3 CL2	Perform vulnerability scans triggered by distinct events (e.g., product release, major technical change, new equipment added to networks).	Explanation: This control highlights the need to perform vulnerability scans not only on a scheduled basis but also when triggered by specific events that could introduce new vulnerabilities to your environment. Such events might include new software releases, significant technical changes, or the addition of new devices to your network. You need to implement a process for triggering vulnerability scans whenever specific events occur, such as new product releases, major technical	Records of vulnerability scans triggered by technology events such as new releases, new products deployment, network appliances installation etc...

		changes, or the addition of new equipment to the network.	
4.3.4 CL2	Use specialized and automated vulnerability scanning tools (e.g., dedicated tools for web servers, mobile apps).	This control recommends using specialized and automated tools for vulnerability scanning. This can help improve the efficiency and effectiveness of your vulnerability management efforts. Utilize specialized and automated tools to conduct vulnerability scans. Select tools that are appropriate for the specific technologies and assets being scanned.	List of approved vulnerability scanning tools. Deployment of VA solutions. VA dashboard access.
4.3.5 CL3	Enhance vulnerability classification and reporting based on inputs from other sources (e.g., penetration testing, threat intelligence).	This control encourages incorporating information from other security activities, such as penetration testing and threat intelligence, to improve the accuracy and comprehensiveness of your vulnerability classification and reporting. Integrate information from penetration testing, threat intelligence feeds, and other relevant sources to enhance the classification of vulnerabilities and provide more detailed vulnerability reports.	Vulnerability reports enriched with insights from penetration testing and threat intelligence feeds and updates.
4.3.6 CL3	Continuously measure, review and optimize the [Requirements for Vulnerability Management] as well as the effectiveness of the process.	This control stresses the importance of continuous improvement. Your vulnerability management requirements and the effectiveness of your overall vulnerability management process should be regularly measured, reviewed, and optimized to ensure they remain relevant and effective in the face of evolving threats and technologies. Establish a process for regularly measuring, reviewing, and optimizing both the vulnerability management requirements and the overall effectiveness of the vulnerability management process.	Reports on the measurement and review of vulnerability management requirements and process effectiveness. Documentation of optimization efforts.
CMA Cybersecurity Guidelines			

Control reference number	Control clauses	Control implementation guidelines	Expected deliverables
4.3.12-1	Set out, document, approve and implement vulnerabilities management process.	This requires establishing a formal, documented process for managing vulnerabilities. This process should be approved by the appropriate authority within your organization and actively put into practice. The organization should define a formal process for managing vulnerabilities, document it thoroughly, obtain necessary approvals, and implement the process.	Documented vulnerability management process. Evidence of approval, publishment, and user acknowledgement.
4.3.12-2	Measure and evaluate effectiveness of vulnerabilities management process periodically.	This emphasizes the importance of ongoing monitoring and assessment. Organizations need to track the performance of their vulnerability management process and regularly evaluate its effectiveness. This might involve using metrics such as the number of vulnerabilities discovered, the time taken to remediate vulnerabilities, and the impact of vulnerabilities on the organization. The organization should define metrics to track the performance of the vulnerability management process. Regularly assess the effectiveness of the process using these metrics and make adjustments as needed.	Reports on vulnerability management process performance. Documentation of periodic evaluations of the VA process.
4.3.12-3 The vulnerabilities management process shall include:	4.3.12-3.1 All information and technical assets;	The vulnerability management process should cover all information assets within the organization, including hardware, software, data, and network components. No system should be left out of the scope of vulnerability management. The organization should ensure that all information and technical assets are included in the scope of the vulnerability management process.	Inventory of all information assets included in the vulnerability management process.

	4.3.12-3.2 Periodic vulnerability scan;	Vulnerability scans should be conducted regularly. The frequency of these scans should be determined based on a risk assessment, with higher-risk assets scanned more frequently. The organization should establish a schedule for conducting periodic vulnerability scans on all information assets. The frequency of scans should be based on the risk level associated with each asset.	Schedule for vulnerability scans. Records of vulnerability scan results.
	4.3.12-3.3 Classifying security vulnerabilities;	Discovered vulnerabilities should be classified based on their severity (e.g., critical, high, medium, low). This helps prioritize remediation efforts. The organization should implement a system for classifying vulnerabilities based on their severity.	Documented vulnerability classification scheme. Vulnerability assessment reports with vulnerability classifications.
	4.3.12-3.4 Setting timelines to patch vulnerabilities, based on their classification;	Specific timelines should be established for addressing vulnerabilities based on their severity classification. Critical vulnerabilities should be addressed with a greater sense of urgency than low-risk vulnerabilities. The organization should define specific timelines for remediating vulnerabilities based on their severity classification.	Remediation plan with defined timelines for each vulnerability class.
	4.3.12-3.5 Setting priorities for classified information and technology assets;	Information assets that handle sensitive or classified data should be given higher priority in the vulnerability management process. The organization should prioritize vulnerability management efforts for information assets that handle sensitive or classified data.	Documented prioritization criteria for information assets.
	4.3.12-3.6 Managing security patching and implementation methods;	The vulnerability management process should include a mechanism for managing and deploying security patches to remediate identified vulnerabilities. This involves selecting, testing, and deploying patches in a controlled manner to minimize disruptions to business operations.	Patch management plan. Records of patch deployments.

		The organization should implement a system for managing and deploying security patches to address identified vulnerabilities.	
	4.3.12-3.7 Communicating and cooperating with trusted sources regarding new and patched vulnerabilities alerts.	This involves staying informed about newly discovered vulnerabilities and available patches by communicating and collaborating with trusted sources such as security vendors, industry groups, and relevant authorities. The organization should establish communication channels with trusted sources to receive timely alerts about new and patched vulnerabilities.	List of trusted sources for vulnerability information. Records of communication with these sources.

Risk Considerations in Vulnerability Management

- **Unaddressed Vulnerabilities:**
 - Failure to patch known vulnerabilities increases exposure to attacks such as ransomware and data breaches.
 - **Delayed Remediation:**
 - Slow patch deployment leaves systems exposed to potential exploitation.
 - **Incomplete Asset Coverage:**
 - Undiscovered assets, shadow IT, or unmonitored IoT devices may harbor hidden vulnerabilities.
 - **Zero-Day Exploits:**
 - Newly discovered vulnerabilities without available patches pose a significant threat.
 - **Third-Party Risks:**
 - Vendor software or systems with undisclosed vulnerabilities can compromise internal networks.
 - **Non-Compliance with Regulations:**
 - Failure to meet regulatory standards such as NCA ECC or SAMA CSF may result in penalties or legal consequences.
 - **Human Error:**
 - Misconfigured systems or overlooked patches due to manual processes increase vulnerability.
 - **Insufficient Monitoring:**
 - Lack of continuous monitoring allows vulnerabilities to persist undetected.
 - **Legacy Systems:**
 - Unsupported systems often cannot receive patches, making them prime targets for attackers.
 - **False Positives:**
 - Excessive false alarms can lead to alert fatigue and overlooked genuine vulnerabilities.
-

Examples of Technologies for Effective Vulnerability Management

- **Vulnerability Scanners**
 - Tools: *OpenVAS* (by Greenbone), *Nikto*, *Nmap* (with NSE scripts).
- **Patch Management Solutions**
 - Tools: *WSUS* (Windows Server Update Services – free for Windows environments), *Ansible* (for Linux-based patch automation), *yum-cron*, *apt unattended-upgrades*.
- **Threat Intelligence Platforms**
 - Tools: *MISP* (*Malware Information Sharing Platform*) – an open-source threat intelligence sharing platform.
- **SIEM Integration**
 - Tools: *Wazuh*, *ELK Stack* (*Elasticsearch*, *Logstash*, *Kibana*), *TheHive*.
- **Configuration Management Tools**
 - Tools: *Chef*, *Puppet*, *Ansible* (all open-source versions available).

- **Application Security Testing**
 - Tools: *OWASP ZAP (Zed Attack Proxy), Nikto, w3af, sqlmap*.
 - **Automation Platforms**
 - Tools: *Ansible, OpenVAS CLI/API, Nessus Essentials* (free limited version), *Cortex (by TheHive)*.
 - **Endpoint Protection Solutions**
 - Tools: *OSSEC, Wazuh* (with endpoint monitoring), *ClamAV* (for antivirus scanning).
 - **Penetration Testing Tools**
 - Tools: *Metasploit Framework (Community Edition), Burp Suite Community Edition, Kali Linux toolset* (includes many open-source tools like Hydra, sqlmap, etc.).
-

Examples of KPIs for Vulnerability Management

- **Patch Compliance Rate:**
 - Percentage of systems patched within the defined SLA period.
 - **Mean Time to Remediate (MTTR):**
 - Average time taken to resolve critical vulnerabilities.
 - **Scan Coverage:**
 - Percentage of organizational assets scanned during regular vulnerability assessments.
 - **False Positive Rate:**
 - Percentage of identified vulnerabilities incorrectly flagged as risks.
 - **Critical Vulnerability Rate:**
 - Number of unresolved high-risk vulnerabilities per reporting period.
 - **Incident Reduction Rate:**
 - Year-over-year decrease in security incidents attributed to vulnerabilities.
 - **Compliance Rate:**
 - Proportion of systems meeting regulatory or organizational vulnerability management standards.
-

Samples of Auditor's Checklist for Vulnerability Management

1. Are vulnerability management policies documented, approved, and periodically updated?
2. Are all critical systems included in regular vulnerability scans?
3. Is there a defined SLA for remediating vulnerabilities, and is it adhered to?
4. Are patch management processes automated to ensure timely updates?
5. Are third-party software vulnerabilities monitored and addressed?
6. Are vulnerability scans and remediation efforts aligned with regulatory requirements like NCA ECC?
7. Are penetration tests conducted to evaluate the organization's defense against known vulnerabilities?
8. Is there evidence of continuous monitoring for new vulnerabilities and zero-day exploits?
9. Are reports on unresolved vulnerabilities regularly escalated to management?
10. Is there a risk-based prioritization framework for addressing vulnerabilities?

Samples of Audit Scenarios for Vulnerability Management

Scenario 1: Delayed Remediation

- **Objective:** Assess whether critical vulnerabilities are resolved within defined SLAs.
- **Steps:**
 1. Review logs for unresolved high-risk vulnerabilities.
 2. Verify adherence to patch management timelines.
 3. Conduct interviews with the remediation team.
- **Questions:**
 - What factors contributed to remediation delays?
 - Are there sufficient resources for patch management?

Scenario 2: Third-Party Software Vulnerabilities

- **Objective:** Ensure third-party software vulnerabilities are effectively managed.
- **Steps:**
 1. Evaluate vendor agreements for patching and vulnerability disclosures.
 2. Review patch logs for third-party software.
 3. Verify security compliance of third-party integrations.
- **Questions:**
 - Are vendors providing timely vulnerability updates?
 - Is third-party software monitored for compliance?

Case Study 1: Vulnerability Management in the Energy Sector

Scenario:

A leading energy company operating critical infrastructure, including power grids and oil refineries, experienced a ransomware attack targeting its Industrial Control Systems (ICS). The attack leveraged a vulnerability in legacy systems, disrupting electricity distribution for 24 hours and resulting in significant financial and reputational damage.

Challenges:

1. **Legacy Systems:**
 - The ICS relied on outdated hardware and software that no longer received vendor support or security updates.
 - Critical infrastructure lacked compatibility with modern security tools.
2. **Inadequate Asset Visibility:**
 - The organization did not have a complete inventory of connected ICS devices, leading to unmanaged vulnerabilities.
3. **Poor Network Segmentation:**
 - Flat network architecture allowed attackers to move laterally from IT to OT systems.
4. **Vendor Dependencies:**
 - Third-party vendors managing the ICS devices did not disclose vulnerabilities, resulting in delayed patches.

Actions Taken:

1. **Comprehensive Asset Inventory:**
 - Deployed **Tenable OT** to map all connected ICS devices and identify vulnerabilities.
 - Conducted manual assessments to cross-verify the automated inventory for completeness.
2. **Virtual Patching:**
 - Applied virtual patches using **Trend Micro Deep Security** to mitigate risks in legacy systems while planning phased replacements.
 - Partnered with ICS vendors to ensure timely patch deployment for supported devices.
3. **Network Security Enhancements:**
 - Implemented network segmentation to isolate IT and OT environments.
 - Deployed industrial-grade firewalls and intrusion detection systems (IDS) tailored for OT networks.
4. **Incident Response Plan (IRP):**
 - Established an OT-specific IRP and conducted training for operators to respond to ICS-targeted threats.
 - Incorporated regular simulations of ransomware attacks to test the response readiness.
5. **Regulatory Alignment:**
 - Worked with the National Cybersecurity Authority (NCA) to align vulnerability management practices with NCA ECC and OTCC guidelines.

- Conducted external audits to validate compliance and assess cybersecurity maturity.

Outcomes:

1. **Risk Reduction:**
 - Reduced critical vulnerabilities by 85% within six months through virtual patching and network segmentation.
2. **Operational Resilience:**
 - Ensured 24/7 availability of power and energy distribution systems with minimal disruptions during subsequent incidents.
3. **Improved Visibility:**
 - Achieved 100% asset inventory coverage, enabling proactive monitoring of all ICS devices.
4. **Regulatory Compliance:**
 - Achieved full compliance with NCA ECC and OTCC, enhancing trust with government stakeholders.

Lessons Learned:

- Legacy systems require a clear strategy combining virtual patches and phased replacements.
 - Vendor accountability is critical; contracts should include timely vulnerability disclosures and SLAs for patches.
 - Segmented networks are essential for containing threats in ICS environments.
-

Case Study 2: Vulnerability Management in the Retail Sector

Scenario:

A multinational retailer suffered a data breach when attackers exploited an unpatched vulnerability in its Point-of-Sale (POS) systems. The breach exposed millions of customer credit card details, leading to financial losses, regulatory fines, and a decline in customer trust.

Challenges:

1. **Outdated Firmware:**
 - The POS systems used obsolete firmware with known vulnerabilities.
 - Firmware updates were delayed due to operational concerns over system downtime.
2. **Weak Network Security:**
 - Poorly configured Wi-Fi networks in stores enabled attackers to intercept traffic and access the POS systems.
3. **Decentralized Management:**
 - Each store operated independently, making it challenging to enforce uniform security policies.
4. **Compliance Gaps:**
 - The retailer failed to meet PCI DSS requirements for securing cardholder data.

Actions Taken:

1. **Centralized Vulnerability Management:**
 - Implemented **Qualys VMDR** to manage vulnerabilities across all store systems from a centralized dashboard.
 - Enabled automated scans and prioritized remediation based on risk levels.
2. **Firmware Updates:**
 - Partnered with the POS vendor to ensure firmware updates were delivered and deployed in a timely manner.
 - Established a regular patch management cycle, scheduling updates during non-operational hours.
3. **Network Security Overhaul:**
 - Upgraded store Wi-Fi to **WPA3 encryption** and implemented Virtual Private Networks (VPNs) for secure communications.
 - Deployed endpoint protection solutions on all POS devices.
4. **Employee Training:**
 - Conducted regular training sessions for store managers and employees to identify and report suspicious activity.
 - Educated staff on the importance of applying updates and securing devices.
5. **PCI DSS Compliance Program:**
 - Worked with external auditors to align POS systems and processes with PCI DSS standards.
 - Implemented regular penetration testing to assess compliance and identify potential vulnerabilities.

Outcomes:

1. **Data Protection:**
 - Customer data breaches were eliminated over the next year.
2. **Compliance:**
 - Achieved PCI DSS certification, avoiding future penalties and demonstrating strong data protection practices.
3. **Operational Efficiency:**
 - Centralized management reduced the average patch deployment time from three weeks to one week.
4. **Restored Trust:**
 - Proactively communicated security improvements to customers, leading to a 20% increase in positive customer sentiment.

Lessons Learned:

- Decentralized operations require strong governance and centralized vulnerability management.
 - Secure communications between devices are critical in retail environments where mobile and POS systems are widely used.
 - Compliance with standards like PCI DSS builds trust and ensures accountability.
-

Case Study 3: Vulnerability Management in the Government Sector

Scenario:

A government ministry managing a citizen services portal experienced a security breach when attackers exploited an unpatched vulnerability in a custom-built web application. Sensitive citizen data was exposed, causing public outcry and regulatory intervention.

Challenges:

1. **Legacy Applications:**
 - The citizen portal relied on outdated frameworks incompatible with modern security measures.
2. **Limited Application Testing:**
 - Static and dynamic application security testing (SAST and DAST) were not conducted regularly.
3. **Third-Party Risk:**
 - The portal was developed by a third-party vendor that did not disclose vulnerabilities.
4. **Regulatory Pressure:**
 - The breach violated NCA ECC requirements, subjecting the ministry to potential penalties.

Actions Taken:

1. **Application Security Overhaul:**
 - Conducted **SAST** and **DAST** using tools like **Fortify** and **Burp Suite** to identify vulnerabilities.
 - Partnered with the vendor to patch identified vulnerabilities and update the application framework.
2. **Web Application Firewall (WAF):**
 - Deployed an **F5 WAF** to block malicious traffic and prevent web-based attacks such as SQL injection and XSS.
3. **Third-Party Contract Review:**
 - Revised vendor agreements to mandate regular security updates and vulnerability disclosures.
4. **Public Communication Plan:**
 - Issued a public statement outlining security enhancements to rebuild citizen trust.
5. **Training and Awareness:**
 - Trained internal developers on secure coding practices and included vulnerability management in onboarding for new hires.

Outcomes:

1. **Enhanced Security:**
 - Identified and patched 90% of vulnerabilities within three months.
2. **Regulatory Compliance:**

- Fully aligned vulnerability management practices with NCA ECC requirements.
- 3. **Public Trust Restored:**
 - Proactive communication reassured citizens about the ministry's commitment to data security.
- 4. **Improved Application Lifecycles:**
 - Integrated regular security testing into the development lifecycle to ensure ongoing protection.

Lessons Learned:

- Custom applications require regular and thorough security testing.
- Clear contracts with vendors ensure accountability for application vulnerabilities.
- Proactive communication following a breach can mitigate reputational damage.

2.11 Penetration Testing:

Definition: Penetration Testing involves simulating cyber-attacks to assess and evaluate an organization's cybersecurity defense capabilities. It focuses on identifying unknown vulnerabilities within the technical infrastructure, such as internet-facing services, websites, web applications, mobile apps, email systems, and remote access points. The goal is to uncover weaknesses that could potentially lead to a cyber breach and ensure robust defenses against both internal and external threats[3], [4].

Objective: To assess and evaluate the efficiency of the organization's cybersecurity defense capabilities through simulated cyber-attacks, aiming to discover unknown weaknesses within the technical infrastructure that may lead to a cyber breach.

Controls Matrix:

Below is a summary matrix detailing relevant penetration testing controls based on NCA Controls, SAMA CSF, CST CRF, and CMA Cybersecurity Guidelines:

Regulation	Main Controls	Control References
NCA ECC	4	2-11-1, 2-11-2, 2-11-3 (2 sub-controls), 2-11-4
SAMA CSF	—	—
CST CRF	5	4.16.1, 4.16.2, 4.16.3, 4.16.4, 4.16.5
CMA CSG	—	—
NCA CCCC	2	2-10-1 (2 sub-controls), 2-10-2
NCA CCC CST	—	—
NCA CCC CSP	1	2-10-P-1 (1 sub-control)
NCA TCC	2	2-10-1 (1 sub-control), 2-10-2
NCA DCC	—	—
NCA OSMACC	—	—
NCA OTCC	2	2-10-1 (4 sub-controls), 2-10-2

Penetration Testing Controls:

National Cybersecurity Authority - Essential Cybersecurity Controls ECC					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
2-11-1		Cybersecurity requirements for penetration testing exercises must be defined, documented and approved.	Penetration Testing Policy Template.	Develop and document cybersecurity policy for penetration testing in the organization, including the following: Determine the scope of the penetration test in the organization. Define periodic penetration testing requirements. Define penetration testing requirements using effective tools and methods. Define the requirements for the team responsible for performing the	- Cybersecurity policy that covers the requirements of penetration testing management (e.g., electronic copy or official hard copy). - Formal approval by the head of the organization or his/her deputy on the policy (e.g., via the organization's official e-mail, paper or electronic signature).

				penetration testing. • Support the organization's policy by the Executive Management. This must be done through the approval of the organization head or his/her deputy.	
2-11-2		The cybersecurity requirements for penetration testing processes must be implemented.	• Implement all cybersecurity requirements to the organization's approved penetration testing. It is also recommended that the penetration testing cover the following, but not limited to: Perform penetration testing periodically. Determine the scope of the penetration testing in the organization.	• Action plan for penetration testing. • Penetration Testing Reports.	
2-11-3 The cybersecurity requirements for penetration testing processes must include at least the following:	2-11-3-1	Scope of penetration tests which must cover Internet-facing services and its technical components including infrastructure, websites, web applications, mobile apps, email and remote access.	• Define and document the requirements of this ECC in the cybersecurity requirements document and approve them by the representative. • Identify and document all services provided online at the organization. • Identify all technical components that support these external services, including: Websites and web applications Smartphones and tablets applications API This includes items on Apple Store, Google Play Store and other app stores. This also includes phone applications that are not available on stores, which are specific to the	•Cybersecurity policy that covers the penetration testing of the following assets: all services provided externally (online) and its technology components including infrastructure, websites, web applications, smartphone and tablet applications, email and remote access. • Formal approval by the head of the organization or his/her deputy on such document (e.g., via the organization's official e-mail, paper or electronic	

			organization. Servers used for external services (e.g., web servers) Servers used for remote access services Servers used by the email service Network devices used to provide external services. • Develop and implement an action plan for penetration testing, including the above.	signature). • Action plan for penetration testing. • Penetration Testing Reports.
2-11-3	2-11-3-2	Conducting penetration tests periodically.	Define and document the requirements of this ECC in the cybersecurity requirements document and approve them by the representative. Develop procedures for penetration testing. Develop and implement an action plan for the penetration testing showing the annual schedule to be followed for penetration testing on the relevant information and technology assets.	Cybersecurity policy that covers penetration testing on a regular basis. Formal approval by the head of the organization or his/her deputy on such document (e.g., via the organization's official e-mail, paper or electronic signature). Action plan for penetration testing. Penetration Testing Reports.
2-11-4	Cybersecurity requirements for penetration testing processes must be reviewed periodically.		Review the cybersecurity requirements of penetration testing by conducting a periodic assessment (according to a documented and approved plan for review, and based on a planned interval ("e.g., quarterly") to implement identity and access management requirements by the Cybersecurity function and in cooperation with relevant departments (such as IT Department). Conduct application review through traditional channels (e.g., email) or automated channels using a compliance management system. The organization may develop a review plan explaining the implementation review schedule for penetration	Results of penetration testing cybersecurity requirements implementation review in the organization. A document that defines the cybersecurity requirements implementation review cycle for penetration testing in the organization (Compliance Assessment Schedule). Compliance assessment report that outlines the assessment of the implementation of cybersecurity requirements for the organization's penetration testing. An approved document that sets the policy's review

		testing. Review and update cybersecurity requirements for penetration testing in the organization periodically according to a documented and approved plan for review and based on a planned interval or in the event of changes in relevant laws and regulations. Document the review and changes to the cybersecurity requirements for penetration testing in the organization and approve them by the head of the organization or his/her deputy.	schedule. Policy indicating that it has been reviewed and updated, and that changes have been documented and approved by the head of the organization or his/her deputy. Formal approval by the head of the organization or his/her deputy on the updated policy (e.g., via the organization's official e-mail, paper or electronic signature).		
National Cybersecurity Authority – Critical Systems Cybersecurity Controls CSCC					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
2-10-1 In addition to the sub-controls under Control 2-11-3 in the Basic Cyber Security Controls, the cyber security requirements for penetration testing of critical systems should cover, at a minimum; the following:	2-10-1-1	The scope of penetration testing work, to include all technical components of critical systems, and all services provided internally and externally.	Penetration Testing Policy Template. Penetration Testing Standard Template.	Ensure that penetration testing activities include all critical systems and all their technical components, for example: Infrastructure websites.	List the scope of work for penetration testing activities.
	2-10-1-2	Penetration testing done by a qualified team.	Penetration Testing Policy Template. Penetration Testing Standard Template.	Attracting qualified human resources to perform penetration tests on critical systems, and among these qualifications:	Penetration testing team resume for critical systems.

				Professional certifications in penetration testing (such as CEH, GPEN, OSCP, eCPPT, etc.) Practical experience in penetration testing Saudi citizen Hold an academic degree in a related field Critical vulnerability finder within vulnerability bounty programs.	
2-10-2	Referring to officer 2-11-3-2 in Basic Controls for Cyber Security, penetration testing must be done on critical systems, every six months; at least.	Penetration Testing Policy Template. Penetration Testing Standard Template.	Ensure that the penetration testing plan includes conducting penetration tests every six months (at least) on all critical systems and their technical components, which include: Applications Devices and servers Databases Network devices such as routers, switches, and firewalls Work to address the observations discovered during the penetration test.	Penetration testing work plan for critical systems. Periodic reports of penetration tests on critical systems. A guide explaining the follow-up treatment of discovered observations.	

National Cybersecurity Authority - Telework Cybersecurity Controls TCC					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
2-10-1 In addition to the sub-controls within control 2-11-3 in the ECC, cybersecurity requirements for penetration testing related to telework systems shall include at least the following:	2-10-1-1	Scope of penetration tests must cover all of the telework systems' technical components.	Penetration Testing Policy Template. Penetration Testing Standard Template.	Work on defining the requirements for this control, document them in the cybersecurity requirements document, and have them approved by the authority holder. Identify all technical components that support telework services. Define the appropriate pre-requisites and stakeholder approvals required before performing penetration testing in telework systems and its technical components. Document the penetration testing	Work on defining the requirements for this control, document them cybersecurity requirements document, and have them approved by the authority holder. Documented scope for the penetration testing of all telework systems and technical components.

				scope, and level allowed for penetration testers by the organization to ensure no impact on business operations.	
2-10-2	With reference to the ECC subcontrol 2-11-3-2, penetration tests must be conducted on telework systems at least once every year.	Penetration Testing Policy Template. Penetration Testing Standard Template.	Work on defining the requirements for this control, document them in the cybersecurity requirements document, and have them approved by the authority holder. Based on the penetration scope, document the pre-requisites and required stakeholder approvals before performing penetration testing on telework system and technical components. Get plan approval to	Work on defining the requirements for this control, document them in the cybersecurity requirements document, and have them approved by the authority holder. Documented and approved plan to conduct periodic penetration testing of telework systems and technical components at least once every year. Detailed Penetration testing report of telework systems.	

			conduct penetration testing, and inform relevant stakeholders prior to testing to ensure there is no impact on operational processes. Ensure planned penetration testing is conducted at least once a year on teleworking systems and technical components. Prepare penetration testing report for audit, compliance and remediation purpose. Prepare a plan to address the gaps discovered in telework systems and follow up on it periodically.	
National Cybersecurity Authority – Operational Technology Cybersecurity Controls OTCC				

Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
2-10-1 In addition to the subcontrols in the ECC control 2-11-3, cybersecurity requirements for penetration testing in OT/ICS must cover, at a minimum, the following:	2-10-1-1	With reference to the ECC subcontrol 2-11-3-1, scope and activities of penetration testing must be defined to ensure the coverage of OT/ICS environment and networks connected to the operational network by qualified team.	Template for Cybersecurity Operational Technology Policy Template for OT/ICS Security Standard Template for Penetration Testing Policy Template for Penetration Testing Standard	Define the scope of penetration testing activities. Ensure that the penetration testing activities are conducted by a qualified team.	A proof that penetration testing is conducted for the OT/ICS environment and networks connected to the operational network and that it is conducted by a qualified team.
	2-10-1-2	With reference to the ECC subcontrol 2-11-3-2, penetration testing must only be conducted with limited or no impact on the production environment, or on an identical separate environment.		Conduct penetration testing with limited or no impact on the production environment, or perform the testing in a separate but identical environment (e.g., testing or training environments).	A proof that penetration testing is conducted with limited or no impact on the production environment, or that it's performed in a separate but identical environment (e.g., testing or training environments).
	2-10-1-3	With reference to the ECC subcontrol 2-11-3-		Ensure that the penetration testing	A proof that penetration testing for OT/ICS systems is conducted periodically in

		2, penetration testing for OT/ICS systems must be conducted periodically.		for OT/ICS systems are conducted periodically in accordance to the facility level stated in (OTCC-1:2022).	accordance to the facility level stated in (OTCC-1:2022).
	2-10-1-4	Alternative testing methods (such as passive testing mechanisms) must be defined and Implemented to collect relevant information when a potential impact to operational production environment may occur.		List OT/ICS systems or assets requiring alternative testing methods. Define, document, and implement alternative testing methods (such as passive testing mechanisms) and that is when a potential impact on the operational production environment may occur. Implement a proper alternative testing methods (such as Passive Testing) for a specified OT/ICS system or asset in line with the approved	Periodically prepared alternative testing methods reports.

				procedures. Verify and ensure that the alternative tests allow for gathering information about assets related to OT/ICS.	
2-10-2	With reference to the ECC control 2-11-4, the cybersecurity requirements for penetration testing in OT/ICS environment must be reviewed, and their implementation effectiveness is measured and evaluated periodically.	Review the cybersecurity requirements for penetration testing on OT/ICS periodically based on a documented and approved review plan and on a defined frequency (e.g., conduct a review annually). Develop key performance indicators (KPIs) for each control within the related policy or procedure to ensure the implementation effectiveness is measured and evaluated periodically based on a defined frequency (e.g., conduct a review annually).	A proof that shows the periodic review of cybersecurity requirements for penetration testing on OT/ICS. A proof that shows the key performance indicators (KPIs) for each control within the related policy or procedure to ensure the implementation effectiveness is measured and evaluated periodically (based on a defined frequency).		
National Cybersecurity Authority - Cloud Cybersecurity Controls CCC					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
2-10-P-1 In addition to sub controls in the ECC control 2-11-3, the CSP shall cover the following additional sub	2-10-P-1-1	Scope of penetration tests must cover Cloud Technology Stack and must be conducted at least once every six months.	Template for Penetration Testing Policy. Template for Penetration Testing Standard.	• Identify Cloud Technology Stack components. • Periodically (every six months) conduct penetration tests of all Cloud	Penetration tests conducted to the entire Cloud Technology Stack.

controls for cybersecurity requirements for penetration testing, as a minimum:				Technology Stack components. • Verify completeness of scope for penetration tests of Cloud Technology Stack.	
CST CRF					
Control reference number	Control clauses	Control implementation guidelines		Expected deliverables	
4.16.1 CL2	Define and document [Requirements for Penetration Testing] which consider the following: • Purpose of the penetration tests and overall objectives • Defining the frequency of the penetration tests	This control emphasizes the need for clearly defined and documented requirements for your penetration testing activities. These requirements should outline the purpose and objectives of the penetration tests, such as identifying vulnerabilities, assessing security controls, or meeting compliance requirements. They should also specify the frequency of penetration testing, which could be based on factors like risk assessments, regulatory requirements, or industry best practices. Define and document comprehensive requirements for penetration testing, including the purpose and objectives of the tests and the frequency with which they should be conducted.		Documented penetration testing requirements.	

4.16.2 CL2	Define a [Penetration Testing] process consisting of the scope and frequency (e.g., at least once quarterly on the critical information assets) of the penetration tests using standard methodologies to identify unknown vulnerabilities (e.g., grey box testing, white box testing).	This control focuses on establishing a formal penetration testing process. This process should define the scope of the penetration tests, including the systems and assets to be tested. It should also specify the frequency of penetration testing, which could be, for example, at least once a quarter for critical information assets. Additionally, the penetration testing process should utilize standard methodologies such as grey box testing (where testers have partial knowledge of the system) or white box testing (where testers have full knowledge of the system) to effectively identify vulnerabilities. Define and implement a formal penetration testing process that includes the scope of the tests, the frequency of testing, and the use of standard penetration testing methodologies.	Documented penetration testing process.
4.16.3 CL2	Depending on the penetration test methodology used, use the [Vulnerabilities Report] as an input to guide the penetration tests.	This control highlights the importance of using vulnerability assessment reports to inform and guide penetration testing efforts. Depending on the penetration testing methodology used, the vulnerability report can provide valuable information about known vulnerabilities, which can help testers focus their efforts and prioritize their testing activities. Utilize vulnerability assessment reports as input to guide penetration testing activities. The specific way in which the vulnerability report is used will depend on the chosen penetration testing methodology.	
4.16.4 CL2	Report the [Penetration Test Report] to the respective departments to trigger remediation	This control stresses the importance of clear and effective reporting following penetration testing. The penetration test report should be communicated to the relevant departments or	Penetration test reports. Remediation plans based on penetration test findings.

	actions when applicable [Patch Management].	stakeholders within the organization to initiate remediation actions, such as patching vulnerabilities or implementing other security controls, as needed. Develop a process for reporting penetration test findings to the appropriate departments or stakeholders within the organization to facilitate timely remediation actions.	
4.16.5 CL3	Continuously measure, review and optimize the [Requirements for Penetration Testing] as well as the effectiveness of the process.	This control emphasizes the need for ongoing monitoring and improvement of the penetration testing program. Organizations should continuously measure and review the effectiveness of their penetration testing activities and make adjustments as needed to ensure they remain aligned with their security objectives and risk tolerance. Implement a process for regularly measuring, reviewing, and optimizing the penetration testing requirements and the overall effectiveness of the penetration testing process.	Reports on the measurement and review of penetration testing requirements and process effectiveness. Documentation of optimization efforts.

Risk Considerations in Penetration Testing

- **Incomplete Testing Scope:**
 - Excluding APIs, cloud environments, or third-party integrations from penetration testing leaves vulnerabilities unaddressed.
 - **Unqualified Testers:**
 - Inexperienced testers may overlook critical issues or produce inaccurate assessments.
 - **Disruption to Operations:**
 - Testing activities could unintentionally cause downtime or disrupt services.
 - **False Positives/Negatives:**
 - Incorrectly flagged vulnerabilities waste resources, while missed issues leave systems at risk.
 - **Sensitive Data Exposure:**
 - Collected data (e.g., credentials or configurations) during testing must be securely managed to avoid leaks.
 - **Vendor Dependency:**
 - Overreliance on external testing providers without clear SLAs may lead to incomplete testing.
 - **Regulatory Non-Compliance:**
 - Not conducting penetration testing as per regulatory frameworks can result in penalties.
 - **Delayed Testing:**
 - Infrequent testing increases the risk of exploitation before vulnerabilities are identified.
 - **Improper Reporting:**
 - Reports lacking actionable insights may hinder effective remediation.
 - **Lack of Remediation Validation:**
 - Without follow-up tests, vulnerabilities might remain unresolved.
-

Examples of Technologies for Effective Penetration Testing

- **Web Application Testing**
 - Tools: *OWASP ZAP, Burp Suite Community Edition, w3af.*
- **Network Testing**
 - Tools: *Nmap, Metasploit Framework (Community Edition), Netcat.*
- **Cloud Security Testing**
 - Tools: *ScoutSuite, Prowler* (both open-source, focused on AWS and multi-cloud).

- **Mobile Application Testing**
 - Tools: *MobSF (Mobile Security Framework)*, *Drozer*.
 - **Password Cracking**
 - Tools: *Hashcat*, *John the Ripper*, *Hydra*.
 - **Social Engineering Simulators**
 - Tools: *GoPhish* (open-source phishing simulation platform).
 - *Note*: KnowBe4 and PhishMe are commercial. Use GoPhish as an open-source alternative.
 - **Wireless Network Testing**
 - Tools: *Aircrack-ng*, *Kismet*, *Wireshark* (for packet capture/analysis).
 - **Reporting Platforms**
 - Tools: *Dradis CE (Community Edition)*, *Faraday Community Edition*.
 - *Note*: PlexTrac is commercial. Use Dradis or Faraday for open-source alternatives.
-

Examples of KPIs for Penetration Testing

- **Number of Critical Vulnerabilities Identified:**
 - Measure vulnerabilities in critical systems and prioritize mitigation.
 - **Remediation Completion Rate:**
 - Percentage of identified vulnerabilities resolved within SLA.
 - **Testing Coverage Rate:**
 - Percentage of organizational assets included in penetration testing.
 - **Mean Time to Resolve (MTTR):**
 - Average time taken to remediate identified vulnerabilities.
 - **False Positive Rate:**
 - Proportion of incorrectly flagged vulnerabilities.
 - **Compliance Rate:**
 - Percentage of tests conducted in alignment with regulatory requirements.
 - **Post-Remediation Validation Rate:**
 - Percentage of remediated vulnerabilities verified through follow-up tests.
-

Samples of Auditor's Checklist for Penetration Testing

1. Are penetration testing policies documented, approved, and reviewed periodically?
2. Is the scope of testing comprehensive and aligned with critical assets and systems?
3. Are internal, external, and third-party systems included in the testing scope?
4. Are penetration testing tools configured to reflect current threats?
5. Are testing results mapped to compliance requirements?
6. Is there a defined SLA for addressing vulnerabilities?
7. Are third-party testers qualified and aligned with security standards?

8. Are results of penetration tests integrated into the organization's risk management program?
9. Are penetration testing reports securely stored and shared with authorized personnel?
10. Is follow-up testing conducted to validate remediation actions?

Samples of Audit Scenarios for Penetration Testing

Scenario 1: Internal Penetration Testing

- **Objective:** Assess vulnerabilities in internal systems.
- **Steps:**
 1. Review the scope of internal penetration testing.
 2. Validate identified vulnerabilities and remediation actions.
 3. Confirm follow-up testing was conducted.
- **Key Questions:**
 - Are all critical internal systems included?
 - Were vulnerabilities addressed within SLA timelines?

Scenario 2: Social Engineering Testing

- **Objective:** Evaluate employee awareness of social engineering threats.
- **Steps:**
 1. Review phishing simulation reports.
 2. Assess training programs and user response times.
- **Key Questions:**
 - How many employees fell victim to phishing simulations?
 - Are training programs effective in reducing susceptibility?

Scenario 3: Web Application Testing

- **Objective:** Assess the security posture of web applications.
- **Steps:**
 1. Review penetration testing reports for web applications.
 2. Validate vulnerabilities such as SQL injection or XSS.
 3. Verify remediation efforts and conduct follow-up tests.
- **Key Questions:**
 - Were all web applications tested?

- Are remediation efforts validated effectively?

Case Study 1: Penetration Testing in Banking

Scenario:

A leading bank faced a targeted cyberattack on its online banking platform. Attackers exploited an untested API vulnerability, exposing sensitive customer financial data and jeopardizing regulatory compliance under SAMA cybersecurity framework CSF. This incident also raised concerns about the bank's preparedness against evolving cyber threats.

Challenges:

1. **Inadequate API Testing:**
 - APIs facilitating interbank transactions and third-party integrations were excluded from penetration testing scope.
 - Legacy APIs lacked secure authentication mechanisms, making them a prime target for attackers.
 2. **Delayed Patch Management:**
 - Previously identified vulnerabilities remained unresolved due to operational constraints and insufficient prioritization of remediation.
 3. **Lack of Real-Time Monitoring:**
 - Absence of integration between penetration testing reports and the bank's Security Information and Event Management (SIEM) system delayed detection and response.
 4. **Compliance Pressure:**
 - Regulatory mandates required stringent controls and frequent testing for all internet-facing systems, which were partially implemented.
-

Actions Taken:

1. **Enhanced Testing Scope:**
 - Expanded penetration testing to include APIs using **Burp Suite Pro**, focusing on authentication, authorization, and input validation vulnerabilities.
2. **Automated Vulnerability Management:**
 - Deployed **Qualys VMDR** to automate vulnerability tracking, patch prioritization, and integration with existing SIEM (Splunk).
3. **Implementation of Zero Trust Architecture:**
 - Introduced a zero-trust model for APIs, requiring all internal and external API calls to undergo token-based authentication and multi-factor verification.
4. **Collaboration with Regulators:**
 - Partnered with a certified cybersecurity consulting firm to align remediation actions with compliance mandates.
5. **Frequent Testing Schedule:**
 - Instituted a quarterly penetration testing cycle for internet-facing systems, APIs, and customer-facing platforms.

Outcomes:

1. **Risk Reduction:**
 - Identified and remediated 15 critical API vulnerabilities within 10 days, reducing the attack surface by 60%.
2. **Operational Efficiency:**
 - Automated vulnerability management reduced mean time to resolve (MTTR) vulnerabilities from 45 to 15 days.
3. **Compliance Achieved:**
 - Passed annual cybersecurity audits with zero penalties or findings.
4. **Customer Trust Restored:**
 - Proactive communication of improved security measures led to a 20% increase in online banking adoption.

Lessons Learned:

- API security should be a core component of penetration testing in financial institutions.
 - Automation and integration between testing tools and SIEM improve response times and operational visibility.
 - Frequent testing cycles help maintain compliance and build stakeholder confidence.
-

Case Study 2: Penetration Testing in Healthcare

Scenario:

A healthcare provider responsible for managing patient records and medical IoT devices suffered a ransomware attack. Attackers exploited vulnerabilities in untested medical devices, encrypting sensitive patient data and disrupting critical operations. The breach also raised compliance risks under healthcare privacy regulations.

Challenges:

1. **Untested Medical IoT Devices:**

- Medical devices such as infusion pumps and imaging machines were excluded from testing due to concerns about operational downtime.
- Lack of firmware updates and unsupported devices left critical vulnerabilities unaddressed.

2. **Weak Network Segmentation:**

- The absence of segmentation between IoT devices and core IT systems enabled attackers to spread ransomware laterally.

3. **Limited Employee Awareness:**

- Healthcare staff were unaware of cybersecurity best practices, making them susceptible to phishing attempts that initiated the ransomware attack.

4. **Regulatory Non-Compliance:**

- Specific requirements for critical infrastructure were not implemented, exposing the organization to potential penalties.
-

Actions Taken:

1. **Comprehensive Penetration Testing:**

- Included IoT devices in penetration testing using **Tenable OT** and **Qualys**, focusing on device configuration and firmware vulnerabilities.

2. **Network Segmentation:**

- Isolated medical IoT devices from core IT systems using VLANs and industrial firewalls, reducing the risk of lateral attacks.

3. **Incident Response Plan (IRP) Overhaul:**

- Conducted ransomware attack simulations and enhanced the organization's IRP to include specific steps for recovering encrypted medical data.

4. **Staff Training:**

- Launched a cybersecurity awareness program targeting phishing, social engineering, and IoT device security.

5. **Collaboration with Vendors:**

- Partnered with medical device manufacturers to ensure timely firmware updates and vulnerability disclosures.

Outcomes:

1. **Reduced Ransomware Incidents:**
 - Implementing proactive testing and segmentation reduced ransomware-related incidents by 70% in one year.
2. **Improved Compliance:**
 - Achieved full compliance with critical infrastructure cybersecurity standards.
3. **Operational Continuity:**
 - Enabled uninterrupted healthcare services by isolating critical systems during remediation efforts.
4. **Enhanced Security Awareness:**
 - Trained over 90% of staff in identifying and mitigating phishing attacks.

Lessons Learned:

- Penetration testing for IoT and medical devices is essential for securing critical healthcare systems.
 - Network segmentation and proactive vulnerability management are key to mitigating ransomware risks.
 - Staff awareness and training significantly reduce the success rate of social engineering attacks.
-

Case Study 3: Penetration Testing in Government Services

Scenario:

A government ministry experienced a cyberattack on its citizen services portal. Attackers exploited SQL injection vulnerabilities, gaining unauthorized access to sensitive citizen data. The incident led to public outcry and regulatory scrutiny under national privacy and data protection laws.

Challenges:

1. **Untested Custom Applications:**

- The citizen portal was developed using custom code, which was excluded from regular penetration testing.
- Developers lacked training in secure coding practices, leading to poorly sanitized inputs.

2. **Absence of Real-Time Threat Detection:**

- The ministry lacked a Web Application Firewall (WAF) to detect and block SQL injection attempts.

3. **Vendor Accountability:**

- The third-party vendor managing the portal did not disclose existing vulnerabilities or conduct regular security assessments.

4. **Reputational Damage:**

- Public trust in government digital services was severely impacted, threatening adoption of new initiatives.
-

Actions Taken:

1. **Application Security Testing:**

- Conducted **Dynamic Application Security Testing (DAST)** using **OWASP ZAP** to simulate attacks and identify input validation vulnerabilities.
- Implemented **Static Application Security Testing (SAST)** with **Fortify** to analyze source code.

2. **WAF Deployment:**

- Deployed an **F5 Web Application Firewall (WAF)** to prevent real-time SQL injection and other application-level attacks.

3. **Vendor Agreements Overhaul:**

- Revised contracts to mandate regular penetration testing, vulnerability disclosures, and compliance with national cybersecurity standards.

4. **Public Communication:**

- Issued public statements assuring citizens of enhanced security measures, including transparency about remediation steps.

5. **Secure Development Lifecycle (SDLC):**

- Introduced secure coding practices and mandatory developer training to prevent future vulnerabilities in custom-built applications.
-

Outcomes:

- 1. Vulnerability Remediation:**
 - Resolved 95% of critical application vulnerabilities within three months.
- 2. Compliance Alignment:**
 - Achieved full compliance with cybersecurity and privacy protection standards, avoiding penalties.
- 3. Restored Public Trust:**
 - Public satisfaction surveys showed a 30% increase in trust following the ministry's security enhancements.
- 4. Sustainable Development Practices:**
 - Secure development processes were integrated into the SDLC, reducing future vulnerabilities by 40%.

Lessons Learned:

- Custom applications require dedicated penetration testing cycles to identify and mitigate unique risks.
- Proactive public communication and transparency help rebuild trust after breaches.
- Partnering with vendors to align on compliance and security standards reduces long-term risks.

2.12 Cybersecurity Event Logs and Monitoring Management:

Definition: Cybersecurity Event Logs and Monitoring Management focuses on the structured collection, storage, and analysis of system logs to support security and operational efficiency. This process ensures that critical cybersecurity events related to system activities, access controls, and infrastructure performance are recorded and maintained for compliance, auditing, and forensic purposes [5], [6].

Objective: To establish a reliable framework for the collection, retention, and review of cybersecurity event logs to support compliance requirements, internal audits, and system performance analysis, ensuring adherence to organizational policies and regulatory obligations.

Controls Matrix:

Below is a summary matrix detailing relevant Cybersecurity Event Logs and Monitoring Management controls based on NCA Controls, SAMA CSF, CST CRF, and CMA Cybersecurity Guidelines:

Regulation	Main Controls	Control References
NCA ECC	4	2-12-1, 2-12-2, 2-12-3 (5 sub-controls), 2-12-4
SAMA CSF	3	3.3.14-1, 3.3.14-2, 3.3.14-3, 3.3.14-4 (12 sub-controls)
CST CRF	9	4.6.1, 4.6.2, 4.6.3, 4.6.4, 4.6.5, 4.6.6, 4.6.7, 4.6.8, 4.6.9
CMA CSG	3	4.3.8-1, 4.3.8-2, 4.3.8-3, 4.3.8-4, 4.3.8-5, 4.3.8-6, 4.3.8-7 (12 sub-controls), 4.3.8-8 (4 sub-controls)
NCA CCCC	2	2-11-1 (5 sub-controls), 2-11-2
NCA CCC CST	1	2-11-T-1 (2 sub-controls)
NCA CCC CSP	1	2-11-P-1 (8 sub-controls)
NCA TCC	2	2-11-1 (4 sub-controls), 2-11-2
NCA DCC	—	—
NCA OSMACC	1	2-6-1 (4 sub-controls)
NCA OTCC	2	2-11-1 (10 sub-controls), 2-11-2

Cybersecurity Event Logs and Monitoring Management Controls:

National Cybersecurity Authority - Essential Cybersecurity Controls ECC					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
2-12-1		Cybersecurity requirements for event logs and monitoring management must be defined, documented and approved.	Cybersecurity Event Logs and Monitoring Management Policy Template.	• Develop and document cybersecurity policy for event logs and cybersecurity monitoring management in the organization, including the following: Define the scope of information assets to which event logs must be activated. Activate cybersecurity event logs on critical information assets in the organization. Activate cybersecurity event logs of privileged access accounts on critical information assets and events of remote access in the organization. Define technologies to collect activated cybersecurity event logs. Continuous monitor cybersecurity event logs. Define	• Cybersecurity policy that covers the requirements of Event Logs and Monitoring Management (e.g., electronic copy or official hard copy). • Formal approval by the head of the organization or his/her deputy on such document (e.g., via the organization's official e-mail, paper or electronic signature).

				retention period for cybersecurity event logs (not less than 12 months). • Support the organization's policy by the Executive Management. This must be done through the approval of the organization head or his/her deputy.	
2-12-2		The cybersecurity requirements for event logs and monitoring management must be implemented.	Implement cybersecurity requirements to Information System and Processing Facilities Protection, including, but not limited to, the following: -Define the scope of information assets to which event logs are activated, and the organization's information and technology asset register and the assets mentioned in the risk register can be used to determine the scope. -Activate cybersecurity event logs on critical information assets in the organization. -Activate cybersecurity event logs of privileged access accounts on critical information assets and events of remote access in the organization. -Define technologies to collect activated cybersecurity event logs. -Define a team to continuously monitor cybersecurity event logs. -Define the retention period for cybersecurity event logs (not less than 12 months) and identify this item	A visit to the organization's Security Operations Center (if any), where the SIEM is viewed directly. A copy of the contract or agreement if the Security Operations Center or the monitoring are provided by a service provider. A report showing the connection of all the organization's devices and systems to the SIEM system. Organization's shift breakdown table covering the approved monitoring model.	

			in contracts and agreements if the Security Operations Center is at the service provider premises and ensure compliance with it.	
2-12-3 The cybersecurity requirements for event logs and monitoring management must include at least the following:	2-12-3-1	Activation of cybersecurity event logs on critical information assets.	- Define and document the requirements of this ECC in the cybersecurity requirements document and approve them by the representative. - Activate cybersecurity event logs on critical information assets in the organization, which may include, but are not limited to, the following: - Network Devices - Applications - Databases - Servers - Workstations (through the protection system). - Activate these records through the configuration of the previously mentioned devices and systems that can be controlled through their control panel. - Develop rules in SIEM system to enable the monitoring team to monitor the activated records of critical information assets (after linking them).	- A document (such as approved policy or procedure) indicating the identification and documentation of the requirements related to this control. - A screenshot or a direct example from the control panel of the mentioned systems that indicates the activation of event logs. - Screenshot or a direct example showing the activation of logs through SIEM.
	2-12-3-2	Activation of cybersecurity event logs on remote access and privileged user accounts.	- Define and document the requirements of this ECC in the cybersecurity requirements document and approve them by the representative. - Activate cybersecurity event logs of privileged access accounts (e.g., database and systems management). -Information assets, so that all changes made through them are recorded and archived.	- A document (such as approved policy or procedure) indicating the identification and documentation of the requirements related to this control. - Screenshot or a direct example showing the activation of logs for some privileged

			-Remote access events, as these processes must only be for the necessary cases and any remote access must be recorded to follow up on the changes made. • Develop a number of rules in the SIEM system so that the special team can monitor the activated logs of privileged access accounts (after linking them).	access accounts on the access management system. • Screenshot or a direct example showing the activation of logs through SIEM. • Screenshot or a direct example showing the activation of logs for some privileged access accounts on the remote access system. • Screenshot or a direct example showing the activation of logs through SIEM.
	2-12-3-3	Identification of required technologies (e.g., SIEM) for cybersecurity event logs collection.	• Define and document the requirements of this ECC in the cybersecurity requirements document and approve them by the representative. • Provide the necessary technologies (SIEM) to collect cybersecurity event logs. • Define the scope of devices, systems, and applications that are linked to SIEM based on their sensitivity, including but not limited to: -Workstations (through the protection system). - Applications -Databases -Network Devices -Servers • Connect all the organization's critical devices and systems, including those previously mentioned to the Security Information and Event Management System (SIEM).	• A document (such as approved policy or procedure) indicating the identification and documentation of the requirements related to this control. • A visit to the organization's Security Operations Center (if any), where the SIEM is viewed directly. • A report showing the connection of all the organization's devices and systems with the SIEM system (including but not limited to a list in Excel or electronic version) and highlighting the

			• Review the periodic linkage of the organization's devices and systems to ensure that all the aforementioned scope and any systems and devices found in the organizations are covered.	addition of any new devices or systems in the organization. • A contract explaining the above if the Security Operations Center is by a service provider.
	2-12-3-4	Continuous monitoring of cybersecurity events.	• Define and document the requirements of this ECC in the cybersecurity requirements document and approve them by the representative. • Identify a team for continuous monitoring of cybersecurity event logs or SIEM and approve the 24/7 monitoring model, so that monitoring is performed around the clock on all days of the week. • This team may consist of the organization's employees or by contracting an external monitoring service. • If an external service is contracted for monitoring, the access location of the organization's SIEM system in the Kingdom, taking into consideration that this system is also available within the Kingdom.	• A document (such as approved policy or procedure) indicating the identification and documentation of the requirements related to this control. • Organization's shift breakdown table covering the approved monitoring model. • A contract showing the monitoring model followed if the security operations center or the monitoring is provided by a service provider.
	2-12-3-5	Retention period for cybersecurity event logs (must be 12 months minimum).	• Define and document the requirements of this ECC in the cybersecurity requirements document and approve them by the representative. • Define the retention period for cybersecurity event logs to be at least 12 months through SIEM management configurations. • Provide enough space to keep these records. • Review stored records periodically to ensure that records that have not been kept for less than one year have not been replaced by the latest and increase the size of the area if this occurs.	• A document (such as approved policy or procedure) indicating the identification and documentation of the requirements related to this control. • A screenshot or direct directory from the SIEM system showing recordkeeping configuration for at least 12 months.

				• A sample of stored logs extracted from the SIEM system where records have been kept for at least 12 months.
2-12-4	The cybersecurity requirements for event logs and monitoring management must be reviewed periodically.	• Review the cybersecurity requirements of Cybersecurity Event Logs and Monitoring Management by conducting a periodic assessment (according to a documented and approved plan for review, and based on a planned interval "e.g., quarterly") to implement cybersecurity Event Logs and Monitoring Management requirements by the Cybersecurity function and in cooperation with relevant departments (such as security operations center, if any). • Conduct application review through traditional channels (e.g., email) or automated channels using a compliance management system. The organization may develop a review plan explaining the implementation review schedule for Cybersecurity Event Logs and Monitoring Management. • Review and update cybersecurity requirements for Cybersecurity Event Logs and Monitoring Management in the organization periodically according to a documented and approved plan for review and based on a planned interval or in the event of changes in relevant laws and regulations. • Document the review and changes to the cybersecurity requirements for Cybersecurity Event Logs and Monitoring Management in the	• Results of Cybersecurity Event Logs and Monitoring Management requirements implementation review in the organization. • A document that defines the cybersecurity requirements implementation review cycle for Cybersecurity Event Logs and Monitoring Management within the organization (Compliance Assessment Schedule). • Compliance assessment report that outlines the assessment of implementation of cybersecurity requirements for Cybersecurity Event Logs and Monitoring Management. • An approved document that sets the policy's review schedule. • Policy indicating that it has been reviewed and updated, and that changes have been documented and approved by	

		organization and approve them by the head of the organization or his/her deputy.	the head of the organization or his/her deputy. • Formal approval by the head of the organization or his/her deputy on the updated policy (e.g., via the organization's official e-mail, paper or electronic signature).		
National Cybersecurity Authority – Critical Systems Cybersecurity Controls CSCC					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
2-11-1 In addition to the subcontrols in ECC control 2-12-3, cybersecurity requirements for event logs and monitoring management for critical systems must include at least the following:	2-11-1-1	activate event logs for cybersecurity; on all technical components of critical systems.	-Cybersecurity Event Logs and Monitoring Management Policy Template -Cybersecurity Event Logs and Monitoring Management Standard Template	Work to provide monitoring systems compatible with the level of risk that collect and analyze the necessary event records, to collect records of cyber events for the technical assets of critical systems, and these records must contain the following information as a minimum: -Event Type. -Event originator (IIS, EDR, AV, Sysmon, security logs, etc...)	Event logs configuration for critical systems.

				-The system from which the event was executed (e.g. mailserver) -Date and Time Event. -The user or tool used to carry out the event. -The status or outcome of the event (Success vs. Failure). Activate and collect Event Logs, Audit Trail, and Login processes for all technical assets of critical systems. Create alerts for information and technology assets when predefined security monitoring events occur and/or indicator levels of potential malicious activity are met.	
	2-11-1-2	Enable alerts and event logs related to File Integrity Management and monitor them.	-Cybersecurity Event Logs and Monitoring Management Policy Template -Cybersecurity Event Logs and Monitoring	Enable alerts and event logs related to File Integrity Management and monitor them. Work to identify and install appropriate technologies	Appropriate techniques for managing and controlling file changes Configuration event logs to send file change alerts to critical systems for dedicated teams so

			Management Standard Template	to manage and monitor file changes. Work on activating alerts and recording events related to managing and monitoring file changes continuously. Work to protect cyber security event logs from alteration, disclosure, corruption, unauthorized access and unauthorized release for example: applying encryption and passwords to logs.	they can be assured they are constantly monitored and not tampered with.
	2-11-1-3	User Behavior Analytics UBA	-Cybersecurity Event Logs and Monitoring Management Policy Template -Cybersecurity Event Logs and Monitoring Management Standard Template	Work on providing specialized systems to monitor and analyze user behavior. Work with the concerned departments in the entity to determine the acceptable behavior of the user on critical systems in order to determine suspicious behavior. Work on developing security procedures	A list of all systems and configuration to monitor user behavior to ensure continuous analysis. A list of all the cases studied and analyzed. Security measures (Incident response playbook).

				(Incident response playbook) to be taken for cases that have been studied and identified with the concerned departments under the framework of suspicious behavior.	
	2-11-1-4	Monitor event logs of critical systems around the clock.	Cybersecurity Event Logs and Monitoring Management Policy Template Cybersecurity Event Logs and Monitoring Management Standard Template	Working on monitoring all cyber security events for critical systems around the clock (24/7/365) through specialized teams.	Monitor event logs of systems around the clock, for example: a table showing the times of specialized teams for monitoring around the clock.
	2-11-1-5	maintaining and protecting logs of cybersecurity incidents related to critical systems; Provided that it is comprehensive and includes full details (e.g.: time, date, identity, affected system).	Cybersecurity Event Logs and Monitoring Management Policy Template Cybersecurity Event Logs and Monitoring Management Standard Template	Work on developing procedures for maintaining records of events, and that they be comprehensive and include full details, with a minimum of the following: -Event log type: System, Security, Audit, Kernel, Authorization, Mail, etc. -The location and system of the event or record source.	Document procedures for maintaining event logs for critical systems.

				-The date and timestamp of the event log. affected system. -The identity of the user or tool used to perform the event. -Event status: successful, failed, active, inactive, allowed, denied, etc. -Event Severity Level: Such as Emergency, Alert, Critical, Error, Warning, Informational Notice, or Corrective Notice. -Event message: an actual message from the event. Work to restrict the archiving and deletion of event records and restrict it to authorized users only after the end of the time period specified for keeping the records, and allow the managers concerned with information and technical assets to carry out the process of archiving and deleting event records.	
--	--	--	--	---	--

2-11-2	Referring to Control 2-12-3-5 in Basic Controls for Cyber Security, the period of retention of event logs related to cyber security, on critical systems, must not be less than 18 months; According to the relevant legislative and regulatory requirements.	Cybersecurity Event Logs and Monitoring Management Policy Template Cybersecurity Event Logs and Monitoring Management Standard Template	Develop procedures for maintaining event records for a minimum of 18 months for critical assets or for a longer period.	Document event log retention procedures for critical systems.
--------	---	--	---	---

National Cybersecurity Authority – Organization Social Media Accounts Cybersecurity Controls OSMACC

Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
2-6-1 In addition to the subcontrols in ECC control 2-12-3, cybersecurity requirements for event logs and monitoring management for organization's	2-6-1-1	Activating all notifications and cybersecurity alerts for organization's social media accounts and cybersecurity events logs on related technology assets.	Template for Cybersecurity Event Logs and Monitoring Management Policy. Template for Cybersecurity Event Logs and Monitoring Management Standard.	Identify the technical assets and systems handling social media accounts. Implement the activation of all notifications and alerts for cybersecurity events related to the logging of events for the organization's social media accounts.	Sample of cybersecurity notifications and alerts activated for events on the assets used for handling organization's social media accounts.

social media accounts and technology assets related to them must include at least the following:	2-6-1-2	Following organization's social media accounts and monitoring them to ensure that they do not post any unauthorized content, or login any unauthorized access.	Template for Cybersecurity Event Logs and Monitoring Management Policy.	Identify, document, and approve procedures for monitoring social media accounts to ensure no unauthorized content is published or unauthorized access occurs. Review the content of the organization's social media accounts by monitoring their accounts and observing their content and activities. Verify that the content posted on social media accounts is authorized. Regularly review the procedures for monitoring social media accounts.	Documented procedures for monitoring social media accounts. Review content that is posted on the organization's social media accounts.
	2-6-1-3	Monitoring social media networks to ensure the organization is not being impersonated.	Template for Cybersecurity Event Logs and Monitoring Management Policy.	Monitoring the social media account networks within the organization to ensure that all accounts and channels are authorized, and that no account is impersonating the identity of the organization and posting	Review of social media network for impersonation of organization's social media plan. Sample of the service used for brand protection. Documented procedure for handling identity impersonation

				on its behalf. In the event of identity theft, appropriate action should be taken regarding the impersonated account, and the reporting mechanism for social media accounts should be implemented.	of the organization, including specifying the necessary actions to be taken. Plan for reporting in case of social media account impersonation.
	2-6-1-4	Automated monitoring for any change in the accounts pattern, indicators of compromise, or the publication of any unauthorized content or impersonation of the organization.	Template for Cybersecurity Event Logs and Monitoring Management Policy.	Review and verify the social media accounts of the organization for any change in account patterns, indicators of compromise or the publication of any unauthorized content or impersonation, through automated monitoring of the network.	Automated monitoring of organizations social media accounts for any anomaly in behavior.
National Cybersecurity Authority - Telework Cybersecurity Controls TCC					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
2-11-1 In addition to the subcontrols in the ECC control 2-12-3, cybersecurity requirements for event logs	2-11-1-1	Activating cybersecurity events logs on all technical components of telework systems.	Cybersecurity Event Logs and Monitoring Management Policy Template. Cybersecurity Event Logs and Monitoring	Work on defining the requirements for this control, document them in the cybersecurity requirements document, and have them approved by the authority holder.	Work on defining the requirements for this control, document them in the cybersecurity requirements document, and have them approved by the authority holder.

and monitoring management for telework systems must include at least the following:			Management Standard Template.	Based on the cyber security policies of the organization and ECC controls, a scope is defined for event logs and monitoring management of telework systems and its technical components. Activate and review logging of all cyber security events of telework environment.	Screenshot or a direct example showing the activation of logs through SIEM.
2-11-1	2-11-1-2	Monitoring and analyzing user behavior (UBA).	Cybersecurity Event Logs and Monitoring Management Policy Template. Cybersecurity Event Logs and Monitoring Management Standard Template.	Work on defining the requirements for this control, document them in the cybersecurity requirements document, and have them approved by the authority holder. Provide specialized systems to monitor and analyze user behaviour. Work with the relevant departments in the entity to determine acceptable user behaviour on telework systems in order to identify suspicious behaviour.	Work on defining the requirements for this control, document them in the cybersecurity requirements document, and have them approved by the authority holder. A list of systems and settings to monitor user behaviour to ensure continuous analysis. A list of all the cases that have been studied and analysed.

2-11-1	2-11-1-3	Monitoring telework systems events around the clock.	Cybersecurity Event Logs and Monitoring Management Policy Template. Cybersecurity Event Logs and Monitoring Management Standard Template.	Work on defining the requirements for this control, document them in the cybersecurity requirements document, and have them approved by the authority holder. Monitor all cybersecurity events for telework systems around the clock (24/7/365/365) through specialized teams.	Work on defining the requirements for this control, document them in the cybersecurity requirements document, and have them approved by the authority holder. Monitor event logs of technical assets and teleworking systems around the clock, including but not limited to: a table showing the allocated times around the clock for the specialized team.
2-11-1	2-11-1-4	Updating and implementing cybersecurity monitoring procedures around the clock, to include monitoring remote access operations, especially remote access from outside the Kingdom of Saudi Arabia, after checking their authenticity.	Cybersecurity Event Logs and Monitoring Management Policy Template. Cybersecurity Event Logs and Monitoring Management Standard Template.	Work on defining the requirements for this control, document them in the cybersecurity requirements document, and have them approved by the authority holder. Review and verify cybersecurity monitoring procedures, update them and implement controls to monitor them around the clock.	Work on defining the requirements for this control, document them in the cybersecurity requirements document, and have them approved by the authority holder. Cybersecurity monitoring procedures document to include monitoring remote access operations, especially remote access operations from outside the Kingdom, and verifying their authenticity.

				Event logs may include but not limited to: remote access operations within or from outside KSA after checking their authenticity, application event logs, system event logs, antivirus event logs, incident logs and others. Work to save all activities and records of remote login operations and ensure that they are sent to the operations and monitoring center to ensure that they are constantly monitored by specialized teams by linking login logs with monitoring systems, for example: the (SEIM) system.	
2-11-2	With reference to the ECC sub-control 2-12-3-5, retention period of cybersecurity's telework systems event logs must be 12 months minimum, in accordance with relevant legislative and regulatory requirements.	Work on defining the requirements for this control, document them in the cybersecurity requirements document, and have them approved by the authority holder.	Identify and develop a mechanism to store all cybersecurity event logs for teleworking systems and technical components for a retention period of at	Work on defining the requirements for this control, document them in the cybersecurity requirements document, and have them approved by the authority holder.	

		least 12 months or more, in accordance with relevant legislative and regulatory requirements. Identify, document, and approve security controls for archiving or deleting stored records in accordance with the designated organization's retention and cybersecurity policy for telework systems.	A screenshot or direct proof from the SIEM system showing record logs period for at least 12 months. A sample of stored logs extracted from the SIEM system where records have been kept for at least 12 months.		
National Cybersecurity Authority – Operational Technology Cybersecurity Controls OTCC					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
2-11-1 In addition to subcontrols in the ECC control 2-12-3, cybersecurity requirements for cybersecurity event logs and monitoring management in OT/ICS must include, at a minimum, the following:	2-11-1-1	Cybersecurity event logs and audit trails must be activated for all OT/ICS assets.	Template for Cybersecurity Operational Technology Policy Template for OT/ICS Security Standard Template for Cybersecurity Event Logs and Monitoring Management Policy Template for Cybersecurity Event Logs and Monitoring Management Standard.	Activate cybersecurity event logs for all assets in the OT/ICS environment (e.g., operators' devices, engineering devices, servers, and network devices).	Cybersecurity event logs and audit trails received by the monitoring system Proof that all OT/ICS assets have event logs and audit trails feature activated (e.g., operators' devices, engineering devices, servers, and network devices).

	2-11-1-2	Failure attempts in accessing the organization's monitoring systems must be detected and logged.	Template for Cybersecurity Operational Technology Policy Template for OT/ICS Security Standard Template for Cybersecurity Event Logs and Monitoring Management Policy Template for Cybersecurity Event Logs and Monitoring Management Standard.	Implement mechanisms to detect and log failure attempts in accessing the organization's monitoring systems (e.g. alerting system in case of unauthorized access). Ensure that event logs are enabled and forwarded to a SIEM or event log collector, then analyze these events through the Security Operation Center (SOC).	A proof that shows the implementation of mechanisms to detect and log failure attempts in accessing the organization's monitoring systems. OT/ICS use-cases list by Security Operation Center (SOC).
	2-11-1-3	Continuous, in-depth cybersecurity log review and monitoring, covering all logs and audit trails must be conducted.	Template for Cybersecurity Operational Technology Policy. Template for OT/ICS Security Standard. Template for Cybersecurity Event Logs and Monitoring Management Policy.	Ensure that the continuous, in-depth cybersecurity log review and monitoring, covering all logs and audit trails are conducted through SOC capabilities. Ensure that event logs are enabled and forwarded to a SIEM or event log collector, then analyze these events through the	Site visit to the Security Operation Center (SOC). OT/ICS use-cases list by Security Operation Center (SOC).

			Template for Cybersecurity Event Logs and Monitoring Management Standard.	Security Operation Center (SOC).	
	2-11-1-4	Monitoring, detecting, and analyzing User Behaviors Analytics (UBA) must be performed.	Template for Cybersecurity Operational Technology Policy. Template for OT/ICS Security Standard. Template for Cybersecurity Event Logs and Monitoring Management Policy. Template for Cybersecurity Event Logs and Monitoring Management Standard.	Define and implement monitoring, detection, and analysis of User Behaviors Analytics mechanisms. Verify and ensure that all users are covered by monitoring, detection, and analyses of User Behaviors Analytics mechanisms. Ensure that event logs are enabled and forwarded to a SIEM or event log collector, then analyze these events through the Security Operation Center (SOC).	A proof that monitoring, detection, and analysis of User Behaviors Analytics are performed.
	2-11-1-5	Upload or download activities of OT/ICS assets including Safety Instrumented Systems (SIS) must be detected.	Template for Cybersecurity Operational Technology Policy. Template for OT/ICS Security Standard.	Identify and list all OT/ICS assets including Safety Instrumented Systems (SIS). Define and implement detection mechanisms for upload or download	Site visit to check that all upload or download activities on the OT/ICS including Safety Instrumented Systems (SIS) assets are detected.

			Template for Cybersecurity Event Logs and Monitoring Management Policy. Template for Cybersecurity Event Logs and Monitoring Management Standard.	activities on the listed OT/ICS assets including Safety Instrumented Systems (SIS). Verify and ensure that all upload or download activities on the OT/ICS including Safety Instrumented Systems (SIS) assets are detected.	
	2-11-1-6	All remote access sessions must be monitored.	Template for Cybersecurity Operational Technology Policy. Template for OT/ICS Security Standard. Template for Cybersecurity Event Logs and Monitoring Management Policy. Template for Cybersecurity Event Logs and Monitoring Management Standard.	Ensure that all remote access sessions are monitored. Ensure that event logs are enabled and forwarded to a SIEM or event log collector, then analyze these events through the Security Operation Center (SOC).	A proof that all remote access sessions are monitored. OT/ICS use-cases list by Security Operation Center (SOC).

	2-11-1-7	Malicious events must be detected and analyzed.	Template for Cybersecurity Operational Technology Policy. Template for OT/ICS Security Standard. Template for Cybersecurity Event Logs and Monitoring Management Policy. Template for Cybersecurity Event Logs and Monitoring Management Standard.	Ensure that the virus scan schedule enabled anti-virus is and performed periodically. Ensure that the malicious events are detected and analyzed through SOC capabilities. Ensure that event logs are enabled and forwarded to a SIEM or event log collector, then analyze these events through the Security Operation Center (SOC).	A proof confirming the detection and analysis of malicious events.
	2-11-1-8	Logging and monitoring of new alerts when new or unauthorized devices are connected to the OT/ICS networks must be performed.	Template for Cybersecurity Operational Technology Policy. Template for OT/ICS Security Standard. Template for Cybersecurity Event Logs and Monitoring Management Policy.	Ensure that the logging and monitoring of new alerts when new or unauthorized devices are connected to the OT/ICS networks are performed through SOC capabilities. Ensure that event logs are enabled and forwarded to a SIEM or event log collector, then analyze these events through the	A proof that shows logging and monitoring mechanisms of new or unauthorized OT/ICS device alerts.

			Template for Cybersecurity Event Logs and Monitoring Management Standard.	Security Operation Center (SOC).	
	2-11-1-9	OT/ICS Threat Intelligence must be used and incorporated to regularly tune and refresh alerts of Security Information and Event Management (SIEM) technologies.	Template for Cybersecurity Operational Technology Policy. Template for OT/ICS Security Standard. Template for Cybersecurity Event Logs and Monitoring Management Policy. Template for Cybersecurity Event Logs and Monitoring Management Standard.	Verify and ensure that the OT/ICS Threat Intelligence is used and incorporated to regularly tune and refresh alerts of Security Information and Event Management (SIEM) technologies.	A proof that the OT/ICS Threat Intelligence is used and incorporated to regularly tune and refresh alerts of SIEM technologies.
	2-11-1-10	All access control points between the network security boundaries and external connections must be monitored.	Template for Cybersecurity Operational Technology Policy. Template for OT/ICS Security Standard. Template for Cybersecurity Event	Ensure that the access control points between the network security boundaries and external connections are monitored. Ensure that event logs are enabled and forwarded to a SIEM or event log	A proof that all access control points between the network security boundaries and external connections are monitored.

			Logs and Monitoring Management Policy. Template for Cybersecurity Event Logs and Monitoring Management Standard.	collector, then analyze these events through the Security Operation Center (SOC).	
2-11-2	With reference to the ECC control 2-12-4, the cybersecurity requirements for cybersecurity event logs and monitoring management in OT/ICS environment must be reviewed, and their implementation effectiveness is measured and evaluated periodically.	Template for Cybersecurity Operational Technology Policy. Template for OT/ICS Security Standard. Template for Cybersecurity Event Logs and Monitoring Management Policy. Template for Key Performance Indicator Report.	Review the cybersecurity requirements for cybersecurity event logs and monitoring management specified to the OT/ICS periodically based on a documented and approved review plan and on a defined frequency (e.g., conduct a review annually); Develop key performance indicators (KPIs) for each control within the related policy or procedure to ensure the implementation effectiveness is measured and evaluated periodically based on a defined frequency (e.g., conduct a review annually).	A proof that shows the periodic review of cybersecurity requirements for OT/ICS event logs and monitoring management. A proof that shows the key performance indicators (KPIs) for each control within the related policy or procedure to ensure the implementation effectiveness is measured and evaluated periodically (based on a defined frequency).	

National Cybersecurity Authority - Cloud Cybersecurity Controls CCC					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
2-11-P-1 In addition to sub controls in the ECC control 2-12-3, the CSP shall cover the following additional sub controls for cybersecurity requirements for cybersecurity event logs and monitoring management, as a minimum:	2-11-P-1-1	Activating and protecting event logs and audit trails of Cloud Technology Stack.	Template for Cybersecurity Event Logs and Monitoring Management Policy. Template for Cybersecurity Event Logs and Monitoring Management Standard.	Define and implement a Log Management policy that includes the intent, purpose, and governance of how a CSP must enable logging and monitoring of cybersecurity events for their respective scope under the Security Shared Responsibility Model. At a minimum, the policy should specify: • The protection methods for logs where these are generated to prevent log tampering or logging technology evasion. • The protection methods for logs transmitted to the log repositories to ensure their confidentiality and integrity with encryption.	Log management policy. Centralized and protected Log base.
	2-11-P-1-2	Activating and collecting login attempts history.	Template for Cybersecurity Event Logs and Monitoring Management Policy.	Configure authentication mechanisms for logging authentication attempts (e.g.: data, time,	Stored and recorded login attempts.

			Template for Cybersecurity Event Logs and Monitoring Management Standard.	authentication method, system/application, user id/Identity). Collect and store that information.	Evidence illustrating mechanisms for verifying login attempts.
	2-11-P-1-3	Activating and protecting all event logs of activities and operations performed by the CSP at the tenant level in order to support forensic analysis.	Template for Cybersecurity Event Logs and Monitoring Management Policy. Template for Cybersecurity Event Logs and Monitoring Management Standard.	Define requirements for logging of activities of CSP and CSTs that is sufficiently to support forensic analysis (e.g.: chain of custody). Build logging functionality to capture these events/activities and protect logs (e.g.: ensure confidentiality, integrity and availability of these logs using encryption, HMAC and redundant storage).	CSP and CST event/activity log.
	2-11-P-1-4	Protecting cybersecurity event logs from alteration, disclosure, destruction and unauthorized access and unauthorized release, in accordance with	Template for Cybersecurity Event Logs and Monitoring Management Policy. Template for Cybersecurity Event	Identify law and regulatory requirements regarding for audit logs. Define and implement a Cybersecurity Log Management and Access Control policy that	Cybersecurity event logs protected. Restrictions applied to protect the logs. Secured log destruction methods.

		regulatory, or law requirements.	Logs and Monitoring Management Standard.	includes the intent, purpose, and governance of how a CSP must enable logging and monitoring of cybersecurity events for their respective scope under the Security Shared Responsibility Model. At a minimum, the policies should specify: • The protection methods for logs where these are generated to prevent log tampering or logging technology evasion. • The protection methods for logs transmitted to the log repositories to ensure their confidentiality and integrity with encryption. • Secure log destruction methods. • Restricted Access to logs • Read-only Access to logs	List of law and regulatory requirements for audit log.
	2-11-P-1-5	Continuous cybersecurity events monitoring using SIEM technique covering the	Template for Cybersecurity Event Logs and Monitoring Management Policy.	Define requirements for cybersecurity events monitoring (e.g. capture of user authentications, privilege elevations, software execution).	Cybersecurity logs monitored in SIEM. List of requirements for cybersecurity event monitoring.

		full Cloud Technology Stack.	Template for Cybersecurity Event Logs and Monitoring Management Standard.	Define scope for cybersecurity events monitoring covering Cloud Technology Stack. Select and deploy SIEM-class system to monitor cybersecurity event logs. Monitor cybersecurity event logs continuously (at least daily).	Sample of monitoring reports/alerts.
	2-11-P-1-6	Reviewing cybersecurity event logs and audit trails periodically, covering CSP events in the Cloud Technology Stack.	Template for Cybersecurity Event Logs and Monitoring Management Policy. Template for Cybersecurity Event Logs and Monitoring Management Standard.	Define scope for CSP event logs reviews covering the Cloud Technology Stack. Define criteria for reviews. Select and assign skilled and independent reviewers of cybersecurity event logs/audit trails. Review periodically cybersecurity event logs/audit trails.	Cybersecurity event logs reviewed by skilled and independent reviewers. Sample of reports, alerts, use cases.
	2-11-P-1-7	Automated monitoring and logging of remote access sessions event logs.	Template for Cybersecurity Event Logs and Monitoring Management Policy.	Log remote access sessions and relevant events.	Remote sessions automatically monitored.

			Template for Cybersecurity Event Logs and Monitoring Management Standard.	Define markers, indicators and patterns for malicious remote accesses. Monitor, detect and block automatically these remote sessions.	
	2-11-P-1-8	Secure handling of user-related data found in the audit trails and the cybersecurity event logs.	Template for Cybersecurity Event Logs and Monitoring Management Policy. Template for Cybersecurity Event Logs and Monitoring Management Standard.	Detect user related data event logs/audit trails. Anonymize that data using tokens.	Personally Identifiable Information anonymized in logs.
2-11-T-1 In addition to sub controls in the ECC control 2-12-3, the CST shall cover the following additional sub controls for cybersecurity requirements for cybersecurity event logs and monitoring	2-11-T-1-1	Activating and collecting of login event logs, and cybersecurity event logs on assets related to cloud services.	Template for Event Log Management and Cybersecurity Monitoring Policy. Template for Event Log Management and Cybersecurity Monitoring Standard.	Enable logging of account authentication and other cybersecurity events in cloud services (e.g.: use cloud native logging service and related agents).	Cloud Services cybersecurity event log.
	2-11-T-1-2	Monitoring shall include all activated cybersecurity logs on the cloud services of the CST.	Template for Event Log Management and Cybersecurity Monitoring Policy.	Define monitoring use-cases relevant to cloud services (e.g.: monitoring of modifications of user accesses).	Cybersecurity event logs monitored.

management, as a minimum:			Template for Event Log Management and Cybersecurity Monitoring Standard.	Collect cybersecurity logs relevant to defined monitoring use-cases across cloud services (e.g.: API calls relevant to user accesses modifications are captured). Monitor cloud service cybersecurity logs (e.g. use cloud native or on-prem SIEM class technologies to analyse logs do detect security incidents).	
SAMA Cyber Security Framework CSF					
Control reference number	Sub-Control	Control clauses	Control implementation guidelines		Expected deliverables
3.3.14-1	The security event management process should be defined, approved and implemented.		Define a formal process for managing security events, document it, obtain approval from relevant authority, and put the process into action.		Documented security event management process. Evidence of approval.
3.3.14-2	The effectiveness of the cyber security controls within the security event management process should be measured and periodically evaluated.		Establish metrics to track the performance of the security event management process (e.g., number of events identified, time to respond). Regularly assess the effectiveness of the process using these metrics.		Reports on security event management process performance. Documentation of periodic evaluations.

3.3.14-3	To support this process a security event monitoring standard should be defined, approved and implemented.		Define and document a security event monitoring standard that outlines the mandatory events to be monitored for all information assets based on their classification or risk profile. Obtain necessary approvals and implement the standard.	Documented security event monitoring standard. Evidence of approval.
3.3.14-3	a	The standard should address for all information assets the mandatory events which should be monitored, based on the classification or risk profile of the information asset.	Ensure that the security event monitoring standard specifies the mandatory events to be monitored for all information assets, taking into account their classification or risk profile.	
3.3.14-4 The security event management process should include requirements for:	a	The establishment of a designated team responsible for security monitoring (i.e., Security Operations Center (SOC));	Establish a dedicated team responsible for security monitoring, such as a Security Operations Center (SOC).	Evidence of SOC establishment, along with framework/process dictating the monitoring team responsibility.
	b	Skilled and (continuously) trained staff;	Ensure that the SOC team consists of skilled personnel who receive continuous training on security monitoring and incident response.	SOC staff training records.
	c	A restricted area to facilitate SOC activities and workspaces;	Provide a dedicated and secure workspace for the SOC team to conduct their activities.	

	d	Resources required for continuous security event monitoring activities (24x7);	Allocate the necessary resources to support continuous security event monitoring operations 24/7.	
	e	Detection and handling of malicious code and software;	Implement measures to detect and handle malicious code and software, such as deploying anti-malware solutions and establishing procedures for incident response.	Evidence of anti-malware deployment. Incident response procedures.
	f	Detection and handling of security or suspicious events and anomalies;	Implement mechanisms to detect and handle security or suspicious events and anomalies, such as deploying an intrusion detection system (IDS) and establishing incident response procedures.	Evidence of IDS deployment. Incident response procedures.
	g	Deployment of security network packet analysis solution;	Deploy a security network packet analysis solution to capture and analyze network traffic for suspicious activities.	Evidence of network packet analyzer deployment.
	h	Adequately protected logs;	Ensure that security event logs are adequately protected from unauthorized access, modification, and deletion.	Log protection mechanisms.
	i	Periodic compliance monitoring of applications and infrastructure cyber security standards	Conduct periodic compliance monitoring of applications and infrastructure to ensure adherence to relevant cyber security standards.	Compliance monitoring reports.
	j	Automated and centralized analysis of security loggings and correlation of event or	Implement a Security Information and Event Management (SIEM) system to automate and centralize the analysis of security logs and correlate events or patterns.	Evidence of SIEM deployment.

		patterns (i.e., Security Information and Event Management (SIEM));		
	k	Reporting of cyber security incidents;	Establish a process for reporting cyber security incidents to relevant stakeholders.	Incident reporting procedures.
	l	Independent periodic testing of the effectiveness of the security operations center (e.g., red-teaming).	Conduct independent periodic testing of the effectiveness of the SOC, such as red-teaming exercises, to evaluate its capabilities and identify areas for improvement.	Red-teaming reports. SOC maturity assessment reports.
CST CRF				
Control reference number	Control clauses		Control implementation guidelines	Expected deliverables
4.6.1 CL1	Define and document [Requirements for Logging and Monitoring] which consider the following: • Logging the events (e.g., login attempts, configuration changes, firewall logs) related to the information assets which belong to the organization. • Monitoring of the event logs and analysis of the detected events. • Required retention period and protection of the event logs.		This control highlights the importance of establishing and documenting clear requirements for logging and monitoring security-related events. These requirements should specify what types of events need to be logged, how the logs should be monitored and analyzed, and how long they should be retained. The organization should define and document comprehensive requirements for logging and monitoring security events. These requirements should cover the types of events to be logged, monitoring and analysis procedures, and log retention policies.	Documented logging and monitoring requirements.

4.6.2 CL1	Activate event logging and record the event logs (e.g., user activities, exceptions, information security events, privileged operations) related to the information assets.	This control focuses on enabling and recording security event logs for various activities and operations related to the organization's information assets. This includes logging user activities, exceptions, security events, and privileged operations. The organization should enable and configure event logging to record relevant security events, including user activities, exceptions, security-related events, and privileged operations.	Evidence of event logging activation and configuration. Log records of user activities, exceptions, security events, and privileged operations.
4.6.3 CL1	Protect log information and logging facilities from unauthorized access and tampering.	This control stresses the importance of protecting log data and the systems that generate and store logs from unauthorized access, modification, or deletion. The organization should implement security controls to protect log information and logging facilities from unauthorized access and tampering. This may include access controls, encryption, and data integrity checks.	Evidence of security controls implemented to protect log information and logging facilities.
4.6.4 CL1	Periodically review the event logs and report suspicious events and detected anomalies to the responsible personnel [Incident Management].	This control emphasizes the need for regular review of security event logs to identify suspicious activities and anomalies. These findings should be reported to the appropriate personnel or incident management team for further investigation and response. The organization should establish a process for periodically reviewing security event logs and reporting suspicious events and anomalies to the incident management team or other responsible personnel.	

4.6.5 CL1	Retain the logs for a defined time duration as specified in the requirements (e.g., 12 months).	This control requires retaining security event logs for a specific duration as defined in the logging and monitoring requirements. The retention period may vary depending on regulatory requirements, industry best practices, or the organization's specific needs. The organization should define and implement log retention policies to ensure that security event logs are retained for the required duration.	Evidence of log retention policies and procedures.
4.6.6 CL2	Collect, monitor, and analyze events using a log management tool (e.g., SIEM) that includes advanced detection and integration capabilities.	This control recommends using a log management tool, such as a Security Information and Event Management (SIEM) system, to collect, monitor, and analyze security events. The tool should have advanced detection capabilities to identify suspicious patterns and anomalies, as well as integration capabilities to connect with other security tools and systems. The organization should implement a log management tool, such as a SIEM, to facilitate the collection, monitoring, and analysis of security events.	Evidence of log management tool deployment and configuration.
4.6.7 CL2	Real-time monitoring and review of the event logs of critical information assets.	This control requires real-time monitoring and review of security event logs for critical information assets. This allows for immediate detection and response to security incidents that may impact these assets. The organization should implement real-time monitoring and review of security event logs for critical information assets to ensure timely detection and response to security incidents.	Evidence of real-time monitoring and review of security event logs for critical information assets.
4.6.8 CL2	Improve the event detection methods by the use of dedicated tools (e.g., Threat	This control recommends using dedicated tools, such as Threat Intelligence Platforms, to enhance event	Evidence of using threat intelligence platforms or other

	Intelligence Platforms) to update the rules of the log management tools.	detection methods. These tools can provide updated threat intelligence feeds, which can be used to update the rules and configurations of log management tools to better identify and respond to emerging threats. The organization should utilize threat intelligence platforms or other dedicated tools to update the rules and configurations of log management tools to improve event detection capabilities.	dedicated tools to update log management tool rules and configurations.
4.6.9 CL3	Continuously measure, review, and optimize the [Requirements for Logging and Monitoring].	This control emphasizes the importance of continuous improvement of the logging and monitoring practices. Organizations should regularly measure and review the effectiveness of their logging and monitoring activities and make adjustments as needed to ensure they remain aligned with their security objectives and risk tolerance. Organizations should establish a process for continuously measuring, reviewing, and optimizing the logging and monitoring requirements and the overall effectiveness of the logging and monitoring process.	Reports on the measurement and review of logging and monitoring requirements and process effectiveness. Documentation of optimization efforts.
CMA Cybersecurity Guidelines			
Control reference number	Control clauses	Control implementation guidelines	Expected deliverables
4.3.8-1	Define, document, approve and implement security event logs management process.	This control requires establishing a formal, documented process for managing security event logs. This process should be approved by the appropriate authority within the organization and actively put into practice.	Documented security event logs management process. Evidence of process approval.

		The organization should define a formal process for managing security event logs, document it thoroughly, obtain necessary approvals, and implement the process.	
4.3.8-2	Measure and periodically evaluate the effectiveness of cybersecurity controls related to the security event logs management process.	This emphasizes the importance of ongoing monitoring and assessment. Organizations need to track the performance of their security event logs management process and regularly evaluate its effectiveness. This might involve using metrics such as the number of security events discovered, and the time taken to respond to them. Define metrics to track the performance of the security event logs management process. Regularly assess the effectiveness of the process using these metrics and make adjustments as needed.	Reports on security events logs management process performance. Documentation of periodic evaluations.
4.3.8-3	Define, document, approve and implement control standards for cybersecurity event logs to support that process.	This control requires the establishment, documentation, approval, and implementation of control standards specifically designed for cybersecurity event logs. These standards are essential to support the overall security event logs management process, ensuring consistency and effectiveness in handling and analyzing security events.	Documented control standards for cybersecurity event logs. Evidence of approval.

		Define and document the control standards for cybersecurity event logs, obtain necessary approvals, and implement the standards.	
4.3.8-4	Identify event standards to be monitored based on classification of information assets or risk profile.	This control mandates the identification of specific event standards that should be monitored. The selection of these standards should be based on the classification of information assets or their risk profile, ensuring that monitoring efforts are aligned with the organization's security priorities and risk tolerance. Identify the specific event standards that need to be monitored based on the classification of information assets or their risk profile.	List of event standards to be monitored.
4.3.8-5	Monitor cybersecurity event logs for accounts with high and sensitive privileges and remote login accounts.	This control specifically requires the monitoring of cybersecurity event logs for accounts that hold high and sensitive privileges, as well as those used for remote login. This heightened scrutiny is necessary due to the potential for significant damage or unauthorized access associated with these types of accounts. Implement monitoring of cybersecurity event logs for accounts with high and sensitive privileges, as well as remote login accounts.	Evidence of monitoring of cybersecurity events logs for privileged and remote accounts.
4.3.8-6	Retention period for cybersecurity event logs must be 12 months at least.	This control sets a minimum retention period of 12 months for cybersecurity event logs. This ensures that sufficient historical data is available for analysis, incident response, and compliance audits.	Evidence of cybersecurity events logs retention for at least 12 months.

		Ensure that cybersecurity event logs are retained for a minimum of 12 months.	
4.3.8-7 Event logs management shall include the following:	1- Form a teamwork in charge of security control (Security Operation Center "SOC").	This sub-control mandates the establishment of a dedicated team responsible for security control, often referred to as a Security Operations Center (SOC). Establish a dedicated team responsible for security control, such as a Security Operations Center (SOC).	Evidence of SOC establishment.
	2- Well-trained and qualified citizen employees.	This sub-control emphasizes the importance of having well-trained and qualified citizen employees as part of the SOC team. Ensure that the SOC team consists of well-trained and qualified citizen employees.	SOC staff training records.
	3- A restricted area dedicated for SOC related activities.	This sub-control requires the provision of a dedicated and secure workspace for SOC-related activities. Provide a dedicated and secure workspace for SOC-related activities.	SOC room access controls
	4- Resources required for constant monitor of security events for 24 hours a day, seven days a week (24/7).	This sub-control highlights the need to allocate sufficient resources to support continuous security event monitoring operations 24/7. Allocate the necessary resources to support continuous security event monitoring operations 24/7.	SOC Shift schedule and employees
	5- Retrieving the source code and detecting malware.	This sub-control mandates the implementation of measures to retrieve source code and detect malware, such as deploying anti-malware solutions.	Evidence of anti-malware deployment.

		Implement measures to retrieve source code and detect malware, such as deploying anti-malware solutions.	
	6- Detecting suspicious security events and addressing them.	This sub-control requires the implementation of mechanisms to detect and address suspicious security events, such as deploying an intrusion detection system (IDS). Implement mechanisms to detect and address suspicious security events, such as deploying an intrusion detection system (IDS) in addition to other security technologies.	Evidence of IDS deployment, and SIEM.
	7- Using solutions to analyze network packets.	This sub-control mandates the deployment of a network packet analysis solution to capture and analyze network traffic for suspicious activities. Deploy a network packet analysis solution to capture and analyze network traffic for suspicious activities.	Evidence of network packet analyzer deployment.
	8- Protecting cybersecurity event records.	This sub-control requires ensuring that cybersecurity event records are adequately protected from unauthorized access, modification, and deletion. Ensure that cybersecurity event records are adequately protected from unauthorized access, modification, and deletion.	Log protection mechanisms.
	9- Periodical monitoring of compliance with cybersecurity standards for applications and infrastructure.	This sub-control mandates the periodic monitoring of compliance with cybersecurity standards for applications and infrastructure.	Compliance monitoring reports/dashboard.

		Conduct periodic compliance monitoring of applications and infrastructure to ensure adherence to relevant cybersecurity standards.	
	10- Using automated and central analysis of security logs and linking events and patterns (e.g. Security information and event management and cybersecurity monitor "SEIM").	This sub-control requires the implementation of a Security Information and Event Management (SIEM) system to automate and centralize the analysis of security logs and correlate events or patterns. Implement a Security Information and Event Management (SIEM) system to automate and centralize the analysis of security logs and correlate events or patterns.	Evidence of SIEM deployment.
	11- Reporting cybersecurity incidents.	This sub-control mandates the establishment of a process for reporting cybersecurity incidents to relevant stakeholders. Establish a process for reporting cybersecurity incidents to relevant stakeholders.	Incident reporting procedures.
	12- Conducting a periodic and independent test to verify SOC effectiveness (For example: Red Team).	This sub-control requires conducting independent periodic testing of the effectiveness of the SOC, such as red-teaming exercises, to evaluate its capabilities and identify areas for improvement. Conduct independent periodic testing of the effectiveness of the SOC, such as red-teaming exercises, to evaluate its capabilities and identify areas for improvement.	Red-teaming reports, SOC Maturity Assessment report, Response Readiness Assessment Reports.
4.3.8-8 In case of any major	1- A crisis management team comprising an employee of the market institution's board of directors, representatives of executive	This control mandates the formation of a crisis management team with specific composition requirements. This team should include a member of	Evidence of crisis management team formation.

cybersecurity incident:	management and qualified persons shall be formed to deal with incidents.	the market institution's board of directors, representatives from executive management, and other qualified individuals. This team is responsible for managing and responding to major cybersecurity incidents. Form a crisis management team comprising an employee of the market institution's board of directors, representatives of executive management, and qualified persons to deal with major cybersecurity incidents.	
	2- Disclosure of cybersecurity incidents shall be made according to certain standards and shall include stakeholders.	This control requires the disclosure of cybersecurity incidents according to predefined standards. These standards likely define the information that needs to be disclosed, the appropriate channels for disclosure, and the timeline for disclosure. The control also emphasizes the inclusion of stakeholders in the disclosure process, ensuring that relevant parties are informed about the incident and its potential impact. Develop and implement a process for disclosing cybersecurity incidents according to predefined standards. Ensure that stakeholders are included in the disclosure process.	Documented disclosure standards and procedures. Evidence of stakeholder communication.
	3- An improvement and development plan shall be developed after the end of crisis. In addition, necessary measures shall be taken, and relevant recommendations shall be made based on the report.	This control mandates the development of an improvement and development plan after the resolution of a major cybersecurity incident. This plan should aim to address the root causes of the incident, enhance security controls, and improve incident response capabilities. The control also	Improvement and development plan. Evidence of implemented measures and recommendations.

		requires taking necessary measures and making relevant recommendations based on the findings of the incident investigation report. Develop an improvement and development plan after the resolution of a major cybersecurity incident. Implement necessary measures and make relevant recommendations based on the incident investigation report.	
	4- Ensure that the incident has ended with all supporting documents explaining how the incident ended, the lessons learned, and any additional investigations and post-crisis reviews and reports needed.	This control emphasizes the importance of proper closure of a cybersecurity incident. This includes ensuring that the incident has been fully contained and remediated, and that all necessary documentation is in place. The documentation should explain how the incident was resolved, the lessons learned from the incident, and any additional investigations or reviews that were conducted. Develop and implement a process for closing cybersecurity incidents. Ensure that all necessary documentation is in place, including incident resolution details, lessons learned, and any additional investigation or review reports.	Incident closure report. Lessons learned documentation. Investigation and review reports.

Risk Considerations in Cybersecurity Event Logs and Monitoring Management

- **Incomplete Log Collection:**
 - Failure to capture logs from all critical systems, such as databases, network devices, and cloud services, can lead to gaps in monitoring and compliance failures.
- **Log Tampering and Unauthorized Access:**
 - Insufficient protection measures may allow attackers or unauthorized personnel to modify or delete logs, undermining forensic investigations and compliance efforts.
- **Retention Policy Violations:**
 - Non-compliance with regulatory requirements related to log retention periods (e.g., 12 months minimum) can result in legal and regulatory penalties.
- **Storage Limitations and Performance Issues:**
 - Inadequate storage capacity or inefficient log management solutions can lead to data loss, performance degradation, or excessive costs.
- **Lack of Standardization:**
 - Inconsistent log formats across different systems can complicate aggregation, analysis, and correlation of log data.
- **Overlooking Privileged Accounts:**
 - Failure to log and monitor activities related to privileged accounts may result in undetected misuse or unauthorized changes.
- **False Positives and Alert Fatigue:**
 - Excessive logging without proper filtering can lead to alert fatigue, causing critical events to be ignored.
- **Limited Log Analysis Capabilities:**
 - Absence of automation and analytics can make it difficult to detect patterns and anomalies, reducing the effectiveness of log management.
- **Integration Challenges:**
 - Incompatibility between various log sources, such as on-premises and cloud environments, can hinder effective centralized monitoring.
- **Lack of Periodic Reviews:**
 - Failure to conduct periodic log reviews may allow security gaps and suspicious activities to go unnoticed for extended periods.

Examples of Technologies for Effective Cybersecurity Event Logs and Monitoring Management

- **Security Information and Event Management (SIEM):**
 - Tools: Wazuh, ELK Stack (Elasticsearch, Logstash, Kibana), OSSIM (AlienVault Community Edition)
 - **Log Management Solutions:**
 - Tools: Graylog (open-source), ELK Stack, Fluentd
 - **Cloud Logging Services:**
 - Tools: Fluent Bit (for multi-cloud log forwarding), Loki (Grafana), OpenTelemetry
 - **Network Monitoring Tools:**
 - Tools: Nagios Core, Zabbix, Icinga, ntopng
 - **Endpoint Detection and Response (EDR):**
 - Tools: OSSEC, Wazuh, Velociraptor
 - **User and Entity Behavior Analytics (UEBA):**
 - Tools: ELK Stack + custom anomaly detection, Apache Spot
 - **Log Encryption and Integrity:**
 - Tools: OpenSSL, Open Source Tripwire, AIDE (Advanced Intrusion Detection Environment)
 - **Audit and Compliance Reporting Tools:**
 - Tools: OpenSCAP, Wazuh (with compliance module), Lynis
 - **Threat Intelligence Platforms:**
 - Tools: MISP (Malware Information Sharing Platform), OpenCTI
-

Examples of KPIs for Cybersecurity Event Logs and Monitoring Management

- **Log Coverage Rate:**
 - Percentage of critical systems covered by logging mechanisms.
- **Log Retention Compliance:**
 - Percentage of logs retained according to policy-defined timeframes.
- **Average Log Processing Time:**
 - Time taken to process and analyze logs in the SIEM system.
- **Alert Resolution Time:**
 - Average time taken to investigate and resolve log-generated alerts.
- **Log Storage Utilization Rate:**
 - Percentage of log storage capacity utilized compared to available capacity.
- **False Positive Rate:**
 - Percentage of alerts generated from logs that were deemed non-actionable.
- **Event Correlation Accuracy:**
 - Effectiveness of event correlation to detect suspicious patterns.
- **Percentage of Privileged Account Activities Logged:**
 - Ensuring privileged account activities are monitored adequately.
- **Compliance Audit Pass Rate:**
 - Percentage of audits passed with satisfactory log management compliance.

Samples of Auditor's Checklist for Cybersecurity Event Logs and Monitoring Management

1. Are log management policies and procedures documented and reviewed periodically?
 2. Are all critical systems configured to generate security event logs?
 3. Is there a centralized log management solution in place (e.g., SIEM)?
 4. Are access controls implemented to protect log data from unauthorized access or modification?
 5. Are log retention policies in compliance with regulatory requirements?
 6. Are cybersecurity logs reviewed periodically for suspicious activities?
 7. Is there a defined process for responding to alerts generated from event logs?
 8. Are encryption and integrity checks applied to logs during storage and transmission?
 9. Are redundant log storage solutions implemented for business continuity?
 10. Is log monitoring integrated with incident response processes?
-

Samples of Audit Scenarios for Cybersecurity Event Logs and Monitoring Management

Scenario 1: Compliance with Log Retention Policies

- **Objective:** Assess adherence to organizational and regulatory log retention requirements.
- **Steps:**
 1. Review log retention policies and compare them with actual retention periods.
 2. Verify that logs are securely archived for the required duration.
 3. Assess compliance documentation and reporting mechanisms.
- **Key Questions:**
 - Are log retention policies aligned with regulatory frameworks from NCA or SAMA?
 - Is there a process for log deletion after retention periods?

Scenario 2: Monitoring Privileged Account Activities

- **Objective:** Evaluate the effectiveness of monitoring privileged accounts for suspicious activities.
- **Steps:**
 1. Verify logging of privileged user access across critical systems.
 2. Assess alerting mechanisms for unauthorized access attempts.
 3. Conduct interviews with the security operations team on monitoring practices.
- **Key Questions:**
 - Are privileged user activities logged and reviewed regularly?
 - How are anomalies in privileged account activities handled?

Scenario 3: Incident Investigation Using Event Logs

- **Objective:** Test the organization's ability to leverage logs for forensic investigations.
 - **Steps:**
 1. Simulate a security incident and analyze the log trail.
 2. Assess the completeness and accuracy of collected logs.
 3. Review response time and efficiency of log analysis.
 - **Key Questions:**
 - Are logs readily available for forensic analysis?
 - Was the incident detected and analyzed within an acceptable timeframe?
-

Case Study 1: Implementing Event Log Management in a Financial Institution

Scenario:

A leading financial institution in Saudi Arabia faced challenges in managing and securing event logs due to regulatory pressures from the Saudi Central Bank (SAMA) and the National Cybersecurity Authority (NCA). The organization struggled with fragmented log management across its branches, leading to compliance gaps and operational inefficiencies.

Challenges:

1. **Regulatory Compliance:**
 - SAMA Cybersecurity Framework (CSF) and NCA Essential Cybersecurity Controls (ECC) require centralized log collection and retention for at least 12 months. The institution lacked a unified strategy to meet these requirements.
2. **Log Storage and Performance Issues:**
 - High log volume from multiple sources, including ATMs, online banking portals, and mobile applications, strained existing storage solutions.
3. **Lack of Real-Time Monitoring:**
 - Absence of a Security Information and Event Management (SIEM) solution made real-time monitoring and alerting difficult.
4. **Inadequate Incident Investigations:**
 - Lack of structured logging made it challenging to trace fraudulent transactions and insider threats.

Actions Taken:

2. **Implementation of SIEM Solution:**
 - Deployed IBM QRadar to centralize log collection, storage, and real-time correlation across all financial systems.
3. **Compliance Alignment:**
 - Developed log retention and review policies to align with SAMA and NCA ECC guidelines, ensuring a 12-month log storage policy.
4. **Automation & Integration:**
 - Integrated the SIEM with banking applications, ATMs, and SWIFT systems to enable automatic detection of suspicious activities.
5. **Capacity Planning & Performance Optimization:**
 - Adopted cloud-based log storage with AWS CloudTrail and Amazon S3 to ensure scalability and availability.
6. **Periodic Auditing & Review:**
 - Implemented quarterly log review processes and partnered with an NCA-approved cybersecurity service provider for audit validation.

Outcomes:

- **100% Regulatory Compliance:** Achieved full compliance with SAMA and NCA ECC log management controls.
- **Enhanced Fraud Detection:** Early detection of fraudulent activity reduced financial losses by 50%.
- **Improved Log Retention:** Achieved centralized log retention across all banking operations, reducing audit response time from weeks to days.

Case Study 2: Enhancing Log Monitoring in a Healthcare Organization

Scenario:

A large healthcare provider operating several hospitals and clinics across Saudi Arabia faced data breaches due to unauthorized access to patient health records. The organization needed to comply with the Saudi Data Management and Personal Data Protection Regulation (PDPL), which mandates the secure collection and storage of logs.

Challenges:

1. **Non-Compliance with PDPL:**
 - Patient data was not being logged or monitored effectively, increasing risks of unauthorized access and data leaks.
2. **Lack of Visibility in IoT Medical Devices:**
 - Medical IoT devices, such as heart monitors and infusion pumps, were not generating logs, leaving security blind spots.
3. **Incident Response Delays:**
 - Investigations into past breaches were hampered by incomplete log records and lack of forensic readiness.
4. **Disparate Systems:**
 - Different healthcare systems (EHR, radiology, pharmacy) had isolated logging mechanisms, making analysis cumbersome.

Actions Taken:

2. **Deployment of Centralized Log Management:**
 - Implemented a SIEM solution (Splunk) to collect logs from various healthcare IT systems and medical devices.
3. **Integration with National Health Platforms:**
 - Integrated log monitoring with the Ministry of Health (MoH) platforms for streamlined compliance reporting.
4. **Role-Based Access Controls (RBAC):**
 - Ensured only authorized personnel had access to logs related to patient data.
5. **Proactive Incident Monitoring:**
 - Deployed real-time alerting mechanisms for anomalous access patterns related to patient data.
6. **Retention Policy Implementation:**
 - Set up a 12-month log retention policy in compliance with PDPL and NCA ECC standards.

Outcomes:

- **Improved Security Posture:** Reduced unauthorized data access incidents by 70%.
- **Efficient Compliance Audits:** Achieved successful regulatory compliance inspections by the MoH.
- **Increased Operational Efficiency:** Consolidated log management across multiple departments, saving 30% on operational costs.

Case Study 3: Strengthening Log Security in a Government Agency

Scenario:

A government agency responsible for managing citizen data portals and national infrastructure encountered an advanced persistent threat (APT) targeting its systems. The organization faced challenges in securing and retaining logs per NCA ECC requirements.

Challenges:

1. **Lack of Log Standardization:**
 - Logs from different departments (HR, finance, and operations) followed inconsistent formats, making aggregation difficult.
2. **Weak Access Controls to Logs:**
 - Unauthorized personnel could access and delete logs, leading to loss of critical evidence.
3. **Failure to Detect Insider Threats:**
 - No mechanisms were in place to monitor anomalous behavior from internal users.
4. **Poor Incident Investigation Capabilities:**
 - Forensic investigations were hindered by missing or incomplete logs.

Actions Taken:

1. **Standardization of Log Formats:**
 - Implemented industry-standard log formats (Syslog, CEF) to ensure consistency across all government departments.
2. **Privileged Access Monitoring:**
 - Integrated UEBA (User and Entity Behavior Analytics) tools like Exabeam to detect abnormal activities by insiders.
3. **Immutable Log Storage:**
 - Deployed log integrity solutions (e.g., Vormetric) to ensure logs could not be altered or deleted without authorization.
4. **Automated Log Review Mechanism:**
 - Introduced AI-driven automated log review and reporting to enhance forensic capabilities.
5. **Training and Awareness:**
 - Conducted workshops to train IT teams on log management best practices in compliance with NCA guidelines.

Outcomes:

- **Advanced Threat Detection:**
 - Successfully detected and blocked an insider attempting unauthorized data access.
- **Improved Log Integrity:**
 - Achieved compliance with NCA ECC log retention and integrity requirements.
- **Streamlined Investigations:**

- Reduced investigation time by 60% due to standardized logging and automated analysis.
-

Lessons Learned from the Case Studies

- 1. Compliance is Key:**
 - Adhering to Saudi cybersecurity frameworks like NCA ECC, SAMA and PDPL is critical for ensuring regulatory success and avoiding penalties.
- 2. Centralization Enhances Visibility:**
 - Implementing centralized log management solutions improves operational efficiency and cybersecurity posture.
- 3. Automation Reduces Risk:**
 - Leveraging automated alerting and anomaly detection helps detect and respond to security threats faster.
- 4. Data Integrity is Crucial:**
 - Ensuring logs are immutable and accessible only to authorized personnel strengthens forensic readiness.
- 5. Training and Awareness Matter:**
 - Regular staff training ensures ongoing compliance and effective log management practices.

2.13 Cybersecurity Incident and Threat Management:

Definition: Cybersecurity Incident and Threat Management refers to the structured process of identifying, classifying, responding to, and reporting cybersecurity incidents and threats that may impact an organization's operations. This domain ensures that threats are detected and addressed effectively through predefined procedures, escalation protocols, and collaboration with relevant regulatory authorities, such as the National Cybersecurity Authority (NCA), Saudi Central Bank (SAMA), and Communication, Space & Technology Commission (CST) [7], [8].

Objective: To ensure timely identification, detection, and effective management of cybersecurity incidents and threats to prevent or minimize negative impacts on an organization's operations.

Controls Matrix:

Below is a summary matrix detailing relevant Cybersecurity Incident and Threat Management controls based on NCA Controls, SAMA CSF, CST CRF, and CMA Cybersecurity Guidelines:

Regulation	Main Controls	Control References
NCA ECC	4	2-13-1, 2-13-2, 2-13-3 (5 sub-controls), 2-13-4
SAMA CSF	3	3.3.15 (10 sub-controls), 3.3.16 (6 sub-controls)
CST CRF	8	4.9.1, 4.9.2, 4.9.3, 4.9.4, 4.9.5, 4.9.6, 4.9.7, 4.9.8
CMA CSG	3	4.3.7 (9 sub-controls), 4.3.9 (5 sub-controls)
NCA CSCC	—	—
NCA CCC CST	—	—
NCA CCC CSP	1	2-12-P-1 (8 sub-controls)
NCA TCC	1	2-12-1 (3 sub-controls)
NCA DCC	—	—
NCA OSMACC	1	2-7-1 (1 sub-control)
NCA OTCC	2	2-12-1 (8 sub-controls), 2-12-2

Cybersecurity Incident and Threat Management controls:

National Cybersecurity Authority - Essential Cybersecurity Controls ECC					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
2-13-1		Requirements for cybersecurity incidents and threat management must be defined, documented and approved.	Cybersecurity Incident and Threat Management Policy Template.	Develop and document cybersecurity policy for Cybersecurity Incident and Threat management in the organization, including the following: - Define a cybersecurity incident response plan. - Classify cybersecurity incidents by severity. - Define the roles and responsibilities for cybersecurity incident response and how to communicate with all stakeholders. - Define a mechanism for notifying the National Cybersecurity Authority in the event of a cybersecurity incident. - Share incidents notifications, threat intelligence, intrusion indicators and reports with NCA. - Collect and handle threat intelligence feeds.	Cybersecurity policy that covers the requirements of Cybersecurity Incident and Threat management requirements in the organization (e.g., electronic copy or official hard copy). Formal approval by the head of the organization or his/her deputy on such document (e.g., via the organization's official e-mail, paper or electronic signature).

				-Periodically review of cybersecurity incident response plan. • Support the organization's policy by the Executive Management. This must be done through the approval of the organization head or his/her deputy.	
2-13-2		The requirements for cybersecurity incidents and threat management must be implemented.		Implement cybersecurity requirements to Cybersecurity Incident and Threat management, including, but not limited to, the following: -Define a cybersecurity incident response plan. -Classify cybersecurity incidents by severity. -Define the roles and responsibilities for cybersecurity incident response and how to communicate with all stakeholders. -Define a mechanism for notifying the National Cybersecurity Authority in the event of a cybersecurity incident. -Share incidents notifications, threat intelligence, intrusion indicators and reports with NCA.	The approved cybersecurity incident response plan (electronic copy). A sample of a previous cybersecurity incident report. Cybersecurity incidents classification mechanism based on severity.

				-Collect and handle threat intelligence feeds. -Periodically review of cybersecurity incident response plan.	
2-13-3 The requirements for cybersecurity incidents and threat management must include at least the following:	2-13-3-1	Cybersecurity incident response plans and escalation procedures.	Event Management Plan Template. Event Management Procedure Template.	Define and document the requirements of this ECC in the cybersecurity requirements document and approve them by the representative. Develop cybersecurity incident response plans containing: -Define the types of accidents and their classification according to their level of severity on the organization's business. - Define the roles and responsibilities for cybersecurity incident response and how to communicate with all stakeholders. -Define communication channels and methods for emergencies. - Define a playbook for incident response that contains the following: *Classify the incident by its severity, the level of response required, and entities that should be involved in response activities.	A document (such as approved policy or procedure) indicating the identification and documentation of the requirements related to this control. The approved cybersecurity incident response plan (electronic copy). A sample of a previous cybersecurity incident report.

				* Report cybersecurity threats and incidents to the NCA. * Define workflow procedures for responding to cybersecurity incidents according to NCA's directions. - Develop cybersecurity incident report upon completion of the response including, but not limited to, the following: -Persons involved in responding to the incident and the means of communication. -The key information of the incident, including but not limited to, date and time, scope of incident, severity, etc. - Summary of the incident. -Containment and removal steps. -Current and future recommendations. -Review the response plan periodically and update it if necessary.	
	2-13-3-2	Cybersecurity incidents classification.		Define and document the requirements of this ECC in the cybersecurity requirements document and approve them by the representative.	A document (such as approved policy or procedure) indicating the identification and documentation of the requirements related to this control.

				Define the organization's cybersecurity incident classification mechanism and ensure its inclusion in the incident response policy and its alignment with the organization's risk classification mechanism. Classify incidents if they occur and determine the duration and mechanism of dealing with these incidents based on the adopted classification mechanism. Document that classification in the cybersecurity incident report.	Document that outlines the mechanism for classifying cybersecurity incidents according to sensitivity and risk level. Sample from a previous incident report showing incident and reporting classification.
	2-13-3-3	Cybersecurity incidents reporting to NCA.	Define and document the requirements of this ECC in the cybersecurity requirements document and approve them by the representative. Identify documented procedures to report to NCA in the event of a cybersecurity incident, including: -The roles and responsibilities for cybersecurity incident response and how to communicate with all stakeholders. -The key information of the incident, including but not limited to, date and time, scope of incident, severity, etc. -Summary of the incident.	A document (such as approved policy or procedure) indicating the identification and documentation of the requirements related to this control. Copy of the file of the procedures followed to report to NCA cybersecurity incidents. Sample of NCA's notification of a previous cybersecurity incident, including but not limited to a	

			Report to NCA the occurrence of a cybersecurity incident through NCA's approved channels, such as Haseen portal and/or the NCA official email for incident reporting "is@nca.gov.sa" and follow up on any updates and instructions that NCA may issue regarding incident reporting on an ongoing basis.	screenshot or direct example of the email sent to NCA.
	2-13-3-4	Sharing incidents notifications, threat intelligence, breach indicators and reports with NCA.	Define and document the requirements of this ECC in the cybersecurity requirements document and approve them by the representative. Identify documented procedures to share the following with NCA: -Alerts, threat intelligence, and penetration indicators that may increase the level of suspicion of a cybersecurity incident. -Cybersecurity incident reports after the incident has been dealt with. Share alerts, threat intelligence, penetration indicators, and incident reports with NCA through the official e-mail to register the information sharing membership "info@nca.gov.sa" and follow up on any updates and instructions that the Authority may issue on reporting alerts, threat intelligence, and penetration indicators on an ongoing basis.	A document (such as approved policy or procedure) indicating the identification and documentation of the requirements related to this control. Procedures followed to share alerts, threat intelligence, and penetration indicators with NCA (including but not limited to: a previous email through which the indicators report was sent to NCA). Sample of a cybersecurity incident report sent to NCA (including but not limited to a previous email through which a cybersecurity incident report was sent to NCA).
	2-13-3-5	Collecting and handling threat intelligence feeds.	Define and document the requirements of this ECC in the cybersecurity requirements document and approve them by the representative.	A document (such as approved policy or procedure) indicating the identification and

			Subscribe in platforms responsible for sending threat intelligence through email or other technical platforms. These platforms include: -Computer Emergency Response Team (Saudi CERT). - Haseen’s information sharing platform. -CITC’s newsletter. -Bulletins provided by cybersecurity companies. - Bulletins provided by security and technology service providers that have been previously contracted by the organization. Handle alerts sent by these platforms by: -Send alerts to the relevant team to deal with (including but not limited to: IT Department, Security Operations Center, update and vulnerability department). Set a time limit for handling these alerts based on the severity level. Continuously monitor to ensure that alerts sent to the relevant team have been handled in a secure manner (including but not limited to ensuring that the sent vulnerabilities patches are applied).	documentation of the requirements related to this control. Screenshot or direct example showing the organization’s subscription in a platform. Screenshot or direct example of alerts that have been dealt with in advance according to the necessary procedures.
2-13-4	The requirements for cybersecurity incidents and threat management must be reviewed periodically.	Review the cybersecurity requirements of cybersecurity incident and threat management by conducting a periodic assessment (according to a documented and approved plan for review, and based on a planned interval “e.g., quarterly”) to implement cybersecurity incident and threat management requirements by the Cybersecurity function and in	Results of Cybersecurity Incident and Threat management requirements implementation review in the organization. A document that defines the cybersecurity requirements	

		cooperation with relevant departments (such as IT Department). Conduct application review through traditional channels (e.g., email) or automated channels using a compliance management system. The organization may develop a review plan explaining the implementation review schedule for cybersecurity incident and threat management. Review and update cybersecurity requirements for cybersecurity incident and threat management in the organization periodically according to a documented and approved plan for review and based on a planned interval or in the event of changes in relevant laws and regulations. Document the review and changes to the cybersecurity requirements for cybersecurity incident and threat management in the organization and approve them by the head of the organization or his/her deputy.	implementation review cycle for cybersecurity incident and threat management within the organization (Compliance Assessment Schedule). Compliance assessment report that outlines the assessment of the implementation of cybersecurity requirements for cybersecurity incident and threat management.		
National Cybersecurity Authority – Organization Social Media Accounts Cybersecurity Controls OSMACC					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
2-7-1	2-7-1-1	Developing a plan to recover the organization’s social	• Template for Cybersecurity Incident	Define and document the recovery plan for the organization’s social media accounts for which the control of the account is lost by the	A documented and approved plan to recover the organization’s social media accounts.

		media accounts and to deal with cyber incidents.	Management and Threat Policy • Template for Cybersecurity Incident Management and Threat Standard • Guideline for Cybersecurity Incident Response • Templates for Cybersecurity Incident Response Detailed Plan.	organization due to any cybersecurity incident or otherwise. Ensure the following in the social media account recovery plan: - Contact information for the Cybersecurity Incident Response Team (IRT). - Timely notification to the Incident Response Team. - Documenting the incident after account recovery.	
National Cybersecurity Authority - Telework Cybersecurity Controls TCC					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
2-12-1 In addition to the sub-controls within control 2-13-3 in the ECC, cybersecurity requirements for incident	2-12-1-1	Updating cyber security incidents response plans and contact information within the organization in a way that is compatible with the telework situation and to ensure the ability to communicate and the	Cybersecurity Incident and Threat Management Policy Template. Cybersecurity Incident and Threat	Work on defining the requirements for this control, document them in the cybersecurity requirements document, and have them approved by the authority holder. Based on organization's cyber security incident and threat management policies, define and	Work on defining the requirements for this control, document them in the cybersecurity requirements document, and have them approved by the authority holder. Updated response plans for telework systems. Documented

and threat management related to telework systems shall include at least the following:		preparedness of the incident response teams.	Management Standards Template. Detailed plans templates for responding to cybersecurity incidents.	update response plans and relevant information for telework systems. Prepare and plan to run appropriate programs to communicate cyber incidents and threat management policies, to prevent mislead actions by telework users. Notify users about how to raise cyber incidents in case of suspected activity or actual event and to show preparedness of the organization's incident response team.	and approved plan to run campaigns to communicate cyber incident and threat management policies. Sample cyber incidents report raised by telework users.
	2-12-1-2	Periodically obtaining and dealing with threat intelligence information related to telework systems.	Cybersecurity Incident and Threat Management Policy Template. Cybersecurity Incident and Threat Management Standards Template.	Work to define the requirements of this control and document them in the cybersecurity requirements document and have them approved by the authority holder. Work to partner with the platforms responsible for sending proactive information (Threat Intelligence) via email or other technical platforms, and these platforms include:	Work on defining the requirements for this control, document them in the cybersecurity requirements document, and have them approved by the authority holder. A screenshot or direct evidence showing the entity's subscription to one of the platforms. A screenshot or live evidence of an example of alerts on telework

			Detailed plans templates for responding to cybersecurity incidents.	- Computer Emergency Response Team (CERT). - Haseen's information sharing platform. - Newsletter of the communication and information technology authority. - Bulletins or announcements provided by companies specialized in cybersecurity. -Bulletins or announcements provided by security and technical service providers that were previously contracted by the entity. Work to deal with alerts sent by these platforms through: - Send it to the relevant team to deal with it (for example, but not limited to: the Information Technology Department, the Security Operations Center, the Department for Updates and Repairs). -Determine a period of time for dealing with these alerts according to the level of severity. - Continuous follow-up to ensure that the alerts sent to the relevant team have been dealt with securely	systems that were previously dealt with according to the necessary procedures.
--	--	--	--	---	---

				(for example, but not limited to: ensuring that the update for the vulnerabilities sent has been applied).	
	2-12-1-3	Addressing and implementing the recommendations and alerts for cyber security incidents and threats issued by the Sector regulator or by the National Cybersecurity Authority (NCA).	Cybersecurity Incident and Threat Management Policy Template. Cybersecurity Incident and Threat Management Standards Template. Detailed plans templates for responding to cybersecurity incidents.	Work to define the requirements of this control and document them in the cybersecurity requirements document, and have them approved by the authority holder. Develop a mechanism to continuously receive information from proactive information platforms and information issued by the National Authority. Develop, adopt and implement a mechanism to address incoming recommendations for cyber alerts/incidents/threats. Communicate identified cyber risks/threats/incidents with the Cyber Security team and Risk Committee to ensure proactive decision making to minimize impact on operational processes.	Work on defining the requirements for this control, document them in the cybersecurity requirements document, and have them approved by the authority holder. An approved document to address recommendations related to incidents and threats by the sector supervisor or the National Cybersecurity Authority. A document for the process of reporting cyber incidents/threats to the organization's cyber security team and dealing with them.
National Cybersecurity Authority – Operational Technology Cybersecurity Controls OTCC					

Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
2-12-1 In addition to subcontrols in the ECC Control 2-13-3, cybersecurity requirements for cybersecurity incident and threat management in OT/ICS must include, at a minimum, the following:	2-12-1-1	OT/ICS cybersecurity incident response plans must be integrated and aligned with organizational plans and its procedures such as IT incident response plans, crisis management, and Business Continuity Plan (BCP).	Template for Cybersecurity Operational Technology Policy. Template for OT/ICS Security Standard. Template for Cybersecurity Incident and Threat Management Policy. Template for Cybersecurity Incident and Threat Management Standard. Guideline for Cybersecurity Incident Response.	Define, document, and approve OT/ICS cybersecurity incident response plans. Approved plans should be formally documented (e.g. as a procedure) based on existing and globally available standards. Include approved OT/ICS cybersecurity incident response plans into the general organizational plans and its procedures. Verify and ensure that OT/ICS cybersecurity incident response plans are integrated and aligned with other organizational plans and procedures.	Documented OT/ICS cybersecurity incident response plans. A proof that shows the approved OT/ICS cybersecurity incident response plans are integrated and aligned with organizational plans and its procedures.

			Templates for Cybersecurity Incident Response Detailed Plan.		
	2-12-1-2	Formal incident response and root cause analysis for any detected cybersecurity incidents must be conducted.	Template for Cybersecurity Operational Technology Policy. Template for OT/ICS Security Standard. Template for Cybersecurity Incident and Threat Management Policy. Template for Cybersecurity Incident and Threat Management Standard.	Define and formally document a root cause analysis procedure and methodologies in case of any detected cybersecurity incidents. Implement developed OT/ICS cybersecurity incident response plans and handle the incidents according to the stages specified in the plan. Conduct defined incident analysis and root cause analysis in case of cybersecurity incident detection.	A documented root cause analysis procedure and methodologies. Prepared incident response and root cause analysis reports. A proof that the incident response and root cause analysis is conducted for all detected cybersecurity incidents.

			Guideline for Cybersecurity Incident Response.		
			Templates for Cybersecurity Incident Response Detailed Plan.		
	2-12-1-3	Sequence of incident response activities necessary to restore normal operations must be defined.	Template for Cybersecurity Operational Technology Policy. Template for OT/ICS Security Standard. Template for Cybersecurity Incident and Threat Management Policy. Template for Cybersecurity Incident and	Define, document, and approve the sequence of incident response activities necessary to restore normal operations, and approved activities should be formally documented (e.g. as an activity plan or procedure). Define and formally document operations restoration action plan. Containing a detailed step-by-step description and a manual. Verify and ensure that in case of an operation breach the restoration plan is performed.	A documented and approved sequence of incident response activities necessary to restore normal operations. A documented restoration action plan when encountering a cybersecurity incident. A proof that ensures the restoration of normal operations when encountering a cybersecurity incident.

			Threat Management Standard. Guideline for Cybersecurity Incident Response. Templates for Cybersecurity Incident Response Detailed Plan.		
	2-12-1-4	Incident communications plan must be established.	Template for Cybersecurity Operational Technology Policy. Template for OT/ICS Security Standard. Template for Cybersecurity Incident and Threat Management Policy.	Define and formally document an incident communications plan in case of incidents. Verify and ensure that the incident communications plan is implemented if an incident occurred.	A documented incident communication plan. A proof that the incident communications plan is implemented in case of incidents.

			Template for Cybersecurity Incident and Threat Management Standard. Guideline for Cybersecurity Incident Response. Templates for Cybersecurity Incident Response Detailed Plan.		
	2-12-1-5	OT/ICS including Safety Instrumented Systems (SIS) recovery procedures must be included in the incident response, system recovery plans, and business continuity plans.	Template for Cybersecurity Operational Technology Policy. Template for OT/ICS Security Standard. Template for Policy and	Ensure the OT/ICS /critical assets including Safety Instrumented Systems (SIS) recovery procedures are included in the incident response, system recovery, and business continuity plans.	Documented recovery procedures for OT/ICS environment. Documented incident response plans for OT/ICS environment. Documented business continuity plans for OT/ICS environment.

			Cybersecurity Incident and Threat Management. Template for Cybersecurity Incident and Threat Management Standard. Guideline for Cybersecurity Incident Response. Templates for Cybersecurity Incident Response Detailed Plan.		
	2-12-1-6	Trainings and skillsets for the organization's personnel (including employees, contractors and subcontractors) to respond to OT/ICS cybersecurity incidents must be provided.	Template for Cybersecurity Operational Technology Policy.	Train personnel within the organization in the required skills and courses (including employees and contractors) to respond to cybersecurity incidents related to OT/ICS.	A documented list of the organization's personnel embraced by the OT/ICS cybersecurity incidents response training program. A proof confirming the provision of all personnel within the

			Template for OT/ICS Security Standard. Template for Cybersecurity Incident and Threat Management Policy. Template for Cybersecurity Incident and Threat Management Standard.		organization with the required skills and courses (including employees and contractors) to respond to cybersecurity incidents related to OT/ICS.
	2-12-1-7	Cybersecurity incident response capabilities, readiness, and plan must be periodically tested by performing cyber-attack simulations exercises.	Template for Cybersecurity Operational Technology Policy. Template for OT/ICS Security Standard. Template for Cybersecurity Incident and	Ensure the cybersecurity incident response capabilities, readiness, and plan are periodically tested by performing cyber-attack simulations exercises (such as drills, tabletop exercises).	A documented list of cyber-attack simulations exercises (such as cybersecurity drills and tabletop exercises). A proof that cybersecurity incident response capabilities, readiness, and plan are periodically tested.

			Threat Management Policy. Template for Cybersecurity Incident and Threat Management Standard.		
	2-12-1-8	Threat Intelligence information must be used to identify Tactics, Techniques, and Procedures (TTPs) of activity groups targeting OT/ICS systems.	Template for Cybersecurity Operational Technology Policy. Template for OT/ICS Security Standard. Template for Cybersecurity Incident and Threat Management Policy. Template for Cybersecurity Incident and	Gather and document Threat Intelligence information and use it to identify Tactics, Techniques, and Procedures (TTPs) of activity groups targeting OT/ICS systems. Verify and ensure Threat Intelligence is up-to-date.	A documented Threat Intelligence report. A proof that shows the Threat Intelligence information is used to identify Tactics, Techniques, and Procedures (TTPs) of activity groups targeting OT/ICS systems.

			Threat Management Standard.		
2-12-2	With reference to the ECC control 2-13-4, the cybersecurity requirements for cybersecurity incident and threat management in OT/ICS environment must be reviewed, and their implementation effectiveness is measured and evaluated periodically.		Template for Cybersecurity Operational Technology Policy. Template for OT/ICS Security Standard. Template for Cybersecurity Incident and Threat Management Policy. Template for Key Performance Indicator Report.	Review the cybersecurity requirements for cybersecurity incident and threat management within the OT/ICS environment periodically based on a documented and approved review plan and on a defined frequency (e.g., conduct a review annually). Develop key performance indicators (KPIs) for each control within the related policy or procedure to ensure the implementation effectiveness is measured and evaluated periodically based on a defined frequency (e.g., conduct a review annually).	A proof that shows the periodic review of cybersecurity requirements for incident and threat management within the OT/ICS environment. A proof that shows the key performance indicators (KPIs) for each control within the related policy or procedure to ensure the implementation effectiveness is measured and evaluated periodically (based on a defined frequency).
National Cybersecurity Authority - Cloud Cybersecurity Controls CCC					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
2-12-P-1 In addition to sub controls in	2-12-P-1-1	Subscribing in authorized and specialized organizations and	Template for Cybersecurity Incident and	Select trusted external threat intelligence vendors (e.g. OSINT).	List of trusted external threat intelligence vendors.

the ECC control 2-13-3, the CSP shall cover the following additional sub controls for cybersecurity requirements for cybersecurity incident and threat management, as a minimum:		groups to stay up-to-date on cybersecurity threats, common practices and key know-how.	Threat Management Policy. Template for Cybersecurity Incident and Threat Management Standards. Cybersecurity Incident Response Guidelines. Template for Cybersecurity Incident Response Detailed Plan.	Monitor publications issued by the National Cybersecurity Authority (NCA) and relevant trusted authorities. Analyze threat intelligence feeds and services for risks relevant to the CSP. Confirm common and best practices in Threat Management with external cybersecurity advisors and consultants.	Cybersecurity threat intelligence. Knowledgebase of common and best practices in cybersecurity.
	2-12-P-1-2	Training for employees and third-party personnel to respond to cybersecurity incidents, in line with their roles and responsibilities.	Template for Cybersecurity Incident and Threat Management Policy. Template for Cybersecurity	Establish a cybersecurity training program for employed and contracted personnel. Train personnel in cybersecurity incident reporting and handling based on their roles and responsibilities (e.g.: what is a	Cybersecurity training program aligned with roles and responsibilities of the target groups. Sample of training certificates/attendance.

			Incident and Threat Management Standards. Cybersecurity Incident Response Guidelines. Template for Cybersecurity Incident Response Detailed Plan.	cybersecurity incident and how to report it). Align the training program with roles and responsibilities of various groups.	
	2-12-P-1-3	Periodically testing the incident response capability.	Template for Cybersecurity Incident and Threat Management Policy. Template for Cybersecurity Incident and Threat Management Standards. Cybersecurity Incident	Schedule regular reviews of incident response plans. Define testing methodology and use appropriate testing method (e.g.: table top exercise, walkthrough, cut-over, incident simulation). Make a Lesson Learnt a mandatory phase of testing methodology.	Incident response plan / procedure test schedule. Report outlining the methodology for testing the cybersecurity incident response capabilities. Lesson Learnt records.

			Response Guidelines. Template for Cybersecurity Incident Response Detailed Plan.		
	2-12-P-1-4	Root Cause Analysis of cybersecurity incidents and developing plans to address them.	Template for Cybersecurity Incident and Threat Management Policy. Template for Cybersecurity Incident and Threat Management Standards. Cybersecurity Incident Response Guidelines. Template for Cybersecurity Incident	Make a Root Cause Analysis a mandatory phase of Incident Response to improve Incident Response Plans. Gather, analyze, prioritize and address conclusions of Root Cause Analyses.	Root Cause Analysis is a mandatory part of Incident Response. Root Cause Analysis conclusions are prioritized and addressed. Incident Response Plan is constantly improved based on Root Cause Analysis conclusions. Sample of root cause analysis.

			Response Detailed Plan.		
	2-12-P-1-5	Support the CST in cases legal proceedings and forensics, protecting the chain of custody that falls under the management and responsibility of the CSP, in accordance with the related law and regulatory requirements.	Template for Cybersecurity Incident and Threat Management Policy. Template for Cybersecurity Incident and Threat Management Standards. Cybersecurity Incident Response Guidelines. Template for Cybersecurity Incident Response Detailed Plan.	Analyze legal and regulatory requirements for CSTs. Build legal and forensics capabilities to support CSTs in their legal obligations relevant to cloud services. Build a process to track movement of evidence and ensure integrity of evidence during that movement and at rest.	Evidence demonstrating the knowledge and understanding of legal and regulatory requirements for CSTs. Legal and forensics capabilities are built. Movement of evidence are tracked, and their integrity ensured.
	2-12-P-1-6	Real-time reporting to the CST of incidents that may affect CST; if the incident is discovered.	Template for Cybersecurity Incident and Threat	Analyze identified incidents for their impact on CSTs (e.g. how CST is using the impacted service).	Impact on CSTs is analyzed for all identified incidents.

			Management Policy. Template for Cybersecurity Incident and Threat Management Standards. Cybersecurity Incident Response Guidelines. Template for Cybersecurity Incident Response Detailed Plan.	Report such incidents immediately to CSTs with sufficient information to analyze related risks and track Incident Response on CSP side.	Incidents impacting CSTs are immediately reported to CSTs with sufficient information. Sample of incidents reported to CST.
	2-12-P-1-7	Support for CSTs to handle security incidents according to the agreement between the CSP and CST.	Template for Cybersecurity Incident and Threat Management Policy. Template for Cybersecurity Incident and	Align incident handling process across CSP and CST before serving services (e.g.: Incident Response systems integration). Report immediately to CSTs incidents (that impact them) with sufficient information to analyze related risks and correlate incident response on the CST side.	Incident handling process agreed between CSP and CST and formally recognized in contract. Process of reporting to CSTs incidents impacting them established.

			Threat Management Standards. Cybersecurity Incident Response Guidelines. Template for Cybersecurity Incident Response Detailed Plan.		
	2-12-P-1-8	Measuring and monitoring cybersecurity incident metrics and monitor compliance with contracts and legislative requirements.	Template for Cybersecurity Incident and Threat Management Policy. Template for Cybersecurity Incident and Threat Management Standards. Cybersecurity Incident	Define contractual and legislative requirements for Cybersecurity Incident Management. Establish cybersecurity incident (compliance and effectiveness) metrics in form of KPI, KCI (e.g.: Mean Time to Detect, Mean Time to Response, Mean Time to Contain). Test the metrics. Formally approve the metrics by authorized person.	Contractual and legislative requirements register. Formally approved and tested cybersecurity incident metrics (KPI, KCI). Metrics dashboards and compliance reports. Records from dashboards and compliance reports review. Sample of dashboard and compliance report.

			Response Guidelines. Template for Cybersecurity Incident Response Detailed Plan; Template for Key Performance Indicator (KPIs) report.	Establish dashboards and compliance reports to report the metrics. Periodically review the dashboards and compliance reports.	
SAMA Cyber Security Framework CSF					
Control reference number	Control clauses		Control implementation guidelines		Expected deliverables
3.3.15 -1 (Incident Management)	The cyber security incident management process should be defined, approved, implemented and aligned with the enterprise incident management process.		This control requires the establishment of a formal, documented process for managing cyber security incidents. This process should be aligned with the overall enterprise incident management process, ensuring a coordinated and consistent approach to incident response. Define a formal process for managing cyber security incidents, document it thoroughly, obtain necessary approvals, and implement the process. Ensure alignment with the enterprise incident management process.		Documented cyber security incident management process. Evidence of alignment with enterprise incident management.
3.3.15 -2	The effectiveness of the cyber security controls within the cyber security		This control emphasizes the importance of ongoing monitoring and assessment. Organizations need to		Reports on cyber security incident management process

	incident management process should be measured and periodically evaluated.	track the performance of their cyber security incident management process and regularly evaluate its effectiveness. This might involve using metrics such as the number of incidents detected, the time taken to resolve incidents, and the impact of incidents on the organization. Define metrics to track the performance of the cyber security incident management process. Regularly assess the effectiveness of the process using these metrics and make adjustments as needed.	performance. Documentation of periodic evaluations.
3.3.15 -3	The standard should address the mandatory and suspicious security events which should be responded to.	This control requires the establishment of a standard that defines the mandatory and suspicious security events that should trigger a response. This standard helps to ensure that all significant security events are identified and addressed promptly. Define and document a standard that outlines the mandatory and suspicious security events that require a response.	Documented standard for security event response.
3.3.15 -4 The security incident management process should include requirements for:	a- the establishment of a designated team responsible for security incident management;	This sub-control mandates the establishment of a dedicated team responsible for managing security incidents. Establish a dedicated team responsible for security incident management.	Evidence of incident management team establishment.
	b- skilled and (continuously) trained staff;	This sub-control emphasizes the importance of having skilled personnel who receive continuous training on security incident management and response.	Incident management team training records.

		Ensure that the incident management team consists of skilled personnel who receive continuous training on security incident management and response.	
	c- sufficient capacity available of certified forensic staff for handling major incidents (e.g., internal staff or contracting an external forensic team);	This sub-control requires ensuring that there is sufficient capacity of certified forensic staff available to handle major security incidents. This might involve having internal forensic staff or contracting an external forensic team. Ensure sufficient capacity of certified forensic staff to handle major security incidents.	Evidence of forensic staff capacity.
	d- a restricted area to facilitate the computer emergency response team (CERT) workspaces;	This sub-control requires providing a dedicated and secure workspace for the computer emergency response team (CERT) to conduct their activities. Provide a dedicated and secure workspace for the CERT.	A dedicated and secure workspace for the CERT
	e- the classification of cyber security incidents;	This sub-control mandates the classification of cyber security incidents based on their severity and potential impact. Develop a classification system for cyber security incidents.	Documented incident classification system.
	f- the timely handling of cyber security incidents, recording and monitoring progress;	This sub-control requires the timely handling of cyber security incidents, including recording and monitoring the progress of incident response. Establish procedures for the timely handling of cyber security incidents, including recording and monitoring progress.	Incident handling procedures.

	g- the protection of relevant evidence and loggings;	This sub-control requires the protection of relevant evidence and logs related to security incidents. Implement measures to protect evidence and logs related to security incidents.	Evidence of evidence and log protection measures.
	h- post-incident activities, such as forensics, root-cause analysis of the incidents;	This sub-control mandates the conduct of post-incident activities, such as forensic analysis and root cause analysis, to learn from security incidents and improve incident response capabilities. Establish procedures for conducting post-incident activities, such as forensics and root cause analysis.	Post-incident procedures.
	i- reporting of suggested improvements to the CISO and the Committee;	This sub-control requires reporting suggested improvements to the CISO and the relevant committee, such as the security committee or audit committee. Establish a process for reporting suggested improvements to the CISO and the relevant committee.	
	j- establish a cyber security incident repository.	This sub-control requires the establishment of a cyber security incident repository to store information about security incidents, including incident details, response actions, and lessons learned. Establish a cyber security incident repository.	Evidence of incident repository establishment.
3.3.15 -5	The Member Organization should inform 'SAMA IT Risk Supervision' immediately when a medium or high	This control requires the prompt notification of SAMA IT Risk Supervision in the event of a medium or high classified security incident.	Cybersecurity Incident Management policy/standard/template.

	classified security incident has occurred and identified.	Establish a process for immediately informing SAMA IT Risk Supervision of medium or high classified security incidents.	
3.3.15 -6	The Member Organization should obtain 'no objection' from 'SAMA IT Risk Supervision' before any media interaction related to the incident.	This control requires obtaining approval from SAMA IT Risk Supervision before any media interaction related to a security incident. Establish a process for obtaining approval from SAMA IT Risk Supervision before any media interaction related to a security incident.	Cybersecurity Incident Management policy/standard/template.
3.3.15 -7	The Member Organization should submit a formal incident report 'SAMA IT Risk Supervision' after resuming operations, including the following incident details: a-title of incident. b-classification of the incident (medium or high); c-date and time of incident occurred. d-date and time of incident detected. e-information assets involved. f-(technical) details of the incident. g-root-cause analysis. h-corrective activities performed and planned.	This control requires the submission of a formal incident report to SAMA IT Risk Supervision after resuming operations following a security incident. The report should include specific details about the incident. Develop a template for the formal incident report and establish a process for submitting it to SAMA IT Risk Supervision after resuming operations.	Incident report template.

	i-description of impact (e.g., loss of data, disruption of services, unauthorized modification of data, (un)intended data leakage, number of customers impacted). j-total estimated cost of incident. k-estimated cost of corrective actions.		
3.3.16-1 (Threat Management)	The threat intelligence management process should be defined, approved and implemented.	This control requires the establishment of a formal, documented process for managing threat intelligence. This process should be approved by the appropriate authority within the organization and actively put into practice. Define a formal process for managing threat intelligence, document it thoroughly, obtain necessary approvals, and implement the process.	Documented threat intelligence management process. Evidence of approval.
3.3.16-2	The effectiveness of the threat intelligence management process should be measured and periodically evaluated.	This control emphasizes the importance of ongoing monitoring and assessment. Organizations need to track the performance of their threat intelligence management process and regularly evaluate its effectiveness. This might involve using metrics such as the number of threats identified and the time taken to respond to them. Define metrics to track the performance of the threat intelligence management process. Regularly assess the effectiveness of the process using these metrics and make adjustments as needed.	Reports on threat intelligence management process performance. Documentation of periodic evaluations.

3.3.16-3 The threat intelligence management process should include:	a- the use of internal sources, such as access control, application and infrastructure logs, IDS, IPS, security tooling, Security Information and Event Monitoring (SIEM), support functions (e.g., Legal, Audit, IT Helpdesk, Forensics, Fraud Management, Risk Management, Compliance);	This sub-control requires the use of internal sources of threat intelligence, such as logs from various security systems, security tools, and support functions. Utilize internal sources of threat intelligence, such as access control logs, application logs, infrastructure logs, IDS/IPS logs, security tool logs, SIEM data, and information from support functions.	An approved threat intelligence management process document.
3.3.16-3	b- the use of reliable and relevant external sources, such as SAMA, government agencies, security forums, (security) vendors, security organizations and specialist notification services;	This sub-control requires the use of reliable and relevant external sources of threat intelligence, such as information from SAMA, government agencies, security forums, security vendors, and security organizations. Utilize reliable and relevant external sources of threat intelligence, such as information from SAMA, government agencies, security forums, security vendors, and security organizations.	
3.3.16-3	c- a defined methodology to analyze the threat information periodically;	This sub-control requires the establishment of a defined methodology for analyzing threat information on a periodic basis. Define and implement a methodology for analyzing threat information periodically.	Documented threat analysis methodology.
3.3.16-3	d- the relevant details on identified or collected threats, such as modus operandi, actors, motivation and type of threats;	This sub-control requires the collection and analysis of relevant details about identified or collected threats, such as their modus operandi, the actors involved, their motivation, and the type of threats.	Threat intelligence repository with detailed threat information.

		Collect and analyze relevant details about identified or collected threats, such as their modus operandi, the actors involved, their motivation, and the type of threats.	
3.3.16-3	e- the relevance of the derived intelligence and the action-ability for follow-up (for e.g., SOC, Risk Management);	This sub-control requires assessing the relevance of the derived threat intelligence and its actionability for follow-up activities, such as those performed by the SOC or Risk Management. Assess the relevance of derived threat intelligence and its actionability for follow-up activities.	
3.3.16-3	f- sharing the relevant intelligence with the relevant stakeholders (e.g., SAMA, BCIS members).	This sub-control requires sharing relevant threat intelligence with appropriate stakeholders, such as SAMA and BCIS members. Establish a process for sharing relevant threat intelligence with appropriate stakeholders.	Evidence of threat intelligence sharing with stakeholders.
CST CRF			
Control reference number	Control clauses	Control implementation guidelines	Expected deliverables
4.9.1 CL1	Define and document [Requirements for Incident Management] which consider the following: • Incident definition, identification and classification, prioritization, and response • Incident reporting structure • Testing the incident response process • Evidence collection	This control highlights the importance of establishing and documenting clear requirements for incident management. These requirements should cover various aspects of incident handling, including defining what constitutes an incident, how to identify and classify incidents, prioritize them, and respond to them effectively. Additionally, it should include guidelines for incident reporting, testing the incident response process, collecting evidence, and	Documented incident management requirements.

	• Learning from information security incidents	incorporating lessons learned from past incidents to improve future response capabilities. Define and document comprehensive requirements for incident management, addressing incident definition, identification, classification, prioritization, response, reporting structure, testing procedures, evidence collection, and learning from incidents.	
4.9.2 CL1	Define and implement an {Incident Response} process considering: • Incident detection by analyzing reported events [Logging and Monitoring] • Incident classification based on predefined criteria as specified in the requirements • Respond to the cybersecurity incidents (contain, eradicate, and recover) within the organization defined timeframes [Change Management] • Prepare the [Incident Report] and lessons learned • Report cybersecurity incidents with appropriate details to CST	This control focuses on establishing and implementing a formal incident response process. This process should include mechanisms for detecting incidents by analyzing reported events and logs, classifying incidents based on predefined criteria, responding to incidents in a timely and effective manner, preparing incident reports, and documenting lessons learned. It also emphasizes the importance of reporting cybersecurity incidents to the Cloud Security Tenant (CST) with appropriate details. Define and implement a formal incident response process that includes incident detection, classification, response, reporting, and lessons learned. Ensure that cybersecurity incidents are reported to the CST with appropriate details.	Documented incident response process. Incident reports. Lessons learned documentation.
4.9.3 CL1	Conduct regular trainings to test the Incident Response process for its effectiveness (e.g. testing communication channels, response times).	This control emphasizes the importance of regular training and testing to ensure the effectiveness of the incident response process. This includes testing communication channels, response times, and other	Training records. Test results and reports.

		aspects of the incident response plan to identify areas for improvement. Conduct regular training and testing of the incident response process to evaluate its effectiveness and identify areas for improvement.	
4.9.4 CL2	Enhance and implement the [Requirements for Incident Management] to use incident management tools to automate the process and integrate with other relevant systems for increasing efficiency.	This control recommends enhancing the incident management process by utilizing incident management tools to automate tasks and integrate with other relevant systems. This can help improve the efficiency and effectiveness of incident response. Evaluate and implement incident management tools to automate the incident management process and integrate with other relevant systems.	Evidence of incident management tool implementation and integration.
4.9.5 CL2	Gather threat intelligence and use it during the analysis of the information security events.	This control encourages the use of threat intelligence to inform and improve the analysis of information security events. Threat intelligence can provide valuable context and insights into potential threats, helping to identify and respond to incidents more effectively. Integrate threat intelligence feeds and platforms into the incident analysis process.	Utilization of threat intelligence feeds during the incident.
4.9.6 CL2	Establish a forensic team to investigate the information security incidents.	This control requires the establishment of a dedicated forensic team to investigate information security incidents. This team is responsible for conducting in-depth investigations to determine the root cause of incidents, gather evidence, and support recovery efforts.	Evidence of forensic team establishment.

		Establish a dedicated forensic team with the necessary skills and expertise to investigate information security incidents.	
4.9.7 CL2	Identify, collect, and preserve the evidences of the information security incidents. Use the knowledge gained from the information security incidents to reduce the probability and impact of future incidents.	This control emphasizes the importance of proper evidence handling during incident response. This includes identifying, collecting, and preserving evidence related to security incidents. Additionally, it highlights the need to learn from past incidents to improve future security posture and reduce the likelihood and impact of similar incidents. Develop and implement procedures for identifying, collecting, and preserving evidence related to information security incidents. Use the knowledge gained from incident investigations to improve security controls and reduce the risk of future incidents.	Documented evidence handling procedures. Evidence of lessons learned implementation.
4.9.8 CL3	Continuously measure, review and optimize the [Requirements for Incident Management] as well as the effectiveness of the process.	This control stresses the importance of continuous improvement in incident management. Organizations should regularly measure and review the effectiveness of their incident management processes and make adjustments as needed to ensure they remain aligned with their security objectives and risk tolerance. Establish a process for continuously measuring, reviewing, and optimizing the incident management requirements and the overall effectiveness of the incident management process.	Reports on the measurement and review of incident management requirements and process effectiveness. Documentation of optimization efforts.
CMA Cybersecurity Guidelines			

Control reference number	Control clauses	Control implementation guidelines	Expected deliverables
4.3.7-1	Develop, document, approve and implement cybersecurity Incident Management Process and align the same with Incident Management Procedures followed by the market institution.	This control requires establishing a formal, documented process for managing cybersecurity incidents. This process should be aligned with the overall incident management procedures followed by the market institution, ensuring a coordinated and consistent approach to incident response. Define a formal process for managing cybersecurity incidents, document it thoroughly, obtain necessary approvals, and implement the process. Ensure alignment with the incident management procedures followed by the market institution.	Documented cybersecurity incident management process. Evidence of alignment with market institution procedures.
4.3.7-2	Disaster recovery plan includes different scenarios of cybersecurity incidents.	This control requires that the disaster recovery plan includes various scenarios related to cybersecurity incidents. This ensures that the organization is prepared to handle different types of cybersecurity incidents and can recover effectively from them. Ensure that the disaster recovery plan includes different scenarios related to cybersecurity incidents.	Disaster recovery plan with cybersecurity incident scenarios.
4.3.7-3	Measure and periodically evaluate effectiveness of cybersecurity controls under Cybersecurity incident management process.	This control emphasizes the importance of ongoing monitoring and assessment. Organizations need to track the performance of their cybersecurity incident management process and regularly evaluate its effectiveness. This might involve using metrics such as the number of incidents detected, the time taken to	Reports on cybersecurity incident management process performance. Documentation of periodic evaluations.

		resolve incidents, and the impact of incidents on the organization. Define metrics to track the performance of the cybersecurity incident management process. Regularly assess the effectiveness of the process using these metrics and make adjustments as needed.	
4.3.7-4	Cybersecurity incident management controls shall include:	This control outlines the key components that should be part of a comprehensive cybersecurity incident management process. Ensure that the cybersecurity incident management process includes the following:	
	1- A team in charge of cybersecurity incident management.	This sub-control mandates the establishment of a dedicated team responsible for managing cybersecurity incidents. Establish a dedicated team responsible for cybersecurity incident management.	Evidence of incident management team establishment.
	2- Provision of well-qualified employees and trainers.	This sub-control emphasizes the importance of having skilled personnel who are well-trained in cybersecurity incident management and response. Ensure that the incident management team consists of well-qualified employees and trainers.	Incident management team training records.
	3- Restricted area for Cybersecurity Emergency Response Team (CERT).	This sub-control requires providing a dedicated and secure workspace for the Cybersecurity Emergency Response Team (CERT) to conduct their activities.	

		Provide a dedicated and secure workspace for the CERT.	
	4- Setting response plan for security incidents and escalation mechanisms.	This sub-control requires establishing a response plan for security incidents, including escalation mechanisms to ensure that incidents are handled promptly and effectively. Develop a response plan for security incidents, including escalation mechanisms.	Documented response plan with escalation mechanisms.
	5- Classifying of Cybersecurity incidents.	This sub-control mandates the classification of cybersecurity incidents based on their severity and potential impact. Develop a classification system for cybersecurity incidents.	Documented incident classification system.
	6- Addressing Cybersecurity incidents in a timely manner, following-up, and monitoring the progress made.	This sub-control requires the timely handling of cybersecurity incidents, including following up on their progress and monitoring their resolution. Establish procedures for the timely handling of cybersecurity incidents, including following up on their progress and monitoring their resolution.	Incident handling procedures.
	7- Protecting related evidence and records.	This sub-control requires the protection of relevant evidence and records related to cybersecurity incidents. Implement measures to protect evidence and records related to cybersecurity incidents.	Evidence of evidence and record protection measures.
	8- Criminal analysis of cybersecurity incidents.	This sub-control requires conducting criminal analysis of cybersecurity incidents to determine their root	

		cause, identify the attackers, and gather evidence for potential legal action. Establish procedures for conducting criminal analysis of cybersecurity incidents.	
	9- Maintaining cybersecurity incidents record.	This sub-control requires maintaining a record of cybersecurity incidents, including incident details, response actions, and lessons learned. Establish a cybersecurity incident repository.	Evidence of incident repository establishment.
4.3.7-5	Coordinating with CMA before any media action concerning the security incident.	This control requires coordinating with competent authorities, such as the Capital Market Authority (CMA), before any media interaction related to a security incident. Establish a process for coordinating with CMA before any media action concerning the security incident.	A cybersecurity incident communication plan/procedure.
4.3.7-6	Report National Cybersecurity Authority of CMA immediately after occurrence/detection of any incident.	This control requires reporting any security incident to the National Cybersecurity Authority (NCA) and CMA immediately after its occurrence or detection. Establish a process for immediately reporting security incidents to NCA and CMA.	
4.3.7-7	Provide official report on security incident to CMA after resuming operation including the following details:	This control requires submitting a formal incident report to CMA after resuming operations following a security incident. The report should include specific details about the incident.	Incident report template.

		Develop a template for the formal incident report and establish a process for submitting it to CMA after resuming operations.	
	1 Name of Cybersecurity incident.	This sub-control requires including the name of the incident in the formal incident report.	
	2 Classification of Cybersecurity incident (mild or severe).	This sub-control requires specifying the classification of the incident (mild or severe) in the formal incident report.	
	3 Date and time of Cybersecurity incident.	This sub-control requires including the date and time the incident occurred in the formal incident report.	
	4 Date and time when the Cybersecurity incident is detected.	This sub-control requires including the date and time the incident was detected in the formal incident report.	
	5 Information assets affected.	This sub-control requires listing the information assets affected by the incident in the formal incident report.	
	6 Technical details of Cybersecurity incident.	This sub-control requires providing technical details about the incident in the formal incident report.	
	7 Analysis of reasons and motivations.	This sub-control requires analyzing the reasons and motivations behind the incident and including the findings in the formal incident report.	
	8 Taken and planned remedial procedures.	This sub-control requires detailing the remedial procedures that were taken and those planned in response to the incident in the formal incident report.	
	9 Description of damage caused (e.g. data loss, services failure, unauthorized modification and intended and	This sub-control requires describing the damage caused by the incident, such as data loss, service disruption, unauthorized data modification, data leakage, and the number of customers impacted, in the formal incident report.	

	unintended data leakage and the number of affected customers).		
	10 Total cost estimated for the Cybersecurity incident.	This sub-control requires including the total estimated cost of the incident in the formal incident report.	
	11 Estimated cost for corrective procedures.	This sub-control requires including the estimated cost of corrective procedures in the formal incident report.	
	12 The report shall be sent to following mail: Cyber.Incident@cma.org.sa	This sub-control specifies the email address to which the formal incident report should be sent.	
4.3.9-1	Define, document, approve and implement Cybersecurity Threats Management process.	This control requires establishing a formal, documented process for managing cybersecurity threats. This process should be defined clearly, documented thoroughly, and approved by the appropriate authority. Once approved, it should be implemented effectively across the organization. Define a formal process for managing cybersecurity threats, document it thoroughly, obtain necessary approvals, and implement the process effectively.	Documented cybersecurity threat management process. Evidence of process implementation.
4.3.9-2	Periodically measure and evaluate effectiveness of Cybersecurity Threats Management process.	This control emphasizes the importance of ongoing monitoring and assessment of the threat management process. Organizations need to track the performance of their cybersecurity threat management process and regularly evaluate its effectiveness. This might involve using metrics such as the number of threats identified, the time taken to respond to threats, and the impact of threats on the organization. Define metrics to track the performance of the cybersecurity threat management process. Regularly	Reports on cybersecurity threat management process performance. Documentation of periodic evaluations.

		assess the effectiveness of the process using these metrics and make adjustments as needed.	
4.3.9-3	Cybersecurity Threats Management process shall include the following:	This control outlines the key components that should be part of a comprehensive cybersecurity threat management process.	
	1 Using the internal sources, such as access and applications control, infrastructure records, Intrusion Detection System (IDS), Intrusion Prevention System (IPS), security tools and SEIM in addition to the supporting department (such as Legal and Audit, Technical Support, Criminal Investigation, Anti-fraud and Compliance and Risk Departments).	This sub-control highlights the importance of leveraging internal sources of information for threat management. This includes data from access controls, application logs, infrastructure records, security tools like IDS/IPS and SIEM, as well as information from various departments within the organization.	Evidence of internal threat intelligence sources being used (e.g., log analysis reports, security tool reports, incident reports from various departments).
	2 Utilizing reliable external sources that are related to threat intelligence, such as government entities and security service providers.	This sub-control emphasizes the need to incorporate external threat intelligence into the threat management process. Organizations should utilize information from trusted sources like government agencies and security service providers to gain insights into the latest threats and vulnerabilities. Establish procedures for gathering and incorporating threat intelligence from reliable external sources.	List of trusted external threat intelligence sources. Evidence of external threat intelligence being used (e.g., threat intelligence reports, security advisories).
	3 Develop a certain methodology to periodically analyze threats-related information.	This sub-control requires establishing a defined methodology for analyzing threat information. This methodology should ensure that threat data is analyzed regularly and systematically to identify potential risks.	Documented threat analysis methodology. Evidence of periodic threat analysis (e.g., threat analysis reports).

	4 Details related to certain threats, such as work method, actors, motivations and threats type.	This sub-control requires gathering specific details about identified threats, such as the methods used by attackers, the actors involved, their motivations, and the type of threats posed. This information helps in better understanding the threat landscape and developing effective mitigation strategies. Establish procedures for gathering detailed information about identified threats.	Threat intelligence repository with detailed threat information.
	5 Sharing the relevant threat intelligence with the concerned entities.	This sub-control highlights the importance of sharing threat intelligence with relevant stakeholders. This could include internal departments, external partners, or even other organizations within the same industry. Sharing threat information helps in collective defense and improves overall cybersecurity posture. Establish procedures for sharing threat intelligence with relevant entities.	Evidence of threat intelligence sharing with stakeholders (e.g., shared reports, participation in threat intelligence sharing platforms).

Risk Considerations in Cybersecurity Incident and Threat Management

1. Delayed Threat Detection:

Failure to detect security threats in real-time increases the risk of breaches and prolonged dwell time of attackers within the network.

2. Inefficient Incident Response Process:

Lack of a well-defined and regularly tested incident response plan can lead to slow containment and mitigation of security incidents.

3. Inadequate Threat Intelligence Utilization:

Failure to integrate threat intelligence feeds into incident response workflows can result in missed early warning signs of emerging threats.

4. Limited Forensic Capabilities:

Insufficient logging and forensic analysis capabilities hinder the ability to investigate security incidents effectively.

5. False Positives and Incident Fatigue:

An excessive number of false positives can overwhelm security teams, leading to important alerts being ignored.

6. Lack of Coordination Between Teams:

Poor communication between cybersecurity, IT, and business units can delay incident resolution and recovery efforts.

7. Unpatched Vulnerabilities:

Failure to remediate known vulnerabilities in a timely manner can expose systems to exploitation and persistent threats.

8. Insufficient User Awareness:

Users unaware of cybersecurity threats and response protocols may inadvertently contribute to security breaches.

9. Regulatory Non-Compliance:

Inability to adhere to cybersecurity regulations and incident reporting requirements can result in penalties and reputational damage.

10. Insider Threats:

Employees or third-party vendors with privileged access can pose a security risk if their activities are not monitored.

Examples of Technologies for Effective Cybersecurity Incident and Threat Management

- **Security Information and Event Management (SIEM):**
 - Tools: Wazuh, ELK Stack, OSSIM
 - **Endpoint Detection and Response (EDR):**
 - Tools: OSSEC, Wazuh, Velociraptor
 - **Extended Detection and Response (XDR):**
 - Tools: Wazuh + Elastic Stack, TheHive + Cortex integration
 - **Threat Intelligence Platforms (TIP):**
 - Tools: MISP, OpenCTI
 - **Security Orchestration, Automation, and Response (SOAR):**
 - Tools: Shuffle, TheHive + Cortex
 - **Intrusion Detection and Prevention Systems (IDPS):**
 - Tools: Snort, Suricata
 - **Deception Technology:**
 - Tools: Canarytokens, OpenCanary
 - **Forensic and Incident Analysis Tools:**
 - Tools: Autopsy, Velociraptor, Plaso
 - **Threat Hunting Platforms:**
 - Tools: Elastic Security, MITRE ATT&CK Navigator, HELK (Hunting ELK)
-

Examples of KPIs for Cybersecurity Incident and Threat Management

1. **Mean Time to Detect (MTTD):**
 - Average time taken to detect a security incident.
2. **Mean Time to Respond (MTTR):**
 - Average time taken to contain and mitigate an incident.
3. **Incident Closure Rate:**
 - Percentage of security incidents resolved within defined SLAs.
4. **False Positive Rate:**
 - Percentage of security alerts that turn out to be non-threats.
5. **Threat Intelligence Effectiveness:**
 - Number of threat intelligence indicators successfully correlated with real incidents.
6. **Security Awareness Training Completion Rate:**
 - Percentage of employees completing cybersecurity awareness training.
7. **Compliance Violation Rate:**
 - Number of security incidents caused by non-compliance with regulations.
8. **Successful Phishing Attack Rate:**
 - Percentage of phishing attempts resulting in credential compromise.

Samples of Auditor's Checklist for Cybersecurity Incident and Threat Management

- Is there a documented and tested Incident Response Plan (IRP)?
 - Are security incidents logged, categorized, and analyzed effectively?
 - Is a SIEM solution deployed to collect and correlate security events?
 - Are threat intelligence feeds integrated into security operations?
 - Are cybersecurity incidents reported to regulators within required timelines?
 - Are regular tabletop exercises conducted to test incident response readiness?
 - Are endpoints protected with EDR/XDR solutions for threat detection?
 - Are security incidents communicated effectively across relevant teams?
 - Are privileged account activities logged and monitored for anomalies?
 - Are post-incident reviews conducted to identify root causes and lessons learned?
-

Samples of Audit Scenarios for Cybersecurity Incident and Threat Management

Scenario 1: Evaluating Incident Response Effectiveness

Objective: Assess the organization's ability to respond to security incidents in a timely manner.

Steps:

1. Review documented incident response plans and compare them with actual incident reports.
2. Evaluate the efficiency of the escalation and containment procedures.
3. Conduct interviews with security teams to assess their readiness.

Key Questions:

- Is there a formalized incident classification framework?
 - How quickly are critical incidents contained and mitigated?
-

Scenario 2: Assessing Threat Intelligence Integration

Objective: Validate the use of threat intelligence in proactive threat detection.

Steps:

1. Review the organization's use of TIPs and threat feeds.
2. Assess how often intelligence indicators are mapped to security alerts.
3. Determine if threat intelligence is used to enhance proactive defense strategies.

Key Questions:

- Are threat intelligence sources vetted and regularly updated?
 - How often do threat intelligence insights lead to actionable security improvements?
-

Case Study 1: Enhancing Threat Management in a Financial Institution

Scenario: A bank in Saudi Arabia faced repeated cyberattacks targeting customer accounts via phishing and credential stuffing attacks.

Challenges:

- High number of fraudulent transactions due to credential reuse.
- Ineffective incident response leading to slow fraud detection.
- Lack of integration between fraud detection and SIEM.

Actions Taken:

- Implemented an AI-driven fraud detection system integrated with SIEM.
- Enhanced multi-factor authentication (MFA) for online banking.
- Established a 24/7 threat intelligence monitoring center.

Outcomes:

- Reduced fraudulent transaction rates by 60%.
 - Improved incident detection speed by 70%.
 - Achieved full compliance with SAMA cybersecurity requirements.
-

Case Study 2: Strengthening Incident Response in a Government Agency

Scenario: A government agency handling sensitive citizen data experienced a ransomware attack that encrypted key databases.

Challenges:

- No rapid containment plan led to significant data unavailability.
- Lack of offline backups prolonged recovery efforts.
- Insider threat contributed to the initial compromise.

Actions Taken:

- Deployed endpoint threat detection (EDR) to block similar attacks.
- Conducted forensic investigations to identify the insider.
- Implemented network segmentation and zero-trust policies.

Outcomes:

- Reduced ransomware recovery time from weeks to hours.
- Strengthened internal monitoring to detect insider threats.
- Established a zero-trust security model for government networks.

Lessons Learned from the Case Studies

1. Proactive Threat Intelligence Enhances Security Posture:

- Organizations that integrate real-time threat intelligence into their cybersecurity operations can detect and mitigate threats faster.

2. Incident Response Plans Must Be Regularly Tested:

- Effective cybersecurity incident management requires continuous testing through tabletop exercises, red teaming, and simulations.

3. Security Automation Reduces Response Time:

- Implementing SOAR solutions can significantly improve the speed and efficiency of incident response by automating repetitive tasks.

4. Insider Threats Require Continuous Monitoring:

- Behavioral analytics and privileged access monitoring are essential to detect and prevent malicious insider activities.

5. Compliance with Cybersecurity Regulations is Critical:

- Aligning security practices with regulatory frameworks like SAMA CSF and NCA ECC ensures legal compliance and avoids financial penalties.

6. Centralized Security Operations Improve Coordination:

- A well-structured Security Operations Center (SOC) enhances visibility, streamlines response processes, and reduces the impact of security incidents.

7. Regular Security Awareness Training is Key:

- Employees should be continuously educated on cybersecurity best practices to reduce the risk of phishing, social engineering, and human errors.

8. Effective Log Management Enables Stronger Forensic Investigations:

- Organizations with robust SIEM implementations can quickly trace and analyze incidents to mitigate damage and prevent recurrence.

2.14 Physical Security:

Definition:

Physical security in the context of cybersecurity refers to the measures taken to protect an organization's information systems, data, and other critical assets from physical threats, such as unauthorized access, theft, damage, or environmental hazards. This includes the physical protection of buildings, facilities, equipment, and personnel [9], [10], [11].

Objective:

The primary objective of physical security is to prevent unauthorized physical access to sensitive areas, equipment, and data, thereby ensuring the confidentiality, integrity, and availability of critical information assets. This involves implementing measures to deter, detect, delay, and respond to physical security threats.

Controls Matrix:

Below is a summary matrix detailing relevant Physical Security controls based on NCA, SAMA CSF, CST CRF, and CMA Cybersecurity Guidelines:

Regulation	Main Controls	Control References
NCA ECC	4	2-14-1, 2-14-2, 2-14-3 (5 sub-controls), 2-14-4
SAMA CSF	1	3.3.2 (with 3.3.2-1, 3.3.2-2, 3.3.2-3 having 5 sub-controls a-e)
CST CRF	2	5.1 (7 sub-controls: 5.1.1-5.1.7), 5.2 (7 sub-controls: 5.2.1-5.2.7)
CMA CSG	1	4.3.14 (6 sub-controls: 4.3.14-1 through 4.3.14-6)
NCA CCCC	—	—
NCA CCC CST	—	—
NCA CCC CSP	1	2-13-P-1 (3 sub-controls: 2-13-P-1-1 through 2-13-P-1-3)
NCA TCC	—	—
NCA DCC	—	—
NCA OSMACC	—	—
NCA OTCC	2	2-13-1 (9 sub-controls: 2-13-1-1 through 2-13-1-9), 2-13-2

Physical Security Controls:

National Cybersecurity Authority - Essential Cybersecurity Controls ECC					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
2-14-1		Cybersecurity requirements for physical protection of information and technology assets must be defined, documented, and approved.	Physical Security Policy Template	Define the cybersecurity requirements for physical protection of information and technology assets, document them thoroughly, and obtain necessary approvals.	Documented cybersecurity requirements for physical protection.
2-14-2		The cybersecurity requirements for physical protection of information and technology assets must be implemented.		Implement the defined cybersecurity requirements for physical protection of information and technology assets.	Evidence of implementation of physical protection requirements.
2-14-3 The cybersecurity requirements for physical protection of information and technology assets must include at least the following:	2.14.3.1	Authorized access to sensitive areas within the organization (e.g., data center, disaster recovery center, sensitive information processing facilities, security surveillance center, network cabinets).	Access Control Systems, Biometric Authentication Systems	Ensure that the cybersecurity requirements for physical protection include the following: Implement access control measures to restrict physical access to sensitive areas within the organization.	Access control measures for sensitive areas.
	2.14.3.2	Facility entry/exit records and CCTV monitoring.	CCTV Systems, Visitor Management Systems	Maintain entry/exit records for the facility and implement CCTV monitoring to track activities.	Entry/exit records and CCTV monitoring system implementation.

	2.14.3.3	Protection of facility entry/exit and surveillance records.		Implement measures to protect facility entry/exit and surveillance records from unauthorized access or modification.	Evidence of protection measures for entry/exit and surveillance records.
	2.14.3.4	Secure destruction and re-use of physical assets that hold classified information (including documents and storage media).	Data Destruction Policies and Procedures	Implement secure procedures for the destruction and re-use of physical assets that contain sensitive information.	Data destruction and re-use procedures.
	2.14.3.5	Security of devices and equipment inside and outside the organization's facilities.		Implement security measures to protect devices and equipment both within and outside the organization's premises.	Evidence of security measures for devices and equipment.
2-14-4	The cybersecurity requirements for physical protection of information and technology assets must be reviewed periodically.			Conduct periodic reviews of the cybersecurity requirements for physical protection to ensure their continued effectiveness and relevance.	Periodic review reports of physical protection requirements.
National Cybersecurity Authority – Operational Technology Cybersecurity Controls OTCC					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
2-13-1	2-13-1-1	List of personnel with authorized access to facilities and sensitive locations where OT/ICS assets reside must be maintained.	Template for Cybersecurity Operational Technology Policy, Template for OT/ICS Security Standard, Template for Physical Security Policy, Template for	Identify and list personnel with authorized access to facilities and sensitive locations where OT/ICS assets reside. Maintain and update the performed list continuously, and manage it according to the mechanism and procedures established within the organization.	A documented list of personnel with authorized access to facilities and sensitive locations where OT/ICS assets reside. A proof that the list is periodically maintained and updated.

			Physical Security Standard		
	2-13-1-2	Real-time physical intrusion detection alarms and surveillance equipment, and proper mechanisms must be implemented to recognize potential intrusions and apply the approved response actions.	Template for Cybersecurity Operational Technology Policy, Template for OT/ICS Security Standard, Template for Physical Security Policy, Template for Physical Security Standard	Ensure that the real-time physical intrusion detection alarms and surveillance equipment, and proper mechanisms are implemented.	Site visit to check that the real-time physical intrusion detection alarms and surveillance equipment, and proper mechanisms are implemented.
	2-13-1-3	Physical access points and perimeter to sensitive OT/ICS areas shall be protected and ensure continuous monitoring.	Template for Cybersecurity Operational Technology Policy, Template for OT/ICS Security Standard, Template for Physical Security Policy, Template for Physical Security Standard	Identify and list physical access points and perimeter to sensitive OT/ICS areas. Implement protection and monitoring mechanisms (e.g. access control system) to avoid unauthorized physical access to sensitive OT/ICS areas. Implemented mechanisms should be formally documented (as an implementation plan or procedure). Verify and ensure that all listed access points and perimeters are continuously monitored.	A documented list of physical access points and perimeter to sensitive OT/ICS areas. Site visit to check that all listed access points and perimeters are continuously monitored.
	2-13-1-4	Safeguards, such as locks on cabinets containing control systems or sensitive assets related to OT/ICS, must be utilized to	Template for Cybersecurity Operational Technology Policy, Template for OT/ICS Security Standard,	Verify and ensure the use of appropriate protection measures, such as locking all cabinets containing control systems. Verify and ensure that all OT/ICS assets are protected from unauthorized physical	Site visit to check the protection measures of the following sites: Physical access to industrial facilities. Cabinets containing

		prevent unauthorized access to devices that could provide a mechanism to compromise the OT/ICS assets.	Template for Physical Security Policy, Template for Physical Security Standard	access in line with the organization's approved mechanisms.	control systems. Control room center (CCR).
	2-13-1-5	Strict limitation must be enforced on the physical access to all OT/ICS assets, including Safety Instrumented Systems (SIS).	Template for Cybersecurity Operational Technology Policy, Template for OT/ICS Security Standard, Template for Physical Security Policy, Template for Physical Security Standard	Verify and ensure that strict physical access limitation to all OT/ICS assets, including Safety Instrumented Systems (SIS) is enforced.	Site visit to check that the strict physical access limitation to all OT/ICS assets, including Safety Instrumented Systems (SIS) is enforced.
	2-13-1-6	Visitor access records to restricted locations where OT/ICS reside must be maintained.	Template for Cybersecurity Operational Technology Policy, Template for OT/ICS Security Standard, Template for Physical Security Policy, Template for Physical Security Standard	Ensure to maintain visitor access records to restricted locations where OT/ICS reside. Ensure that the visitors must record their entries once they access the restricted locations where OT/ICS reside.	Documented visitor access logs to restricted area where OT/ICS reside. Site visit to check that the visitor access records to restricted locations where OT/ICS reside is maintained.
	2-13-1-7	Work being performed by contractor or vendor	Template for Cybersecurity	Define the requirements for monitoring work that is being performed by the	Requirements document for monitoring work that is

		personnel must be monitored.	Operational Technology Policy, Template for OT/ICS Security Standard, Template for Physical Security Policy, Template for Physical Security Standard	contractor or vendor personnel. All requirements should be formally documented and aligned with related documents such as (work permits). Define and prepare contractor or vendor personnel's works register. Verify and ensure that all work being performed by contractor or vendor personnel is monitored.	being performed by the contractor or vendor personnel. A proof that shows all work being performed by contractor, service providers, or vendor personnel is monitored.
	2-13-1-8	Trainings and skillsets for the organizational security guards must be provided in line with roles and responsibilities with respect to OT/ICS physical security.	Template for Cybersecurity Operational Technology Policy, Template for OT/ICS Security Standard, Template for Physical Security Policy, Template for Physical Security Standard	Ensure that training and skillsets for industrial security personnel including (facilities and plants) are provided in line with their roles and responsibilities with respect to OT/ICS physical security.	A documented list of the organizational security guards names embraced by the OT/ICS physical security training program. A proof confirming that training and skillsets for industrial security personnel including (facilities and plants) are provided, and are in line with their roles and responsibilities with respect to OT/ICS physical security.
	2-13-1-9	Physical security capabilities and readiness must be periodically tested by performing simulation	Template for Cybersecurity Operational Technology Policy, Template for OT/ICS Security Standard,	Ensure the physical security capabilities and readiness are periodically tested (based on a defined frequency) by performing simulation exercises (such as social engineering).	A documented list of cyber-attack simulations (cybersecurity drills and tabletop exercises). A proof that physical security capabilities and

		exercises (such as social engineering).	Template for Physical Security Policy, Template for Physical Security Standard		readiness are periodically tested by performing simulation exercises (such as social engineering).
2-13-2		With reference to the ECC control 2-14-4, the cybersecurity requirements for physical security in OT/ICS environment must be reviewed, and their implementation effectiveness is measured and evaluated periodically.	Template for Cybersecurity Operational Technology Policy, Template for OT/ICS Security Standard, Template for Physical Security Policy, Template for Key Performance Indicator Report	Review the cybersecurity requirements for physical security management within the OT/ICS environment periodically based on a documented and approved review plan and on a defined frequency (e.g., conduct a review annually). Develop key performance indicators (KPIs) for each control within the related policy or procedure to ensure the implementation effectiveness is measured and evaluated periodically based on a defined frequency (e.g., conduct a review annually).	A proof that shows the periodic review of cybersecurity requirements for physical security management within the OT/ICS environment. A proof that shows the key performance indicators (KPIs) for each control within the related policy or procedure to ensure the implementation effectiveness is measured and evaluated periodically (based on a defined frequency).
National Cybersecurity Authority - Cloud Cybersecurity Controls CCC					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
2-13-P-1 In addition to sub controls in the ECC control	2-13-P-1-1	Continuous monitoring of access to CSP's sites and buildings.	Template for Physical Security Cybersecurity Policy, Template for	Identify all access points/gates to sites and buildings. Define attack vectors against access points (consider piggybacking, reusing of stolen access	Inventory of sites' and buildings' gates and access points. Documentation of defined

2-14-3, the CSP shall cover the following additional sub controls for cybersecurity requirements for physical security, as a minimum:			Physical Security Standards	tokens, tampering access prevention systems). Define requirements for CSP's sites and building access monitoring. Define a process for effective access monitoring and access violation detection. Implement technical systems for effective access monitoring. Involve trained Analysts when professional judgement is required in the monitoring process. Keep monitoring records - access logs and who and when reviewed these logs for no less than six (6) months. Record the dates and times of visitor entries and departures and supervise all visitors unless their access has previously been approved. Monitor ingress and egress points to service and delivery areas and other points where unauthorized personnel may enter the premises. Monitor access by reviewing access logs, access attempts and access recordings.	attack vectors, access monitoring requirements and access monitoring process (procedure or instructions). Access logs and records. Access logs and records reviews.
	2-13-P-1-2	Preventing unauthorized access to devices in the Cloud Technology Stack.	Template for Physical Security Cybersecurity Policy, Template for Physical Security Standards	Build physical security isolated perimeter for the data storage and processing facilities areas, including gates, physical authentication mechanisms, access control points and monitoring equipment. Place the Cloud Technology Stack devices in secure area the perimeter in dedicated server room with	Closed physical perimeter for servers and data storage with access control points. Devices locked in secure racks preventing from damage and external portable devices insertions.

				access limited to authorized personnel. Secure devices in the Cloud Technology Stack using rack cabinet enclosures to prevent damage or inserting external devices (e.g. USB flash drives, portable SSD drives, etc.).	
	2-13-P-1-3	Disposal of cloud infrastructure hardware storage equipment (external or internal), by adopting relevant legislation and best practices.	Template for Physical Security Cybersecurity Policy, Template for Physical Security Standards	Identify legal regulations and best practices for hardware disposal. Define roles and responsibilities in the disposal process. Select hardware sanitization methods (e.g. cryptographic erase, media degaussing, media physical destruction: pulverizing, burning, melting, etc. or industrial shredding) adequate to hardware type ensuring that data stored on these devices will not be recoverable. Record the hardware disposal process.	Legal regulations and best practices for hardware disposal gathered. Formally approved cloud infrastructure hardware disposal policy. Hardware disposal records and tracking system.
SAMA Cyber Security Framework CSF					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
3.3.2-1		The physical security process should be defined, approved and implemented.		This means that there needs to be a documented and authorized plan for physical security. It shouldn't be ad-hoc or left to individual interpretations. This process should cover all aspects of physical security, from access control to environmental protection.	Documented physical security process. Evidence of approval.

				Define a formal process for physical security, document it thoroughly, obtain necessary approvals, and implement the process.	
3.3.2-2		The effectiveness of the physical security process should be monitored, measured and periodically evaluated.		Physical security isn't a "set it and forget it" task. This control emphasizes the need for regular checks to ensure the security measures are working as intended and are still adequate for the current threats. This could involve audits, reviews, and vulnerability assessments. Define metrics to track the performance of the physical security process. Regularly assess the effectiveness of the process using these metrics and make adjustments as needed.	Reports on physical security process performance. Documentation of periodic evaluations.
3.3.2-3 The physical security process should include (but not limited to):	a	Physical entry controls (including visitor security).	Access control systems, visitor management systems	This involves managing who can physically access the organization's facilities. It includes things like security guards, locked doors, access cards, and visitor logs. Implement access control measures to restrict physical access to the organization's facilities.	Evidence of access control measures.
	b	Monitoring and surveillance (e.g., CCTV, ATMs GPS tracking, sensitivity sensors).	CCTV systems, intrusion detection systems	Using technology to keep an eye on the premises and the assets within. This acts as both a deterrent and a way to record evidence in case of an incident.	Evidence of monitoring and surveillance measures.

				Implement monitoring and surveillance measures to track activities within and around the organization's facilities.	
	c	Protection of data centers and data rooms.	Access control systems, environmental monitoring systems	These are sensitive areas that require extra layers of security, such as biometric access control, strict environmental monitoring, and potentially even mantraps. Implement additional security measures to protect data centers and data rooms.	Evidence of additional security measures for data centers and data rooms.
	d	Environmental protection.	Fire suppression systems, environmental monitoring systems	This refers to protecting the organization's assets from environmental threats like fire, flood, and extreme temperatures. This could involve fire suppression systems, water leak detection, and backup power generators. Implement environmental protection measures to protect the organization's assets from environmental threats.	Evidence of environmental protection measures.
	e	Protection of information assets during their lifecycle (including transport and secure disposal, avoiding unauthorized access and (un)intended data leakage).	Data loss prevention (DLP) tools, encryption tools	Explanation: Information security isn't confined to a building. This control highlights the need to protect information wherever it goes, even when it leaves the premises – during transport, storage, and disposal.	Evidence of information asset protection measures.

				Implement measures to protect information assets during their lifecycle, including transport, storage, and disposal.	
CST CRF					
Control reference number	Control clauses	Control implementation guidelines			Expected deliverables
5.1.1 CL1	Define and document [Requirements for the Protection of Physical Information Assets] which consider the following: • Protecting physical facilities that host information assets • Protecting physical information assets and physical facilities installed on offsite premises • Delivery and loading areas • Transportation of physical information assets • Defining physical protection measures against environmental threats	This control highlights the importance of establishing and documenting clear requirements for the physical protection of information assets. These requirements should cover various aspects of physical security, including the protection of facilities, offsite assets, delivery and loading areas, transportation of assets, and measures to protect against environmental threats. Define and document comprehensive requirements for the physical protection of information assets, addressing the protection of facilities, offsite assets, delivery and loading areas, transportation of assets, and environmental protection measures.			Documented requirements for the protection of physical information assets.
5.1.2 CL1	Define security perimeters in order to protect physical facilities (e.g. offices, rooms, data centers, ground stations, and telecommunication processing equipment) that contain information assets.	This control focuses on defining security perimeters to protect physical facilities that house information assets. This includes establishing clear boundaries and access controls to prevent unauthorized physical access to sensitive areas. Define and establish security perimeters for all physical facilities that contain information assets.			Documented security perimeters for physical facilities.

5.1.3 CL1	Ensure that the physical information assets reside within appropriate security zones and are stored in secure physical facilities during non-operational hours.	This control emphasizes the importance of storing physical information assets in secure locations with appropriate security zones. This includes ensuring that assets are properly secured during non-operational hours to prevent unauthorized access or theft. Define and implement procedures for storing physical information assets in secure locations with appropriate security zones. Ensure that assets are properly secured during non-operational hours.	Evidence of secure storage of physical information assets.
5.1.4 CL1	Secure the delivery/loading areas that could be used by unauthorized personnel to enter the organization's premises (e.g. segregate physically where possible, incoming and outgoing shipments).	This control focuses on securing delivery and loading areas to prevent unauthorized access to the organization's premises. This could involve physical segregation of incoming and outgoing shipments, access controls, and surveillance measures. Implement security measures to secure delivery and loading areas and prevent unauthorized access to the organization's premises.	Evidence of security measures for delivery and loading areas.
5.1.5 CL1	Protect physical information assets against damage from environmental threats, hazards, and unauthorized physical access by taking into consideration the following factors: - Protection measures against physical threats (e.g. fires, accidents, power failures, failures in supporting utilities, natural disasters) - Securing cables against interception, interference or damage as well as a	This control requires the implementation of measures to protect physical information assets from various threats, including environmental factors, physical damage, and unauthorized access. This could involve measures like fire suppression systems, environmental controls, cable management, and physical security controls like surveillance and alarm systems. Implement physical security controls to protect information assets from environmental threats, physical damage, and unauthorized access.	Evidence of physical security controls implementation.

	proper cable management (e.g. cable labelling, color code) - Operating physical information assets according to the manufacturer specified requirements and controlling the working atmosphere (e.g. temperature, humidity, air quality, water, and light) - Protection against unauthorized access (e.g. surveillance through CCTV, alarm systems, motion sensors)		
5.1.6 CL1	Protect physical information assets during their transportation taking into consideration e.g. the assessed risks, security during movement.	This control emphasizes the importance of protecting physical information assets during transportation. This could involve measures like secure packaging, encryption, and tracking mechanisms to prevent unauthorized access, theft, or damage during transit. Define and implement procedures for the secure transportation of physical information assets.	Documented procedures for secure transportation of physical information assets.
5.1.7 CL3	Continuously measure, review and optimize the [Requirements for the Protection of Physical Information Assets].	This control highlights the need for continuous monitoring and improvement of physical security measures. Organizations should regularly review and update their physical security controls to ensure they remain effective and relevant in the face of evolving threats and vulnerabilities. Establish a process for regularly measuring, reviewing, and optimizing the requirements for the protection of physical information assets.	Reports on the measurement and review of physical security requirements. Documentation of optimization efforts.

5.2.1 CL1	Define and document [Requirements for Physical Access Management] which consider the following: • Physical access authorizations and control • Monitoring physical access	This control highlights the importance of establishing and documenting clear requirements for managing physical access to the organization's facilities and sensitive areas. These requirements should cover the authorization and control of physical access, as well as the monitoring of access activities. Define and document comprehensive requirements for physical access management, addressing physical access authorizations, access control measures, and monitoring procedures.	Documented requirements for physical access management.
5.2.2 CL1	Create a [Physical Access Control List] of individuals with authorized access to the organization's facilities and issue appropriate authorization credentials.	This control focuses on creating and maintaining a list of individuals who have authorized access to the organization's facilities. It also requires issuing appropriate credentials, such as access cards or badges, to authorized personnel. Create and maintain a physical access control list. Issue appropriate authorization credentials to authorized personnel.	Physical access control list. Authorization credentials for authorized personnel.
5.2.3 CL1	Define and implement {Physical Access Management} process to grant and manage access (e.g. secure keys) to the physical facilities.	This control requires defining and implementing a formal process for granting and managing physical access to facilities. This process should include procedures for requesting access, approving access requests, issuing credentials, and revoking access when it is no longer needed. Define and implement a formal process for granting and managing physical access to facilities.	Documented physical access management process.
5.2.4 CL1	Establish physical entry controls for visitors (e.g. provide security badges to the visitors and monitor unusual activity).	This control focuses on establishing physical entry controls for visitors to the organization's facilities. This could include measures like requiring visitors to sign in, issuing visitor badges, and escorting visitors while they are on the premises.	Visitor logs and badges.

		Implement physical entry controls for visitors, such as visitor logs, badges, and escorts.	
5.2.5 CL2	Continuously review the [Physical Access Control List] of individuals with authorized access to facilities and remove them from the list when access is no longer required.	This control requires regular review of the physical access control list to ensure that only authorized individuals have access to the organization's facilities. When an individual's access is no longer needed, they should be removed from the list and their access credentials should be revoked. Establish a process for regularly reviewing and updating the physical access control list.	Evidence of regular review and updates to the physical access control list.
5.2.6 CL2	Regularly review physical access logs for suspicious activity [Logging and Monitoring].	This control requires regular review of physical access logs to identify any suspicious activity, such as unauthorized access attempts or unusual access patterns. Establish a process for regularly reviewing physical access logs for suspicious activity.	Evidence of regular review of physical access logs.
5.2.7 CL3	Continuously measure, review and optimize the [Requirements for Physical Access Management] as well as the effectiveness of the process.	Explanation: This control emphasizes the importance of continuous improvement in physical access management. Organizations should regularly measure and review the effectiveness of their physical access controls and make adjustments as needed to ensure they remain aligned with their security objectives and risk tolerance. Establish a process for continuously measuring, reviewing, and optimizing the requirements for physical access management.	Reports on the measurement and review of physical access management requirements. Documentation of optimization efforts.
CMA Cybersecurity Guidelines			

Control reference number	Control clauses	Control implementation guidelines	Expected deliverables
4.3.14-1	Set out, document, approve, and implement physical security controls.	Establish a documented and approved process for setting out, documenting, approving, and implementing physical security controls. This process should include regular reviews and updates to ensure alignment with industry best practices and regulatory requirements.	Documented physical security controls and evidence of approval and implementation.
4.3.14-2	Measure, monitor effectiveness, and periodically evaluate physical security controls.	Establish metrics and procedures for monitoring and evaluating the effectiveness of physical security controls. Conduct periodic reviews and updates to ensure alignment with industry best practices and regulatory requirements.	Reports on the effectiveness of physical security controls, evidence of periodic evaluations, and documentation of any updates or improvements made.
4.3.14-3	Ensure that trading services are protected against service disruption due to power outage.	Implement backup power systems and redundant network infrastructure to ensure continuous operation of trading services in case of power outages.	Evidence of backup power systems and redundant network infrastructure implementation.
4.3.14-4	Monitor fire alarms on an ongoing basis, test them regularly, and maintain them according to manufacturer specifications.	Implement a system for monitoring fire alarms, conducting regular tests, and performing maintenance according to manufacturer specifications.	Fire alarm monitoring and maintenance records.
4.3.14-5	Mitigate the impact of natural disasters.	Develop and implement a disaster recovery plan that includes procedures for mitigating the impact of natural disasters. Implement backup and recovery systems to ensure business continuity in case of a natural disaster.	Disaster recovery plan and evidence of backup and recovery systems implementation.
4.3.14-6	1- Physical entry controls (including visitor security).	Implement physical entry controls, including visitor logs, badges, and escorts.	Visitor logs and badges.

The physical security process includes, but not limited to, the following:	2- Surveillance and monitoring (using "CCTV" systems, sensors, etc.).	Utilize surveillance systems and sensors to monitor the premises for security breaches.	Evidence of surveillance and monitoring systems implementation.
	3- Protecting data centers, data rooms and power supplies for crucial facilities.	Implement additional security measures to protect data centers, data rooms, and power supplies for crucial facilities.	Evidence of additional security measures for data centers, data rooms, and power supplies.
	4- Protection against environmental hazards.	Implement measures to protect against environmental hazards, such as fire, water damage, and other environmental risks.	Evidence of environmental hazard protection measures.
	5- Protect information assets during their life cycle (including transportation, safe disposal, avoid unauthorized access and intentional or unintentional data leakage).	Implement measures to protect information assets during their lifecycle, from creation to disposal, including secure transportation and data leakage prevention.	Evidence of information asset protection measures.
	6- Train personnel on use of fire extinguishers and other safety equipment.	Conduct training for personnel on the use of fire extinguishers and other safety equipment.	Training records

Risk Considerations in "Physical Security"

- **Unauthorized Physical Access:** Failure to restrict physical access to sensitive areas, such as data centers, server rooms, and communication closets, can expose critical assets to theft, damage, or sabotage.
- **Environmental Threats:** Inadequate protection against environmental hazards, such as fire, water damage, and extreme temperatures, can damage equipment and disrupt operations.
- **Theft and Vandalism:** Lack of security measures to deter theft and vandalism can result in the loss or damage of valuable equipment and data.
- **Social Engineering:** Employees or visitors may be tricked into granting unauthorized physical access to sensitive areas through social engineering tactics.
- **Insider Threats:** Malicious insiders or disgruntled employees may pose a significant risk to physical security, potentially leading to data breaches or sabotage.
- **Lack of Physical Security Policies and Procedures:** Absence of clear policies and procedures for physical security can lead to inconsistencies and vulnerabilities in security practices.
- **Inadequate Training and Awareness:** Insufficient training and awareness among employees regarding physical security protocols can increase the risk of security breaches.

Examples of Technologies for Effective Physical Security

- **Access Control Systems:**
Tools: OpenAccess, Open Source RFID, OpenBioPalm
- **Surveillance Systems:**
Tools: ZoneMinder, Shinobi, MotionEye
- **Environmental Monitoring Systems:**
Tools: Nagios with environmental plugins, OpenHAB, Zabbix sensors
- **Perimeter Security Systems:**
Tools: Integration of open-source sensor controllers (e.g., Arduino + Motion sensors)
- **Physical Intrusion Detection Systems:**
Tools: OpenPIDS (experimental), DIY sensor systems with Raspberry Pi/Arduino
- **Security Lighting:**
Tools: Automated lighting with OpenHAB, Home Assistant integrations
- **Locks and Safes:**
Tools: Open-source smart lock firmware (e.g., OpenLock), mechanical safes (non-digital)

Examples of KPIs for Physical Security

- **Number of Physical Security Incidents:** Track the number of physical security breaches, such as unauthorized access attempts, theft, or vandalism.
- **Mean Time to Detect (MTTD) Physical Intrusions:** Measure the average time taken to detect physical security breaches.
- **Mean Time to Respond (MTTR) to Physical Security Incidents:** Measure the average time taken to respond to and resolve physical security incidents.
- **Compliance with Physical Security Policies:** Track the percentage of employees and visitors who comply with physical security policies and procedures.
- **Physical Security Training Completion Rate:** Monitor the percentage of employees who have completed physical security awareness training.
- **Number of Access Control Violations:** Track the number of unauthorized access attempts or violations of access control policies.

Samples of Auditor's Checklist for "Physical Security"

- Are physical security policies and procedures documented and up-to-date?
- Are all sensitive areas, such as data centers and server rooms, adequately secured?
- Are access control systems in place and functioning properly?
- Are surveillance systems in place and monitored effectively?
- Are environmental controls in place to protect equipment from damage?
- Are there procedures for the secure disposal of physical assets containing sensitive data?
- Are employees and visitors properly trained on physical security protocols?
- Are physical security incidents properly investigated and documented?

Samples of Audit Scenarios for "Physical Security"

- **Scenario 1: Unauthorized Access Attempt:** A former employee attempts to gain access to the building using their old access card. The auditor would assess the effectiveness of access control systems and procedures for deactivating access credentials.
- **Scenario 2: Environmental Threat:** A fire breaks out in the server room. The auditor would assess the effectiveness of fire suppression systems, evacuation procedures, and the impact on critical systems and data.
- **Scenario 3: Theft of Equipment:** A laptop containing sensitive data is stolen from an employee's workstation. The auditor would assess the physical security measures in place to prevent theft, as well as the organization's data encryption and remote wipe capabilities.

Case Study 1: Physical Security Breach at a Government Agency

Scenario: A government agency experienced a physical security breach when an unauthorized individual gained access to a secure area containing sensitive information. The individual was able to bypass security checkpoints by impersonating a maintenance worker.

Challenges:

- **Inadequate Access Control:** The security checkpoints relied on visual identification and did not have robust authentication mechanisms in place.
- **Lack of Employee Awareness:** Employees were not adequately trained to identify and report suspicious behavior.
- **Insider Threat:** The investigation revealed that the intruder had colluded with an employee who provided them with access information.

Actions Taken:

- **Enhanced Access Control:** The agency implemented multi-factor authentication and stricter access control measures, including biometric verification.
- **Employee Training:** Mandatory security awareness training was conducted to educate employees on identifying and reporting suspicious behavior and insider threats.
- **Background Checks:** More thorough background checks were implemented for all employees and contractors.

Outcomes:

- **Improved Security Posture:** The enhanced security measures significantly reduced the risk of unauthorized physical access.
- **Increased Employee Awareness:** Employees became more vigilant and aware of potential security threats.
- **Reduced Insider Threat Risk:** The stricter background checks and security awareness training helped mitigate the risk of insider threats.

Case Study 2: Physical Security and Disaster Recovery at a Telecommunications Company

Scenario: A telecommunications company's data center was severely damaged by a flood. The flood caused significant damage to equipment and disrupted critical communication services.

Challenges:

- **Inadequate Disaster Planning:** The company's disaster recovery plan did not adequately account for the risk of flooding.
- **Lack of Redundancy:** Critical systems and data were not adequately backed up or replicated at an offsite location.
- **Service Disruption:** The flood caused significant disruption to communication services, impacting customers and business operations.

Actions Taken:

- **Disaster Recovery Plan Enhancement:** The company revised its disaster recovery plan to include specific procedures for mitigating the impact of natural disasters, including flooding.
- **Redundancy and Backup:** Critical systems and data were replicated at a geographically diverse location to ensure business continuity in case of a disaster.
- **Infrastructure Hardening:** The data center was relocated to a less flood-prone area, and flood mitigation measures were implemented.

Outcomes:

- **Reduced Downtime:** The improved disaster recovery plan and redundancy measures enabled the company to restore services more quickly after the flood.
- **Protected Critical Assets:** The relocation and infrastructure hardening measures reduced the risk of future damage from natural disasters.
- **Improved Business Continuity:** The company's ability to maintain critical communication services during and after the flood enhanced its resilience and reputation.

Lessons Learned from the Case Studies

- **Comprehensive Physical Security:** Physical security is a critical component of a comprehensive cybersecurity strategy and should not be overlooked.
- **Layered Defense:** A multi-layered approach to physical security, combining physical measures, technological solutions, and personnel training, is essential for effective protection.
- **Continuous Improvement:** Regular assessments, testing, and updates to physical security controls are necessary to adapt to evolving threats and vulnerabilities.
- **Collaboration:** Collaboration with internal and external stakeholders, including law enforcement and cybersecurity agencies, can enhance physical security posture.
- **Employee Awareness:** Educating and training employees on physical security protocols and potential threats is crucial for maintaining a secure environment.
- **Disaster Preparedness:** Developing and testing a comprehensive disaster recovery plan is essential for minimizing the impact of natural disasters and other disruptive events.

2.15 Web Application Security:

Definition: Web Application Security refers to the implementation of cybersecurity controls and best practices to protect external web applications from cyber risks, unauthorized access, and potential exploitation. It involves securing web application architectures, enforcing authentication mechanisms, utilizing encryption, and implementing protective measures such as Web Application Firewalls (WAF) to prevent security breaches and ensure compliance with security regulations [12], [13], [14].

Objective: To ensure the protection of external web applications against cyber threats by defining, implementing, and continuously reviewing cybersecurity requirements. This includes enforcing secure architecture principles, secure protocols (e.g., HTTPS), robust user authentication mechanisms, and security monitoring to mitigate risks such as injection attacks, unauthorized access, and data breaches.

Controls Matrix:

Below is a summary matrix detailing relevant Web Application Security controls based on NCA requirements:

Regulation	Main Controls	Control References
NCA ECC	4	2-15-1, 2-15-2, 2-15-3 (5 sub-controls), 2-15-4
SAMA CSF	—	—
CST CRF	—	—
CMA CSG	—	—
NCA CCCC	2	2-12-1 (2 sub-controls), 2-12-2
NCA CCC CST	—	—
NCA CCC CSP	1	2-14-P-1 (1 sub-control)
NCA TCC	—	—
NCA DCC	—	—
NCA OSMACC	—	—
NCA OTCC	—	—

Web Application Security Controls:

National Cybersecurity Authority - Essential Cybersecurity Controls ECC				
Control reference number	Sub-Control	Control clauses	Control implementation guidelines	Expected deliverables
2-15-1		Cybersecurity requirements for external web applications must be defined, documented and approved.	Relevant cybersecurity tools: Web Application Protection Policy Template. Include and document cybersecurity requirements for the organization's external web applications security against cyber risks, including, but not limited to: -Web Application Firewall. -Multi-tier Architecture. -Use secure protocols such as HTTPS. -Use of applications development and update standards and testing them. -Clarify secure user usage policy. -Multi-Factor Authentication of users access. -Screening for application-specific vulnerabilities (Vulnerability Assessment). –Regular backups in secure locations (Backup Log Files). –Regular screening of open ports, services, processes, and unused protocols. Cybersecurity requirements for the security of external web applications must be supported by the Executive Management. This must be done through the approval of the organization head or his/her deputy.	A cybersecurity policy that covers the requirements for the organization's external web applications security against cyber risks (electronic copy or official hard copy). Formal approval by the head of the organization or his/her deputy on such document (e.g., via the organization's official e-mail, paper or electronic signature).

2-15-2	The cybersecurity requirements for external web applications must be implemented.	Implement all cybersecurity requirements to External web applications security procedures in the organization. The External web applications security procedures must cover at least the following, but not limited to: -Web Application Firewall. -Multi-tier Architecture. -Use secure protocols such as HTTPS. -Clarify secure user usage policy. -Multi-Factor Authentication of users access. Develop an action plan to implement all cybersecurity requirements related to external web applications security. Include cybersecurity requirements for external web applications security in the organization's external web applications security procedures to ensure compliance with cybersecurity requirements for all internal and external stakeholders.	Documents that confirm the implementation of cybersecurity requirements related to the protection of external web applications as documented in the policy. An action plan document to implement the cybersecurity requirements for external web applications security. Evidence showing the implementation of external web applications security controls, including but not limited to: Screenshot of web application firewall used by the organization. Sample of web application designs that demonstrate the use of a multi-tier architecture principle for the organization's web application. Screenshot from a web application showing the use of HTTPS in its link. Screenshot from the organization's website indicating the publication of the secure usage policy for users. Multiple screenshots showing entry process including MFA.
--------	---	--	---

2-15-3 The cybersecurity requirements for external web applications must include at least the following:	2-15-3-1	Use of web application firewall.	Define and document the requirements of this ECC in the cybersecurity requirements document and approve them by the representative. Web applications must be identified, including: -Purchased external applications. -Internally developed applications. If there are web applications purchased and operated by a third party, the following must be done: -Ensure the supplier's compliance with cybersecurity policies and standard controls including the use of a web application firewall system. If there are internally developed applications or external applications purchased from a third-party that are operated by the organization, the following must be done: Identify the firewall technologies that the organization wishes to acquire, including but not limited to: Firewall with pre-managed rules managed by the system itself. A firewall with the option to customize the rules by the organization. Identify and assign several application firewall systems that include the technologies supplied by the organization, while defining the positive and negative aspects of each system separately. Identify and assign a specific firewall system to be used for the organization's external web applications. Implement and install the firewall system for all web applications operated by the organization. Include an application and install the firewall in the application development lifecycle to ensure the protection of future applications.	A document (such as approved policy or procedure) indicating the identification and documentation of the requirements related to this control. Documents indicating the identification and documentation of the requirements of this ECC in the policies or procedures of the organization approved by the representative (e.g., electronic copy or official hard copy). Screenshot of web application firewall used by the organization.
	2-15-3-2	Adoption of the multi-tier architecture principle.	Define and document the requirements of this ECC in the cybersecurity requirements document and approve them	A document approved policy indicating the identification and

			by the representative. Web applications must be identified, including: Purchased external applications. Internally developed applications. Current web applications used in the organization must be identified. If there are web applications purchased and operated by a third party, the following must be done: Ensure the supplier's compliance with cybersecurity policies and standard controls including the use of multi-tier architecture principle. If there are internally developed applications or external applications purchased from a third-party that are operated by the organization, the following must be done: Determine the tiers of the architecture principle appropriate to the nature of the web application, which must not be less than three tiers: Database Tier. Business Tier. Presentation/Client Tier. Identify relevant departments to implement the multi-tiered architecture principle. Apply the principle of multi-tier architecture, which must not be less than three tiers for all web applications of the organization. Include and use the multi-tier architecture principle in the application development life cycle to ensure the protection of future applications.	documentation of the requirements related to this control. A document approved procedure indicating the identification and documentation of the requirements related to this control. Sample of web application designs that demonstrate the use of a multi-tier architecture principle for the organizations web application. Sample of web application designs that demonstrate the use of a multi-tier architecture principle for the organization's web application purchased from a third party.
	2-15-3-3	Use of secure protocols (e.g., HTTPS).	Define and document the requirements of this ECC in the cybersecurity requirements document and approve them by the representative. Web applications must be identified, including: Purchased external applications. Internally developed applications. Current web applications used in the organization must be identified. If there are web applications purchased and operated by a third party, the following must be done: Ensure the	A document (such as approved policy or procedure) indicating the identification and documentation of the requirements related to this control. Screenshot from a web application showing the use of HTTPS in its link.

			supplier's compliance with cybersecurity policies and standard controls including the use of secure protocols. If there are internally developed applications or external applications purchased from a third-party that are operated by the organization, the following must be done: Define the secure communication protocol to be applied to the organization's web applications, including but not limited to: Hypertext Transfer Protocol Secure (HTTPS). Secure File Transfer Protocol (SFTP). Transport Layer Security Protocol (TLS). Implement and install secure communication protocols in the organizations external web applications to protect them. Include an application and install the secure communication protocols development lifecycle to ensure the protection of future applications.	
	2-15-3-4	Clarification of the secure usage policy for users.	Define and document the requirements of this ECC in the cybersecurity requirements document and approve them by the representative. Document the secure use policy for the organization's web applications for users. Ensure that the secure use policy is shared on the organization's web applications through the external network (extranet) and not the intranet.	A document (such as approved policy or procedure) indicating the identification and documentation of the requirements related to this control. Secure Use of Web Application Users Policy. Screenshot from the organization's website indicating the publication of the secure usage policy for users.
	2-15-3-5	User authentication based on a defined number and factors of authentication, as a result of impact	This control emphasizes a risk-based approach to authentication. It mandates that the strength of user authentication (i.e., the number of authentication factors used) should be determined by the potential impact of an	Risk Assessment Report: A documented risk assessment that outlines the potential

		assessment of authentication failure and bypass for users' access.	authentication failure or bypass. This means that systems or applications with higher security risks would require stronger authentication methods. Impact Assessment: Conduct a thorough risk assessment to evaluate the potential consequences of unauthorized access due to authentication failures. Consider factors like the sensitivity of data, the criticality of the system, and the potential financial or reputational damage. Define Authentication Factors: Based on the risk assessment, define the appropriate number and types of authentication factors to be used. This could include: Something you know: Passwords, PINs, security questions Something you have: Security tokens, mobile devices, smart cards Something you are: Biometrics (fingerprint, facial recognition, etc.) Implement Multi-Factor Authentication (MFA): For high-risk systems or applications, implement MFA, requiring users to provide at least two different authentication factors to verify their identity. Regular Review and Updates: Periodically review and update the authentication mechanisms based on changes in risk profile, new technologies, or evolving threats.	impact of authentication failures. Authentication Policy: A policy document defining the authentication requirements for different systems and applications based on their risk profile. Evidence of MFA Implementation: Proof of MFA implementation for high-risk systems or applications. Periodic Review Reports: Documentation of periodic reviews and updates to the authentication mechanisms.
2-15-4	The cybersecurity requirements for external web applications must be reviewed periodically.	Review the cybersecurity requirements of external web applications security by conducting a periodic assessment (according to a documented and approved plan for review, and based on a planned interval ("e.g., quarterly") to implement identity and access management requirements by the Cybersecurity function and in	Results of external web applications protection requirements implementation review in the organization. A document that defines the cybersecurity requirements	

		cooperation with relevant departments (such as IT Department). Conduct application review through traditional channels (e.g., email) or automated channels using a compliance management system. The organization may develop a review plan explaining the implementation review schedule for external web applications protection. Review and update cybersecurity requirements for external web applications security in the organization periodically according to a documented and approved plan for review and based on a planned interval or in the event of changes in relevant laws and regulations. Document the review and changes to the cybersecurity requirements for external web applications security in the organization and approve them by the head of the organization or his/her deputy.	application review cycle for the organization's external web applications (Compliance Assessment Schedule). Compliance assessment report that outlines the assessment of the implementation of cybersecurity requirements for external web applications security. An approved document that sets the policy's review schedule. Policy indicating that it has been reviewed and updated, and that changes have been documented and approved by the head of the organization or his/her deputy. Formal approval by the head of the organization or his/her deputy on the updated policy (e.g., via the organization's official e-mail, paper or electronic signature)		
National Cybersecurity Authority – Critical Systems Cybersecurity Controls CSCC					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
2-12-1 In addition to the subcontrols in ECC control	2-12-1-1	Secure Session Management, including	Web Application Protection Policy Template,	Defining and documenting a secure session management process, which includes: -Authentication of sessions.	A report of a secure session, which includes: Session reliability. Lockout session. Session timeout.

2-15-3, cybersecurity requirements for external web applications for the organization's critical systems must include at least the following:		authenticity, lockout, and timeout.	Web Application Security Standard Template	-Access. -Control. -Authorization. -Lockout. -Timeout. Use a trusted server to generate session identifiers. Ensure that the logout function completely terminates the connection/session. Ensure that the session inactivity timeout is as short as possible, and it is recommended that the session timeout be less than several hours.	
	2-12-1-2	Implementing application security and protection standards (OWASP Top Ten) at a minimum.	Web Application Protection Policy Template, Web Application Security Standard Template	Work on establishing a methodology to verify the application of security standards for system applications on a regular basis, with no less than annual updates, according to the OWASP organization. Work to implement and protect each application security standard, which includes: Broken Access Control service. Cryptographic Failures. Injection. Insecure design. Security Misconfiguration error. Vulnerable and Outdated Components.	A document explaining the application of application security standards, clarifying the minimum and the extent of the entity's compliance with the standards.

				Identification and Authentication Failures. Software and Data Integrity Failures. Security Logging and Monitoring Failures. Server-Side Request Forgery.	
2-12-2	With reference to ECC subcontrol 2-15-3-2, multi-tier architecture principle, with minimum 3 tiers, must be used.	Web Application Protection Policy Template, Web Application Security Standard Template	Work on the use of the multi-tier architecture principle, where critical web application components are separated on at least three levels, which consist of: Presentation/client tier. Application/business tier. Database layer.	Diagram of the entity's applications, showing the use of the multi-level architecture principle.	
National Cybersecurity Authority - Cloud Cybersecurity Controls CCC					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
2-14-P-1 In addition to subcontrols in the ECC control 2-15-3, the CSP shall cover the following additional subcontrols for cybersecurity requirements for web	2-14-P-1-1	Protecting information involved in application service transactions against possible risks (e.g.: incomplete transmission, misrouting, unauthorized message alteration, unauthorized disclosure, etc.).	Template for Web Application Security Policy, Template for Web Application Security Standard	-Identify possible risks related to information involved in application service transactions. -Determine security measures that can be applied to protect information involved in application service transactions against identified risks. -Implement defined security measures. -Periodically review and update (or add new if relevant) identified risks	-Web application firewalls appropriately configured. -Traffic inspection and behavioural monitoring established. -Access from known malicious or/and bad reputation sources denied. -Data transmission encryption and integration protection layer (TLS, SSL) applied. -Regular application exposure to the

application security, as a minimum:				and implemented measures to ensure its applicability. -Configure web application firewalls to inspect traffic, apply rules, and perform behavioural monitoring. -Deny access from known malicious or/and bad reputation sources. -Apply Transport Layer Security (TLS, SSL) or other data transmission encryption and integration protection layer. -Review Periodically the application exposure to the Internet to detect unintentional data exposures. - Deny default or common passwords for applications. -Monitor routing tables for malicious/unintentional changes or service redirections. -Establish ongoing monitoring of transactions in as near to real-time manner.	Internet review and unintentional data exposure detection set. -Default or common passwords for applications denied. -Identification of malicious/unintentional changes or service redirections in routing tables implemented. -Ongoing monitoring of transactions established
-------------------------------------	--	--	--	--	--

Risk Considerations in Web Application Security

1. Insecure Application Architecture:

- Poorly designed multi-tier architecture can expose critical components to attacks such as unauthorized access and privilege escalation.

2. Insufficient Authentication and Authorization Mechanisms:

- Weak or misconfigured authentication (e.g., lack of MFA) can lead to credential stuffing, session hijacking, or unauthorized access.

3. Lack of Secure Coding Practices:

- Poorly developed applications may be vulnerable to OWASP Top 10 risks, including SQL injection, cross-site scripting (XSS), and broken access control.

4. Unprotected Data in Transit and at Rest:

- Failure to implement secure protocols (e.g., HTTPS, TLS) can lead to man-in-the-middle (MitM) attacks and data exposure.

5. Insufficient Web Application Firewall (WAF) Implementation:

- Absence or misconfiguration of WAF may fail to block malicious requests such as injection attempts and DDoS attacks.

6. Poor Patch and Update Management:

- Outdated application components, libraries, and frameworks may introduce security vulnerabilities.

7. Lack of Secure API Protection:

- Web applications exposing APIs without proper authentication and rate limiting may suffer from API abuses and data breaches.

8. Session Management Weaknesses:

- Insecure session handling may result in session hijacking, session fixation, or replay attacks.

9. Misconfigured Security Controls:

- Poor implementation of security headers, weak CSP policies, and incorrect ACLs may leave web applications exposed to attacks.

10. Compliance and Regulatory Failures:

- Non-compliance with NCA ECC, CSCC, OWASP, or other regulatory frameworks may lead to penalties and reputational damage.
-

Examples of Technologies for Effective Web Application Security

- 1. Web Application Firewall (WAF):**
 - Tools: ModSecurity, NAXSI
- 2. Secure Protocols & Encryption:**
 - Tools: Let's Encrypt, OpenSSL, Certbot
- 3. Identity & Access Management (IAM):**
 - Tools: Keycloak, Authelia, Authentik
- 4. Secure Code Analysis & Vulnerability Scanners:**
 - Tools: SonarQube (Community Edition), Semgrep, Brakeman
- 5. API Security & Gateway Solutions:**
 - Tools: Kong (Community Edition), WSO2 API Manager, Tyk (Open Source Gateway)
- 6. Content Security Policy (CSP) & Security Headers:**
 - Tools: Mozilla Observatory, SecurityHeaders.io, Helmet.js (for Node.js apps)
- 7. SIEM & Threat Intelligence:**
 - Tools: Wazuh, Elastic Security, MISP
- 8. Web Security Testing Tools:**
 - Tools: OWASP ZAP, Burp Suite Community Edition, Nikto

Examples of KPIs for Web Application Security

- 1. Percentage of Web Applications Covered by WAF:**
 - KPI: % of applications protected by a WAF compared to total web assets.
- 2. Patch Compliance Rate for Web Applications:**
 - KPI: % of critical patches applied within SLA timelines.
- 3. Number of Web Application Security Incidents:**
 - KPI: Count of successful or attempted web-based attacks per month.
- 4. Average Time to Detect (MTTD) and Respond (MTTR) to Web Threats:**
 - KPI: Time taken to detect and remediate security vulnerabilities.
- 5. Percentage of Web Applications Using Secure Protocols (HTTPS, TLS):**
 - KPI: % of applications compliant with secure communication protocols.
- 6. Web Application Security Audit Compliance Rate:**
 - KPI: % of web applications passing security audits and penetration tests.
- 7. Number of High-Risk Vulnerabilities Found in Web Security Assessments:**
 - KPI: Count of critical issues found during testing and mitigation success rates.

Samples of Auditor's Checklist for Web Application Security

- Are WAF and secure coding practices implemented for all external web applications?
 - Is HTTPS enforced across all web applications?
 - Are authentication mechanisms using MFA for user and admin access?
 - Are all web applications tested for vulnerabilities (e.g., OWASP Top 10)?
 - Are application logs reviewed for security events and anomalies?
 - Is session management secure against hijacking and replay attacks?
 - Are third-party APIs and integrations assessed for security risks?
 - Are web applications compliant with NCA ECC and CSCC guidelines?
-

Samples of Audit Scenarios for Web Application Security

Scenario 1: Evaluating WAF Effectiveness

- Objective: Assess the ability of the WAF to detect and block malicious requests.
- Steps: Conduct penetration testing using SQL injection and XSS payloads.
- Key Questions: Are attack attempts logged and blocked in real-time?

Scenario 2: Reviewing Secure Session Management

- Objective: Validate session timeout and secure logout mechanisms.
 - Steps: Attempt to hijack a session using cookie replay.
 - Key Questions: Does the application terminate inactive sessions securely?
-

Case Study 1: Government Agency

Scenario: A government entity's public-facing web portals experienced persistent cyberattacks, including DDoS and SQL injection.

Challenges:

- Outdated application frameworks vulnerable to attacks.
- No WAF protection, leading to frequent downtime.
- Lack of API security and authentication controls.

Actions Taken:

- Implemented F5 WAF with tailored rules against injection attacks.
- Applied multi-factor authentication (MFA) for admin access.
- Conducted regular penetration tests and automated security scans.

Outcomes:

- 90% reduction in successful attack attempts.
 - Improved compliance with NCA ECC requirements.
 - Enhanced uptime and public service availability.
-

Case Study 2: Semi-Government Entity

Scenario: A financial services company experienced unauthorized access attempts due to weak authentication mechanisms.

Challenges:

- Password-only authentication led to account takeovers.
- API endpoints were exposed, leading to data scraping incidents.
- Inconsistent implementation of security headers and CSP.

Actions Taken:

- Enforced multi-tiered authentication using OAuth and JWT tokens.
- Implemented API rate limiting and monitoring.
- Applied strict CSP policies to prevent XSS attacks.

Outcomes:

- 85% decrease in account takeover incidents.
 - API exploitation attempts reduced by 75%.
 - Improved trust and compliance with financial sector regulations.
-

Lessons Learned from the Case Studies

1. **Proactive Security Prevents Attacks:** Regular penetration testing and proactive security controls reduce incident risks.
2. **Multi-Factor Authentication is Essential:** Weak authentication is a primary attack vector; MFA significantly reduces account takeovers.
3. **WAF and API Security Are Critical:** Proper WAF rules and API security best practices prevent common web-based attacks.
4. **Compliance Alignment Enhances Security:** Implementing regulatory controls (e.g., NCA ECC, CCCC) ensures structured and robust security practices.
5. **Automation Improves Security Monitoring:** SIEM and automated testing tools enhance real-time detection and response capabilities.

2.16 Application Security:

Definition: Application Security refers to the measures taken to protect applications from unauthorized access, modification, or disclosure. It involves designing, building, and deploying applications with security considerations in mind, as well as implementing controls to prevent malicious attacks[15], [16], [17].

Objective: The objective of Application Security is to ensure the confidentiality, integrity, and availability of applications and the data they process. This includes protecting against vulnerabilities, mitigating threats, and ensuring compliance with relevant security standards and regulations.

Controls Matrix:

Below is a summary matrix detailing relevant Application Security controls based on NCA CSCC, SAMA CSF, and CMA Cybersecurity Guidelines:

Regulation	Main Controls	Control References
NCA ECC	–	–
SAMA CSF	5	3.3.6-1, 3.3.6-2, 3.3.6-3, 3.3.6-4, 3.3.6-5 (7 sub-controls)
CST CRF	–	–
CMA CSG	5	4.3.10-1, 4.3.10-2, 4.3.10-3, 4.3.10-4, 4.3.10-5 (12 sub-controls)
NCA CSCC	4	2-13-1, 2-13-2, 2-13-3 (4 sub-controls), 2-13-4
NCA CCC CST	–	–
NCA CCC CSP	–	–
NCA TCC	–	–
NCA DCC	–	–
NCA OSMACC	–	–
NCA OTCC	–	–

Application Security Controls:

National Cybersecurity Authority – Critical Systems Cybersecurity Controls CSCC				
Control reference number	Sub-Control	Control clauses	Control implementation guidelines	Expected deliverables
2-13-1		Cybersecurity requirements must be identified, documented and approved to protect the internal applications of the entity's critical systems from cyber risks.	Relevant cybersecurity tools: Web Application Security Standard Template, Procedure for Development of Cybersecurity Documents Template Work to include and document cybersecurity requirements to protect internal web applications in the entity from cyber risks. These requirements include, for example: -Using the multi-tier architecture principle. -Use secure protocols such as HTTPS. -Clarify the acceptable use policy for users. -Secure Session Management, including authenticity, logout, and timeout. Developing an action plan to implement all cybersecurity requirements related to the protection of internal web applications. Include cybersecurity requirements related to the protection of internal applications in the application protection procedures in the entity to ensure compliance with the cybersecurity	The cybersecurity policy document that covers the requirements for protecting the entity's internal applications from cyber risks (electronic copy or official paper copy). Official approval of the document by the head of the entity or his representative (for example: via the entity's official e-mail, or by paper or electronic signature). An action plan document to implement cybersecurity requirements to protect the entity's internal applications. Evidence confirming the periodic review of the implementation of cybersecurity requirements to protect the entity's internal applications. A guide explaining the application of the entity's internal application protection controls, including but not limited to: -A sample of an application design that demonstrates the use of the multi-level architecture principle. -A screenshot of an app demonstrating the use of HTTPS.

			requirements of all internal and external stakeholders.	-A screenshot of the application showing the deployment of the safe usage policy to users. -A screenshot of a secure session with it being trusted, locked, and timed out.
2-13-2	Cybersecurity requirements must be applied; To protect the internal applications of the party's critical systems.		Work to implement all cybersecurity requirements when applying application protection measures in the entity, and the entity's application protection measures must cover, at a minimum, the following, for example: -Multi-tier Architecture. -Use secure protocols such as HTTPS. -Clarify the acceptable use policy for users. -Secure Session Management, including authenticity, logout, and timeout. Developing an action plan to implement all cybersecurity requirements related to application protection. Include cybersecurity requirements related to application protection in the entity's application protection procedures to ensure compliance with cybersecurity requirements for all internal and external stakeholders.	Application security procedures document. Documents confirming the application of cybersecurity requirements related to the protection of applications that are documented in the policy document. An action plan document to implement cyber security requirements to protect applications. Evidence showing the application of application protection controls, for example: -Screenshot showing the use of the multi-level architecture principle in applications. -Screenshot of an application showing the use of the HTTPS protocol. -Screenshot of the app showing the publication of the Acceptable use policy to users. -Screenshot of a secure session including authoritative, locking, and timing out.
2-13-3	2-13-3-1	Using the principle of multi-tier architecture, provided that the number	Relevant cybersecurity tools: Web Application Security Standard Template. In the case of internal applications purchased and operated by a third party, must be: Ensure that the supplier adheres to cyber security policies	Design an internal application that demonstrates the use of the multi-level architecture principle for an internally developed entity-specific application. Design an internal application that

		of levels is not less than 3 (3-Tier Architecture).	and standards, which include the use of the multi-level architecture principle. In the event that there are applications that are developed internally or internal applications that were purchased from a third party but are operated by the entity, must be: Determine the architectural principle levels appropriate to the nature of the web application, which should not be less than three levels: Presentation/client tier. Application/business tier. Database tier. Work to identify the relevant departments to apply the principle of multi-level architecture. Work on applying the principle of multi-level architecture, which must not be less than three levels for all internal applications of the entity.	demonstrates the use of the multi-level architecture principle for an application purchased from an external party.
	2-13-3-2	Use secure protocols (such as HTTPS).	Relevant cybersecurity tools: Web Application Security Standard Template. In the case of internal applications purchased and operated by a third party, it must: Ensure that the supplier adheres to cyber security policies and standards, which include the use of secure protocols. In the event that there are applications that are developed internally or internal applications that were purchased from a third party but are operated by the entity, it must: Determine the secure communications protocol to be applied to the internal applications of the entity, which include, for example: Hypertext Transfer Protocol Security (HTTPS). Secure File Transfer Protocol (SFTP). Transport Layer Security	List of secure protocols used in applications. An internal application demonstrating the use of the HTTPS protocol.

			protocol (TLS). Implementing and downloading secure communication protocols in the internal applications of the entity to protect them. Work to include the application and download of secure communication protocols in the application development life cycle to ensure the protection of applications to be developed in the future.	
	2-13-3-3	Clarify the acceptable use policy for users.	Relevant cybersecurity tools: Web Application Security Standard Template. Work on documenting the policy for the safe use of the entity's internal applications for users. Work to include a safe usage policy on the application login page. Ensure that the safe use policy for users is shared on the entity's internal applications.	Acceptable use policy for users of internal applications. A guide explaining the publication of the Acceptable use policy for App users.
	2-13-3-4	Secure Session Management, including authenticity, lockout, and timeout.	Relevant cybersecurity tools: Web Application Security Standard Template. Defining and documenting a secure session management process, which includes: Authentication. Access. Control. Authorization. Lockout. Timeout. Use a trusted server to generate session identifiers. Ensure that the logout function completely terminates the connection/session. Ensure that the session inactivity timeout is as short as possible, and it is recommended that the session timeout be less than several hours.	Screenshot of one of the secure sessions, including: Session reliability. Lockout the session. Session times out.

2-13-4	Periodically review the cybersecurity requirements to protect the internal applications of the entity's critical systems.	Relevant cybersecurity tools: Procedure for Development of Cybersecurity Documents Template. Work on reviewing the application of cybersecurity requirements to protect the applications of the entity by conducting a periodic assessment (according to a documented and approved plan for review, and based on a specific period of time "for example, on a quarterly basis") to protect the applications by the department concerned with cybersecurity and in cooperation with relevant departments The relationship (such as the department concerned with information technology). Application review may be done through traditional channels (such as email) or it may be automated using a compliance management system. The entity may develop a review plan in which it clarifies the schedule for reviewing the application of cybersecurity requirements to protect the applications of the entity. Periodically review and update the cybersecurity requirements to protect the applications of the entity according to a documented and approved plan for review based on a specific period of time or in the event of changes in the relevant legislative and regulatory requirements. Documenting the review and changes made to the cybersecurity requirements to protect	The policy document indicates that it has been reviewed and updated, and the changes have been documented and approved by the head of the entity or his representative. Official approval and approval by the head of the entity or his representative on the updated policy (for example: via the entity's official e-mail, or by paper or electronic signature)
--------	---	--	---

		applications in the entity and having them approved by the head of the entity or his representative.	
SAMA Cyber Security Framework CSF			
Control reference number	Control clauses	Control implementation guidelines	Expected deliverables
3.3.6-1	The application cyber security standards should be defined, approved and implemented.	Define and document the application cybersecurity standards, obtain necessary approvals, and implement the standards.	Documented application cybersecurity standards. Evidence of approval.
3.3.6-2	The compliance with the application security standards should be monitored.	Implement a process for monitoring compliance with the application security standards.	Compliance monitoring reports.
3.3.6-3	The effectiveness of the application cyber security controls should be measured and periodically evaluated.	Define metrics to track the effectiveness of the application cybersecurity controls. Regularly assess the effectiveness of the controls using these metrics and make adjustments as needed.	Reports on the effectiveness of application cybersecurity controls. Documentation of periodic evaluations.
3.3.6-4	Application development should follow the approved secure system development life cycle methodology (SDLC).	Ensure that application development follows the approved secure system development life cycle (SDLC) methodology.	Evidence of adherence to the secure SDLC methodology.
3.3.6-5 The application security standard should include:	a Secure coding standards.	Define and implement secure coding standards for application development.	Documented secure coding standards.
	b The cyber security controls implemented (e.g., configuration parameters, events to monitor and	Implement appropriate cybersecurity controls for applications, including configuration parameters, event monitoring and retention, and identity and access management.	Evidence of implemented cybersecurity controls for applications.

	retain [including system access and data], identity and access management).		
	c The segregation of duties within the application (supported with a documented authorization matrix).	Implement segregation of duties within applications and document the authorization matrix.	Documented authorization matrix.
	d The protection of data aligned with the (agreed) classification scheme (including privacy of customer data and, avoiding unauthorized access and (un)intended data leakage).	Ensure that data protection measures are aligned with the agreed classification scheme and include provisions for protecting customer data and preventing unauthorized access and data leakage.	Evidence of data protection measures aligned with the classification scheme.
	e Vulnerability and patch management.	Implement a vulnerability and patch management process for applications.	Vulnerability and patch management procedures.
	f Back-up and recovery procedures.	Define and implement backup and recovery procedures for applications.	Backup and recovery procedures for applications.
	g Periodic cyber security compliance review.	Conduct periodic cybersecurity compliance reviews for applications.	Compliance review reports.
CMA Cybersecurity Guidelines			
Control reference number	Control clauses	Control implementation guidelines	Expected deliverables

4.3.10-1	Define, document, approve and implement applications cybersecurity controls.	Define and document the applications cybersecurity controls, obtain necessary approvals, and implement the controls.	Documented applications cybersecurity controls. Evidence of approval.
4.3.10-2	Monitor compliance with cybersecurity controls to protect applications.	Implement a process for monitoring compliance with the applications cybersecurity controls.	Compliance monitoring reports.
4.3.10-3	Periodically measure and evaluate effectiveness of applications cybersecurity controls.	Define metrics to track the effectiveness of the applications cybersecurity controls. Regularly assess the effectiveness of the controls using these metrics and make adjustments as needed.	Reports on the effectiveness of applications cybersecurity controls. Documentation of periodic evaluations.
4.3.10-4	Follow the adopted methodology on Software Development Life Cycle upon development of applications.	Ensure that application development follows the adopted methodology on the Software Development Life Cycle (SDLC).	Evidence of adherence to the adopted SDLC methodology.
4.3.10-5 Applications Cybersecurity controls shall include the following:	a Adoption of Applications' Secure Coding Standards.	Adopt and implement secure coding standards for application development.	Documented secure coding standards.
	b Applicable cybersecurity controls (Configuration Parameters) and events to be monitored and retained (including system and data access), Identity Management, Access privileges).	Implement applicable cybersecurity controls for applications, including configuration parameters, event monitoring and retention, identity management, and access privileges.	Evidence of implemented cybersecurity controls for applications.
	c Using reliable and approved sources and libraries.	Use only reliable and approved sources and libraries for application development.	List of approved sources and libraries.
	d Using Multi-tier Architecture Principle, Multi-Factor	Utilize multi-tier architecture principles, multi-factor authentication, web application firewalls, and secure protocols for applications.	Evidence of implementation of multi-tier architecture, multi-factor authentication, web application firewalls, and secure protocols.

	Authentication, Web Application Firewall and secure protocols.		
e	Conducting penetration testing for all external (Online) services annually at minimum.	Conduct annual penetration testing for all external (online) services.	Penetration testing reports.
f	Application integration security.	Ensure secure integration of applications with other systems and services.	Evidence of secure application integration.
g	Acceptable Use Policy.	Define and implement an acceptable use policy for applications.	Acceptable use policy for applications.
h	Segregation of Duties supported by the approved matrix of authorities.	Implement segregation of duties within applications and support it with an approved matrix of authorities.	Documented matrix of authorities.
i	Protecting and dealing with data according to the classification system adopted (including client data privacy, prevent unauthorized access, intended or unintended data leakage).	Protect and handle data according to the adopted classification system, including provisions for client data privacy, preventing unauthorized access, and preventing data leakage.	Evidence of data protection measures aligned with the classification system.
j	Manage vulnerability, updates package and security patching.	Implement a vulnerability management, updates, and security patching process for applications.	Vulnerability and patch management procedures.
k	Backups and data recovery procedures.	Define and implement backup and data recovery procedures for applications.	Backup and recovery procedures for applications.
l	Periodic review of compliance with cybersecurity controls.	Conduct periodic reviews of compliance with cybersecurity controls for applications.	Compliance review reports

Risk Considerations in Application Security

1. Insecure Software Development Lifecycle (SDLC):

- Lack of secure coding practices can introduce vulnerabilities such as injection attacks and insecure deserialization.

2. Weak Authentication and Authorization Controls:

- Inadequate access controls and poor enforcement of authentication mechanisms (e.g., no MFA) can lead to unauthorized access.

3. Outdated Software and Unpatched Vulnerabilities:

- Using outdated frameworks, third-party libraries, or failing to apply security patches increases exposure to known exploits.

4. Unprotected Data Storage and Transmission:

- Failure to implement proper encryption (e.g., TLS, AES) can lead to data leaks, tampering, and compliance violations.

5. Poor API Security Management:

- Exposed or unsecured APIs can be exploited for unauthorized data access, API abuse, or injection attacks.

6. Business Logic Vulnerabilities:

- Inadequate validation of input parameters and logical flows may allow users to bypass security controls.

7. Lack of Secure Session Management:

- Poor session handling can result in session hijacking, fixation, or replay attacks.

8. Insufficient Monitoring and Logging:

- Lack of application logging and security monitoring may hinder incident response and forensic investigations.

9. Compliance and Regulatory Risks:

- Non-adherence to cybersecurity regulations (e.g., NCA CSCC, SAMA CSF) can result in legal penalties and reputational damage.

10. Insider Threats:

- Malicious or negligent insiders with access to sensitive applications can cause data breaches or sabotage critical operations.

Examples of Technologies for Effective Application Security

- **Secure Coding and Static Analysis Tools:**

Tools: SonarQube (Community Edition), Semgrep, Brakeman

- **Web Application Firewalls (WAF):**

Tools: ModSecurity, NAXSI

- **API Security and Gateway Solutions:**

Tools: Kong (Community Edition), Tyk (Open Source), WSO2 API Manager

- **Identity and Access Management (IAM):**

Tools: Keycloak, Authelia, Authentik

- **Secure DevOps & CI/CD Security:**

Tools: GitLab CI/CD (open-source version), Trivy, Aqua Trivy, OWASP Dependency-Check

- **Application Security Testing (AST):**
Tools: OWASP ZAP, Burp Suite Community Edition, Nikto
 - **Runtime Application Self-Protection (RASP):**
Tools: OpenRASP
 - **Security Information and Event Management (SIEM):**
Tools: Wazuh, Elastic Security, OSSIM
-

Examples of KPIs for Application Security

1. Percentage of Applications Passing Security Audits:

- KPI: % of applications compliant with security standards (e.g., NCA, SAMA, OWASP).

2. Number of High-Risk Vulnerabilities in Security Scans:

- KPI: Count of critical vulnerabilities detected per application security assessment.

3. Time to Patch Identified Vulnerabilities (MTTR):

- KPI: Average time taken to remediate critical security flaws.

4. API Security Compliance Rate:

- KPI: % of APIs implementing authentication and access control mechanisms.

5. Number of Successful or Attempted Application Attacks:

- KPI: Number of detected attack attempts, categorized by attack type.

6. Application Security Awareness Training Completion Rate:

- KPI: % of developers completing secure coding training.
-

Samples of Auditor's Checklist for Application Security

- Are secure coding standards defined, documented, and enforced in the SDLC?
 - Are authentication and access controls implemented, including MFA?
 - Are web applications protected by a Web Application Firewall (WAF)?
 - Are security testing tools integrated into the development lifecycle?
 - Are APIs secured with authentication, rate limiting, and input validation?
 - Are all application vulnerabilities patched within defined SLAs?
 - Are audit logs reviewed for unauthorized access and anomalies?
 - Are applications compliant with NCA CSCC, SAMA CSF, and industry best practices?
-

Samples of Audit Scenarios for Application Security

Scenario 1: Evaluating Secure Software Development Practices

- Objective: Assess whether secure coding practices are integrated into the SDLC.
- Steps: Review secure coding policies, examine code review processes, and verify vulnerability scanning reports.
- Key Questions: Are static analysis and penetration testing results reviewed before deployment?

Scenario 2: Reviewing Application Access Control and Authentication Security

- Objective: Validate enforcement of authentication and access control policies.
 - Steps: Review user roles, conduct access control testing, and attempt privilege escalation.
 - Key Questions: Are least privilege and role-based access control (RBAC) principles enforced?
-

Case Study 1: Application Security in a Government Ministry

Scenario: A government ministry developed an e-service portal for citizens, but penetration testing revealed several critical vulnerabilities.

Challenges:

- Weak authentication mechanisms leading to unauthorized access attempts.
- Lack of security validation in the SDLC, resulting in frequent security issues.
- Exposure of APIs to the public without proper security controls.

Actions Taken:

- Implemented MFA and RBAC for user authentication.
- Integrated security testing into the CI/CD pipeline.
- Deployed API Gateway with rate limiting and OAuth authentication.

Outcomes:

- 70% reduction in security vulnerabilities reported in audits.
 - Improved user authentication security and compliance with NCA CCCC.
 - Strengthened API security, reducing unauthorized data access incidents.
-

Case Study 2: Strengthening Application Security in a Bank

Scenario: A bank's mobile banking application faced credential stuffing attacks and API security vulnerabilities.

Challenges:

- No MFA on high-risk transactions, leading to account takeovers.
- Unsecured API endpoints allowed unauthorized data scraping.
- Inadequate application logging hindered fraud detection.

Actions Taken:

- Introduced MFA for all critical banking transactions.
- Implemented API security controls, including token-based authentication.
- Enhanced logging and real-time monitoring using SIEM solutions.

Outcomes:

- 80% decrease in fraud incidents due to strengthened authentication.
 - API exploitation reduced significantly, improving customer data security.
 - Enhanced monitoring and incident response capabilities.
-

Lessons Learned from the Case Studies

- 1. Integrating Security Early in the Development Lifecycle Prevents Risks:**
 - Secure SDLC and DevSecOps reduce vulnerabilities introduced in production.
- 2. Strong Authentication and Authorization Controls Reduce Fraud and Unauthorized Access:**
 - Enforcing MFA and access controls mitigates the risk of credential theft.
- 3. API Security is Critical for Protecting Data and Preventing Abuse:**
 - Proper API authentication, rate limiting, and encryption prevent exploitation.
- 4. Compliance with Regulatory Standards Ensures a Strong Security Posture:**
 - Aligning with frameworks like NCA CSCC and SAMA CSF improves audit readiness.
- 5. Continuous Monitoring and Security Testing Enhance Threat Detection:**
 - Regular vulnerability assessments, SIEM monitoring, and automated security scans improve application resilience.

2.17 Key Management:

Definition: Key Management refers to the process of handling cryptographic keys throughout their lifecycle, including their generation, distribution, storage, usage, rotation, revocation, and destruction. It ensures that cryptographic keys used to protect sensitive data and secure transactions are managed securely to prevent unauthorized access, loss, or compromise [18], [19], [20].

Objective: To ensure the secure management of CSP (Cloud Service Provider) and CST (Cloud Service Tenant) cryptographic keys to protect confidentiality, integrity, and availability of information and technical assets. This involves enforcing ownership, secure storage, retrieval mechanisms, audit trails, and periodic reviews to maintain compliance with cybersecurity best practices and regulatory requirements.

Controls Matrix:

Below is a summary matrix detailing relevant key management controls based on NCA CCC:

Regulation	Main Controls	Control References
NCA ECC	—	—
SAMA CSF	—	—
CST CRF	—	—
CMA CSG	—	—
NCA CSCC	—	—
NCA CCC CST	4	2-15-T-1, 2-15-T-2, 2-15-T-3 (2 sub-controls), 2-15-T-4
NCA CCC CSP	4	2-15-P-1, 2-15-P-2, 2-15-P-3 (3 sub-controls), 2-15-P-4
NCA TCC	—	—
NCA DCC	—	—
NCA OSMACC	—	—
NCA OTCC	—	—

Key Management Controls:

National Cybersecurity Authority - Cloud Cybersecurity Controls CCC					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
2-15-P-1	-	Cybersecurity requirements for key management processes within the CSP shall be identified, documented, and approved.	Key Management Systems (KMS), Hardware Security Modules (HSM)	Develop and document a comprehensive key management policy covering generation, distribution, rotation, and decommissioning.	Approved key management policy document signed by the CSP.
2-15-P-2	-	Cybersecurity requirements for key management processes within the CSP shall be applied.	AWS KMS, Azure Key Vault, Google Cloud KMS	Implement key management best practices to securely store and protect cryptographic keys used in CSP environments.	Evidence of applied key management practices, such as configuration settings and compliance reports.
2-15-P-3 In addition to the ECC subcontrol 2-8-3-2, cybersecurity requirements for key management	2-15-P-3-1	Ensure well-defined ownership for cryptographic keys.	Identity and Access Management (IAM) tools, PKI Solutions	Assign key ownership roles and enforce role-based access controls (RBAC) for cryptographic key management.	List of key owners, assigned roles, and an access control policy.
	2-15-P-3-2	A secure cryptographic key retrieval mechanism in case of key loss (e.g., backup of keys and enforcement of trusted key storage, strictly external to cloud).	Encrypted Backup Solutions, HSM-based storage	Establish a redundant and highly secure key backup system with multi-location storage and encryption standards.	Documented backup process, periodic backup reports, and key retrieval procedures.

within the CSP shall cover, at minimum, the following:	2-15-P-3-3	Activation and monitoring of all audit trails of keys.	SIEM Solutions, Audit Logging Tools (Splunk, IBM QRadar)	Enable continuous monitoring of cryptographic key usage, ensuring all actions are logged, analyzed, and stored securely.	Audit logs and reports verifying cryptographic key lifecycle monitoring.
2-15-P-4	-	Cybersecurity requirements for key management within the CSP shall be reviewed periodically.	Compliance Management Tools, Security Assessment Frameworks	Perform regular security assessments and compliance audits on the CSP key management processes.	Review reports and audit assessments for CSP key management compliance.
2-15-T-1	-	Cybersecurity requirements for key management within the CST shall be identified, documented, and approved.	Key Management Systems (KMS), Hardware Security Modules (HSM)	Define and document a key management policy, covering key generation, distribution, storage, rotation, and destruction.	Approved key management policy document for CST.
2-15-T-2	-	Cybersecurity requirements for key management within the CST shall be applied.	AWS KMS, Azure Key Vault, Google Cloud KMS	Implement key management controls to ensure the security of cryptographic keys used in cloud environments.	Evidence of implemented key management practices, such as system logs and configuration settings.
2-15-T-3 In addition to the ECC	2-15-T-3-1	Ensure well-defined ownership for cryptographic keys.	Identity and Access Management	Assign cryptographic key owners and enforce role-based access control	List of key owners, assigned roles, and an

subcontrol 2-8-3-2, cybersecurity requirements for key management within the CST shall cover, at minimum, the following:			(IAM) tools, PKI Solutions	(RBAC) for key management operations.	access control policy document.
	2-15-T-3-2	A secure data retrieval mechanism in case of cryptographic encryption key loss (e.g., backup of keys and enforcement of trusted key storage, strictly external to cloud).	Encrypted Backup Solutions, HSM-based storage	Establish a highly secure, redundant key backup and storage mechanism, ensuring compliance with data security best practices.	Backup process documentation, periodic backup reports, and retrieval test results.
2-15-T-4	-	Cybersecurity requirements for key management within the CST shall be applied and reviewed periodically.	Compliance Management Tools, Security Assessment Frameworks	Conduct periodic security reviews and audits of CST key management policies and implementations.	Audit reports and review assessments for CST key management.

Risk Considerations in Key Management

1. **Unauthorized Access to Cryptographic Keys:** Weak access controls may lead to unauthorized key usage or exposure.
 2. **Key Compromise or Theft:** Inadequate storage or transmission of cryptographic keys can result in data breaches.
 3. **Failure to Rotate or Revoke Keys:** Delayed rotation or revocation increases the risk of key misuse.
 4. **Insufficient Backup and Recovery Mechanisms:** Key loss without recovery options can lead to data inaccessibility.
 5. **Lack of Auditability and Monitoring:** Without logging and monitoring, security incidents involving keys may go undetected.
 6. **Non-Compliance with Security Regulations:** Failure to adhere to NCA CCC or any other cybersecurity frameworks can result in penalties.
-

Examples of Technologies for Effective Key Management

1. **Key Management Systems (KMS):**
 - Tools: HashiCorp Vault (open-source), Barbican (OpenStack Key Manager)
 2. **Hardware Security Modules (HSM):**
 - Tools: SoftHSM (for development/testing)
 3. **Identity and Access Management (IAM):**
 - Tools: Keycloak, Authelia, Authentik
 4. **SIEM for Key Monitoring:**
 - Tools: Wazuh, Elastic Security, OSSIM
 5. **Encryption and Secure Storage:**
 - Tools: HashiCorp Vault (open-source), OpenSSL, GnuPG
 6. **Compliance and Auditing Tools:**
 - Tools: OpenSCAP, Wazuh (compliance module), AIDE (Advanced Intrusion Detection Environment)
-

Examples of KPIs for Key Management

1. **Percentage of Keys Properly Managed:** % of cryptographic keys stored securely within a managed system.
 2. **Key Rotation Compliance Rate:** % of keys rotated within their defined lifecycle.
 3. **Number of Key Compromise Incidents:** Total incidents related to unauthorized access or exposure.
 4. **Time to Recover Lost Keys:** Average time taken to restore key access in case of failure.
 5. **Audit Trail Completeness:** % of key-related activities logged and monitored.
-

Samples of Auditor's Checklist for Key Management

- Is there a defined key management policy covering lifecycle management?
 - Are cryptographic keys stored securely in a KMS or HSM?
 - Are access controls and role-based permissions enforced for key usage?
 - Are key rotation and revocation processes regularly tested and implemented?
 - Is key usage monitored with SIEM or other security tools?
 - Are audit logs maintained and reviewed for unauthorized activities?
 - Is compliance with NCA and other cybersecurity frameworks validated?
-

Samples of Audit Scenarios for Key Management

Scenario 1: Evaluating Cryptographic Key Storage Security

- **Objective:** Assess whether encryption keys are securely stored and managed.
- **Steps:** Review KMS/HSM configurations, check access logs, and verify key backup procedures.
- **Key Questions:** Are cryptographic keys stored in a secure environment with restricted access?

Scenario 2: Testing Key Rotation and Revocation Processes

- **Objective:** Validate that key lifecycle management practices are in place.
 - **Steps:** Simulate key expiration and revocation, assess policy enforcement, and check access controls.
 - **Key Questions:** Are outdated keys properly deactivated to prevent unauthorized access?
-

Case Study 1: Semi-Government Entity

Scenario: A financial regulator needed to enhance cryptographic key security due to regulatory requirements.

Challenges:

- Weak key rotation practices led to extended usage of aging cryptographic keys.
- Lack of SIEM integration for key usage monitoring.
- No defined ownership structure for key lifecycle management.

Actions Taken:

- Implemented HSM-based storage with strict access control policies.
- Integrated SIEM to monitor key activity in real-time.
- Developed and enforced a key rotation schedule.

Outcomes:

- 90% improvement in compliance with key management policies.
 - Enhanced monitoring led to early detection of unauthorized key usage.
 - Full alignment with NCA and SAMA CSF regulations.
-

Case Study 2: Technology Company

Scenario: A multinational technology company faced key management risks after a cryptographic key compromise incident.

Challenges:

- A lack of key backup and retrieval mechanisms led to data loss risks.
- Unauthorized personnel had access to cryptographic keys.
- Inconsistent key management policies across multiple locations.

Actions Taken:

- Adopted a centralized key management system (KMS) integrated with cloud services.
- Enforced strict RBAC for key access, limiting exposure to authorized personnel.
- Developed automated backup and restoration processes for cryptographic keys.

Outcomes:

- 75% reduction in unauthorized access attempts.
- Automated key recovery reduced downtime from key loss incidents.
- Strengthened global compliance with cybersecurity regulations.

Lessons Learned from the Case Studies

1. **Centralized Key Management Enhances Security:** A managed KMS or HSM reduces the risk of unauthorized access and exposure.
2. **Continuous Monitoring and Logging Are Critical:** Real-time SIEM integration ensures timely detection of key misuse.
3. **Enforcing Access Controls Prevents Key Compromise:** Strong RBAC minimizes the likelihood of unauthorized access.
4. **Regular Key Rotation and Revocation Are Necessary:** Periodic key updates reduce security risks and prevent unauthorized persistence.
5. **Compliance Alignment Strengthens Security Posture:** Adhering to NCA, SAMA, and industry standards ensures regulatory success.

2.18 System Development Security:

Definition: System Development Security refers to the implementation of security controls, processes, and best practices throughout the software development lifecycle (SDLC) to protect applications, systems, and services from security threats. It includes secure coding practices, vulnerability assessments, security testing, and compliance with cybersecurity frameworks to mitigate risks associated with software development and deployment [21], [22], [23], [24].

Objective: To ensure confidentiality, integrity, and availability of applications and systems by incorporating security principles at every phase of the SDLC. This involves secure design, threat modeling, secure coding, rigorous testing, and deployment best practices to reduce vulnerabilities, prevent unauthorized access, and comply with cybersecurity regulations.

Controls Matrix:

Below is a summary matrix detailing relevant System Development Security controls based on NCA CCC CSP and CST CRF:

Regulation	Main Controls	Control References
NCA ECC	—	—
SAMA CSF	—	—
CST CRF	8	4.14.1, 4.14.2, 4.14.3, 4.14.4, 4.14.5, 4.14.6, 4.14.7, 4.14.8
CMA CSG	—	—
NCA CSCC	—	—
NCA CCC CST	—	—
NCA CCC CSP	4	2-16-P-1, 2-16-P-2, 2-16-P-3 (2 sub-controls), 2-16-P-4
NCA TCC	—	—
NCA DCC	—	—
NCA OSMACC	—	—
NCA OTCC	—	—

System Development Security Controls:

National Cybersecurity Authority - Cloud Cybersecurity Controls CCC					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
2-16-P-1	-	Cybersecurity requirements for system development within the CSP shall be identified, documented, and approved.	Template for Secure Software Development Lifecycle Policy	- Identify cybersecurity requirements for system development using questionnaires and workshops with relevant stakeholders. - Document these requirements (Cybersecurity standard for System Development).	- Cybersecurity requirements for system development are formally approved and periodically reviewed.
2-16-P-2	-	Cybersecurity requirements for system development within the CSP shall be applied.	-	- Enforce Cybersecurity standard for System Development. - Measure compliance with that standard. - Manage exceptions for this standard. - Escalate violations regarding this standard.	- Enforced cybersecurity requirements for system development. - Document outlining the implementation of the compliance measurement tool for standard implementation. - Documents for violation escalation procedures.
2-16-P-3 Cybersecurity requirements for system	2-16-P-3-1	Considering cybersecurity requirements of the Cloud Technology Stack and relevant systems in the	Template for Secure Software Development Lifecycle Policy	- Identify cybersecurity requirements of the Cloud Technology Stack and relevant systems for cloud computing services.	- Sample of compliance review. - Applied cybersecurity requirements.

development within the CSP shall include at a minimum the following controls along the development lifecycle:		design and implementation of the cloud computing services.		- Apply identified requirements both during design and implementation of cloud computing services. - Periodically review the compliance with the requirements and monitor whether new applicable requirements occurred.	
	2-16-P-3-2	Protecting system development environments, testing environments (including data used in testing environments), and integration platforms.	Template for Secure Software Development Lifecycle Policy	- Identify risks related to development environments, testing environments, and integration platforms. - Develop and implement protection measures to provide secure development and testing environments, as well as secure integration platforms, taking account of identified risk. - Ensure that protection of data used in testing environments is included in the implemented protection measures.	- List of identified risks. - Evidence confirming the identification of preventive measures and ensuring the protection of data used in the testing environment.
2-16-P-4	-	Cybersecurity requirements for system development within the CSP shall be applied and reviewed periodically.	Template for Cybersecurity Reviewing and Auditing Policy Template for Developing Cybersecurity Documentation Procedures	- Review requirements periodically based on defined timeframes, at least annually. - Define Roles and Responsibilities in the review process. - Update requirements, if applicable. - Maintain records of periodical reviews (e.g.: who and when reviewed and a change log).	- Current cybersecurity requirements for system development. - Sample of periodical reviews.
CST CRF					
Control reference number	Control clauses		Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables

4.14.1 CL 1	Define and document [Requirements for Secure Software Development] which consider the following: • Utilization of secure coding standards and practices (e.g. approved libraries, APIs) • Segregation and allocation of access rights to different environments • Conducting tests to verify the compliance of the developed software with the organization's cybersecurity requirements	Secure Software Development Policy, Secure Coding Guidelines	Develop and document secure software development requirements. Ensure access controls are properly allocated and conduct security testing.	Approved secure software development policy, testing results validating compliance.
4.14.2 CL 1	Ensure that only authorized personnel have access to the appropriate environment [Identity and Access Management].	Identity and Access Management (IAM) Tools	Implement strict access control measures, monitor and log access, and enforce role-based access control (RBAC).	IAM access control policies, access logs, audit reports.
4.14.3 CL 1	Utilize secure coding standards and practices (e.g. security-by-design principles supported via static or dynamic analysis tools) and ensure the security of integration between the applications.	Static & Dynamic Code Analysis Tools (SAST, DAST), Secure Development Frameworks	Apply security-by-design principles, conduct static and dynamic security testing, and verify integration security across applications.	Secure coding compliance reports, static & dynamic analysis results.
4.14.4 CL 1	Ensure a secure and reliable transmission of the software between the environments.	Secure Transmission Protocols (TLS, HTTPS, SFTP)	Implement encryption for software transmission, ensure integrity verification mechanisms.	Encryption & transmission integrity logs, verification reports.
4.14.5 CL 1	Use only trusted and up-to-date third-party components for internally developed software.	Software Composition Analysis (SCA) Tools	Validate third-party components, conduct vulnerability assessments, and regularly update dependencies.	Third-party component validation reports,

				vulnerability assessment results.
4.14.6 CL 2	Conduct and document a security review for developed software and source code (e.g. performing error checking for all input).	Secure Code Review Tools, Source Code Analysis Tools	Perform security reviews as part of SDLC, identify and remediate vulnerabilities in source code.	Security review reports, secure code analysis findings.
4.14.7 CL 2	Conduct security tests to verify the extent to which the developed software meets the organization's cybersecurity requirements.	Security Testing Tools (Penetration Testing, Fuzz Testing)	Conduct penetration testing and ensure applications are tested against OWASP Top 10 vulnerabilities.	Security test reports, remediation actions taken.
4.14.8 CL 3	Continuously measure, review and optimize the [Requirements for Secure Software Development].	Secure Software Development Lifecycle (SDLC) Monitoring Tools	Establish a continuous monitoring process, review secure software development policies periodically, and apply lessons learned.	Secure software development performance metrics, updated policies.

Risk Considerations in System Development Security

1. **Insecure Coding Practices:** Poor coding habits can introduce vulnerabilities such as injection attacks, insecure deserialization, and buffer overflows.
 2. **Lack of Secure Software Development Lifecycle (SDLC) Integration:** Failing to incorporate security early in development increases risks of late-stage vulnerabilities.
 3. **Weak Access Controls in Development & Testing Environments:** Unauthorized users may gain access to sensitive code, APIs, and test data, leading to data exposure.
 4. **Unpatched Third-Party Components:** Using outdated or vulnerable open-source libraries can introduce security flaws.
 5. **Insufficient Security Testing & Code Reviews:** Lack of static and dynamic security testing (SAST/DAST) can result in undetected vulnerabilities.
 6. **Weak Data Protection in Testing Environments:** Using real customer data without masking or encryption increases the risk of compliance violations.
 7. **Non-Adherence to Regulatory Requirements:** Failure to comply with frameworks like NCA CCC, OWASP, and SAMA CSF can lead to penalties.
-

Examples of Technologies for Effective System Development Security

1. **Secure Development Lifecycle (SDLC) Management:**
 - Tools: OWASP SAMM, GitLab, GitHub Projects (free tiers)
 2. **Static Application Security Testing (SAST):**
 - Tools: SonarQube (Community Edition), Semgrep, Brakeman
 3. **Dynamic Application Security Testing (DAST):**
 - Tools: OWASP ZAP, Burp Suite Community Edition, w3af
 4. **Software Composition Analysis (SCA):**
 - Tools: OWASP Dependency-Check, Syft, Trivy
 5. **Threat Modeling & Secure Architecture:**
 - Tools: OWASP Threat Dragon, IriusRisk Community Edition
 6. **CI/CD Security & DevSecOps:**
 - Tools: GitLab CI/CD (open-source), Jenkins Security Plugins, Trivy
 7. **Penetration Testing & Code Review:**
 - Tools: Metasploit Framework, Codacy (free for open-source), Nikto
 8. **Data Masking & Protection in Testing:**
 - Tools: Faker (Python), Data Anonymization Toolkits, Open Data Masking Frameworks (e.g., Aircloak's open tools)
-

Examples of KPIs for System Development Security

1. **Percentage of Secure Code Compliance:** Measures the percentage of code that adheres to secure coding standards.
 2. **Number of High-Risk Vulnerabilities in Pre-Deployment Testing:** Tracks critical security defects before production.
 3. **Mean Time to Remediate (MTTR) Identified Vulnerabilities:** Measures efficiency in fixing security issues.
 4. **Security Test Coverage Rate:** Determines the percentage of applications undergoing SAST/DAST/security assessments.
 5. **Access Violation Incidents in Development Environments:** Monitors unauthorized access attempts to development/test systems.
 6. **Regulatory Compliance Adherence Score:** Measures compliance with NCA CCC, CRF, and OWASP guidelines.
-

Samples of Auditor's Checklist for System Development Security

- Are security requirements integrated into the software development lifecycle (SDLC)?
 - Does the organization perform threat modeling and secure design reviews?
 - Are static and dynamic security testing (SAST/DAST) tools implemented?
 - Are all development environments protected with proper access controls?
 - Is real customer data masked or anonymized in testing environments?
 - Are secure coding practices followed, including compliance with OWASP Top 10?
 - Are software updates and patches applied regularly?
 - Does the organization monitor and audit development environments for security breaches?
-

Samples of Audit Scenarios for System Development Security

Scenario 1: Secure Software Development Lifecycle Compliance

Objective: Assess whether security controls are properly embedded within the SDLC.

Steps:

- Review SDLC security policies.
- Check for threat modeling and risk assessments during development.
- Validate developer training records on secure coding.

Key Questions: Are security reviews conducted at each SDLC phase?

Scenario 2: Secure Coding & Vulnerability Testing

Objective: Ensure security testing is integrated into development processes.

Steps:

- Verify the use of SAST/DAST in CI/CD pipelines.
- Review security test reports and vulnerability remediation logs.
- Check compliance with OWASP Top 10 security guidelines.

Key Questions: Are vulnerabilities remediated before deployment?

Scenario 3: Development & Testing Environment Security

Objective: Evaluate access control and data security in development environments.

Steps:

- Check if access controls (RBAC, MFA) are enforced for developers and testers.
- Verify if sensitive data in testing is properly anonymized or masked.
- Review audit logs for unauthorized access attempts.

Key Questions: Are development and testing environments secured against insider threats?

Case Study: System Development Security in a Semi-Government Entity

Scenario:

A semi-government entity faced multiple security incidents in its internally developed applications due to insecure coding practices and lack of security testing.

Challenges:

- No static or dynamic security testing (SAST/DAST) integration in development pipelines.
- Weak access controls in development and testing environments.
- Use of outdated third-party libraries with known vulnerabilities.
- Lack of compliance with OWASP Top 10 security best practices.

Actions Taken:

- Integrated SAST & DAST tools into DevSecOps pipelines to detect vulnerabilities early.
- Implemented IAM & RBAC controls to limit developer access to sensitive environments.
- Mandated threat modeling for all new applications.
- Established automated software composition analysis (SCA) to track third-party library security.
- Conducted security awareness training for developers on secure coding best practices.

Outcomes:

- 80% reduction in critical security vulnerabilities before deployment.
 - 95% compliance with OWASP Top 10 security guidelines.
 - Reduced security testing time by 60% with automated tools.
 - Regulatory compliance achieved for NCA CCC cybersecurity controls.
-

Lessons Learned from the Case Study

1. **Security Must Be Integrated Early in SDLC:** Identifying vulnerabilities late in development increases costs and risks.
2. **Automated Security Testing Enhances Efficiency:** Integrating SAST, DAST, and SCA tools in CI/CD improves security detection rates.
3. **Strict Access Controls Are Essential:** Implementing RBAC and MFA prevents unauthorized access to critical systems.
4. **Regular Security Training for Developers Reduces Risk:** Secure coding awareness minimizes unintentional vulnerabilities.
5. **Compliance Alignment Improves Security Posture:** Adhering to NCA CCC and OWASP ensures strong regulatory compliance.

2.19 Storage Media Security:

Definition: Storage Media Security refers to the implementation of security controls and best practices to ensure the safe handling, storage, and disposal of physical and digital media containing sensitive information. It involves enforcing strict access controls, secure disposal mechanisms, and encryption techniques to prevent unauthorized access, data breaches, and information leakage from removable storage devices, hard drives, and other media [25], [26], [27], [28].

Objective: To ensure confidentiality, integrity, and availability of information stored on physical and digital media within CSPs by implementing security measures for proper usage, handling, storage, disposal, and access control. This includes enforcing sanitization, labeling, encryption, and access restriction mechanisms to mitigate risks associated with unauthorized access, loss, or theft of sensitive data.

Controls Matrix:

Below is a summary matrix detailing relevant Storage Media Security controls based on NCA CCC CSP:

Regulation	Main Controls	Control References
NCA ECC	—	—
SAMA CSF	—	—
CST CRF	—	—
CMA CSG	—	—
NCA CCCC	—	—
NCA CCC CST	—	—
NCA CCC CSP	4	2-17-P-1, 2-17-P-2, 2-17-P-3 (6 sub-controls), 2-17-P-4
NCA TCC	—	—
NCA DCC	—	—
NCA OSMACC	—	—
NCA OTCC	—	—

Storage Media Security Controls:

National Cybersecurity Authority - Cloud Cybersecurity Controls CCC			
Control reference number	Control clauses	Control implementation guidelines	Expected deliverables
2-17-P-1	Ensure CSPs' secure handling of information and data on physical media. Cybersecurity requirements for usage of information and data media within the CSP shall be identified, documented and approved.	Identify cybersecurity requirements for usage of information and media (e.g.: labelling, encryption, secure storage, secure disposal) - use questionnaires and conduct workshops with relevant stakeholders. Define Information and Data Media Usage standard to document these requirements. Formally approve the standard. Periodically review the standard (e.g.: annually)	Information and data media usage standard
2-17-P-2	Cybersecurity requirements for usage of information and data media within the CSP shall be applied.	Enforce Cybersecurity standard for Information and Data Media Usage (e.g.: access control, encryption)	Information and data media labelled, securely stored and disposed.
2-17-P-3 Cybersecurity requirements for usage of information and data media within the CSP shall cover, at minimum, the following	2-17-P-3-1 Enforcement of sanitization of media, prior to disposal or reuse.	Define requirements for media sanitization to ensure that storage media is erased in a secure manner (e.g.: the process is irreversible). Define media sanitization methods (e.g. overwrite storage media with random input data several times, destroy or overwrite encryption keys, degaussing) Select sanitization tools that implement defined methods. Enforce sanitization of media by making it a mandatory step in media reuse or disposal process (e.g.: build a proper process flow)	Media sanitization tools in use. Using secure means when disposing of media.

	2-17-P-3-2 Using secure means when disposing of media.	Define requirements for secure disposal of media. Identify methods for disposal that meet these requirements. Apply accepted methods for the secure disposal of data from storage media. Ensure that data is not recoverable using any means.	Defined requirements and acceptable methods for disposal of media.
	2-17-P-3-3 Provision to maintain confidentiality and integrity of data on removable media.	Identify risks related to confidentiality and integrity of data on removable media (e.g. media theft). Define applicable controls and requirements for data confidentiality and integrity on removable media (e.g.: encryption, physical security). Apply applicable security measures to ensure data confidentiality and integrity on removable media. Periodically review and update the controls and requirements to ensure its applicability.	List of identified risks. Defined controls and requirements for data on removable media. Regular review reports.
	2-17-P-3-4 Human readable labelling of media, to explain its classification and the sensitivity of the information it contains.	Establish clear labelling rules of the media including its classification and the sensitivity of information (e.g. Top secret, Secret, Restricted) Ensure that used classification and sensitivity levels are well-defined and communicated. Ensure that each media in use is labelled according to the established rules. Ensure that each new media to be used is labelled according to the established rules.	Established labelling rules. Each media is labelled according to established rules.
	2-17-P-3-5 Controlled and physically secure storage of removable media.	Identify risks related to storage of removable media (e.g. media theft) Define applicable controls (including physical controls) and requirements for secure storage of removable media, taking account of identified risks. Apply these controls (e.g. access control, HVAC)	List of identified risks for storing removable media. Controls and requirements for secure storage of removable media.
	2-17-P-3-6	Identify risks related to usage of portable media inside the Cloud Technology Stack (e.g. media theft) Define and	List of identified risks for using external storage

	Restriction and control of usage of portable media inside the Cloud Technology Stack.	approve adequate restrictions and controls of portable media inside the Cloud Technology Stack taking account of identified risks. Implement the restrictions and controls (e.g. encryption, ownership, RFID tags).	media on the Cloud Technology Stack. Approved restrictions and controls for using external storage media on the Cloud Technology Stack.
2-17-P-4	Cybersecurity requirements for usage of information and data media within the CSP shall be applied and reviewed periodically.	Relevant cybersecurity tools: Template for Cybersecurity Reviewing and Auditing Policy Template for Developing Cybersecurity Documentation Procedures Define Roles and Responsibilities in the review process. Review requirements Periodically based on defined timeframes, at least annually. Update requirements if applicable. Maintain records of periodical reviews (e.g.: who and when reviewed and a change log).	Current cybersecurity requirements for usage of information and data media Periodical review logs.

Risk Considerations in Storage Media Security

1. **Unauthorized Access to Storage Media:** Improper access controls may lead to data breaches or unauthorized exposure.
 2. **Data Leakage Due to Improper Disposal:** Failing to securely erase or destroy storage media can result in data being recovered by unauthorized entities.
 3. **Loss or Theft of Storage Media:** Portable media like USB drives and external hard disks can be easily lost or stolen, leading to data exposure.
 4. **Lack of Encryption for Sensitive Data:** Storing unencrypted data on removable or shared media increases the risk of unauthorized access.
 5. **Failure to Sanitize Media Before Reuse or Disposal:** Media that is not properly sanitized before reuse or disposal may retain residual sensitive data.
 6. **Physical Damage or Environmental Risks:** Exposure to heat, moisture, or magnetic fields can render storage media unreadable and cause data loss.
 7. **Non-Compliance with Regulations:** Failure to adhere to NCA CCC CSP or industry cybersecurity standards can result in legal and regulatory penalties.
-

Examples of Technologies for Effective Storage Media Security

1. **Encryption Solutions:**
 - Tools: VeraCrypt, LUKS (Linux Unified Key Setup), GnuPG
 2. **Media Sanitization & Secure Erasure Tools:**
 - Tools: DBAN, SDelete, nwipe
 3. **Access Control & Monitoring:**
 - Tools: Keycloak, Authelia, Wazuh (for access monitoring), OSSEC
 4. **Secure Storage Solutions:**
 - Tools: VeraCrypt, LUKS, EncFS
 5. **Media Disposal Solutions:**
 - Tools: DIY degaussing techniques (manual), open-source disk wipe tools; physical shredding recommendations (non-digital)
 6. **Data Loss Prevention (DLP) Solutions:**
 - Tools: MyDLP (Community Edition), OpenDLP
 7. **Asset Tracking & RFID Solutions:**
 - Tools: OpenMAINT, Snipe-IT (asset management with basic tracking capabilities)
-

Examples of KPIs for Storage Media Security

1. **Percentage of Encrypted Storage Media:** % of storage media encrypted before use.
 2. **Number of Unauthorized Access Attempts:** Total number of unauthorized access attempts to storage media.
 3. **Compliance Rate for Secure Disposal Methods:** % of disposed media that follows secure sanitization and destruction policies.
 4. **Time to Detect & Respond to Media Loss:** Average time taken to detect and mitigate lost or stolen media incidents.
 5. **Audit Trail Completeness for Media Usage:** % of recorded transactions related to storage media access, transfer, and disposal.
 6. **Incidents of Improper Media Disposal:** Number of cases where storage media was improperly disposed of without sanitization.
-

Samples of Auditor's Checklist for Storage Media Security

1. **Storage Media Policies & Procedures**
 - Are there documented policies for storage media security and usage?
 - Is there a policy for restricting access to sensitive storage media?
 2. **Access Controls & Encryption**
 - Are removable storage devices encrypted before use?
 - Are access controls and authentication mechanisms in place for storage media?
 3. **Secure Disposal & Media Sanitization**
 - Is data sanitization enforced before reusing or disposing of media?
 - Are storage media destruction records maintained?
 4. **Storage & Handling Practices**
 - Are physical storage locations for removable media secured?
 - Are employees trained on secure handling of storage media?
 5. **Compliance with Cybersecurity Standards**
 - Does the entity comply with NCA CCC CSP and other regulatory standards?
 - Is storage media security regularly audited and reviewed?
-

Samples of Audit Scenarios for Storage Media Security

Scenario 1: Evaluating Secure Storage of Removable Media

- **Objective:** Assess whether removable storage media is stored securely with access controls.
 - **Steps:**
 - Inspect storage areas for removable media.
 - Verify that access controls are enforced (e.g., biometric authentication, role-based access).
 - Review security policies for removable media storage.
 - **Key Questions:**
 - Is storage media physically secured?
 - Are logs maintained for access to removable storage?
-

Scenario 2: Testing Data Sanitization Practices for Storage Media

- **Objective:** Validate that storage media is sanitized before disposal or reuse.
 - **Steps:**
 - Review the data sanitization process.
 - Verify the use of certified wiping tools such as Blancco or DBAN.
 - Check for audit logs of media sanitization.
 - **Key Questions:**
 - Are all storage media securely wiped before reuse or disposal?
 - Are there documented procedures for verifying secure erasure?
-

Case Study: Cloud Technology Service Provider Company

Scenario: Addressing Storage Media Security Risks in a Cloud Service Provider

Background:

A leading cloud service provider handling sensitive customer data faced multiple security challenges related to storage media. The organization needed to comply with national cybersecurity regulations while ensuring secure handling and disposal of physical and digital media.

Challenges:

- Lack of encryption for removable storage media.
- Absence of a clear media sanitization policy.
- Inconsistent enforcement of access controls for storage media usage.
- Non-compliance with regulatory storage media security guidelines.

Actions Taken:

1. **Implemented Strong Encryption Measures:**
 - Adopted hardware-based encryption for removable storage devices.
 - Mandated encryption of all stored data at rest.
2. **Developed and Enforced a Media Sanitization Policy:**
 - Introduced Blancco Drive Eraser and DBAN for secure wiping.
 - Required degaussing or physical destruction of obsolete media.
3. **Enforced Role-Based Access Controls:**
 - Deployed Microsoft Entra ID to restrict access to storage media.
 - Integrated SIEM tools to monitor access attempts.
4. **Regular Compliance Audits and Employee Training:**
 - Conducted periodic audits to ensure policy enforcement.
 - Provided mandatory cybersecurity training on secure media handling.

Outcomes:

- **95% compliance rate** with secure storage and disposal policies.
- **Zero incidents of unauthorized media access** post-implementation.
- **Reduced risk of data leakage** through enforced encryption and sanitization.
- **Full alignment with NCA CCC CSP storage media security controls.**

Lessons Learned from the Case Study

1. **Encryption is Key to Protecting Storage Media:** Encrypting all storage devices minimizes the risk of unauthorized access.
2. **Strict Enforcement of Media Sanitization Prevents Data Leaks:** Secure disposal mechanisms like degaussing and shredding ensure data cannot be recovered.
3. **Access Control Mechanisms Reduce Insider Threats:** Implementing role-based access controls (RBAC) prevents unauthorized usage of storage media.

4. **Continuous Monitoring Strengthens Security Posture:** Logging and SIEM integration help detect suspicious activities related to storage media.
5. **Compliance with Regulatory Frameworks Ensures Better Governance:** Aligning with NCA CCC CSP and other security standards enhances an organization's data protection measures.

2.20 Secure Data Disposal:

Definition: Secure Data Disposal refers to the implementation of cybersecurity measures and best practices to ensure that sensitive information is permanently removed or destroyed from storage media in a manner that prevents unauthorized recovery or access. It includes the secure erasure, degaussing, shredding, incineration, and other approved disposal methods to mitigate data leakage risks and ensure compliance with cybersecurity regulations [29], [30], [31], [32].

Objective: To ensure that organizations securely dispose of data when it is no longer needed, preventing unauthorized access, data breaches, and unintended disclosure. This involves defining, implementing, and continuously improving secure data disposal policies, procedures, and technologies while complying with regulatory requirements and industry best practices.

Controls Matrix:

Below is a summary matrix detailing relevant secure data disposal controls based on NCA, SAMA CSF, CST CRF, and CMA Cybersecurity Guidelines:

Regulation	Main Controls	Control References
NCA ECC	–	–
SAMA CSF	6	3.3.11-1, 3.3.11-2, 3.3.11-3, 3.3.11-4, 3.3.11-5, 3.3.11-6
CST CRF	3	2.6.1, 2.6.2, 2.6.3
CMA CSG	7	4.3.6-1, 4.3.6-2, 4.3.6-3, 4.3.6-4, 4.3.6-5, 4.3.6-6, 4.3.6-7
NCA CSCC	–	–
NCA CCC CST	–	–
NCA CCC CSP	–	–
NCA TCC	–	–
NCA DCC	2	2-6-1 (5 sub-controls), 2-6-2
NCA OSMACC	–	–
NCA OTCC	–	–

Secure Data Disposal Controls:

National Cybersecurity Authority - Data Cybersecurity Controls DCC					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
2-6-1 Cybersecurity requirements for secure data disposal must cover at least the following:	2-6-1-1	Identification of technologies, tools and procedures for the implementation of secure data disposal according to the data classification level.	Template for Physical Security Cybersecurity Policy, Template for Physical Security Standards	Identify the requirements of this control and document them in a cybersecurity requirements document, followed by approval from the authorizing officials. Identify the list of on premises and mobile storage physical assets such as external hard drives, tape drives, optical storage devices, flash storage etc. in use for storage of confidential, secret and top secret data of the organization. Define and document the data disposal plan for the above mentioned storage devices in a secured manner. Review the data disposal techniques used for secure data disposal which should include, but not limited to, data wiping using third party software, overwriting, reformatting; data destruction using physical destruction of storage asset using vendor services.	Document detailing the identification and documentation of the requirements of this control (eg. a policy and/or procedure approved by the authorizing officials). Documented list of storage assets handling confidential, secret or top secret data. Documented data disposal plan for storage equipments.
	2-6-1-2	When storage media is no longer needed, it must be securely disposed by using	Template for Physical Security Standards	Identify the requirements of this control and document them in a cybersecurity requirements document, followed by	Document detailing the identification and documentation of the

		the technologies, tools and procedures identified in subcontrol 2-6-1-1. Implement secure destruction of storage media when they are no longer in need for use.		approval from the authorizing officials. Define and document the data disposal plan for the above mentioned storage devices in a secured manner. Review and implement the device destruction techniques used in the process for device disposal that ensure permanent destruction beyond recovery. Further, in case of third party service to be utilized, review, verify and approve as per the requirements of the organization.	requirements of this control (e.g. a policy and/or procedure approved by the authorizing officials). Documented list of on premises and mobile storage physical assets in use for storage of confidential, secret and top secret data of the organization. Documented data disposal procedure for storage media. Implementation plan of third party service for data device disposal, if required. Sample of disposal records/reports.
	2-6-1-3	When storage media needs to be re-used, data must be securely erased (secure erasure) in a manner it cannot be recovered.	Template for Physical Security Standards	Identify the requirements of this control and document them in a cybersecurity requirements document, followed by approval from the authorizing officials. Define and document the data erasure plan for the above mentioned data in a secured manner. Review and implement the data wiping techniques used in the process for data wiping that ensure permanent wiping of data beyond recovery, without any damage to the usability of the device. Further, in case of third party software or service to be	Document detailing the identification and documentation of the requirements of this control (e.g. a policy and/or procedure approved by the authorizing officials). Documented list of storage assets handling restricted, secret or top secret data. Documented data erasure plan for storage equipments. Implementation plan data erasure, including actions of

				utilized, review, verify and approve as per the requirements of the organization.	third party software or service for data wiping, if required.
	2-6-1-4	Implementation of secure data disposal or erasure operations referred to in sub-controls 2-6-1-2 and 2-6-1-3 must be verified.	Template for Physical Security Standards	Identify the requirements of this control and document them in a cybersecurity requirements document, followed by approval from the authorizing officials. Review the implementation plan secure data disposal operations in the organization for the storage media handling confidential, secret or top secret data. Verify that for all the storage media, appropriate implementation plan steps are followed as per the requirement of either data erasure or media disposal. Further, verify that all the proper approvals and sign offs are provided prior to the hand off and conorganizationation of data disposal is provided.	Document detailing the identification and documentation of the requirements of this control (e.g. a policy and/or procedure approved by the authorizing officials). Implementation plan data erasure, including actions of third party software or service for data wiping, if required. Document trail of proper data disposal steps is maintained.
	2-6-1-5	Keeping a record of all secure data disposal and erasure operations that have been conducted.	Identify the requirements of this control and document them in a cybersecurity requirements document, followed by approval from the authorizing officials. Review the data disposal action plan in place and conorganizationation that it should include the monitoring and logging of data and devices in the organization. It should also maintain the status of all the in scope data storage assets and log any changes to the status as per the defined rules by the organization. Review and implement any third party software or service to be utilized to monitor and log the data storage assets' operations.		Document detailing the identification and documentation of the requirements of this control (e.g. a policy and/or procedure approved by the authorizing officials). Maintained list of all the data storage assets in the organization with their status

				and other relevant parameters. Implementation plan of monitoring of data disposal, including actions of third party service for data storage assets' operations, if required. Sample of disposal and erasure records/reports.
2-6-2	The implementation of the secure data disposal requirements must be reviewed as specified for each data classification level.	Template for Physical Security Cybersecurity Policy	Identify the requirements of this control and document them in a cybersecurity requirements document, followed by approval from the authorizing officials. Review the process of secure data disposal techniques with respect to the implementation plan and data disposal policy. Periodic review of data disposal process for storage devices must be conducted at least annually or less for Public or Confidential data classification level and at least every 6 months or less for Secret or Top Secret data classification level, to ensure that the requirements are effectively implemented.	Document detailing the identification and documentation of the requirements of this control (e.g. a policy and/or procedure approved by the authorizing officials). Review report of secure data disposal process.
SAMA Cyber Security Framework CSF				
Control reference number	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables

3.3.11-1	The secure disposal standard and procedure should be defined, approved, and implemented.	Secure Disposal Policy Templates, Governance Frameworks	Establish clear policies for secure disposal, including proper documentation and approval workflows. Ensure compliance with industry standards.	Formalized and approved secure disposal standard and procedures.
3.3.11-2	The compliance with the secure disposal standard and procedure should be monitored.	Data Compliance Tools, Auditing Mechanisms (e.g., SIEM, Compliance Reports)	Regularly audit and review compliance with secure disposal procedures to ensure adherence to policy. Automate compliance checks where possible.	Secure disposal compliance reports, audit findings.
3.3.11-3	The effectiveness of the secure disposal cybersecurity controls should be measured and periodically evaluated.	Data Loss Prevention (DLP) Systems, Security Monitoring Tools	Establish KPIs and monitoring mechanisms to track the effectiveness of data disposal processes. Conduct periodic reviews and security tests.	Security assessment reports, evaluation records.
3.3.11-4	Information assets should be disposed of in accordance with legal and regulatory requirements when no longer required.	Legal Compliance Frameworks, Data Retention Schedules	Ensure alignment with data privacy regulations and industry-specific mandates for data destruction. Define retention policies before disposal.	Regulatory compliance audit reports, legal validation documentation.
3.3.11-5	Sensitive information should be destroyed using techniques to make the information non-retrievable (e.g., secure erase, secure wiping, incineration, double crosscut, shredding).	Secure Data Wiping Tools, Physical Destruction Methods (Shredders, Incinerators)	Implement certified destruction methods to prevent unauthorized recovery. Use advanced cryptographic wiping for digital data and physical destruction for paper/media.	Proof of secure data destruction, destruction method validation logs.
3.3.11-6	The Member Organization should ensure that third-party service providers used for secure disposal,	Vendor Risk Management (VRM) Solutions,	Conduct due diligence on third-party disposal providers to verify compliance with security policies. Include contractual agreements enforcing compliance.	Third-party compliance verification reports, service provider audit records.

	transport, and storage comply with the secure disposal standard and procedure.	Third-Party Security Assessments		
CST CRF				
Control reference number	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
2.6.1 CL1	Define and document Requirements for Secure Disposal of Assets, considering: - Setting rules for information asset disposal based on classification and labeling of assets in the Asset Inventory.	Secure Disposal Policies, Asset Classification Tools	Develop and document disposal requirements. Ensure classification-based disposal rules align with the organization's asset inventory framework.	Approved Secure Disposal of Assets policy and documented classification-based disposal procedures.
2.6.2 CL1	Define and implement a Secure Asset Disposal process based on the Requirements for Secure Disposal of Assets. This includes using appropriate disposal techniques (e.g., secure erase, drilling, shredding) to prevent unauthorized disclosure or modification of sensitive data.	Secure Data Destruction Tools (e.g., Blancco, DBAN), Secure Shredding & Incineration Equipment	Establish a structured disposal process, ensuring secure disposal techniques are enforced. Implement a verification mechanism to validate proper destruction.	Formalized Secure Asset Disposal process, verification logs for asset disposal.
2.6.3 CL3	Continuously measure, review, and optimize the Requirements for Secure Disposal of Assets, ensuring the effectiveness of the disposal process.	Compliance Monitoring Tools, Periodic Review Frameworks	Conduct regular audits of disposal activities. Track compliance and adjust disposal policies based on security assessments.	Periodic audit reports, records of improvements made to the Secure Disposal of Assets framework.
CMA Cybersecurity Guidelines				

Control reference number	Control clauses	Control implementation guidelines	Expected deliverables
4.3.6-1	Set out, document, approve and implement safe disposal criteria and procedures.	Establish disposal procedures for unused assets.	Approved disposal policy and records.
4.3.6-2	Safe disposal standards cover digital and hard copies and reuse of assets.	Include all digital and hard-copy assets in disposal policies.	Guidelines covering digital and physical disposal.
4.3.6-3	Monitor compliance with safe disposal standards and procedures.	Monitor adherence to disposal policies through assessments.	Compliance monitoring reports and logs.
4.3.6-4	Measure and evaluate cybersecurity effectiveness in disposal.	Assess cybersecurity effectiveness in disposal activities.	Cybersecurity effectiveness assessment reports.
4.3.6-5	Dispose of information assets when they are no longer needed according to the relevant legislative and legal requirements and in line with data privacy regulations to avoid unauthorized access and intended and unintended leakage.	Ensure compliance with regulations for asset disposal.	Regulatory compliance documentation.
4.3.6-6	Destroy sensitive information using certain technologies to make information not recoverable (e.g. Secure Wiping and Degaussing).	Implement secure deletion and physical destruction.	Destruction certification for disposed data.
4.3.6-7	Ensure that third-party service providers comply with safe disposal standards and procedures, and measure and evaluate this effectiveness periodically.	Verify third-party compliance with safe disposal standards.	Third-party vendor compliance audit logs.

Risk Considerations in Secure Data Disposal

1. **Unauthorized Access to Disposed Data** – Inadequate disposal methods can lead to unauthorized retrieval of sensitive data from improperly erased or destroyed media.
2. **Failure to Comply with Regulatory Requirements** – Non-compliance with legal and regulatory frameworks (e.g., NCA DCC, SAMA CSF) can lead to fines, legal repercussions, and reputational damage.
3. **Improper Classification of Data Before Disposal** – If data is not correctly classified, it may be disposed of improperly, leading to data breaches.
4. **Use of Unreliable Disposal Techniques** – Insecure wiping, shredding, or degaussing methods may leave recoverable remnants of sensitive data.
5. **Third-Party Risk** – Engaging external disposal vendors without conducting security assessments may lead to unauthorized data leaks.
6. **Lack of Auditability and Documentation** – Without proper logging and verification of disposal processes, organizations may struggle to prove compliance and track incidents.
7. **Inadequate Employee Awareness and Training** – Employees handling sensitive data disposal without proper training can introduce risks of accidental data exposure.

Examples of Technologies for Effective Secure Data Disposal

1. **Data Wiping Software** – DBAN, nwipe, shred (Linux utility)
2. **Secure File Deletion Tools** – Eraser, srm (Secure Remove), wipe (Linux utility)
3. **Degaussing Machines** – Manual process reference only; no open-source tools available
4. **Physical Destruction Equipment** – Reference to non-digital tools like shredders and incinerators (no software alternatives)
5. **Compliance & Audit Tools** – OpenSCAP, Wazuh, AIDE
6. **Encryption Before Disposal** – OpenSSL (for AES-256), VeraCrypt, LUKS
7. **Third-Party Vendor Assessment Platforms** – OSCAL (NIST Open Security Controls Assessment Language), openTMS (for basic tracking); no full-featured open-source alternatives to OneTrust or Archer

Examples of KPIs for Secure Data Disposal

1. **Percentage of Securely Disposed Data** – % of data that has been disposed of using approved secure disposal methods.
2. **Compliance Rate for Data Disposal Policies** – % of disposal activities audited and found compliant with policies.
3. **Number of Secure Disposal Incidents** – Count of incidents where improper disposal was detected.
4. **Time to Securely Dispose of Retired Data Assets** – Average time taken from data asset retirement to its secure disposal.

5. **Third-Party Compliance Rate** – % of disposal vendors audited and found compliant with disposal security policies.
6. **Percentage of Employees Trained on Secure Disposal Procedures** – % of employees with annual training on secure data disposal.
7. **Number of Non-Compliant Disposal Events Detected** – Total instances where disposal did not meet security standards.

Samples of Auditor's Checklist for Secure Data Disposal

- Is there a formally approved secure data disposal policy in place?
 - Are storage media classified before disposal to determine proper destruction methods?
 - Are data disposal logs maintained, reviewed, and audited periodically?
 - Are secure data erasure methods (e.g., wiping, degaussing, physical destruction) in use?
 - Are employees trained on secure data disposal practices and aware of security risks?
 - Are third-party disposal vendors assessed for compliance with cybersecurity regulations?
 - Are all disposed storage devices verified to ensure complete data destruction?
 - Is there a process for monitoring and reporting disposal activities?
-

Samples of Audit Scenarios for Secure Data Disposal

Scenario 1: Evaluating Compliance with Data Disposal Policies

Objective: Verify that the organization's data disposal activities comply with security policies and regulatory requirements.

Steps:

- Review disposal policy documents and logs.
- Sample-check disposed storage devices to ensure compliance with disposal techniques.
- Interview employees responsible for disposal and verify awareness of policies.

Key Questions:

- Is there documented evidence of compliance?
- Are there any gaps in adherence to disposal protocols?

Scenario 2: Validating Secure Erasure of Reused Storage Media

Objective: Ensure that storage media reused internally is wiped securely to prevent data recovery.

Steps:

- Inspect storage media reuse policy and confirm the use of secure erasure tools.
- Conduct forensic tests to verify that no data remnants are recoverable.
- Validate logs of secure wiping operations.

Key Questions:

- Does the organization follow a defined process for media sanitization?
- Can wiped storage devices be recovered through advanced forensic tools?

Scenario 3: Assessing Third-Party Secure Disposal Vendors

Objective: Confirm that external disposal service providers comply with the organization's security policies.

Steps:

- Review vendor contracts and compliance certifications.
- Audit disposal service logs and obtain proof of secure disposal.
- Conduct site visits to assess vendor facilities.

Key Questions:

- Does the vendor meet regulatory requirements?
 - Are third-party disposal activities documented and verified?
-

Case Study: Secure Data Disposal at a Cloud Service Provider

Scenario:

A major **Cloud Service Provider (CSP)** was found to have **insecure data disposal practices** that posed risks of unauthorized data recovery. The organization relied on third-party vendors without a formal verification process, leading to compliance gaps.

Challenges:

- **Lack of secure wiping policies** for decommissioned cloud storage devices.
- **Insufficient oversight of third-party disposal vendors**, leading to potential compliance risks.
- **Failure to document and audit disposal activities**, making regulatory adherence difficult.

Actions Taken:

- Implemented an **internal Secure Data Disposal Policy** aligned with NCA DCC and SAMA CSF.
- Adopted certified data erasure software** (Blancco, DBAN) for all decommissioned storage devices.
- Established a **vendor compliance verification program**, requiring third-party providers to submit disposal audit reports.
- Deployed **automated disposal tracking systems** for monitoring disposal workflows in real time.

Outcomes:

- 100% compliance** with regulatory standards and third-party security requirements.
- Reduced risk of unauthorized data recovery** through certified disposal techniques.
- Improved audit readiness**, with full logs of disposal activities for regulatory reviews.

Lessons Learned from the Case Study

- 1-**Regulatory Compliance Is Critical** – Organizations must ensure alignment with cybersecurity laws and frameworks for data disposal.
- 2-**Third-Party Vendors Must Be Verified** – Outsourced disposal services should be audited regularly to prevent compliance risks.
- 3-**Secure Wiping Should Be a Standard Practice** – Cryptographic erasure, degaussing, and physical destruction methods must be implemented.
- 4-**Continuous Monitoring Enhances Security** – Using disposal tracking tools ensures secure handling of decommissioned assets.
- 5-**Employee Awareness Reduces Risks** – Training programs help minimize accidental exposure through improper disposal practices.

2.21 Cybersecurity for Printers, Scanners, and Copy Machines:

Definition: Cybersecurity for Printers, Scanners, and Copy Machines refers to the implementation of security measures to protect these devices from cyber threats, unauthorized access, data leakage, and misuse. Given that modern printers, scanners, and copy machines are network-connected and store sensitive data, proper security controls must be in place to ensure the confidentiality, integrity, and availability of information processed by these devices [33], [34], [35], [36].

Objective: The objective of this domain is to ensure secure handling, processing, and storage of sensitive data when using printers, scanners, and copy machines. This includes defining and enforcing security policies, controlling access, monitoring device activity, and securely disposing of sensitive data to prevent unauthorized disclosure or compromise.

Controls Matrix:

Below is a summary matrix detailing relevant identity and access management controls based on NCA DCC:

Regulation	Main Controls	Control References
NCA ECC	—	—
SAMA CSF	—	—
CST CRF	—	—
CMA CSG	—	—
NCA CCCC	—	—
NCA CCC CST	—	—
NCA CCC CSP	—	—
NCA TCC	—	—
NCA DCC	4	2-7-1, 2-7-2, 2-7-3 (5 sub-controls), 2-7-4
NCA OSMACC	—	—
NCA OTCC	—	—

Cybersecurity controls for Printers, Scanners, and Copy Machines:

National Cybersecurity Authority - Data Cybersecurity Controls DCC			
Control reference number	Control clauses	Control implementation guidelines	Expected deliverables
2-7-1	Cybersecurity requirements for printers, scanners and copy machines must be defined, documented and approved.	Identify the requirements of this control and document them in a cybersecurity requirements document, followed by approval from the authorizing officials. Review the cybersecurity requirements for printers, scanners and copy machines handling confidential, secret and top secret data of the organization. Define, document and approve the security configuration and hardening policy for the organization to ensure appropriate use of organization's printers, scanners and copy machines by authorized personnel.	Document detailing, the identification and documentation of the requirements of this control (e.g. a policy and/or procedure approved by the authorizing officials).
2-7-2	Cybersecurity requirements for printers, scanners and copy machines must be implemented.	Identify the requirements of this control and document them in a cybersecurity requirements document, followed by approval from the authorizing officials. Review the cybersecurity requirements for printers, scanners and copy machines handling confidential, secret and top secret data of the organization. Implement the security configuration and hardening policy for the organization to ensure appropriate use of organization's printers, scanners and copy machines by authorized personnel. This should include, but not limited to, placement of the devices, configuration of	Document detailing the identification and documentation of the requirements of this control (e.g. a policy and/or procedure approved by the authorizing officials). Implemented cybersecurity requirements for printers, scanners, and copy machines within the organization.

		the devices, access management to the devices, patching, logging and monitoring, disabling default configurations among other requirements.	
2-7-3 Cybersecurity requirements for printers, scanners and copy machines must cover at least the following:	2-7-3-1 Disabling the temporary storage feature.	Identify the requirements of this control and document them in a cybersecurity requirements document, followed by approval from the authorizing officials. Review and implement the printers, scanners and copy machine devices' settings for temporary storage and ensure that the feature is disabled for devices handling confidential, secret and top secret data of the organization.	Document detailing the identification and documentation of the requirements of this control (e.g. a policy and/or procedure approved by the authorizing officials). Implementation of disabling temporary storage feature in printers, scanners and copy machines of the organization.
	2-7-3-2 Enabling authentication on centralized printers, scanners and copy machines and requiring it before usage.	Identify the requirements of this control and document them in a cybersecurity requirements document, followed by approval from the authorizing officials. Review and implement the printers, scanners and copy machine devices' authentication settings and ensure that it is enabled for all the authorized personnel accessing the confidential, secret and top secret data of the organization.	Document detailing the identification and documentation of the requirements of this control (e.g. a policy and/or procedure approved by the authorizing officials). Implementation of enabling authentication for centralized printers, scanners and copy machines.
	2-7-3-3 Securely retaining (for a period not less than 12 months) logs of printers, scanners and copy machines usage.	Identify the requirements of this control and document them in a cybersecurity requirements document, followed by approval from the authorizing officials. Review and implement the printers, scanners and copy machine devices' logging settings and ensure that it is logs are retained for devices handling secret and top	Document detailing the identification and documentation of the requirements of this control (e.g. a policy and/or procedure approved by the authorizing

		secret data of the organization for a period not less than 12 months. The electronic log should contain records of what has been printed, scanned, copied. Additionally, Hashing can be used to create a digital signature for documents or files and to verify their integrity by determining if they were altered or modified.	officials). Implementation of retention of logs for printers, scanners and copy machines.
	2-7-3-4 Enabling and protecting CCTV logs which are used to monitor centralized printers, scanners and copy machines areas.	Identify the requirements of this control and document them in a cybersecurity requirements document, followed by approval from the authorizing officials. Review and implement the CCTV setup in the organization to ensure that monitoring of assets related to secret and top secret data such as centralized printers, scanners and copy machines. Verify that the logging of CCTV of the above mentioned setup is enabled and stored as per the data disposal policy. Review that the access to the CCTV logs is restricted only to authorized personnel. Periodic review of access to CCTV logs should be performed to ensure that only authorized personnel have access to them.	Document detailing the identification and documentation of the requirements of this control (e.g. a policy and/or procedure approved by the authorizing officials). Implementing logging of CCTV cameras monitoring centralized printers, scanners and copy machines. Review of access to CCTV logs to authorized personnel only.
	2-7-3-5 Using cross-shredding devices, to securely dispose documents when no longer needed.	Identify the requirements of this control and document them in a cybersecurity requirements document for secure data disposal in all its forms, both soft and hard copies, followed by approval from the authorizing officials. Ensure that physical copies of secret and top secret data are shredded, if not in use. This should be implemented by placing cross-shredding devices in the organization premises.	Document detailing the identification and documentation of the requirements of this control (e.g. a policy and/or procedure approved by the authorizing officials). Providing shredding devices in the organization's

		Review the data retention policy for shredding of physical copies in case of end of retention period of data.	buildings for proper disposal of paper documents.
2-7-4	Implementation of cybersecurity requirements for printers, scanners and copy machines must be reviewed as specified for each data classification level.	Identify the requirements of this control and document them in a cybersecurity requirements document, followed by approval from the authorizing officials. Periodic review of printers, scanners and copy machine devices' cybersecurity requirements should be carried out on at least annually for devices handling public and confidential data and at least every 3 months for devices handling secret and top secret data.	Document detailing the identification and documentation of the requirements of this control (e.g. a policy and/or procedure approved by the authorizing officials). Implementation of periodic reviews for printers, scanners and copy machines.

2.22 Electronic Banking Services (SAMA CSF):

Definition: Electronic Banking Services Security refers to the implementation of cybersecurity controls and measures to protect digital banking platforms, transactions, and customer data from cyber threats. It encompasses secure authentication mechanisms, encryption, fraud detection, secure communication protocols, and real-time transaction monitoring to mitigate risks associated with online, mobile, and ATM-based banking services [37], [38], [39].

Objective: To ensure that electronic banking services are secure, resilient, and compliant with cybersecurity standards by safeguarding confidentiality, integrity, and availability of customer information and financial transactions. This involves monitoring, defining, and continuously improving security policies, enforcing multi-factor authentication (MFA), fraud detection measures, and ensuring regulatory compliance to prevent cyber threats such as identity theft, phishing, man-in-the-middle (MITM) attacks, and unauthorized financial transactions.

Controls Matrix:

Below is a summary matrix detailing relevant Electronic Banking Services controls based on SAMA CSF:

Regulation	Main Controls	Control References
NCA ECC	—	—
SAMA CSF	4	3.3.13-1, 3.3.13-2, 3.3.13-3, 3.3.13-4 (21 sub-controls)
CST CRF	—	—
CMA CSG	—	—
NCA CSCC	—	—
NCA CCC CST	—	—
NCA CCC CSP	—	—
NCA TCC	—	—
NCA DCC	—	—
NCA OSMACC	—	—
NCA OTCC	—	—

Electronic Banking Services Controls:

SAMA Cyber Security Framework CSF				
Control reference number	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
3.3.13-1	The cybersecurity standards for electronic banking services should be defined, approved, and implemented.	E-Banking Security Policies, Compliance Frameworks	- Develop and document e-banking cybersecurity policies. - Obtain executive and regulatory approval before implementation. - Conduct annual policy reviews and updates.	Approved cybersecurity policy, Compliance review documentation.
3.3.13-2	Compliance with cybersecurity standards for electronic banking services should be monitored.	Security Compliance Tools, SIEM Solutions	- Establish real-time monitoring of cybersecurity compliance. - Integrate SIEM tools for anomaly detection in banking transactions. - Ensure quarterly compliance assessments.	Compliance assessment reports, SIEM monitoring logs, Incident response records.
3.3.13-3	The effectiveness of the cybersecurity standard for electronic banking services should be measured and periodically evaluated.	Cybersecurity Maturity Assessment Tools, Security Metrics Dashboards	- Define KPIs for measuring cybersecurity effectiveness. - Conduct penetration testing and vulnerability assessments. - Report findings and improvements periodically to SAMA.	Cybersecurity effectiveness reports, Penetration test results, Security improvement action plans.
3.3.13-4 Electronic banking services security standard should cover:			Refer to sub-controls below	N/A

3.3.13-4a	Brand protection measures to protect online services, including social media.	Brand Monitoring Tools, Social Media Threat Intelligence	- Deploy brand protection services to monitor phishing and fraudulent activities. - Implement automated takedown mechanisms for impersonating domains or apps.	Threat intelligence reports, Brand protection monitoring logs.
3.3.13-4b	Online, Mobile, and Phone Banking Security Requirements:	Mobile Banking Security Frameworks, Secure Communication Tools	Refer to sub-controls below	N/A
3.3.13-4b-1	Use of official application stores and websites for online and mobile banking.	Application Whitelisting, Secure App Deployment Tools	- Ensure all mobile apps are distributed via official app stores. - Monitor app integrity to prevent tampering.	List of authorized app distribution channels, Security audit logs.
3.3.13-4b-2	Detection measures and takedown of malicious apps and websites.	Threat Intelligence Platforms, Anti-Phishing Tools	- Implement anti-phishing and fraud detection solutions. - Work with domain registrars for rapid takedown of fraudulent websites.	Fraud detection logs, Malicious app takedown records.
3.3.13-4b-3	Use of sandboxing for online and mobile banking.	Application Sandboxing Solutions	- Deploy sandboxed environments for e-banking apps to isolate threats. - Prevent malware infiltration via secure execution environments.	Secure app execution reports, Sandboxing logs.
3.3.13-4b-4	Use of non-caching techniques for online and mobile banking.	Data Protection Tools, Secure Session Management	- Implement cache control policies to prevent storage of sensitive information. - Ensure that session data is encrypted and non-persistent.	Compliance reports on non-caching policies, Secure session configuration logs.

3.3.13-4b-5	Use of secure communication techniques to avoid 'man-in-the-middle' attacks.	TLS Encryption, HSTS, Certificate Pinning	- Enforce HTTPS with HSTS for all banking transactions. - Deploy certificate pinning to prevent impersonation attacks.	Secure communication audit logs, Certificate configuration policies.
3.3.13-4b-6	Multi-Factor Authentication (MFA) Mechanisms	MFA Solutions, Secure Authentication Gateways	Refer to sub-controls below	N/A
3.3.13-4b-6a	MFA should be used during customer registration for electronic banking services.	MFA Enrollment Tools	- Implement strong authentication for onboarding. - Use biometric or OTP-based verification.	MFA implementation logs, Onboarding verification reports.
3.3.13-4b-6b	MFA should be implemented for all e-banking services.	MFA for Banking Services	- Enforce MFA across all online and mobile banking transactions. - Prevent access without secure authentication factors.	MFA enforcement logs, Transaction security validation.
3.3.13-4b-6c	Hard and soft tokens should be password-protected.	Token Security Frameworks	- Ensure that tokens require PIN/password authentication before use. - Implement session expiration for inactive tokens.	Token security validation reports, Audit logs for token protection.
3.3.13-4b-6d	Revoke customer access after 3 successive incorrect passwords or invalid PINs.	Account Lockout Mechanisms, Fraud Prevention Systems	- Implement account lockout policies after multiple failed attempts. - Require secure identity verification for account reactivation.	Lockout logs, Incident reports on failed authentication.
3.3.13-4b-6e	Change of customer mobile number should only be done via branch or ATM.	Identity Verification Systems	- Restrict mobile number changes to physical identity verification points. - Implement audit logging for number changes.	Secure transaction logs, Mobile number change approvals.
3.3.13-4c	ATMs and POS Security Measures:	ATM & POS Security	Refer to sub-controls below	N/A

		Frameworks, Endpoint Security		
3.3.13-4c-1	Prevention and detection of ATM/POS vulnerabilities.	Endpoint Security, Intrusion Detection for ATMs	- Implement anti-tampering mechanisms and real-time intrusion detection. - Enforce strict physical security measures.	ATM/POS security assessment reports, Intrusion detection logs.
3.3.13-4c-2	Cybersecurity measures for ATMs/POS including anti-skimming and geo-blocking.	ATM Security Enhancements, Geo-Blocking Tools	- Enforce chip-based transactions, disable magnetic strip transactions. - Implement geo-blocking for unauthorized locations.	ATM security audit reports, Geo-blocking policy validation.
3.3.13-4c-3	Remote stopping of ATMs in case of malicious activities.	ATM Remote Management Systems	- Enable remote shutdown of ATMs in case of fraud or attacks. - Establish automated threat response mechanisms.	Logs of remote ATM shutdown events, Incident response records.
3.3.13-4d	SMS Instant Notification Services:	Secure Messaging Platforms, Mobile Notification Systems	Refer to sub-controls below	N/A
3.3.13-4d-1	SMS messages should not contain sensitive data (e.g., account balance - except for credit cards).	Secure SMS Gateways, Data Masking Tools	- Implement data masking for all sensitive information transmitted via SMS. - Ensure that account balances are not disclosed, except for credit cards where applicable.	Compliance validation reports, SMS policy configuration logs.
3.3.13-4d-2	SMS alerts should be sent to both mobile numbers (old and new) when the customer's mobile number has been changed.	Multi-Channel Alert Systems, Customer Notification Services	- Configure SMS alerts to notify both old and new numbers upon mobile number changes. - Ensure logging and verification of mobile number changes to prevent fraud.	Notification logs, Customer change request records.

3.3.13-4d-3	SMS notifications should be sent to the customer's mobile number when requesting a new multi-factor authentication mechanism.	MFA Notification Services, Secure Messaging Systems	- Implement automated alerts whenever a new MFA method is requested. - Verify that alerts align with customer identity verification procedures.	MFA request logs, Notification delivery reports.
3.3.13-4d-4	SMS notifications should be sent to the customer's mobile number for all retail and personal financial transactions.	Transaction Monitoring Tools, Fraud Detection Systems	- Enable real-time transaction notifications for all financial activities. - Ensure SMS notifications are sent without delays to prevent fraud.	Transaction notification logs, Fraud prevention reports.
3.3.13-4d-5	SMS notifications should be sent to the customer's mobile number when beneficiaries are added, modified, and activated.	Beneficiary Management Systems, Secure SMS Infrastructure	- Implement SMS alerts for any beneficiary changes to enhance security. - Ensure audit trails of all modifications to beneficiaries.	Beneficiary update logs, Security audit records.

Risk Considerations in Electronic Banking Services

1. **Phishing & Social Engineering Attacks** – Cybercriminals target customers with deceptive emails, fake banking websites, and fraudulent SMS messages to steal login credentials.
2. **Man-in-the-Middle (MITM) Attacks** – Attackers intercept unencrypted banking communications, exploiting weak or outdated security protocols.
3. **Unauthorized Account Access & Credential Theft** – Weak password policies, lack of multi-factor authentication (MFA), and poor session management can lead to account takeovers.
4. **Online & Mobile Banking Malware** – Banking Trojans, keyloggers, and malicious applications infect customer devices to steal banking information.
5. **ATM & POS Attacks** – Skimming, card cloning, jackpotting attacks, and exploitation of ATM vulnerabilities result in financial fraud.
6. **Insider Threats** – Employees with privileged access may misuse or leak sensitive customer data.
7. **Weak Encryption & Data Leakage** – Poorly implemented encryption and unsecure storage of sensitive banking information can lead to regulatory non-compliance and data breaches.
8. **DDoS & Service Disruptions** – Distributed Denial-of-Service (DDoS) attacks can render electronic banking services unavailable, leading to financial and reputational damage.
9. **Lack of Secure Mobile Banking Practices** – Using untrusted app stores, weak authentication mechanisms, and lack of sandboxing techniques increase the risk of compromise.
10. **Regulatory Non-Compliance Risks** – Failure to meet regulatory standards (e.g., SAMA CSF, PCI DSS, GDPR) can result in legal consequences and financial penalties.

Examples of Technologies for Effective Electronic Banking Services

1. **Multi-Factor Authentication (MFA)** – FreeOTP, Aegis Authenticator, Authenticator Plus (open-source), privacyIDEA
2. **Fraud Detection & Transaction Monitoring** – Open Banking Threat Modeling Toolkit, custom rules in Wazuh or Elastic Stack
3. **Secure Banking Communications** – TLS 1.3, HSTS, Certificate Pinning (via OpenSSL, curl, browsers), OpenVPN
4. **Endpoint Protection & Mobile Security** – OSSEC, Wazuh, ClamAV, Hypatia (Android)
5. **SIEM & Threat Intelligence Solutions** – Wazuh, Elastic Security, MISP, TheHive

6. **ATM & POS Security Solutions** – Open firewall rules, custom hardening scripts, OS-level lockdown (Linux-based POS), Snort for network monitoring
 7. **DDoS Mitigation Tools** – FastNetMon, ddos-deflate, Fail2Ban, iptables with rate limiting
 8. **Secure Application Development (DevSecOps)** – OWASP ASVS, OWASP ZAP, SonarQube (Community), Semgrep
 9. **Anti-Phishing & Brand Protection** – GoPhish, MailScanner, URLScan.io API integration
 10. **Secure SMS & Notification Services** – GAMMU (open-source SMS gateway), Signal API, Matrix protocol integrations
-

Examples of KPIs for Electronic Banking Services

1. **Percentage of Successful Multi-Factor Authentication (MFA) Logins** – Measures the adoption and success rate of MFA.
 2. **Number of Phishing Attempts Detected & Blocked** – Tracks the effectiveness of email and website security controls.
 3. **ATM/POS Fraud Detection Rate** – Identifies fraudulent transactions prevented in ATM/POS systems.
 4. **DDoS Attack Mitigation Time** – Measures the response time to mitigate service disruption from DDoS attacks.
 5. **Incident Response Time for Fraudulent Transactions** – Evaluates how quickly fraud is detected and mitigated.
 6. **Percentage of Transactions Processed Securely** – Ensures that transactions comply with encryption, authentication, and fraud prevention standards.
 7. **Time to Detect and Remove Malicious Banking Apps/Sites** – Measures brand protection efforts in removing fraudulent banking content.
 8. **Customer Mobile Banking Adoption Rate** – Tracks the percentage of customers using mobile banking securely.
 9. **Regulatory Compliance Score** – Measures adherence to SAMA CSF, PCI DSS, and GDPR requirements.
 10. **Percentage of Vulnerabilities Remediated in Online Banking Applications** – Tracks the resolution of security flaws in digital banking platforms.
-

Samples of Auditor's Checklist for Electronic Banking Services

- Are electronic banking security policies documented, reviewed, and approved?
 - Is multi-factor authentication (MFA) enforced for customer login and high-risk transactions?
 - Are ATM and POS systems secured with anti-skimming and geo-blocking mechanisms?
 - Is transaction monitoring in place to detect fraud in real-time?
 - Are mobile banking applications only available from official stores?
 - Is there a brand protection service monitoring for phishing and malicious banking apps?
 - Are banking websites secured with HTTPS, HSTS, and certificate pinning?
 - Are DDoS protection measures implemented for critical banking services?
 - Is a security incident response plan in place for fraudulent banking transactions?
 - Are regulatory compliance assessments (SAMA CSF, PCI DSS) conducted periodically?
-

Samples of Audit Scenarios for Electronic Banking Services

Scenario 1: Evaluating Multi-Factor Authentication (MFA) Implementation

- **Objective:** Ensure MFA is enforced for online and mobile banking logins.
- **Steps:** Review authentication logs, test user login workflows, and verify password policies.
- **Key Questions:** Is MFA required for all login attempts? Are accounts locked after failed attempts?

Scenario 2: Assessing Online Banking Phishing Protection Measures

- **Objective:** Evaluate brand protection efforts against phishing sites.
- **Steps:** Review domain monitoring tools, analyze phishing attack trends, and test takedown response times.
- **Key Questions:** Are fraudulent banking domains promptly detected and taken down?

Scenario 3: Reviewing ATM & POS Cybersecurity Controls

- **Objective:** Validate security configurations in ATMs and POS systems.
- **Steps:** Review ATM/POS security settings, check for anti-skimming solutions, and test remote shutdown mechanisms.
- **Key Questions:** Are ATMs protected against unauthorized rebooting and skimming?

Scenario 4: Testing Secure Mobile Banking Applications

- **Objective:** Assess mobile banking app security.
- **Steps:** Perform static and dynamic analysis, verify sandboxing implementation, and review session handling.
- **Key Questions:** Are mobile banking apps free from vulnerabilities? Are transactions encrypted?

Scenario 5: Evaluating Fraud Detection & Transaction Monitoring

- **Objective:** Verify fraud detection mechanisms in online banking.
- **Steps:** Review SIEM/SOC logs, test fraud detection scenarios, and analyze response times.
- **Key Questions:** Are suspicious transactions flagged in real-time? Are fraud alerts actioned promptly?

Case Study 1: Bank's Digital Banking Security Enhancement

Background:

A leading retail bank faced multiple phishing and credential theft attacks targeting its online banking customers.

Challenges:

- Customers fell victim to fake banking websites.
- Lack of multi-factor authentication (MFA) increased unauthorized account access.
- Fraudulent transactions were difficult to detect in real-time.

Actions Taken:

Implemented **MFA for all transactions** and login attempts.

Deployed **AI-based fraud detection systems** for real-time anomaly detection.

Launched **anti-phishing brand monitoring tools** to detect fraudulent domains.

Outcomes:

- **92% reduction** in phishing-related fraud losses.
 - **100% adoption** of MFA among customers.
 - **Real-time fraud detection improved by 80%**, preventing unauthorized transactions.
-

Case Study 2: FinTech Company's Secure Mobile Banking Deployment

Background:

A FinTech company launched a digital-only banking platform but faced security concerns related to mobile application threats.

Challenges:

- Customers downloaded fake apps mimicking the FinTech brand.
- Weak session management led to unauthorized logins.
- Fraudulent transactions increased due to social engineering attacks.

Actions Taken:

Enforced **application whitelisting** to restrict app downloads to official stores.
Implemented **session timeout and secure authentication mechanisms** for logins.
Used **behavioral analytics** to flag unusual spending patterns.

Outcomes:

- **80% decrease** in fraudulent app downloads.
- **Enhanced login security** prevented unauthorized access.
- **Improved fraud detection**, blocking over **\$5 million in fraudulent transactions**.

Lessons Learned from the Case Studies

1. **MFA is crucial for fraud prevention** – Banks and FinTechs must enforce strong authentication for all transactions.
2. **Real-time fraud detection improves security** – AI-powered monitoring can detect and prevent fraud faster.
3. **Secure mobile banking apps require strict control** – Only allow downloads from trusted stores.
4. **Brand protection reduces phishing risks** – Proactively monitor and remove fake banking apps/websites.
5. **Customer security awareness is essential** – Educating users about scams helps reduce fraud incidents.

2.23 Change Management (SAMA CSF and CST CRF):

Definition: Change Management in cybersecurity refers to the structured process of planning, implementing, monitoring, and evaluating modifications to information systems, applications, configurations, and security controls to ensure they do not introduce vulnerabilities or disrupt business operations. It includes risk assessments, security testing, approval workflows, and post-implementation reviews to maintain system integrity, availability, and security [40].

Objective: To ensure that all changes to information assets within an organization are performed in a controlled and secure manner, minimizing risks, ensuring compliance with regulatory frameworks, and maintaining business continuity. The objective includes defining, approving, and monitoring changes while evaluating their impact on cybersecurity, ensuring proper segregation of duties, and preventing unauthorized or untested changes that may lead to security breaches or operational failures.

Controls Matrix:

Below is a summary matrix detailing the relevant of management change controls based on SAMA CSF and CST CRF:

Regulation	Main Controls	Control References
NCA ECC	–	–
SAMA CSF	4	3.3.7-1, 3.3.7-2, 3.3.7-3, 3.3.7-4 (15 sub-controls)
CST CRF	5	4.2.1, 4.2.2, 4.2.3, 4.2.4, 4.2.5
CMA CSG	–	–
NCA CSCC	–	–
NCA CCC CST	–	–
NCA CCC CSP	–	–
NCA TCC	–	–
NCA DCC	–	–
NCA OSMACC	–	–
NCA OTCC	–	–

Change Management Controls:

SAMA Cyber Security Framework CSF				
Control reference number	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
3.3.7-1	The change management process should be defined, approved, and implemented.	Change Management System (CMS), IT Service Management (ITSM) Tools	Define a structured change management process, document roles and responsibilities, and ensure approval workflows are followed.	Approved change management policy and documented process.
3.3.7-2	The compliance with the change management process should be monitored.	Compliance Monitoring Tools, SIEM, IT Auditing Software	Implement monitoring mechanisms to track compliance with change management policies and log all changes for auditability.	Compliance reports, audit logs of change requests.
3.3.7-3	The effectiveness of the cyber security controls within the change management process should be measured and periodically evaluated.	Risk Assessment Tools, Security Metrics Dashboard	Establish key performance indicators (KPIs) to measure effectiveness and conduct periodic reviews to ensure security impact is minimized.	Security effectiveness assessment reports, evaluation metrics.
3.3.7-4	The change management process should include:	---	---	---
3.3.7-4a	Cyber security requirements for controlling changes to information assets, such as assessing the impact of requested changes, classification of changes, and the review of changes.	Change Impact Assessment Tools, IT Asset Management (ITAM)	Conduct thorough risk assessments for proposed changes before implementation.	Risk assessment reports, change classification logs.

3.3.7-4b	Security testing, which should (if applicable) include:	Security Testing Tools (DAST, SAST, IAST, Penetration Testing Tools)	Perform security testing before deploying changes to critical systems.	Security test reports, penetration testing results.
3.3.7-4b-1	Penetration testing.	Penetration Testing Tools (Metasploit, Burp Suite)	Conduct penetration testing on system updates and configurations.	Penetration test reports and vulnerability remediation actions.
3.3.7-4b-2	Code review if applications are developed internally.	Static Code Analysis Tools (SonarQube, Checkmarx)	Enforce secure coding practices and conduct code reviews for all internal applications.	Code review reports, secure coding policy enforcement records.
3.3.7-4b-3	Code review of externally developed applications and if the source code is available.	Secure Code Review Tools	Conduct security assessments for externally developed applications before deployment.	External code review reports, third-party application security assessments.
3.3.7-4b-4	A code review report (or equivalent, such as an independent assurance statement) in case the source code cannot be provided.	Independent Security Assurance Tools	Obtain independent verification reports for third-party applications.	Third-party security assurance statements.
3.3.7-4c	Approval of changes by the business owner.	Change Approval Workflow in ITSM	Ensure that changes are reviewed and approved by business owners before implementation.	Documented approvals, change request logs.
3.3.7-4d	Approval from the cyber security function before submitting to the Change Advisory Board (CAB).	Cybersecurity Governance and Risk Compliance (GRC) Tools	Require cybersecurity review and approval before submitting changes for final approval.	Security function approval records, change request logs.
3.3.7-4e	Approval by CAB.	Change Management	Ensure final CAB approval before deploying significant changes.	CAB meeting minutes, approved change requests.

		Workflow Automation		
3.3.7-4f	Post-implementation review of the related cyber security controls.	Post-Implementation Audit Tools, Security Validation Tools	Conduct security validation after change deployment to ensure no new risks are introduced.	Security post-implementation review reports.
3.3.7-4g	Development, testing, and implementation are segregated for both the (technical) environment and involved individuals.	DevOps Security Tools, Access Management Solutions	Ensure that development, testing, and production environments are separate, enforcing access control policies.	Segregation of Duties (SoD) audit logs, environment separation validation.
3.3.7-4h	The procedure for emergency changes and fixes.	Emergency Change Workflow Automation	Define and implement a rapid response process for emergency fixes while ensuring security validation.	Emergency change logs, risk mitigation reports.
3.3.7-4i	Fall-back and roll-back procedures.	System Rollback Solutions, Backup and Restore Tools	Establish rollback mechanisms to revert changes in case of issues.	Rollback and contingency plans, backup validation records.
CST CRF				
Control reference number	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
4.2.1 CL 1	Define and document Requirements for Change Management, ensuring identification, classification, and prioritization of cybersecurity-related changes.	Change Management Policy, Configuration Management Tools (e.g., ServiceNow, Jira)	- Establish a formal change management policy. - Identify and classify changes based on impact and urgency.
 - Maintain records of all changes to information assets.	Approved Change Management Policy, Change Classification Matrix

4.2.2 CL 1	Define and implement the Change Management process to authorize cybersecurity-relevant changes (e.g., applied patches, configuration changes, equipment upgrades).	ITSM Solutions (e.g., BMC Remedy, Jira Service Desk), Patch Management Tools	- Define authorization workflow for cybersecurity-related changes. - Ensure patches, updates, and configuration changes follow a structured approval process. - Implement role-based access control for change authorization.	Change Approval Records, Audit Logs for Change Requests
4.2.3 CL 1	Plan and test identified changes. Assess the potential impact (Cybersecurity Risk Assessment) of changes on cybersecurity, communicate changes, and obtain approval from authorized roles.	Risk Assessment Tools, Vulnerability Scanners (e.g., Nessus, Qualys)	- Conduct risk assessments before approving changes. - Simulate changes in a controlled test environment. - Implement a rollback plan for failed changes.	Risk Assessment Reports, Test Environment Validation Reports
4.2.4 CL 2	Enhance and implement the Requirements for Change Management to include procedures for emergency changes.	Incident Response Playbooks, Change Advisory Board (CAB)	- Define emergency change procedures for cybersecurity incidents. - Ensure emergency changes are reviewed post-implementation. - Establish an approval hierarchy for emergency scenarios.	Emergency Change Records, Post-Implementation Review Reports
4.2.5 CL 3	Continuously measure, review, and optimize the Requirements for Change Management, ensuring effectiveness.	Change Metrics Dashboards, Compliance Auditing Tools	- Define key performance indicators (KPIs) for change management efficiency. - Conduct periodic reviews and audits. - Document lessons learned and process improvements.	Change Management Audit Reports, KPI Monitoring Dashboards

Risk Considerations in Change Management

1. **Unauthorized Changes** – Lack of proper approvals can introduce vulnerabilities.
2. **Inadequate Risk Assessment** – Unassessed changes may lead to security gaps.
3. **Failure to Test Changes** – Untested modifications can disrupt business operations.
4. **Ineffective Emergency Change Handling** – Bypassing controls can lead to security risks.
5. **Lack of Segregation of Duties** – Overlapping roles increase insider threats.
6. **Configuration Drift** – Unmanaged changes can cause inconsistencies.
7. **Rollback Failures** – Lack of contingency planning can prolong outages.
8. **Regulatory Non-Compliance** – Violations can result in fines or legal issues.

Examples of Technologies for Effective Change Management

1. **Change Management & ITSM:** GLPI, iTop, OpenITCOCKPIT.
2. **Configuration & Patch Management:** Ansible, Puppet, SaltStack.
3. **Security Testing:** OWASP ZAP, Nikto, Wapiti, Nmap.
4. **SIEM & Monitoring:** Wazuh, ELK Stack, OSSIM.
5. **Rollback & Disaster Recovery:** ReaR (Relax-and-Recover), Clonezilla, Bacula.
6. **Privileged Access Management (PAM):** Boundary (HashiCorp), Teleport (Community Edition), StrongDM (limited OSS alternatives).
7. **DevOps Security:** GitLab CI/CD (open-source), Trivy, Semgrep.

Examples of KPIs for Change Management

1. **Percentage of Unauthorized Changes** – Detect policy violations.
2. **Percentage of Changes Successfully Implemented Without Rollbacks** – Measures change stability.
3. **Mean Time to Approve and Implement Changes** – Evaluates efficiency.
4. **Percentage of Emergency Changes** – Tracks deviations from standard processes.
5. **Percentage of Changes with Security Assessments** – Ensures security testing is performed.
6. **Regulatory Compliance Rate** – Tracks adherence to SAMA CSF & CST CRF.
7. **Change Management Audit Pass Rate** – Measures control effectiveness.

Samples of Auditor's Checklist for Change Management

- ✓ Is there a formal Change Management Policy?
- ✓ Are all changes classified based on security impact?
- ✓ Are risk assessments and security tests conducted before deployment?
- ✓ Are emergency changes documented and reviewed post-implementation?
- ✓ Is there a rollback plan for failed changes?
- ✓ Are change requests reviewed and approved by the CAB?

Samples of Audit Scenarios for Change Management

Scenario 1: Unauthorized System Changes

- **Objective:** Identify unapproved modifications.
- **Key Questions:** Are all system changes properly documented and approved?

Scenario 2: Lack of Security Testing

- **Objective:** Verify if security assessments are conducted.
- **Key Questions:** Are penetration tests performed before critical system updates?

Scenario 3: Ineffective Rollback Procedures

- **Objective:** Evaluate the organization's ability to revert failed changes.
- **Key Questions:** Are rollback plans tested and documented?

Case Study 1: Financial Institution

Challenges:

- Unstructured change approval process.
- Emergency changes bypassing security assessments.
- Regulatory compliance failures.

Actions Taken:

- Implemented CAB for change approvals.
- Enforced mandatory security testing.
- Automated rollback tracking.

Outcomes:

- 80% reduction in unauthorized changes.
 - Improved compliance and faster incident resolution.
-

Case Study 2: Telecom Company

Challenges:

- Service outages due to untested network changes.
- Poorly managed emergency changes.
- Configuration inconsistencies.

Actions Taken:

- Integrated DevSecOps security controls.
- Pre-production testing for all changes.
- Real-time change monitoring.

Outcomes:

- 60% fewer service disruptions.
- Enhanced security and compliance.
- Improved customer satisfaction.

Reference:

- [1] C. C. Editor, "Vulnerability Management - Glossary | CSRC." Accessed: Apr. 21, 2025. [Online]. Available: https://csrc.nist.gov/glossary/term/vulnerability_management
- [2] "What is Vulnerability Management? | IBM." Accessed: Apr. 21, 2025. [Online]. Available: <https://www.ibm.com/think/topics/vulnerability-management>
- [3] C. C. Editor, "penetration testing - Glossary | CSRC." Accessed: Apr. 21, 2025. [Online]. Available: https://csrc.nist.gov/glossary/term/penetration_testing
- [4] "What is penetration testing? | What is pen testing?" Accessed: Apr. 21, 2025. [Online]. Available: <https://www.cloudflare.com/learning/security/glossary/what-is-penetration-testing/>
- [5] K. Scarfone and M. Souppaya, "Cybersecurity Log Management Planning Guide," National Institute of Standards and Technology, NIST Special Publication (SP) 800-92 Rev. 1 (Draft), Oct. 2023. doi: 10.6028/NIST.SP.800-92r1.ipd.
- [6] "What Is Log Management? Security, Processes, and Best Practices - IT Glossary | SolarWinds." Accessed: Apr. 21, 2025. [Online]. Available: <https://www.solarwinds.com/resources/it-glossary/log-management>
- [7] "3.2 Cyber Security Operations and Technology | SAMA Rulebook." Accessed: Apr. 21, 2025. [Online]. Available: <https://rulebook.sama.gov.sa/en/32-cyber-security-operations-and-technology>
- [8] "NIST Incident Response: Framework and Key Recommendations," BlueVoyant. Accessed: Apr. 21, 2025. [Online]. Available: <https://www.bluevoyant.com/knowledge-center/nist-incident-response-framework-and-key-recommendations>
- [9] L. J. Fennelly, *Effective physical security*. Butterworth-Heinemann, 2016. Accessed: Apr. 21, 2025. [Online]. Available: <https://books.google.com/books?hl=en&lr=&id=v0y0DAAAQBAJ&oi=fnd&pg=PP1&dq=Physical+Security&ots=yqeseQ7GEA&sig=UnosexgW1jd2N5TWjVM2TUqilno>
- [10] A. Sinha, T. H. Nguyen, D. Kar, M. Brown, M. Tambe, and A. X. Jiang, "From physical security to cybersecurity," *Journal of Cybersecurity*, vol. 1, no. 1, pp. 19–35, 2015.
- [11] "NIST SP 800-171 Requirement 3.10: Physical Protection - NeQter Labs." Accessed: Apr. 21, 2025. [Online]. Available: <https://neqterlabs.com/nist-sp-800-171-requirement-3-10-physical-protection/>
- [12] X. Li and Y. Xue, "A survey on web application security," *Nashville, TN USA*, vol. 25, no. 5, pp. 1–14, 2011.
- [13] A. Hoffman, *Web application security*. O'Reilly Media, Inc., 2024. Accessed: Apr. 21, 2025. [Online]. Available: <https://books.google.com/books?hl=en&lr=&id=ar7uEAAAQBAJ&oi=fnd&pg=PR4&dq=Web+Ap+plication+Security&ots=vd16t2P1mE&sig=W7QXXXLSixOFXWdjGEXwq-4Yh4>
- [14] "Web Application Security 101 - Learn All About Web Application Security | VMware." Accessed: Apr. 21, 2025. [Online]. Available: <https://www.vmware.com/topics/web-application-security>
- [15] W. Enck, D. Oteau, P. D. McDaniel, and S. Chaudhuri, "A study of android application security.," in *USENIX security symposium*, 2011, pp. 1–38. Accessed: Apr. 21, 2025. [Online]. Available: <https://www.usenix.org/legacy/event/sec11/tech/slides/enck.pdf>
- [16] A. Yip, X. Wang, N. Zeldovich, and M. F. Kaashoek, "Improving application security with data flow assertions," in *Proceedings of the ACM SIGOPS 22nd symposium on Operating systems principles*, Big Sky Montana USA: ACM, Oct. 2009, pp. 291–304. doi: 10.1145/1629575.1629604.
- [17] "What is application security? | IBM." Accessed: Apr. 21, 2025. [Online]. Available: <https://www.ibm.com/think/topics/application-security>

- [18] A. M. Hegland, E. Winjum, S. F. Mjolsnes, C. Rong, O. Kure, and P. Spilling, "A survey of key management in ad hoc networks," *IEEE Communications Surveys & Tutorials*, vol. 8, no. 3, pp. 48–66, 2006.
- [19] "key management - Glossary | CSRC." Accessed: Apr. 22, 2025. [Online]. Available: https://csrc.nist.gov/glossary/term/key_management
- [20] W. Fumy and P. Landrock, "Principles of key management," *IEEE Journal on selected areas in communications*, vol. 11, no. 5, pp. 785–793, 1993.
- [21] L. Chung, "Dealing with security requirements during the development of information systems," in *Active Flow and Combustion Control 2018*, vol. 141, R. King, Ed., in Notes on Numerical Fluid Mechanics and Multidisciplinary Design, vol. 141. , Cham: Springer International Publishing, 1993, pp. 234–251. doi: 10.1007/3-540-56777-1_13.
- [22] "NIST SSDF (Secure Software Development Framework): A Comprehensive Guide," Confluent. Accessed: Apr. 22, 2025. [Online]. Available: <https://www.confluent.io/learn/nist-ssdf/>
- [23] J. Jürjens, *Secure systems development with UML*. Springer Science & Business Media, 2005. Accessed: Apr. 22, 2025. [Online]. Available: <https://books.google.com/books?hl=en&lr=&id=oHxiMnDHqnoC&oi=fnd&pg=PA3&dq=System+Development+Security&ots=XvoZfB17We&sig=j7wF3WQvfT8PoFDsFMBzNbn21Ss>
- [24] "What is Secure SDLC?," Check Point Software. Accessed: Apr. 22, 2025. [Online]. Available: <https://www.checkpoint.com/cyber-hub/cloud-security/what-is-secure-sdlc/>
- [25] E. Riedel, M. Kallahalla, and R. Swaminathan, "A framework for evaluating storage system security," in *Conference on File and Storage Technologies (FAST 02)*, 2002. Accessed: Apr. 22, 2025. [Online]. Available: https://www.usenix.org/events/fast02/full_papers/riedel/riedel_html/
- [26] C.-T. Huang, Z. Qin, and C.-C. J. Kuo, "Multimedia storage security in cloud computing: An overview," in *2011 IEEE 13th international workshop on multimedia signal processing*, IEEE, 2011, pp. 1–6. Accessed: Apr. 22, 2025. [Online]. Available: <https://ieeexplore.ieee.org/abstract/document/6093775/>
- [27] "NIST SP 800-171 Requirement 3.8: Media Protection - NeQter Labs." Accessed: Apr. 22, 2025. [Online]. Available: <https://neqterlabs.com/nist-sp-800-171-requirement-3-7-media-protection/>
- [28] H. Gobioff, G. Gibson, and D. Tygar, *Security for network attached storage devices*. Citeseer, 1997. Accessed: Apr. 22, 2025. [Online]. Available: <https://citeseerx.ist.psu.edu/document?repid=rep1&type=pdf&doi=1f059077d16ba1c6ba5f60891bd85272718c43cc>
- [29] G. F. Hughes, T. Coughlin, and D. M. Commins, "Disposal of disk and tape data by secure sanitization," *IEEE Security & Privacy*, vol. 7, no. 4, pp. 29–34, 2009.
- [30] S. Barker, "ISO 27001 Annex A 7.14 Secure Disposal Or Re-Use Of Equipment," High Table. Accessed: Apr. 22, 2025. [Online]. Available: <https://hightable.io/iso-27001-annex-a-7-14-secure-disposal-or-re-use-of-equipment/>
- [31] A. Jones, "Lessons not learned on data disposal," *Digital Investigation*, vol. 6, no. 1–2, pp. 3–7, 2009.
- [32] V. F., "NIST SP 800-88 Guidelines for Media Sanitization Explained," Jetico. Accessed: Apr. 22, 2025. [Online]. Available: <https://jetico.com/blog/nist-sp-800-88-guidelines-media-sanitization-explained/>
- [33] P. Shepita, L. Tupychak, and J. Shepita, "Analysis of Cyber Security Threats of the Printing Enterprise," *Journal of Cyber Security and Mobility*, pp. 415–434, 2023.

- [34] J. Toh, M. Hatib, O. Porzecanski, and Y. Elovici, "Cyber security patrol: detecting fake and vulnerable wifi-enabled printers," in *Proceedings of the Symposium on Applied Computing*, Marrakech Morocco: ACM, Apr. 2017, pp. 535–542. doi: 10.1145/3019612.3019722.
- [35] "open.pdf." Accessed: Apr. 22, 2025. [Online]. Available: <https://it.nc.gov/documents/files/securing-multifunctional-devices-mfds/open>
- [36] E. B. Blancaflor and A. J. Montoya, "Vulnerabilities in Office Printers, Multifunction Printers (MFP), 3D Printers, and Digital Copiers: A Gateway to Breach Our Enterprise Network," in *International Conference on Cloud Computing and Computer Networks*, L. Meng, Ed., in Signals and Communication Technology. , Cham: Springer Nature Switzerland, 2024, pp. 53–62. doi: 10.1007/978-3-031-47100-1_5.
- [37] "3.3.13 Electronic Banking Services | SAMA Rulebook." Accessed: Apr. 22, 2025. [Online]. Available: <https://rulebook.sama.gov.sa/en/3313-electronic-banking-services-0>
- [38] "4.4. Authentication | SAMA Rulebook." Accessed: Apr. 22, 2025. [Online]. Available: <https://rulebook.sama.gov.sa/en/44-authentication>
- [39] "Cyber Security Framework | SAMA Rulebook." Accessed: Apr. 22, 2025. [Online]. Available: <https://rulebook.sama.gov.sa/en/cyber-security-framework-2>
- [40] "3.3.7 Change Management | SAMA Rulebook." Accessed: Apr. 22, 2025. [Online]. Available: <https://rulebook.sama.gov.sa/en/337-change-management-0>

Module 3: Cybersecurity Resilience Aspects of Business Continuity management (BCM)

Overview:

Cybersecurity Resilience within Business Continuity Management (BCM) emphasizes the integration of cybersecurity considerations into broader business continuity strategies, ensuring organizations can effectively withstand, recover from, and adapt to cybersecurity incidents without significant disruption to critical operations. This module addresses how cybersecurity threats—such as ransomware attacks, data breaches, and system failures—can severely impact operational continuity and outlines proactive and reactive strategies to mitigate these impacts.

Key elements include developing comprehensive cybersecurity incident response plans, clearly defining roles and responsibilities during incidents, and maintaining disaster recovery plans tailored specifically for cyber threats. Organizations must establish secure, redundant infrastructure solutions, conduct periodic Business Impact Analysis (BIA), and regularly test disaster recovery and continuity plans. These processes align with Saudi Arabian cybersecurity regulations (NCA ECC, CCCC, OTCC, CCC, and CMA guidelines), highlighting legal obligations for maintaining data integrity, confidentiality, and availability during and after cybersecurity incidents. Case studies and practical examples illustrate the application of resilience strategies across various critical sectors, guiding participants in crafting robust, legally compliant continuity frameworks capable of minimizing downtime and ensuring resilient business operations.

Introduction to Cybersecurity Resilience Aspects of Business Continuity Management (BCM):

Cybersecurity Resilience Aspects of Business Continuity Management (BCM) refer to the integration of cybersecurity practices and principles into an organization's BCM framework to ensure the ability to prevent, withstand, recover from, and adapt to cyber threats while maintaining critical operations [1], [2].

Objective:

To ensure the inclusion of the cybersecurity resiliency requirements within the organization's business continuity management and to remediate and minimize the impacts on systems, information processing facilities and critical e-services from disasters caused by cybersecurity incidents.

Controls Matrix:

Below is a summary matrix detailing relevant Cybersecurity Resilience Aspects of Business Continuity management (BCM) controls based on NCA, SAMA CSF, CST CRF, and CMA Cybersecurity guidelines:

Regulation	Main Controls	Control References
NCA ECC	4	3.1.1, 3.1.2, 3.1.3, 3.1.4
SAMA CSF	1	3.1.3.4.f.8
CST CRF	-	-
CMA CSG	1	4.3.15 (11 Sub-controls: 4.3.15.1-4.3.15.11)
NCA CCCC	1	3.1.1 (4 Sub-controls)
NCA CCC CST	1	3.1.T.1.1
NCA CCC CSP	1	3.1.P.1 (2 Sub-controls: 3.1.P.1.1, 3.1.P.1.2)
NCA TCC	-	-
NCA DCC	-	-
NCA OSMACC	-	-
NCA OTCC	2	3.1.1, 3.1.2 (6 Sub-controls under 3.1.1)

Cybersecurity Resilience Controls:

Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines:	Expected deliverables
ECC					
3.1.1		Cybersecurity requirements for business continuity management must be defined, documented and approved.	• Cybersecurity Business Continuity Policy Template	• Include and document cybersecurity requirements within the organization's business continuity management, including but not limited to. ○ Ensure the continuity of cybersecurity-related systems and procedures. ○ Develop cybersecurity incident response plans that may affect the business continuity of the organization. ○ Develop Disaster Recovery Plan. • Cybersecurity requirements within business continuity management must be supported by the Executive Management. This must be done through the approval of the organization head or his/ her deputy.	• Cybersecurity policy that covers the requirements of business continuity management (e.g., electronic copy or official hard copy). • Formal approval by the head of the organization or his/her deputy on such document (e.g., via the organizations official e-mail, paper or electronic signature).
3.1.2		The cybersecurity requirements for business continuity management must be implemented.		• Implement cybersecurity requirements within business continuity management that have been identified, documented, and approved in the policy. • Develop an action plan to implement all cybersecurity requirements to ensure BCM in the organization. • Include cybersecurity requirements for BCM in the organizations BCM procedures to ensure compliance with cybersecurity requirements for all internal and external stakeholders.	• Documents that confirm the implementation of cybersecurity requirements related to BCM as documented in the policy. • An action plan to implement cybersecurity requirements for BCM in the organization. • Evidence showing the implementation of BCM controls at the organization, including but not limited to:

					• Documented and approved business continuity plans for the organization. • Approved plans to respond to cybersecurity incidents that may affect the business continuity of the organization. • Reports on the implementation of disaster recovery plans tests at the organization.
3.1.3	3.1.3.1	The cybersecurity requirements for business continuity management must include at least the following: 3-1-3-1 Ensuring the continuity of cybersecurity systems and procedures.		• Define and document the requirements of this ECC in the cybersecurity requirements document and approve them by the representative. • Laws and regulations related to business continuity in the organization must be defined. • Include high-risk cybersecurity incidents as a rationale for activating the organizations business continuity plan. • Develop Business Continuity Management Program in the organization. • Document and approve business continuity plans, including but not limited to: ○ Procedures for assessing risks that may affect the organization's business continuity. ○ Business Impact Analysis. ○ Definition of the cybersecurity systems, procedures and assets and their importance to the organization. ○ Cybersecurity-related systems continuity procedures, including technical requirements such as high	• A document (such as approved policy or procedure) indicating the identification and documentation of the requirements related to this control • Documented and approved business continuity management program for the organization. • Documented and approved business continuity plans for the organization. • Formal approval by the head of the organization or his/her deputy on such documents (eg., via the organization's official e-mail, paper or electronic signature. • Reports on the implementation of the organization's business continuity plans tests. • Report showing the sharing of the periodic meetings for

				availability, and regulatory requirements, such as the presence of a deputy that replaces the operators of cybersecurity systems when needed. ○ Definition of cybersecurity services and their importance to the organization and develop a plan to ensure the continuity of these services. ● Review the organization's business continuity plans periodically and update them if necessary.	sharing cybersecurity business continuity plans with the enterprise business continuity and involvement of stakeholders
	3.1.3.2	Developing response plans for cybersecurity incidents that may affect the business continuity.		● Define and document the requirements of this ECC in the cybersecurity requirements document and approve them by the representative. ● Develop the plans for cybersecurity incident response that may affect the organization's business continuity, including (but not limited to): ○ An explanation of the types of accidents and their classification according to their impact on the organization's business continuity. ○ Roles and responsibilities for responding to cybersecurity incidents affecting the organization's business continuity. ○ Definition of incident response phases, including (but not limited to): ▪ Planning and Preparation ▪ Detection and Analysis ▪ Containment, Eradication and Recovery ▪ Review and Learn ○ Utilizing NCA published incident response playbooks.	● A document (such as approved policy or procedure) indicating the identification and documentation of the requirements related to this control ● Approved plans to respond to cybersecurity incidents that may affect the business continuity of the organization. ● Formal approval by the head of the organization or his/her deputy on such documents (e.g., via the organizations official e-mail, paper or electronic signature)

				• Include high-risk cybersecurity incidents as a rationale for activating the cybersecurity incident response plans. • Draft a report on cybersecurity incidents affecting the organization's business continuity upon the completion of the response to include (but not limited to): ○ Persons involved in responding to the incident and the means of communication. ○ Basic information of the incident, including but not limited to: ▪ Date and time. ▪ Scope of incident. ▪ Severity Level. ○ Summary of the incident. ○ Containment and removal steps. ○ Current and future recommendations. • Review the response plans for cybersecurity incidents that may affect the organization's business continuity periodically and update them if necessary.	
	3.1.3.3	Developing disaster recovery plans.		• Define and document the requirements of this ECC in the cybersecurity requirements document and approve them by the representative. • Develop disaster recovery plans, including (but not limited to): ○ Identify disaster recovery team. ○ Identify and assess disaster risk. ○ Conduct Business Impact Analysis (BIA) to identify critical systems within the organization. ○ Define backup and external storage procedures. ○ Test disaster recovery plans. • Establish a disaster recovery center for critical systems.	• A document (such as approved policy or procedure) indicating the identification and documentation of the requirements related to this control • Organization -approved disaster recovery plans. • Reports on the implementation of disaster recovery plans tests at the organization. • Formal approval by the head of the organization or his/her deputy on such documents

				• Conduct periodic tests to ensure the effectiveness of disaster recovery plans. • Identify the requirements of periodic copies of the organization's systems to the recovery center.	(eg., via the organization's official e-mail, paper or electronic signature).
3.1.4		The cybersecurity requirements for business continuity management must be reviewed periodically.		• Review and update cybersecurity requirements for business continuity in the organization periodically according to a documented and approved plan for review and based on a planned interval or in the event of changes in relevant laws and regulations. • Document the review and changes to the cybersecurity requirements for business continuity management in the organization and approve them by the head of the organization or his/her deputy.	• An approved document that sets the policy review schedule • Policy indicating that it is up to date and the changes to the cybersecurity requirements for business continuity have been documented and approved by the head of the organization or his/her deputy. • Formal approval by the head of the organization or his/her deputy on the updated policy (e.g., via the organizations official e-mail, paper or electronic signature).
NCA CSCC					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines:	Expected deliverables
3.1.1	3.1.1.1	In addition to the sub-controls within Control 3-1-3 in Basic Controls for Cyber Security, they must cover business continuity management in the entity, at a minimum; the following: 3-1-1-1 Develop a		• Develop a disaster recovery center for critical systems, which includes: ○ Determine whether the recovery center is established by the entity or is a cloud service provided by a third party, if the service is provided by a third party: ▪ The service provider must be located in the Kingdom of Saudi Arabia.	• Entity network diagram. • Designing the entity's recovery center.

		disaster recovery center for critical systems.		○ In the event that the entity wanted to establish its own recovery center, it is necessary to prepare and equip the recovery center, which includes, for example : ▪ Separate the disaster recovery center of critical systems from other systems. ▪ Total storage of hardware, software, and other equipment. ▪ Documenting business objectives. ▪ Define and specify the time/limit for failure and data loss. ▪ Recovery center team. ▪ Alternate/backup workspaces. ▪ Activate the remote access option. ▪ Secure backups. ▪ Comprehensive testing strategy. ○ Define a geographic area and scope for the disaster recovery center for critical systems away from the data center for critical systems.	
	3.1.1.2	inclusion of critical systems; within disaster recovery plans.		• Working to include critical systems; Within disaster recovery plans, it includes: ○ Identify a team for critical systems to activate procedures in disaster recovery plans. ○ Identify and evaluate risks affecting critical systems. ○ Define backup and external storage procedures for critical systems.	• Disaster recovery plans documented and approved by the entity, which include critical systems.
	3.1.1.3	conduct periodic examinations; Once a year, to ensure the effectiveness of disaster recovery plans for critical systems; at least.		• conduct periodic examinations; Once a year, to ensure the effectiveness of disaster recovery plans for critical systems; At a minimum, it includes: ○ Define and document a periodic testing schedule to ensure the effectiveness of	• Updated report for effective testing of disaster recovery plans for critical systems. • A plan to conduct tests of the effectiveness of disaster recovery plans for critical systems in the entity.

				disaster recovery plans for critical systems. ○ Determine the documentation of the period of conducting the test periodically, not less than once a year. ○ Adopting a schedule of periodic tests to ensure the effectiveness of recovery plans by those with authority. ○ Defining and documenting a plan to address feedback discovered during periodic testing to ensure the effectiveness of recovery plans.	
	3.1.1.4	The NCA recommends periodic live testing; Disaster recovery (Live DR Test) for critical systems.		• NCA recommends conducting periodic live testing; For disaster recovery (Live DR Test) for critical systems, which includes: ○ Determine the Objective, intent and actions to be taken to create the post-test analysis. ○ Determine the scope of the test. ○ Confirm that the test environment is ready, and will not impact production systems or interfere with other activities. ○ Stop and review testing when problems arise and reschedule it if necessary.	• The live DR Testing Schedule for critical systems approved by the entity. • A recent report of a live disaster recovery test for critical systems.
NCA OSMACC					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines:	Expected deliverables
N/A					
NCA TCC					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
N/A					
NCA DCC					

Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
N/A					
NCA OTCC					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
3.1.1	3.1.1.1	In addition to subcontrols in the ECC control 3-1-3, cybersecurity requirements for cybersecurity resilience aspects of business continuity management in OT/ICS must include, at a minimum, the following: 3-1-1-1 Activities necessary to sustain minimum operations of the OT/ICS systems must be defined.	• Template for Cybersecurity Operational Technology Policy • Template for OT/ICS Security Standard • Template for Cybersecurity Business Continuity Policy	• Define a list of sensitive operation technologies and activities necessary to sustain minimum operations of the OT/ICS systems in coordination with the industrial facility personnel. • Verify and ensure that all activities identified are sufficient to maintain the minimum operation of sensitive operation technologies.	• A documented list of sensitive operation technologies of the OT/ICS systems at the facility. • A documented list of essential activities to maintain the minimum operation of sensitive operation technologies. • A proof that all activities identified are sufficient to maintain the minimum operation of sensitive operation technologies.
	3.1.1.2	Redundant OT/ICS networks, connections, and devices must be implemented in accordance to the periodic cybersecurity risk assessment.	• Template for Cybersecurity Operational Technology Policy • Template for OT/ICS Security Standard • Template for Cybersecurity Business Continuity Policy	• Perform the periodic cybersecurity risk assessment in line with the defined periodical OT/ICS risk assessment plan. • Based on the risk assessment, identify and document areas and systems where redundancy is necessary. • Implement redundant networks, connections, and sensitive devices for OT/ICS assets in line with risk assessment results.	• A periodic risk assessment report. • A documented list of areas and systems where redundancy is necessary. • Site visit to check that redundant networks, connections, and sensitive devices for OT/ICS assets are implemented in line with risk assessment results.

	3.1.1.3	OT/ICS cybersecurity requirements must be incorporated into the Business Continuity Plan (BCP), Business Impact Analysis (BIA), Recovery Time Objectives (RTO), and Recovery Point Objectives (RPO).	• Template for Cybersecurity Operational Technology Policy • Template for OT/ICS Security Standard • Template for Cybersecurity Business Continuity Policy	• Define and document OT/ICS cybersecurity requirements related to the Business Continuity Plan (BCP), Business Impact Analysis (BIA), Recovery Time Objectives (RTO), and Recovery Point Objectives (RPO). • Include documented requirements in the Business Continuity Plan (BCP), Business Impact Analysis (BIA), Recovery Time Objectives (RTO), and Recovery Point Objectives (RPO). • Verify and ensure that documented OT/ICS cybersecurity requirements are integrated and aligned with general organizational requirements.	• Documented OT/ICS cybersecurity requirements. • A proof that documented OT/ICS cybersecurity requirements are incorporated into the Business Continuity Plan (BCP), Business Impact Analysis (BIA), Recovery Time Objectives (RTO), and Recovery Point Objectives (RPO).
	3.1.1.4	OT/ICS cybersecurity requirements must be incorporated into the Disaster Recovery Plan (DRP) including cybersecurity-related disaster scenarios, system failure handling procedures, and operational continuity management procedures.	• Template for Cybersecurity Operational Technology Policy • Template for OT/ICS Security Standard • Template for Cybersecurity Business Continuity Policy	• Define and document OT/ICS cybersecurity requirements related to the Disaster Recovery Plan (DRP). • Ensure the OT/ICS cybersecurity requirements are incorporated into the Disaster Recovery Plan (DRP) including: ○ Cybersecurity related disaster scenarios. ○ System failure handling procedures. ○ Operational technology management procedures.	• Documented OT/ICS cybersecurity requirements. • A proof that the documented OT/ICS cybersecurity requirements are incorporated into the Disaster Recovery Plan (DRP) including cybersecurity-related disaster scenarios, system failure handling procedures, and operational continuity management procedures.
	3.1.1.5	In the event of a system failure due to a cybersecurity incident, OT/ICS assets or systems must operate on an acceptable safe mode to achieve a continuous operation.	• Template for Cybersecurity Operational Technology Policy • Template for OT/ICS Security Standard • Template for Cybersecurity	• Develop and implement system failure handling procedures. • Verify and ensure that all OT/ICS assets or systems have defined the acceptable safe mode and the action plan to achieve a continuous operation.	• A documented system failure handling procedures. • A proof that shows all OT/ICS assets or systems have defined the acceptable safe mode and the action plan to achieve a continuous operation..

			Business Continuity Policy		
	3.1.1.6	Periodic testing and simulation exercises (e.g. tabletop exercises "TTX") must be conducted to test the effectiveness of OT/ICS related DRP and BCP and complete incident root cause analysis.	• Template for Cybersecurity Operational Technology Policy • Template for OT/ICS Security Standard • Template for Cybersecurity Business Continuity Policy	• Conduct a periodic testing and simulation exercises (e.g. tabletop exercises "TTX") to test the effectiveness of OT/ICS related DRP and BCP and complete incident root cause analysis. • Document the reports specified for testing and simulation exercises results.	• A documented OT/ICS related DRP and BCP effectiveness testing plan. • A periodically prepared testing and simulation exercises reports. • A proof that OT/ICS related to DRP and BCP effectiveness and complete incident root cause analysis is periodically tested.
3.1.2		With reference to the ECC control 3-1-4, the cybersecurity requirements for cybersecurity resilience aspects of business continuity management in OT/ICS environment must be reviewed, and their implementation effectiveness is measured and evaluated periodically.	• Template for Cybersecurity Operational Technology Policy • Template for OT/ICS Security Standard • Template for Cybersecurity Business Continuity Policy • Template for Key Performance Indicator Report	• Review the cybersecurity requirements for cybersecurity resilience aspects of business continuity management in the OT/ICS environment periodically based on a documented and approved review plan and on a defined frequency (e.g., conduct a review annually). • Develop key performance indicators (KPIs) for each control within the related policy or procedure to ensure the implementation effectiveness is measured and evaluated periodically based on a defined frequency (e.g., conduct a review annually).	• A proof that shows the periodic review of cybersecurity requirements for cybersecurity resilience aspects of business continuity management for the OT/ICS environment. • A proof that shows the key performance indicators (KPIs) for each control within the related policy or procedure to ensure the implementation effectiveness is measured and evaluated periodically (based on a defined frequency).
NCA CCC CST					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables

3.1.T.1.1		In addition to sub controls in the ECC control 3-1-3, the CST shall cover the following additional sub controls for cybersecurity requirements for cybersecurity resilience aspects of business continuity management, as a minimum: 3-1-T-1-1 Developing and implementing disaster recovery and business continuity procedures related to cloud computing, in a secure manner.	• Template for Cybersecurity Policy within Business Continuity	• Define requirements for disaster recovery and business continuity procedures, taking account of identified risks related to cloud computing (e.g. data leakage or unintentional exposure) • Develop, approve and implement disaster recovery and business continuity procedures/plans for cloud computing based on requirements. • Test the procedures regularly and upon significant changes to ensure its applicability.	• Disaster Recovery Procedure/Plan for cloud computing. • Business Continuity Procedure/Plan for cloud computing.
NCA CCC CSP					
3.1.P.1	3.1.P.1.1	In addition to sub controls in the ECC control 3-1-3, the CSP shall cover the following additional sub controls for cybersecurity requirements for cybersecurity resilience aspects of business continuity management, as a minimum: 3-1-P-1-1 Developing and implementing disaster	• Template for Cybersecurity Policy within Business Continuity	• Define requirements for disaster recovery and business continuity procedures, taking account of identified risks related to cloud computing. • Develop, approve and implement disaster recovery and business continuity procedures/plans including security measures, taking account of defined requirements. • Clearly communicate and make the documents available for the relevant authorized personnel. • Test the procedures Periodically and upon significant changes to ensure its applicability.	• Disaster Recovery Procedure/Plan for cloud computing • Business Continuity Procedure/Plan for cloud computing.

		recovery and business continuity procedures in a secure manner.			
	3.1.P.1.2	Developing and implementing procedures to ensure resilience and continuity of cybersecurity systems dedicated to the protection of Cloud Technology Stack	• Template for Cybersecurity Policy within Business Continuity	• Develop procedures to ensure resilience and continuity that are specific to cybersecurity of Cloud Technology Stack. • Review Periodically these procedures. • Make resilience and continuity mechanisms an Architectural Principle for cybersecurity. • Develop catalogue of resilience and continuity assurance techniques and methods.	• Document outlining enhanced measures to ensure resilience and continuity of cybersecurity systems dedicated to protecting the Cloud Technology Stack. • Periodical review reports and documents. • Evidence illustrating techniques and methods ensuring resilience and continuity.

SAMA CSF

Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
3.1.3.4	3.1.3.4.f.8	The cyber security policy should include ;f. cyber security requirements that ensure: 8. cyber security is reflected in business continuity management.			

CST CRF

Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
N/A					

CMA Cybersecurity Guidelines

Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
--------------------------	-------------	-----------------	------------------------------	-----------------------------------	-----------------------

4.3.15.1		Set out, document, approve and update a business continuity policy and communicate the same to stakeholders inside and outside the market institution.			
4.3.15.2		Review business continuity policy on an annual basis or when significant changes occur.			
4.3.15.3		Identify standards, legislation and regulations to be observed on development of business continuity policy.			
4.3.15.4		Conduct BIA, through which all key processes and services can be identified for market institution's business.			
4.3.15.5		Conduct BIA on an annual basis to identify scope of Business Continuity Management Program and to confirm business priorities and resources.			
4.3.15.6		Prepare a Business Continuity Management Strategy that clarifies business recovery requirements and is consistent with time			

		required and expected to restore the capacity for work specified and approved in BIA.			
4.3.15.7		Establish a Crisis Management Team, comprising representatives of the board of directors, executive management and employees qualified to deal with accidents that affect business continuity.			
4.3.15.8		The business continuity plan includes clear and specific steps that shall be taken in the event of crises or emergencies, contact details of all officers in charge, in addition to regular testing of the plan to know how far it represents the reality.			
4.3.15.9		Test Business Continuity Management and Disaster Recovery Plans periodically or after every material change to ensure being suitable, updated and compatible with business continuity objectives.			

4.3.15.10		Ensure that employees entrusted with developing Business Continuity Management Programs are trained and qualified and have the necessary experience to deal with management of such plans and programs.			
4.3.15.11		Provide general training and awareness required for all employees regarding Business Continuity Management.			

Risk Considerations in Cybersecurity Resilience Aspects of Business Continuity management (BCM)

- **Risk Title:** Inadequate Threat Detection and Response
Risk Description: The failure to implement effective systems for detecting and responding to cybersecurity threats could lead to undetected attacks and prolonged system downtimes.
Risk Mitigation: Implement continuous threat monitoring, advanced intrusion detection systems (IDS), and establish well-defined incident response protocols to ensure fast detection and recovery.
- **Risk Title:** Insufficient Employee Training and Awareness
Risk Description: Employees not being well-informed about cybersecurity risks may unintentionally contribute to security breaches.
Risk Mitigation: Regularly train employees on cybersecurity best practices, phishing awareness, and the importance of security hygiene.
- **Risk Title:** Lack of Robust Backup and Recovery Solutions
Risk Description: Insufficient or outdated backup systems may result in catastrophic data loss or slower recovery from security incidents.
Risk Mitigation: Regularly update and test backup processes, ensuring redundant systems and offsite backups are available for critical business operations.
- **Risk Title:** Failure to Address Critical Dependencies
Risk Description: Overlooking cybersecurity resilience of critical infrastructure or third-party dependencies can disrupt business operations in the event of an attack.
Risk Mitigation: Map out all dependencies, including third-party services, and ensure they adhere to a robust cybersecurity framework and have backup options in place.
- **Risk Title:** Poor Communication During Crisis
Risk Description: Inadequate communication during a cybersecurity crisis can exacerbate the situation and cause delayed actions.
Risk Mitigation: Establish a comprehensive communication plan that clearly outlines internal and external communication channels, roles, and responsibilities during a crisis.

Examples of Technologies for Effective Cybersecurity Resilience Aspects of Business Continuity management (BCM)

- **Disaster Recovery & Business Continuity Planning Tools**
 - **Zerto**: Enables disaster recovery (DR) and business continuity with continuous data protection, replication, and failover functionality.
 - **Veeam**: Provides backup, replication, and disaster recovery solutions for maintaining business continuity during cybersecurity incidents.
 - **Arcserve UDP**: Provides comprehensive data protection, business continuity, and disaster recovery capabilities.
- **Incident Response and Management Tools**
 - **Cortex XSOAR (formerly Demisto)**: An automated security orchestration, incident response, and case management tool.
 - **IBM Resilient**: Helps businesses respond and manage cybersecurity incidents, integrating incident management with business continuity and recovery strategies.
- **Risk Management Platforms**
 - **RSA Archer**: A risk management platform for identifying, assessing, and managing the business continuity risks tied to cybersecurity.
 - **LogicManager**: Helps organizations create risk and resilience frameworks within the business continuity and disaster recovery context.
- **Business Continuity and Cybersecurity Maturity Models**
 - **NIST Cybersecurity Framework (CSF)**: A guide for understanding and managing cybersecurity resilience aspects of BCM, ensuring consistency and alignment with best practices.
- **Continuous Monitoring and Analytics Tools**
 - **Splunk**: A tool for monitoring security events, which is essential for identifying potential threats and recovery timelines during and post-cybersecurity incidents.
 - **Datadog**: Allows proactive monitoring of system uptime and service disruptions during a disaster recovery event.

Examples of KPIs for Cybersecurity Resilience Aspects of Business Continuity management (BCM)

1. **KPI Title:** Incident Recovery Time (Mean Time to Recovery - MTTR)
Description: Measures the average time it takes to restore normal business operations following a cybersecurity incident or failure.
Goal: Minimize downtime and ensure fast recovery through resilient business continuity plans.
2. **KPI Title:** Cybersecurity Incident Frequency
Description: Tracks the number of cybersecurity incidents affecting business continuity within a given period.
Goal: Reduce the frequency of security incidents through proactive risk management and enhanced resilience protocols.
3. **KPI Title:** Business Continuity Plan Testing Frequency
Description: The number of times business continuity and disaster recovery plans are tested annually.
Goal: Ensure regular testing to guarantee readiness and preparedness in case of a real cybersecurity event.
4. **KPI Title:** System Availability Rate
Description: Measures the percentage of time critical systems are available and functional.
Goal: Achieve a high system availability rate (>99%) to minimize disruptions in critical business services.
5. **KPI Title:** Employee Recovery Training Completion Rate
Description: Tracks the percentage of employees trained to follow the business continuity and disaster recovery procedures during cybersecurity incidents.
Goal: Ensure 100% of key staff is trained and aware of recovery protocols to enable rapid recovery from incidents.

Case Study: Developing and Implementing Cybersecurity Resilience Aspects of Business Continuity Management (BCM) for a Saudi Organization

This case study provides a detailed framework for integrating cybersecurity resilience into the Business Continuity Management (BCM) of a Saudi organization. By aligning cybersecurity requirements with organizational BCM objectives, the initiative aims to ensure operational continuity during and after cybersecurity incidents, fostering resilience and compliance with regulatory mandates.

Phase 1: Incorporating Cybersecurity into Business Continuity Management

1. Documenting Cybersecurity Requirements

- Identify and document all cybersecurity requirements related to BCM, including system continuity and incident response needs.
- Secure endorsement and formal approval from executive management, represented by the organization's head or deputy.

2. Action Plan Development

- Create a comprehensive action plan to implement the identified cybersecurity requirements within BCM.
- Coordinate with relevant departments to ensure alignment with internal and external stakeholders.

3. Compliance and Regulation

- Define applicable laws and regulations governing business continuity in the organization.
- Ensure high-risk cybersecurity incidents are accounted for in the BCM activation plan.

Phase 2: Business Continuity Planning

1. Business Continuity Plans (BCP)

- Document and approve BCPs addressing:
 - Risk assessment procedures for identifying factors affecting business continuity.
 - Business Impact Analysis (BIA) to evaluate organizational priorities.
 - Identification and categorization of critical cybersecurity systems and procedures.
 - High-availability requirements for technical systems.
 - Development of deputy systems or personnel to manage cybersecurity during critical events.
- Define procedures to ensure continuity of essential cybersecurity services.

2. Periodic Reviews

- Regularly review and update BCPs to adapt to emerging threats and organizational changes.

Phase 3: Cybersecurity Incident Response Plan

1. Incident Response Framework

- Develop a comprehensive incident response plan addressing potential impacts on business continuity:
 - Classify incidents based on their severity and business impact.
 - Define roles and responsibilities for incident management.
 - Establish incident response phases:
 - Planning and Preparation.
 - Detection and Analysis.
 - Containment, Eradication, and Recovery.
 - Post-incident Review and Learning.

- Leverage the National Cybersecurity Authority (NCA) incident response playbooks for guidance.

2. Incident Response Activation

- Integrate high-risk cybersecurity incidents into the criteria for activating the BCM plan.
- Draft and document post-incident reports, including:
 - Incident details such as date, scope, and severity.
 - Containment and eradication measures taken.
 - Recommendations for future prevention.

3. Periodic Plan Review

- Regularly review and update incident response plans to reflect changes in the threat landscape and regulatory requirements.

Phase 4: Disaster Recovery Planning

1. Developing Disaster Recovery Plans

- Assemble a disaster recovery team and assign responsibilities.
- Conduct risk assessments to identify disaster scenarios.
- Perform Business Impact Analysis (BIA) to pinpoint critical systems.
- Establish and document backup and external storage procedures.
- Define and implement a disaster recovery center for critical systems.

2. Testing and Validation

- Conduct periodic tests to assess the effectiveness of disaster recovery plans.
- Ensure regular system backups and alignment with disaster recovery objectives.

3. Ongoing Evaluation

- Schedule periodic reviews and updates of disaster recovery plans to incorporate changes in laws and regulations or organizational needs.

Phase 5: Continuous Improvement

1. Monitoring and Compliance

- Document and approve any changes to BCM-related cybersecurity requirements.
- Maintain periodic review cycles to ensure continued compliance with evolving legal and operational standards.

2. Training and Awareness

- Train employees and stakeholders on updated BCM and cybersecurity procedures.
- Foster a culture of resilience and preparedness through ongoing education and communication.

Reference:

- [1] T. Savolainen, N. McCarthy, K. Neville, and H. Ruoslahti, “Business Continuity Management of Critical Infrastructures from the Cybersecurity Perspective,” in *2024 IEEE Global Engineering Education Conference (EDUCON)*, IEEE, 2024, pp. 1–6. Accessed: Apr. 22, 2025. [Online]. Available: <https://ieeexplore.ieee.org/abstract/document/10578811/>
- [2] R. Steen, O. J. Haug, and R. Patriarca, “Business continuity and resilience management: A conceptual framework,” *Contingencies & Crisis Mgmt*, vol. 32, no. 1, p. e12501, Mar. 2024, doi: 10.1111/1468-5973.12501.

Module 4: Third-Party and Outsourcing Cybersecurity

Overview

The Third-Party and Outsourcing Cybersecurity module explores the critical area of managing cybersecurity risks arising from external partnerships, including service providers, outsourcing vendors, and cloud computing arrangements. Due to their potential access to sensitive data and systems, third parties introduce significant cybersecurity vulnerabilities if inadequately managed.

This module emphasizes the establishment of clear, detailed cybersecurity requirements within contractual agreements, conducting rigorous third-party risk assessments before engagements, and implementing continuous monitoring of vendor security postures. Participants learn how to structure comprehensive contracts that include mandatory data protection clauses, non-disclosure agreements, cybersecurity incident communication protocols, data deletion upon termination, and adherence to national cybersecurity standards.

Special attention is given to compliance with Saudi Arabian regulations mandating localized cybersecurity management (including hosting critical cybersecurity operations within the Kingdom), rigorous screening of outsourced employees, and verifying the cybersecurity capabilities of third-party entities. Case studies provide insight into effective third-party cybersecurity practices in finance, government, and real estate sectors, offering participants actionable insights and practical tools to ensure comprehensive third-party cybersecurity management and compliance.

Introduction to Third-Party Cybersecurity:

Third-Party Cybersecurity refers to the practice of managing and securing an organization's digital assets and data from cyber threats originating from its external vendors, partners, or service providers. These third parties often have access to the organization's systems, networks, or sensitive data to perform their roles, which can create vulnerabilities if not properly managed [1], [2], [3].

Objective:

To ensure the protection of assets against the cybersecurity risks related to third-parties including outsourcing and managed services as per organizational policies and procedures, and related laws and regulations.

Controls Matrix:

Below is a summary matrix detailing relevant Third-Party and Outsourcing Cybersecurity controls based on NCA, SAMA CSF, CST CRF, and CMA Cybersecurity guidelines:

Regulation	Main Controls	Control References
NCA ECC	4	4.1.1, 4.1.2, 4.1.3, 4.1.4
SAMA CSF	2	3.4.1, 3.4.2 (9 Sub-controls)
CST CRF	1	6.2 (7 Sub-controls: 6.2.1-6.2.7)
CMA CSG	2	4.4.1, 4.4.2 (11 Sub-controls: 4.4.1.1-4.4.1.6, 4.4.2.1-4.4.2.5)
NCA CSCC	1	4.1.1 (2 Sub-controls)
NCA CCC CST	-	-
NCA CCC CSP	1	4.1.P (4 Sub-controls: 4.1.P.1-4.1.P.4)
NCA TCC	-	-
NCA DCC	2	3.1.1, 3.1.2 (14 Sub-controls)
NCA OSMACC	2	3.1.1, 3.1.2 (3 Sub-controls under 3.1.2)
NCA OTCC	2	4.1.1, 4.1.2 (4 Sub-controls under 4.1.1)

Third-Party and Outsourcing Cybersecurity Controls:

Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines:	Expected deliverables
ECC					
4.1.1		Cybersecurity requirements for contracts and agreements with third-parties must be identified, documented and approved.	Third-party Cybersecurity Policy Template.	- Develop and document cybersecurity policy for Third-Party Cybersecurity in the organization, including the following: - Cybersecurity requirements within contracts and agreements with third parties. - Third-party risk assessment procedures. - Data and Information Protection. - Cybersecurity Incident Management. - Support the organization's policy by the Executive Management. This must be done through the approval of the organization head or his/ her deputy.	- Cybersecurity policy that covers the requirements of contracts and agreements with third-parties (e.g., electronic copy or official hard copy). - Formal approval by the head of the organization or his/her deputy on the policy (e.g., via the organization's official e-mail, paper or electronic signature).
4.1.2	4.1.2.1	The cybersecurity requirements for contracts and agreements with third-parties (e.g., Service Level Agreement (SLA)) -which may affect, if impacted, the organization's data or services- must include at least the following: 4-1-2-1 Non-disclosure clauses and secure removal of		- Define and document the requirements of this control in the cybersecurity requirements and approve them by the representative, provided that the cybersecurity requirements include non-disclosure requirements and secure removal by the third party of the organizations data upon service termination. - Include in the organization's contracts with third party's clauses stating the third party's commitment to maintain the confidentiality of the information. - Include in the organization's contracts with third parties clauses stating that	- Cybersecurity policy that covers the requirements of contracts and agreements with third-parties (e.g., electronic copy or official hard copy). - Signed sample of a contract or agreement with third parties indicating the inclusion of confidentiality clauses and secure removal of data hard copy or electronic copy.

		organization's data by third parties upon end of service.		the third party must be obligated to safely remove the organizations data upon the expiry of the contract/service period.	
	4.1.2.2	Communication procedures in case of cybersecurity incidents.		- Define and document the requirements of this control in the cybersecurity requirements document and approve them by the representative, provided that they include the requirements of the communication procedures in the event of a cybersecurity incident. - Include in the organization's contracts with third parties clauses stating the third party's obligation to define the communication procedures in the event of a cybersecurity incident. - Ensure that third parties develop communication procedures with the organization, including communication means and data in the event of a cybersecurity incident that may affect the organizations data or service provided by the third party. These requirements include: - Communication data (e.g., e-mail). - The mechanism for reporting the cybersecurity incident and its classification to the organization. - Escalation mechanisms.	- Cybersecurity policy that covers the requirements of contracts and agreements with third-parties (e.g., electronic copy or official hard copy). - Procedures adopted with third parties to communicate in the event of a cybersecurity incident through which the organizations data or service may be affected.
	4.1.2.3	Requirements for third-parties to comply with related organizational policies and procedures, laws and regulations.		- Define and document the requirements of this control in the cybersecurity requirements document and approve them by the representative, provided that they include the requirements of third parties obligation to apply the organizations cybersecurity requirements and policies and the relevant laws and regulations. - Include in the organization's contracts with third parties clauses stating that	- Cybersecurity policy that covers the requirements of contracts and agreements with third-parties (e.g., electronic copy or official hard copy). - Signed sample of a contract or agreement with third parties indicating the obligation of third parties to apply the organization's cybersecurity requirements and policies and

				the third party must be obligated to implement the organizations cybersecurity requirements and policies and the relevant laws and regulations.	the relevant laws and regulations.
4.1.3	4.1.3.1	The cybersecurity requirements for contracts and agreements with IT outsourcing and managed services third-parties must include at least the following: 4-1-3-1 Conducting a cybersecurity risk assessment to ensure the availability of risk mitigation controls before signing contracts and agreements or upon changes in related regulatory requirements.		- Define and document the requirements of this control in the cybersecurity requirements document and approve them by the representative, provided that they include the requirements of conducting a cybersecurity risk assessment, and ensuring that there is a guarantee to control those risks before signing contracts and agreements or in the event of changes in the relevant laws and regulations. - Conduct a third-party cybersecurity risk assessment by the organization in the following cases. - Before the organization signs any contracts or agreements with third parties. - In the event of changes in relevant laws and regulations.	- Cybersecurity policy that covers the requirements of contracts and agreements with third-parties (e.g., electronic copy or official hard copy). - Sample of the third-party cyber risk assessment report before signing the contract or in the event of changes in relevant laws and regulations.
	4.1.3.2	Cybersecurity managed services centers for monitoring and operations must be completely present inside the Kingdom of Saudi Arabia.		- Define and document the requirements of this control in the cybersecurity requirements document and approve them by the representative, provided that they include the requirements for the managed operation and monitoring cybersecurity operations centers, which use remote access method, to be located within the Kingdom. - Ensure that Cybersecurity operation centers managed for operation and monitoring are located within the Kingdom. - Ensure that remote access to Cybersecurity operation centers managed for operation and	- Cybersecurity policy that covers the requirements of contracts and agreements with third-parties (e.g., electronic copy or official hard copy). - A sample of the evidence of hosting or managing the cybersecurity operations center within the Kingdom (e.g., as an item of the signed contract or having a Service Level Agreement (SLA) signed between the third party and the organization).

				monitoring is performed within the Kingdom. • Include a clause in the contract or service level agreement signed with the third party that obliges the third party to have operations centers for operating and monitoring cybersecurity services, which use remote access within the Kingdom.	
4.1.4		The cybersecurity requirements for contracts and agreements with third-parties must be reviewed periodically.		• Review and update cybersecurity requirements for third party cybersecurity in the organization periodically according to a documented and approved plan for review and based on a planned interval or in the event of changes in relevant laws and regulations. • Document the review and changes to the cybersecurity requirements for third party cybersecurity in the organization and approve them by the head of the organization or his/ her deputy.	• An approved document that sets the policy review schedule • Policy indicating that it has been reviewed and updated, and that changes have been documented and approved by the head of the organization or his/ her deputy.

NCA CSCC

Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines:	Expected deliverables
4.1.1	4.1.1.1	In addition to the controls under subcomponent 4-1 of the Basic Cyber Security Controls, they must cover, at a minimum, the cyber security requirements related to third parties; the following : 4-1-1-1 Screening or Vetting for outsourcing companies, outsourcing personnel, and	• Third-Party Cybersecurity Policy Template	• Work with the relevant departments to ensure that a security scan (screening or vetting) is conducted for external parties operating on critical systems, by communicating with the concerned authorities (Presidency of State Security, Ministry of Interior, etc...) to verify the criminal record of companies and workers, including: ○ Outsourcing companies. ○ Outsourcing personnel	• An official document from the competent authorities explaining the security scanning procedure for workers on critical systems.

		managed services working on critical systems.		○ Managed services companies for critical systems. ○ Managed services personnel working on critical systems.	
	4.1.1.2	to be backup services, managed services on critical systems; Through companies and national destinations; In accordance with the relevant legislative and regulatory requirements.	• Third-Party Cybersecurity Policy Template	• Ensuring that outsourcing services and operations centers for cybersecurity services managed for the operation and monitoring of critical systems are managed by national companies through due diligence and by obtaining the companies recommendation from the National Cybersecurity Authority, and ensuring that local companies and entities comply with the relevant legislative and regulatory requirements.	• Service Level Agreements (SLA) contracts and agreements with third party outsourcing services and managed cybersecurity services operations centers for the operation and monitoring of critical systems. • An official document proving that the managed cybersecurity services operations centers for operation and monitoring of critical systems are entirely located within the Kingdom of Saudi Arabia (example: its existence as one of the terms of the signed contract, the existence of a service level agreement (SLA) signed between the external party and the entity, or the entity's visit to the service provider's workplace). • An acknowledgment from the provider of support services and the operations centers of cybersecurity services managed to operate and monitor critical systems to adhere to all internal policies and procedures for support services and managed services for the entity and to adhere to the relevant legislative and regulatory requirements.
NCA OSMACC					

Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines:	Expected deliverables
3.1.1		A need assessment for the use of social media management, automated monitoring or brand protection services along with associated cybersecurity risks must be conducted.	• Template for Cybersecurity Policy Related to Third-Parties	• In case there is a need to use social media account management services, automated monitoring of social media accounts, or protection against impersonation, a study and assessment of the necessity for such actions must be conducted, considering the associated cybersecurity risks. The results should be documented and approved by the authorized party.	• Documented report to assess the needs of the organization before resorting to external parties' services for managing social media accounts, automated monitoring, or brand protection services. • Documented report for the risk assessment that conducted before resorting to external parties services for managing social media, automated monitoring or brand protection services. • Documented report to assess the needs of the organization using social media management, automated monitoring or brand protection services.
3.1.2	3.1.2.1	In addition to the subcontrols within control 4-1-2 in ECC, cybersecurity requirements for use of social media management, automated monitoring or brand protection services in the organization must include at least the following: 3-1-2-1 Non-disclosure clauses and secure removal of organization's data by the third-party upon service termination	• Template for Cybersecurity Policy Related to Third-Parties	• Review the service level agreement between the organization and third-parties who are responsible of managing social media accounts, automated monitoring or brand protection services firm. • Verify that the non-disclosure clauses and secure removal of organization's data are documented in the agreement. Further, verify that the services firm must also provide evidence of secure removal of data to the organization.	• Documented service level agreement with third-parties who are responsible of managing social media accounts, automated monitoring or brand protection services firm that includes clauses of non-disclosure and secure data removal upon service termination.

	3.1.2.2	Communication procedures to report vulnerabilities and cyber incidents.	• Template for Cybersecurity Policy Related to Third-Parties	• Review the service level agreement between the organization and third-parties who are responsible of managing social media accounts, automated monitoring or brand protection services firm. • Verify and document the procedures to be followed by the services firm with respect to the incident management of cyber incidents and reporting of vulnerabilities to the organization in a timely manner, in the contract or the service level agreements.	• Documented procedures for cyber incidents and reporting of vulnerability to the organization, in the contract or service level agreement.
	3.1.2.3	Requirements for the third-party to comply with cybersecurity requirements and policies to protect organizations' social media accounts, and related laws and regulation.	• Template for Cybersecurity Policy Related to Third-Parties	• Review the service level agreement between the organization and third-parties who are responsible of managing social media accounts, automated monitoring or brand protection services firm. • Verify and document the requirements for the services firm to comply with the cybersecurity requirements and policies to protect organizations' social media accounts in line with the organizational policies and procedures of the authority and the relevant national legal and regulatory requirements, in the service level agreement.	• Documented procedures for compliance with the cybersecurity requirements and policies of the organization, and the relevant national legal and regulatory requirements in the service level agreement.
NCA TCC					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
N/A					
NCA DCC					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables

3.1.1	3.1.1.1	In addition to the controls in ECC subdomain 4-1, cybersecurity requirements for third parties cybersecurity must include at least the following: 3-1-1-1 Screening or vetting third-party employees who have access to the data.	• Template for Cybersecurity Policy Related to Third-Parties	• Identify the requirements of this control and document them in a cybersecurity requirements document, followed by approval from the authorizing officials. • Review their skillset using various methodologies including RFPs, candidate CV, accreditation among others. Also, develop a background verification process for the selected outsourced employees either by an internal or third party vendor team. • Develop, document and approve an action plan for granting new access to the candidates according to the roles and permissions required. • Develop a periodic review process to delete unused and unjustified roles and permissions.	• Document detailing the identification and documentation of the requirements of this control (eg. a policy and/or procedure approved by the authorizing officials). • A recruitment and onboarding process which includes screening and vetting as per the skillset of the third-party employees. • Selection of background verification vendor or internal team. • Periodically verified and approved list of users with their permissions. • Review of HR Cybersecurity policy in line with data cybersecurity policies.
	3.1.1.2	Requiring contractual commitment by third-parties to securely dispose the organization's data at the end of the contract or in case of contract termination, including providing evidences of such disposal to the organization.	• Template for Cybersecurity Policy Related to Third-Parties	• Identify the requirements of this control and document them in a cybersecurity requirements document, followed by approval from the authorizing officials. • Review the service level agreement between the organization and the third parties with respect to the confidential, secret and top secret data handling of the organization. • Verify that the end of service clause in the agreement defines and documents proper data disposal of organization's data as per the data disposal policy. Further, verify that the third parties should also provide evidence of data disposal to the organization.	• Document detailing the identification and documentation of the requirements of this control (e.g. a policy and/or procedure approved by the authorizing officials). • Documented procedures for third parties in data disposal policy of the organization for confidential, secret and top secret data. • Review of service level agreement for proper data disposal in the end of service.
	3.1.1.3	Documenting all data sharing operations within third-parties, including data	• Template for Cybersecurity	• Identify the requirements of this control and document them in a cybersecurity requirements	• Document detailing the identification and documentation of the

		sharing justification.	Policy Related to Third-Parties	document, followed by approval from the authorizing officials. - Review the service level agreement between the organization and the third parties with respect to the confidential, secret and top secret data sharing operations of the organization within the third-parties. - Define and implement the clause related to data sharing in the agreement., which should include, but not limited to, description of data shared, restrictions of data usage, required data protection safeguards and justification related to sharing of data. - Verify and document the organization's data flow to the third parties only after appropriate data sharing justification is provided.	requirements of this control (e.g. a policy and/or procedure approved by the authorizing officials). - Documented procedure for data sharing operations with the third-parties. - Review of service level agreement for proper process for data sharing operations with the third-parties.
	3.1.1.4	When transferring data outside the kingdom, the capability of the hosting organization abroad to safeguard data must be verified, approval of the Authorizing Official must be obtained and complying with related laws and regulations.	Template for Cybersecurity Policy Related to Third-Parties	- Identify the requirements of this control and document them in a cybersecurity requirements document, followed by approval from the authorizing officials. - Review the service level agreement between the organization and the third parties with respect to the cross border data transfer of the organization's confidential, secret and top secret data outside the kingdom. - Verify and define the data protection standards and laws followed by hosting organization outside the kingdom, to safeguard the organization's data. Further, obtain the written approval from the Authorizing Official to transfer the data outside the kingdom, in accordance with the related laws and regulations.	- Document detailing the identification and documentation of the requirements of this control (e.g. a policy and/or procedure approved by the authorizing officials). - Documented procedure for cross border data transfer of the organization outside the kingdom. - Review of service level agreement for proper process for cross border data transfer with the third-parties.

				• Verify the other required regulatory requirement such as data subject consent requirements, impact assessment for cross border data transfer outside the kingdom.	
	3.1.1.5	Requiring third-parties to notify the organization immediately in case of cybersecurity incident that may affect data that has been shared or created	• Template for Cybersecurity Policy Related to Third-Parties	• Identify the requirements of this control and document them in a cybersecurity requirements document, followed by approval from the authorizing officials. • Review the service level agreement between the organization and the third parties with respect to the incident that may affect confidential, secret and top secret data. • Verify and define the process to notify the organization in case of a cybersecurity incident which might have led to an exposure to the organization's data. Further, also define specific SLA timelines that third-parties have to follow for prompt notification to the organization.	• Document detailing the identification and documentation of the requirements of this control (e.g. a policy and/or procedure approved by the authorizing officials). • Documented procedure for cybersecurity incident notification related to the data of the organization. • Review of service level agreement for proper process for cybersecurity incident notification with the third-parties.
	3.1.1.6	Reclassifying data to the least level to achieve the objective before sharing it with third-parties using data masking or data scrambling techniques.	• Template for Cybersecurity Policy Related to Third-Parties	• Identify the requirements of this control and document them in a cybersecurity requirements document, followed by approval from the authorizing officials. • Verify and define the process to reclassify the data to the least level to make sure that only required data is sent across to the third -party and any unintended data for them must not be sent. This can be achieved by various data hiding techniques, such as, but not limited to, data masking, data anonymization, data scrambling, data filtering.	• Document detailing the identification and documentation of the requirements of this control (e.g. a policy and/or procedure approved by the authorizing officials). • Documented procedure for data hiding on outgoing data sent by the organization.
3.1.2	3.1.2.1	In alignment with related laws and regulations, and in addition to the applicable	• Template for Cybersecurity	• Identify the requirements of this control and document them in a cybersecurity requirements	• Document detailing the identification and documentation of the

		controls in ECC and controls within DCC domain (1), (2), and (3); cybersecurity requirements when dealing with consultancy services that works on high-sensitivity strategic projects at the national level must cover at least the following: 3-1-2-1 Screening or vetting consultancy services employees who have access to the data.	Policy Related to Third-Parties	document, followed by approval from the authorizing officials. • Enforce consultancy services companies that are working on strategic projects to provide screening or vetting data for employees working on these projects, and consultancy services companies should cooperate with the organization in this matter. • Review and assess the candidates' skills and competencies using various methodologies including interviews, and oral and written test. Furthermore, consider the candidate's screening or vetting results that are selected either by an internal or third party vendor team. • Review their skillset using various methodologies including RFPs, candidate CV, accreditation among others. Also, develop a background verification process for the selected outsourced employees either by an internal or third party vendor team. • Develop, document and approve an action plan for granting new access to the candidates according to the roles and permissions required. • Develop a periodic review process to delete unused and unjustified roles and permissions.	requirements of this control (e.g. a policy and/or procedure approved by the authorizing officials). • Document outlining the provision of employee data by consulting services company required to conduct security screenings for personnel working on strategic projects within the organization. • Document outlining the completion of the security screening process for employees of consulting services companies by the organization. • A recruitment and onboarding process which includes screening and vetting as per the skillset of the consultancy services employees. • Selection of background verification vendor or internal team. • Verified and approved list of users with their permissions. • Review of HR Cybersecurity policy in line with data cybersecurity policies.
	3.1.2.2	Requiring contractual commitment by consultancy services including employees non-disclosure agreements and secure disposal the organization's data at the end of the contract or in case of contract termination, including providing evidences	• Template for Cybersecurity Policy Related to Third-Parties	• Identify the requirements of this control and document them in a cybersecurity requirements document, followed by approval from the authorizing officials. • The organization should work on obtaining assurances from consulting services companies and their employees working on strategic projects regarding non-disclosure of	• Document detailing the identification and documentation of the requirements of this control (e.g. a policy and/or procedure approved by the authorizing officials). • Document outlining the inclusion of clauses regarding confidentiality, non-disclosure

		of such disposal to the organization.		information and their ability to securely delete the organization's data upon the termination of the contractual relationship. Additionally, they should refrain from disclosing any information before obtaining written consent from the organization. Consulting services companies are required to cooperate with the organization in implementing this procedure. • Review the service level agreement between the organization and the consultancy services organization with respect to the confidential, secret and top secret data handling of the organization. • Verify that the end of service clause in the agreement defines and documents proper data disposal of organization's data as per the data disposal policy. Further, verify that the consultancy services organization should also provide evidence of data disposal to the organization.	of data, and secure data deletion to ensure consulting services companies and their employees do not disclose the organization's information (Hard or soft copy). • Documented procedures for consultancy services organization in data disposal policy of the organization for confidential, secret and top secret data. • Review of service level agreement for proper data disposal in the end of service.
	3.1.2.3	Documenting all data sharing operations within consultancy services, including data sharing justification.	• Template for Cybersecurity Policy Related to Third-Parties	• Identify the requirements of this control and document them in a cybersecurity requirements document, followed by approval from the authorizing officials. • The organization should document the process of sharing data with consulting services companies involved in strategic projects based on the principle of Need-to-Know. • Consulting services companies involved in strategic projects should ensure the documentation of data sharing with authorized employees based on the principle of Need-to-Know.	• Document detailing the identification and documentation of the requirements of this control (eg. a policy and/or procedure approved by the authorizing officials). • Documented procedure for data sharing operations with the consultancy services. • Review of service level agreement for proper process for data sharing operations with the consultancy services.

				• Review the service level agreement between the organization and the consultancy services with respect to the confidential, secret and top secret data sharing operations of the organization within the third-parties. • Define and implement the clause related to data sharing in the agreement., which should include, but not limited to, description of data shared, restrictions of data usage, required data protection safeguards and justification related to sharing of data. • Verify and document the organization's data flow to the consultancy services only after appropriate data sharing justification is provided	
	3.1.2.4	Requiring consultancy services to notify the organization immediately in case of cybersecurity incident that may affect data that has been shared or created.	• Template for Cybersecurity Policy Related to Third-Parties	• Identify the requirements of this control and document them in a cybersecurity requirements document, followed by approval from the authorizing officials. • The organization must mandate consulting services companies working on strategic projects to inform them in the event of a cybersecurity incident affecting the shared data, and to cooperate with the organization in implementing this procedure. • Review the service level agreement between the organization and the consultancy services with respect to the incident that may affect confidential, secret and top secret cross border data. • Verify and define the process to notify the organization in case of a cybersecurity incident which might have led to an exposure to the	• Document detailing the identification and documentation of the requirements of this control (e.g. a policy and/or procedure approved by the authorizing officials). • Documented procedure for cybersecurity incident notification related to the data of the organization. • Review of service level agreement for proper process for cybersecurity incident notification with the consultancy services.

				organization's data. Further, also define specific SLA timelines that consultancy services have to follow for prompt notification to the organization.	
	3.1.2.5	Reclassifying data to the least level to achieve the objective before sharing it with consultancy services using data masking or data scrambling techniques.	• Template for Cybersecurity Policy Related to Third-Parties	• Identify the requirements of this control and document them in a cybersecurity requirements document, followed by approval from the authorizing officials. • The organization must mandate consulting services companies working on strategic projects to use data within the scope defined by the organization, and to cooperate with the organization in implementing this procedure. • Verify and define the process to reclassify the data to the least level to make sure that only required data is sent across to the consultancy services and any unintended data for them must not be sent. This can be achieved by various data hiding techniques, such as, but not limited to, data masking, data anonymization, data scrambling, data filtering.	• Document detailing the identification and documentation of the requirements of this control (eg. a policy and/or procedure approved by the authorizing officials). • Documented procedure for reclassifying data to the lowest level that achieves the objective before sharing it (e.g. data masking, data anonymization, data scrambling, data filtering).
	3.1.2.6	Dedicating a closed room for the consultancy services employees to perform their work, in addition to providing dedicated organization owned devices to share and process data.	• Template for Cybersecurity Policy Related to Third-Parties	• Identify the requirements of this control and document them in a cybersecurity requirements document, followed by approval from the authorizing officials. • The organization must mandate consulting services companies working on strategic projects involving secret and top secret data not to use open and non-designated rooms for consultancy services employees, and not to use devices not owned by the organization. It is also the responsibility of the	• Document detailing the identification and documentation of the requirements of this control (e.g. a policy and/or procedure approved by the authorizing officials). • Documented procedure for handling closed room workspace and data handling devices for consultancy services employees. • Evidence illustrating that the consulting services companies

				consulting services companies to cooperate with the organization in implementing this procedure. • Review the service level agreement between the organization and the consultancy services with respect to the dedicated closed room and devices that utilize secret and top secret organization data. • Verify and define a dedicated closed room where the consultancy services employees can dedicatedly provide service to the organization. Further, provide organization's devices for them to share and process data.	are compliant with not using non-designated rooms for consultancy services employees. • Review of service level agreement for using dedicated workspace and devices for the consultancy services employees.
	3.1.2.7	Activating access control system to allow only authorized access to the closed room.	• Template for Cybersecurity Policy Related to Third-Parties	• Identify the requirements of this control and document them in a cybersecurity requirements document, followed by approval from the authorizing officials. • The organization must mandate consulting services companies working on strategic projects involving secret and top secret data to use access control systems for entry and exit from designated rooms for authorized consultancy services employees, according to their permissions. Consulting services companies should cooperate with the organization in implementing this procedure. • Review the service level agreement between the organization and the consultancy services with respect to the access control to the closed room for handling secret and top secret organization data. • Verify and define a dedicated closed room as an access controlled space where only	• Document detailing the identification and documentation of the requirements of this control (e.g. a policy and/or procedure approved by the authorizing officials). • Documented procedure for activating access control system to the closed room workspace for consultancy services employees. • Review of service level agreement for using dedicated access controlled workspace for the consultancy services employees.

				- authorized consultancy services employees can have access to the organization's data and - data storage devices.	
	3.1.2.8	Preventing carrying out of devices, storage media and documents outside the closed room, as well as the entry of any other electronic devices.	Template for Cybersecurity Policy Related to Third-Parties	- Identify the requirements of this control and document them in a cybersecurity requirements document, followed by approval from the authorizing officials. - The organization must mandate consulting services companies working on strategic projects involving secret and top secret data to prohibit the entry of devices not owned by the organization and to prevent taking out storage media and devices from the closed rooms designated for consultancy services employees. - Review the service level agreement between the organization and the consultancy services with respect to the storage media and device used to handle secret and top secret organization data. - Verify and define the procedures which prevent carrying the storage devices and media dealing with organization's data outside the closed room. Further, verify that no other storage media must be allowed to enter the closed room. This should be implemented using security checks at the entry and exit from the closed room.	- Document detailing the identification and documentation of the requirements of this control (e.g. a policy and/or procedure approved by the authorizing officials). - Documented procedure for restrictions on storage devices during the entry and exit of closed room workspace for consultancy services employees. - Review of service level agreement for proper usage of organization's storage media by consultancy services employees.
NCA OTCC					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
4.1.1	4.1.1.1	In addition to the ECC subcontrols within controls 4-	Template for Cybersecurity	Define, document, and approve OT/ICS products and services	A documented OT/ICS products and services cybersecurity

		1-2 and 4-1-3, cybersecurity requirements for third-party cybersecurity in OT/ICS must include, at a minimum, the following: 4-1-1-1 Cybersecurity requirements are included during procurement lifecycle for OT/ICS products and services.	Operational Technology Policy • Template for OT/ICS Security Standard • Template for Third-Party Cybersecurity Policy	cybersecurity requirements to be included within the procurement lifecycle (Defining the Requirements, Vendor Selection, Negotiation and Contracting, Service Delivery and Performance Monitoring, and Renewal/Contract Closure). • Ensure that the cybersecurity requirements are included in the procurement lifecycle for OT/ICS products and services.	requirements during the procurement lifecycle. • A proof that all new procurements of OT/ICS products and services are conducted in line with defined requirements.
	4.1.1.2	Cybersecurity requirements for third-party evaluation, selection, and information sharing must be defined.	• Template for Cybersecurity Operational Technology Policy • Template for OT/ICS Security Standard • Template for Third-Party Cybersecurity Policy	• Define, document, and approve cybersecurity requirements for third-party evaluation, selection, and information sharing. • Ensure that all defined cybersecurity requirements are included within the qualification requirements.	• Documented cybersecurity requirements for third-party evaluation, selection, and information sharing. • A qualification requirements document that include all defined cybersecurity requirements. • A proof that the evaluation, selection, and information sharing of all third-parties are conducted based on the defined requirements.
	4.1.1.3	Third-party contractors and vendors must use formal and documented Secure Development Life Cycle (SDLC) practices for systems and components designed or deployed in OT/ICS environment.	• Template for Cybersecurity Operational Technology Policy • Template for OT/ICS Security Standard • Template for Third-Party Cybersecurity Policy	• Obtain a certification from third-party contractors and vendors that use formal and documented practices for the Secure Development Life Cycle (SDLC) of systems and assets designed or deployed in the OT/ICS environment.	• A certification from approved third-party contractors and vendors that they are using Secure Development Life Cycle (SDLC) practices for systems and assets designed or deployed in OT/ICS environment.
	4.1.1.4	Periodic cybersecurity assessment and audits of third-party providers must be conducted to ensure the	• Template for Cybersecurity Operational Technology Policy	• Conduct periodic cybersecurity assessment and audits of third-party providers to ensure control over any identified cyber risks.	• Cybersecurity assessments and audits of OT/ICS third-party providers' reports.

		mitigation of any identified cyber threats.	• Template for OT/ICS Security Standard • Template for Third-Party Cybersecurity Policy		
4.1.2		With reference to the ECC control 4-1-4, the cybersecurity requirements for third-party cybersecurity in OT/ICS environment must be reviewed, and their implementation effectiveness is measured and evaluated periodically.	• Template for Cybersecurity Operational Technology Policy • Template for OT/ICS Security Standard • Template for Third-Party Cybersecurity Policy • Template for Key Performance Indicator Report	• Review the cybersecurity requirements for third-party cybersecurity for the OT/ICS environment periodically based on a documented and approved review plan and on a defined frequency (e.g., conduct a review annually). • Develop key performance indicators (KPIs) for each control within the related policy or procedure to ensure the implementation effectiveness is measured and evaluated periodically based on a defined frequency (e.g. conduct a review annually).	• A proof that shows the periodic review of cybersecurity requirements for third-party cybersecurity for the OT/ICS environment. • A proof that shows the key performance indicators (KPIs) for each control within the related policy or procedure to ensure the implementation effectiveness is measured and evaluated periodically (based on a defined frequency).
NCA CCC CST					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
N/A					
NCA CCC CSP					
4.1.P.1	4.1.P.1	In addition to implementing the ECC controls 4-1-2 and 4-1-3, the CSP shall cover the following additional sub controls for third-party cybersecurity requirements, as a minimum:	• Template for Cybersecurity Policy Regarding Third-Party	• Maintain a catalogue of third-party providers and their software available to CSTs. • Establish a robust process to remove specific software from the marketplace based on NCA's requests. • Introduce appropriate legal statements allowing CSP to remove from the marketplace any software considered as cybersecurity threat.	• Review the catalogue of third-party software providers and their software. • A document outlining procedures for removing specific programs from the market based on legislative requests.

		Ensure that the CSP fulfills NCA's requests to remove software or services, provided by third-party providers that may be considered a cybersecurity threat to national organizations, from the marketplace provided to CSTs.			
	4.1.P.2	Requirement to provide security documentation for any equipment or services from suppliers and third-party providers.	• Template for Cybersecurity Policy Regarding Third-Party	• Introduce contractual obligations on suppliers and third-party providers to provide security documentation of their equipment, product or service. • Define security aspects to be documented (e.g. security architecture, security controls in place, security technologies in use) • Intake and review Periodically provided documentation.	• Security documentation for equipment or services from suppliers and third-party providers. • Periodical review reports and documents.
	4.1.P.3	Third party providers compliant with law and regulatory requirements relevant to their scope.	• Template for Cybersecurity Policy Regarding Third-Party	• Identify and document Periodically (e.g. annually) laws and regulatory requirements relevant to third party providers. • Audit third party providers or request independent audits to verify their compliance.	• Relevant laws and regulatory requirements identified for each of third-party providers. • Proof of compliance with laws and regulatory requirements provided for each third-party provider.
	4.1.P.4	Risk management and security governance on third-party providers as part of general cybersecurity risk management and governance.	• Template for Cybersecurity Policy Regarding Third-Party	• Include third-party providers related risks (e.g. supply chain risk) into the cybersecurity risk management and governance processes.	• Third party risks embedded into Risk Management processes. • Sample of risk register that includes third party identified risks.
SAMA CSF					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
3.4.1.1		The cyber security requirements should be defined, approved,			

		implemented and communicated within the contract and vendor management processes.			
3.4.1.2		The compliance with contract and vendor management process should be monitored.			
3.4.1.3		The effectiveness of the cyber security controls within the contract and vendor management process should be measured and periodically evaluated.			
3.4.1.4		These contract and vendor management processes should cover:a. whether the involvement of the cyber security function is actively required (e.g., in case of due diligence);b. the baseline cyber security requirements which should be applied in all cases;c. the right to periodically perform cyber security reviews and audits.			
3.4.1.5		The contract management process should cover requirements for:a. executing a cyber security risk assessment as part of the procurement process; b. defining the specific cyber security requirements as part of the tender process;			

		c. evaluating the replies of potential vendors on the defined cyber security requirements; d. testing of the agreed cyber security requirements (risk-based); e. defining the communication or escalation process in case of cyber security incidents; f. ensuring cyber security requirements are defined for exiting, terminating or renewing the contract (including escrow agreements if applicable); g. defining a mutual confidentiality agreement.			
3.4.1.6		The vendor management process (i.e., service level management) should cover requirements for: a. periodic reporting, reviewing and evaluating the contractually agreed cyber security requirements (in SLAs).			
3.4.2.1		The cyber security requirements within the outsourcing policy and process should be defined, approved, implemented and communicated within Member Organization.			
3.4.2.2		The cyber security requirements regarding the outsourcing policy and process			

		should be measured and periodically evaluated.			
3.4.2.3		The outsourcing process should include: a. the approval from SAMA prior to material outsourcing;b. the involvement of the cyber security function;c. compliance with the SAMA circular on outsourcing.			
CST CRF					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
6.2.1		Define and document [Requirements for Outsourcing Services] which consider the following: • Risk assessment for outsourcing information assets to a third party • Addressing cybersecurity requirements expected from the third-party provider • Service level agreements			
6.2.2		Conduct a risk assessment in accordance with the [Cybersecurity Risk Assessment] and [Information Protection] prior to outsourcing any information assets to a third party provider (or in the event of changes in relevant legislative and regulatory requirements) to ensure that risks related to the			

		use of outsourcing are appropriately addressed.			
6.2.3		Based on the risk assessment identify the [Third-party Cybersecurity Requirements] which the third-party provider must comply with to protect the confidentiality, integrity and availability of the outsourced information assets (e.g. non-disclosure clauses).			
6.2.4		Establish service level agreements with the third party service provider which consider at least the following: • [Third-party Cybersecurity Requirements] • Communication procedure in case of a cybersecurity incident • Ensuring that the outsourced service can be terminated in case of non-compliance with the contractual agreements • Defining the exit procedures covering the secure deletion of data (e.g. media destruction, encryption).			
6.2.5		Audit, review, and monitor the third-party provider for compliance with contractual obligations.			
6.2.6		Ensure that third party personnel are screened when they are contracted to work on critical systems.			

6.2.7		Continuously measure, review and optimize the [Requirements for Outsourcing Services].			
CMA Cybersecurity Guidelines					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
4.4.1.1		Set out, document, approve, apply and circulate Cybersecurity controls related to management of contracts and suppliers.			
4.4.1.2		Monitor compliance with Contracts and Suppliers Management process			
4.4.1.3		Measure and periodically evaluate effectiveness of Cybersecurity controls related to management of contracts and suppliers.			
4.4.1.4		Contracts and Suppliers Management process shall include: •inclusion of the minimum cybersecurity controls that shall be applied in all cases. •Authority to conduct periodic cybersecurity audit and review			
4.4.1.5		Contracts Management process shall include: •Evaluate Cybersecurity risks as a part of signing contracts with third party (e.g. Outsourcing and Managed Services).			

		•Define Cybersecurity controls as a part of bidding. •Evaluate responses of potential suppliers according to cybersecurity controls adopted. •Test the agreed cybersecurity controls (Risks-Based Testing). •Identify communication and escalation procedures in case of cybersecurity incident. •Lay down Non-Disclosure Clauses. •Safe disposal by the third party of market institution's data upon the end of contractual relationship.			
4.4.1.6		Suppliers Management Process includes preparing, reviewing and evaluating periodic reports for cybersecurity controls agreed upon in the relevant agreements (SLA)			
4.4.2.1		Set out, document, approve and apply cybersecurity controls set forth in outsourcing policy and process and circulate the same across the market institution.			
4.4.2.2		Measure and periodically evaluate cybersecurity controls related to outsourcing policy and process.			
4.4.2.3		Outsourcing includes engagement of Cybersecurity			

		Department and evaluating Cybersecurity risks.			
4.4.2.4		Compliance with related national laws and regulations.			
4.4.2.5		Outsourcing is limited to providing security operations monitoring services for service providers within KSA.			

Risk Considerations in Third-Party Cybersecurity

1. Risk Title

- **Risk Title:** Inadequate Third-Party Security Posture
Risk Description: Third-party vendors or outsourcing partners may have vulnerabilities that can be exploited, leading to a breach in your cybersecurity perimeter.
Risk Mitigation: Conduct rigorous third-party security assessments, enforce strong contractual cybersecurity clauses, and ensure third-party vendors adhere to industry security standards.
- **Risk Title:** Data Breach Due to External Parties
Risk Description: Sensitive data entrusted to third-party vendors or contractors could be exposed or mishandled, leading to privacy violations or theft.
Risk Mitigation: Enforce strong data encryption, monitoring systems, and audit trails for data handling with third parties. Ensure vendors comply with the required privacy regulations.
- **Risk Title:** Limited Visibility and Control Over Third-Party Systems
Risk Description: Organizations may not have full visibility into third-party systems, leaving potential attack vectors unmonitored.
Risk Mitigation: Implement strong service level agreements (SLAs) and require continuous monitoring of outsourced systems, using technologies such as security information and event management (SIEM) to maintain visibility.
- **Risk Title:** Disruptions to Business Continuity Due to Vendor Failure
Risk Description: A failure or disruption on the third-party vendor's end, including cybersecurity incidents, may cause a cascading effect on your business operations.
Risk Mitigation: Identify and regularly evaluate critical vendors, have contingency plans in place, and ensure there are alternate providers or in-house capabilities to mitigate the impact of a vendor failure.
- **Risk Title:** Unclear or Inconsistent Cybersecurity Policies
Risk Description: Third-party cybersecurity policies may not align with the organization's own policies, leading to inconsistent security standards.
Risk Mitigation: Standardize cybersecurity policies across the supply chain and ensure all third-party vendors adhere to these policies through clear agreements and periodic compliance audits.

Examples of Technologies for Effective Third-Party Cybersecurity

- **Vendor Risk Management Tools**
Tools: ThirdPartyTrust OSS, OSCAL (NIST Open Security Controls Assessment Language)
Purpose: Assess, monitor, and manage cybersecurity risks associated with third-party vendors using standardized frameworks and open documentation formats
- **Security Posture Assessment and Monitoring Tools**
Tools: OpenVAS, Security Shepherd, SpiderFoot
Purpose: Continuously assess external-facing assets for security posture gaps and support due diligence processes for third-party risk
- **Compliance Management Tools**
Tools: OpenSCAP, Eramba (Community Edition), SimpleRisk
Purpose: Track compliance of third-party vendors with cybersecurity frameworks and automate documentation and monitoring

- **Identity and Access Management (IAM) Solutions**

Tools: Keycloak, Authentik, Authelia

Purpose: Manage and govern secure third-party access to systems and applications using authentication, RBAC, and federated identity management

- **Third-Party Cloud Security Tools**

Tools: Cloudsploit (by Aqua Security), ScoutSuite, Prowler

Purpose: Audit and secure third-party cloud environments (AWS, Azure, GCP) against misconfigurations and policy violations

Examples of KPIs for Third-Party Cybersecurity

1. **KPI Title:** Third-Party Risk Assessment Completion Rate
Description: Measures the percentage of third-party vendors assessed for cybersecurity risks within a specified timeframe.
Goal: Complete cybersecurity risk assessments for all high-risk and critical vendors annually.
2. **KPI Title:** Percentage of Third-Party Security Issues Resolved
Description: The ratio of third-party cybersecurity vulnerabilities or issues identified and successfully mitigated.
Goal: Resolve 90% or more of identified cybersecurity issues with third-party vendors within agreed timelines.
3. **KPI Title:** Vendor Compliance with Cybersecurity Standards
Description: Measures the percentage of third-party vendors that meet the organization's minimum cybersecurity requirements or contractual obligations.
Goal: Achieve 100% vendor compliance with the organization's security standards and cybersecurity requirements.
4. **KPI Title:** Number of Third-Party Breaches
Description: The total number of cybersecurity incidents or breaches originating from third-party vendors that impact the organization.
Goal: Keep third-party cybersecurity incidents to zero by ensuring due diligence and continuous monitoring.
5. **KPI Title:** Third-Party Security Training Completion Rate
Description: Tracks the percentage of critical third-party employees who have completed cybersecurity training provided by the organization.
Goal: Ensure that 100% of critical third-party stakeholders are trained annually on cybersecurity best practices.

Case Study: Developing and Implementing Third-Party and Outsourcing Cybersecurity for a Saudi Organization

This case study outlines a comprehensive framework for managing third-party and outsourcing cybersecurity in a Saudi organization. By embedding robust cybersecurity policies and contractual agreements, the organization ensures the integrity, confidentiality, and availability of its data while complying with regulatory requirements.

Phase 1: Developing Cybersecurity Policy for Third-Party Management

1. Cybersecurity Policy Components

- Contracts and Agreements: Incorporate cybersecurity requirements within third-party contracts, ensuring compliance with organizational standards.
- Risk Assessment: Establish third-party risk assessment procedures.
- Data Protection: Define strict measures for data and information protection.
- Incident Management: Develop protocols for managing cybersecurity incidents involving third parties.

2. Executive Endorsement

- Secure approval from the organization's head or deputy to support the third-party cybersecurity policy.

Phase 2: Documentation and Contractual Requirements

1. Non-Disclosure and Data Removal

- Document requirements ensuring third-party obligations include non-disclosure and secure data removal upon contract termination.
- Include contractual clauses stating third-party commitments to confidentiality and data removal.

2. Communication in Case of Cybersecurity Incidents

- Include in contracts the obligation of third parties to define communication procedures in the event of a cybersecurity incident. Requirements must address:
 - Communication data (e.g., email addresses).
 - Mechanisms for reporting and classifying incidents.
 - Escalation procedures.

3. Compliance with Organizational Policies

- Ensure third parties agree to adhere to the organization's cybersecurity requirements, policies, and relevant laws.

4. Risk Assessment Documentation

- Define and approve the need for third-party cybersecurity risk assessments before signing contracts or when laws and regulations change.

Phase 3: Risk Assessments

1. Third-Party Cybersecurity Risk Assessment

- Conduct assessments in the following cases:
 - Prior to signing contracts or agreements with third parties.
 - After changes in relevant laws and regulations.

2. Risk Control Guarantee

- Ensure that risk control measures are in place before entering into agreements.

Phase 4: Cybersecurity Operation Centers

1. Locating Operation Centers

- Ensure operation and monitoring cybersecurity centers using remote access are located within the Kingdom.
- Include contractual clauses obligating third parties to:
 - Manage operations and monitoring within the Kingdom.
 - Restrict remote access operations to within the Kingdom.

2. Contractual Obligations

- Include clauses in service level agreements mandating local operations for remote access and cybersecurity monitoring.

Phase 5: Policy Review and Updates

1. Periodic Reviews

- Develop a documented and approved plan to periodically review cybersecurity requirements for third parties.
- Ensure reviews are conducted based on planned intervals or regulatory changes.

2. Documentation of Updates

- Document and secure approval for updates to third-party cybersecurity requirements from the organization's head or deputy.

4.2 Cloud Computing and Hosting Cybersecurity:

Definition: Cloud Computing and Hosting Cybersecurity refers to the practices, technologies, and frameworks used to protect data, applications, and infrastructure hosted in cloud environments from unauthorized access, data breaches, and other cyber threats. It ensures the confidentiality, integrity, and availability of cloud-based resources and services [4], [5], [6].

Objective: To ensure the proper and efficient remediation of cyber risks and the implementation of cybersecurity requirements related to hosting and cloud computing as per organizational policies and procedures, and related laws and regulations. It is also to ensure the protection of the organization's information and technology assets hosted on the cloud or processed/managed by third-parties.

Controls Matrix:

Below is a summary matrix detailing relevant Cloud Computing and Hosting Cybersecurity controls based on NCA, SAMA CSF, CST CRF, and CMA Cybersecurity guidelines:

Regulation	Main Controls	Control References
NCA ECC	4	4.1.1, 4.1.2, 4.1.3, 4.1.4
SAMA CSF	2	3.4.1, 3.4.2 (9 Sub-controls)
CST CRF	1	6.2 (7 Sub-controls: 6.2.1-6.2.7)
CMA CSG	2	4.4.1, 4.4.2 (11 Sub-controls: 4.4.1.1-4.4.1.6, 4.4.2.1-4.4.2.5)
NCA CCCC	1	4.1.1 (2 Sub-controls)
NCA CCC CST	-	-
NCA CCC CSP	1	4.1.P (4 Sub-controls: 4.1.P.1-4.1.P.4)
NCA TCC	-	-
NCA DCC	2	3.1.1, 3.1.2 (14 Sub-controls)
NCA OSMACC	2	3.1.1, 3.1.2 (3 Sub-controls under 3.1.2)
NCA OTCC	2	4.1.1, 4.1.2 (4 Sub-controls under 4.1.1)

Cloud Computing and Hosting Cybersecurity Controls:

Control reference number	Sub-Contr ol	Control clauses	Relevant cybersecurity tools	Control implementation guidelines:	Expected deliverables
ECC					
4.2.1		Cybersecurity requirements related to the use of hosting and cloud computing services must be defined, documented and approved.	Cloud Computing and Hosting Cybersecurity Policy Template	- Develop and document cybersecurity policy for cloud computing and hosting services in the organization, including the following: - Cloud computing and hosting services providers contract requirements. - Requirements for the location of hosting and storing the organizations systems and data. - Requirements for data removal and retrieval. - Classification of data prior to hosting/ storing on cloud computing or hosting services. - inclusion of Service Level Agreement SLA. - Inclusion of Non-disclosure Clauses. - Support the organization's policy by the Executive Management. This must be done through the approval of the organization head or his her deputy.	- Cybersecurity policy that covers the requirements of the use of cloud computing and hosting services (e.g., electronic copy or official hard copy). - Formal approval by the head of the organization or his/her deputy on the policy (e.g., via the organization's official e-mail, paper or electronic signature).
4.2.2		The cybersecurity requirements related to the use of hosting and cloud computing services must be implemented.		Implement cybersecurity requirements for cloud computing and hosting services for the organization, including, but not limited to.	- An action plan to implement the cybersecurity requirements for cloud computing and hosting services. - A signed sample of the agreement or contract

				○ Ensure that the location of hosting and storing the organizations information is within the Kingdom. ○ Ensure the activation of event logs on hosted information assets. ○ Ensure that cloud computing and hosting service providers must return data (in a usable format) and remove it in a non-recoverable manner upon termination/ expiry of the service. ○ Ensure that the organization's environment including virtual servers, networks and databases) is separated from other entities environments in cloud computing services. ○ Ensure that data and information transmitted to, stored in, or transmitted from cloud services are encrypted in accordance with the relevant laws and regulations of the organization. ○ Ensure that the cloud computing and hosting service provider must periodically backup and protect backups in accordance with the organizations backup policy. • The organization may also develop an action plan to implement cybersecurity requirements related to cloud computing and hosting service, in order to ensure that the organization complies with all cybersecurity requirements for all internal and external stakeholders and follow up and	between the organization and the cloud service provider. • Evidence by the cloud computing service provider of the implementation of the cybersecurity requirements of cloud computing and hosting services.
--	--	--	--	---	---

				monitor them periodically to ensure implementation. • Ensure continuous compliance with cloud computing cybersecurity controls for (CCC).	
4.2.3	4.2.3.1	In line with related and applicable laws and regulations, and in addition to the applicable ECC controls from main domains (1), (2), (3) and subdomain (4-1), the cybersecurity requirements related to the use of hosting and cloud computing services must include at least the following: 4-2-3-1 Classification of data prior to hosting on cloud or hosting services and returning data (in a usable format) upon service completion.		• Ensure that data is classified before being hosted by cloud computing and hosting service providers, ensuring that such data is handled according to that classification and that such data is returned by the service provider upon the expiry of the contract/service with the organization through the following steps: ○ Identify all data to be sent to the cloud computing service provider. ○ Classify and label the identified data in line with the data classification and labelling mechanism in the organization and the related laws and regulations. ○ Share this data with the cloud service provider for cloud hosting. ○ Develop procedures to ensure data is returned by the cloud computing service provider (in a usable format) after the contract/service ends.	• Cybersecurity policy that covers the requirements of the use of cloud computing and hosting services (e.g, electronic copy or official hard copy). • Sample of the data list that was classified before hosting it with cloud computing service providers, including but not limited to (a file) showing the data that were classified, prior to sharing with the cloud service provider • A signed sample of the agreement or contract between the organization and the cloud service provider. • Approved procedures for data return after the termination of cloud computing services. • Classification policies and procedures for data to be hosted on computing and hosting services. • Up to date list of hosted services and their classification
	4.2.3.2	Separation of organization's environments (specifically virtual servers) from other environments hosted at the cloud service provider.		• Define the organization's environment separation requirements especially virtual servers) from other entities environments in cloud computing services. • Include in the organization's contracts with cloud computing and hosting providers clauses	• Cybersecurity policy that covers the requirements of the use of cloud computing and hosting services (e.g., electronic copy or official hard copy). • Evidence that outlines the separation of the organizations environment from other

				stating that the organizations environment must be separated from other entities environments in the cloud computing services.	entities environments in cloud computing services (e.g., as an item of the signed contract or having an agreement signed between the service provider and the organization). • Evidence by the cloud computing service provider' that the organization's environment is separated from other entities environments in cloud computing services.
	4.2.3.3	Organization's information hosting and storage must be inside the Kingdom of Saudi Arabia.		• Ensure that the documented and approved policy includes the requirements for the location of hosting and storing the organizations information and must be within the Kingdom. • Ensure that the location of hosting and storing the organization's information is within the Kingdom by, but not limited to: ○ Include a clause in the contract or service level agreement signed with the service provider that data storage must be within the Kingdom. ○ Include a clause regarding the service provider's compliance with the controls of NCA related to cloud computing and hosting services, taking into account the classification of hosted data.	• Cybersecurity policy that covers the requirements of the use of cloud computing and hosting services (e.g., electronic copy or official hard copy). • Evidence of the location of hosting and storing the organization's information within the Kingdom (eg., one of the clauses of the signed contract or service level agreement (SLA) signed between the service provider and the organization). • Evidence by the service provider proving the storage of data within the Kingdom.
4.2.4		The cybersecurity requirements related to the use of hosting and cloud computing services must be reviewed periodically.		• Review and update the cybersecurity policy that covers the requirements of using cloud computing and hosting services periodically according to documented and approved plan for review based on a planned	• An approved document that sets the policy review schedule • Policy indicating that it is up to date and the changes to the cybersecurity requirements for cloud computing and hosting services have been documented and approved by

				interval (e.g., periodic review must be conducted annually). • Review and update the cybersecurity policy covering the requirements of using cloud computing and hosting services in the event of changes in the relevant laws and regulations for example, when a new cybersecurity law is issued that applies to the organization). • Document the review and changes to the cybersecurity requirements for cloud computing and hosting services in the organization and approve them by the head of the organization or his/her deputy.	the head of the organization or his/ her deputy. • Formal approval by the head of the organization or his/her deputy on the updated policy (e.g., via the organizations official e-mail, paper or electronic signature).
NCA CSCC					
Control reference number	Sub-Contr ol	Control clauses	Relevant cybersecurity tools	Control implementation guidelines:	Expected deliverables
4.2.1	4.2.1.1	In addition to the sub-controls under Control 4-2-3 in the Basic Cyber Security Controls, they must cover the cyber security requirements for the use of cloud computing services and hosting, at a minimum; the following : 4-2-1-1 The site for hosting critical systems, or any part of its technical components, must be inside the entity, or in cloud computing services provided by government agencies, or national companies that fulfil the cloud computing controls issued by the	• Cloud Computing and Hosting Cybersecurity Policy Template	• Ensure the classification and coding of data in accordance with the classification and coding mechanism in the entity and the relevant legislative and regulatory requirements before hosting it with cloud computing and hosting service providers. • Ensuring that the entity's critical systems, or any part of its technical components, are hosted in a reliable and safe place within the Kingdom of Saudi Arabia, and these places include the following: ○ The data must be hosted within the entity.	• • Contracts and agreements of the entity with the cloud computing and hosting service provider for critical systems. • An acknowledgment from the cloud computing service provider that it adheres to all internal policies and procedures for the entity's cloud computing and hosting services and adheres to the relevant legislative and regulatory requirements. • • A list of data that was classified before being hosted with cloud computing service providers, including but not limited to: (a file) showing the

		NCA, taking into account the classification of the hosted data .		○ The data is hosted by cloud computing service providers provided by government agencies in the Kingdom of Saudi Arabia. ○ That the data be hosted by cloud computing service providers provided by private companies, such that they are Saudi companies that have verified cloud computing controls (CCC) issued by the National Cybersecurity Authority. ○ Adding a feasibility study and risk assessment for private companies and obtaining a recommendation from the National Cybersecurity Authority.	data that was classified before sharing it with the cloud computing and hosting service provider. • An official document proving that the entity's critical systems, or any part of its technical components, are hosted in a reliable and secure place within the Kingdom of Saudi Arabia.
NCA OSMACC					
Control reference number	Sub-Contr ol	Control clauses	Relevant cybersecurity tools	Control implementation guidelines:	Expected deliverables
N/A				•	•
NCA TCC					
Control reference number	Sub-Contr ol	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
3.1.1	3.1.1.1	In addition to the sub-controls in the ECC control 4-2-3, cybersecurity requirements related to the use of hosting and cloud computing services must include at least the following: 3-1-1-1 The location of the hosted telework systems must be inside the Kingdom of Saudi Arabia	• Cloud Computing and Hosting Cybersecurity Policy Template	• Work to define the requirements of this control and document them in the cybersecurity requirements document, and have them approved by the authority holder. • Ensure that the organization's telework systems, or any part of its technical components, are hosted in a reliable and secure place within the Kingdom of Saudi Arabia.	• Work on defining the requirements for this control, document them in the cybersecurity requirements document, and have them approved by the authority holder. • An official document proving that the organization's telework systems, or any part of its technical components, are hosted in a reliable and

					secure place within the Kingdom of Saudi Arabia.
NCA DCC					
Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables		
N/A					
NCA OTCC					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
N/A					
NCA CCC CST					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
N/A					
NCA CCC CSP					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
N/A					
SAMA CSF					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
3.4.3.1		The cyber security controls within the cloud computing policy for hybrid and public cloud services should be defined, approved and implemented and communicated within Member Organization.		•	•

3.4.3.2		The compliance with the cloud computing policy should be monitored.		•	•
3.4.3.3		The cyber security controls regarding the cloud computing policy and process for hybrid and public cloud services should be periodically measured and evaluated.		•	•
3.4.3.4		"The cloud computing policy for hybrid and public cloud services should address requirements for: a. the process for adopting cloud services, including that: 1. a cyber security risk assessment and due diligence on the cloud service provider and its cloud services should be performed; 2. the Member Organization should obtain SAMA approval prior to using cloud services or signing the contract with the cloud provider; 3. a contract should be in place, including the cyber security requirements, before using cloud services;" "b. data location, including that: 1. in principle only cloud services should be used that are located in Saudi Arabia, or when cloud services are to be used outside Saudi Arabia that the Member Organization should obtain explicit approval from SAMA;" "c. data use limitations, including that:		•	•

		1. the cloud service provider should not use the Member Organization's data for secondary purposes;" "d. security, including that: 1. the cloud service provider should implement and monitor the cyber security controls as determined in the risk assessment for protecting the confidentiality, integrity and availability of the Member Organization's data;" "e. data segregation, including that: 1. the Member Organization's data is logically segregated from other data held by the cloud service provider, including that the cloud service provider should be able to identify the Member Organization's data and at all times should be able to distinguish it from other data." "f. business continuity, including that: 1. business continuity requirements are met in accordance with the Member Organization's business continuity policy;" "g. audit, review and monitoring, including that: 1. the Member Organization has the right to perform a cyber security review at the cloud service provider; 2. the Member Organization has the right to perform a cyber security audit at the cloud service provider; 3. the Member Organization has the right to perform a cyber security			
--	--	---	--	--	--

		examination at the cloud service provider;" "h. exit, including that: 1. the Member Organization has termination rights; 2. the cloud service provider has to return the Member Organization's data on termination; 3. the cloud service provider has to irreversibly delete the Member Organization's data on termination."			
CST CRF					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
6.1.1		Define and document [Requirements for Cloud Services] which consider the following: • Cybersecurity requirements expected from the cloud provider • Service level agreements		•	•
6.1.2		Conduct a risk assessment in accordance with the [Cybersecurity Risk Assessment] and [Information Protection] prior to adopt cloud services (or in the event of changes in relevant legislative and regulatory requirements) to ensure that risks related to the use of cloud services are appropriately identified and addressed.		•	•
6.1.3		Based on the cloud risk assessment and the [Requirements for Asset classification] identify the [Cloud Cybersecurity Requirements] needed to protect the confidentiality,		•	•

		integrity and availability of the information assets in the cloud.			
6.1.4		Establish service level agreements (SLAs) with the cloud service provider which consider at least the following: • [Cloud Cybersecurity Requirements] • Incident notification and recovery obligations • Making sure that the cloud service can be terminated in case of non-compliance with the contractual agreements • Defining the exit procedures covering the secure deletion of data (e.g. irreversibly delete the organization's data, media destruction, returning organization data in a usable format, data retention).		•	•
6.1.5		Ensure that the hosting and storage site of the organization's data is in the Kingdom of Saudi Arabia.		•	•
6.1.6		Audit, review, and monitor the cloud service provider for compliance with contractual obligations.		•	•
6.1.7		Continuously measure, review and optimize the [Requirements for Cloud Services].		•	•
CMA Cybersecurity Guidelines					
Control reference number	Sub-Control	Control clauses	Relevant cybersecurity tools	Control implementation guidelines	Expected deliverables
4.4.3.1		Set out, document, approve and apply cybersecurity controls related to Cloud Computing Policy organizing cloud computing and hosting services		•	•

		and circulate the same across the market institution.			
4.4.3.2		Monitor compliance with Cloud Computing Policy		•	•
4.4.3.3		Measure and periodically evaluate cybersecurity controls related to Cloud Computing Policy organizing cloud computing and hosting services.		•	•
4.4.3.4		Cybersecurity controls related to Cloud Computing Policy shall include: • Approval of cloud computing services, which include: Conduct cybersecurity risk assessment of cloud computing services provider. Conclude a contract laying down cybersecurity controls before using cloud-computing services. • Conduct data classification before hosting. Data hosting location, i.e. to use cloud-computing services within KSA. • Data use restrictions, which prevent cloud computing service provider from using data of market institution for other purposes. • Protection; Cloud Computing Service Provider shall apply and monitor cybersecurity controls as defined in risk assessment in order to protect confidentiality, integrity and availability of market institution's data. • Segregation of data; to properly separate market institution's data		•	•

		from other data maintained by the cloud computing service provider, in order for the cloud computing service provider to be capable of identifying market institution's data and distinguishing them from other data at all times. • Business Continuity; to meet business continuity requirements according to business continuity policy adopted by the market institution. • The market institution shall have the right to conduct cybersecurity review, audit and inspection of the cloud computing service provider. • Termination, which includes: The market institution shall have the right to termination. The market institution shall have the right to recover its data from the cloud computing service provider, upon termination, in an appropriate and usable form. The market institution shall have the right to request deletion of its data by cloud computing service provider, upon termination, in an unrecoverable way			
--	--	---	--	--	--

Risk Considerations in Cloud Computing and Hosting Cybersecurity

- **Risk Title:** Data Security and Compliance Violations
Risk Description: Sensitive data hosted on the cloud may be exposed, and the organization could face compliance issues regarding data protection laws and regulations.
Risk Mitigation: Ensure cloud providers implement strong encryption and comply with regional and industry-specific regulatory requirements (GDPR, HIPAA). Conduct regular security audits and reviews.
- **Risk Title:** Insider Threats from Cloud Service Providers
Risk Description: Insiders at the cloud hosting provider may misuse their access to compromise the security and integrity of the data hosted.
Risk Mitigation: Implement role-based access controls (RBAC) to limit cloud access, and monitor for suspicious activity using auditing and logging tools. Regularly review access permissions.
- **Risk Title:** Insufficient Security Configuration of Cloud Services
Risk Description: Misconfigurations in cloud infrastructure, such as incorrect access rights or public data exposure, can open systems to attacks.
Risk Mitigation: Follow cloud security best practices, including configuring firewalls, virtual private networks (VPNs), and multi-factor authentication (MFA) for administrative access. Use automated tools to check configurations regularly.
- **Risk Title:** Loss of Data Integrity or Availability
Risk Description: Cloud service outages, data corruption, or the lack of redundancy can affect business continuity or result in irreversible data loss.
Risk Mitigation: Establish disaster recovery plans and use multi-cloud or hybrid cloud environments to reduce risks of service disruptions. Ensure that your cloud provider has a robust Service Level Agreement (SLA) that guarantees uptime and data availability.
- **Risk Title:** Vendor Lock-In and Limited Flexibility
Risk Description: Becoming too dependent on a single cloud provider could restrict flexibility, increase costs, or lead to service issues.
Risk Mitigation: Design systems with portability in mind, allowing for smooth migration to alternative cloud providers if necessary. Negotiate multi-cloud or hybrid environments and ensure data export capabilities are clearly defined in vendor contracts.

Examples of Technologies for Effective Cloud Computing and Hosting Cybersecurity

- **Cloud Security Posture Management (CSPM) Tools**
Tools: **ScoutSuite, Prowler, CloudSploit**
Purpose: Monitor cloud configurations for misconfigurations, enforce compliance, and reduce cloud security risks across AWS, Azure, and GCP
- **Cloud Access Security Brokers (CASB)**
Tools: **OpenCASB** (early-stage), **custom reverse proxies with policy enforcement (e.g., Squid + ACLs)**
Purpose: Provide basic visibility and access control over cloud apps; full-featured open-source CASBs are still emerging
- **Identity and Access Management (IAM) for Cloud**
Tools: **Keycloak, Authentik, WSO2 Identity Server (Community Edition)**
Purpose: Manage authentication, SSO, RBAC, and access policies across cloud services and internal apps
- **Cloud Data Encryption Tools**
Tools: **Vault by HashiCorp, OpenSSL, GnuPG**
Purpose: Protect sensitive data and secrets in cloud infrastructure using encryption-as-a-service, secure storage, and cryptographic APIs
- **Intrusion Detection & Prevention Systems (IDPS) for Cloud**
Tools: **Suricata, Snort, Wazuh**
Purpose: Monitor and prevent threats in cloud-based systems through traffic inspection and real-time event detection
- **Cloud Disaster Recovery & Backup Solutions**
Tools: **Restic, Duplicacy, BorgBackup**
Purpose: Backup and restore cloud data with strong encryption, deduplication, and support for multiple backends (e.g., S3, GCS, Azure)
- **Security Information and Event Management (SIEM) for Cloud**
Tools: **Wazuh, ELK Stack (Elasticsearch, Logstash, Kibana), OSSIM**
Purpose: Collect and analyze logs from cloud systems to detect anomalies, monitor incidents, and support compliance

Examples of KPIs for Cloud Computing and Hosting Cybersecurity

1. **KPI Title:** Cloud Infrastructure Downtime
Description: Measures the total amount of downtime experienced in cloud environments, impacting the availability of critical services or systems.
Goal: Achieve a downtime rate of less than 1% annually for cloud-hosted infrastructure.
2. **KPI Title:** Cloud Vulnerability Patch Rate
Description: The percentage of vulnerabilities identified in cloud environments that are patched within the defined time frame.
Goal: Achieve a patching rate of 95% or higher for all critical vulnerabilities within 72 hours.
3. **KPI Title:** Cloud Data Encryption Rate
Description: Measures the percentage of sensitive data stored in cloud environments that is encrypted both at rest and in transit.
Goal: Ensure 100% of sensitive data is encrypted as part of the organization's cloud security standards.
4. **KPI Title:** Compliance Audit Score for Cloud Security
Description: Tracks the organization's score from compliance audits focused on cloud security standards and frameworks, such as NCA ECC and CCC, SAMA CSF, etc.
Goal: Achieve a compliance audit score of at least 90% across all relevant standards.
5. **KPI Title:** User Access Review Frequency in Cloud Environments
Description: Measures the frequency of user access reviews (e.g., privilege access and role-based access controls) conducted in the cloud environment to minimize the risk of unauthorized access.
Goal: Perform quarterly user access reviews to maintain strict control over permissions and access rights in cloud systems.

Case Study: Developing and Implementing Third-Party and Outsourcing Cybersecurity for a Saudi Organization

This case study provides a structured approach for integrating cybersecurity into cloud computing and hosting services in a Saudi organization. By developing a robust policy and implementing comprehensive cybersecurity requirements, the organization ensures data security and compliance with local regulations.

Phase 1: Developing Cybersecurity Policy for Cloud Computing

1. Policy Components

- Contract Requirements:
 - Specify provider obligations in contracts, including service delivery, data security, and incident handling.
- Hosting and Storage Location:
 - Ensure hosting and storing of organizational systems and data occur within the Kingdom.
- Data Removal and Retrieval:
 - Define secure methods for data removal and retrieval upon contract termination.
- Data Classification:
 - Require data classification prior to hosting or storing data on cloud services.
- Service Level Agreements (SLA):
 - Include SLAs to specify service performance and security requirements.
- Non-Disclosure Clauses:
 - Embed clauses to ensure confidentiality of organizational information.

2. Executive Endorsement

- Obtain policy approval from the organization's head or deputy for authority and compliance.

Phase 2: Implementation of Cybersecurity Requirements

1. Hosting and Storing Information

- Enforce hosting and storage of organizational information within the Kingdom.

2. Event Logs and Data Encryption

- Activate event logs on hosted information assets.
- Encrypt data transmitted to, stored in, or transmitted from cloud services per organizational and regulatory requirements.

3. Separation of Environments

- Ensure organizational environments (e.g., virtual servers, networks, databases) are separated from other entities in the cloud.
- Include contractual clauses mandating environment separation.

4. Data Management

- Periodically back up hosted data per the organization's backup policy.
- Ensure the provider securely returns and irretrievably removes data upon service termination.

5. Compliance Monitoring

- Develop an action plan for continuous monitoring of compliance with cloud computing cybersecurity controls (CCC).
- Conduct periodic reviews of providers to ensure ongoing adherence.

Phase 3: Data Classification and Labelling

1. Identifying and Labelling Data

- Identify all data for hosting.
- Classify and label the data according to the organizational data classification mechanism and relevant laws.

2. Handling Classified Data

- Ensure that data classification guides the handling process.
- Share classified data with cloud providers for hosting while ensuring confidentiality.

3. Data Retrieval Procedures

- Develop mechanisms to retrieve data in usable formats upon contract termination.

Phase 4: Location of Hosting and Compliance

1. Hosting Location

- Include clauses in contracts requiring data storage within the Kingdom.
- Ensure the provider complies with National Cybersecurity Authority (NCA) regulations.

2. Periodic Backups

- Require periodic data backups and protection per the organization's backup policy.

3. Regulatory Compliance

- Mandate provider compliance with cybersecurity controls specific to hosted data classification.

Phase 5: Policy Review and Updates

1. Regular Reviews

- Conduct annual reviews of cybersecurity policies governing cloud computing.
- Update policies upon changes in laws or regulations (e.g., issuance of new cybersecurity laws).

2. Document Changes

- Record reviews and updates.
- Obtain approval of changes from the organization's head or deputy.

Reference:

- [1] M. Benaroch, "Third-party induced cyber incidents—much ado about nothing?," *Journal of Cybersecurity*, vol. 7, no. 1, p. tyab020, 2021.
- [2] "Essential Cybersecurity Controls in Saudi Arabia | FDT." Accessed: Apr. 22, 2025. [Online]. Available: <https://fastdigitaltechnology.com/grc-solutions/essential-cybersecurity-controls>
- [3] I. A. Mohamed, "Cyber Risk Management of Third-Party Relationships: The Need for an Assessment Guidelines to Regulate Private Sectors in Libya," in *2024 IEEE 4th International Maghreb Meeting of the Conference on Sciences and Techniques of Automatic Control and Computer Engineering (MI-STA)*, IEEE, 2024, pp. 7–12. Accessed: Apr. 22, 2025. [Online]. Available: <https://ieeexplore.ieee.org/abstract/document/10599763/>
- [4] "CSA Cloud Controls Matrix: Guide to Cloud Security Controls." Accessed: Apr. 22, 2025. [Online]. Available: <https://linfordco.com/blog/csa-cloud-controls-matrix/>
- [5] M. C. Ltd, "Saudi Banks' Sensitive Data Security and SAMA Compliance | Microminder Cybersecurity | Holistic Cybersecurity Services," Microminder Cybersecurity. Accessed: Apr. 22, 2025. [Online]. Available: <https://www.micromindercs.com/blog/saudi-banks-sensitive-data-security-sama-compliance>
- [6] P. Alves, "What is NCA CCC (Cloud Cybersecurity Controls)? | CyberArrow." Accessed: Apr. 22, 2025. [Online]. Available: <https://www.cyberarrow.io/blog/what-is-nca-ccc-cloud-cybersecurity-controls/>

Module 5: Personal Data Protection Law (PDPL)

Overview

This module gives learners a 360-degree understanding of Saudi Arabia's PDPL, starting with the statute's scope, definitions, and core processing principles, then drilling down into data-subject rights, controller/processor duties, lawful bases, and cross-border transfer rules. Practical elements policy templates, risk-mitigation playbooks, KPIs, and the "NajdPay Digital" case study—translate legal text into day-to-day controls. By the end, participants can:

- identify when PDPL applies and which data are in-scope;
- choose and document an appropriate legal basis for processing or disclosure;
- design privacy notices, RoPA registers, DPIAs, and breach-response workflows that match PDPL/IR articles;
- align vendor contracts and international transfers with the law's requirements;
- measure ongoing compliance with clear, executive-level KPIs.

By the end of the module, learners can map PDPL/IR articles to concrete controls, identify mandatory artefacts (e.g. DPIA, consent logs), and recognise situations that trigger regulator or data-subject notification.

Personal Data Protection Law (PDPL) Definition

Saudi Arabia's Personal Data Protection Law (PDPL) is a comprehensive privacy statute that governs the collection, processing, transfer, and protection of personal data relating to individuals in—or connected to—the Kingdom[1], [2].

Objective

to ensure personal data is collected, processed, stored, transferred, and destroyed in a lawful, fair, secure, and transparent manner that safeguards the rights of data subjects while enabling responsible organizational use.

PDPL Detailed Overview

Based on Saudi Arabia’s Personal Data Protection Law (PDPL) [3] and its Implementing Regulation [4], the following detailed overview explains how the framework operates in practice—outlining its scope of application, key definitions, processing principles, and the specific rights and obligations it creates for organizations and individuals alike.

Scope and Application

Processing Scope	Processed by entities within Saudi Arabia or outside the Kingdom if targeting Saudi residents.
Identifiable Persons	Covers living individuals and deceased persons if data identifies them or their families.
Entities Covered	Government agencies, private companies, and non-profit organizations.
Data Types	All personally identifiable data, whether processed by automated, manual, or mixed means.

Key Definitions Under PDPL

- Personal Data:** Information that relates to an identified or identifiable individual, including contact details, personal identifiers (like ID numbers), and online data (e.g., IP addresses). If it is impossible to identify a particular individual from the data in question, then such data is not personal data and its use is not regulated by the PDPL.
- Sensitive Data:** Spans racial, religious, health, financial, genetic, and biometric information requiring higher levels of protection.
 The PDPL provides for a separate subset of personal data – “sensitive data”. It includes personal data revealing racial or ethnic origin, or religious, intellectual or political belief, security data, data relating to criminal offenses, biometric or genetic data, health data, and data that indicates that one or both of the individual’s parents are unknown.
- Anonymized Data:** Data irreversibly altered so the individual cannot be re-identified (excluded from the law).
- Controller:** is an entity that makes decisions about the purposes and ways of the processing of personal data. The Controller is ultimately responsible for the processing under the PDPL.
- Processor:** is an entity that processes personal data on behalf of a Controller. As opposed to the Controller, the Processor does not make decisions about the purposes and ways of personal data processing and instead takes direction from the Controller.
- Personal Data:** Information that relates to an identified or identifiable individual, including contact details, personal identifiers (like ID numbers), and online data (e.g., IP addresses). If it is impossible to identify a particular individual from the data in question, then such data is not personal data and its use is not regulated by the PDPL.

Core Principles of Data Processing

- **Lawfulness:** Data must be processed for lawful and legitimate reasons.
- **Fairness:** Avoid harmful or misleading practices.
- **Transparency:** Ensure clarity and openness regarding how and why data is collected or processed.
- **Purpose Limitation:** Only collect data for specific, explicit purposes and refrain from secondary use.
- **Minimization:** Only process data relevant and necessary for defined purposes.
- **Accountability:** Data controllers

Data Subject Rights

PDPL empowers individuals with comprehensive rights, including:

- **Right to Information:** Data controllers must inform individuals about the purpose of data collection, third-party access, and security safeguards in place.
- **Right to Data Access:** Individuals can request copies of their personal data.
- **Right to Rectification:** Corrections to errors or omissions must be facilitated promptly.
- **Right to Restrict Processing:** Under certain legal bases, individuals can object to or restrict data usage.
- **Right to Erasure ("Right to Be Forgotten"):** Individuals can request deletion when data is no longer necessary for original purposes.

Roles and Stakeholders

- key obligations of a Controller:
 - To define the purpose of the processing of personal data.
 - To ensure that there is a suitable lawful basis for the processing of personal data (e.g., consent, legal obligation, legitimate interest, etc.).
 - To ensure that personal data is processed pursuant to the principles of personal data processing (for example storage limitation).
 - To notify data subjects⁶ on how their personal data is processed (for example, via a privacy notice).
 - To enable data subjects to exercise their rights under the PDPL.
 - To maintain records of processing activities register ("RoPA") for all processing of personal data across the entity.
 - To conduct impact assessments of personal data processing (for example, Data Protection Impact Assessment; Data Transfer Impact Assessment or Legitimate Interest Assessment).
 - To ensure lawful cross-border transfers of personal data outside the KSA.
 - To implement all the necessary organisational, administrative and technical measures to protect personal data.

- To cooperate only with those Processors that provide necessary guarantees to implement the provisions of the PDPL and the Regulations, to enter into data processing agreements with Processors, and to monitor compliance of Processors with such agreements.
- To notify any changes in personal data to entities to which the personal data was transferred.
- To notify the Competent Authority and data subjects of personal data breaches.
- To appoint a Data Protection Officer, where required by the Implementing Regulation⁷.
- To comply with requirements of the PDPL and Implementing Regulation to specific types of processing activities, for example:
 - processing of health data and credit data;
 - processing of personal data for sending advertising or awareness-raising materials;
 - processing of personal data for scientific, research, or statistical purposes;
 - disclosure of personal data;
 - copying official documents where data subjects are identifiable.
- To comply with the rules for registration of Controllers in the National Register of Controllers (the rules are to be issued by the Competent Authority).
- key obligations of a Processor:
 - To process personal data for the Controller based on a data processing agreement.
 - To comply with instructions of the Controller regarding the personal data processing.
 - To assist the Controller by implementing appropriate organizational, administrative and technical measures to protect personal data that it is processing for the Controller.
 - Before a Processor engages with any sub-processor for the processing, to ensure the following:
 - the contracts with sub-processors will not impact the level of protection provided to the personal data being processed;
 - the sub-processors will provide sufficient guarantees to comply with the PDPL and the Regulations; and
 - the Processor shall notify the Controller on engaging a sub-processor and the Controller shall have the right to object to such engagement within a timeframe agreed upon between the Controller and the Processor.
- Data Protection Officer (DPO): Required for certain organizations handling sensitive or large-scale data processing. The DPO shall be organizationally linked to the Data Management Office within the Controller. If the Controller is not obligated to establish a Data Management Office, the DPO should be linked to another department, ensuring that there is no conflict with DPO tasks or affect DPO's independence.

PDPL Policies and Procedures

- **Data Privacy Policy** – The Data Privacy Policy is the key document that defines all data privacy requirements within Neotek. It outlines how Neotek ensures the protection and handling of personal data. This policy serves as the foundation for data privacy governance across all departments.
- **Privacy Notices** –are essential for informing individuals (employees, customers) about how their personal data is collected, used, stored, and shared, ensuring transparency and compliance with legal obligations while safeguarding individuals' data privacy rights.
- **Consent Management Policy** – This policy outlines the organization's approach to obtaining, recording, managing, and revoking the consent of individuals for the collection and processing of their personal data. It ensures that consent is informed, freely given, specific, and recorded, complying with the PDPL requirements.
- **Data Subject Request Policy and Procedure** – This policy establishes the processes for managing and responding to requests from data subjects regarding their rights under the PDPL. These rights typically include access to, rectification of, deletion of, and objection to the processing of their personal data.
- **Data Protection Impact Assessment Policy, Procedure** – This policy governs the process of conducting Data Protection Impact Assessments for processing activities that are likely to pose significant risks to data subjects' privacy. It provides a framework for identifying, assessing, and mitigating risks associated with the processing of personal data.
- **Third Party Data Policy** – This policy sets guidelines for managing relationships with third-party entities that process personal data on behalf of the organization. It ensures that these entities comply with the PDPL through appropriate contractual arrangements, due diligence, and monitoring.
- **Data Retention Policy** – This policy defines the rules for how long personal data should be retained by the organization and provides procedures for securely deleting or archiving data once it is no longer needed for its original purpose or as required by law.
- **Data Breach Response** – This policy outlines the organization's strategy for responding to data breaches. It includes procedures for identifying, containing, investigating, and reporting data breaches, as well as measures to prevent future breaches and mitigate damage.

Lawful bases for personal data processing

- **Consent** – data subject has given consent to the processing of his or her personal data.
- **Actual interests** – processing serves actual interests of the data subject, but communicating with the data subject is impossible or difficult.
- **Contract** – processing is pursuant to the implementation of a previous agreement to which the data subject is a party.
- **Legal obligation** – processing is required and regulated by another law.
- **Public interest** – if the Controller is a public entity and the processing is required for security purposes or to satisfy judicial requirements.
- **Legitimate interest** – processing is necessary for the purpose of legitimate interest of the Controller, provided that no sensitive data is to be processed.
- **Publicly available data** – personal data is publicly available or collected from a publicly available source.
- **Public interest or security purposes** – the Controller is a public entity and processing of personal data is required for public interest or security purposes, or to implement another law, or to fulfill judicial requirements.
- **Vital interests** – if not collecting or processing of personal data may harm the data subject or affect their vital interests.
- **Public health and safety** – personal data collection or processing is necessary to protect public health, public safety, or to protect the life or health of specific individuals.
- **Anonymised data** – personal data is not to be recorded or stored in a form that makes it possible to identify the data subject directly or indirectly.
- **Legitimate interest** – processing is necessary for the purpose of legitimate interest of the Controller, provided that no sensitive data is to be processed.

Lawful bases for disclosure of personal data

In addition to having a lawful basis for processing, a separate lawful basis is required when a Controller discloses personal data (e.g. disclosure of personal data to another legal entity – including within the same group).

- **Consent** – data subject has given consent to disclosure of his or her personal data.
- **Publicly available data** – personal data has been collected from a publicly available source.
- **Public interest or security purposes** – the entity requesting disclosure is a public entity, and the collection or processing of the personal data is required for public interest or security purposes, or to implement another law, to fulfill judicial requirements.
- **Public health and safety** – the disclosure is necessary to protect public health, public safety, or to protect the lives or health of specific individuals.
- **Anonymised data** – the disclosure will only involve subsequent Processing in a form that makes it impossible to directly or indirectly identify the data subject.

- **Legitimate interest** – the disclosure is necessary to achieve legitimate interests of the Controller, without prejudice to the rights and interests of the data subject, and provided that no sensitive data is to be processed.

International Data Transfers

The PDPL imposes strict limitations on transferring data outside Saudi Arabia. Transfers are permissible only if:

- The receiving country has equivalent or higher data protection measures.
- The data subject consents explicitly, understanding the potential risks involved.
- Approval from the Saudi Data & Artificial Intelligence Authority (SDAIA) is secured for sensitive or critical data.

Compliance and Penalties

- **Financial Fines:** Up to SAR 5 million (approx. \$1.3 million) for non-compliance.
- **Imprisonment:** Unauthorized access or disclosure of sensitive data may result in jail sentences of up to 2 years.
- **Data Breaches:** Repeated violations lead to doubled penalties and potential suspension of activities.

Exemptions and Special Cases

Certain processing activities may not require full compliance:

- **Personal and Household Use:** As long as data isn't disclosed to third parties.
- **Scientific Research:** Exempt under conditions ensuring privacy safeguards.
- **National Security:** Processing for security or defense is governed separately.

Implementation Challenges for Organizations

- **Technology Infrastructure:** Upgrading systems for localization, encryption, and security.
- **Operational Changes:** Integrating processes for timely breach reporting and record maintenance.
- **Training:** Developing organizational awareness and specialized training on PDPL responsibilities.

Global Relevance

International businesses processing data of Saudi individuals must ensure PDPL compliance, regardless of their geographic location. Non-compliance can lead to bans on operations in the Kingdom.

Implementation: Data Protection Officer (DPO) Appointment

Controllers are required to appoint a DPO if:

- They are a public entity processing personal data on a large scale.
- Their primary activities involve regular and continuous monitoring of individuals.
- Their core activities include processing sensitive personal data.

Implementation: DPO Responsibilities

The DPO's key duties include:

- Serving as the direct liaison with the Saudi Data & Artificial Intelligence Authority (SDAIA).
- Overseeing impact assessments, audits, and evaluations.
- Maintaining and updating records of personal data processing activities (RoPA).
- Facilitating data subjects in exercising their rights.
- Responding to data subjects' requests and addressing complaints.
- Notifying SDAIA and data subjects of data breaches when applicable.
- Managing the Controller's violations related to personal data and implementing corrective actions.

Implementation: Data Subject Rights

Controllers must be:

- Respond to data subject requests within 30 days, extendable by an additional 30 days if necessary.
- Implement measures to ensure prompt responses and verify the identity of requesters.
- Document and retain records of all submitted requests, including verbal ones.

Implementation: Exercising Data Subject Rights

The Regulation details how Controllers should facilitate:

- The right to be informed, specifying the information to be provided and the communication method.
- The right of access, including safeguards for data disclosure.
- The right to rectification, allowing data subjects to request processing restrictions while accuracy is contested.
- The right to data destruction, outlining conditions and procedures for data deletion.

Implementation: Complaint Procedures

Data subjects can file complaints to SDAIA within 90 days from the incident or awareness of it. The Regulation specifies:

- Required contents of the complaint.
- Actions SDAIA will undertake in response.

Implementation: Consent Requirements

Consent must be:

- Freely given, without misleading methods.
- Informed, with clear and specific processing purposes explained beforehand.
- Provided by individuals with full legal capacity.
- Documented appropriately.
- Obtained separately for each processing purpose.

Implementation: Data Lifecycle Management

Controllers are required to:

- Establish data retention policies aligned with processing purposes.
- Implement measures for secure data destruction when no longer needed.
- Maintain records detailing data collection, processing, storage, and destruction activities.

Implementation: Data Breach Notification

In the event of a data breach, Controllers must:

- Notify SDAIA within 72 hours if the breach may cause harm.
- Inform affected data subjects promptly, detailing the nature of the breach and mitigation measures.

Implementation: Records of Processing Activities (RoPA)

- **Intro**
 - Records of Processing Activities (RoPA) is a crucial component of personal data protection accountability. It serves as a comprehensive documentation on how personal data is processed within an organization.
 - RoPA outlines data processing activities, including types of data collected, purposes of processing, and data sharing practices.

- It enables organizations to demonstrate compliance with data protection regulations and fosters transparency and trust with stakeholders.
- By implementing best practices in RoPA creation and maintenance, organizations can enhance efficiency of existing processes.
- **Why do we need RoPA**
 - By documenting data processing activities comprehensively, RoPA enables organization to quickly identify what data are processed, where they are stored, to estimate consequences for data subjects.
 - RoPA enhances transparency by providing clear understanding what data are processed about the data subject, which systems are involved and make it easy to respond to any request.
 - By identifying and documenting data processing activities, RoPA allows organization to identify high risk processes and conduct a Data Protection Impact Assessment to mitigate risks.
- **How DPO does ensure that RoPA is kept up to date:**
 - Identification of RoPA update triggers:
 - Initiation of a new process which involves Personal Data
 - Change in purpose, scope of processing
 - Change in business unit owner
 - Change in system used to process Personal Data
 - Addition of a third party
 - Documentation and Record-Keeping of relevant details in RoPA such as categories of personal data, categories of data subjects, recipients, data transfers, and retention periods
 - Collaboration with departments' representatives by working closely with departments' representatives to ensure RoPA compliance, seek guidance on business processes details regarding RoPA.
 - Assisting in Risk Assessments (DPIAs, LIAs):
 - Initiate DPIAs, LIAs as necessary, ask departments' representatives to make input on data processing activities and associated risks.
 - Ensure that DPIA, LIAs findings and recommendations are reflected in the RoPA where applicable.
 - Regular Updates and Maintenance:
 - Keep the RoPA up-to-date by promptly documenting any changes or new processing activities.
 - Review and revise RoPA entries regularly to reflect changes in data processing practices.

Implementation: Data Protection Impact Assessment

- **When DPIA should be carried out?**
 - Processing of Sensitive Data: This involves handling sensitive categories of personal data.
 - Collecting, Comparing, or Linking Data: Combining different sets of personal data obtained from various sources.
 - Processing Data of Individuals Without Legal Capacity: Continuous and large-scale processing of personal data of individuals who cannot legally make decisions on their own.
 - Continuous Monitoring: Keeping a regular watch on data subjects.
 - Using New Technologies: Implementing new technological methods in data processing.
 - Automated Decision Making: Making decisions based on automated processing of personal data.
 - Potential Harm to Privacy: Offering products or services that could seriously affect the privacy of data subjects.
- **DPIA Steps**
 - Determine the Need for a DPIA
 - Assess if the processing involves high-risk activities like large-scale sensitive data processing or new technologies.
 - Describe the Processing Activities
 - Clearly outline the scope, purpose, data types, sources, recipients, and technologies involved.
 - Identify Risks
 - Analyze privacy risks, such as unauthorized access, loss, or harm to individuals' rights.
 - Evaluate Necessity and Proportionality
 - Ensure the processing is necessary, proportional, and complies with legal requirements.
 - Assess and Mitigate Risks
 - Develop measures to mitigate identified risks (e.g., encryption, limited access).
 - Consult Stakeholders
 - Involve key stakeholders, such as the DPO, internal teams, external partners, or data subjects.
 - Document the DPIA
 - Keep a detailed record of activities, risks, decisions, and outcomes.
 - Seek Approval
 - Obtain sign-off from the DPO or appropriate authority and consult regulators if necessary.
 - Implement Mitigation Measures
 - Apply the agreed-upon risk mitigation strategies.
 - Monitor and Review
 - Regularly update the DPIA to reflect any changes in processing activities or risks.

Implementation: Data Protection by Design and by Default

- Establishing a culture of Privacy is about empowering development teams and the wider business to consider data and user first when it comes to every new system, service, product or business practice. Where data privacy was once an expensive and stressful afterthought, it is now an exciting driver to developing the most innovative, efficient and effective products.

- **Data Protection by Design**

This approach ensures privacy and data protection are embedded into the design of processing activities, systems, and technologies from the outset. Key aspects include:

- Proactive Measures
 - Anticipate and address privacy risks before they occur.
 - Focus on prevention, not just remediation.
- End-to-End Safeguards
 - Protect data throughout its lifecycle—collection, storage, processing, and deletion.
- Embedding Privacy-Friendly Features
 - Integrate privacy-enhancing tools like encryption, pseudonymization, or anonymization.
 - Minimize data collection and limit access to essential personnel.

- **Data Protection by Default**

This principle ensures that the strictest privacy settings are applied automatically, without requiring user intervention. Key elements include:

- Minimal Data Processing
 - Collect only what is necessary for the stated purpose.
 - Avoid excessive data collection or processing.
- Purpose and Use Limitation
 - Ensure data is processed only for the purposes explicitly defined and communicated.
- Accessible Privacy Settings
 - Provide clear options for users to adjust privacy settings if necessary.
 - Default configurations must favor privacy.
- Secure by Default
 - Apply robust security measures to prevent unauthorized access or data breaches.

Implementation: Third Party Privacy Requirements

- **Before engaging with a Third Party,**
 - Organization shall assess the safeguards that the Third Party has in place to protect Personal Data and the risk that the proposed processing poses to Data Subjects using:
 - Have a Personal Data Protection Questionnaire - to assess, using a risk-based approach, the safeguards that the Third Party has in place to protect Personal Data.
- **At the start of the engagement with a Third Party**
 - Organization shall agree in writing through a contract and Data Transfer Agreement / Data Processing Agreement / Joint Controllership Agreement in the terms and conditions of the Processing and sharing to take place between the organization and the Third Party. Throughout the duration of the engagement, Neotek shall ensure that safeguards are in place to protect Personal Data
 - Have a Third-Party Technical Audit Checklist - to ensure that Third Party outsourced technology providers that use or retain Personal Data meet the appropriate standard of security, encryption and data privacy protection through regular audits.
- **At the end of the engagement with a Third Party,**
 - Organization shall require the Third Party to comply with requirements in the contract regarding the end of the contract term, for example to make all reasonable efforts to delete any Personal Data held under the contract. To do this, organization can use Contract Exit Checklist - to ensure that all actions are taken to appropriately protect Personal Data at the end of contractual relationships.

Risk Considerations

Key Risks and Paired Mitigations

- **Unlawful or unsupported processing** → *Mitigation:* maintain an up-to-date Record of Processing Activities (RoPA) and require legal-basis checks in the intake workflow.
- **Inadequate consent documentation** → *Mitigation:* deploy a consent-management platform with immutable logs and self-service withdrawal.
- **Cross-border transfer without adequate safeguards** → *Mitigation:* embed an automated transfer-impact checklist and require Standard Contractual Clauses (SCCs) or SDAIA approval before export.
- **Personal-data breach leading to fines or reputational loss** → *Mitigation:* implement 24x7 security monitoring, NCA-aligned controls, and rehearse breach-response playbooks.
- **Processor non-compliance** → *Mitigation:* use tiered vendor-risk scoring, insist on PDPL clauses, and schedule annual audits.

Examples of Technologies for Personal Data Protection Law (PDPL)

- **Privacy Ops & RoPA**
Tools: PDP4E, OpenControl, Eramba (Community Edition)
Purpose: Automate records of processing activities (RoPA), support data protection impact assessments (DPIA), and manage consent documentation to align with PDPL requirements
- **Data Loss Prevention (DLP)**
Tools: Wazuh, OpenDLP, MyDLP (Community Edition)
Purpose: Monitor, detect, and block unauthorized transmission of personal data to prevent breaches and enforce data handling policies
- **Secrets Management & Encryption**
Tools: HashiCorp Vault (open-source), OpenSSL, GnuPG
Purpose: Centralize management of encryption keys and secrets, ensuring compliance with encryption mandates for data at rest and in transit
- **Security Orchestration, Automation, and Response (SOAR)**
Tools: TheHive + Cortex, Wazuh
Purpose: Automate breach detection, incident triage, and notification workflows to support PDPL's 72-hour breach reporting requirement
- **Vulnerability Scanning**
Tools: OpenVAS, Trivy, Nikto
Purpose: Identify and prioritize vulnerabilities in systems that handle personal data, reducing exposure and supporting proactive risk mitigation
- **Vendor & Risk Management**
Tools: Eramba (Community Edition), SimpleRisk, OpenGRC
Purpose: Track third-party processor assessments, audit results, and remediation actions to ensure vendors comply with PDPL obligations

Example of Key Performance Indicators (KPIs)

1. **DSAR Turnaround Time** – Average time to fulfil a data-subject request. Shorter times show streamlined rights-management.
2. **Breach Notification Timeliness** – Percentage of breaches reported to SDAIA within 72 h. Higher percentage = stronger incident response.
3. **Processor Contract Coverage** – Share of active vendors under PDPL-compliant contracts. 100 % indicates full third-party control.
4. **Annual PDPL Training Completion** – Percentage of employees finishing mandatory privacy course. High completion reflects awareness culture.
5. **DPIA Completion Rate** – Proportion of high-risk projects with a finished impact assessment before go-live. Shows preventive risk management.
6. **RoPA Accuracy Score** – Percentage of processing records updated in the last 90 days. High score means reliable inventory.
7. **Consent Withdrawal Processing Time** – Average hours to honour a withdrawal request. Faster processing respects data-subject autonomy.
8. **Third-Party Audit Coverage** – Percentage of critical processors audited in the last 12 months. Demonstrates oversight of outsourced risks.

Case Study – “NajdPay Digital”

Learning Objective: Help trainees connect each PDPL/IR requirement to real-world actions, evaluate risk, and articulate compliance outcomes.

Background Narrative

NajdPay Digital is a Riyadh-based fintech that offers e-wallets, micro-loans, and a budgeting app. It handles ID copies, salary slips, and behavioural analytics on **1.2 million** Saudi customers and expatriates.

Trigger: After the PDPL came into force, the board ordered a 6-month compliance sprint when a peer was fined SAR 2 M for an unreported breach.

Phased Programme (What, Why, PDPL Link)

Phase	Key Actions	Why it Matters	PDPL/IR Hook
1 – Discover & Assess (Weeks 1-4)	• Map 12 systems. • Populate RoPA. • Run 3 DPIAs (credit scoring, biometrics, cross-border CRM).	You can’t secure what you haven’t mapped; DPIA flags high-risk flows early.	Art 31 (RoPA), Art 22 (DPIA), IR 25, 33
2 – Fix & Embed Controls (Weeks 5-12)	• Launch consent-portal & dynamic privacy-notice engine. • Encrypt databases, tokenise PANs. • Amend 17 processor contracts with PDPL clauses. • Staff micro-learning (legal, IT, call-centre).	Converts legal text into daily processes; stops “shadow” data leaks.	Art 5, 12-13, 19; IR 11-12, 17, 23
3 – Operationalise & Test (Weeks 13-20)	• Integrate DSAR workflow into ServiceDesk. • Table-top + live breach drill. • Launch KPI dashboard to execs; colour-coded heat map.	Drills prove 72-h breach rule; KPIs keep compliance visible to leadership.	Art 4, 20, 21; IR 24
4 – Certify & Continuously Improve (Weeks 21-24)	• Internal audit vs. ISO 27701. • Annual vendor-audit schedule & risk scoring. • Quarterly privacy town-hall with Q&A.	External badge builds customer trust; town-halls embed culture.	Art 8, 17 (processor oversight)

Results Dashboard (12-Month Snapshot)

Metric	Baseline	After Project	Target Met?
DSAR turnaround	28 days avg.	5 days	✓ (≤ 30)
Breach notification drill	n/a	36 h	✓ (≤ 72 h)
Processor contracts updated	41 %	100 %	✓
Staff PDPL training pass	None	94 % of 600 staff	✓ (≥ 90 %)
Fines / warnings	0 SAR (but at risk)	0 SAR	✓

Trainer Discussion Points

1. **Mapping vs. DPIA:** Why must RoPA come first? What could go wrong if you skip it?
2. **Consent vs. Legitimate Interest:** Which basis would *you* pick for behavioural analytics? Justify.
3. **72-Hour Rule:** What team roles must be alerted within the first hour of a breach?
4. **Third-Party Risk:** How would you rank a cloud CRM vs. a local print shop under PDPL?
5. **Metrics:** Which KPI would you add to keep the board engaged

Reference:

- [1] "Data Protection Law." Accessed: Apr. 21, 2025. [Online]. Available: <https://sdaia.gov.sa/en/Research/Pages/DataProtection.aspx>
- [2] "An overview of Saudi Arabia's new Personal Data Protection Law," Al Tamimi & Company. Accessed: Apr. 21, 2025. [Online]. Available: <https://www.tamimi.com/law-update-articles/an-overview-of-saudi-arabias-new-personal-data-protection-law/>
- [3] "Personal Data English V2-23April2023- Reviewed-.pdf." Accessed: Apr. 21, 2025. [Online]. Available: <https://sdaia.gov.sa/en/SDAIA/about/Documents/Personal%20Data%20English%20V2-23April2023-%20Reviewed-.pdf>
- [4] "ImplementingRegulation.pdf." Accessed: Apr. 21, 2025. [Online]. Available: <https://sdaia.gov.sa/en/SDAIA/about/Documents/ImplementingRegulation.pdf>

Module 6: Digital Trust

Overview

This module equips participants with the technical know-how and regulatory insight needed to create, verify, and govern trustworthy electronic transactions in Saudi Arabia. It begins with the cryptographic foundations of digital signatures, electronic stamps, and time-stamps, then walks through the Public-Key Infrastructure (PKI) workflow that underpins their authenticity and integrity. Learners explore the Kingdom's legal landscape—Royal Decree M/18, its forthcoming Implementing Regulations, and Digital Government Authority (DGA) licensing requirements for Certification Service Providers (CSPs)—so they understand when a signature is legally binding and how to maintain compliance.

The module also demystifies the roles of CSPs, digital certificates, and the full certificate lifecycle (issuance, renewal, revocation), before detailing mandatory technical and procedural controls for creating and validating signatures/stamps. Industry spotlights (government, finance, healthcare, real estate) and Saudi-specific case studies illustrate how organisations streamline workflows, reduce fraud, and cut paperwork by adopting accredited e-signature solutions. Finally, participants assess risk scenarios, map security best practices to National Cybersecurity Authority (NCA) controls, and survey future trends such as blockchain-anchored signatures and quantum-resistant encryption—laying a practical roadmap for sustaining digital trust in an evolving threat and regulatory environment.

Introduction to Digital Signatures & Stamps

- A Digital Signature is a secure cryptographic method that authenticates digital documents and transactions, ensuring security, integrity, and legal validity [1].
- Electronic Stamp: Electronic data included, added, or logically linked to an electronic transaction, used to prove the identity of the stamp holder, authenticate the electronic transaction, and detect any modification to this transaction after being stamped.
- Time Stamp: Electronic data contained, added, or linked to an electronic record, for the purpose of determining the date and time of the procedure that took place on this record, and detecting any modification thereto [2].

Why Digital Signatures Matter

- Global adoption in finance, government, and enterprise sectors.
- Legally binding under Saudi Arabian Electronic Transactions Law.
- Improves efficiency by reducing paperwork and fraud.
- Secure and encrypted, preventing unauthorized modifications.

Industries That Use Digital Signatures

- Government: e-Governance, taxation, permits, birth certificates.
- Finance: Banking transactions, loan agreements, stock trading.
- Healthcare: e-Prescriptions, patient records, insurance claims.
- Legal: Court documents, contracts, affidavits.
- Real Estate: Property deeds, rental agreements, land registrations.

Understanding the Digital Signature Process

How Digital Signatures Work

- Digital signatures use Public Key Infrastructure (PKI) to encrypt and authenticate documents.

Step-by-Step Process:

- Hashing: The document is hashed using SHA-256 or another cryptographic algorithm.
- Encryption: The hash is encrypted using the signer's private key, forming the digital signature.
- Verification: The recipient decrypts the signature with the public key to validate the signature's authenticity.
- Validation: If the decrypted hash matches the original, the document remains untampered and valid.

Cryptographic Algorithms Used in Digital Signatures

- RSA (Rivest-Shamir-Adleman) – Used in government and financial institutions.
- ECDSA (Elliptic Curve Digital Signature Algorithm) – Used in blockchain applications.
- SHA-256 (Secure Hash Algorithm) – Ensures document integrity.

Saudi Arabian Legal Framework & Compliance

Digital Signature Laws & Regulations [3]

- Digital Signatures in Saudi Arabia are regulated by:
 - Electronic Transactions Law (Royal Decree No. M/18)
 - Implementing Regulations for Electronic Transactions Law (2025)

Legal Criteria for a Valid Digital Signature:

- Uniquely linked to the signer.
- Secure authentication using an accredited CSP.
- Ensures document integrity (unchangeable after signing).
- Created using a secure and verifiable method.
- Meets Saudi Arabian cybersecurity and encryption standards.

Global Digital Signature Laws Compared

Country/Region	Regulation	Key Features
Saudi Arabia	Electronic Transactions Law	Requires CSP accreditation from DGA
Europe	eIDAS Regulation	Recognizes Qualified Electronic Signatures (QES)
United States	E-SIGN Act, UETA	Recognizes electronic signatures for contracts

Certification Service Providers (CSPs) & Digital Certificates

What is a CSP?

A Certification Service Provider (CSP) is an accredited entity that issues digital certificates used to authenticate digital signatures [1].

Saudi Arabian CSP Accreditation

- Must be approved by DGA.
- Must comply with ISO 27001 Information Security Standards.
- Provides time-stamping services for document authenticity.

Digital Certificate Lifecycle

Issuance → Renewal → Revocation

- Issued after identity verification.
- Requires periodic renewal to maintain validity.
- Revoked if compromised or misused.

Conditions and Specifications for Making Electronic Signature/Stamp Roles and Stakeholders

The electronic signature/stamp shall be deemed valid, if the following controls and conditions are adhered to:

1. The electronic signature/stamp shall be associated with a digital certificate issued by the Center or by a certification service provider licensed by the Authority.
2. The digital certificate associated with the electronic signature/stamp shall be valid at the time the signature/stamp is made.
3. The identity data of the holder of the electronic signature/stamp shall be compatible with the digital certificate.
4. If the electronic signature/stamp is made in conjunction with an electronic data system at the signatory, the logical and technical connection between the electronic signature/stamp system and the electronic data system shall be sound, and thus free of technical defects that may affect the validity and sending of the signature/stamp.
5. The minimum technical and administrative structure, as well as the relevant resources, shall be available to ensure the reliability of electronic signature/stamp procedures according to the technical conditions contained in the digital certification procedures of the Center or the certification service provider.
6. The holder of the electronic signature/stamp shall adhere to all conditions contained in the digital certification procedures of the Center or the certification service provider regarding making the electronic signature/stamp, in a manner that does not contradict with the relevant laws and regulations

The electronic signature/stamp associated with a digital certificate shall consist of the following technical elements as a minimum:

1. The issuer of the digital certificate, so that the certificate contains all the information indicating the Center or certification service provider, and its electronic signature.
2. The type, scope of work, and serial number of the electronic signature/stamp.
3. The date and validity period of the electronic signature/stamp.
4. Identity data of the holder of the electronic signature/stamp and the scope of use of the signature/stamp.

Electronic Signature/Stamp Verification Procedures

The party that relies on the electronic signature/stamp of another party shall exercise due care to verify the authenticity of the signature/stamp, using data to verify the electronic signature/stamp, in accordance with the following procedures:

1. Verifying the origin of the digital certificate associated with the electronic signature/stamp, and that it is issued by the Center or the certification service provider, in accordance with the provisions of these Regulations, and verifying its validity, and that it is not canceled or suspended.
2. Ensuring that the data attached to the electronic signature/stamp matches the data of the signature/stamp holder based on the digital certificate issued thereto.
3. Verifying that there are no alert or warning messages indicating the possibility of a defect in the automatic matching of the electronic signature/stamp, or any other defect related to the origin or content, within the incoming message and signature/stamp

The electronic signature/stamp shall be deemed null and void and shall not determine the identity of the originator of the electronic record if one of its constituent elements is defective in accordance with the provisions of these Regulations [1], [4].

Digital Certification Service by DGA's licensees

Digital certification services include [5]:

1. Digital certificate issuance services
 - a. They allow the licensee to provide services for issuing electronic signature and stamp certificates to other licensees determined by the DGA to enable them to provide other digital certification services to the end beneficiary
 - b. Digital certificate issuance services include the following:
 - a. Issuance of an electronic signature certificate: The process of issuing a digital certificate for the purpose of using it in electronic signature processes.
 - b. Issuance of an electronic stamp certificate: The process of issuing a digital certificate for the purpose of using it in electronic stamp processes.
 - c. Issuance of a website certificate: Issuing a digital certificate for the purpose of using it in website certification processes.
 - c. Requirements for providing digital certificate issuance services:
 - a. Adherence to all procedures and conditions set forth in these Regulations and the Law and the instructions issued by the DGA in this regard.

- b. Association with the NICr's Saudi Root Center, or as determined by the DGA, in agreement with the NIC, in this regard
 - d. The licensee to provide services for issuing digital certificates for electronic signatures and stamps shall have the right to provide some or all other digital certification services to the end beneficiary as determined by the DGA in this regard.
- 2. Electronic signature and electronic and time stamp Services:
 - a. They allow the licensee to provide electronic signature, electronic or timestamp services to the end beneficiary.
 - b. **Electronic signature and electronic and time stamp services** include:
 - a. Electronic signature creation: A service that allows the creation of electronic signatures, using a device to create them based on an electronic signature certificate.
 - b. Electronic signature verification: A service through which the authenticity and integrity of electronic signatures are verified.
 - c. Electronic signature preservation: The process of preserving electronic signatures in a way that ensures that they are not tampered with, and they can be retrieved and verified later.
 - d. Electronic signature creation device management: A program or device to manage and create electronic signatures.
 - e. Electronic stamp creation: Creating electronic stamps using a device to create them based on an electronic stamp certificate.
 - f. Electronic stamp verification: A service through which the authenticity and integrity of electronic stamps are verified.
 - g. Electronic stamp preservation: The process of preserving electronic stamps in a way that ensures that they are not tampered with, and they can be retrieved and verified later.
 - h. Electronic stamp creation device management: A program or device to manage and create electronic signatures.
 - i. Electronic time stamp creation: The process of creating data in electronic form to prove the time at which an electronic signature or stamp process was made.

Risks, Challenges & Security Measures

Digital Signature Security Risks

- Cybersecurity Threats – Man-in-the-middle (MITM) attacks intercepting signatures.
- Private Key Theft – Compromised credentials leading to identity fraud.
- Regulatory Non-Compliance – Using non-accredited CSPs invalidates signatures.

Security Best Practices

- Comply with all NCA cybersecurity controls issued.
- End-to-End Encryption (E2EE) to protect documents.
- Biometric authentication for additional signer verification.
- Timestamping to validate signature authenticity.
- Blockchain Integration for tamper-proof records.

Case Studies

Government & E-Governance: Digital Birth Certificates

- A government issues e-birth certificates with official digital stamps.
Outcome: Reduced processing time from weeks to days, eliminating forgery.

Banking & Finance: Digital Loan Approvals in Banks

- Banks adopt digital signatures for mortgage agreements.
Outcome: Faster approvals, legally binding contracts, and fraud prevention.

Real Estate & Property Transactions: E-Signed Rental Agreements

- Real estate agencies use digital signatures for property lease contracts.
Outcome: Reduced paperwork, secure transactions, and legally recognized agreements.

Future Trends in Digital Signatures

Upcoming Innovations

- Blockchain-based Digital Signatures for immutable contracts
- AI-powered Fraud Detection in signature verification.
- Quantum-Resistant Encryption for next-generation security.
- Biometric & Smartcard Authentication replacing passwords.

Regulatory Evolution

- Governments are adopting eIDAS-equivalent frameworks for global trade compliance.

References:

- [1] "Electronic Signature Laws & Regulations - Kingdom of Saudi Arabia." Accessed: Apr. 21, 2025. [Online]. Available: <https://helpx.adobe.com/content/help/en/legal/esignatures/regulations/ksa.html>
- [2] "GoodSign eSignatures for you and your team." Accessed: Apr. 21, 2025. [Online]. Available: <https://goodsign.io>
- [3] "معاينة أصل النظام." Accessed: Apr. 21, 2025. [Online]. Available: <https://laws.boe.gov.sa/BoeLaws/Laws/Viewer/9ae1fb66-5a60-40a3-af83-9470c8215247?lawId=99d72691-f7ed-4b33-a4bf-a9a700f2ed16>
- [4] "Electronic signature legality in Saudi Arabia | Zoho Sign," Zoho. Accessed: Apr. 21, 2025. [Online]. Available: <https://www.zoho.com/sign/electronic-signatures/legality/saudi-arabia.html>
- [5] "Digital Certification Services Statistics." Accessed: Apr. 21, 2025. [Online]. Available: <https://sdaia.gov.sa/en/Services/Pages/DigitalCertification.aspx>